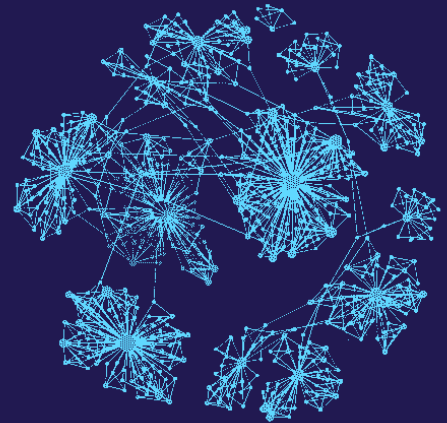

BSI Grundschutz++ Kernel

Stand der Technik

S. Dierkes



Inhaltsverzeichnis

Einleitung BSI Grundschutz++	40
Disclaimer	40
Lizenz	40
BSI Stand der Technik Kernel	41
Praktik: ARCH Architektur	42
Praktik: BER Berechtigung	43
Praktik: BES Beschaffungsmanagement	44
Praktik: DET Detektion	45
Praktik: DLS Dienstleistersteuerung	46
Praktik: DEV Entwicklung	47
Praktik: GEB Gebäudemanagement	48
Praktik: ASST Informationen und Assets	49
Praktik: KONF Konfiguration	50
Praktik: NOT Notfallplanung	51
Praktik: PERS Personal	52
Praktik: SENS Sensibilisierung	53
Praktik: REA Sicherheitsvorfallsbehandlung	54
Praktik: TEST Änderungen und Tests	55
Control: ARCH.1.1 - Verfahren und Regelungen	56
Control: ARCH.1.1.1 - Dokumentation	57
Control: ARCH.1.1.2 - Zuweisung der Aufgaben	58
Control: ARCH.1.1.3 - Bekanntgabe	59
Control: ARCH.1.2 - Regelmäßige Überprüfung	60

Control: ARCH.2.1 - Netzsegmente	61
Control: ARCH.2.2 - Einschränkung von Verbindungen zwischen Segmenten	62
Control: ARCH.2.2.1 - Externe Netzanschlüsse	64
Control: ARCH.2.2.2 - Gastnetz	65
Control: ARCH.2.2.3 - Segmentierung von Servern und Clients	66
Control: ARCH.2.2.4 - VoIP-Netz	67
Control: ARCH.2.2.5 - OT-Systeme	68
Control: ARCH.2.2.6 - Demilitarisierte Zone	69
Control: ARCH.2.2.7 - Management-Netz	70
Control: ARCH.2.2.8 - Segmentierung von Test und Betrieb	71
Control: ARCH.2.2.9 - Segmentierung von IPv4 und IPv6	72
Control: ARCH.2.2.10 - Drucker-Netz	73
Control: ARCH.2.2.11 - Physische Segmentierung	74
Control: ARCH.2.2.12 - Sprungserver	75
Control: ARCH.2.3 - Mikrosegmentierung	76
Control: ARCH.2.4 - Inventar der Netze	77
Control: ARCH.2.5 - Netzplan	79
Control: ARCH.2.6 - Topologieüberwachung	80
Control: ARCH.3.1 - Netzabdeckung	81
Control: ARCH.3.2 - Einschränkung in Sicherheitsbereichen	82
Control: ARCH.3.3 - SSIDs	83
Control: ARCH.3.4 - Verschlüsselte Netzanbindung	84
Control: ARCH.4.1 - Netzzugangskontrolle	85

Control: ARCH.4.1.1 - Dynamische Netzzugangskontrolle	87
Control: ARCH.4.1.2 - Quarantäne	88
Control: ARCH.4.2 - Autorisiertes Routing	89
Control: ARCH.4.3 - Authentifizierung von Routingprotokollen	91
Control: ARCH.5.1 - Einschränkung und Inspektion von Verbindungen	92
Control: ARCH.5.1.1 - Blockieren anfälliger Netzprotokolle	94
Control: ARCH.5.1.2 - Netzbasierte Angriffe	95
Control: ARCH.5.1.3 - TCP-basierte Angriffe	96
Control: ARCH.5.1.4 - UDP-basierte Angriffe	97
Control: ARCH.5.1.5 - Deaktivierung von Split Tunneling	98
Control: ARCH.5.1.6 - Blockieren direkter Management-Verbindungen	99
Control: ARCH.5.1.7 - Edge-Routing	100
Control: ARCH.5.1.8 - Inspektion verschlüsselter Verbindungen	101
Control: ARCH.5.1.9 - Filterung von DNS	102
Control: ARCH.5.1.10 - Webfilterung	103
Control: ARCH.5.1.10.1 - Bekannte schädliche Inhalte	104
Control: ARCH.5.1.10.2 - Bekannte illegale Inhalte	105
Control: ARCH.5.1.10.3 - Speicherdienste	106
Control: ARCH.5.1.11 - P-A-P-Struktur	107
Control: ARCH.5.1.12 - Software-definierte Verbindungen	108
Control: ARCH.5.1.13 - Produktdiversität	109
Control: ARCH.5.2 - Blockieren direkter öffentlicher Verbindungen	110
Control: ARCH.6.1 - Kontrollierte Verbindungsführung	111
Control: ARCH.6.2 - Verschlüsselung von Weiterverkehrsverbindungen	112

Control: ARCH.7.1 - Dedizierte Hostsysteme für Server	113
Control: ARCH.7.2 - Dedizierte Hardware	114
Control: ARCH.7.3 - Entwicklungs- und Testumgebungen	115
Control: ARCH.8.1 - Redundanz im Kernnetz	116
Control: ARCH.8.2 - Redundante TK-Anbindung	117
Control: ARCH.8.3 - Redundante Server	118
Control: ARCH.9.1 - Dimensionierung der Netzanbindung	119
Control: ARCH.9.2 - Lastverteilung	120
Control: ARCH.9.3 - Automatische Skalierung	121
Control: ARCH.9.4 - Content Delivery Network	123
Control: ARCH.9.5 - Schutz gegen volumetrische DoS-Angriffe	124
Control: BER.1.1 - Verfahren und Regelungen	125
Control: BER.1.1.1 - Dokumentation	126
Control: BER.1.1.2 - Zuweisung der Aufgaben	127
Control: BER.1.1.3 - Bekanntgabe	128
Control: BER.1.2 - Regelmäßige Überprüfung	129
Control: BER.1.3 - Inventar Authentifizierungs- und Autorisierungssysteme	130
Control: BER.1.4 - Inventar der Berechtigungen	132
Control: BER.2.1 - Person-Identität	133
Control: BER.2.2 - Einschränkung	134
Control: BER.2.3 - Stammdatenprüfung	135
Control: BER.2.4 - Protokollierung von Stammdatenänderungen	136
Control: BER.2.5 - Deaktivierung bei Weggang	137

Control: BER.2.6 - Löschen nach Fristablauf	138
Control: BER.3.1 - Zentrales Management	139
Control: BER.3.2 - Einschränkung des Managements	140
Control: BER.3.3 - Protokollierung von Änderungen	141
Control: BER.3.4 - Identität-Zugangskonto	142
Control: BER.3.5 - Privilegierte Zugangskonten	143
Control: BER.3.6 - Single-Sign-On	144
Control: BER.3.7 - Hinweise bei Anmeldefehlern	145
Control: BER.3.8 - Ereignisgesteuerte Deaktivierung	146
Control: BER.3.9 - Anmeldeversuchsgrenze am System	147
Control: BER.3.10 - Anmeldeversuchsgrenze an der Anwendung	148
Control: BER.3.11 - Systemsperre bei Inaktivität	149
Control: BER.3.12 - Sperre der Anwendung bei Inaktivität	150
Control: BER.3.13 - Zugang löschen nach Fristablauf	151
Control: BER.3.14 - Zugang nur durch zwei Personen	152
Control: BER.3.15 - Keine Gruppenkonten	153
Control: BER.3.16 - Gruppenkonten - MFA	154
Control: BER.3.17 - Gruppenkonten - Wechsel dokumentieren	155
Control: BER.3.18 - Gruppenkonten - Passwortwechsel bei Weggang	156
Control: BER.3.19 - Zwischenspeicherung von Zugangsdaten	157
Control: BER.3.20 - Dienstkonten	158
Control: BER.3.21 - Notfallzugang	159
Control: BER.3.22 - Notfallzugang Verzeichnisdienst	160
Control: BER.4.1 - Identitätsüberprüfung	161

Control: BER.5.1 - Prinzip der geringsten Berechtigungen	162
Control: BER.5.1.1 - Rollenbasierte Berechtigung	164
Control: BER.5.1.2 - JIT-/JEA-Berechtigungen	165
Control: BER.5.2 - Begründung von Berechtigungen	166
Control: BER.5.3 - Überprüfung von Berechtigungen	167
Control: BER.5.3.1 - Überprüfung tatsächlicher Berechtigungen	169
Control: BER.5.4 - Kompromittierte Berechtigungsmittel	170
Control: BER.5.5 - Systemfunktionen ohne Authentifizierung	171
Control: BER.5.6 - Anwendungsfunktionen ohne Authentifizierung	172
Control: BER.5.7 - IT-System-Zugangskonto	173
Control: BER.5.8 - Entzug von Berechtigungen	174
Control: BER.6.1 - Passwortmanager	175
Control: BER.6.2 - Vorkonfigurierte Authentisierungsmittel	176
Control: BER.6.3 - Deaktivierung einfacher Biometrie	177
Control: BER.6.4 - Mehr-Faktor-Authentisierung am Perimeter	178
Control: BER.6.5 - Mehr-Faktor-Authentisierung für weitreichende Berechtigungen	179
Control: BER.6.6 - Blockieren von Passwort Recycling	180
Control: BER.6.7 - Trivialpasswörter	182
Control: BER.6.8 - Kriterien für die Qualität von Passwörtern	183
Control: BER.6.9 - Anlassbezogene Passwortwechsel	184
Control: BER.6.10 - Monitoring von Zugangsdaten	185
Control: BER.7.1 - Etablierte Algorithmen bei der Schlüsselerzeugung	186
Control: BER.7.2 - Schlüssellänge	187

Control: BER.7.3 - Verzeichnis öffentlicher Schlüssel	188
Control: BER.7.4 - Erzeugung auf sicheren IT-Systemen	189
Control: BER.7.5 - Kriterien für die Qualität von Zufallszahlen	190
Control: BER.7.6 - Etablierte Algorithmen beim Transport	191
Control: BER.7.7 - Kein Transport privater Schlüssel	192
Control: BER.7.8 - Etablierte Algorithmen bei der Schlüsselnutzung	193
Control: BER.7.9 - Zweckbindung	194
Control: BER.7.10 - Abgelaufene Schlüssel	195
Control: BER.7.11 - Integrität	196
Control: BER.7.12 - Authentizität	197
Control: BER.7.13 - Gültigkeit	198
Control: BER.7.14 - Schlüssel vor Ablauf prüfen	199
Control: BER.7.15 - Vorgehensweise nach Nutzung	200
Control: BER.7.16 - Vorgaben für die Schlüsselbeglaubigung	201
Control: BER.7.16.1 - Zertifizierungsstelle	202
Control: BER.7.16.2 - Beglaubigung	203
Control: BER.7.16.3 - Erneuerung	205
Control: BER.7.16.4 - Revocation	206
Control: BER.7.16.5 - Beglaubigungsstatus	208
Control: BER.7.16.6 - Revocationstatus	209
Control: BES.1.1 - Verfahren und Regelungen	210
Control: BES.1.1.1 - Dokumentation	211
Control: BES.1.1.2 - Zuweisung der Aufgaben	212
Control: BES.1.1.3 - Bekanntgabe	213

Control: BES.1.2 - Regelmäßige Überprüfung	214
Control: BES.1.3 - Lieferanten- und Dienstleisterverzeichnis	215
Control: BES.1.3.1 - Gesamte Lieferkette	216
Control: BES.1.4 - Outsourcing-Strategie	217
Control: BES.1.4.1 - Freigabe der Strategie	219
Control: BES.1.5 - Autorisierung des Bereitstellungsmodells	220
Control: BES.1.6 - Dokumentation des Bereitstellungsmodells	221
Control: BES.1.7 - Vereinbarung der geteilten Verantwortung	222
Control: BES.2.1 - Erfassung des Bedarfes	223
Control: BES.2.1.1 - Verwendungszweck	224
Control: BES.2.1.2 - Geschäftsprozessprofile	225
Control: BES.2.1.3 - Systemvoraussetzungen	226
Control: BES.2.1.4 - Kompatibilität	227
Control: BES.2.1.4.1 - Kompatibilität der Schnittstellen	228
Control: BES.2.1.4.2 - Kompatibilität der Netzanbindung	229
Control: BES.2.1.4.3 - Kompatibilität des Administrationsmodells	231
Control: BES.2.1.4.4 - Kompatibilität des Datenmanagementmodells	233
Control: BES.2.1.5 - Lizenzierung	235
Control: BES.2.1.6 - Support- und Wartungsverträge	236
Control: BES.2.2 - Dokumentation des Rechtsraums und der Datenlo- kation	237
Control: BES.2.3 - Vereinbarung des Rechtsraums und der Datenloka- tion	238
Control: BES.2.4 - Anhörung Nutzender	239

Control: BES.2.5 - Anhörung Adminstrierender	240
Control: BES.2.6 - Outsourcing auf Grundlage der Geschäftsprozess-profile	241
Control: BES.3.1 - Klassifizierung von Lieferantenbeziehungen	242
Control: BES.3.2 - Auswahlkriterien	243
Control: BES.3.2.1 - Zertifizierte Lieferanten	244
Control: BES.3.2.2 - Quellendiversifikation	245
Control: BES.3.3 - Unzuverlässige Lieferanten	246
Control: BES.4.1 - Klassifizierung von Beschaffungsvorhaben	247
Control: BES.4.2 - Dokumentation der Beschaffungskriterien	248
Control: BES.4.3 - Beschaffung anhand der Kriterien	250
Control: BES.4.4 - Vertragsvorlage für Outsourcing	251
Control: BES.4.5 - Security by Design	252
Control: BES.4.5.1 - Entwicklung nach einem Sicherheitslebenszyklus	253
Control: BES.4.5.2 - Mandantentrennung	254
Control: BES.4.6 - Security by Default	255
Control: BES.4.6.1 - Authentifizierung des Kunden	256
Control: BES.4.6.2 - Verschlüsselung durch den Anbieter	257
Control: BES.4.6.3 - Manipulationsschutz	258
Control: BES.4.7 - ISMS beim Dienstleister	259
Control: BES.4.8 - Konformitätsnachweise	260
Control: BES.4.8.1 - Zertifizierung	261
Control: BES.4.8.2 - Cloud-Konformität	262
Control: BES.4.8.3 - IT-Grundschutz-Analyse der Infrastruktur	263

Control: BES.4.8.4 - Offenlegung der Risikoanalyse	264
Control: BES.4.9 - Sicherheitsüberprüfung (extern)	265
Control: BES.5.1 - Kompetenzen	266
Control: BES.5.2 - Service Level Agreement	267
Control: BES.5.3 - Compliance-Verpflichtungen	268
Control: BES.5.4 - Informationssicherheitskontrollmechanismen	269
Control: BES.5.5 - Nutzungsregelungen	270
Control: BES.5.5.1 - Datenlokationen	271
Control: BES.5.5.2 - Autorisierung der Zugriffsberechtigung	272
Control: BES.5.6 - Vergabe von Unteraufträgen	273
Control: BES.5.6.1 - Weitergabe der Beschaffungskriterien	275
Control: BES.5.6.2 - Autorisierung von Unterauftragnehmern	276
Control: BES.5.6.3 - Nachverfolgbarkeit der Lieferkette	277
Control: BES.5.7 - Schulung	278
Control: BES.5.8 - Rechte für geistiges Eigentum	279
Control: BES.5.9 - Umgang mit Änderungen	280
Control: BES.5.9.1 - Autorisierung von Änderungen	281
Control: BES.5.10 - Behandlung von Vorfällen	283
Control: BES.5.10.1 - Erreichbarkeit über Meldewege	284
Control: BES.5.10.2 - Melden von Vorfällen	285
Control: BES.5.10.3 - Schwachstellenbehebung	286
Control: BES.5.10.3.1 - Schwachstellenmeldeprozess	287
Control: BES.5.10.4 - Konfliktlösungsprozesse	288
Control: BES.5.10.5 - Konsequenzen bei Verstößen	290

Control: BES.5.11 - Recht auf Audit	291
Control: BES.5.12 - Informationspflichten	292
Control: BES.5.13 - Bereitstellung von Datensicherungen	293
Control: BES.5.13.1 - Datenbereitstellung	294
Control: BES.5.14 - Löschregeln	295
Control: BES.6.1 - Entziehung der Zugangsberechtigungen	296
Control: BES.6.2 - Löschung von Daten	297
Control: BES.6.2.1 - Lösungsverfahren	298
Control: BES.6.3 - Übertragbarkeit von Daten	299
Control: BES.6.4 - Übertragung von Supportdienstleistungen	300
Control: BES.6.5 - Behandlung aufzubewahrender Aufzeichnungen	302
Control: BES.6.6 - Rückgewähr von Assets	303
Control: BES.7.1 - Eingangskontrolle	305
Control: BES.7.1.1 - Test der Kompatibilität	306
Control: BES.7.1.2 - Netzcheck	307
Control: BES.7.2 - Prozesse vor Netzanbindung	309
Control: BES.7.3 - Anhörung Prozessbeteiligter	311
Control: BES.7.4 - Vollständigkeit der Unterlagen	312
Control: BES.7.4.1 - Beschreibung der Sicherheitsarchitektur	314
Control: BES.7.4.2 - Beschreibung von Sicherheitsmechanismen	316
Control: BES.7.4.3 - Empfohlene Konfiguration	317
Control: BES.7.4.4 - Dokumentation der Komponenten	319
Control: BES.7.4.4.1 - Software Bill of Materials (SBOM)	320
Control: BES.7.4.5 - Netzverbindungen ab Werk	321

Control: BES.7.4.6 - Shared Responsibility	322
Control: BES.7.4.7 - Organisatorische Schnittstellen	323
Control: BES.7.4.8 - Technische Schnittstellen	324
Control: BES.7.4.9 - Auslagerungsregister	325
Control: BES.7.4.10 - Serviceprofil	326
Control: BES.7.4.11 - Dokumentierte Mandantentrennung	327
Control: BES.7.4.12 - Software Bill of Materials (SBOM) - Cloud	329
Control: BES.8.1 - Bereithaltung alternativer Lieferanten	330
Control: BES.8.2 - Verfahren zur Übertragung von Geschäftsprozessen	332
Control: BES.8.3 - Ressourcensouveränität	333
Control: BES.8.4 - Individuelle Implementierung kritischer Komponenten	334
Control: BES.8.5 - Treuhand	336
Control: DET.1.1 - Verfahren und Regelungen	337
Control: DET.1.1.1 - Dokumentation	338
Control: DET.1.1.2 - Zuweisung der Aufgaben	339
Control: DET.1.1.3 - Bekanntgabe	340
Control: DET.1.2 - Regelmäßige Überprüfung	341
Control: DET.2.1 - Meldeverfahren	342
Control: DET.2.1.1 - Sofortmaßnahmen Nutzender	343
Control: DET.2.1.2 - Meldeformulare	344
Control: DET.2.1.3 - Rückmeldungen	345
Control: DET.2.2 - Security Operations Center	346
Control: DET.2.3 - Ständiger Bereitschaftsdienst	347

Control: DET.3.1 - Protokollierung sicherheitsrelevanter Ereignisse	348
Control: DET.3.1.1 - Authentifizierungen	349
Control: DET.3.1.2 - Ausgeführte Kommandozeilenbefehle	350
Control: DET.3.1.3 - Anbindung von Peripheriegeräten	351
Control: DET.3.1.4 - Systemfehler	352
Control: DET.3.1.5 - Störungen der Netzerreichbarkeit	353
Control: DET.3.1.6 - Systemspezifische Ereignisse	354
Control: DET.3.1.7 - Was, Wann, Wo	355
Control: DET.3.1.8 - Privilegierte Ereignisse	356
Control: DET.3.1.9 - Fehler der Anwendung	357
Control: DET.3.1.10 - Nutzungsstatistik	358
Control: DET.3.1.11 - Anwendungsspezifische Ereignisse	359
Control: DET.3.1.12 - Datenverarbeitungen	360
Control: DET.3.1.13 - Integration von Cloud-Diensten	361
Control: DET.3.2 - Filterung nicht benötigter Inhalte	362
Control: DET.3.3 - Speicherkapazität	363
Control: DET.3.4 - Revisionssicherheit	364
Control: DET.3.5 - Unbestreitbarkeit	365
Control: DET.4.1 - Überwachung der Protokollierung	366
Control: DET.4.2 - Automatische Angriffserkennung	367
Control: DET.4.3 - Überwachung der Angriffserkennung	368
Control: DET.4.4 - Änderungen an Sicherheitsrichtlinien	369
Control: DET.4.5 - Unerwünschte Datenabflüsse	370
Control: DET.4.6 - Anomale Nutzung der Anwendung	371

Control: DET.4.6.1 - Verhaltensanalyse von Zugangskonten	372
Control: DET.4.7 - Auslaufen von Domains	373
Control: DET.4.8 - Ausstellung neuer HTTPS-Zertifikate	374
Control: DET.4.9 - Manipulations-Checkup	375
Control: DET.4.10 - Host-basierte Köder	376
Control: DET.4.11 - Anomalien in Netzen und am Perimeter	377
Control: DET.4.11.1 - Authentifizierungsversuche an externen Schnittstellen	378
Control: DET.4.11.2 - Netzwerk-Honeypots	380
Control: DET.4.11.3 - Netzverkehrsfluss	381
Control: DET.4.12 - Monitoring der Netzverfügbarkeit	382
Control: DET.4.12.1 - Auslastung des Netzes	383
Control: DET.4.13 - Verfügbarkeit des Hostsystems	384
Control: DET.4.14 - Verfügbarkeit der Anwendung	385
Control: DET.4.15 - Ressourcenauslastung von Hostsystemen	386
Control: DET.4.16 - Ressourcenauslastung der Server-Dienste	387
Control: DET.4.17 - Anwendungsbasiertes Kapazitätsmanagement	388
Control: DET.4.18 - Öffentliche Blocklisten	389
Control: DET.4.19 - Unautorisierte Sendeanlagen	390
Control: DET.5.1 - Zeitnahes Schwachstellenmanagement	391
Control: DET.5.1.1 - Risikobasierte Priorisierung	392
Control: DET.5.2 - Schwachstellenregister	393
Control: DET.5.3 - Schwachstellenscans	394
Control: DET.5.3.1 - Autorisierung kritischer Scans	395

Control: DET.5.3.2 - Korrelation komplexer Angriffswege	396
Control: DET.5.3.3 - Historische Analyse	397
Control: DET.5.4 - Regelmäßige Penetrationstests	398
Control: DET.5.5 - Red Teaming	400
Control: DET.5.6 - Threat Hunting	401
Control: DET.5.7 - Analyse verdeckter Kanäle	402
Control: DET.5.8 - Bedrohungsanalyse	403
Control: DET.5.8.1 - Auswertung öffentlicher Quellen	404
Control: DET.5.8.1.1 - Unautorisierte Publikation	405
Control: DET.5.9 - Externe Schwachstellenmeldungen	406
Control: DET.5.9.1 - Bonusprogramm	408
Control: DET.5.10 - Zeitnahe Patchmanagement	409
Control: DET.5.10.1 - Autorisierte Bezugsquellen	410
Control: DET.5.10.2 - Automatisierte Überwachung von Systemupdates	411
Control: DET.5.10.3 - Automatisierte Überwachung von Anwendungsupdates	412
Control: DET.5.10.4 - Integritätsprüfung von Patches	413
Control: DET.5.10.5 - Test gemäß Änderungsmanagement	414
Control: DET.6.1 - Beurteilung von Ereignissen	415
Control: DET.6.1.1 - Automatisierte Feststellung	416
Control: DET.6.1.2 - Automatische Alarmierung	417
Control: DET.6.1.3 - Dokumentation von Ergebnissen	418
Control: DET.6.2 - Beurteilung von Eingängen	419
Control: DET.6.2.1 - Dynamische Sandbox-Analyse	420

Control: DET.6.2.2 - Datenträgerschleuse	421
Control: DLS.1.1 - Verfahren und Regelungen	422
Control: DLS.1.1.1 - Dokumentation	423
Control: DLS.1.1.2 - Zuweisung der Aufgaben	424
Control: DLS.1.1.3 - Bekanntgabe	425
Control: DLS.1.2 - Regelmäßige Überprüfung	426
Control: DLS.2.1 - Mehr-Faktor-Authentifizierung	427
Control: DLS.2.2 - Transportverschlüsselung	428
Control: DLS.2.3 - Vollverschlüsselung	429
Control: DLS.3.1 - Einhaltung der Sicherheitsvorgaben	430
Control: DLS.3.1.1 - Audit oder Zertifikat	431
Control: DLS.3.2 - Checkup	432
Control: DLS.3.3 - Strategie-Check	434
Control: DLS.3.4 - Anhörung	435
Control: DLS.3.5 - Blockierung unzuverlässiger Dienstleister	436
Control: DLS.3.6 - Portabilität	437
Control: DLS.4.1 - Dekommissionierung	438
Control: DLS.4.1.1 - Unabhängigkeit	440
Control: DLS.4.1.2 - Berechtigungen deaktivieren	442
Control: DEV.1.1 - Verfahren und Regelungen	443
Control: DEV.1.1.1 - Dokumentation	444
Control: DEV.1.1.2 - Zuweisung der Aufgaben	445
Control: DEV.1.1.3 - Bekanntgabe	446
Control: DEV.1.2 - Regelmäßige Überprüfung	447

Control: DEV.2.1 - Security by Design Architektur	448
Control: DEV.2.2 - Dokumentation der (Software-)Architektur	449
Control: DEV.2.3 - Ausführbarkeit mit minimalen Rechten	451
Control: DEV.2.4 - Einschränkung Zugriffs auf Quellcode	452
Control: DEV.2.5 - Einschränkung des Zugriffs auf Zugangsdaten	453
Control: DEV.2.6 - Widerstandsfähigkeit gegen gängige Angriffsmuster	454
Control: DEV.2.6.1 - Eingabevalidierung	455
Control: DEV.2.6.2 - Ausgabekodierung	456
Control: DEV.3.1 - Replay-Angriffe	457
Control: DEV.3.2 - Routinen zur Fehlerbehandlung	458
Control: DEV.3.3 - Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen	459
Control: DEV.3.4 - Passwort-Hashing	460
Control: DEV.4.1 - Nutzerinformation bei kritischen Ereignissen	461
Control: DEV.4.2 - Bibliotheksquellen	462
Control: DEV.4.3 - Softwarebestandteile (SBOM)	463
Control: DEV.4.4 - Integrität externer Softwarebibliotheken	464
Control: DEV.4.5 - Updates externer Softwarebibliotheken	465
Control: DEV.4.6 - Compileroptionen	466
Control: DEV.4.7 - Deterministischer Binärcode	467
Control: DEV.4.8 - Default-Zugangsdaten	468
Control: DEV.4.9 - Voreinstellungen nach dem Prinzip "Security by Default"	469
Control: DEV.4.10 - Protokollierung von Codeänderungen	470

Control: DEV.4.11 - Test bei Änderungen am Quellcode	472
Control: DEV.5.1 - Verankerung des Zeitraums für Updates	474
Control: DEV.5.2 - Information über Zeitraum für Updates	475
Control: DEV.5.3 - Integritätsprüfung	476
Control: DEV.6.1 - Freigabe nach Änderungen und Tests	477
Control: DEV.7.1 - Sichere Bereitstellung	478
Control: DEV.7.2 - Zertifikatsmonitoring	479
Control: GEB.1.1 - Verfahren und Regelungen	480
Control: GEB.1.1.1 - Dokumentation	481
Control: GEB.1.1.2 - Zuweisung der Aufgaben	482
Control: GEB.1.1.3 - Bekanntgabe	483
Control: GEB.1.2 - Regelmäßige Überprüfung	484
Control: GEB.1.3 - Autorisierung von Standorten	485
Control: GEB.1.3.1 - Abnahme von Standorten	487
Control: GEB.1.4 - Exponierte Bereiche	488
Control: GEB.1.5 - Strukturpläne	489
Control: GEB.2.1 - Installation von Perimetern	490
Control: GEB.2.2 - Dokumentation öffentlicher Bereiche	491
Control: GEB.2.3 - Erkundung aus dem öffentlichen Raum	492
Control: GEB.2.4 - Elektromagnetische Abschirmung	493
Control: GEB.3.1 - Überwachung von Zutrittspunkten	494
Control: GEB.3.1.1 - Videoüberwachung	495
Control: GEB.3.1.2 - Überprüfung mitgeführter Gegenstände	496
Control: GEB.3.2 - Anmelde- und Empfangsbereiche	498

Control: GEB.3.3 - Authentifizierung vor Zutritt	499
Control: GEB.3.3.1 - Zugangskontrollanlage	501
Control: GEB.3.3.2 - Dokumentation von Zutritten	503
Control: GEB.3.3.3 - Besucheranmeldung	504
Control: GEB.3.4 - Berechtigungsmarkierung	506
Control: GEB.3.5 - Einbruchhemmung	507
Control: GEB.3.6 - Einbruchmeldeanlagen	508
Control: GEB.3.7 - Kontrolle der Zutrittskontrolle	509
Control: GEB.4.1 - Einrichtung	510
Control: GEB.4.2 - Gesonderte Autorisierung	511
Control: GEB.4.3 - Schleusen	512
Control: GEB.4.4 - Vereinzelungsanlage	513
Control: GEB.5.1 - Clean Desk	514
Control: GEB.5.2 - Screen Lock	515
Control: GEB.5.3 - Lieferzugang	516
Control: GEB.5.4 - Schutz gegen Manipulation	517
Control: GEB.5.5 - Physische Mikrosegmentierung	518
Control: GEB.6.1 - Zugang zu Ausgabesystemen	519
Control: GEB.6.2 - Geschützte Aufstellung	520
Control: GEB.6.2.1 - Hostsysteme	521
Control: GEB.6.3 - Netzkomponenten	522
Control: GEB.6.4 - Normgerechte Rechenzentren	523
Control: GEB.7.1 - Schlüsselbeauftragte	525
Control: GEB.7.2 - Verwahrung von Schlüsseln	526

Control: GEB.7.3 - Schlüsselaudit	527
Control: GEB.8.1 - Gesonderte Aufbewahrung	528
Control: GEB.8.1.1 - Archiv	529
Control: GEB.8.2 - Staub und Schmutz	530
Control: GEB.8.3 - Schutz der Datenträger vor Brandschäden	531
Control: GEB.8.4 - Überwachung schonender Klimatisierung	532
Control: GEB.9.1 - Normgerechte Stromversorgung	533
Control: GEB.9.1.1 - Vorausschauende Lastanalyse	534
Control: GEB.9.1.2 - Dedizierte Elektrounterverteilung	535
Control: GEB.9.1.3 - Redundante Stromversorgung	536
Control: GEB.9.1.4 - Langanhaltende Sekundärversorgung	537
Control: GEB.9.2 - Lasttest	539
Control: GEB.9.3 - Notaus	540
Control: GEB.9.4 - Überspannungsschutz	541
Control: GEB.9.5 - Strukturierte Datenverkabelung	543
Control: GEB.9.5.1 - Physisch geschützte Verlegung	544
Control: GEB.9.6 - Zugang zu Räumen für technische Infrastruktur	545
Control: GEB.9.7 - Zweckentfremdung	546
Control: GEB.10.1 - Klimatisierung	547
Control: GEB.10.1.1 - Luftstrom-Analyse	549
Control: GEB.10.1.2 - Klimamessung	551
Control: GEB.10.1.3 - Redundante Klimatisierung	552
Control: GEB.10.2 - Brandschutz	553
Control: GEB.10.2.1 - Baulicher Brandschutz	554

Control: GEB.10.2.2 - Brandabschnitte	555
Control: GEB.10.2.3 - Rauchdichtheit	556
Control: GEB.10.2.4 - Brandwiderstandsklassen	557
Control: GEB.10.2.5 - Vermeidung von Brandlasten	559
Control: GEB.10.2.6 - Brandmeldeanlagen	560
Control: GEB.10.2.7 - Brandunterdrückung	561
Control: GEB.10.2.8 - Brandschutzprüfung	562
Control: GEB.10.3 - Wasserschutz	563
Control: GEB.10.3.1 - Doppelter baulicher Wasserschutz	564
Control: GEB.10.3.2 - Leckagesensor	565
Control: GEB.10.4 - Blitzschutzeinrichtungen	566
Control: GEB.10.4.1 - Niederohmigkeit	567
Control: GEB.10.5 - Ableitfähiger Fußbodenbelag	568
Control: ASST.1.1 - Verfahren und Regelungen	569
Control: ASST.1.1.1 - Dokumentation	570
Control: ASST.1.1.2 - Zuweisung der Aufgaben	571
Control: ASST.1.1.3 - Bekanntgabe	572
Control: ASST.1.2 - Regelmäßige Überprüfung	573
Control: ASST.2.1 - Inventar der Informationen	574
Control: ASST.2.1.1 - Informationsverantwortung	576
Control: ASST.2.2 - Inventar der Systeme	577
Control: ASST.2.2.1 - Aufdecken unauthorisierter IT-Systeme	578
Control: ASST.2.3 - Inventar der Anwendungen	579
Control: ASST.2.3.1 - Autorisierung von Anwendungen	581

Control: ASST.2.3.2 - Software Bill of Materials (SBOM)	582
Control: ASST.2.3.2.1 - Software Discovery	583
Control: ASST.2.4 - Klassifizierung	585
Control: ASST.3.1 - Nutzungsvereinbarungen	586
Control: ASST.3.1.1 - Weitergabe nur bei Erforderlichkeit	587
Control: ASST.3.2 - Entfernung nicht erforderlicher Rest- oder Zusatzdaten	588
Control: ASST.3.3 - Kennzeichnung	589
Control: ASST.3.4 - Kennzeichnung ohne vertrauliche Daten	590
Control: ASST.3.5 - Tainting	591
Control: ASST.3.6 - Verifikation	593
Control: ASST.3.7 - Pseudonymisierung	594
Control: ASST.3.8 - Anonymisierung	595
Control: ASST.3.9 - Aktualisierung	596
Control: ASST.3.10 - Autorisierung von Datenlokalationen	597
Control: ASST.3.11 - Autorisierung von Systemen	598
Control: ASST.3.11.1 - Autorisierung von Peripheriegeräten	599
Control: ASST.3.12 - Autorisierung von Personen oder Institutionen	601
Control: ASST.3.13 - Lagerung physischer Assets	602
Control: ASST.3.14 - Reserve physischer Assets	603
Control: ASST.3.15 - Ausleihe physischer Assets	604
Control: ASST.4.1 - Autorisierung von Schnittstellen	605
Control: ASST.4.2 - Vertraulichkeit und Integrität beim Transport	606
Control: ASST.4.3 - Autorisierung von Veröffentlichungen	607

Control: ASST.4.4 - Nachweis des Zugangs	609
Control: ASST.4.5 - Vereinbarungen zum Austausch	610
Control: ASST.5.1 - Wartungsbedarf dokumentieren	611
Control: ASST.5.2 - Geregelter Wartungen	613
Control: ASST.5.3 - Autorisierung von Wartungen	614
Control: ASST.5.4 - Behandlung als Änderungen und Tests	615
Control: ASST.5.5 - Wartungsfenster	616
Control: ASST.5.6 - Wartung durch Externe	617
Control: ASST.5.7 - Dokumentation von Wartungen	619
Control: ASST.6.1 - Abhandeln kommen	620
Control: ASST.6.2 - Rückkehr abhandeln gekommener Assets	621
Control: ASST.6.3 - Konformitätsprüfung	622
Control: ASST.6.4 - Zurücksetzen auf Ausgangszustand	623
Control: ASST.7.1 - Nicht mehr benötigte Anwendungen	624
Control: ASST.7.2 - Aufbewahrungs- und Löschrufen	625
Control: ASST.7.2.1 - Langfristige Archivierung	626
Control: ASST.7.3 - Geregelter Löschen oder Vernichten	627
Control: ASST.7.3.1 - Standardisierte Vernichtung	628
Control: ASST.7.3.2 - Löschrufen	629
Control: ASST.7.3.3 - Zugelassene Löschanwendungen	630
Control: ASST.7.4 - Wiederherstelltest	631
Control: ASST.7.5 - Vernichtungseinrichtungen	632
Control: ASST.7.6 - Autorisierung von Veräußerungen	633
Control: ASST.7.7 - Beschriftungen entfernen	634

Control: KONF.1.1 - Verfahren und Regelungen	636
Control: KONF.1.1.1 - Dokumentation	637
Control: KONF.1.1.2 - Zuweisung der Aufgaben	638
Control: KONF.1.1.3 - Bekanntgabe	639
Control: KONF.1.2 - Regelmäßige Überprüfung	640
Control: KONF.1.3 - Management von Werkzeugen	641
Control: KONF.1.4 - Einschränkung des Zugriffs auf Dokumentation	643
Control: KONF.1.5 - Verschlüsselung von Konfigurationsgeheimnissen	644
Control: KONF.2.1 - Grundkonfiguration für Systeme	645
Control: KONF.2.1.1 - Versionierung der Systemkonfiguration	647
Control: KONF.2.2 - Kryptographische Verfahren in IT-Systemen	649
Control: KONF.2.3 - Änderung von Default-Zugangsdaten	650
Control: KONF.2.4 - Deaktivierung nicht benötigter Systemfunktionen	651
Control: KONF.2.4.1 - Nicht benötigte Zertifikate	652
Control: KONF.2.4.2 - Externe Cloud-Anbindungen	653
Control: KONF.2.5 - Überprüfung der Konfiguration	654
Control: KONF.2.5.1 - Automatische Konfigurationsverwaltung	656
Control: KONF.2.5.1.1 - Automatische Konfigurationsverwaltung	657
Control: KONF.2.6 - Souveräne Werkzeuge	658
Control: KONF.2.7 - Alternative Administrationszugänge	659
Control: KONF.2.8 - Abgesicherter und authentisierter Bootprozess	660
Control: KONF.3.1 - Kryptographischer Hardwarespeicher	661
Control: KONF.3.2 - Speicherverschlüsselung	662
Control: KONF.3.3 - SIM-PIN	663

Control: KONF.3.4 - Physischer Diebstahlschutz	664
Control: KONF.3.5 - Standortbestimmung	665
Control: KONF.3.6 - Fernlöschung oder -sperre	667
Control: KONF.3.6.1 - Automatische Fernlöschung oder -sperre	668
Control: KONF.3.7 - Einschränkung angeschlossener Peripherie	669
Control: KONF.3.8 - Einschränkung von Wechselmedien	670
Control: KONF.4.1 - Anbindung an Verzeichnisdienst	671
Control: KONF.4.1.1 - Weiterleitung von Anmeldeinformationen	672
Control: KONF.4.2 - DNS-Anbindung	674
Control: KONF.4.2.1 - DNS-Verschlüsselung	675
Control: KONF.4.3 - Authentifizierung von Fernwartungsfunktionen	676
Control: KONF.4.4 - Einschränkung von Fernwartungsfunktionen	677
Control: KONF.4.5 - Zeitquellen	678
Control: KONF.5.1 - Authentifizierung am System	679
Control: KONF.5.1.1 - Authentifizierung an der Firmware	680
Control: KONF.5.1.2 - Pre-Boot-Authentifizierung	681
Control: KONF.5.2 - Keine Mehrfachanmeldung	682
Control: KONF.6.1 - Minimal erforderliche Berechtigungen für Anwendungen	683
Control: KONF.6.1.1 - Datenkapselung	685
Control: KONF.6.1.2 - Isolierung von Anwendungen	686
Control: KONF.6.1.3 - Isolierte Arbeitsumgebungen	687
Control: KONF.6.2 - Gemeinsam genutzte Verzeichnisse	688
Control: KONF.6.3 - Kiosk-Modus	689

Control: KONF.6.4 - Privilegierte Systemfunktionen	691
Control: KONF.6.4.1 - Rollenbasierte Privilegierung	692
Control: KONF.6.5 - Dynamische Zugriffskontrolle im System	693
Control: KONF.6.6 - Getrennte Datenhaltung	694
Control: KONF.6.6.1 - Mandantenfähigkeit	695
Control: KONF.6.7 - Privilegierte Funktionen der Anwendung	696
Control: KONF.6.8 - Berechtigungen des Webserver-Prozesses	697
Control: KONF.6.9 - Zugriff auf Code	698
Control: KONF.6.10 - Auflistung von Verzeichnisinhalten	699
Control: KONF.6.11 - Einschränkung von Uploads	700
Control: KONF.6.12 - Konferenzmoderation	701
Control: KONF.6.13 - Dynamische Zugriffskontrolle in der Anwendung	702
Control: KONF.6.14 - Browser Sandboxing	704
Control: KONF.6.15 - Virtualisierte Browser-Umgebung	705
Control: KONF.6.16 - Datenaustausch in der Virtualisierung	706
Control: KONF.7.1 - Echtzeitscanner	708
Control: KONF.7.2 - Regelmäßige Scans	709
Control: KONF.7.3 - Host-basierte Angriffserkennung	710
Control: KONF.7.4 - Angriffserkennung anhand von Netzverkehr	711
Control: KONF.7.5 - Alarmierung	713
Control: KONF.7.6 - Automatische Updates	714
Control: KONF.7.7 - Regelmäßiger Funktionstest	715
Control: KONF.7.8 - Dual-Engine-Strategie	717
Control: KONF.7.9 - Einschränkung der Installation	718

Control: KONF.7.10 - Einschränkung der Ausführung	719
Control: KONF.7.11 - Einschränkung von Softwarebibliotheken	721
Control: KONF.7.12 - Einschränkung von Skripten	722
Control: KONF.7.13 - Einschränkung von Systemaufrufen	723
Control: KONF.7.14 - Code-Signierung im Betriebssystemkern	724
Control: KONF.7.15 - Lokale Firewall	725
Control: KONF.7.16 - Anti-Exploit	726
Control: KONF.7.16.1 - Anti-Exploit für den Arbeitsspeicher	727
Control: KONF.8.1 - Automatische Überprüfung	728
Control: KONF.8.1.1 - Automatische Sicherheitsupdates	729
Control: KONF.8.2 - Automatische Updates der Anwendung	730
Control: KONF.9.1 - Speicherplatzbegrenzung	731
Control: KONF.9.2 - Begrenzung der Rechenleistung	732
Control: KONF.9.3 - Alternative Komponenten für kritische Funktionen	733
Control: KONF.10.1 - Grundkonfiguration für Anwendungen	734
Control: KONF.10.1.1 - Versionierung der Anwendungskonfiguration	736
Control: KONF.10.2 - Kryptographische Verfahren in Anwendungen	737
Control: KONF.10.3 - Änderung von Default-Zugangsdaten	738
Control: KONF.10.4 - Deaktivierung nicht benötigter Anwendungsfunktionen	739
Control: KONF.10.5 - Überprüfung der Konfiguration	740
Control: KONF.10.5.1 - Automatisierte Überprüfung der Konfiguration	741
Control: KONF.11.1 - Authentifizierung vor dem Zugriff	742
Control: KONF.11.1.1 - Authentifizierung von geplanten Konversationen	744

Control: KONF.11.1.2 - Authentifizierung von Netzverbindungen - clientseitig	745
Control: KONF.11.2 - Warteraum	747
Control: KONF.11.3 - Alternative Authentifizierung	748
Control: KONF.11.4 - Veröffentlichung von Domain-Informationen	749
Control: KONF.11.5 - Erraten von Zugriffslinks	750
Control: KONF.11.6 - Einschränkung unauthentifizierter Anschlüsse	751
Control: KONF.11.7 - Übersicht angemeldeter Verbindungen	752
Control: KONF.11.8 - Einschränkung von Schnittstellen	753
Control: KONF.11.8.1 - Einschränkung von Zonentransfers	755
Control: KONF.11.8.2 - Einschränkung von TK-Verbindungen	756
Control: KONF.11.8.2.1 - Einschränkung der TK-Gegenstellen	757
Control: KONF.11.9 - Verschlüsselung schützenswerter Daten (at-rest)	758
Control: KONF.12.1 - Eingabevalidierung	759
Control: KONF.12.1.1 - Zertifikatsprüfung	761
Control: KONF.12.1.2 - Content Security Policy (CSP)	762
Control: KONF.12.1.3 - Same-Origin-Policy	763
Control: KONF.12.1.4 - Subresource Integrity-Prüfung	764
Control: KONF.12.1.5 - HTTP Strict Transport Security (HSTS)	765
Control: KONF.12.1.6 - JavaScript	766
Control: KONF.12.1.7 - Filtern schädlicher Webinhalte	767
Control: KONF.12.1.8 - Duplikate im Verzeichnisbaum	768
Control: KONF.12.1.9 - Journaling	769
Control: KONF.12.1.10 - HTTP-Response-Header	770

Control: KONF.12.1.11 - Aktive Dateiinhalte	771
Control: KONF.12.2 - Verschlüsselungsstatus der aktuellen Verbindung	772
Control: KONF.12.3 - Cookies	773
Control: KONF.12.4 - Speicherung von Zugangsdaten	774
Control: KONF.12.5 - Auto-Vervollständigung von Daten	776
Control: KONF.12.6 - Browser-Historie	777
Control: KONF.12.7 - Erweiterte Attribute	778
Control: KONF.12.8 - Teilnahme per Default ohne Bild und Ton	779
Control: KONF.12.9 - Information über Aufzeichnung	780
Control: KONF.12.10 - Cookie-Attribute	781
Control: KONF.12.11 - Anonyme oder Pseudonyme Kommunikation	782
Control: KONF.12.12 - Verbindungsprotokoll	783
Control: KONF.12.13 - Sendebericht	784
Control: KONF.12.14 - DNS-Falschinformationen	785
Control: KONF.13.1 - Filtern schädlicher Nachrichten	786
Control: KONF.13.1.1 - SPAM-Filter	788
Control: KONF.13.1.2 - Interpretation aktiver Inhalte	789
Control: KONF.13.2 - Authentizität von Nachrichten	790
Control: KONF.13.2.1 - Verifikation der Sendeberechtigung	792
Control: KONF.13.2.2 - Verifikation der Serversignatur	793
Control: KONF.13.3 - Kryptographische Signatur des Mailservers	794
Control: KONF.13.4 - Kryptographische Signatur durch Nutzende	795
Control: KONF.13.5 - Publikation der Sendeberechtigung	796
Control: KONF.13.5.1 - Strenge Senderpolicy	797

Control: KONF.13.6 - Publikation der Serversignatur	798
Control: KONF.13.7 - TLS-Reports	799
Control: KONF.13.8 - DMARC-Reports	800
Control: KONF.13.9 - Publikation der DMARC-Richtlinie	801
Control: KONF.13.10 - Authentifizierung der Server-Zertifikate über DNS	802
Control: KONF.13.11 - MTA-STS	803
Control: KONF.14.1 - Verschlüsselung beim Transport	804
Control: KONF.14.1.1 - Obligatorische Verschlüsselung	805
Control: KONF.14.1.2 - Ende-zu-Ende-Verschlüsselung	806
Control: KONF.14.2 - Source Port Randomisierung	807
Control: KONF.14.3 - Iterative Beantwortung	808
Control: KONF.14.4 - Caching	809
Control: KONF.14.5 - Zeitüberschreitung von Netzverbindungen	810
Control: KONF.15.1 - Begrenzung des Speicherplatzes	811
Control: KONF.15.2 - Begrenzung der Rechenleistung	812
Control: KONF.15.3 - Denial of Service	813
Control: KONF.15.4 - Überbuchung von virtualisierten Ressourcen	814
Control: NOT.1.1 - Verfahren und Regelungen	815
Control: NOT.1.1.1 - Dokumentation	816
Control: NOT.1.1.2 - Zuweisung der Aufgaben	817
Control: NOT.1.1.3 - Bekanntgabe	818
Control: NOT.1.1.4 - Business Continuity Management System	819
Control: NOT.1.2 - Regelmäßige Überprüfung	820
Control: NOT.2.1 - Verfahren und Regelungen zur BAO	821

Control: NOT.2.1.1 - Rollen	822
Control: NOT.2.1.2 - Alarmierung	823
Control: NOT.2.1.3 - Stabsraum	824
Control: NOT.2.1.4 - Stabsübung	825
Control: NOT.3.1 - Wiederanlaufplan	826
Control: NOT.3.2 - Geschäftsfortführungsplan	827
Control: NOT.3.3 - Sensibilisierung zum Vorgehen im Notfall	828
Control: NOT.3.4 - Funktionstest	829
Control: NOT.3.5 - Ausweich-Telekommunikation	830
Control: NOT.3.6 - Sicherheitsmechanismen	831
Control: NOT.4.1 - Dokumentation der Quellen	832
Control: NOT.4.2 - Sicherung des Systems	833
Control: NOT.4.3 - Sicherung der Anwendung	834
Control: NOT.4.4 - Automatische Datensicherung	835
Control: NOT.4.5 - Archivierung langfristig benötigter Daten	836
Control: NOT.4.5.1 - Zum Archiv gehörende Assets	837
Control: NOT.4.5.2 - Zum Archiv gehörende Dokumentation	838
Control: NOT.4.6 - Geschützte Aufbewahrung	839
Control: NOT.4.7 - Versionierte Datensicherung	840
Control: NOT.4.8 - Verschlüsselte Datensicherung	841
Control: NOT.4.9 - Speichermedien	842
Control: NOT.4.10 - Getrennte Aufbewahrung	843
Control: NOT.4.11 - Datenträgerarchiv	844
Control: NOT.4.12 - Georedundanz	845

Control: NOT.4.13 - Datensouveränität	846
Control: NOT.4.14 - Offline-Kopie	847
Control: NOT.4.15 - Vorgehen zur Wiederherstellung	848
Control: NOT.4.16 - Test der Datensicherung	849
Control: NOT.4.16.1 - Test der Wiederherstellung	850
Control: NOT.4.17 - Anwendungstest	852
Control: PERS.1.1 - Verfahren und Regelungen	853
Control: PERS.1.1.1 - Dokumentation	854
Control: PERS.1.1.2 - Zuweisung der Aufgaben	855
Control: PERS.1.1.3 - Bekanntgabe	856
Control: PERS.1.2 - Regelmäßige Überprüfung	857
Control: PERS.2.1 - Aufgaben	858
Control: PERS.2.2 - Rollen	859
Control: PERS.2.3 - Rollentrennung	860
Control: PERS.2.3.1 - Rollentrennung - Verzeichnisdienst	861
Control: PERS.2.3.2 - Rollentrennung - Virtualisierung	862
Control: PERS.2.3.3 - Rollentrennung - Audits	863
Control: PERS.2.3.4 - Rollentrennung - Änderungen und Tests	864
Control: PERS.2.4 - Zuständigkeiten	865
Control: PERS.3.1 - Dienst- oder Arbeitsvertrag	866
Control: PERS.3.2 - Verfahrensanweisungen	867
Control: PERS.3.3 - Betriebs- und Geschäftsgeheimnisse	868
Control: PERS.3.4 - Stellenbeschreibungen	869
Control: PERS.3.5 - Prüfung der Bewerbungsunterlagen	871

Control: PERS.3.6 - Vertrauenswürdigkeit von Bewerbenden	872
Control: PERS.3.6.1 - Sicherheitsüberprüfung (intern)	873
Control: PERS.3.7 - Einarbeitung	875
Control: PERS.4.1 - Qualifikationsbedarf	876
Control: PERS.4.2 - Rollenspezifische Schulungen und Sensibilisierungen	877
Control: PERS.4.2.1 - Produktspezifische Schulungen und Sensibilisierungen	879
Control: PERS.5.1 - Maßregelung	880
Control: PERS.5.2 - Innentäter	881
Control: PERS.5.3 - Vertrauens-Check sicherheitskritischer Rollen	882
Control: PERS.6.1 - Vorgehensweise für den Weggang	884
Control: PERS.6.1.1 - Entzug von Berechtigungen gemäß BER	885
Control: PERS.6.1.2 - Neubesetzung	887
Control: SENS.1.1 - Verfahren und Regelungen	888
Control: SENS.1.1.1 - Dokumentation	889
Control: SENS.1.1.2 - Zuweisung der Aufgaben	890
Control: SENS.1.1.3 - Bekanntgabe	891
Control: SENS.1.2 - Erfolgsmessung	892
Control: SENS.2.1 - Schutzziele	893
Control: SENS.2.2 - Meldewege	894
Control: SENS.2.3 - Verschlüsselung und Signatur	895
Control: SENS.2.4 - Nutzung unautorisierter Assets	896
Control: SENS.2.4.1 - Verbindung unautorisierter IT-Systeme	897

Control: SENS.2.5 - Zuständigkeitsbereiche	898
Control: SENS.2.6 - Umgehung von Sicherheitsfunktionen	899
Control: SENS.2.7 - Änderung von Konfigurationen	900
Control: SENS.2.8 - Melden von Ereignissen	901
Control: SENS.2.8.1 - Melden von Fehler- und Warnmeldungen	903
Control: SENS.3.1 - Schadprogramme	904
Control: SENS.3.2 - Öffnen in der Sandbox	905
Control: SENS.3.3 - Umwandeln verdächtiger Dateien	906
Control: SENS.4.1 - Personengebundene Authentisierungsmittel	907
Control: SENS.4.1.1 - Verdeckte Eingabe	908
Control: SENS.4.1.2 - Untersagung von Passwort Recycling	909
Control: SENS.4.1.3 - Wahl von Passwörtern	910
Control: SENS.4.1.4 - Passwörter nur im Passwortmanager	912
Control: SENS.4.1.5 - Biometrische Authentifikation	913
Control: SENS.4.1.6 - Keine Weitergabe personengebundener Authentisierungsmittel	914
Control: SENS.4.2 - Mehrfachnutzung von Zugängen	915
Control: SENS.4.3 - Abmelden nach Nutzung	916
Control: SENS.5.1 - Datenablage	917
Control: SENS.5.2 - Weitergabe von Informationen	918
Control: SENS.5.3 - Weitergabe von Erreichbarkeiten	919
Control: SENS.5.4 - Rest- und Zusatzdaten	920
Control: SENS.5.5 - Löschfristen	921
Control: SENS.5.6 - Papiervernichtung	922

Control: SENS.6.1 - Scan angenommener Wechseldatenträger	923
Control: SENS.6.2 - Verschlüsselung	924
Control: SENS.7.1 - Spezifische Sensibilisierung	925
Control: SENS.7.2 - Virensan	926
Control: SENS.7.3 - Automatische Antworten	927
Control: SENS.7.4 - SPAM - Löschen oder Melden	928
Control: SENS.7.5 - SPAM - Nichtbeantwortung	929
Control: SENS.7.6 - SPAM - Links	930
Control: SENS.7.7 - SPAM - Anhänge	931
Control: SENS.7.8 - Gefälschte E-Mails	932
Control: SENS.7.9 - Aktive Inhalte	933
Control: SENS.7.10 - Trennen nicht benötigter Anschlüsse	934
Control: SENS.7.11 - Heimliche Aufzeichnung	935
Control: SENS.7.12 - Öffentliche WLANs	936
Control: SENS.7.13 - Unverschlüsselte WLANs	937
Control: SENS.7.14 - Unautorisierte WLANs	938
Control: SENS.7.15 - Social Engineering Anrufe	939
Control: SENS.7.16 - Mailbox-PIN und Co.	940
Control: SENS.7.17 - Unverschlüsseltes Telefonieren	941
Control: SENS.7.18 - Mobiltelefone in Sicherheitsbereichen	942
Control: SENS.7.19 - Unverschlüsselte SMS oder MMS	943
Control: SENS.7.20 - Authentifizierung von Gesprächspartnern	944
Control: SENS.7.21 - Rechtsunsicherheit von Faxen	945
Control: SENS.7.22 - Unverschlüsselte Faxleitungen	946

Control: SENS.7.23 - Geolokation	947
Control: SENS.7.24 - Zertifikatswarnungen	948
Control: SENS.7.25 - Zugang zum Fahrzeug	949
Control: SENS.8.1 - Risiken der Nutzung von mobilen Endgeräten	950
Control: SENS.8.2 - Schließen von Türen und Fenstern	951
Control: SENS.8.3 - Mitbringen von IT-Systemen	952
Control: SENS.8.4 - Begleitung Externer	953
Control: SENS.8.4.1 - Beaufsichtigung Externer	954
Control: SENS.8.5 - Verwahrung Intern	955
Control: SENS.8.6 - Rückgabe nicht mehr benötigter Assets	956
Control: SENS.8.7 - Verwendung von Brandschuttmitteln	957
Control: SENS.8.8 - Verwendung von Wasserschuttmitteln	958
Control: SENS.9.1 - Verarbeitung in der Öffentlichkeit	959
Control: SENS.9.2 - Vorsicht vor Mithören	960
Control: SENS.9.3 - Verwahrung außer Haus	961
Control: SENS.9.4 - Mobile Arbeit mit Dokumenten	962
Control: SENS.9.5 - Mitnahme zur mobilen Arbeit	963
Control: SENS.9.6 - Mitnahme ins Ausland	964
Control: SENS.9.7 - Reise- und Sicherheitshinweise	965
Control: SENS.10.1 - Grundprinzipien der Systemadministration	966
Control: SENS.10.2 - Umgang mit privilegierten Berechtigungen	967
Control: SENS.10.3 - Systemadministration - Sicherheitsvorfälle	968
Control: SENS.10.4 - Systemadministration - Strukturierte Verkabelung	969
Control: SENS.10.5 - Systemadministration - Internetnutzung	970

Control: SENS.11.1 - Sensibilisierung der Institutionsleitung	971
Control: SENS.11.2 - Führen als Vorbild	972
Control: SENS.11.3 - Whaling	973
Control: SENS.12.1 - Hohe Risiken	974
Control: REA.1.1 - Verfahren und Regelungen	975
Control: REA.1.1.1 - Dokumentation	976
Control: REA.1.1.2 - Zuweisung der Aufgaben	977
Control: REA.1.1.3 - Bekanntgabe	978
Control: REA.1.2 - Regelmäßige Überprüfung	979
Control: REA.1.3 - Übungen zur Vorfallsbehandlung	980
Control: REA.2.1 - Triage und Erstreaktion	981
Control: REA.2.2 - Automatische Erstreaktion	982
Control: REA.2.3 - Dokumentation von Vorfällen	983
Control: REA.2.4 - Diagnosedaten	984
Control: REA.2.5 - IT-Forensik	985
Control: REA.2.5.1 - Rechtssichere Beweissicherung	986
Control: REA.2.5.2 - Vier-Augen-Prinzip	987
Control: REA.2.5.3 - Forensik-Dienstleister	988
Control: REA.2.6 - Ursachenanalyse und Behandlung	989
Control: REA.2.6.1 - Dokumentation des Vorgehens	990
Control: REA.2.6.2 - Kommunikation bei Vorfällen	991
Control: REA.2.6.2.1 - Information zuständiger Behörden	992
Control: REA.2.6.3 - Koordinierung	993
Control: REA.2.6.4 - Service Level	994

Control: REA.2.6.5 - Eskalation	995
Control: REA.3.1 - Verbesserung durch Erkenntnisse	997
Control: REA.3.1.1 - Quantitative Analyse	999
Control: TEST.1.1 - Verfahren und Regelungen	1000
Control: TEST.1.1.1 - Dokumentation	1002
Control: TEST.1.1.2 - Zuweisung der Aufgaben	1003
Control: TEST.1.1.3 - Bekanntgabe	1004
Control: TEST.1.2 - Regelmäßige Überprüfung	1005
Control: TEST.1.3 - Einschränkung von Änderungen	1006
Control: TEST.2.1 - Versionshistorie	1007
Control: TEST.2.2 - Folgenabschätzung	1008
Control: TEST.2.2.1 - Kategorisierung von Änderungen	1009
Control: TEST.2.2.2 - Anpassung der Dokumentation	1010
Control: TEST.2.2.3 - Dokumentation der Abhängigkeiten	1011
Control: TEST.3.1 - Sicherheitstest	1012
Control: TEST.3.1.1 - Dokumentation von Testergebnissen	1014
Control: TEST.3.1.2 - Integritätstest	1016
Control: TEST.3.1.3 - Testdaten	1017
Control: TEST.3.1.4 - Testumgebung	1018
Control: TEST.3.1.5 - Kontinuierliche Tests	1020
Control: TEST.3.1.6 - Chaos Engineering	1022
Control: TEST.3.1.7 - Analyse der Zusammensetzung	1023
Control: TEST.3.1.8 - Fuzzing	1024
Control: TEST.3.1.9 - Lasttest	1025

Control: TEST.3.1.10 - Penetrationstest bei Änderungen	1026
Control: TEST.3.2 - Testabdeckung	1027
Control: TEST.4.1 - Autorisierung von Änderungen	1029
Control: TEST.4.1.1 - Unabhängigkeit der Autorisierung	1031
Control: TEST.4.1.1.1 - Staging	1032
Control: TEST.4.1.2 - Dokumentation der Freigabe	1033
Control: TEST.4.2 - Signatur	1034
Control: TEST.4.3 - Rückfalllösung	1035
Control: TEST.4.4 - Geregelte Notfalländerungen	1036
Control: TEST.5.1 - Information betroffener Kreise	1037
Control: TEST.5.2 - Verschlüsselte Bereitstellung	1038
Control: TEST.5.3 - Schrittweiser Rollout	1039
Control: TEST.5.4 - Persistenz	1040
Control: TEST.5.5 - Rückblick	1041

Einleitung BSI Grundschutz++

Dieses Dokument wurde automatisch generiert aus den OSCAL Dateien des BSI für den neuen Grundschutz++ und bildet den zum Zeitpunkt der Generierung verfügbaren Datenbestand ab.

Disclaimer

Dieses Dokument dient ausschließlich der Information, Dokumentation und internen Unterstützung.

Es wird keine Gewähr für die Richtigkeit, Vollständigkeit, Aktualität oder Eignung für einen bestimmten Zweck übernommen. Jegliche Nutzung erfolgt auf eigene Verantwortung. Vor operativen, fachlichen, rechtlichen oder regulatorischen Entscheidungen sind die Inhalte eigenständig zu prüfen und bei Bedarf fachlich zu validieren. Automatisch erzeugte Verknüpfungen, Klassifizierungen, Zuordnungen oder Auswertungen können vereinfachend sein und bedürfen gegebenenfalls einer manuellen Nachprüfung.

Lizenz

Dieses Dokument basiert auf Inhalten des **Bundesamts für Sicherheit in der Informationstechnik (BSI)** aus dem Projekt **Stand der Technik Bibliothek (Grundschutz++)**.

Originalquelle:

<https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek>

Verwendete Bestandteile:

- Anwendungskatalog (OSCAL)
- Namespace-Definitionen
- Quellkataloge

Die Originalinhalte stehen unter der Lizenz **Creative Commons Attribution-ShareAlike 4.0 International (CC BY-SA 4.0)**:

<https://creativecommons.org/licenses/by-sa/4.0/>

Dieses Dokument stellt eine bearbeitete bzw. transformierte Fassung dar und wird gemäß den Bedingungen der Lizenz ebenfalls unter **CC BY-SA 4.0** bereitgestellt.

BSI Stand der Technik Kernel

Norm

Beschreibung Quellkataloge

Version 0.9

zuletzt geändert 2026-04-20T11:58:00.538523Z

Keywords

URL

<https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/raw/refs/heads/main/Quellkataloge/Kernel/BSI-Stand-der-Technik-Kernel-catalog.json>

Rollen

ID Titel / Beschreibung

publisher Publisher

Referenzen

Relation Label / Link

Praktik: ARCH Architektur

Kürzel	ARCH
auch bekannt als	Netzarchitektur
Schwerpunkt	Technisch

Definition

Die Praktik Architektur definiert die grundlegende Struktur sowie die Sicherheitsprinzipien der IT-Infrastruktur und leitet daraus Anforderungen für einzelne IT-Komponenten ab – etwa für Anwendungen oder IT-Systeme. Ziel ist es, eine sichere und skalierbare Basis zu schaffen.

Im Rahmen dieser Praktik werden Sicherheitsanforderungen systematisch in die Gesamtarchitektur eingebettet. Dazu gehören die Gestaltung der Netzarchitektur sowie die Entwicklung übergreifender Konzepte, beispielsweise für Kryptografie oder den Schutz vor Schadsoftware.

Untergeordnete Gruppen:

- ARCH.1 Grundlagen
- ARCH.2 Netzdesign
- ARCH.3 Wireless LAN
- ARCH.4 Zugangsbeschränkungen
- ARCH.5 Perimeterschutz
- ARCH.6 Vertraulichkeit und Integrität im Weitverkehrsnetz
- ARCH.7 Dedizierte Systeme
- ARCH.8 Ausfallsicherheit
- ARCH.9 Kapazitätsmanagement

Praktik: BER Berechtigung

Kürzel	BER
auch bekannt als	Identitäts- und Berechtigungsmanagement
Schwerpunkt	Technisch

Definition

Die Praktik Berechtigung stellt sicher, dass ausschließlich autorisierte Personen und IT-Systeme Zugriff auf sensible Informationen und Ressourcen erhalten. Sie regelt die Verwaltung von Identitäten und Berechtigungen, um die Vertraulichkeit, Integrität und Verfügbarkeit von Informationen zu gewährleisten.

Dabei bildet die Praktik Berechtigung eine zentrale Schnittstelle zwischen den Praktiken Personal, Dienstleistersteuerung, Asset Management und Gebäudemanagement. Während IT-Systeme den Zugriff regeln, behandeln die Praktik Personal den Umgang mit Mitarbeitenden. Die Praktik Berechtigung vereint diese organisatorischen und technischen Aspekte, um Zugriffsrechte sicher und effizient zu verwalten.

Untergeordnete Gruppen:

- BER.1 Grundlagen
- BER.2 Identitätsmanagement
- BER.3 Zugangskonten
- BER.4 Authentifizierung
- BER.5 Berechtigungsmanagement
- BER.6 Passwortgebrauch
- BER.7 Schlüsselmanagement

Praktik: BES Beschaffungsmanagement

Kürzel	BES
auch bekannt als	Beschaffungswesen
Schwerpunkt	Organisatorisch

Definition

Die Praktik Beschaffungsmanagement sorgt für die frühzeitige Integration von Informationssicherheit in fachliche Anforderungs-, Planungs- und Beschaffungsverfahren, einschließlich angehender Projekte.

Dabei erfolgt keine Unterscheidung zwischen den Bereichen Organisation, Personal, Dienstleister, IT-Infrastruktur, Komponenten oder Gebäuden. Ziel ist es, Sicherheitsanforderungen frühzeitig in die strategische Planung einzubinden – von der "Make-or-Buy"-Entscheidung bis hin zur konkreten Beschaffung.

Während die Praktik Compliance sich explizit auf Anforderungen auf die Informationssicherheit konzentriert, umfasst das Beschaffungsmanagement alle fachlichen, regulatorischen und technischen Anforderungen, die in die Organisation, Personal-, Dienstleisterverträge, IT-Infrastruktur, Komponenten und Gebäude integriert werden müssen.

Untergeordnete Gruppen:

- BES.1 Grundlagen
- BES.2 Bedarfserfassung
- BES.3 Auswahl von Lieferanten
- BES.4 Auswahl von Produkten und Dienstleistungen
- BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit
- BES.6 Auswahl von Produkten und Dienstleistungen - Kündigung
- BES.7 Abnahme
- BES.8 Kompensierende Kontrollmechanismen

Praktik: DET Detektion

Kürzel	DET
auch bekannt als	Bedrohungserkennung
Schwerpunkt	Technisch

Definition

Die Praktik Detektion sorgt dafür, dass sicherheitsrelevante Ereignisse rechtzeitig erkannt werden. Zu diesem Zweck werden geeignete organisatorische, personelle und technische Maßnahmen im Vorfeld geplant, implementiert und regelmäßig geübt.

Damit die Detektion erfolgreich ist, muss umfassend protokolliert werden. Das Zusammenspiel zwischen den Praktiken Protokollierung und Detektion ist für die erfolgreiche Erkennung sicherheitsrelevanter Ereignisse unerlässlich.

Die Praktik Detektion regelt jedoch nicht den Umgang mit sicherheitsrelevanten Ereignissen nach deren Erkennung. Dies ist Aufgabe der Praktik Sicherheitsvorfallsbehandlung.

Untergeordnete Gruppen:

- DET.1 Grundlagen
- DET.2 Meldung von Ereignissen
- DET.3 Protokollierung
- DET.4 Überwachung von Aktivitäten
- DET.5 Management von Schwachstellen
- DET.6 Vorfallserkennung

Praktik: DLS Dienstleistersteuerung

Kürzel	DLS
auch bekannt als	Management bestehender Dienstleisterbeziehungen
Schwerpunkt	Organisatorisch

Definition

Die Praktik Dienstleistersteuerung regelt die kontinuierliche Überwachung und Steuerung externer Dienstleister, wie etwa Outsourcing-Partner oder Cloud-Anbieter. Sie stellt sicher, dass die erbrachten Leistungen den vereinbarten Sicherheitsanforderungen entsprechen und die Dienstleister ihre vertraglichen Verpflichtungen in Bezug auf die Informationssicherheit erfüllen.

Im Gegensatz dazu befasst sich die Praktik Beschaffungsmanagement mit der Auswahl von Dienstleistern sowie der vertraglichen Absicherung, wobei die Integration von Informationssicherheitsanforderungen in den Beschaffungsprozess im Vordergrund steht.

Während das Beschaffungsmanagement also die Grundlage für die Zusammenarbeit mit externen Dienstleistern schafft, übernimmt die Dienstleistersteuerung die fortlaufende Kontrolle und das Management dieser Beziehungen, um sicherzustellen, dass die vereinbarten Sicherheitsstandards auch langfristig eingehalten werden.

Untergeordnete Gruppen:

- DLS.1 Grundlagen
- DLS.2 Nutzung von digitalen Dienstleistungen
- DLS.3 Kontrolle von Dienstleistern
- DLS.4 Dekommissionierung von Dienstleistern

Praktik: DEV Entwicklung

Kürzel	DEV
auch bekannt als	Entwicklungsmanagement
Schwerpunkt	Technisch

Definition

Die Praktik Entwicklung stellt sicher, dass Sicherheitsanforderungen bereits von Beginn an in die Planungs- und Entwicklungsphase von IT-Systemen und Anwendungen integriert werden. Auf diese Weise können potenzielle Schwachstellen frühzeitig erkannt und vermieden werden, wodurch die Sicherheit über den gesamten Lebenszyklus der IT-Systeme und Anwendungen hinweg gewährleistet ist.

Entwicklung berücksichtigt die Software- und Systementwicklung, also die Erzeugung und Integration neuer IT-Komponenten in die IT-Infrastruktur der Institution.

Durch die enge Zusammenarbeit mit anderen Praktiken wie IT-Betrieb, Asset Management und Konfiguration wird gewährleistet, dass die entwickelten IT-Komponenten nicht nur sicher entwickelt werden, sondern auch sicher betrieben, verwaltet und gepflegt werden können. Diese enge Verzahnung sorgt dafür, dass Sicherheitsanforderungen durchgängig und über alle Phasen hinweg eingehalten werden.

Untergeordnete Gruppen:

- DEV.1 Grundlagen
- DEV.2 Softwareentwicklung - Security by Design
- DEV.3 Softwareentwicklung - Härtung
- DEV.4 Softwareentwicklung - Code
- DEV.5 Softwareentwicklung - Updates
- DEV.6 Freigabe
- DEV.7 Bereitstellung und Betrieb

Praktik: GEB Gebäudemanagement

Kürzel	GEB
auch bekannt als	Gebäudemanagement
Schwerpunkt	Organisatorisch

Definition

Das Gebäudemanagement sorgt für die Implementierung von physischen Sicherheitsmaßnahmen in und um das Gebäude. Dazu gehören insbesondere Zutrittskontrollen, Überwachungsmechanismen und die Sicherstellung geeigneter Umgebungsbedingungen, um sensible IT-Systeme und Informationen vor physischen Bedrohungen zu schützen.

Diese Praktik fokussiert sich auf den Schutz der physischen Umgebung (z.B. Gebäude, Räume), während andere Praktiken wie IT-Betrieb oder Berechtigungen sich mit systemseitigen und personellen Sicherheitsmaßnahmen beschäftigen. Das Gebäudemanagement stellt sicher, dass die physische Infrastruktur so gestaltet ist, dass sie IT-Systeme und sensible Daten bestmöglich schützt.

Untergeordnete Gruppen:

- GEB.1 Grundlagen
- GEB.2 Physischer Perimeter
- GEB.3 Physischer Zutritt
- GEB.4 Sicherheitsbereiche
- GEB.5 Gemeinsame Arbeitsbereiche
- GEB.6 Platzierung von Assets
- GEB.7 Schlüsselverwaltung
- GEB.8 Verwahrung von Speichermedien
- GEB.9 Versorgungseinrichtungen
- GEB.10 Schutz vor Elementarschäden

Praktik: ASST Informationen und Assets

Kürzel	ASST
auch bekannt als	Management von Informationen und Assets
Schwerpunkt	Organisatorisch

Definition

Im Rahmen der IT-Komponenten stellt das Asset Management sicher, dass die IT-Komponenten erfasst und inventarisiert werden. Hierbei geht es darum eine Übersicht, über relevante "Assets", wie Server, Clients, Netzwerkkomponenten sowie auch Datenträger sowie deren Verantwortlichkeiten, Besitzer oder auch Produktlebenszyklus zu haben. Des Weiteren soll im Rahmen des Asset Management auch die Ist-Dokumentation der Komponenten (z.B. Konfiguration, Patch-Level, Kritikalitätsstufen) erfasst werden.

Während die Praktik "Konfiguration" die Parameter einer IT-Komponenten betrachtet und IT-Betrieb die Vorgehensweisen zu Wartung und Pflege von IT-Komponenten, betrachtet Asset Management die Übersicht und Dokumentation aller IT-Komponenten.

Untergeordnete Gruppen:

- ASST.1 Grundlagen
- ASST.2 Inventarisierung
- ASST.3 Regelungen zum Gebrauch
- ASST.4 Regelungen zum Transfer
- ASST.5 Wartung
- ASST.6 Rücknahme von Assets
- ASST.7 Löschen und Vernichten

Praktik: KONF Konfiguration

Kürzel	KONF
auch bekannt als	Konfigurationsmanagement
Schwerpunkt	Technisch

Definition

Die Praktik Konfiguration stellt sicher, dass IT-Komponenten – wie Anwendungen und IT-Systeme – gemäß den festgelegten Informationssicherheitsrichtlinien eingerichtet und kontinuierlich gepflegt werden, um Sicherheitslücken durch fehlerhafte oder unsichere Einstellungen zu vermeiden. Dies umfasst auch die nachvollziehbare Erstellung und Fortführung der Dokumentation.

Untergeordnete Gruppen:

- KONF.1 Grundlagen
- KONF.2 Konfiguration von Systemen
- KONF.3 Physischer Schutz
- KONF.4 Vertrauenswürdige Basisdienste
- KONF.5 Authentifizierung
- KONF.6 Rollen und Berechtigungen
- KONF.7 Schutz vor Schadcode
- KONF.8 Sicherheitsupdates
- KONF.9 Verfügbarkeit von Ressourcen
- KONF.10 Konfiguration von Anwendungen
- KONF.11 Vertrauensbeziehungen
- KONF.12 Kontrollierte Datenverarbeitung
- KONF.13 Senden und Empfangen von Nachrichten
- KONF.14 Verteilte Anwendungen
- KONF.15 Ressourcenauslastung

Praktik: NOT Notfallplanung

Kürzel	NOT
auch bekannt als	Betriebliches Kontinuitätsmanagement
Schwerpunkt	Organisatorisch

Definition

Die Notfallplanung stellt sicher, dass bei schwerwiegenden Störungen oder Krisen schnell und koordiniert reagiert wird, um den Fortbestand kritischer Geschäftsprozesse und die Wiederherstellung der betroffenen Systeme zu gewährleisten.

Notfallplanung adressiert umfassende Notfälle und Krisensituationen, während die Sicherheitsvorfallbehandlung spezifisch auf Informationssicherheitsvorfälle fokussiert ist. Notfallmanagement ist strategisch und organisatorisch umfassender, während die Vorfallbehandlung auf operative Sicherheitsprobleme eingeht.

Untergeordnete Gruppen:

- NOT.1 Grundlagen
- NOT.2 Besondere Aufbauorganisation
- NOT.3 Notfallvorsorge
- NOT.4 Datensicherung

Praktik: PERS Personal

Kürzel	PERS
auch bekannt als	Personalmanagement
Schwerpunkt	Organisatorisch

Definition

Die Praktik Personal fokussiert sich auf die Integration von Sicherheitsanforderungen über den gesamten Beschäftigungs- oder Vertragszyklus von Mitarbeitenden sowie externen Partnern hinweg. Ziel ist es, einen sicheren Umgang mit Informationen während der gesamten Dauer der Beschäftigung oder Zusammenarbeit zu gewährleisten.

Diese Praktik fokussiert auf den sicheren Umgang mit Personen, während Praktiken, wie Berechtigungen, den systemseitigen Zugriff regeln.

Untergeordnete Gruppen:

- PERS.1 Grundlagen
- PERS.2 Aufgaben, Rollen, Zuständigkeiten
- PERS.3 Personalzugang
- PERS.4 Personalentwicklung
- PERS.5 Personalbetreuung
- PERS.6 Weggang von Mitarbeitenden

Praktik: SENS Sensibilisierung

Kürzel	SENS
auch bekannt als	Schulung und Sensibilisierung
Schwerpunkt	Organisatorisch

Definition

Die Praktik Sensibilisierung sorgt dafür, dass alle Mitarbeitenden über die Leitlinie zur Informationssicherheit sowie relevanten Informationssicherheitsrichtlinien, -verfahren und -bedrohungen informiert sind. Ziel ist es, ein sicherheitsbewusstes Verhalten im Arbeitsalltag zu fördern und zu verankern.

Der Fokus liegt auf der Schaffung eines Verständnisses für die Bedeutung der Informationssicherheit innerhalb der Institution. Gleichzeitig wird die notwendige Qualifikation für den sicheren Betrieb und die Nutzung von Anwendungen und IT-Systemen vermittelt, um Fehler zu vermeiden.

Die Praktik Personalmanagement stellt sicher, dass Informationssicherheitsaspekte während des gesamten Beschäftigungszyklus von Mitarbeitenden berücksichtigt werden, während Sensibilisierung speziell auf die kontinuierliche Weiterbildung und Sensibilisierung im Bereich Informationssicherheit abzielt.

Untergeordnete Gruppen:

- SENS.1 Grundlagen
- SENS.2 Grundlegende Sensibilisierung
- SENS.3 Schutz vor Schadprogrammen
- SENS.4 Authentisierung
- SENS.5 Umgang mit Informationen
- SENS.6 Umgang mit Datenträgern
- SENS.7 Umgang mit spezifischen Zielobjekten
- SENS.8 Physische Sicherheit
- SENS.9 Mobiles Arbeiten
- SENS.10 Administration
- SENS.11 Sensibilisierung der Leitungsebene
- SENS.12 Spezifische Risiken

Praktik: REA Sicherheitsvorfallsbehandlung

Kürzel	REA
auch bekannt als	Behandlung von Sicherheitsvorfällen
Schwerpunkt	Technisch

Definition

Die Praktik Sicherheitsvorfallsbehandlung sorgt dafür, dass Informationssicherheitsvorfälle effizient erkannt, gemeldet, analysiert und behoben werden, um Schäden zu minimieren und den Normalbetrieb so schnell wie möglich wiederherzustellen.

Diese Praktik ist reaktiv und konzentriert sich darauf, die Auswirkungen von Sicherheitsvorfällen zu minimieren. Sie stellt sicher, dass bei einem Sicherheitsvorfall schnell und effizient gehandelt wird, um den Schaden zu begrenzen.

Andere Praktiken, wie z.B. Architektur, Personal, Sensibilisierung wirken proaktiv und versuchen, Sicherheitsvorfälle durch präventive Maßnahmen zu verhindern oder deren Häufigkeit zu reduzieren.

Untergeordnete Gruppen:

- REA.1 Grundlagen
- REA.2 Reaktion
- REA.3 Nachbereitung

Praktik: TEST Änderungen und Tests

Kürzel	TEST
auch bekannt als	Veränderungsmanagement
Schwerpunkt	Organisatorisch

Definition

Die Praktik "Änderungen und Tests" stellt sicher, dass alle geplanten Veränderungen an Informationssystemen systematisch und kontrolliert ablaufen, um ungewollte Störungen, Sicherheitsrisiken oder Compliance-Verstöße zu vermeiden (Change Management). Sie umfasst die Vorbereitung, Planung und Durchführung von Tests, die Freigabe und den Rollout von Änderungen, sowie die begleitende Dokumentation.

Untergeordnete Gruppen:

- TEST.1 Grundlagen
- TEST.2 Vorbereitung
- TEST.3 Tests
- TEST.4 Freigabe
- TEST.5 Bereitstellung

Control: ARCH.1.1 - Verfahren und Regelungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.1 Grundlagen
UUID: 67c185f2-ebfd-49cc-a910-9a6dd0901578
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ARCH.1.1.1 Dokumentation
- ARCH.1.1.2 Zuweisung der Aufgaben
- ARCH.1.1.3 Bekanntgabe

Statement

Architektur MUSS Verfahren und Regelungen zur Architektur des Netzes und damit verbundener Infrastrukturen verankern.

Guidance

Die Netzarchitektur ist der strukturierte Entwurf einer Netzinfrastuktur, einschließlich der IT-Systeme und verbundsbezogenen Schutzmechanismen darin. Hierzu gehören die Segmentierung und Filterung von kabelgebundenen und kabellosen Netzen, Netzmanagement sowie die Redundanz wichtiger Systeme für eine ausreichende Gewährleistung der Verfügbarkeit. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik. Empfehlenswert ist ein Design des Netzes nach dem Zero-Trust-Prinzip (siehe BSI Positionspapier Zero-Trust). Dennoch sind Netzgrenzen zur Isolierung durch Filterung oder Zugbrücken bei Angriffen weiterhin sinnvoll. Weitere Informationen zur Absicherung von Netzen sind in ISO/IEC 27033 zu finden.

Control: ARCH.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.1 Grundlagen

Übergeordnetes Control:

ARCH.1.1 Verfahren und Regelungen

UUID: cc8c3dda-e62f-4dda-9190-bfd4f1aa4feb

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Architektur MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es, Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: ARCH.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.1 Grundlagen

Übergeordnetes Control:

ARCH.1.1 Verfahren und Regelungen

UUID: d3792075-d03a-414c-b28c-43d78dbaded9

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Architektur MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, arch.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es, die Zuweisung anhand von Rollen (z. B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: ARCH.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.1 Grundlagen

Übergeordnetes Control:

ARCH.1.1 Verfahren und Regelungen

UUID: 1721e1fd-79b4-4cb2-a189-ae8571d66931

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Architektur MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll, die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: ARCH.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.1 Grundlagen

UUID: 16e72553-fd92-4cc2-b3d6-d2c72809e6b1

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Architektur MUSS die Verfahren und Regelungen {{ insert: param, arch.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante Überprüfung der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: ARCH.2.1 - Netzsegmente

Tags: "Lateral Movement" "Separation of Concerns"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.2 Netzdesign
UUID: ec31da4c-f5bd-43f5-b94f-f0fb7a5e1a18
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE eine Unterteilung des internen Netzes in Netzsegmente unter Berücksichtigung der Anforderungen der Institution und des Schutzbedarfes verankern.

Guidance

Die Aufteilung in Netzsegmente (auch Netzdomänen oder Subnetze genannt) ermöglicht es, verschiedene Zonen mit unterschiedlichen Schutzanforderungen – z. B. Büro-IT, Produktionsnetz, Managementnetz – getrennt zu betrachten und gezielt zu schützen. Relevant sind dabei (falls vorhanden) auch WLANs/SSIDs, IoT-Geräte wie vernetzte Kühlschränke, Hausleittechnik, operative Technologien, Industrielle Steuerungssysteme oder Netze zum Zugriff auf Speichersysteme (Storage Area Network, SAN). Die Anforderung gilt auch, wenn die Systeme nur noch als VMs oder Container existieren. Die Segmentierung kann hier in die virtuelle Netzwerk-Ebene verlagert werden, sodass die Segmentierung weder vom Hypervisor noch von den Workloads umgangen wird. Die Einteilung in Segmente kann anhand einer Klassifizierung von Netzen erfolgen (z.B. nach Schutzbedarf der dort verarbeiteten Daten oder nach Risikoklassen angeschlossener Systeme) erfolgen. Beispiele hierfür sind Internet-Domäne, Endgeräte-Domäne, Domäne für zentrale Serverdienste, Domäne für Systeme hoher Vertraulichkeit. Alternativ können auch organisatorische Domänen verwendet werden, z. B. Personalwesen, Marketing, Finanzverwaltung, Innere Verwaltung. Die Filterkriterien können sich nach den Sicherheitsanforderungen der jeweiligen Netze im Einzelnen oder nach einer vorgenommenen Klassifikation der Netze richten. Hierzu gehören insbesondere die Anforderungen zur Authentifizierung und Autorisierung von Assets.

Control: ARCH.2.2 - Einschränkung von Verbindungen zwischen Segmenten

Tags: "Lateral Movement" "Separation of Concerns"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.2 Netzdesign

UUID: 6ff2de76-4a01-42cc-a794-1a6ec9313f46

Aufwand: 2

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ARCH.2.2.1 Externe Netzanschlüsse
- ARCH.2.2.2 Gastnetz
- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.2.10 Drucker-Netz
- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.12 Sprungserver

Statement

Architektur für Netze SOLLTE Verbindungen zwischen Netzsegmenten anhand von {{ insert: param, arch.2.2-prm1 }} einschränken.

Guidance

Dient dem Ziel, die Angriffsfläche innerhalb interner und externer Netze zu reduzieren und die Ausbreitung potenzieller Schadsoftware oder unberechtigter Zugriffe einzudämmen. Ohne solche Begrenzungen könnte ein einzelner kompromittierter Bereich direkten Zugriff auf weitere sensible Segmente erhalten und dadurch Geschäftsprozesse massiv beeinträchtigen. Beispielsweise benötigt ein Endgerät Verbindungen zu internen Servern und Druckern, während Gäste lediglich auf den In-

ternetanschluss Zugriff benötigen. Im Blick auf weitreichende Sicherheitsvorfälle ist hier insbesondere die Trennung interner Netzsegmente vom Internet zu beachten. Diese Regeln können auf Kriterien wie Gerätetyp (z. B. Laptop, IoT-Gerät), Benutzerrolle (z. B. Administrator, Gast), physischem Anschlussort oder Uhrzeit basieren. Eine klare Trennung von Benutzergruppen über VLANs oder dynamische ACLs erhöht die Sicherheit und Transparenz. Für die Einführung in eine bestehende Umgebung kann ein gestuftes Vorgehen gewählt werden: (1) Zunächst wird ein Überwachungsmodus ("Audit-Only") aktiviert, der protokolliert, welche Zugriffe durch eine strengere Richtlinie verweigert würden, ohne sie tatsächlich zu blockieren. (2) Anschließend werden diese Protokolle analysiert, um legitime, für den Geschäftsbetrieb notwendige Zugriffe zu identifizieren und diese gezielt in die jeweiligen Rollen und Berechtigungsgruppen aufzunehmen. (3) Erst wenn keine legitimen Zugriffe mehr in den Protokollen als "verweigert" auftauchen, wird die Richtlinie scharf geschaltet und blockiert aktiv alle nicht explizit erlaubten Zugriffe.

Control: ARCH.2.2.1 - Externe Netzanschlüsse

Tags: "Internet Exposure" "Command & Control"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.2 Netzdesign

Übergeordnetes Control:

ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten

UUID: 56a54bba-30a4-478f-8464-bc5194cae49f

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE Verbindungen über externe Netzanschlüsse einschränken.

Guidance

Dient dazu, die Angriffsfläche zu reduzieren, unerwünschte Ein- und Ausleitungen zu begrenzen und das Risiko von Datenabflüssen zu minimieren. Für mobile Systeme kann dies z. B. über das Erzwingen einer VPN-Verbindung ins gefilterte Netz der Institution oder über die Verwendung eines direkten Internetzugangs erfolgen, welcher über einen Direct-Internet-Access Agenten abgesichert ist.

Control: ARCH.2.2.2 - Gastnetz

Tags: "Lateral Movement" "Separation of Concerns"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.2 Netzdesign
Übergeordnetes Control:
ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
UUID: 73c9c122-d3f6-42f9-a6f1-6b454a8b1853
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE Verbindungen zwischen Gastnetz und internem Netz einschränken.

Guidance

Wenn Gäste der Institution sich mit dem internen Netz verbinden, könnten Schadprogramme in das Netz gelangen oder unbeabsichtigte Datenflüsse über die Verbindung fließen. Daher ist es sinnvoll, einen vom übrigen Netz getrennten Gastzugang einzurichten, z.B. in Besprechungs-, Veranstaltungs- und Schulungsräumen. Wenn die Einschränkungen von Gastnetzen lockerer sind als die internen Netze am gleichen Standort, so zeigt die Erfahrung, dass auch interne Mitarbeitende gerne auf Gastnetze zurückgreifen. Dadurch könnte es zur Umgehung der internen Schutzmaßnahmen kommen. Daher ist es empfehlenswert, für das Gastnetz gleiche oder strengere Einschränkungen zu wählen oder die Nutzung des Gastnetzes durch Mitarbeitende technisch oder organisatorisch zu beschränken.

Control: ARCH.2.2.3 - Segmentierung von Servern und Clients

Tags: "Lateral Movement" "Separation of Concerns"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.2 Netzdesign
Übergeordnetes Control:
ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
UUID: 8af42e9e-5340-4690-9567-88a5309aee3a
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE Verbindungen zwischen Hostsystemen und Clients einschränken.

Guidance

Die Anforderung gilt auch, wenn die IT-Systeme nur noch als VMs oder Container existieren. Die Segmentierung kann hier in die virtuelle Netzwerk-Ebene verlagert werden, sodass die Segmentierung weder vom Hypervisor noch von den Workloads umgangen wird. Die Anforderung kann auch physisch durch dedizierte Infrastruktur für VDI/Client-VMs umgesetzt werden. Um die klare Trennung sicherzustellen, wird empfohlen kein Bridging zwischen Port-Groups sowie auf dem virtuellen Switch keinen promiscuous Mode zu verwenden.

Control: ARCH.2.2.4 - VoIP-Netz

Tags: "Lateral Movement" "Separation of Concerns"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.2 Netzdesign

Übergeordnetes Control:

ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten

UUID: 02cac8a8-60e3-481d-96bf-3fa484afea78

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Architektur für Netze KANN Verbindungen zwischen Daten- und VoIP-Systemen einschränken.

Guidance

Werden sowohl Telefonie als auch andere Daten über dasselbe Netz geführt, so könnte dies bei einem Netzausfall dazu führen, dass keine Kommunikation mehr möglich ist, auch nicht zur Meldung oder Behebung der Störung. Die Wahrscheinlichkeit kann durch getrennt betriebene Voice- und Datennetze verringert werden. Für weitere Details siehe „Kompendium für organisationsinterne Telekommunikationssysteme mit erhöhtem Schutzbedarf“.

Control: ARCH.2.2.5 - OT-Systeme

Tags: "Lateral Movement" "Separation of Concerns"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.2 Netzdesign
Übergeordnetes Control:
ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
UUID: 43badc07-0172-4666-9a72-0c0289b7f540
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE Verbindungen zwischen OT-Systemen und anderen IT-Systemen einschränken.

Guidance

IT- und OT-Systeme haben typischerweise sehr unterschiedliche Risikoprofile (IT: Schnelllebig, viele Cybersicherheitsmechanismen, OT: Stabilität, weniger Cybersicherheitsmechanismen, beispielsweise industrielle Steuerungssysteme und Gebäudeautomationstechnik). Insbesondere der Zugriff auf OT-Funktionen (z. B. Öffnung zentraler Schließanlage) ist mit erhöhtem Risiko verbunden und könnte auch versehentlich z.B. durch Portscanner ausgelöst werden. Stattdessen ist es empfehlenswert, den Zugriff zu solchen Netzen nur über dafür vorgesehene Quellen zu ermöglichen (z. B. Sprungserver, bestimmte auslösende OT-Systeme).

Control: ARCH.2.2.6 - Demilitarisierte Zone

Tag: "Lateral Movement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.2 Netzdesign
Übergeordnetes Control:
ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
UUID: f9e8c80d-0043-42ac-a71b-73ff1e6cad50
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE eine demilitarisierte Zone installieren.

Guidance

Unter einer Demilitarisierten Zone versteht man in diesem Kontext ein logisch oder physisch getrenntes Teilnetz, in dem Systeme mit exponierten Diensten – wie Webserver, Mail-Gateways oder VPN-Endpunkte – betrieben werden. Systeme der Institution, die sowohl aus dem öffentlichen Netz als auch aus dem internen Netz erreichbar sind, werden in einer demilitarisierten Zone (DMZ) so betrieben, dass (1) der Netzverkehr zwischen dem System und dem öffentlichen Netz gefiltert wird und (2) der Netzverkehr zwischen dem System und anderen internen Netzen gefiltert wird. Eine DMZ kann sowohl durch dedizierte Hardware-Firewalls als auch durch virtuelle Netzwerksegmente umgesetzt werden. Ohne eine solche Trennung könnte ein kompromittierter Webserver direkt als Sprungbrett ins interne Netz dienen oder Schadsoftware könnte sich ungehindert auf sensible Systeme ausbreiten. Mit einer DMZ kann eine Institution hingegen erreichen, dass kompromittierte Systeme isoliert bleiben und sicherheitskritische interne Netze weiterhin geschützt sind.

Control: ARCH.2.2.7 - Management-Netz

Tags: "Lateral Movement" "Separation of Concerns"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.2 Netzdesign
Übergeordnetes Control:
ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
UUID: d02f23d0-9c15-4811-838f-6440ee744334
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE ein oder mehrere Management-Netze installieren.

Guidance

Ein Management-Netz ist ein physisch oder durch Netzfilter separiertes Netzsegment, das dediziert für die Überwachung, Verwaltung und Wartung von IT-Systemen bestimmt ist. Es ist von anderen Produktions- und Datennetzen getrennt, um den Zugriff auf kritische Verwaltungsfunktionen zu schützen und die Verfügbarkeit dieser Zugänge auch bei Problemen im restlichen Netz zu sichern. Dies gilt auch für virtualisierte Systeme. Im Kontext der Containerisierung empfiehlt es sich, administrative Zugänge auf Applikations-Container immer über die Container-Runtime erfolgen zu lassen.

Control: ARCH.2.2.8 - Segmentierung von Test und Betrieb

Tags: "Lateral Movement" "Separation of Concerns"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.2 Netzdesign
Übergeordnetes Control:
ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
UUID: 53ea67c4-1ee1-47f3-abc2-0f2462c57cd1
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE Verbindungen zwischen Testumgebungen und Betrieb einschränken.

Guidance

Entwicklungs-, Staging- und Testumgebungen haben oft geringere Sicherheitsvorkehrungen als Produktivsysteme. Eine saubere Trennung zwischen Test- und Produktivumgebung verhindert Übergriffe auf das Produktivsystem und vermeidet Ressourcenkonflikte.

Links

related: TEST.3.1.4 Testumgebung

Control: ARCH.2.2.9 - Segmentierung von IPv4 und IPv6

Tags: "Lateral Movement" "Separation of Concerns"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.2 Netzdesign

Übergeordnetes Control:

ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten

UUID: dabbb234-5678-456b-8db4-4c7ac9ed1e12

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE Verbindungen zwischen IPv4 und IPv6 einschränken.

Guidance

IPv4 und IPv6 sind grundlegende Netzprotokolle, die unterschiedliche Protokollstacks und Sicherheitseigenschaften haben. Eine Trennung von IT-Systemen mit IPv4 und IPv6 erschwert es Angreifern, Schwachstellen der Protokolle auszunutzen oder zu kombinieren und verringert die Wahrscheinlichkeit von Fehlern durch Wechselwirkungen.

Control: ARCH.2.2.10 - Drucker-Netz

Tags: "Lateral Movement" "Separation of Concerns"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.2 Netzdesign

Übergeordnetes Control:

ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten

UUID: 48013e9f-7f90-495c-8cbd-aaf33f5060fb

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE Verbindungen zwischen Druckern und anderen Systemen einschränken.

Guidance

Drucker können Schwachstellen aufweisen, die Angreifer ausnutzen, z.B. veraltete Firmware oder ungesicherte Netzprotokolle. Durch die Segmentierung wird die Angriffsoberfläche reduziert und die Netzüberwachung erleichtert. Die Umsetzung kann physisch oder durch VLANs erfolgen.

Control: ARCH.2.2.11 - Physische Segmentierung

Tags: "Lateral Movement" "Separation of Concerns"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.2 Netzdesign
Übergeordnetes Control:
ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
UUID: 8629ffa8-91c9-4ed3-b7b7-922aba672ab4
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Architektur für Netze KANN den physischen Zugang auf diese einschränken.

Guidance

Obwohl sich eine virtuelle Vernetzung immer größerer Beliebtheit erfreut, können Konfigurationsfehler oder Sicherheitslücken dabei leichter zu einer Umgehung der Netztrennung führen, als wenn die Netze bereits auf physischer Ebene voneinander getrennt werden.

Control: ARCH.2.2.12 - Sprungserver

Tags: "Lateral Movement" "Separation of Concerns"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.2 Netzdesign
Übergeordnetes Control:
ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
UUID: c907e5e0-bccc-4467-9962-7f4972b0ad8f
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Architektur KANN Sprungserver installieren.

Guidance

Ein Sprungserver (englisch „jump server“ oder „jump host“) ist ein speziell abgesicherter Server, der als einzig vorgesehener Einstiegspunkt in ein Verwaltungsnetz oder zu administrierten Systemen dient. Alle administrativen Sitzungen laufen über diesen zentralen Knotenpunkt, wodurch die Angriffsfläche reduziert und die Nachvollziehbarkeit erhöht wird. Ohne Sprungserver könnte ein Angreifer beispielsweise über kompromittierte Administrator-Notebooks unbemerkt direkt auf zentrale Systeme zugreifen und dort Manipulationen durchführen. Ein Sprungserver kann hingegen alle Management-Zugriffe zentral kanalisieren, sodass verdächtige Aktivitäten leichter erkannt und im Nachhinein nachvollzogen werden können. Praktische Umsetzungen können sein: (1) der Einsatz eines dedizierten, gehärteten Servers mit restriktiven Firewall-Regeln, (2) die Nutzung von Mehrfaktor-Authentisierung und zentralem Benutzer-Management auf dem Sprungserver, (3) eine verpflichtende Session-Aufzeichnung oder Protokollierung sämtlicher Administrationsvorgänge.

Control: ARCH.2.3 - Mikrosegmentierung

Tags: "Zero Trust" "Advanced Persistent Threats (APT)" "Lateral Movement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.2 Netzdesign
UUID: 193a28ca-0382-4998-874d-4c08b6326f26
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Architektur für IT-Systeme KANN Verbindungen zu allen anderen IT-Systemen einschränken.

Guidance

Mikrosegmentierung ist die Unterteilung des Netzes in möglichst kleine Segmente (z.B. pro IT-System oder Server-Anwendung). Für jedes dieser Segmente wird die erlaubte Kommunikation definiert und gefiltert. Mikrosegmentierung sorgt dafür, dass z.B. zwei medizinische Geräte mit gleicher Rolle zwar ins gleiche VLAN dürfen, aber nicht direkt miteinander kommunizieren dürfen. Die Umsetzung kann mit dynamischen VLANs, softwaredefinierten Netzwerken (SDN) oder Netzwerk-Firewalls auf Host-Ebene erfolgen. Die Mikrosegmentierung begrenzt Angriffe, die sich lateral ausbreiten.

Control: ARCH.2.4 - Inventar der Netze

Tag: "Inventories"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.2 Netzdesign
UUID: 7b2381fe-9617-4b2a-a8da-7972b81a3909
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Architektur SOLLTE ein Inventar der Netze einschließlich interner Segmente, externer Netzanschlüsse und deren Verwendungszweck dokumentieren.

Guidance

Die Erfassung externer Netzanschlüsse – etwa zu Partnernetzen, Cloud-Diensten oder dem Internet – hilft, potenzielle Angriffspunkte zu identifizieren und gezielte Schutzmaßnahmen zu planen. Beispiele für interne Netzsegmente können klassische Trennungen wie IT-Office-Netze, SCADA-/Leittechnik-Netze oder DMZs für externe Zugriffe sein. Dabei sollten auch virtuelle Netze und virtuelle Switches berücksichtigt werden, ebenso wie Container-Infrastrukturen. Als externe Netzanschlüsse kommen etwa VPN-Gateways, dedizierte Providerverbindungen, Fernwartungszugänge oder Cloud-Endpunkte in Frage. Dabei sind nicht nur die auf den ersten Blick relevanten Datennetze, sondern auch andere Telekommunikationsanbindungen wie ISDN-Leitungen, Mobilfunkausweichstrecken oder WLAN-Roaming von Clients relevant. Der Verwendungszweck beschreibt, warum ein Segment oder Anschluss existiert – etwa für Produktivsysteme, Entwicklung, Administration oder Gastzugänge. Der Zweck von Netzsegmenten kann durch einen sprechenden Namen dokumentiert werden, z. B. Management-Netz, OT-Netz, Internetanschluss, Netz der Finanzverwaltung. Dies hilft, Zuständigkeiten und Zugriffsrechte klar zuzuordnen, z. B. anhand von Geschäftsprozessen, Organisationseinheiten oder Zielgruppen (z. B. Gäste, Vertrieb, Leitung). Dabei sind, falls vorhanden, auch WLANs/SSIDs, IoT-Geräte wie vernetzte Kühlschränke, Hausleittechnik, operative Technologien oder Industrielle Steuerungssysteme zu berücksichtigen. Informationen können aus Netzwerkmanagementsystemen, Konfigurationsdateien oder Asset-Management-Tools gewonnen werden. Die Pflege kann als wiederkehrende Aufgabe in Prozesse eingebettet oder im Rahmen von Änderungen (z. B. Change Management) angestoßen werden.

Auch eine einfache Pflege in Tabellenform kann sinnvoll sein – entscheidend ist die Klarheit und Aktualität.

Links

related: ASST.2.1 Inventar der Informationen

Control: ARCH.2.5 - Netzplan

Info

Control der Klasse "BSI-Stand-der-Technik-Kern"
Gruppe: ARCH.2 Netzdesign
UUID: 7630e7d2-883b-4697-9b7a-b212dfa5666d
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE einen Netzplan dokumentieren.

Guidance

Ein Netzplan (engl. network diagram) stellt eine schematische Darstellung der logischen und physischen Struktur von Kommunikationsnetzen dar und bildet die Grundlage für Transparenz im Betrieb. Er kann einen zentralen Beitrag zur Informationssicherheit leisten, da er Transparenz über die Struktur, Verbindungen und Schutzbedarfe einer Netzwerkumgebung schafft. Ein aktueller Netzplan, aus dem sich gut die Netzstruktur erkennen lässt, ermöglicht es Anschlüssen mit hohem Risiko oder von einzelnen Ausfallstellen (Single Points of Failure) auf einen Blick zu erkennen. Für die Umsetzung ist es nicht erforderlich, jedes Subnetz einzeln in einer Grafik zu visualisieren. Vielmehr kann es hilfreich sein, Netzpläne auf einem abstrahierten Level zu halten, z. B. als logische Übersicht mit Domänen, Segmenten und Übergängen (bereinigter Netzplan). Eine Visualisierung als Layer-Modell (z. B. Infrastruktur-, Kommunikations- und Applikationsebene) kann zusätzliche Einblicke schaffen. Auch eine einfache Pflege als visuelle Skizze kann sinnvoll sein – entscheidend ist die Klarheit und Aktualität.

Control: ARCH.2.6 - Topologieüberwachung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.2 Netzdesign
UUID: f97736f7-f2c7-4366-a996-7e28512972de
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE die Einhaltung der Netzarchitektur {{ insert: param, arch.2.6-prm1 }} überprüfen.

Guidance

Unbeabsichtigte Netzverbindungen können z.B. über falsch gesteckte Kabel, WLAN auf Clients oder Modems im öffentlichen Telefonnetz (PSTN) an einer TK-Anlage entstehen. Die Anforderung kann durch Netzscans, Software zur Topologieüberwachung oder Protokollanalyse umgesetzt werden. Hierbei sind auch virtualisierte Systeme auf VM-Hosts zu berücksichtigen.

Control: ARCH.3.1 - Netzabdeckung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.3 Wireless LAN
UUID: 57639fa6-7898-4ad8-91c5-cc77106e0d02
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Architektur für WLANs SOLLTE die Netzabdeckung testen.

Guidance

Drahtlose Netzanbindungen sind schwerer zu schützen als kabelgebundene Netze, da der Perimeter des Netzes schwerer zu erkennen ist. Das erschwert es, die Netzverfügbarkeit zu gewährleisten und gleichzeitig den Zugang zum Netz vor unbefugtem Zugriff oder Störungen zwischen Netzen zu schützen. Zudem können Wände und andere strahlende Geräte wie Mikrowellen-Geräte oder Bluetooth-Sender den Empfang beeinträchtigen. Ein Test des Empfangs an wichtigen Standorten unter realen Bedingungen hilft, die WLAN-Qualität zu gewährleisten. Der Empfang in den verschiedenen Frequenzbändern kann dabei unterschiedlich ausfallen. Für weitere Informationen, siehe Allgemeinzuteilungen von Frequenzen für Mobilfunkanwendungen, DECT, WLAN, CB-Funk und ähnliche Anwendungen der Bundesnetzagentur. Abdeckungsbereich ist der Bereich, in dem das WLAN mit gewöhnlichen Endgeräten genutzt werden kann. Relevant ist dabei auch die Abdeckung aller Orte, an denen sich Gäste aufhalten, sowie an Orte an denen gerade kein Empfang gewünscht ist, z.B. Serverräume oder abhörsichere Räume.

Control: ARCH.3.2 - Einschränkung in Sicherheitsbereichen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.3 Wireless LAN
UUID: 0ecd6068-4509-4cb5-bf12-b35076cc88e3
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Architektur für WLANs KANN in Sicherheitsbereichen die Ausstrahlung einschränken.

Guidance

Hierzu gehören beispielsweise abhörsichere Räume oder Serverräume, von denen aus keine Daten ins Internet gesendet werden sollen. Dies kann z.B. durch die Reduktion der Sendeleistung in benachbarten Räumen oder die Isolierung der Räume erfolgen.

Control: ARCH.3.3 - SSIDs

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.3 Wireless LAN
UUID: 06d3eb79-4326-4bd8-87c0-9808909d29c7
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Architektur für WLANs SOLLTE institutionsspezifische SSIDs aktivieren.

Guidance

Viele WLAN-Geräte bringen ab Werk eingestellte Netznamen (Default SSID) mit, aus denen sich häufig Rückschlüsse auf eingesetzte Geräte oder sogar Zugangsdaten ziehen lassen. Eigene SSIDs können Nutzenden die Zuordnung der Netze zur Institution oder deren Unterscheidung erleichtern, wenn hierfür sprechende Namen konfiguriert werden (z.B. "Institutionsname-Gastnetz").

Control: ARCH.3.4 - Verschlüsselte Netzanbindung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.3 Wireless LAN
UUID: 45bb11ba-1018-430e-be4f-7cae54407f3c
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Architektur für WLANs SOLLTE die Netzanbindung {{ insert: param, arch.3.4-prm1 }} verschlüsseln.

Guidance

Ohne eine sichere Verschlüsselung könnte ein Angreifer durch „Sniffing“ sensible Inhalte wie Passwörter, E-Mails oder Geschäftsdaten abfangen oder sogar schadhaften Datenverkehr in die Kommunikation einschleusen. Ebenso könnte ein schwacher oder veralteter Standard wie WEP einem Angreifer ermöglichen, das WLAN-Passwort innerhalb weniger Minuten zu knacken und damit vollständigen Netzzugang zu erlangen. Eine zeitgemäße und wirksame Verschlüsselung kann dagegen die Vertraulichkeit und Integrität der Kommunikation sicherstellen und bietet Schutz vor Angriffen wie „Man-in-the-Middle“-Manipulationen oder unerwünschtem Zugriff über „Rogue Clients“. Netzanbindung bedeutet hier, dass nicht nur die über das Netz transportierten Daten verschlüsselt werden, sondern auch die Kommunikation selbst, z.B. die Adressen kommunizierender Geräte. Anerkannten Standards meint z.B. WPA3-Enterprise mit 802.1X und EAP-TLS. Für Details siehe IEEE 80211, WPA3.

Control: ARCH.4.1 - Netzzugangskontrolle

Tags: "Network Access Control" "Rogue Access Point"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.4 Zugangsbeschränkungen
UUID: 9ec9762e-c115-4e56-8b45-b88a872f47ce
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne

Statement

Architektur für Interne Netzsegmente SOLLTE den Zugriff von IT-Systemen auf das Netzsegment im Einklang mit den zugehörigen Anforderungen des Identitäts- und Berechtigungsmanagements authentifizieren.

Guidance

Unautorisierte Systeme könnten Ausgangspunkt von Angriffen sein oder zu unbeabsichtigten Störungen im Netz führen. Netzzugangskontrolle (Network Access Control, NAC) bietet eine wirksame Möglichkeit, den Zugriff auf Netzwerke kontrolliert zu steuern, insbesondere in schützenswerten Bereichen wie Management-Netzen, Produktionssystemen oder Forschungsumgebungen. Die Auswahl der Netzbereiche für die Netzzugangskontrolle richtet sich nach dem Schutzbedarf oder Risikoprofil. Dabei empfiehlt sich zu dokumentieren, welche Zonen mit NAC abgesichert werden und warum andere bewusst nicht berücksichtigt werden (z.B. aufgrund technischer Einschränkungen oder fehlender Relevanz). Die Umsetzung kann (1) auf Zertifikaten basieren (X.509, EAP-TLS or mTLS), (2) auf Zugangskonten basieren (IEEE 802.1X, RADIUS), (3) auf dynamischen Prüfungen basieren (z.B. Sicherheitspatches). Eine Authentifizierung, die nur auf MAC-Adressen basiert, gilt dagegen nicht mehr als zeitgemäß, da MAC-Adressen sehr leicht ausgelesen und auf Systemen eingestellt werden könnten und so unberechtigte IT-Systeme zu leicht auch Zugang erhalten. Wenn Systeme die Netzzugangskontrolle nicht oder nur unzureichend unterstützen, ist für solche Systeme anstelle einer Netzzugangskontrolle die Nutzung eines eigenen Netzsegmentes empfehlenswert.

Für die Verbindung zwischen RADIUS-Servern, Switches und Verzeichnisdiensten kommen Protokolle wie RadSec, IPsec oder LDAPS in Betracht. Die Verwendung nur einer einzigen Serverkonfigurationen (z.B. ein gemeinsamer RADIUS-Server für NAC und VPN) führt zu Komplexität und Angriffspunkten. Daher werden getrennte Systeme empfohlen. Dies gilt insbesondere bei unterschiedlichen Schutzklassen im LAN/WLAN oder Büro-/Produktionsnetz. Bei WLANs kann die Umsetzung in größeren Umgebungen mittels 802.1X (WPA3-Enterprise) und an kleineren Zugangspunkten oder Gastnetzen durch SAE (WPA3-Personal) erfolgen. Da es sich um eine automatisierte Sicherheitsrichtlinie handelt, ist hier auch die Anforderung zur Überwachung solcher Richtlinien anwendbar. Überwachungskriterien sind hier z.B. die Erreichbarkeit des RADIUS-Servers, die Antwortzeiten, die Last auf Access-Switches und andere Metriken. Für die Überwachung der Integrität ist insbesondere die Authentifizierung oder deren Fehlschlag relevant, z.B. viele abgelehnte Authentisierungen, plötzliche Deaktivierung eines Supplicants. Durch synthetische Anfragen an Testkonten kann die gesamte Authentisierungskette regelmäßig geprüft werden. Die Formulierung "im Einklang mit den Festlegungen des Identitäts- und Berechtigungsmanagements" bedeutet, dass die Authentifizierung so erfolgt, wie in der Praktik IDM festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist.

Links

related: DET.4.4 Änderungen an Sicherheitsrichtlinien

related: DET.3.1.8 Privilegierte Ereignisse

Control: ARCH.4.1.1 - Dynamische Netzzugangskontrolle

Tags: "Network Access Control" "Rogue Access Point" "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.4 Zugangsbeschränkungen

Übergeordnetes Control:

ARCH.4.1 Netzzugangskontrolle

UUID: fec4fcdf-13e7-4a32-a3e1-52dce90ea1d7

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Architektur für Interne Netzsegmente SOLLTE den Zugriff von IT-Systemen auf das Netzsegment anhand {{ insert: param, arch.4.1.1-prm1 }} im Einklang mit den zugehörigen Anforderungen des Identitäts- und Berechtigungsmanagements authentifizieren.

Guidance

Bei der dynamischen Netzzugangskontrolle (Posturing oder Dynamic NAC) wird vor dem Netzzugang auch der Zustand des IT-Systems geprüft, z.B. der aktuelle Patch-level des Systems oder von Erkennungssignaturen. Hierzu gehört auch die softwaredefinierte Netzzugangskontrolle, die dynamisch auf Aktivitäten des Systems oder aktuelle Threat Intelligence reagieren kann. Empfehlenswert ist es hierbei, die Konfiguration der Systeme automatisiert vorzunehmen, z.B. über eine automatische Supplicant-Konfiguration beim Rollout und die Zuweisung von Zertifikaten über Enrollment-Dienste. Die Formulierung "im Einklang mit den Festlegungen des Identitäts- und Berechtigungsmanagements" bedeutet, dass die Authentifizierung so erfolgt, wie in der Praktik IDM festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist.

Control: ARCH.4.1.2 - Quarantäne

Tags: "Network Access Control" "Rogue Access Point" "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.4 Zugangsbeschränkungen
Übergeordnetes Control:
ARCH.4.1 Netzzugangskontrolle
UUID: 5f97efff-4db1-4b26-8ab9-4521108e5c0c
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Architektur für Interne Netzsegmente KANN ein Quarantänenetz für nicht authentifizierte IT-Systeme installieren.

Guidance

Wenn Systeme aufgrund bestimmter Voraussetzungen sich nicht authentifizieren (z.B. installierte Sicherheitsupdates oder weil sie keine 802.1X-Anmeldung unterstützen), kann ein vollständiges blockieren aller Netzverbindungen die Verfügbarkeit erforderlicher Geschäftsprozesse unmöglich machen. Um IT-Systemen einen eingeschränkten Zugang zu Netzressourcen zu ermöglichen – etwa damit diese die Voraussetzungen durch den Download von Updates erfüllen können – kann ein Quarantänenetz eingerichtet werden, das z.B. Zugang zu bestimmten Downloadservern oder eine Meldung des Problems ermöglicht.

Control: ARCH.4.2 - Autorisiertes Routing

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.4 Zugangsbeschränkungen
UUID: 77aebab8-462b-4849-aaa2-9c939af5e1dc
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE Routing-Verbindungen durch {{ insert: param, arch.4.2-prm1 }} autorisieren.

Guidance

Dient der Kontrolle von Netzarchitekturen, um unbeabsichtigte oder böswillige Änderungen zu verhindern. Ohne eine solche Freigabe könnte ein Angreifer durch unbemerkte Manipulation von Routing-Einträgen den Datenverkehr umleiten, abhören oder blockieren; auch ein ungeschulter Administrator könnte versehentlich falsche Routen konfigurieren, wodurch kritische Dienste ausfallen könnten. Die Autorisierung kann sicherstellen, dass jede Änderung nachvollziehbar geprüft, dokumentiert und nur nach sachgerechter Bewertung umgesetzt wird, wodurch die Integrität und Verfügbarkeit der Netze erhöht werden kann. Im konkreten Kontext bedeutet „Routing-Verbindungen“ die Konfiguration von Pfaden, über die Datenpakete zwischen Netzsegmenten oder über Gateways weitergeleitet werden. „Autorisieren“ bedeutet hier die formale Freigabe nach einer sachlichen und fachlichen Prüfung, typischerweise durch Rollen wie (1) Netzwerkarchitekt, (2) IT-Sicherheitsbeauftragter oder (3) Leiter IT-Betrieb. Eine Institution kann dies umsetzen, indem sie (1) eine dokumentierte Freigabeprozedur für alle Routing-Änderungen etabliert, (2) Änderungen technisch über ein Ticket- oder Change-Management-System prüfen und protokollieren lässt, (3) rollenbasierte Zugriffsrechte in Routern und Firewalls so einschränken kann, dass nur autorisierte Personen Konfigurationsänderungen durchführen, und (4) automatisierte Plausibilitätsprüfungen oder Peer-Reviews nutzen kann, um fehlerhafte oder unsichere Routen frühzeitig zu erkennen. Die Autorisierung kann entweder einzelne Routen (z.B. für Netz A zwischen Router B und C), als auch bestimmte Routing-Regeln (z.B. Default-Routing über die zentrale Firewall) autorisieren. Sinnvoll ist es dabei das Prinzip "so allgemein wie für den Betrieb nötig, so spezifisch wie für die Sicherheit möglich" als Faustregel anzuwenden. Bei der Ver-

wendung dynamischer Routing-Algorithmen kann die Anforderung umgesetzt werden, indem eingeschränkte Bereiche freigegeben werden, z.B. "dynamisches Routing im Bereich 10.x.x.x)".

Control: ARCH.4.3 - Authentifizierung von Routingprotokollen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.4 Zugangsbeschränkungen
UUID: 739ad3ad-cbbc-4809-9f20-1c59e85c864b
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE Änderungen an Routing-Tabellen im Einklang mit den zugehörigen Anforderungen des Identitäts- und Berechtigungsmanagements authentifizieren.

Guidance

Hierzu zählt z.B. die Authentifizierung von BGP/OSPF-Sitzungen zur Verhinderung von Route Hijacking, BGP origin validation with RPKI oder OSPF/ISIS/BGP MD5 or TTL+hMAC authentication. Die Formulierung "im Einklang mit den Festlegungen des Identitäts- und Berechtigungsmanagements" bedeutet, dass die Authentifizierung so erfolgt, wie in der Praktik IDM festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist.

Control: ARCH.5.1 - Einschränkung und Inspektion von Verbindungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
UUID: 025c298a-7c8d-441d-b9d5-a1422556c6e1
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- ARCH.5.1.10 Webfilterung
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.13 Produktdiversität

Statement

Architektur für Netze SOLLTE Verbindungen zwischen IT-Systemen einschränken.

Guidance

Über Netverbindungen können unbeabsichtigte Verbindungen aufgebaut werden oder netzbasierte Angriffe über das Internet gegen die Institution erfolgen. Unerwünschter Datenverkehr nach außen können z.B. private IP-Adressen (RFC 1918 leakage), Multicasting, TCP/UDP Ports für veraltete, angreifbare Protokolle oder ICMP-Verkehr sein. Die Beschränkung der Verbindung zwischen IT-Systemen kann sowohl durch zustandsbehaftete Paketfilter, als auch mit Application Layer Gateways umgesetzt werden. Empfehlenswert ist eine Kombination aus Allowlisting, IP-Reputationslisten, Deep Packet Inspection und Durchsatzratenbegrenzung.

Hierbei können Verbindungen auch nach Kategorien autorisiert werden (z.B. anhand von IP-Subnetzen oder Voraussetzungen wie per Zertifikat authentifizierten IT-Systemen). Damit dabei keine unnötigen Verbindungen zugelassen werden, ist es wichtig, die Kategorisierung möglich genau zu wählen (z.B. möglichst einzelne Subnetze statt des ganzen Netzes oder nur bestimmte Ports oder Anwendungen zuzulassen).

Control: ARCH.5.1.1 - Blockieren anfälliger Netzprotokolle

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: b4977fc1-727c-41c8-a397-f84ba68fc11a
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE anfällige Netzwerkprotokolle blockieren.

Guidance

Anfällig sind Netzprotokolle, wenn sie veraltete oder gar keine Algorithmen zur Verschlüsselung oder Integritätsprüfung verwenden. Hierzu gehören Protokolle wie Telnet, SMB v1, SNMP v1/v2c. Für aktuelle Verschlüsselungsalgorithmen siehe BSI TR 02102.

Control: ARCH.5.1.2 - Netzbasierte Angriffe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: 09d37d0c-fda7-4f38-9aa6-f8cbae7d878d
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE bekannte netzbasierte Angriffsmethoden blockieren.

Guidance

Netzbasierte Angriffe verwenden Netzwerktechnologien (typischerweise auf OSI Layer 2-3), z.B. Fragmentierungsangriffe. Beispiele für mögliche Maßnahmen sind DHCP snooping, ARP/Dynamic ARP Inspection, IP-source guard, BPDU guard, root guard, port-security (sticky MAC).

Control: ARCH.5.1.3 - TCP-basierte Angriffe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: cc1cf52d-6be3-4e7d-a5c0-6ecce6c282b1
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE bekannte TCP-basierte Angriffsmethoden blockieren.

Guidance

TCP ist das am meisten verwendete Protokoll für die zuverlässige Datenübertragung. Durch TCP-basierte Angriffe können IT-Systeme gehackt oder Daten unbemerkt ausgeleitet werden. Beispiele sind TCP Session Hijacking (ACK-number guessing), Overlapping-Segment Attacks, TCP Reset (RST) Injection, Xmas-tree Scanning. Die Anforderung kann durch Blockieren solcher Verbindungen oder nur bestimmter Mechanismen umgesetzt werden.

Control: ARCH.5.1.4 - UDP-basierte Angriffe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: d2b4e523-ee05-47ae-8d5e-95f30015dce2
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE bekannte UDP-basierte Angriffsmethoden blockieren.

Guidance

UDP-basierte Angriffsmethoden (englisch: known UDP-based attack vectors) sind hierbei Techniken zu verstehen, die das User Datagram Protocol (UDP) ausnutzen. UDP ist das am meisten verwendete Protokoll für die Übertragung von Datenstreams. Aufgrund seiner verbindungslosen Eigenschaft ermöglicht UDP eine sehr schnelle Datenübertragung und wird daher oft für zeitkritische Anwendungen wie Videostreaming, VoIP oder DNS-Anfragen verwendet. Genau diese Eigenschaft macht es jedoch anfällig für Missbrauch, da die Absenderadresse leicht gefälscht werden kann (IP-Spoofing). Beispiele für Angriffe sind Sequence Number Guessing, DHCP Starvation und UDP Hole-Punching Abuse. Die Anforderung kann durch Blockieren solcher Verbindungen oder nur bestimmter Mechanismen umgesetzt werden.

Control: ARCH.5.1.5 - Deaktivierung von Split Tunneling

Tag: "Internet Exposure"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: 7ff5e3bc-64e8-4487-a77a-c4897f97431d
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Externe Netzanschlüsse SOLLTE Split Tunneling blockieren.

Guidance

Um eine durchgehende Kontrolle und Absicherung des Netzverkehrs zu gewährleisten, muss verhindert werden, dass IT-Clients während einer aktiven Verbindung zum internen Netz gleichzeitig ungeschützten Zugriff auf das öffentliche Internet oder andere Netzwerke haben. Dies schließt sogenannte „Split Tunneling“-Konfigurationen aus, bei denen nur ausgewählter Datenverkehr über das VPN geleitet wird, während anderer Datenverkehr (z. B. Webzugriffe) über das lokale Netzwerk oder die Internetverbindung des Clients erfolgt.

Control: ARCH.5.1.6 - Blockieren direkter Management-Verbindungen

Tag: "Internet Exposure"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: 9e1420ba-9cc0-4d0d-a127-36881c1b90e5
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Externe Netzanschlüsse SOLLTE Verbindungen zu Management-Schnittstellen blockieren.

Guidance

Zum Internet offene Management-Schnittstellen werden von Angreifern durch Scans leicht gefunden und sind häufig Ziel von Angriffen. Deshalb ist es sinnvoll, alle eingehenden Verbindungen zu Management-Schnittstellen aus externen Netzen zu blockieren, einschließlich der Verwaltung von VPN- und Firewallsystemen selbst. Wenn eine Administration dieser Systeme aus der Ferne erforderlich ist, so kann dieser Zugriff stattdessen über ein VPN in das interne Netz hergestellt werden, wobei auch hiermit ein erhöhtes Risiko für Angriffe einhergeht.

Control: ARCH.5.1.7 - Edge-Routing

Tag: "Internet Exposure"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: b9019268-f8d4-4820-b744-2c79c31ce75a
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Externe Netzanschlüsse SOLLTE dynamische Routingprotokolle blockieren.

Guidance

Dynamische Routingprotokolle könnten versehentlich oder durch Angriffe unerwünschte Verbindungen ermöglichen. An den Übergängen zu externen Netzen sind statische Default-Routen deshalb die bessere Alternative.

Control: ARCH.5.1.8 - Inspektion verschlüsselter Verbindungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: 657f0690-9aaf-42fb-8474-3986a22277c8
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Architektur für Externe Netzanschlüsse SOLLTE den Inhalt unverschlüsselter und verschlüsselter Verbindungen basierend auf der Art des Inhalts einschränken.

Guidance

Verschlüsselte Verbindungen wie VoIP über TLS oder HTTPS-Anfragen können über Sicherheitsproxies oder die Inspektion auf den Endstellen der Verbindungen inspiert werden. Ein Proxy bzw. Proxy-Server ist ein Vermittler im Netz, der zwischen dem Client und einer Netzressource, wie einer Webseite, fungiert. Er dient als Brücke zwischen dem Client und dem Server, wobei Anfragen und Antworten stellvertretend abgewickelt werden. Proxys können Datenverkehr filtern, blockieren, oder auch speichern, um die Netzwerkleistung zu optimieren. Systeme zur Filterung von Webinhalten gehören zu den häufigsten Arten von Proxyservern, die zur Vermittlung des Internetzugangs eingesetzt werden. Diese Server können TCP-Sitzungen protokollieren und die Zugriffskontrolle durch Blockieren bestimmter URLs, IP-Adressen oder Domännennamen erzwingen. Institutionen können Web-Proxys mit benutzerdefinierten Erlaubnis- und Sperrlisten konfigurieren, um den Zugriff auf der Grundlage von Richtlinien zu regeln. Es ist jedoch zu beachten, dass Proxyserver die Nutzung virtueller privater Netzwerke (VPN) beeinträchtigen und je nach Implementierung Risiken wie Man-in-the-Middle-Angriffe (MitM) mit sich bringen können. Beispiel-Implementierungen sind Squid, Nginx, Privoxy.

Control: ARCH.5.1.9 - Filterung von DNS

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: 4938a7c4-fdbb-4ca8-a33c-87d177d25f8b
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Externe Netzanschlüsse SOLLTE unerwünschte Inhalte in DNS-Verbindungen einschränken.

Guidance

Unerwünschte Inhalte sind DNS-Anfragen oder -Antworten, die für Geschäftsprozesse unnötige oder sogar schädliche Daten enthalten, z.B. Verbindungen zu bekannten Malware-Domains oder zu Werbe- oder Telemetriediensten. Dies kann entweder nach dem Allowlist- oder Denylist-Ansatz erfolgen. Listen bekannter schädlicher Domains können über Threat Intelligence-Feeds oder spezielle DNS-Lösungen wie Pi-hole bezogen werden.

Control: ARCH.5.1.10 - Webfilterung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: 327ca27d-e60f-47d1-8840-5bcb09340030
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste

Statement

Architektur für Externe Netzanschlüsse SOLLTE den Zugriff auf Webinhalte anhand von {{ insert: param, arch.5.1.10-prm1 }} einschränken.

Guidance

Das World Wide Web ist für zahlreiche Geschäftsprozesse essenziell. Andererseits wird das Web von Angreifern auch für die Verbreitung von illegalen Inhalten, Schadprogrammen oder Phishing verwendet. Durch unkontrollierten Webzugriff könnten etwa Schadcode, Phishing oder Datenabfluss in die Institution gelangen. Kriterien meint hier die festgelegten Maßstäbe, nach denen externe Verbindungen zu Webinhalten gefiltert oder eingeschränkt werden. Im Fachjargon spricht man von filtering criteria oder access control policies. Solche Kriterien können beispielsweise Inhaltskategorien (z. B. Glücksspiel, soziale Netzwerke, Streaming), Reputationsbewertungen von Domains (z. B. „malicious“ oder „suspicious“ laut Threat-Intelligence-Feeds), oder technische Eigenschaften (z. B. bekannte IP-Ranges, Länderzugehörigkeit, verwendete Protokolle/Ports, Signaturen) sein. Sinnvoll ist eine Kombination verschiedener Kriterien. Die Anforderung kann über Filterung im Browser, auf Systemen oder an Netzgrenzen umgesetzt werden (z.B. durch Firewalls, Sicherheitsproxies oder VPN-Gateways).

Links

related: KONF.12.1.7 Filtern schädlicher Webinhalte

Control: ARCH.5.1.10.1 - Bekannte schädliche Inhalte

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1.10 Webfilterung
UUID: 3eb3dc59-6fdb-41d2-80da-65490c0156d7
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Architektur für Externe Netzanschlüsse SOLLTE bekannte schädliche Inhalte einschränken.

Guidance

Hierzu gehören beispielsweise Schadprogramme, Phishing, Malware Command & Control Server. Zur Einschränkung kann auf öffentlich verfügbare Sperrlisten für solche Webseiten, auf Filtersysteme spezialisierter Hersteller von Firewalls und ähnlichen Systemen oder auf Daten aus der Threat Intelligence zurückgegriffen werden.

Control: ARCH.5.1.10.2 - Bekannte illegale Inhalte

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.5 Perimeterschutz

Übergeordnetes Control:

ARCH.5.1.10 Webfilterung

UUID: c776fdb1-92b7-4f11-be53-41104fdd71f7

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Architektur für Externe Netzanschlüsse SOLLTE bekannte illegale Inhalte einschränken.

Guidance

Gerade bei größeren Webdiensten kann es vorkommen, dass hierüber immer wieder vereinzelt illegale Inhalte verbreitet werden, obwohl der Dienst selbst von einer legitimen Institution betrieben wird. In solchen Fällen empfiehlt es sich, die Filterung möglich passgenau vorzunehmen (also soweit möglich nur bestimmte Seiten, Seitenbereiche oder Subdomains zu filtern) und den Anbieter über die illegalen Inhalte zu informieren.

Control: ARCH.5.1.10.3 - Speicherdienste

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.5 Perimeterschutz

Übergeordnetes Control:

ARCH.5.1.10 Webfilterung

UUID: 205d7828-80e7-4f02-963c-582a8a38eb4d

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Architektur für Externe Netzanschlüsse SOLLTE Speicherdienste einschränken.

Guidance

Ausnahmen können sinnvoll sein, wenn es nach den Geschäftsprozessen erforderlich ist, die Daten öffentlich zur Verfügung zu stellen oder diese mit anderen Institutionen über den Speicherdienst auszutauschen.

Control: ARCH.5.1.11 - P-A-P-Struktur

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: bd23cb10-ab1e-42b2-81bc-b7c1705fb16a
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Architektur für Externe Netzanschlüsse SOLLTE eine P-A-P-Struktur für eingehende und ausgehende Verbindungen installieren.

Guidance

Die P-A-P-Struktur besteht aus 2 Paketfiltern (P) und einem Filter auf Anwendungsebene (A), die durch Hardware getrennt sind und alle Verbindungen auf Anwendungsebene filtern. In Hardware getrennte Systeme sind hier solche, die jeweils über eigene Rechenkomponenten (CPU, RAM, etc.) verfügen und nur über Netzverbindungen zusammenhängen. Dies minimiert die Angriffsfläche für übergreifende Angriffe wie Covert Channel oder Side Channel.

Control: ARCH.5.1.12 - Software-definierte Verbindungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: e1e4bec9-8dc4-4062-a025-6ea70eedb9c9
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Architektur für Netze KANN Verbindungen zwischen IT-Systemen anhand dynamischer Kriterien einschränken.

Guidance

Software-definierte Verbindungen sind logisch kontrollierte Netzwerkpfade, deren Zugriffsbedingungen nicht statisch hinterlegt, sondern anhand aktueller Merkmale bewertet werden; dynamische Kriterien meint dabei festgelegte Filterregeln, deren Werte situativ ermittelt werden, etwa über „context attributes“ oder „dynamic policies“. Solche Merkmale können als contextual signals wie momentane Auslastung, Gerätezustand („device posture“) oder zeitliche Rahmenbedingungen interpretiert werden, während die zugrunde liegenden Regeln unverändert bleiben und nur ihre Bewertung variiert. Dies kann helfen, laterale Bewegungen einzudämmen und kann gleichzeitig unerwartete Zugriffe in veränderten Betriebszuständen abblocken; ein Angriff, der unentdeckt Systeme durchqueren könnte, oder ein kompromittierter Client, der außerhalb definierter Parameter agiert, könnte dadurch abgewehrt werden. Praktisch kann dies über segmentierende „Software-Defined Networking“-Mechanismen, kontextabhängige Firewall-Policies oder adaptive Access-Control-Engines erfolgen. Eine angemessene Absicherung ist hier zu verstehen als ein Bündel verlässlicher Signale, die den Zustand eines Endpunkts oder Dienstes authentisch widerspiegeln. Als Varianten kommen etwa kontextabhängige SDN-Flows, regelbasierte Mikrosegmentierung über Identity-Tags oder der Einsatz von Policy-Engines infrage, die ihre Entscheidungen anhand dynamisch erfasster Werte wie Geräteintegrität, Standort oder Risikobewertung fällen.

Control: ARCH.5.1.13 - Produktdiversität

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
Übergeordnetes Control:
ARCH.5.1 Einschränkung und Inspektion von Verbindungen
UUID: 32682181-5136-4d4b-8466-3fd3a1d3b03c
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Architektur für Externe Netzanschlüsse KANN für die Filterung diverse Produkte unterschiedlicher Hersteller für eingehende und ausgehende Verbindungen installieren.

Guidance

Wenn nur gleichartige Filtersysteme verwendet werden, könnten Angreifer eine Schwachstelle zweimal hintereinander ausnutzen, um Netzzugang zu erhalten. Der Einsatz verschiedener, voneinander unabhängiger Hersteller hintereinander verringert die Wahrscheinlichkeit, dass beide Systeme gleichzeitig anfällig sind.

Control: ARCH.5.2 - Blockieren direkter öffentlicher Verbindungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.5 Perimeterschutz
UUID: b94287af-31a1-4500-a8da-89583fdaef92
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Architektur für IT-Systeme SOLLTE direkte Verbindungen von diesen ins öffentliche Netz blockieren.

Guidance

Direkte Verbindungen sind hier alle Verbindungen, die nicht von der Filterung erfasst werden. Die Anforderung ist für Firewallsysteme umgesetzt, wenn deren eingehende Verbindungen ebenfalls vollständig gefiltert werden, bevor sie Daten an Systemschnittstellen senden können.

Control: ARCH.6.1 - Kontrollierte Verbindungsführung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.6 Vertraulichkeit und Integrität im Weitverkehrsnetz

UUID: acd884af-7aad-470c-bfcf-216cff90e9be

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Architektur für Externe Netzanschlüsse KANN eine {{ insert: param, arch.6.1-prm1 }} kontrollierte Verbindungsführung für Weitverkehrsverbindungen aktivieren.

Guidance

Unter einer physisch kontrollierten Verbindungsführung kann in diesem Kontext die Verwendung dedizierter Leitungswege (Dark Fiber), sowie Hardware-Komponenten wie Router, Firewalls oder Trennstellen verstanden werden, die den Zugriff auf Leitungen oder Ports unmittelbar begrenzen. Eine logisch kontrollierte Verbindungsführung kann durch softwarebasierte Mechanismen wie VLANs, VPN-Tunnel oder Routing-Regeln erfolgen, die den Datenverkehr unabhängig von der physischen Leitung steuern. Ohne eine kontrollierte Verbindungsführung könnte ein Angreifer über eine ungeschützte oder direkt angebundene Leitung in interne Systeme eindringen und dort Schadsoftware platzieren, Daten manipulieren oder vertrauliche Informationen abziehen. Ebenso könnte durch eine unzureichend kontrollierte Verbindung ein Ausfall der Netzstabilität eintreten, etwa wenn über eine falsch konfigurierte Schnittstelle großflächiger Datenverkehr einbricht und produktive Systeme beeinträchtigt. Eine kontrollierte Architektur kann dagegen Angriffsflächen reduzieren, Datenströme nachvollziehbar machen und die Sicherheit der Informationsflüsse zwischen Institution und externen Partnern oder Netzanbietern erhöhen. Die Umsetzung kann beispielsweise durch klar definierte Übergabepunkte zum externen Netz erfolgen, an denen sämtliche eingehenden und ausgehenden Verbindungen zentral zusammenlaufen und durch Filter- oder Segmentierungsmechanismen geprüft werden.

Control: ARCH.6.2 - Verschlüsselung von Weiterverkehrsverbindungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.6 Vertraulichkeit und Integrität im Weitverkehrsnetz
UUID: 1999335e-7d66-4dc5-8960-8115234e8e23
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Externe Netzanschlüsse SOLLTE Verbindungen ins Weitverkehrsnetz nach {{ insert: param, arch.6.2-prm1 }} verschlüsseln.

Guidance

Ohne ein etabliertes Verschlüsselungsverfahren könnte sensible Kommunikation im Klartext übertragen werden, was Angreifern ein einfaches Mitlesen ermöglichen könnte – etwa durch Abhören in einem öffentlichen WLAN, durch kompromittierte Router eines Providers oder durch staatliche Massenüberwachung. Auch die unbemerkte Manipulation von Datenpaketen auf dem Weg zwischen Institution und Gegenstelle könnte die Integrität der übermittelten Inhalte gefährden und beispielsweise zu manipulierten Geschäftsdaten oder Schadcode-Einschleusungen führen. Der Einsatz von anerkannten Standards zur Verschlüsselung kann Vertraulichkeit und Integrität wahren, indem die Inhalte für Unbefugte unlesbar bleiben und Kommunikationspartner einander zuverlässig identifizieren können. So kann beispielsweise sichergestellt werden, dass eine entfernte Niederlassung tatsächlich mit der Zentrale verbunden ist und nicht mit einem Angreifer, der den Datenverkehr umleitet. Im Kontext externer Netzanschlüsse bezeichnet „Weitverkehrsnetz“ typischerweise öffentliche Netze wie das Internet oder auch gemietete WAN-Verbindungen über Telekommunikationsanbieter, die institutionsextern betrieben und potenziell unsicher sind. Anerkannte Standards sind z.B. TLS, IPsec oder WireGuard, die regelmäßig überprüft und weit verbreitet eingesetzt werden. Eine Institution kann diese Anforderung durch konkrete Maßnahmen umsetzen, z. B. indem sie Site-to-Site-VPNs zwischen Standorten einrichtet, Remote-Zugriffe von Mitarbeitenden ausschließlich über VPN-Gateways mit Zwei-Faktor-Authentisierung ermöglicht und auch Cloud-Dienste konsequent über gesicherte Verbindungen anbindet.

Control: ARCH.7.1 - Dedizierte Hostsysteme für Server

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.7 Dedizierte Systeme
UUID: dbc89a40-82e3-48c7-9422-ce8f874ca1cf
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Anwendungen SOLLTE Serverdienste ausschließlich auf für die Anwendung dedizierten {{ insert: param, arch.7.1-prm1 }} Hostsystemen platzieren.

Guidance

„Serverdienste“ bezeichnen hier die logisch oder physisch abgegrenzten IT-Services (engl. server services), die bestimmte Funktionalitäten einer Anwendung bereitstellen, etwa Datenbankinstanzen, Webserver-Komponenten oder API-Endpunkte. Ein „dediziertes Hostsystem“ (engl. dedicated host system) ist dabei ein physischer oder virtueller Server, der ausschließlich für eine einzelne Anwendung und deren zugehörige Serverdienste betrieben wird, ohne dass darauf weitere fachfremde oder von der Anwendung unabhängige Dienste ausgeführt werden. Mögliche Bereitstellungsformen können virtualisierte Maschinen, Container-fähige Hypervisor-Instanzen, Bare-Metal-Server oder Appliances sein. Diese Abgrenzung dient der klaren Trennung von Verantwortlichkeiten, Konfigurationen und Ressourcen und reduziert die Komplexität innerhalb der Systemlandschaft. Sie schafft eine saubere Zuordnung zwischen Anwendung und ihrer technischen Plattform, was die Nachvollziehbarkeit, Wartbarkeit und Sicherheit der jeweiligen Lösung deutlich erhöht. Ziel ist, dass nicht mehrere Server-Anwendungen auf einem Betriebssystem (oder sogar auf Endgeräten) laufen, um systemische Risiken zu minimieren, die aus Mehrfachnutzung oder unklarer Ressourcenteilung entstehen könnten. Sonst könnte es etwa durch unerwartete Wechselwirkungen zwischen Diensten, fehlerhafte Berechtigungszuweisungen, unbeabsichtigte Seitenkanäle, unkontrollierte Ressourcenkonflikte oder Abhängigkeiten bei Systemupdates zu Betriebsproblemen oder lateralen Bewegungen von Angreifenden kommen. Die Anforderung kann auch durch die Verwendung von virtuellen Maschinen oder Containern realisiert werden.

Control: ARCH.7.2 - Dedizierte Hardware

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.7 Dedizierte Systeme
UUID: 85fe83c0-ac96-43c8-b2a9-98059b801b73
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Architektur für Hostsysteme KANN diese auf dedizierter Hardware platzieren.

Guidance

Um die Verfügbarkeit ausreichender Ressourcen sicherzustellen und zyklische Abhängigkeiten zu vermeiden (z.B. einen VM-Host, dessen Domain Controller auf ihm selbst virtualisiert wird).

Control: ARCH.7.3 - Entwicklungs- und Testumgebungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.7 Dedizierte Systeme
UUID: 15bdb341-c907-4daa-9e39-1dc3777ef9bc
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Architektur für Virtualisierungslösungen SOLLTE Entwicklungs- und Testumgebungen nicht auf produktiven Hostsystemen platzieren.

Guidance

Entwicklungs- und Testumgebungen sind dabei Umgebungen, in denen Software noch nicht ausgereift ist, sondern aktiv entwickelt, angepasst oder erprobt wird. Der Sinn der Vorgabe liegt darin, dass instabile oder absichtlich manipulierbare Testsysteme nicht auf denselben Hostsystemen betrieben werden sollten, auf denen produktive Anwendungen laufen. Andernfalls könnte ein Fehler in experimenteller Software dazu führen, dass der Hypervisor oder das Host-Betriebssystem beeinträchtigt wird und produktive Daten oder Dienste in Mitleidenschaft gezogen werden. Ebenso könnte Schadcode, der in einer Testumgebung eingebracht wird, unerwartet in produktive Netze durchgreifen. Durch die Trennung kann sichergestellt werden, dass ein Ausfall oder eine Kompromittierung in Entwicklungsumgebungen nicht die Stabilität und Vertraulichkeit produktiver Systeme gefährdet. Zur praktischen Umsetzung kann eine Institution Entwicklungs- und Testumgebungen auf dedizierte Virtualisierungshosts auslagern, die physisch oder logisch getrennt von den produktiven Hosts betrieben werden. Zusätzlich kann eine Institution Richtlinien zur Lifecycle-Kennzeichnung von VMs einführen (z. B. „dev“, „test“, „prod“ im Namen oder Tagging), um die klare Trennung auch in größeren Umgebungen praktikabel zu machen.

Links

related: TEST.3.1.4 Testumgebung

Control: ARCH.8.1 - Redundanz im Kernnetz

Tags: "Hochverfügbarkeit" "Failover"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.8 Ausfallsicherheit

UUID: 37f932b2-e132-4bf0-b8c3-eed73eadc680

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE für das Kernnetz redundante Netzkomponenten installieren.

Guidance

Ziel hierbei ist es, dass beim Ausfall eines Systems oder einer Systemkomponente die Netzanbindung stets weiterhin funktionsfähig bleibt (Single-Point-of-Failure).

Control: ARCH.8.2 - Redundante TK-Anbindung

Tags: "Hochverfügbarkeit" "Failover" "PSTN"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.8 Ausfallsicherheit

UUID: 11904e1d-22f5-4855-b2b4-5b82a423c2d7

Aufwand: 4

Sicherheitsstufe: erhöht

Statement

Architektur für Externe Netzanschlüsse KANN redundante TK-Anbindungen für eingehende und ausgehende Verbindungen installieren.

Guidance

Telekommunikationsanbindungen sind z.B. SIP-Trunks zum öffentlichen Telefonnetz (PSTN). Für weitere Details siehe „Kompendium für organisationsinterne Telekommunikationssysteme mit erhöhtem Schutzbedarf“.

Control: ARCH.8.3 - Redundante Server

Tags: "Hochverfügbarkeit" "Failover"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.8 Ausfallsicherheit
UUID: d1a0c0ac-dc2e-4d90-b67d-b76eec256915
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Architektur für Anwendungen KANN für die Funktionsfähigkeit der Anwendung erforderliche Hostsysteme redundant installieren.

Guidance

Redundanz ist gegeben, wenn sowohl das System als auch seine Netzanbindung redundant vorhanden sind. Das System selbst ist nur redundant, wenn auch seine Datenspeicher und Stromversorgung redundant ausgelegt sind. Automatische Umschaltung meint das Failover. Die Anforderung kann durch netzbasierte Load Balancer oder serverseitige automatisch Umschaltung umgesetzt werden (z.B. durch Hello-Pakete).

Control: ARCH.9.1 - Dimensionierung der Netzanbindung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.9 Kapazitätsmanagement
UUID: 82cfd8da-b3d8-4b87-8770-f39aaf7de728
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Architektur für Netze SOLLTE eine bedarfsgerechte Netzanbindung installieren.

Guidance

Für die Verfügbarkeit und Leistungsfähigkeit kritischer Geschäfts- und Fachverfahren ist eine bedarfsgerechte Netzanbindung erforderlich. Durch das strukturierte Erfassen des Bedarfes kann eine Institution frühzeitig Engpässe erkennen, Ausfallrisiken minimieren und eine wirtschaftliche Auslegung ihrer Anschlüsse erreichen. Gleichzeitig lässt sich so eine belastbare Grundlage für Kapazitäts-, Notfall- und Budget-Planungen schaffen, ohne sich allein auf starre Hersteller- oder Provider-Vorgaben zu verlassen. Relevant ist hierbei die gesamte Netzstrecke zwischen Servern und IT-Clients, zumindest bis zum Internet-Anschluss der Institution. Beispiele für den Anwendungsbereich können sehr unterschiedlich ausfallen: In einem Call-Center kann sich der Bedarf aus der Anzahl zeitgleich aktiver Soft-Phones ableiten, deren Codec-Bandbreite sowie der gewünschten Gesprächsqualität (Latenz < Antwortzeit in ms). In einem Forschungslabor kann die Anbindung darauf basieren, dass täglich große Datensätze mit einer bestimmten maximalen Bandbreite in Gbit/s zu Kooperationspartnern repliziert werden. Auch eine E-Learning-Plattform kann berücksichtigen, dass zu Semesterbeginn Studierende gleichzeitig parallele Video-Streams in HD abrufen, während administrative Dienste weiterhin innerhalb einer bestimmten Antwortzeit in ms reagieren sollen. Dabei ist es sinnvoll, die Netzanbindung an realistische Belastungsszenarien anzupassen.

Control: ARCH.9.2 - Lastverteilung

Tag: "Hochverfügbarkeit"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.9 Kapazitätsmanagement
UUID: 50e54872-271e-41b4-b54a-50e9ebab82bd
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Architektur für Anwendungen KANN eine {{ insert: param, arch.9.2-prm1 }} automatische Lastverteilung aktivieren.

Guidance

Netzbasierte Lastverteilung bedeutet hier, dass ein dedizierter Netzwerkdienst – z. B. über Load-Balancer oder Layer-4/Layer-7-Komponenten – den eingehenden Datenverkehr dynamisch auf mehrere Server oder Dienste verteilt. Serverbasierte Lastverteilung bedeutet dagegen, dass die beteiligten Systeme selbst Mechanismen bereitstellen, um Anfragen untereinander weiterzugeben oder zu koordinieren, etwa durch eingebaute Proxy- oder Cluster-Funktionalitäten. Der Zweck einer solchen Verteilung liegt in der Absicherung der Verfügbarkeit: Ein plötzlicher Anstieg von Benutzeranfragen könnte ansonsten einzelne Systeme überlasten und zu Ausfällen führen; ebenso könnte ein Defekt in einem Knoten die Gesamtleistung stark beeinträchtigen. Mit geeigneter Lastverteilung kann die Stabilität der Anwendung verbessert und ein unterbrechungsfreier Betrieb unterstützt werden. Zur Umsetzung kann die Institution netzbasierte Verfahren einsetzen, etwa (1) hardware- oder softwaregestützte Load-Balancer, die eingehende Verbindungen nach konfigurierbaren Regeln verteilen, (2) DNS-basierte Verfahren, bei denen Abfragen gezielt auf unterschiedliche Zielsysteme geleitet werden, oder (3) virtuelle Appliances in virtualisierten oder Cloud-nahen Umgebungen. Serverbasierte Verfahren können etwa durch den Einsatz von Cluster-Software, eingebaute Reverse-Proxy-Funktionen in Webservern oder den Einsatz von Message-Queues realisiert werden. Dabei kann eine Institution darauf achten, dass Monitoring-Funktionen integriert sind, um Engpässe frühzeitig zu erkennen, und dass Konfigurationen für Failover-Szenarien getestet werden. Auch ein gestuftes Testen der Lastverteilung unter realitätsnahen Bedingungen kann helfen, die Wirksamkeit sicherzustellen.

Control: ARCH.9.3 - Automatische Skalierung

Tags: "Hochverfügbarkeit" "DDoS"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ARCH.9 Kapazitätsmanagement
UUID: bbfa749a-99a4-4ff3-9cce-5ceeb3162596
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Architektur für Anwendungen KANN eine automatische Skalierung der von der Anwendung verwendeten Computerinstanzen anhand von {{ insert: param, arch.9.3-prm1 }} aktivieren.

Guidance

Automatische Skalierung ist die Fähigkeit einer Anwendungsarchitektur, die Anzahl der von einer Anwendung genutzten Serverinstanzen dynamisch und automatisiert zu erhöhen oder zu verringern. Grundlage für diese Anpassungen sind definierte Schwellwerte, die beispielsweise auf Metriken wie CPU-Auslastung, Speichernutzung oder Antwortzeiten beruhen können. Damit wird festgelegt, bei welchen messbaren Bedingungen zusätzliche Server gestartet oder wieder abgeschaltet werden. Typische Werte für Schwellwerte können etwa „80 % durchschnittliche CPU-Auslastung über 5 Minuten“, „weniger als 500 MB freier Arbeitsspeicher“ oder „Antwortzeit über 2 Sekunden bei mehr als 100 gleichzeitigen Anfragen“ sein. Ohne Auto-Scaling könnte es vorkommen, dass Anwendungen unter hoher Last nicht mehr reagieren, Datenverlust entsteht oder ganze Dienste für Nutzer unerreichbar werden. Umgekehrt kann Auto-Scaling helfen, Kosten und Ressourcen zu optimieren, indem ungenutzte Server wieder abgeschaltet werden. Eine sinnvolle Umsetzung kann beispielsweise durch den Einsatz von cloudbasierten Skalierungsgruppen erfolgen, die auf klar definierte Metriken reagieren, oder durch Virtualisierungsplattformen, die zusätzliche Instanzen automatisch bereitstellen. Praktische Tipps sind etwa (1) die Definition realistischer und getesteter Schwellwerte auf Basis historischer Lastprofile, (2) die Einrichtung von Stresstests, um das Verhalten bei Erreichen der Schwellwerte zu validieren, und (3) die Einführung von Alarmierungen, die Administratoren über ungewöhnlich häufiges Hoch- oder Runterskalieren informieren können. So kann die Institution sicherstellen,

dass Auto-Scaling verlässlich funktioniert und gleichzeitig eine ökonomische Ressourcennutzung gewährleistet bleibt.

Control: ARCH.9.4 - Content Delivery Network

Tags: "Hochverfügbarkeit" "DDoS"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.9 Kapazitätsmanagement

UUID: 4b5b81aa-fe5f-47f5-a081-136145f7ccc9

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Architektur für Anwendungen KANN ein Content Delivery Network installieren.

Guidance

Ein Content Delivery Network (CDN) ist ein Netz geographisch verteilter Server, welches Inhalte wie Webseiten und große Mediendateien auch bei hoher Last skaliert zur Verfügung stellt. CDNs sind sinnvoll für weltweit hochverfügbare Server-Anwendungen, da so Lastspitzen und DDoS-Angriffe abgemildert werden. Ein CDN kann selbst umgesetzt oder durch einen entsprechenden Dienstleister übernommen werden.

Control: ARCH.9.5 - Schutz gegen volumetrische DoS-Angriffe

Tags: "Hochverfügbarkeit" "DDoS"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ARCH.9 Kapazitätsmanagement

UUID: ac441ef0-08de-40c4-b600-8be20d8a55b1

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Architektur für Netze KANN Schutzmaßnahmen gegen volumetrische DoS-Angriffe aktivieren.

Guidance

Volumetrische Angriffe können z.B. durch die Verwendung von Anycast-DNS, Upstream Rate Limiting, On-Premise- oder Cloud-Scrubbing, BGP FlowSpec-Filter, Auto-Null-Routing oder Remotely Triggered Blackholing abgewehrt werden.

Control: BER.1.1 - Verfahren und Regelungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.1 Grundlagen
UUID: 16d497ce-da97-4c76-89a6-33f53a71d381
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BER.1.1.1 Dokumentation
- BER.1.1.2 Zuweisung der Aufgaben
- BER.1.1.3 Bekanntgabe

Statement

Berechtigung MUSS Verfahren und Regelungen zum Identitäts- und Berechtigungsmanagement verankern.

Guidance

Ziel ist einen dokumentierten Prozess einzurichten, der die Vergabe, Verwaltung und Entfernung von Zugangs- und Zugriffsberechtigungen, sowie der damit verbundenen Identitäten regelt. Zu berücksichtigen sind insbesondere Neueinstellungen, Versetzungen und Entlassungen. Empfehlenswert ist es, die Vergabe und den Entzug von Berechtigungen so weit wie möglich zu automatisieren. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Control: BER.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.1 Grundlagen

Übergeordnetes Control:

BER.1.1 Verfahren und Regelungen

UUID: 552ed210-7580-4b3e-91f3-72f46b75406c

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Berechtigung MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: BER.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.1 Grundlagen

Übergeordnetes Control:

BER.1.1 Verfahren und Regelungen

UUID: 9d1f9325-ae2e-471f-8ce1-b05def44443c

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Berechtigung MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, ber.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es, die Zuweisung anhand von Rollen (z. B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: BER.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.1 Grundlagen

Übergeordnetes Control:

BER.1.1 Verfahren und Regelungen

UUID: 1eb287af-27f5-4cec-b181-1ef3a8135224

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Berechtigung MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: BER.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.1 Grundlagen

UUID: 7ff251bd-78a1-40af-ba57-56f970c0664b

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Berechtigung MUSS die Verfahren und Regelungen {{ insert: param, ber.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante Überprüfung der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: BER.1.3 - Inventar Authentifizierungs- und Autorisierungssysteme

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.1 Grundlagen
UUID: d5b8b9a6-59f5-4ad4-9771-4f090af22fd1
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE ein Inventar der Systeme zur Authentifizierung und Autorisierung dokumentieren.

Guidance

Ein dokumentiertes Inventar der Authentifizierungs- und Autorisierungssysteme kann eine zentrale Grundlage sein, um den Überblick über sicherheitsrelevante Zugangskontrollen zu behalten, sowohl lokal als auch in der Cloud. Solche Systeme sind dafür zuständig zu prüfen, wer Zugriff auf IT-Ressourcen erhält (Authentifizierung) und was dieser Zugriff umfassen darf (Autorisierung). Wird kein vollständiges und gepflegtes Inventar geführt, könnten Schwachstellen unentdeckt bleiben, z.B. veraltete Login-Dienste, falsch konfigurierte Rollen oder Schatten-Identitäten in cloudbasierten Identitätsplattformen. In einem konkreten Vorfall könnte etwa ein ehemals genutzter Verzeichnisdienst (z.B. ein ausgemusterter LDAP-Server) unbemerkt weiterhin aktiv sein und von Angreifern für unautorisierte Zugriffe verwendet werden. Ebenso könnte ein unerkannter Konfigurationsfehler in einem Authentifizierungs-Gateway dazu führen, dass privilegierte Nutzerrollen ohne Zwei-Faktor-Absicherung zugänglich sind. Zu Authentifizierungs- und Autorisierungssystemen zählen beispielsweise Verzeichnisdienste (Directory Services), Identity Provider (IdPs), Single Sign-On-Plattformen (SSO), lokale Passwortdatenbanken sowie API-Gateways mit Zugriffskontrolllogik. Eine Möglichkeit zur Umsetzung kann darin bestehen, auf eine Liste aller Systeme des Informationsverbundes zurückzugreifen und Informationen zum Berechtigungsmanagement zu ergänzen – inklusive ihrer Funktion, angebundenen Anwendungen, unterstützten Protokollen (wie SAML, OAuth2, OpenID Connect) sowie Zuständigkeiten. Die Pflege dieses Inventars kann über ein zentrales Configuration Management Database (CMDB) erfolgen oder alternativ über eine revisionsfähige Tabellenstruktur mit Zugriffskon-

trollen. Hilfreich kann es sein, den Lifecycle einzelner Systeme zu erfassen, etwa ob sich diese in Einführung, Nutzung oder Stilllegung befinden. Ein Abgleich mit dem Rollen- und Rechtemanagement der Institution kann die Konsistenz zusätzlich verbessern.

Links

related: ASST.2.2 Inventar der Systeme

Control: BER.1.4 - Inventar der Berechtigungen

Tag: "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.1 Grundlagen
UUID: c18f2b2d-fb62-42d5-bf73-ec3966ed0fb4
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE ein Inventar der Berechtigungen mit Personen, Identitäten, Zugangskonten, Berechtigungen und deren jeweiliger Zuordnung dokumentieren.

Guidance

Ein Inventar der Berechtigungen kann helfen, Zugriffsrechte innerhalb einer Institution transparent zu machen und unnötige oder riskante Berechtigungen zu erkennen. Es dokumentiert, welche Identitäten – also digitale Repräsentationen von Personen oder Systemen – über welche Konten und Berechtigungen verfügen. So können potenzielle Risiken wie verwaiste Konten oder unautorisierte Privilegien sichtbar werden. Beispielsweise könnte ein ehemaliger Mitarbeitender noch aktive Zugänge besitzen, oder ein Dienstkonto könnte über weitreichende Rechte verfügen, obwohl der Einsatz längst beendet ist – beides kann ein Einfallstor für Missbrauch sein. Relevant sind neben den Berechtigungen von Personen auch Dienstkonten, Cloud-Zugänge und physische Zugangsberechtigungen wie Schlüssel-Schließpläne. Berechtigungen bezeichnen konkrete Zugriffsrechte auf Ressourcen (z. B. Lesen oder Administrieren). Eine Institution kann dies etwa durch einen Verzeichnisdienst, ein zentrales Berechtigungsmanagement oder gepflegte Berechtigungsverzeichnisse abbilden. Die Benennung von Zuständigen je Fachbereich, regelmäßige Überprüfungen und der Einsatz von klaren Rollenkennzeichnungen (z. B. „temporär“, „Admin“) können helfen, das Inventar aktuell und verständlich zu halten. Auch eine strukturierte Offboarding-Checkliste kann sicherstellen, dass veraltete Zugänge rechtzeitig entfernt werden.

Control: BER.2.1 - Person-Identität

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.2 Identitätsmanagement
UUID: f8cb577c-7999-4837-b983-f96e4f33b1b2
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE eine eindeutige Identität zu genau einer natürlichen Person oder einem IT-System zuweisen.

Guidance

Hier wird eine Identität ("muellera") genau einer natürlichen Person ("Andrea Müller") zugewiesen, oder einem IT-System ("pc02348" zu "pc02348.our.domain").

Control: BER.2.2 - Einschränkung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.2 Identitätsmanagement
UUID: e83e80c1-6725-4812-82be-f86dce11d07e
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die Einrichtung, Änderung oder Löschung einer Identität einschränken.

Guidance

Das Identitäts- und Berechtigungsmanagement ist entscheidend für die sichere Authentifizierung vor Zugang zu Informationen. Identitäten sind die Grundlage hierfür. Je nach Organisationsstruktur benötigen z.B. das Personalmanagement oder Administrierende schreibenden Zugang zu Identitäten.

Control: BER.2.3 - Stammdatenprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.2 Identitätsmanagement
UUID: ee2514d4-b2ce-4e97-85e7-a82cdb937e82
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE Stammdaten einer Identität anhand allgemeiner Stammdaten {{ insert: param, ber.2.3-prm1 }} überprüfen.

Guidance

Allgemeine Stammdaten können z.B. sein: Unterlagen der Personalabteilung, Ergebnisse von Netzwerkskans für IT-Systeme, CMDB. Der Abgleich kann auch automatisiert vorgenommen werden.

Control: BER.2.4 - Protokollierung von Stammdatenänderungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.2 Identitätsmanagement
UUID: 7bba1e58-63d0-4588-81dc-f87c512e7e82
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE Änderungen von Identitäts-Stammdaten protokollieren.

Guidance

Zu einem Ereignisprotokoll gehört der Zeitpunkt, das Zugangskonto, sowie welche Änderungen vorgenommen wurden.

Control: BER.2.5 - Deaktivierung bei Weggang

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.2 Identitätsmanagement
UUID: fbc81602-53a3-44a0-a6bf-c83b3ec60964
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die zugeordnete Identität bei Weggang von Nutzenden deaktivieren.

Guidance

Weggang meint hier die nicht nur kurzfristige Beendigung der Aktivitäten der Identität, z.B. bei Kündigung, Elternzeit, Sabbatical. Die Anforderung ist auch umgesetzt, wenn die Identität gelöscht wird. Empfehlenswert ist die Löschung jedoch erst nach Ablauf längerer Löschfristen, um die Nachvollziehbarkeit von Aktionen im Audit Log zu erhalten.

Control: BER.2.6 - Löschen nach Fristablauf

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.2 Identitätsmanagement
UUID: f7541c92-ff46-4d17-9232-2998a41c6613
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE nicht mehr benötigte Identitäten nach Ablauf der Löschfristen löschen.

Guidance

Gesetzliche Aufbewahrungs- und Löschfristen ergeben sich aus dem Compliance-Management, z.B. aus Regelungen der DSGVO oder dem Handels- und Steuerrecht. Sicheres Löschen bedeutet, Daten so zu entfernen, dass sie mit vertretbarem Aufwand (auch forensisch) nicht mehr rekonstruierbar sind. Je nach Medium geschieht das z. B. durch verifizierbares Überschreiben, kryptografisches Löschen (Schlüsselvernichtung) oder physische Zerstörung (inklusive zugehöriger Metadaten, Caches und Datensicherungen).

Control: BER.3.1 - Zentrales Management

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.3 Zugangskonten
UUID: 0aec1964-0172-4194-836b-90fa6d8002ba
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE ein zentrales Managementsystem für Zugangskonten installieren.

Guidance

Wenn Zugangskonten lokal auf jedem Gerät einzeln verwaltet werden, könnte es zu inkonsistenten und veralteten Zugängen und Berechtigungen kommen. Ein zentrales System steuert Benutzeridentitäten und Zugriffsrechte übergreifend – oft als Identity and Access Management (IAM) oder bei sensiblen Konten als Privileged Access Management (PAM) bezeichnet. Es kann die Nachvollziehbarkeit erhöhen, Audits erleichtern und gerade in komplexen IT-Umgebungen Transparenz schaffen. Umsetzbar ist dies etwa über Verzeichnisdienste wie LDAP oder Active Directory, ergänzt durch rollenbasierte Zugriffsmodelle (RBAC). Praktische Maßnahmen zum Management können Self-Service-Portale, automatische Genehmigungsworkflows und regelmäßige Rechteüberprüfungen umfassen. Für den Einstieg kann eine Institution kritische Systeme priorisieren und Prozesse schrittweise zentralisieren.

Control: BER.3.2 - Einschränkung des Managements

Tag: "Change Management"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.3 Zugangskonten

UUID: 6b065020-06dc-4be4-86f7-12371499a6c0

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE das Management von Zugangskonten auf Administrieren-
de einschränken.

Guidance

Management meint hier Aktionen wie z.B. das Erstellen oder Ändern von Metadaten
oder Berechtigungen oder die Löschung des Zugangskontos.

Control: BER.3.3 - Protokollierung von Änderungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.3 Zugangskonten

UUID: 744a1a50-616b-4092-91f6-b2b4b1b0aa01

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE Aktionen an Zugangskonten revisionsfähig protokollieren.

Guidance

Werden Aktionen an Zugangskonten wie die Erstellung, Veränderung von Metadaten oder Berechtigungen, Aktivierung, Deaktivierung oder Löschung von Zugangskonten automatisch protokolliert, so können Sicherheitsverstöße erkannt und nachgewiesen werden. Siehe auch Praktik Detektion.

Control: BER.3.4 - Identität-Zugangskonto

Tag: "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.3 Zugangskonten
UUID: 3aee31a9-78e2-453e-8bce-d4212130dbf7
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE ein Zugangskonto zu genau einer Identität zuweisen.

Guidance

Wenn ein Zugangskonto genau einer Identität zugewiesen ist erleichtert dies die Vergabe von Berechtigungen nach dem Need-to-know-Prinzip. Außerdem kann so bei einem Vorfall nachvollzogen werden, welche Person welche Befehle ausgeführt hat, z.B. mittels des Audit Logs. Anders herum können einer Identität auch mehrere Zugangskonten zugewiesen sein, z.B. ein normales Nutzungskonto und ein Zugangskonto für die Systemadministration.

Control: BER.3.5 - Privilegierte Zugangskonten

Tags: "Zero Trust" "Privilege Escalation" "Insider Threat" "Privilegierte Rechte"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.3 Zugangskonten

UUID: 4791c533-f811-48cf-9957-6e1d438028f5

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung für Administrierende SOLLTE separate Zugangskonten für administrative Tätigkeiten (Administrationskonten) verankern.

Guidance

Zugangskonten mit privilegierten Rechten (Superuser wie z.B. root) könnten durch menschliche Fehler oder Schadcode weitreichende Probleme verursachen. Bewährt hat es sich daher für administrative Tätigkeiten wie die Installation von Anwendungen dedizierte Zugangskonten einzurichten und diese auch nur für derartige Tätigkeiten zu verwenden. Für normale Geschäftsaktivitäten wie E-Mail oder Webbrowser nutzen auch Administrierende dann ausschließlich Zugangskonten ohne administrative Berechtigungen.

Links

related: SENS.10.5 Systemadministration - Internetnutzung

Control: BER.3.6 - Single-Sign-On

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.3 Zugangskonten
UUID: 494391e7-774c-4cc4-b9ed-dc8ab652e83b
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung für Anwendungen SOLLTE die Anmeldung über einen zentralen Identitätsprovider aktivieren.

Guidance

Bei Single Sign-on authentifizieren sich Nutzende bei einem zentralen Identity Provider, der auch die Berechtigungen zur Nutzung der Anwendung prüft. Bei erfolgreicher Authentifizierung und passenden Berechtigungen wird für die Sitzung ein Token ausgestellt, das den Zugang zur Anwendung ermöglicht. Da Nutzende durch Single-Sign-On weniger Anmeldeinformationen benötigen, wird es leichter, sich komplexe Passwörter zu merken oder zentrale gepflegte Schutzmaßnahmen, wie eine Mehr-Faktor-Authentifizierung oder Überwachung von Anmeldeinformationen, auch auf die Anwendung anzuwenden. Zudem erschwert Single-Sign-On auch Phishing-Angriffe, da Anmeldeinformationen nur noch an zentraler Stelle und nicht mehr verstreut in einzelne Anwendungen oder Webseiten abgefragt werden. Andererseits ist bei der Kompromittierung des Single-Sign-On-Logins auch die Authentifizierung an der Anwendung kompromittiert und die Verfügbarkeit der Anwendung hängt auch von der Verfügbarkeit des zentralen Logins ab. Dies kann unter Windows durch Nutzung eines Windows Server Domain Controllers und unter Linux durch Samba mit aktiviertem Heimdal Kerberos Key Distribution Center (KDC) umgesetzt werden.

Control: BER.3.7 - Hinweise bei Anmeldefehlern

Tags: "Credential Stuffing" "Brute-Force-Angriffe"

Info

Control der Klasse "BSI-Stand-der-Technik-Kern"
Gruppe: BER.3 Zugangskonten
UUID: dd5fcc0c-d602-4d15-839c-5adb4fef150e
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung für Anwendungen SOLLTE Hinweise darauf, ob ein Zugangskonto existiert bei erfolglosen Anmeldeversuchen deaktivieren.

Guidance

Den Hinweis, dass bei erfolglosen Anmeldeversuchen das Passwort oder die Kennung falsch ist, könnte ein Angreifer als sogenannte User Enumeration (Benutzerkonten-Aufzählung) oder Account Discovery (Konto-Entdeckung) Schwachstelle ausnutzen. Dadurch wird das Risiko einer Brute-Force-Angriffe oder eines Credential Stuffings erhöht, bei der ein Angreifer eine Liste potenzieller Benutzernamen durchprobieren könnte, um gültige Konten zu identifizieren. Der Schutz kann gewährleisten, dass ein Angreifer nicht automatisch weiß, welche Konten er als Nächstes mit Passwörtern attackieren muss oder Rückschlüsse auf registrierte Zugangskonten erhält. Zur Umsetzung kann die Institution alle Rückmeldungen bei fehlgeschlagenen Anmeldeversuchen so vereinheitlichen, dass sie keinen Aufschluss über den Grund des Fehlschlags geben, beispielsweise durch die generische Nachricht „Der eingegebene Benutzername oder das Passwort ist ungültig.“.

Control: BER.3.8 - Ereignisgesteuerte Deaktivierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.3 Zugangskonten
UUID: 610f7bda-9051-44a0-bc6e-c8cbbac35af0
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE Zugangskonten ereignisgesteuert deaktivieren.

Guidance

Ungenutzte Zugangskonten stellen ein unnötiges Risiko für unberechtigte Zugriffe dar. Werden sie z.B. bei längerer Inaktivität, bei Personalweggang oder bei Verletzung von Richtlinien unverzüglich deaktiviert, so vermindert sich das Risiko eines Missbrauchs erheblich.

Control: BER.3.9 - Anmeldeversuchsgrenze am System

Tags: "Credential Stuffing" "Brute-Force-Attacke"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.3 Zugangskonten
UUID: c37f30d1-8fd7-4497-b3f1-07d8f54b717c
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Berechtigung für IT-Systeme SOLLTE weitere Anmeldeversuche nach Erreichen von {{ insert: param, ber.3.9-prm1 }} fehlgeschlagenen Versuchen vorübergehend blockieren.

Guidance

Betrifft sowohl die lokale Anmeldung über eine Benutzeroberfläche als auch den Zugriff über Fernwartungsprotokolle oder -anwendungen wie RDP, SNMP, wenn diese vorhanden sind. Die Umsetzung erfolgt im einfachsten Fall durch ein Login, bzw. eine Bildschirmsperre für das IT-System. Biometrische Daten wie Fingerabdrücke können gefälscht werden und sind nicht so leicht zu ändern wie Passwörter. Setzen Sie Biometrie daher nicht als einzigen Authentifizierungsfaktor ein, sondern wenn, dann nur zur Ergänzung (Mehr-Faktor-Authentifizierung). Die Anforderung ist entbehrlich, wenn das System keinen Zugriff auf schützenswerte Daten erlaubt, z.B. bei Nutzung als Kiosk.

Control: BER.3.10 - Anmeldeversuchsgrenze an der Anwendung

Tags: "Credential Stuffing" "Brute-Force-Attacke"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.3 Zugangskonten

UUID: 265ee5bc-059a-4bde-b480-9bc1611171bf

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung für Anwendungen SOLLTE weitere Anmeldeversuche nach Erreichen von einem maximalen Schwellwert an fehlgeschlagenen Versuchen vorübergehend blockieren.

Guidance

Häufen sich Anmeldeversuche, so könnte ein Angreifer Zugangsdaten durchprobieren. Durch eine Anmeldeversuchsgrenze wird der Zugriff durch das massenhafte Durchprobieren von Zugangsdaten (Credential Stuffing) verhindert. Dies kann z.B. durch die Begrenzung der Anmeldeversuche pro Client oder pro IP erfolgen. Dies betrifft sowohl die Anmeldung an der Benutzeroberfläche als auch über das Netz. Relevant sind hierbei sowohl primäre als auch ggf. vorhandene sekundäre Zugänge (z.B. Sicherheitsfragen, Passwort zurücksetzen). Für die Wahl des Schwellwertes ist die Anzahl der betroffenen Zugangskonten, die Passwortlänge und der Schutzbedarf der Anwendung von Bedeutung. Je nach Risikoprofil der Anwendung sind verschiedene Lösungen denkbar, z.B. die Verwendung von CAPTCHAS bei Erreichen der Anmeldeversuchsgrenze oder indem der Zeitraum einer Blockierung nach jedem fehlgeschlagenen Anmeldeversuch erhöht wird. Erfordert die Anwendung keine Zugangsdaten, so ist auch diese Anforderung entbehrlich.

Control: BER.3.11 - Systemsperre bei Inaktivität

Tags: "Automatic Session Locking" "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.3 Zugangskonten

UUID: de11e8f3-d1fa-4b11-a6b0-e0d327b42849

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung für IT-Systeme SOLLTE eine Sperre bei Inaktivität nach {{ insert: param, ber.3.11-prm1 }} aktivieren.

Guidance

Kann durch eine Bildschirmsperre oder Abmeldung (Automatic Session Locking) umgesetzt werden. Eine längere Inaktivität kann z.B. 5-15 Minuten lang sein. Verwendet das System keine eigene Authentifizierung, so ist auch diese Anforderung entbehrlich.

Control: BER.3.12 - Sperre der Anwendung bei Inaktivität

Tags: "Automatic Session Locking" "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.3 Zugangskonten

UUID: 5c8bb88d-6692-4904-908a-ed3f7a81b34e

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung für Anwendungen SOLLTE eine Sperre bei Inaktivität nach {{ insert: param, ber.3.12-prm1 }} aktivieren.

Guidance

Kann je nach Anmeldeweg durch eine Abmeldung (Automatic Session Locking) direkt an der Anwendung, über Single-Sign-On oder (bei Anmeldung über das Netz) die Trennung der Netzverbindung umgesetzt werden. Eine längere Inaktivität kann z.B. 5-15 Minuten lang sein. Verfügt die Anwendung über keine eigene Authentifizierungsmethode, so ist die Anforderung entbehrlich.

Control: BER.3.13 - Zugang löschen nach Fristablauf

Tags: "Credential Stuffing" "Brute-Force-Attacke"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.3 Zugangskonten
UUID: 04d6a7fe-9e5a-424b-b647-3e95ce943ce9
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE nicht mehr benötigte Zugangskonten nach Ablauf der Löschfristen löschen.

Guidance

Die Löschfristen ergeben sich aus gesetzlichen Aufbewahrungs- und Löschfristen, die dem Compliance-Management entnommen werden können. Sicheres Löschen bedeutet, Daten so zu entfernen, dass sie mit vertretbarem Aufwand (auch forensisch) nicht mehr rekonstruierbar sind. Je nach Medium geschieht das z. B. durch verifizierbares Überschreiben, kryptografisches Löschen (Schlüsselvernichtung) oder physische Zerstörung (inklusive zugehöriger Metadaten, Caches und Datensicherungen).

Links

related: ASST.7.2 Aufbewahrungs- und Löschfristen

Control: BER.3.14 - Zugang nur durch zwei Personen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.3 Zugangskonten
UUID: cc01c015-42f4-4e42-a986-ad7c954733db
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Berechtigung KANN die Aufteilung von Authentisierungsmitteln auf mehrere Personen verankern.

Guidance

Dient zur Absicherung des Zugriffs auf Daten, deren Vertraulichkeit oder Integrität als hoch einzuschätzen ist, nach dem Vier-Augen-Prinzip. Dazu kann z.B. Person #1 die ersten zehn Stellen eines Passwort kennen und Person #2 die hinteren zehn Stellen eines Passwortes. Oder aber Person #1 erhält einen Hardwaretoken, während Person #2 das Passwort kennt.

Control: BER.3.15 - Keine Gruppenkonten

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.3 Zugangskonten

UUID: 78e70d76-b423-4707-a3c4-27f416fa7d14

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE Gruppenkonten untersagen.

Guidance

Werden Zugangskonten von mehr als einer Person genutzt, so kann später nur noch schwer ermittelt werden, wer eine bestimmte Tätigkeit mit dem Konto ausgeführt hat.

Control: BER.3.16 - Gruppenkonten - MFA

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.3 Zugangskonten

UUID: d59c4b33-c1d6-446a-bb0f-047fe832974d

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE für Gruppenkonten die Mehr-Faktor-Authentisierung aktivieren.

Guidance

Werden trotz des damit verbundenen Risikos Gruppenkonten genutzt, so kann mit Mehr-Faktor-Authentifizierung der Mißbrauch von Zugangsdaten erschwert werden. Kann zum Beispiel durch mehrere dem Zugangskonto zugewiesene Hardwaretoken oder durch OTP-Apps umgesetzt werden. Falls keine Gruppenkonten verwendet werden, so ist die Anforderung entbehrlich.

Control: BER.3.17 - Gruppenkonten - Wechsel dokumentieren

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.3 Zugangskonten
UUID: 8a3e8298-6e99-4fe7-9924-72a910207f4f
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE für Gruppenkonten die Identitäten, welche die Möglichkeit zum Zugriff haben, zum Wechselzeitpunkt dokumentieren.

Guidance

Es kann z.B. anhand von Dienst- oder Anwesenheitsplänen nachvollzogen werden, wer wann theoretisch Zugriff gehabt haben könnte. Werden keine Gruppenkonten verwendet, so ist die Anforderung entbehrlich.

Control: BER.3.18 - Gruppenkonten - Passwortwechsel bei Weggang

Tag: "Password Policy"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.3 Zugangskonten

UUID: 08b7177e-98ce-435f-b9bb-44eade12366b

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE für Gruppenkonten die Änderung von Zugangsdaten bei Weggang von Nutzenden ausführen.

Guidance

Gruppenkonten werden von mehreren Nutzenden (z.B. Schichtdienst) verwendet. Verlassen Nutzende die Institution oder Wechseln das Tätigkeitsfeld und das Passwort des Gruppenkontos wird nicht gewechselt, so besteht die Gefahr, dass das Gruppenkonto unberechtigt verwendet wird.

Control: BER.3.19 - Zwischenspeicherung von Zugangsdaten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.3 Zugangskonten
UUID: 13d83a70-bce9-4027-8d4b-d16ee051cfd5
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung für IT-Systeme SOLLTE die Zwischenspeicherung der Zugangsdaten von Nutzern deaktivieren.

Guidance

Wird die Zwischenspeicherung von Zugangsdaten auf IT-Systemen deaktiviert, so wird Angreifern deren Diebstahl erschwert. Kann unter Windows ab Server 2012 R2 durch Zuweisung aller Zugangskonten zur Gruppe "Geschützte Benutzer" (Protected Users) umgesetzt werden. Konten für Dienste und Computer brauchen nicht Mitglied von „Geschützte Nutzer“ sein.

Control: BER.3.20 - Dienstkonten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.3 Zugangskonten
UUID: 403fac1f-a78a-4548-858e-a06168253dea
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Berechtigung für Hostsysteme SOLLTE eine automatische Verwaltung der Zugangsdaten von Dienste-Konten aktivieren.

Guidance

Eine automatische Verwaltung der Zugangsdaten von Dienste-Konten bezeichnet in diesem Kontext die technische Fähigkeit, Passwörter, Schlüssel oder Tokens solcher Konten – im Englischen häufig als service accounts oder machine identities bezeichnet – durch spezialisierte Systeme ohne manuelles Eingreifen zu erzeugen, zu speichern, regelmäßig zu erneuern und kontrolliert zu verteilen. Zugangsdaten sind hierbei sämtliche Authentifizierungsinformationen, die einem Dienst ermöglichen, auf Ressourcen anderer Systeme zuzugreifen, beispielsweise API-Schlüssel, SSH-Keys oder Anmeldedaten für Datenbanken. Dienste-Konten werden meist von Applikationen, Hintergrunddiensten oder Automatisierungsprozessen genutzt und unterscheiden sich von personenbezogenen Benutzerkonten dadurch, dass sie keinem Individuum zugeordnet sind, sondern einem technischen Zweck dienen. Erfolgt bei Zugangskonten für automatisierte Dienste eine automatische Rotation von Passwörtern oder Anmeldezertifikaten, so werden statische Passwörter, die Ablage von Zugangsdaten auf Netzlaufwerken oder plötzliche Fehlfunktionen durch Zertifikatsablauf vermieden. Ihre automatische Verwaltung kann durch zentrale Passworttresore (password vaults), Identitätsmanagementsysteme (Identity and Access Management, IAM) oder Secret-Management-Lösungen realisiert werden.

Control: BER.3.21 - Notfallzugang

Tags: "BCM" "Privilegierte Rechte"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.3 Zugangskonten
UUID: abdd8f32-ec02-491a-a39b-7b0b25a597ca
Aufwand: 1
Sicherheitsstufe: erhöht

Statement

Berechtigung KANN Notfallzugangskonten installieren.

Guidance

Ein Notfallzugangskonto (sog. Break Glass Account) ist ein Zugang mit privilegierten Berechtigungen, der bei Notfällen als letztes Mittel zum Zugang zu wichtigen Systemen verwendet werden kann, z.B. Verzeichnisdienste, Cloud-Infrastrukturen. Es empfiehlt sich für diese Konten die Verwendung langer Passwörter und die Aufbewahrung dieser z.B. in einem Safe oder aufgeteilt auf mehrere Administrierende.

Control: BER.3.22 - Notfallzugang Verzeichnisdienst

Tag: "BCM"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.3 Zugangskonten
UUID: 7cd7ca02-458d-4348-ae2f-0b096d4078e3
Aufwand: 5
Sicherheitsstufe: normal-SdT

Statement

Berechtigung für Verzeichnisdienste SOLLTE ein Notfallzugangskonto installieren.

Guidance

Ein Notfallzugangskonto (sog. Break Glass Account) ist ein Zugang mit privilegierten Berechtigungen, der bei Notfällen als letztes Mittel zum Zugang zu wichtigen Systemen verwendet werden kann, z.B. Verzeichnisdienste, Cloud-Infrastrukturen. Verwenden Sie für diese Konten lange Passwörter und bewahren Sie diese z.B. in einem Safe oder aufgeteilt auf mehrere Administrierende auf.

Control: BER.4.1 - Identitätsüberprüfung

Tag: "Password Policy"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.4 Authentifizierung
UUID: fb946aab-b392-49b1-bb88-44902c331955
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE eine Identitätsüberprüfung vor dem Zurücksetzen von Passwörtern ausführen.

Guidance

Das unberechtigte Zurücksetzen von Zugangsdaten ist eine bekannte Angriffsmethode. Eine eindeutige Identifizierung des Inhabers des Zugangs z.B. anhand eines Personalausweises oder OTP ist eine zwingende Voraussetzung bevor eine Zurücksetzung erfolgen kann.

Control: BER.5.1 - Prinzip der geringsten Berechtigungen

Tags: "Security by Default" "Privilegierte Rechte"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.5 Berechtigungsmanagement
UUID: 0e1f4190-44ad-48f0-9504-781aef585ba0
Aufwand: 1
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.1.2 JIT-/JEA-Berechtigungen

Statement

Berechtigung SOLLTE die Vergabe von Berechtigungen nach dem Prinzip der geringsten Berechtigungen einschränken.

Guidance

Das Prinzip der geringsten Berechtigungen, im Englischen als Principle of Least Privilege (PoLP) bekannt, besagt, dass Nutzende, Prozesse oder Systeme nur die minimal notwendigen Zugriffsrechte erhalten dürfen, um die ihnen jeweils zugewiesenen Aufgaben zu erfüllen. Dies dient primär der Minimierung der Angriffsfläche und der Begrenzung potenzieller Schäden. Sollte beispielsweise ein Zugangskonto durch Phishing kompromittiert werden, könnte ein Angreifer ohne dieses Prinzip weitreichenden Zugriff auf kritische Daten oder Systeme erlangen und diese manipulieren, exfiltrieren oder verschlüsseln. Die konsequente Anwendung dieses Grundsatzes kann die Ausbreitung von Schadsoftware nach einem ersten Eindringen erheblich erschweren und sicherstellen, dass Mitarbeitende nur jene Informationen einsehen, die für ihre Tätigkeit unmittelbar relevant sind. Hierdurch wird auch das Risiko von Datendiebstahl durch Innentäter reduziert. Es empfiehlt sich als Ergänzung hier auch das "Need to know"-Prinzip zu betrachten, da sich beide Prinzipien ergänzen. Während das "Least Privilege"-Prinzip auf Systemrechte, Rollen und Berechtigungen fokussiert, liegt der Fokus des "Need to know"-Prinzips mehr auf Informationen und Datenzugriff. Zur sinnvollen Umsetzung kann die Institution ein

rollenbasiertes Berechtigungskonzept (Role-Based Access Control, RBAC) etablieren, bei dem Berechtigungen nicht an einzelne Personen, sondern an vordefinierte Rollen (z.B. "Finanzbuchhaltung" oder "Netzwerkadministrator") gebunden werden. Für die Einführung in eine bestehende Umgebung kann ein gestuftes Vorgehen gewählt werden: (1) Zunächst wird ein Überwachungsmodus ("Audit-Only") aktiviert, der protokolliert, welche Zugriffe durch eine strengere Richtlinie verweigert würden, ohne sie tatsächlich zu blockieren. (2) Anschließend werden diese Protokolle analysiert, um legitime, für den Geschäftsbetrieb notwendige Zugriffe zu identifizieren und diese gezielt in die jeweiligen Rollen und Berechtigungsgruppen aufzunehmen. (3) Erst wenn keine legitimen Zugriffe mehr in den Protokollen als "verweigert" auftauchen, wird die Richtlinie scharf geschaltet und blockiert aktiv alle nicht explizit erlaubten Zugriffe. Alle relevanten Anforderungen zur Vergabe von Berechtigungen können mit den Handlungsworten "authentifizieren", "autorisieren" und "einschränken" gefunden werden.

Control: BER.5.1.1 - Rollenbasierte Berechtigung

Tag: "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.5 Berechtigungsmanagement
Übergeordnetes Control:
BER.5.1 Prinzip der geringsten Berechtigungen
UUID: a9aa521b-e610-40ae-80d0-f1dd3b4ec47f
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE Berechtigungen rollenbasiert zuweisen.

Guidance

Aus Gründen der Nachvollziehbarkeit und des administrativen Aufwands wird die direkte Vergabe von Berechtigungen an Einzelkonten vermieden. Berechtigungen werden gemäß dem Least-Privilege-Prinzip in Rollen gebündelt, wobei die Zuweisung und der Entzug ausschließlich über diese Rollen erfolgt. Etwaige Ausnahmen, beispielsweise für temporäre Spezialrechte, werden restriktiv gehandhabt, nachvollziehbar dokumentiert und zeitlich befristet.

Links

required: PERS.2.2 Rollen

Control: BER.5.1.2 - JIT-/JEA-Berechtigungen

Tag: "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.5 Berechtigungsmanagement
Übergeordnetes Control:
BER.5.1 Prinzip der geringsten Berechtigungen
UUID: e549f464-b2fb-42a1-83b9-21bd3bb0f3cf
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Berechtigung KANN die Berechtigung zum Zeitpunkt des Zugriffs für {{ insert: param, ber.5.1.2-prm1 }} aktivieren.

Guidance

„JIT-/JEA-Berechtigungen“ (Just-In-Time/Just-Enough-Access) ist die zeitlich und inhaltlich begrenzte Vergabe von Rechten zum Zeitpunkt eines Zugriffs auf eine Ressource. Dies kann insbesondere für privilegierte Zugangskonten und Administrationszugänge sinnvoll sein, um erhöhte Rechte nur genau dann zu ermöglichen, wenn sie wirklich erforderlich sind.

Control: BER.5.2 - Begründung von Berechtigungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.5 Berechtigungsmanagement
UUID: d1151b4b-8e26-48fe-a4fe-8c6f14d3bdce
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die Vergabe von Berechtigungen und Änderungen an Berechtigungen mit einer Begründung dokumentieren.

Guidance

Zweck ist die Nachvollziehbarkeit der Vergabe von Berechtigungen. Die Dokumentation kann z.B. mit einem Identity-Access-Management oder Personalmanagementsystem automatisiert werden.

Control: BER.5.3 - Überprüfung von Berechtigungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.5 Berechtigungsmanagement

UUID: 4123f246-95b2-4785-9714-17a5e68462c5

Aufwand: 3

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen

Statement

Berechtigung SOLLTE vergebene Berechtigungen {{ insert: param, ber.5.3-prm1 }} auf Erforderlichkeit überprüfen.

Guidance

Erforderlichkeit bedeutet in diesem Kontext, dass eine vergebene Berechtigung nur dann als gerechtfertigt gilt, wenn sie für die aktuelle Aufgabenwahrnehmung, Rolle oder Funktion einer Person tatsächlich benötigt wird. Dabei kann zwischen fachlicher Notwendigkeit (z. B. Zugriff auf eine bestimmte Anwendung, um Kernaufgaben erfüllen zu können) und zeitlicher Relevanz (z. B. Projektzugriff, der nur für die Dauer des Projekts sinnvoll ist) unterschieden werden. Als mögliche Werte für den Parameter regelmäßig bieten sich an: (1) quartalsweise, (2) halbjährlich, (3) jährlich – je nach Kritikalität der Systeme und Sensibilität der Daten. Die regelmäßige Überprüfung der Erforderlichkeit kann verhindern, dass sich unbemerkt überhöhte Rechte („Privilege Creep“) ansammeln, die Angreifern im Falle einer Kompromittierung zusätzlichen Spielraum eröffnen könnten. Ohne solche Kontrollen könnte ein ehemaliger Projektmitarbeiter weiterhin Zugang zu sensiblen Daten haben oder ein interner Angreifer auf nicht benötigte Administrationsrechte stoßen. Umgekehrt kann die Überprüfung sicherstellen, dass Berechtigungen stets am aktuellen Aufgabenprofil ausgerichtet bleiben und so Schaden durch Missbrauch oder Fehlhandlungen eingedämmt werden kann. Zur Umsetzung kann eine Institution rollenbasierte Zugriffskonzepte einsetzen, die regelmäßig mit den Ist-Berechtigungen der Nutzer abgeglichen werden („Access Reviews“). Dies kann durch automatisierte Reports aus Verzeichnisdiensten, Datenbanken oder Fachanwendungen erfolgen, die Verantwortlichen zur Bestätigung oder Korrektur vorgelegt werden. Hilfreich kann auch ein

Vier-Augen-Prinzip sein, bei dem Vorgesetzte die Notwendigkeit von Berechtigungen bestätigen. Darüber hinaus kann es nützlich sein, temporäre Projekt- oder Sonderrechte mit Ablaufdatum zu vergeben, sodass diese automatisch entzogen werden, wenn sie nicht mehr bestätigt werden.

Control: BER.5.3.1 - Überprüfung tatsächlicher Berechtigungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.5 Berechtigungsmanagement
Übergeordnetes Control:
BER.5.3 Überprüfung von Berechtigungen
UUID: 4e815b01-7a59-4e8c-bbcc-e4998f342e68
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE dokumentierte und tatsächlich vergebene Berechtigungen {{ insert: param, ber.5.3.1-prm1 }} auf Übereinstimmung überprüfen.

Guidance

Der Sinn und Zweck der Vorgabe liegt darin, eine unbemerkte Abweichung zwischen Dokumentation und Realität frühzeitig zu erkennen. Ohne diesen Abgleich könnte es vorkommen, dass ehemalige Mitarbeitende weiterhin Zugriff auf interne Systeme behalten oder dass sich im Laufe der Zeit unautorisierte Rechteanhäufungen einschleichen. Durch eine wirksame Überprüfung kann hingegen sichergestellt werden, dass nur aktuelle, geprüfte und erforderliche Zugriffsrechte bestehen bleiben und so die Angriffsfläche der Institution reduziert werden kann. Zur Umsetzung kann die Institution Berechtigungsübersichten automatisiert aus IT-Systemen exportieren und diese mit den in Verzeichnissen oder Rollenmodellen hinterlegten Daten vergleichen, z.B. anhand eines automatisierten Abgleiches mit Personalstammdaten einmal pro Quartal. Diese Anforderung ist auch dann erfüllt, wenn Dokumentation der Berechtigungen und tatsächliche Berechtigung (z.B. ein Verzeichnisdienst) dasselbe sind. Bitte beachten Sie dabei, dass die generelle Anforderung zur Überprüfung vergebener Berechtigungen weiter gefasst ist und z.B. auch den Abgleich zwischen tatsächlich vergebenen Berechtigungen und nicht dokumentierten Erfordernissen (beispielsweise durch die Vorlage bei Vorgesetzten) umfassen kann.

Links

required: BER.5.2 Begründung von Berechtigungen

Control: BER.5.4 - Kompromittierte Berechtigungsmittel

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.5 Berechtigungsmanagement
UUID: 7dbede94-beea-430f-b058-3ff2f9f6b90c
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE kompromittierte Berechtigungsmittel deaktivieren.

Guidance

Ein Berechtigungsmittel gilt als kompromittiert, wenn Anzeichen bestehen, dass Unbefugte es nutzen oder Zugriff darauf gehabt haben könnten. Beispiele sind Passwörter, die durch Datenlecks öffentlich geworden sind, oder biometrische Merkmale (z. B. Fingerabdrücke), die Unbefugten vorliegen. In solchen Fällen ist das Berechtigungsmittel zu sperren oder zu entziehen, etwa durch den Einsatz von Sperrlisten. Bei biometrischen Merkmalen besteht zusätzlich ein enger Bezug zu datenschutzrechtlichen Anforderungen, da diese Daten nicht einfach ausgetauscht werden können.

Control: BER.5.5 - Systemfunktionen ohne Authentifizierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.5 Berechtigungsmanagement
UUID: bf5b5f6a-f525-45fc-b5a5-62379b3e6b2f
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Berechtigung für IT-Systeme SOLLTE Funktionen, auf die ohne vorherige Authentifizierung zugegriffen werden kann, dokumentieren.

Guidance

Funktionen ohne Authentifizierung sind alle Zugriffsmöglichkeiten auf Schnittstellen oder Daten des Systems, für die keine Authentifizierung erforderlich ist. Hierzu gehören z. B. Sprachassistenten, offene Webserver-Ports oder das Einblenden von Inhalten aus Apps auf dem Sperrbildschirm, wodurch persönliche Nachrichten oder Logintoken für Unbefugte zugänglich sein könnten. Solche Funktionen sind häufige Einfallstore für Angriffe auf das System oder für Datenleaks. Daher ist es sinnvoll eine Übersicht dieser Funktionen zu führen, selbst wenn die Funktionen benötigt werden.

Control: BER.5.6 - Anwendungsfunktionen ohne Authentifizierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.5 Berechtigungsmanagement
UUID: 383f3a5e-d627-46aa-960f-4e8c5c9c9592
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Berechtigung für Anwendungen SOLLTE Funktionen, auf die ohne vorherige Authentifizierung zugegriffen werden kann, dokumentieren.

Guidance

Hierzu gehören z.B. der Zugriff auf öffentliche Inhalte oder Funktionen zum Zurücksetzen des Passwortes, wodurch persönliche Daten oder Logintoken für Unbefugte zugänglich sein könnten. Allerdings kann es auch unauthentifizierte Funktionen geben, die für Betrieb oder Informationssicherheit benötigt werden, z.B. Meldeformulare für Sicherheitsvorfälle oder öffentliche Webseiteninhalte.

Control: BER.5.7 - IT-System-Zugangskonto

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.5 Berechtigungsmanagement
UUID: 7057a1f6-0804-49ac-9d7f-289ecc71fa33
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Berechtigung für IT-Systeme KANN diese genau einem Zugangskonto zuweisen.

Guidance

Wenn ein besonders schützenswertes IT-System nur von einer Person oder Identität genutzt wird, empfiehlt es sich dieses mit genau einem zugehörigen Zugangskonto zu verknüpfen. Dadurch wird ausgeschlossen, dass weitere Konten unnötig Zugriff erhalten. Bei Revisionen ist auf diese Weise eindeutig nachvollziehbar, welche Identität Zugriff auf das System hatte. Das Vorgehen ist auch auf virtualisierte IT-Systeme übertragbar. Ein Beispiel ist eine spezielle Administrationskonsole, die ausschließlich einem dedizierten Admin-Konto zugeordnet ist.

Control: BER.5.8 - Entzug von Berechtigungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.5 Berechtigungsmanagement
UUID: 12ab3443-67a1-4ecd-9177-d9547f62d27e
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE eine Vorgehensweise zum Entzug von Berechtigungen verankern.

Guidance

Innerhalb der Institution ist ein Prozess etabliert, mit dem Berechtigungen system- und anwendungsübergreifend entzogen sowie Zugänge deaktiviert oder gelöscht werden, sobald diese nicht mehr benötigt werden. Dadurch wird sichergestellt, dass bei Personalwechseln oder Aufgabenänderungen keine Berechtigungen für einzelne Systeme oder Anwendungen bestehen bleiben. Der Entzug von Berechtigungen bei Kündigungen, Versetzungen oder Änderungen von Zuständigkeiten ist, soweit möglich, als automatisierter Ablauf umgesetzt.

Links

required: PERS.6.1 Vorgehensweise für den Weggang

related: PERS.6.1.1 Entzug von Berechtigungen gemäß BER

Control: BER.6.1 - Passwortmanager

Tag: "Password Policy"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.6 Passwortgebrauch

UUID: c1cfa733-340c-497d-a3b6-8480d78e1278

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung für Nutzende SOLLTE einen Passwortmanager installieren.

Guidance

Der Einsatz eines Passwortmanagers, der von der Institution den Nutzenden zur Verfügung gestellt wird, erleichtert die Generierung von sicheren Passwörtern und deren sicherer Verwahrung, indem eine verschlüsselte Datenbank genutzt wird und der Zugang zu dem Passwortmanager mit einem Masterpasswort oder Multi-Faktor Authentisierung geschützt ist.

Control: BER.6.2 - Vorkonfigurierte Authentisierungsmittel

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.6 Passwortgebrauch

UUID: 7e0edf55-22d6-42d8-973f-d3f8635a0913

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE vorkonfigurierte Authentisierungsmittel deaktivieren.

Guidance

Herstellerseitige Standardkonten und Default-Passwörter stellen ein beliebtes Eingangstor für Angreifer dar. Wenn vorhanden können auch andere Zugangsmittel wie Hardware-Zugangstoken, Zertifikate oder physische Zugangskontrollsysteme als Authentisierungsmittel verstanden werden.

Control: BER.6.3 - Deaktivierung einfacher Biometrie

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.6 Passwortgebrauch
UUID: 4483f020-da27-44af-ae23-edf7d676d72f
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die Authentifizierung nur anhand von Biometrie deaktivieren.

Guidance

Wenn die Authentifizierung nur biometrisch vorgenommen wird (z.B. anhand von Fingerabdrücken oder Abbildern des Gesichtes), dann könnten Angreifer Fälschungen oder gestohlene Fingerabdrücke missbrauchen, um sich Zugang zu verschaffen. Werden biometrische Verfahren dagegen mit weiteren Authentisierungsmittel (z.B. einer PIN) kombiniert, können sie den Zugriffsschutz verbessern. Ein häufig vorkommendes Beispiel sind Mobilgeräte wie Smartphones, die durch Fingerabdruck den Zugriff auf Daten oder Funktionen wie das mobile Bezahlen gestatten - obwohl auf dem Gerät selbst häufig noch Fingerabdrücke erkennbar sind.

Control: BER.6.4 - Mehr-Faktor-Authentisierung am Perimeter

Tags: "MFA" "Credential Stuffing" "Brute-Force-Attacke"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.6 Passwortgebrauch

UUID: 2b9ddd3e-5233-46f5-abca-1793b89e2809

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Berechtigung für Anwendungen von Externe Netzanschlüssen SOLLTE Mehr-Faktor-Authentisierung aktivieren.

Guidance

Aus externen Netzen wie dem Internet erreichbaren Anwendungen (insbesondere die VPN-Einwahl oder Cloud-Anwendungen) stellen ein beliebtes Ziel für Angreifer dar. Eine Mehr-Faktor-Authentifizierung erschwert einen unberechtigten Zugang zu diesen extern erreichbaren Anwendungen.

Control: BER.6.5 - Mehr-Faktor-Authentisierung für weitreichende Berechtigungen

Tags: "MFA" "Living off the land" "Privilege Escalation" "Credential Stuffing" "Brute-Force-Attacke"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.6 Passwortgebrauch
UUID: 55b70084-f446-42af-908b-0f514a72f380
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE Mehr-Faktor-Authentisierung für weitreichende Berechtigungen aktivieren.

Guidance

Eine Mehr-Faktor-Authentifizierung bei Zugängen mit weitreichenden Berechtigungen, z.B. Administrationskonten, die Zugriff auf wichtige Server wie den Verzeichnisdienst, das MDM, EDR oder DNS haben, erschwert den unberechtigten Zugang zu diesen Zugängen. Auch der Zugriff auf besonders sensible Daten kann eine weitreichende Berechtigung sein.

Links

required: BER.3.5 Privilegierte Zugangskonten

related: BER.6.4 Mehr-Faktor-Authentisierung am Perimeter

Control: BER.6.6 - Blockieren von Passwort-Recycling

Tags: "Credential Stuffing" "Privilege Escalation" "Password Policy"

Info

Control der Klasse "BSI-Stand-der-Technik-Kern"

Gruppe: BER.6 Passwortgebrauch

UUID: d7c76736-0c1d-4693-92d5-894a8b740204

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Berechtigung für Nutzer SOLLTE die Wiederverwendung von Passwörtern blockieren.

Guidance

Die Wiederverwendung von Passwörtern („password reuse“) ist die Nutzung identischer oder bereits früher verwendeter Passwörter für verschiedene Konten, Systeme oder aufeinanderfolgende Authentifizierungsvorgänge. Die Blockierung der Passwortwiederverwendung bedeutet hier, dass das Berechtigungsmanagementsystem („access management system“) technisch verhindert, dass ein neues Passwort mit einem zuvor verwendeten identisch ist oder einer vordefinierten Anzahl früherer Passwörter entspricht. Dies könnte nicht nur bei Wiederverwendung einer Person problematisch sein, sondern auch bei einer systemübergreifenden Fehlkonfiguration: Ein typisches Szenario wäre, dass in einer Institution mehrere Arbeitsplatzrechner mit identischen lokalen Administratorpasswörtern konfiguriert sind („local admin password reuse“). Wird ein einzelner Rechner durch Schadsoftware oder physischen Zugriff kompromittiert, könnte ein Angreifer dieses Passwort anschließend nutzen, um sich mit denselben Anmeldeinformationen lateral auf weitere Systeme auszubreiten. Die Wiederverwendung des lokalen Administratorpassworts könnte somit eine vollständige Kompromittierung der internen IT-Infrastruktur ermöglichen. Diese Anforderung adressiert den Schutz vor solchen Angriffen, die sich aus der Wiederverwendung kompromittierter Anmeldeinformationen ergeben könnten, etwa durch Credential-Stuffing oder Brute-Force-Angriffe auf bekannte Passwortmuster. Blockieren kann das Risiko verringern, dass ein Angreifer durch bekannte Passwörter unbefugten Zugang zu Konten erhält. Hierzu können zum einen eine lokale Passworstabelle oder zum anderen elektronische Passwortmanager genutzt werden, die unabhängige sichere Passwörter generieren, wo die Wahrscheinlichkeit ei-

ner Passwortwiederholung ausgeschlossen werden kann.

Control: BER.6.7 - Trivialpasswörter

Tags: "Credential Stuffing" "Password Policy"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.6 Passwortgebrauch
UUID: f0722999-f8c4-4c75-810b-94d7563dd698
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Berechtigung für Nutzende SOLLTE die Verwendung von Trivialpasswörtern blockieren.

Guidance

Trivialpasswörter sind leicht zu erratende oder zu diesem Zugangskonto bereits öffentlich bekannte Passwörter (erkennbar durch Nutzung sog. Leak Check Datenbanken). Leicht zu erraten sind Passwörter, wenn sie mit gängigen Wörterbuchangriffen (dictionary attacks) bzw. systematischem Ausprobieren (brute force) in kurzer Zeit zu kompromittieren sind. Dazu zählen etwa einfache Folgen wie „123456“, „Passwort“ oder „qwerty“ sowie häufig vorkommende, in Leaks dokumentierte Standardkombinationen. Der Zweck der Anforderung liegt darin, das Risiko unautorisierter Zugriffe zu reduzieren: Ein Angreifer könnte mit automatisierten Tools in Sekunden oder Minuten triviale Passwörter durchprobieren, was zu einem unbefugten Zugriff auf Benutzerkonten, Systemressourcen oder sensible Daten führen könnte. Die Blockierung solcher Passwörter kann dagegen sicherstellen, dass nur schwer vorhersehbare Kennwörter verwendet werden, wodurch ein entscheidender Schutz gegen automatisierte Angriffsverfahren erreicht werden kann. Zudem können Passwortmanager beim Generieren nicht-trivialer Passwörter unterstützen.

Control: BER.6.8 - Kriterien für die Qualität von Passwörtern

Tags: "Privilege Escalation" "Credential Stuffing" "Brute-Force-Attacke" "Password Policy" "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.6 Passwortgebrauch
UUID: af5ba77a-8d77-4a4f-8842-23ba9dedb829
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE Kriterien für die Qualität von Passwörtern anhand von Lebensdauer und Angriffsmöglichkeiten verankern.

Guidance

Kriterien für die Qualität von Passwörtern können z.B. eine minimale Entropie, Passwortlänge oder Verwendung verschiedener Symbole sein. Die Lebensdauer meint die erwartete Nutzungsdauer des Passwortes. Die erforderliche Qualität hängt von den Angriffsmöglichkeiten ab, z.B. Anzahl der Zugangskonten, verwendetes kryptografisches Verfahren (vgl. BSI TR-02102) und begleitenden Sicherheitsmaßnahmen wie maximale Passwortversuche oder Mehr-Faktor-Authentifizierung. Für Zugänge ohne begleitende Maßnahmen ist eine Passwortlänge nicht unter 14 Zeichen empfehlenswert. Die Kriterien können einmalig festgelegt werden oder zwischen Zugängen oder Anwendungen differenzieren.

Control: BER.6.9 - Anlassbezogene Passwortwechsel

Tag: "Password Policy"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.6 Passwortgebrauch
UUID: 4de1c314-e6b3-4b70-bc73-54cdafca7ae9
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE einen Passwortwechsel ausschließlich anlassbezogen ausführen.

Guidance

Ein ausschließlich anlassbezogener Passwortwechsel bedeutet, dass Passwörter nur genau dann geändert werden, wenn ein begründeter Sicherheitsanlass vorliegt – beispielsweise ein Verdacht auf Kompromittierung des Endgerätes oder Zugangs, neue einschlägige Einträge in öffentlichen Leak-Datenbanken, die Weitergabe an Unbefugte durch einen Phishing-Vorfall, oder technische Indikatoren für einen möglichen Missbrauch des Zugangs zu Systemen oder Anwendungen. Dieser Ansatz unterscheidet sich vom früher häufig praktizierten, periodischen Passwortwechsel, der ohne konkreten Anlass in festen Intervallen erzwungen wurde. Ein solcher erzwungener Rhythmus könnte die Passwortsicherheit sogar verringern, weil Nutzende dann dazu neigen, schwächere, nur leicht veränderte Passwörter („sommer5“) zu wählen oder Zugangsdaten in verschiedenen Zugängen wiederzuverwenden. Zweck dieser Regelung ist es, die tatsächliche Sicherheit von Zugangskonten zu erhöhen und unnötige Belastungen der Nutzenden zu vermeiden.

Control: BER.6.10 - Monitoring von Zugangsdaten

Tags: "Credential Stuffing" "Password Policy"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.6 Passwortgebrauch
UUID: 4785649d-561d-4757-9421-4d0db14ee4df
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE Zugangsdaten auf Kompromittierung durch {{ insert: param, ber.6.10-prm1 }} überwachen.

Guidance

Eine Kompromittierung meint hier, dass Zugangsdaten wie Benutzername und Passwort (englisch: credentials) von Unbefugten eingesehen, abgefangen oder manipuliert wurden, sodass ein Missbrauch für unautorisierte Zugriffe möglich wird. Dies könnte etwa durch Leaks in Datenbanken, durch Phishing-Angriffe oder durch das Abfangen unverschlüsselter Übertragungen entstehen. Ein automatisierter Mechanismus bezeichnet hierbei eine technische Lösung, die ohne manuelles Zutun kontinuierlich prüft, ob bekannte Indikatoren einer Kompromittierung vorliegen (englisch: credential monitoring system). Geeignete Mechanismen können etwa Credential-Leak-Monitoring-Dienste, Data Breach Checker oder Darknet-Scanning-Tools sein. Der Zweck dieser Vorgabe liegt darin, dass ein frühzeitiges Erkennen von kompromittierten Zugangsdaten helfen kann, unautorisierte Logins und den Missbrauch sensibler Systeme zu verhindern; ohne eine solche Überwachung könnte ein Angreifer über lange Zeit unentdeckt mit gestohlenen Daten arbeiten und kritische Schäden verursachen. Ergeben sich hierbei Anzeichen auf eine Kompromittierung oder einen Leak der Zugangsdaten, so kann als Reaktion ein Wechsel der Zugangsdaten über einen nicht kompromittierten Kommunikationskanal veranlasst oder schlicht das betroffene Zugangskonto gesperrt werden.

Control: BER.7.1 - Etablierte Algorithmen bei der Schlüsselerzeugung

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.7 Schlüsselmanagement

UUID: d9e08db0-484e-4cce-89de-2f29f1a52e4e

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die ausschließliche Verwendung etablierter kryptografischer Algorithmen bei der Schlüsselerzeugung nach {{ insert: param, ber.7.1-prm1 }} verankern.

Guidance

Etablierte kryptografische Algorithmen sind mathematisch fundierte Verschlüsselungsverfahren und Protokolle, die in der aktuellen Praxis nicht mit vertretbarem Aufwand gebrochen werden können. Sie basieren auf mathematisch schwer lösba- ren Problemen, bieten Resistenz gegen bekannte kryptanalytische Angriffe, unter- stützen ausreichend große Schlüssellängen und wurden von Experten gründlich ge- prüft und analysiert. Aktuelle etablierte Algorithmen sind in BSI TR-02102 zu finden. Für weitere Details zur Implementierung siehe Detailspezifikation kryptografischer Abläufe und Mechanismen des BSI.

Control: BER.7.2 - Schlüssellänge

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.7 Schlüsselmanagement

UUID: 39301f7d-20ca-49c0-97e5-a8b048877e68

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die Schlüssellängen nach {{ insert: param, ber.7.2-prm1 }} bei der Schlüsselerzeugung zuweisen.

Guidance

Für die Sicherheit von Schlüsseln wie Passwörter oder PINs ist die Länge von Bedeutung. Für Details siehe BSI TR-02102.

Control: BER.7.3 - Verzeichnis öffentlicher Schlüssel

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.7 Schlüsselmanagement
UUID: 1434b374-7b49-427e-a015-82bffd0d5ea
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE zu jedem öffentlichen Schlüssel die dazugehörige Identität, das Ablaufdatum, den Nutzungszweck, die Schlüsselart und den Algorithmus bei der Schlüsselbeglaubigung dokumentieren.

Guidance

Im Verzeichnis öffentlicher Schlüssel werden die öffentlichen Schlüssel, die von der Institution erzeugt oder eingesetzt werden, aufgelistet. Hiermit werden kryptografische Schlüssel systematisch erfasst und dokumentiert. Zweckmäßig ist es, die Angaben direkt im Schlüssel abzuspeichern.

Control: BER.7.4 - Erzeugung auf sicheren IT-Systemen

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.7 Schlüsselmanagement

UUID: f99e7db6-714a-4fd8-94dd-e27cce24f0a7

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die Verwendung eines IT-Systems, welches mindestens dasselbe Schutzniveau bietet, für das der Schlüssel eingesetzt werden soll, bei der Schlüsselerzeugung verankern.

Guidance

Wird ein Schlüssel auf einem System erzeugt, das einen geringeren Schutz bietet als auf dem späteren Einsatzsystem, dann könnte der Schlüssel bereits kompromittiert sein.

Control: BER.7.5 - Kriterien für die Qualität von Zufallszahlen

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.7 Schlüsselmanagement

UUID: 426ad852-4455-43a4-b4ff-795ee2caa47b

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE {{ insert: param, ber.7.5-prm1 }} für die Qualität von Zufallszahlen bei der Schlüsselerzeugung verankern.

Guidance

Wenn bei der Schlüsselerzeugung ein ungeeigneter Zufallszahlengenerator verwendet wird, könnte ein Angreifer Schlüssel errechnen. Daher sind Kriterien für Zufallszahlengeneratoren zu wählen, z.B. Verwendung etablierter, durch unabhängige Dritte geprüfter Zufallszahlengeneratoren. Für Details siehe BSI TR-02102-1. Wichtig ist dabei auch, dass die verwendete Zufallsquelle tatsächlich eine nicht vorhersagbare Zahlenerzeugung erreicht. Insbesondere virtualisierte Systeme könnten ungeeignet sein zur Schlüsselerzeugung, da ihre Zufallszahlenquellen nicht direkt auf Hardwarefunktionen zurückgreifen.

Control: BER.7.6 - Etablierte Algorithmen beim Transport

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.7 Schlüsselmanagement

UUID: 88e6ce16-583d-40b4-a0cc-8a31bbb8c62c

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die ausschließliche Verwendung etablierter kryptografischer Algorithmen beim Transport geheimer Schlüssel verankern.

Guidance

Aktuelle etablierte Algorithmen sind in BSI TR-02102 zu finden. Der Transport kann mit Public Key Cryptography Standards (PKCS), z.B. PKCS#12 Dateiformat erfolgen. Für weitere Details zur Implementierung siehe Detailspezifikation kryptografischer Abläufe und Mechanismen des BSI.

Control: BER.7.7 - Kein Transport privater Schlüssel

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.7 Schlüsselmanagement
UUID: c28426cd-d01c-427d-bade-141936177c55
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Berechtigung KANN den Export privater Schlüssel durch {{ insert: param, ber.7.7-prm1 }} autorisieren.

Guidance

Im Allgemeinen ist es sinnvoll, private Schlüssel nur dort zu erzeugen, wo sie auch genutzt werden. Andernfalls könnten sie durch den Export kompromittiert werden. Hiervon sind allerdings zahlreiche Ausnahmen denkbar, z.B. zur Schlüsselerzeugung auf besonders abgesicherten Systemen, zum Transport auf Redundanzsysteme oder zur Datensicherung. Daher ist eine Abwägung sinnvoll, ob der Export zu genehmigen ist.

Control: BER.7.8 - Etablierte Algorithmen bei der Schlüsselnutzung

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.7 Schlüsselmanagement

UUID: efea2ba5-e5b5-4344-9341-b87340dab114

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die ausschließliche Verwendung etablierter Algorithmen bei der Schlüsselnutzung verankern.

Guidance

Aktuelle etablierte Algorithmen sind in BSI TR-02102 zu finden. Für weitere Details zur Implementierung siehe Detailspezifikation kryptografischer Abläufe und Mechanismen des BSI.

Control: BER.7.9 - Zweckbindung

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.7 Schlüsselmanagement
UUID: c5ed06a9-b144-43a9-b269-ff914304036a
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE Verstöße gegen die Zweckbindung bei der Schlüsselnutzung untersagen.

Guidance

Zweckbindung bedeutet, dass der Schlüssel ausschließlich zu dem im Verzeichnis öffentlicher Schlüssel festgelegten Nutzungszweck verwendet werden darf. Die Zweckbindung gilt insbesondere auch für den privaten Schlüssel.

Control: BER.7.10 - Abgelaufene Schlüssel

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.7 Schlüsselmanagement

UUID: f9429a00-a0c2-434c-89d5-cb768d87a192

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die Nutzung des Schlüssels zur Verschlüsselung oder Signierung nach Ablauf der Nutzungszeit untersagen.

Guidance

Schlüssel dürfen nach Ablauf der Nutzungszeit nur noch zur Entschlüsselung oder Signaturprüfung alter Daten verwendet werden. Bei automatisierter Schlüsselnutzung ist der Schlüssel zu deaktivieren, bei manueller Schlüsselnutzung ist den Nutzenden weitere Verwendung des Schlüssels zu verbieten.

Control: BER.7.11 - Integrität

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.7 Schlüsselmanagement
UUID: 3ec4d43b-001d-4911-9adf-707657321030
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die Verifikation der Integrität geheimer Schlüssel vor jeder Nutzung verankern.

Guidance

Wird die Integrität von Schlüsseln vor der Verwendung nicht geprüft, so könnte er unbemerkt durch einen Angreifer ausgetauscht werden, wodurch der Angreifer den vermeintlich verschlüsselten Austausch mitlesen. Daher ist ein Integritätsschutz (z.B. eine bekannte Checksumme oder Fingerabdruck) von abgelegten Schlüsseln sinnvoll. Dies kann z.B. durch den Abgleich von Prüfsummen geschehen, welche auf einem anderen IT-System gespeichert sind. Für die Implementierung genügt es, wenn die eingesetzten IT-Produkte bereits so entwickelt oder beschafft worden sind, dass sie die Prüfung automatisiert durchführen.

Control: BER.7.12 - Authentizität

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.7 Schlüsselmanagement

UUID: 4e4a2385-0cb0-4bb4-938f-a47b96b6f819

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die Verifikation der Authentizität öffentlicher Schlüssel vor jeder Nutzung verankern.

Guidance

Für die Implementierung genügt es, wenn die eingesetzten IT-Produkte bereits so entwickelt oder beschafft worden sind, dass sie die Prüfung automatisiert durchführen.

Control: BER.7.13 - Gültigkeit

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.7 Schlüsselmanagement

UUID: 792bc79a-4114-461d-bc6e-3e16ee8069c4

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die Verifikation der Gültigkeit des Schlüssels vor jeder Nutzung verankern.

Guidance

Die Gültigkeit ergibt sich aus Nutzungszeit und Revocation-Status. Für die Implementierung genügt es, wenn die eingesetzten IT-Produkte bereits so entwickelt oder beschafft worden sind, dass sie die Prüfung automatisiert durchführen.

Control: BER.7.14 - Schlüssel vor Ablauf prüfen

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.7 Schlüsselmanagement
UUID: 681822fa-f526-4580-9436-7c7d4c94edf3
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE Schlüssel auf das baldige Auslaufen der Nutzungszeit {{ insert: param, ber.7.14-prm1 }} überprüfen.

Guidance

Wird die Gültigkeit von Schlüsseln vor dem Auslaufen nicht überwacht, so könnten Schlüssel ungültig werden, wodurch Schnittstellen oder Anwendungen plötzlich nicht mehr verfügbar sein könnten. Läuft ein Schlüssel bald ab, obwohl der Zweck weiterhin bestehen bleibt, so ist es sinnvoll den Schlüssel rechtzeitig durch einen neuen zu ersetzen. Hierbei ist zu beachten, dass bei Schlüsselwechsel verschlüsselte Daten entschlüsselt und erneut verschlüsselt werden.

Control: BER.7.15 - Vorgehensweise nach Nutzung

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.7 Schlüsselmanagement

UUID: 4eb39607-cb0f-4dac-8a4c-5637fe5f3ab3

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE eine Vorgehensweise zur Außerbetriebnahme geheimer Schlüssel , sobald sie nicht mehr benötigt werden, verankern.

Guidance

Werden Schlüssen nicht mehr benötigt, so ist es sinnvoll diese im Einklang mit den Anforderungen zur Löschung von Informationen außer Betrieb zu nehmen. Hierbei ist zu beachten, dass bei einem Schlüsselwechsel verschlüsselte Daten entschlüsselt und erneut verschlüsselt werden. Flüchtige Schlüssel sind nach der Sitzung umgehend zu löschen.

Links

related: ASST.7.3.2 Lösungsverfahren

Control: BER.7.16 - Vorgaben für die Schlüsselbeglaubigung

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BER.7 Schlüsselmanagement

UUID: 38cae0e5-8758-426c-b02f-07e7d585c475

Aufwand: 3

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BER.7.16.1 Zertifizierungsstelle
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus

Statement

Berechtigung SOLLTE Vorgaben für die Schlüsselbeglaubigung verankern.

Guidance

Je nach Umfang der Beglaubigungstätigkeit gehören hierzu z.B. Algorithmen, Zweckbindung, Nutzungsdauer, sowie prozessuale Vorgaben für Speicherung, Beantragung, Revocation, Erneuerung und Verfügbarkeit. Für Details siehe IETF RFC 3647.

Control: BER.7.16.1 - Zertifizierungsstelle

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.7 Schlüsselmanagement
Übergeordnetes Control:
BER.7.16 Vorgaben für die Schlüsselbeglaubigung
UUID: 7b80290b-5c6d-4e39-857c-0a63a8e2543a
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE die Beglaubigung von Schlüsseln {{ insert: param, ber.7.16.1-prm1 }} zuweisen.

Guidance

Die Beglaubigung von Schlüsseln ist technisch komplex. Gleichzeitig hängt von ihr die Vertrauensstellung von Systemen und Anwendungen im Informationsverbund ab. Daher ist es sinnvoll diese Aufgabe konkret bestimmten Personen oder Rollen zuzuweisen.

Control: BER.7.16.2 - Beglaubigung

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.7 Schlüsselmanagement
Übergeordnetes Control:
BER.7.16 Vorgaben für die Schlüsselbeglaubigung
UUID: 921cdb15-bf12-4a04-98f0-3bb7af3628d6
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Beantragung einer Beglaubigung testen.

Guidance

Schlüsselbeglaubigung (engl. key certification) ist der kryptographische Nachweis, dass ein kryptographischer Schlüssel echt, unverändert und einer berechtigten Identität eindeutig zugeordnet ist. Der Schlüsseltest vor der Beglaubigung dient dazu, sicherzustellen, dass der einzureichende Schlüssel die festgelegten technischen und organisatorischen Vorgaben für die Genehmigung der Beglaubigung erfüllt – etwa hinsichtlich Schlüssellänge, Algorithmuskompatibilität oder Integrität der Schlüsseldaten. Solche Prüfungen können die korrekte Formatierung, die Funktionsfähigkeit innerhalb der vorgesehenen Kryptosysteme sowie den Abgleich mit vertrauenswürdigen Referenzen umfassen. Ziel ist die Gewährleistung, dass keine fehlerhaften, kompromittierten oder absichtlich manipulierten Schlüssel in eine Vertrauenskette eingebracht werden. Diese Vorgabe kann das Risiko reduzieren, dass fehlerhafte oder böartig erzeugte Schlüssel zu einer Täuschung über die Identität oder zu unbemerkten Datenmanipulationen führen könnte. Ebenso kann sie verhindern, dass ein unzureichend geprüfter Schlüssel später als gültig angesehen wird, obwohl er kompromittiert ist. Eine konsequente Umsetzung kann die Integrität kryptographischer Infrastrukturen stärken und die Vertrauenswürdigkeit digitaler Signaturen, Authentifizierungen und Verschlüsselungsprozesse sichern. In der Praxis kann dies etwa durch automatisierte Validierungsroutinen in einer Public-Key-Infrastruktur (PKI), durch den Einsatz spezialisierter HSM-Testwerkzeuge oder durch manuelle Prüfung anhand festgelegter Zertifizierungsrichtlinien erfolgen.

Links

required: BER.7.16 Vorgaben für die Schlüsselbeglaubigung

Control: BER.7.16.3 - Erneuerung

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.7 Schlüsselmanagement
Übergeordnetes Control:
BER.7.16 Vorgaben für die Schlüsselbeglaubigung
UUID: 40d229bb-6fab-4a1a-a96a-a2a119acef5f
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Erneuerung einer Beglaubigung testen.

Guidance

Die Erneuerung einer Beglaubigung beschreibt den Vorgang, bei dem ein ablaufendes oder gefährdetes Zertifikat durch ein neues ersetzt wird, wobei die Vertrauenskette erhalten bleibt. Dazu wird geprüft, ob die Vorgaben für die Erneuerung der Beglaubigung erfüllt sind. Das Testen des Schlüssels im Rahmen der Erneuerung dient dazu, die fortgesetzte Vertrauenswürdigkeit und Funktionsfähigkeit des Schlüssels sicherzustellen, etwa durch Verifikation der Signatur, Abgleich der Fingerprints oder Validierung gegen Sperrlisten. Der Zweck dieser Anforderung liegt in der Sicherstellung, dass bei der Erneuerung eines Zertifikats keine kompromittierten, fehlerhaften oder unautorisierten Schlüssel weiterverwendet werden. Wird die Schlüsselprüfung unterlassen, könnte ein Angreifer manipulierte oder gefälschte Schlüssel einschleusen, was zu unbemerktem Datenabgriff, Identitätsmissbrauch oder Integritätsverlust führen könnte. Eine wirksame Prüfung kann dagegen sicherstellen, dass nur überprüfte und gültige Schlüssel erneut beglaubigt werden, wodurch das Vertrauensniveau der gesamten kryptographischen Infrastruktur stabil bleibt. Sinnvolle Umsetzungsvarianten können z. B. die Nutzung automatisierter Schlüsselvalidierungen in Public-Key-Infrastrukturen (PKI), der Einsatz von Hardware-Sicherheitsmodulen (HSM) für die Signaturprüfung oder der Abgleich über Transparenzregister wie Certificate Transparency Logs sein.

Links

required: BER.7.16 Vorgaben für die Schlüsselbeglaubigung

Control: BER.7.16.4 - Revocation

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.7 Schlüsselmanagement
Übergeordnetes Control:
BER.7.16 Vorgaben für die Schlüsselbeglaubigung
UUID: 0e70f6df-b9c4-4046-871a-5e4d1263fb9f
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE den Schlüssel anhand der Vorgaben für die Schlüsselbeglaubigung bei Revocation einer Beglaubigung testen.

Guidance

Die Revocation einer Beglaubigung (engl. revocation of attestation) ist die nachträgliche Ungültigerklärung einer solchen Bestätigung, beispielsweise durch Sperrung eines Zertifikats mittels Certificate Revocation List (CRL) oder Online Certificate Status Protocol (OCSP). Das Testen des Schlüssels anhand der Vorgaben für die Schlüsselbeglaubigung bedeutet hier, dass geprüft wird, ob die festgelegten Vorgaben für die Revocation erfüllt sind. Damit wird sichergestellt, dass der Widerruf einer Beglaubigung nur bei Vorliegen der Voraussetzungen angestoßen wird und dann technisch und organisatorisch korrekt umgesetzt und im Systemverhalten nachvollziehbar berücksichtigt wird, etwa durch sofortige Ungültigkeitserklärung oder Sperrung des betreffenden Schlüssels. Der Zweck dieser Vorgabe liegt darin, unzulässige oder verfrühte Revocations ebenso zu vermeiden wie verspätete oder unvollständige Umsetzungen, die zu Sicherheitslücken führen könnten. Wird die Prüfung der Revocation-Vorgaben fehlerhaft oder unvollständig durchgeführt, könnte ein gültiger Schlüssel fälschlich gesperrt werden oder ein tatsächlich kompromittierter Schlüssel weiter im Einsatz bleiben. Eine konsequente Umsetzung kann dagegen gewährleisten, dass der Widerruf von Beglaubigungen nur im vorgesehenen Rahmen erfolgt, die Integrität des Vertrauensmodells erhalten bleibt und alle abhängigen Systeme den neuen Status korrekt übernehmen. Praktisch kann dies durch automatisierte Regelprüfungen in Zertifikatsverwaltungsdiensten, durch Ereignisprotokollierung in Key Management Services (KMS) oder durch Hardware-Sicherheitsmodule (HSM) umge-

setzt werden, die Revocation-Bedingungen strikt validieren, bevor Änderungen am Schlüsselstatus ausgeführt werden.

Links

required: BER.7.16 Vorgaben für die Schlüsselbeglaubigung

Control: BER.7.16.5 - Beglaubigungsstatus

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.7 Schlüsselmanagement
Übergeordnetes Control:
BER.7.16 Vorgaben für die Schlüsselbeglaubigung
UUID: 3f4e22f4-f99f-46fc-91c8-d9faad3cedcc
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE den Beglaubigungsstatus des Schlüssels im Verzeichnis öffentlicher Schlüssel dokumentieren.

Guidance

Der Beglaubigungsstatus erfasst, ob der Schlüssel von der Beglaubigungs- oder Zertifizierungsstelle der Institution beglaubigt wurde.

Links

required: BER.7.3 Verzeichnis öffentlicher Schlüssel

Control: BER.7.16.6 - Revocationstatus

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BER.7 Schlüsselmanagement
Übergeordnetes Control:
BER.7.16 Vorgaben für die Schlüsselbeglaubigung
UUID: 7d843f5e-e393-4f0b-a72c-0c3de4936859
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Berechtigung SOLLTE den Revocationstatus des Schlüssels im Verzeichnis öffentlicher Schlüssel dokumentieren.

Guidance

Der Revocationsstatus des Schlüssels erfasst, ob der Schlüssel zurückgezogen wurde, etwa weil er aufgrund einer Kompromittierung nicht mehr sicher verwendet werden kann.

Links

required: BER.7.3 Verzeichnis öffentlicher Schlüssel

Control: BES.1.1 - Verfahren und Regelungen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.1 Grundlagen
UUID: ee4c5028-8cf8-44b6-b154-ea870db33a13
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.1.1.1 Dokumentation
- BES.1.1.2 Zuweisung der Aufgaben
- BES.1.1.3 Bekanntgabe

Statement

Beschaffungsmanagement MUSS Verfahren und Regelungen zur Beschaffung von IT-Produkten und Dienstleistungen verankern.

Guidance

Relevant sind hierbei sowohl Beschaffungen von Produkten und Dienstleistungen für den internen Betrieb als auch Verträge bei denen Informationen für die Institution extern verarbeitet werden, z.B. Cloud-Dienstleistungen. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Control: BES.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.1 Grundlagen

Übergeordnetes Control:

BES.1.1 Verfahren und Regelungen

UUID: 8eb5586d-0d76-4ed4-b300-9ca657839eac

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: BES.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.1 Grundlagen

Übergeordnetes Control:

BES.1.1 Verfahren und Regelungen

UUID: 6412af95-f83a-4b0c-ba66-edcecfaf85

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, bes.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es die Zuweisung anhand von Rollen (z.B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: BES.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.1 Grundlagen

Übergeordnetes Control:

BES.1.1 Verfahren und Regelungen

UUID: d94fc3e4-589a-4395-97e3-fd9152540248

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: BES.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.1 Grundlagen

UUID: 5a10cf6d-51f6-48cf-8a79-98bab4565b7b

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement MUSS die Verfahren und Regelungen {{ insert: param, bes.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante Überprüfung der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: BES.1.3 - Lieferanten- und Dienstleisterverzeichnis

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.1 Grundlagen

UUID: d02f25dc-07c0-4470-a43d-31d34bcf5af4

Aufwand: 2

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.1.3.1 Gesamte Lieferkette

Statement

Beschaffungsmanagement für Einkäufe SOLLTE alle direkten Zulieferer und Dienstleister inklusive der jeweiligen Kontaktdaten und den bezogenen Lieferungen dokumentieren.

Guidance

Direkte Zulieferer sind hier alle Vertragspartner, von denen IT-Produkte bezogen werden. Dienstleister sind alle Vertragspartner, die schützenswerte Informationen des Informationsverbundes verarbeiten.

Control: BES.1.3.1 - Gesamte Lieferkette

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.1 Grundlagen
Übergeordnetes Control:
BES.1.3 Lieferanten- und Dienstleisterverzeichnis
UUID: 4aa61c74-cb3e-42ee-8217-ed9cabe74c3b
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Einkäufe KANN die gesamte Lieferkette inklusive der jeweiligen Unterauftragnehmer und deren Kontaktdaten dokumentieren.

Guidance

Sicherheitsvorfälle können nicht nur auf direkter Ebene entstehen, sondern werden häufig durch nachgelagerte Dienstleister oder Unterlieferanten verursacht – etwa wenn ein Unterauftragnehmer unzureichende Sicherheitsmaßnahmen umsetzt, kritische Softwarekomponenten fehlerhaft bezieht oder sensible Daten bei einem Subdienstleister unkontrolliert verarbeitet werden. Ein solches Ereignis könnte sich durch Lieferausfälle, den Einschleusung kompromittierter Hard- oder Software oder auch durch den Verlust von Betriebsgeheimnissen bemerkbar machen. Nur wenn eine Institution die gesamte Kette kennt, kann sie Schwachstellen lückenlos erkennen, Abhängigkeiten bewerten und im Bedarfsfall schneller reagieren, etwa indem bei Störungen alternative Bezugsquellen aktiviert werden. Die (ja fortlaufend zu gewährleistende) Dokumentation der gesamten Lieferkette ist allerdings auch mit großem Aufwand verbunden und setzt auch die Bereitschaft zur Mitwirkung in der gesamten Lieferkette voraus.

Control: BES.1.4 - Outsourcing-Strategie

Tags: "Lieferketten" "Shared Responsibility Model"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.1 Grundlagen
UUID: 302952ea-72e1-4104-9cbb-678717a267db
Aufwand: 4
Sicherheitsstufe: erhöht

Untergeordnete Controls

- BES.1.4.1 Freigabe der Strategie

Statement

Beschaffungsmanagement für Outsourcing KANN eine Strategie mit Zielen, Chancen und Risiken des Outsourcings verankern.

Guidance

Outsourcing-Strategie bezeichnet hierbei die von der Institution festgelegten Grundsätze, Entscheidungskriterien und Grenzen für die Auslagerung von Leistungen. Die Strategie beinhaltet z.B. die Entscheidung über die Art und den Scope des Outsourcings und welche Arten von Anwendungen/Daten oder Prozessen ausgelagert werden. Bei einem Outsourcing in die Cloud wäre hier z.B. über "cloud only, cloud first, some cloud, no cloud" und bei der Bereitstellungsart über "Saas, PaaS, IaaS" etc. zu entscheiden. Typische Risiken sind versteckte Kosten, unklare Zuständigkeiten ("Verantwortungsdiffusion") durch gemeinsame Verantwortlichkeit mit dem Dienstleister für die Informationssicherheit (Shared Responsibility), Verlust von eigenem Knowhow, Abhängigkeit vom Anbietenden von Outsourcing, Verlust von Kontroll- und Steuerungsmöglichkeiten, Einblicke Dritter in interne Betriebsabläufe und Daten. Ziele beinhalten unter anderem auch die angestrebten Sicherheitsziele, z.B. "bei Bearbeitung von VS-NfD Inhalten die Einhaltung der VSA". Chancen können z.B. in einer schnelleren Einführung neuer Technologien, einer höheren Flexibilität bei Lastspitzen, einer verbesserten Verfügbarkeit durch die Infrastruktur des Dienstleisters oder in Kostenersparnissen durch Skaleneffekte liegen. Im Cloud-Kontext ergeben sich zudem Möglichkeiten wie eine weltweite Standortunabhängigkeit, einfachere Anbindung verteilter Teams oder die Nutzung spezialisierter Sicherheits- und

Compliance-Services, die intern nur mit erheblichem Aufwand aufgebaut werden könnten.

Control: BES.1.4.1 - Freigabe der Strategie

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.1 Grundlagen
Übergeordnetes Control:
BES.1.4 Outsourcing-Strategie
UUID: 235c1c4a-c202-4d06-8391-254cac868ec2
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Outsourcing SOLLTE die Strategie durch die Institutionsleitung autorisieren.

Guidance

Ziel ist es sicherzustellen, dass Auslagerungen dem Risikoverständnis, den gesetzlichen Rahmenbedingungen und den geschäftlichen Zielen entsprechen und Verantwortlichkeiten eindeutig verankert sind. Fehlende oder uneinheitliche Leitentscheidungen könnten zu Schattenbeschaffungen, regulatorischen Beanstandungen, Konzentrationsrisiken oder unkontrollierten Datenabflüssen führen; etwa könnte ein Fachbereich ohne strategischen Rahmen einen Dienst in einer problematischen Jurisdiktion beauftragen oder mehrere kritische Leistungen bei einem einzigen Anbieter bündeln, was bei dessen Ausfall zu erheblichen Betriebsunterbrechungen führen könnte.

Control: BES.1.5 - Autorisierung des Bereitstellungsmodells

Tags: "Lieferketten" "Shared Responsibility Model"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.1 Grundlagen

UUID: 6d50b322-84b8-4c9b-bd2a-0b48d6b61847

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Cloud-Dienste SOLLTE für jeden Cloud-Dienst das Bereitstellungsmodell durch {{ insert: param, bes.1.5-prm1 }} autorisieren.

Guidance

Hiermit ist die bewusste Entscheidung für ein Modell und die konzeptionelle Umsetzung ("Shared Responsibility") dieser Entscheidung gemeint. Bereitstellungsmodelle sind z.B.: Public Cloud, Private Cloud, Community Cloud, Hybrid Cloud. Es kann in der Praxis aber zu dadurch nicht abgedeckten Varianten, wie z. B. "Virtual Private Cloud" kommen. Die Anforderung ist erst dann umgesetzt, wenn auch zwischen den Vertragspartnern das Bereitstellungsmodell explizit vereinbart ist, so dass die Verteilung der Verantwortlichkeiten (Shared Responsibility) für Schutzmaßnahmen zwischen Institution und Dienstleister klar geregelt ist.

Control: BES.1.6 - Dokumentation des Bereitstellungsmodells

Tags: "Lieferketten" "Shared Responsibility Model"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.1 Grundlagen

UUID: 43e11ef1-4161-444d-ba0d-0fed61d31dd8

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Cloud-Dienste SOLLTE für jeden Cloud-Dienst das gewünschte Bereitstellungsmodell mit Ausführung der geteilten Verantwortlichkeiten dokumentieren.

Guidance

Hiermit ist die bewusste Entscheidung für ein Modell und die konzeptionelle Umsetzung ("Shared Responsibility") dieser Entscheidung gemeint. Bereitstellungsmodelle sind z.B.: Public Cloud, Private Cloud, Community Cloud, Hybrid Cloud. Es kann in der Praxis aber zu dadurch nicht abgedeckten Varianten, wie z. B. "Virtual Private Cloud" kommen.

Control: BES.1.7 - Vereinbarung der geteilten Verantwortung

Tags: "Lieferketten" "Shared Responsibility Model"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.1 Grundlagen

UUID: 6cc29c32-b75a-4a6f-b260-1e5038f37866

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Cloud-Dienste SOLLTE für jeden Cloud-Dienst mit dem Anbieter die geteilte Verantwortung vereinbaren.

Guidance

Die Anforderung ist erst dann umgesetzt, wenn auch zwischen den Vertragspartnern das Bereitstellungsmodell explizit vereinbart ist, so dass die Verteilung der Verantwortlichkeiten (Shared Responsibility) für Schutzmaßnahmen zwischen Institution und Dienstleister klar geregelt ist.

Links

required: BES.1.5 Autorisierung des Bereitstellungsmodells

Control: BES.2.1 - Erfassung des Bedarfes

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.2 Bedarfserfassung
UUID: 0c2aa136-750b-4213-aa8a-1911537934e6
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.2.1.1 Verwendungszweck
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.1.3 Systemvoraussetzungen
- BES.2.1.4 Kompatibilität
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge

Statement

Beschaffungsmanagement für Einkäufe SOLLTE den Bedarf anhand einer Leistungsbeschreibung oder einer Umsetzungsstrategie dokumentieren.

Guidance

Dies umfasst sowohl Bedürfnisse für eine sichere Funktionalität als auch nicht-funktionalen Bedarf wie Datensicherung und Einbindung in das Monitoring.

Control: BES.2.1.1 - Verwendungszweck

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.2 Bedarfserfassung

Übergeordnetes Control:

BES.2.1 Erfassung des Bedarfes

UUID: 419911b0-2fc0-4f2c-898d-062b9466c35d

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für IT-Produkte SOLLTE den Verwendungszweck dokumentieren.

Guidance

Relevant kann hierbei beispielsweise sein, ob es verschiedene Einsatzszenarien (z.B. Innen- und Außendienst) gibt.

Control: BES.2.1.2 - Geschäftsprozessprofile

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.2 Bedarfserfassung
Übergeordnetes Control:
BES.2.1 Erfassung des Bedarfes
UUID: cf24172d-d505-4960-b580-ccea153e1abe
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Outsourcing KANN Geschäftsprozessprofile für (Teil-)Prozesse, die ausgelagert werden, mit Funktion, verarbeiteten Informationen, einzuhaltenden rechtlichen und organisatorischen Rahmenbedingungen, prozessualen Schnittstellen, Abhängigkeiten zwischen Prozessen, sowie ihren Schutzbedarfen und Kritikalitäten dokumentieren.

Guidance

Ist bereits eine Business-Impact-Analyse (BIA) vorhanden, welche die Angaben enthält, so kann die Anforderung durch die BIA erfüllt werden. Kritikalität bezeichnet die Bedeutung eines Prozesses für den Geschäftsbetrieb der Institution. Die Umsetzung kann auch durch eine Tabelle von Geschäftsprozessprofilen geschehen.

Control: BES.2.1.3 - Systemvoraussetzungen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.2 Bedarfserfassung

Übergeordnetes Control:

BES.2.1 Erfassung des Bedarfes

UUID: 84f323b8-6090-4c5c-9ca4-48869567d624

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für IT-Produkte SOLLTE Systemvoraussetzungen dokumentieren.

Guidance

Hierzu können sowohl Hardwareparameter gehören (z.B. 8 GB RAM, TPM 2.0), als auch Voraussetzungen an Betriebssysteme (z.B. Lauffähigkeit nur auf bestimmten Betriebssystemen oder bei Unterstützung bestimmter Funktionen), auf denen der Einsatz geplant ist.

Control: BES.2.1.4 - Kompatibilität

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.2 Bedarfserfassung

Übergeordnetes Control:

BES.2.1 Erfassung des Bedarfes

UUID: 4625c5ac-57d7-404c-9ab3-620b724b36b8

Aufwand: 3

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.2.1.4.1 Kompatibilität der Schnittstellen
- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells

Statement

Beschaffungsmanagement für Einkäufe SOLLTE den Bedarf für die Kompatibilität mit der bestehenden Infrastruktur dokumentieren.

Guidance

Werden Beschaffungen ohne Betrachtung der Kompatibilität zur angebundenen Infrastruktur vorgenommen, kann es zu unvorhergesehenen Wechselwirkungen zwischen Komponenten kommen. Durch die steigende Komplexität von Infrastrukturen wächst auch das Risiko solcher Inkompatibilitäten oder Fehlerbilder. Zur relevanten Infrastruktur können je nach Einsatzzweck z.B. der Verzeichnisdienst, die Protokollierung von Ereignissen, das Monitoring oder der Datenspeicher gehören. Soweit möglich, ist es sinnvoll, zur Anbindung anerkannte Standards zu nutzen, z.B. REST-API und HTTPS für die Schnittstellen, TCP/IP und Ethernet (IEEE 802.3) für die Netzanbindung, SSH für die Administration, sowie SQL oder JSON für das Datenmanagement.

Control: BES.2.1.4.1 - Kompatibilität der Schnittstellen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.2 Bedarfserfassung
Übergeordnetes Control:
BES.2.1.4 Kompatibilität
UUID: c6743b13-6c1b-4706-94ba-c185e4839d35
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE den Bedarf für die Kompatibilität im Hinblick auf Schnittstellen dokumentieren.

Guidance

Kompatibilität im Hinblick auf Schnittstellen meint die Fähigkeit eines zu beschaffenden IT-Systems, einer Anwendung oder Komponente, mit bestehenden oder vorgesehenen IT- und OT-Umgebungen interoperabel zu sein; hierzu zählen technische Schnittstellen wie APIs (Application Programming Interfaces), Protokolle, Authentifizierungsmechanismen sowie physische oder virtuelle Netzanschlüsse. Eine Schnittstelle ist dabei jede definierte Übergabestelle, an der Daten, Signale oder Steuerungsinformationen zwischen Systemen ausgetauscht werden, einschließlich logischer (z. B. Webservices, REST, SOAP), datenbezogener (z. B. XML, JSON, CSV, authentifizierender (z.B. SAML oder OAuth 2.0) und infrastruktureller Anbindungen (z. B. VPN, TLS-gesicherte Verbindungen). Die Dokumentation des Bedarfs umfasst eine nachvollziehbare Beschreibung, welche bestehenden Infrastrukturen angebunden werden, welche Kommunikationsprotokolle und Sicherheitsmechanismen unterstützt werden und welche Abhängigkeiten oder Einschränkungen bestehen. Die Regelung zielt darauf ab, Integrationsrisiken frühzeitig zu erkennen und Fehlbeschaffungen zu vermeiden; ohne dokumentierten Kompatibilitätsbedarf könnte es zu Medienbrüchen, unsicheren Ad-hoc-Anbindungen oder kostenintensiven Nachrüstungen kommen, wodurch Sicherheitslücken entstehen könnten. Eine systematische Erfassung der Schnittstellenanforderungen kann hingegen sicherstellen, dass nur Lösungen ausgewählt werden, die sich kontrolliert und sicher in die bestehende Architektur einfügen lassen.

Control: BES.2.1.4.2 - Kompatibilität der Netzanbindung

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.2 Bedarfserfassung
Übergeordnetes Control:
BES.2.1.4 Kompatibilität
UUID: 004ebc71-2ee1-4b26-993e-9bc3f5088bfc
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE den Bedarf für die Kompatibilität im Hinblick auf die Netzanbindung dokumentieren.

Guidance

Kompatibilität im Hinblick auf die Netzanbindung ist hier die technische und logische Anschlussfähigkeit einer zu beschaffenden Komponente an die bestehende Netzwerkinfrastruktur der Institution zu verstehen, einschließlich physischer Schnittstellen (z.B. Ethernet, Glasfaser), unterstützter Übertragungsprotokolle (z.B. TCP/IP, HTTP, TLS), Authentisierungs- und Autorisierungsverfahren (z.B. IEEE 802.1X, RADIUS), Adressierungskonzepte (IPv4/IPv6, erforderlicher Netzbandbreite und Laufzeiten, sowie Segmentierungs- und Sicherheitsarchitekturen (z.B. VLAN, Network Access Control - NAC). Netzanbindung meint dabei jede Form der Integration in interne Netze, Perimeternetze oder dedizierte Verbindungen zu externen Netzen, einschließlich drahtloser Anbindungen (WLAN) oder standortübergreifender Kopplungen (WAN). Der dokumentierte Bedarf beschreibt die konkret erforderlichen technischen, sicherheitsrelevanten und betrieblichen Eigenschaften der Netzschnittstelle, sodass bereits im Beschaffungsprozess transparent wird, welche Integrationsvoraussetzungen notwendig sind und welche Abweichungen nicht akzeptabel sind. Die Dokumentation dieses Bedarfs kann verhindern, dass Lösungen beschafft werden, die sich nur mit unsicheren Protokollen anbinden lassen oder bestehende Segmentierungs- und Schutzmechanismen umgehen, was zu ungewollten Netzöffnungen, erhöhten Angriffsflächen oder Integrationsproblemen führen könnte. Sie kann zudem Transparenz schaffen, sodass spätere Notlösungen wie unkontrollierte Gateways oder Protokollkonverter vermieden werden, die

zusätzliche Schwachstellen einführen könnten.

Control: BES.2.1.4.3 - Kompatibilität des Administrationsmodells

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.2 Bedarfserfassung

Übergeordnetes Control:

BES.2.1.4 Kompatibilität

UUID: 962e52b2-54ab-4c5d-842d-fb3c3132e986

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE den Bedarf für die Kompatibilität im Hinblick auf das Administrationsmodell dokumentieren.

Guidance

Unter „Kompatibilität im Hinblick auf das Administrationsmodell“ ist hier die technische und organisatorische Anschlussfähigkeit einer zu beschaffenden Lösung an das bestehende Berechtigungs- und Rollenmodell der Institution zu verstehen, also an die Struktur von Benutzerkonten, Rollen, Gruppen, Verantwortlichkeiten und administrativen Zuständigkeiten (z.B. Role-Based Access Control – RBAC, Attribute-Based Access Control – ABAC, Privileged Access Management – PAM). Das Administrationsmodell beschreibt dabei, wie Identitäten angelegt, geändert und gelöscht werden (Identity Lifecycle), wie Rechte vergeben und überprüft werden (Access Governance) und wie administrative Tätigkeiten nachvollziehbar protokolliert werden (Logging, Audit Trail). Die Dokumentation des Bedarfs für diese Kompatibilität bedeutet, dass im Beschaffungsprozess transparent festgehalten wird, welche Integrationsanforderungen bestehen, etwa hinsichtlich zentraler Verzeichnisdienste (z.B. LDAP, Active Directory), Single Sign-On (SSO), Multi-Faktor-Authentisierung (MFA), Mandantenfähigkeit oder der Trennung von administrativen und fachlichen Rollen. Der Zweck dieser Vorgabe liegt darin, Inkonsistenzen und Medienbrüche im Identitäts- und Berechtigungsmanagement zu vermeiden, da eine nicht kompatible Lösung zu Schattenadministration, doppelten Benutzerkonten oder unzureichender Trennung von Aufgaben führen könnte und dadurch unautorisierte Zugriffe oder feh-

lende Nachvollziehbarkeit begünstigt werden könnten. Eine frühzeitige und strukturierte Festlegung der Kompatibilitätsanforderungen kann hingegen eine einheitliche Durchsetzung von Sicherheitsrichtlinien, eine zentrale Steuerung privilegierter Konten und eine revisionssichere Protokollierung administrativer Handlungen unterstützen. die Unterstützung sowie (3) die technische Möglichkeit zur rollenbasierten Delegation administrativer Rechte innerhalb der Anwendung umfassen.

Control: BES.2.1.4.4 - Kompatibilität des Datenmanagementmodells

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.2 Bedarfserfassung

Übergeordnetes Control:

BES.2.1.4 Kompatibilität

UUID: f285248f-ba16-4748-80ac-a613dc09e448

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE den Bedarf für die Kompatibilität im Hinblick auf das Datenmanagementmodell dokumentieren.

Guidance

Unter „Kompatibilität im Hinblick auf das Datenmanagementmodell“ ist im Kontext dieser Anforderung die fachliche und technische Übereinstimmung beschaffter Produkte oder Dienstleistungen mit den in der Institution etablierten Regeln zur Strukturierung, Klassifizierung, Speicherung und Verarbeitung von Daten zu verstehen. Das Datenmanagementmodell beschreibt dabei unter anderem Datenkategorien (z.B. „confidentiality level“), Metadatenstrukturen, Datenformate, Lebenszyklusregeln („data lifecycle management“) sowie Integrationsvorgaben für Schnittstellen und Austauschformate. Kompatibilität meint hier insbesondere, dass neue IT-Systeme oder Anwendungen die definierten Datenformate, Klassifizierungsmerkmale, Aufbewahrungs- und Löschregeln sowie Anforderungen an Datenlokation („data residency“) technisch unterstützen oder abbilden können, ohne dass Medienbrüche, manuelle Nacharbeiten oder unkontrollierte Parallelstrukturen entstehen. Die Dokumentation dieses Bedarfs kann dazu beitragen, dass bei Beschaffungen von Anfang an Transparenz über notwendige Integrations- und Datenanforderungen entsteht und spätere kostenintensive Anpassungen vermieden werden. Ohne eine solche Berücksichtigung könnte es zu inkonsistenten Datenbeständen, fehlender Durchgängigkeit von Klassifizierungen oder zu unzulässigen Datenübertragungen in nicht vorgesehene Speicherorte kommen, was Integritäts- und Verfügbarkeitsrisiken er-

höht. Eine frühzeitige Festlegung kann hingegen eine konsistente Datenarchitektur und nachvollziehbare Datenflüsse unterstützen.

Control: BES.2.1.5 - Lizenzierung

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.2 Bedarfserfassung
Übergeordnetes Control:
BES.2.1 Erfassung des Bedarfes
UUID: 44fc68cb-5ee8-44aa-83ff-be56342c99dc
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für IT-Produkte SOLLTE für den geplanten Einsatzzeitraum erforderliche Lizenzen dokumentieren.

Guidance

Lizenzen sind erforderlich, wenn sie für den Einsatz des geplanten IT-Produktes benötigt werden. Hierbei können sowohl Softwarelizenzen selbst als auch begleitende Lizenzen, z.B. für Protokollierungssysteme oder Cloud-Schnittstellen gehören. Die Lizenzierung ist ausreichend, wenn voraussichtlich für alle anfallenden Arbeiten genug Zugänge und aktivierte IT-Produkte über den geplanten Einsatzzeitraum verfügbar sind. Denken Sie auch daran, welche Funktionen unter welcher Lizenz vom Anbieter freigeschaltet und erlaubt sind.

Control: BES.2.1.6 - Support- und Wartungsverträge

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.2 Bedarfserfassung
Übergeordnetes Control:
BES.2.1 Erfassung des Bedarfes
UUID: 0cdd35ea-188d-4731-99e3-27b5dbe8eca6
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für IT-Produkte SOLLTE den Bedarf an Support- und Wartungsverträgen basierend auf dem Schutzbedarf für Verfügbarkeit dokumentieren.

Guidance

Dies zielt auf den Abschluss von Support- und Wartungsverträgen für alle IT-Produkte ab, deren Verfügbarkeit nicht durch die Institution allein sichergestellt werden kann. Zur Ermittlung des Bedarfes können die Empfehlungen des jeweiligen Anbieters zu Wartungsintervallen herangezogen werden. Dabei kann es vorkommen, dass unterschiedliche Komponenten durchaus unterschiedliche Wartungsintervalle benötigen.

Control: BES.2.2 - Dokumentation des Rechtsraums und der Datenlokation

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.2 Bedarfserfassung

UUID: d4001ad1-3cac-4b4c-b075-dae3a8678a65

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Cloud-Dienste SOLLTE Rechtsraum und Datenlokation dokumentieren.

Guidance

Beispielsweise könnte die Datenlokation auf europäische Standorte eingeschränkt sein, während der Anbieter seinen Hauptsitz im außereuropäischen Rechtsraum hat und daher nicht der DSGVO unterliegt. Werden keine Daten aus dem Informationsverbund verarbeitet, so ist die Anforderung entbehrlich.

Links

required: BES.2.1.2 Geschäftsprozessprofile

related: BES.5.5.1 Datenlokationen

related: ASST.3.10 Autorisierung von Datenlokationen

Control: BES.2.3 - Vereinbarung des Rechtsraums und der Datenlokation

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.2 Bedarfserfassung

UUID: 00330bf7-9ed8-4606-bf6c-2657e7c47c61

Aufwand: 4

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Cloud-Dienste KANN Rechtsraum und Datenlokation mit dem Anbieter vereinbaren.

Guidance

Beispielsweise könnte die Datenlokation auf europäische Standorte eingeschränkt sein, während der Anbieter seinen Hauptsitz im außereuropäischen Rechtsraum hat und daher nicht der DSGVO unterliegt. Werden keine Daten aus dem Informationsverbund verarbeitet, so ist die Anforderung entbehrlich.

Links

related: BES.2.2 Dokumentation des Rechtsraums und der Datenlokation

Control: BES.2.4 - Anhörung Nutzender

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.2 Bedarfserfassung

UUID: d61dea6e-ac0f-42a9-8801-857fed920d50

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE Nutzende bei der Bedarfserfassung anhören.

Guidance

Werden IT-Produkte oder Dienstleistungen für eine Zielgruppe beschafft, so ist es zweckmäßig, Vertreter dieser Zielgruppe in die Erhebung der Beschaffungskriterien mit einzubeziehen. Dies kann durch die Anhörung aller potenziellen Nutzer, z.B. durch eine Umfrage, oder durch die Anhörung bestimmter Personen oder Rollen aus dem Kreis der Nutzenden (z.B. Fachverantwortliche, Testgruppen oder Stichproben) erfolgen.

Control: BES.2.5 - Anhörung Administrierender

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.2 Bedarfserfassung
UUID: 64a8bc51-2358-41c0-820d-d306f71d13ad
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE Administrierende bei der Bedarfserfassung anhören.

Guidance

Ohne diese Einbindung könnte etwa eine Fachabteilung Systeme einkaufen, die keine sicheren Schnittstellen bieten, nicht mit bestehenden Sicherheitsrichtlinien kompatibel sind oder schwer zu administrieren sind, was später zu kostspieligen Nacharbeiten oder Sicherheitslücken führen könnte. Eine rechtzeitige Beteiligung kann hingegen gewährleisten, dass Produkte aus administrativer Sicht wartbar, updatefähig und kompatibel mit etablierten Sicherheitsmechanismen sind. Die Anforderung kann durch verschiedene Maßnahmen praktisch umgesetzt werden: (1) Ein definiertes Beschaffungsformular kann Eingabefelder enthalten, in denen die fachliche Einschätzung von Administrierenden dokumentiert werden kann. (2) Eine Checkliste mit Mindestkriterien wie Updatefähigkeit, Protokollierungsoptionen oder Berechtigungssteuerung kann bei jeder Bedarfserfassung hinzugezogen werden. (3) Ein kurzer, standardisierter Freigabeprozess über ein Ticket- oder Workflow-System kann sicherstellen, dass vor der endgültigen Beschaffung eine Rückmeldung aus administrativer Sicht eingeholt wird. (4) Zur Effizienzsteigerung kann eine Wissensdatenbank mit Erfahrungswerten zu bereits genutzten Produkten gepflegt werden, sodass Administrierende wiederkehrende Anforderungen schneller einschätzen können.

Control: BES.2.6 - Outsourcing auf Grundlage der Geschäftsprozessprofile

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.2 Bedarfserfassung

UUID: 5b865e92-14ed-47a0-ae5f-219e5ef7b09b

Aufwand: 4

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Outsourcing KANN Outsourcingverträge auf Grundlage der Geschäftsprozessprofile durch die Leitung autorisieren.

Guidance

Das Outsourcing eigener (Teil-)Prozesse ist eine bewusste und häufig folgenreiche Entscheidung - auch für die eigene Kontrolle der Informationssicherheit. Die Entscheidung kann sich am festgestellten Schutzbedarf oder Risikoprofil der Institution und der betroffenen Geschäftsprozesse orientieren. Die Entscheidung durch die Leitung bezieht sich hier auf die Frage, ob Outsourcing von der Institution grundsätzlich gewollt ist und welche (Teil-)Prozesse ausgelagert werden können oder in der Institution verbleiben. Diese kann konkrete Geschäftsprozesse benennen, aber auch anhand allgemeiner Kriterien getroffen werden (z.B. Keine Auslagerung von Geschäftsprozessen mit hohem Schutzbedarf).

Links

required: BES.2.1.2 Geschäftsprozessprofile

Control: BES.3.1 - Klassifizierung von Lieferantenbeziehungen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.3 Auswahl von Lieferanten

UUID: 5d268fc9-f0f7-4d5d-ade2-68b6910070db

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE Lieferantenbeziehungen einer Klasse zuweisen.

Guidance

Klasse meint hier eine Einstufung der Lieferantenbeziehung aus dem Blickwinkel der Informationssicherheit. Dies ermöglicht den Mitarbeitern der Institution eine schnelle und korrekte Abschätzung, welche Informationen dem Lieferanten gegenüber preisgegeben werden dürfen. Die Klassen können sowohl anhand einer Einstufung der Daten (z.B. Preisgabe von Verschlusssachen oder nicht), als auch anhand der Funktion aus Sicht der Institution (z.B. Finanzdienstleister, Versorgungseinrichtungen, Cloud, Logistik, Lieferant von IT-Produkten) gewählt werden. Es empfiehlt sich auch das Herkunftsland oder nachrichtendienstliche Erkenntnisse über den Lieferanten mit in die Bewertung einfließen zu lassen.

Control: BES.3.2 - Auswahlkriterien

Tags: "Lieferketten" "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.3 Auswahl von Lieferanten
UUID: 3f92f682-56ae-447b-996e-a4b5f4bd8963
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation

Statement

Beschaffungsmanagement für Einkäufe SOLLTE die Auswahl von Lieferanten anhand von Kriterien zu ihrer Verlässlichkeit verankern.

Guidance

Beispielsweise durch Marktanalysen, Kundenreferenzen, Zertifizierungen, Begutachtungen oder Audits. Hierzu können z.B. Entwicklungsprozesse, Verschlüsselung oder Anonymisierung vertraulicher Daten, Schlüsselmanagement, Authentifizierung von Zugriffen, Wiederherstellung nach Vorfällen oder die Evaluation der sicheren Verarbeitung gehören. Auch die Prüfung auf finanzielle Stabilität des Lieferanten ist zu empfehlen. Ein finanziell instabiler Lieferant stellt ein erhebliches Risiko für die Geschäftskontinuität dar, da er möglicherweise den Betrieb einstellt, Supportleistungen nicht mehr erbringen kann oder von einem Unternehmen mit unklaren Sicherheitsstandards übernommen wird.

Links

related: BES.1.3 Lieferanten- und Dienstleisterverzeichnis
related: DLS.3.5 Blockierung unzuverlässiger Dienstleister

Control: BES.3.2.1 - Zertifizierte Lieferanten

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.3 Auswahl von Lieferanten
Übergeordnetes Control:
BES.3.2 Auswahlkriterien
UUID: 66e8a313-c8cf-48e2-b04e-98013c2c9243
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Einkäufe KANN die Auswahl von Lieferanten anhand von Zertifikaten, Testaten oder Vergleichbarem verankern.

Guidance

Ein „Zertifikat“ ist in diesem Kontext ein formaler Nachweis durch eine akkreditierte, unabhängige Stelle, dass bestimmte Anforderungen oder Standards erfüllt werden (z. B. ISO/IEC-Normen). Ein „Testat“ kann die schriftliche Bestätigung einer fachkundigen Prüfstelle darstellen, dass ein Prozess oder System in definierten Punkten geprüft und als konform bewertet wurde. Vergleichbare Nachweise können Berichte von Audits, externe Gutachten oder auch dokumentierte Ergebnisse standardisierter Sicherheitstests sein. Eine Institution kann die Anforderung konkret umsetzen, indem sie in Ausschreibungen eine Liste akzeptierter Zertifikate (z. B. ISO 27001, ISO 9001, SOC 2), Testate (z. B. C5 für Cloud-Dienste) oder vergleichbarer Nachweise (z. B. Penetrationstest-Reports durch Dritte) benennt. Hilfreich kann es sein, Mindestgültigkeitszeiträume für Nachweise zu definieren, stichprobenartige Plausibilitätsprüfungen der Dokumente vorzunehmen oder in Bewertungsmatrizen höhere Gewichtungspunkte für aktuelle und unabhängige Nachweise zu vergeben. Zusätzlich kann ein einfacher Maßnahmenkatalog etabliert werden, der (1) überprüft, ob Nachweise aktuell und gültig sind, (2) die Relevanz für den konkreten Leistungsumfang bewertet und (3) die Ergebnisse nachvollziehbar dokumentiert, um Entscheidungen transparent und revisionssicher zu halten.

Control: BES.3.2.2 - Quellendiversifikation

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.3 Auswahl von Lieferanten
Übergeordnetes Control:
BES.3.2 Auswahlkriterien
UUID: 6d1954f0-d3b8-4c4b-84bc-b0586d0d6476
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Einkäufe KANN die Auswahl von Lieferanten anhand ihrer Fähigkeit, ihre Bezugsquellen zu diversifizieren und die Bindung an bestimmte Lieferanten zu begrenzen, verankern.

Guidance

Die Fähigkeit zur Diversifizierung von Bezugsquellen bedeutet in diesem Kontext, dass ein Lieferant nicht ausschließlich auf einzelne Hersteller, Produzenten oder Märkte angewiesen ist, sondern alternative Beschaffungswege vorweisen kann. Die Bindung an bestimmte Lieferanten beschreibt eine Abhängigkeit, bei der zentrale Produkte oder Dienstleistungen faktisch nur von wenigen oder gar einem Anbieter bezogen werden können. Der Sinn dieser Anforderung liegt darin, die Risiken eines Vendor lock-in auf Seiten des Lieferanten zu begrenzen: Könnte ein Lieferant aufgrund geopolitischer Spannungen, wirtschaftlicher Probleme oder technischer Abkündigungen sich nicht mehr auf seine Zulieferer verlassen, so könnte er möglicherweise seine Leistungen nicht mehr erbringen, wodurch die Institution ohne Alternativen möglicherweise gravierende Ausfälle erleiden würde. Eine bewusste Auswahl nach Diversifizierungsfähigkeit kann die Versorgungssicherheit erhöhen und kritische Engpässe vermeiden.

Control: BES.3.3 - Unzuverlässige Lieferanten

Tags: "Lieferketten" "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.3 Auswahl von Lieferanten
UUID: 4bcaa246-3ee4-4d39-9998-d9ce1f5faf44
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE die Beschaffung aus einer unbekannten oder unzuverlässigen Quelle untersagen.

Guidance

Eine Quelle (z.B. ein Softwarelieferant) ist unzuverlässig, wenn zukünftig mit Verstößen gegen die Schutzziele Vertraulichkeit, Verfügbarkeit oder Integrität durch ihn zu rechnen ist (d.h. eine Prognose der Vertrauenswürdigkeit). Dies ist insbesondere der Fall, wenn erhebliche Verstöße gegen die Schutzziele durch ihn begangen worden sind oder Anzeichen dafür vorliegen, dass bei einer Verwendung mit solchen Verstößen zu rechnen ist.

Links

related: DEV.4.2 Bibliotheksquellen

Control: BES.4.1 - Klassifizierung von Beschaffungsvorhaben

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
UUID: 0e95983d-3def-4ce0-a037-31ed7dbc9ef8
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE dem Beschaffungsvorhaben eine Klasse zuweisen.

Guidance

Hierzu kann auf die Klassifizierung von Informationen zurückgegriffen werden, die vom zu beschaffenden Vertrag betroffen sind. Oft verfügen Lieferanten über eigene Klassifizierungsschemata, die sie wiederum mit bestimmten Sicherheitsregelungen und -mechanismen verknüpft haben. In diesem Fall bietet sich ein Mapping zwischen den institutionseigenen Klassen und denen des Lieferanten an. Weitere Informationen zur Festlegung möglicher Kriterien, inklusive einer Risikobeurteilung, können der ISO/IEC 27036-3 entnommen werden.

Control: BES.4.2 - Dokumentation der Beschaffungskriterien

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
UUID: 91319f26-75c0-476c-b544-aedd4dbf6e14
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE {{ insert: param, bes.4.2-prm1 }} für die Beschaffung dokumentieren.

Guidance

Beschaffungskriterien sind nachvollziehbare Bewertungsmaßstäbe, die bei der Anschaffung von IT-Produkten und Dienstleistungen berücksichtigt werden, um sicherzustellen, dass diese den Sicherheitsanforderungen der Institution entsprechen. Sie ergeben sich aus dem erfassten Bedarf (z.B. einer Beschreibung der Funktionen von IT-Produkten oder zu leistenden Diensten), sowie den Sicherheitsanforderungen an das zu beschaffende Produkt oder die Dienstleistung, die über das jeweilige Zielobjekt im Katalog gefiltert werden können. Beispiele für Beschaffungskriterien sind die Erfüllung definierter Sicherheitsstandards, Verschlüsselungsfähigkeiten, Authentifizierungsmechanismen, Autorisierungskonzepte, die Stärke der geforderten Mechanismen (z.B. Mehr-Faktor-Authentifizierung), Verfügbarkeitsgarantien (SLAs), Umfang und Qualität der Dokumentation, Regelungen zur Prüfung oder Überwachung der Sicherheitskontrollen, sowie Einsatzbedingungen wie Temperatur oder mobile Konnektivität. Relevant ist dabei der gesamte Lebenszyklus von Vertragsabschluss über Entwicklung von Lösungen bis hin zu Regelungen für Kündigungen. Zu den Kriterien können auch Negativkriterien gehören, die eine Beschaffung verhindern würden (z.B. "Keine Komponenten von der unmittelbaren Konkurrenz oder aus Staaten von denen bekannt ist, dass sie Spionage gegen den Sektor der Institution betreiben"). Je nach Beschaffung kann dafür eine Beschreibung von Informationen und Methoden zur Bereitstellung oder zum Abruf der Informationen relevant sein, sowie eine Beschreibung bestimmter technischer Eigenschaften eines Systems oder

einer Anwendung. Zur Umsetzung bietet es sich an, standardisierte Vertragsvorlagen für neue Verträge zu verwenden. Bei individuellen Verträgen, die einzelne Sicherheitskontrollmechanismen festlegen, bietet sich ein Austausch von Beschreibungen der Mechanismen über strukturierte Datenformate wie OSCAL an. Weitere Informationen zur Festlegung möglicher Kriterien, inklusive einer Risikobeurteilung, können der ISO/IEC 27036-3 entnommen werden.

Links

related: BES.2.1 Erfassung des Bedarfes

Control: BES.4.3 - Beschaffung anhand der Kriterien

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
UUID: f8089693-7d13-4f0e-b9a0-98102f685d74
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE die Beschaffung anhand der festgelegten Kriterien verankern.

Guidance

Werden Waren, Systeme oder Dienstleistungen ohne überprüfbare Kriterien beschafft, kann dies zu Sicherheitslücken, finanziellen Schäden oder Abhängigkeiten führen. Beispielsweise könnte eine Institution Hardware von einem unbekannten Anbieter erwerben, deren Firmware Schadcode enthält, oder Cloud-Dienste nutzen, die ihre Datenhaltung in unsicheren Rechtsräumen vornehmen. Ebenso könnte ein IT-Dienstleister beauftragt werden, ohne dass geprüft wurde, ob er über angemessene Qualifikationen oder Referenzen verfügt, was im Ernstfall zu Ausfällen oder Datenverlust führen könnte.

Links

required: BES.4.2 Dokumentation der Beschaffungskriterien

Control: BES.4.4 - Vertragsvorlage für Outsourcing

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
UUID: 5e9bc675-aaa4-48eb-a7c2-5ab27fff09c4
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Outsourcing SOLLTE Kriterien für Outsourcing-Dienstleistungen in einer standardisierten Richtlinie für Verträge dokumentieren.

Guidance

Eine standardisierte Richtlinie für Verträge enthält klare grundlegende Kriterien für Verträge mit Anbietenden von Outsourcing , etwa zu Datenlokationen, Test- und Freigabeverfahren, Compliance-Risiken bei Anbietenden von Outsourcing sowie bei Sub-Dienstleistenden, sowie weiteren Aspekte der Informationssicherheit für Outsourcing-Vorhaben. Der besondere Fokus auf Outsourcing ergibt sich daraus, dass hierbei nicht nur Werk- oder Dienstleistungen zugekauft werden, sondern sensible Prozesse oder Daten langfristig aus der direkten Kontrolle der Institution herausgegeben werden. Ohne standardisierte Kriterien könnte ein eigenhändisch formulierter Vertrag z. B. unpräzise Datenschutzregelungen enthalten, was im Vorfallfall dazu führen könnte, dass vertrauliche Daten in ein unsicheres Drittland gelangen oder dass bei Ausfällen keine klaren Eskalationswege bestehen.

Control: BES.4.5 - Security by Design

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
UUID: 90462e6d-fc7a-4bf6-bffb-5f005d89aa7c
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.5.2 Mandantentrennung

Statement

Beschaffungsmanagement für Einkäufe SOLLTE Security by Design vereinbaren.

Guidance

Security by Design gilt als vereinbart, wenn eine Vorgehensweise nach diesem Prinzip oder eine bestimmte Sicherheitsarchitektur Vertragsbestandteil geworden sind, unabhängig von der Frage, von welchem Vertragspartner dies in den Vertrag eingebracht wurde. Zu einer Sicherheitsarchitektur gehören beispielsweise eine Beschreibung der bereitgestellten Schnittstellen und deren Sicherheitsmechanismen, ein Architekturdiagramm, sowie Schemata zum Aufbau von Komponenten oder von Quellcode.

Links

related: DEV.1.1 Verfahren und Regelungen

related: DEV.2.1 Security by Design Architektur

Control: BES.4.5.1 - Entwicklung nach einem Sicherheitslebenszyklus

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
Übergeordnetes Control:
BES.4.5 Security by Design
UUID: e6a52543-165f-4465-a59f-1928482a96c5
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für IT-Produkte KANN Nachweise zur Entwicklung nach einem Sicherheitslebenszyklus vereinbaren.

Guidance

Ein Sicherheitslebenszyklus (engl. security development lifecycle, kurz SDL) besteht aus strukturierten Entwicklungsphasen, in denen Sicherheitsaspekte systematisch in Planung, Design, Implementierung, Test und Wartung eines IT-Produkts integriert werden. Solche Nachweise können etwa BSI-Zertifizierungen oder Dokumentationen einer vom Lieferanten unabhängigen Auditierung von Bedrohungsanalysen (threat modeling), sicheren Programmierpraktiken (secure coding guidelines), oder Ergebnissen von Penetrationstests umfassen. Ziel ist, nachprüfbar zu belegen, dass das Produkt nicht nur funktional, sondern auch sicherheitsseitig kontrolliert entwickelt wurde. Fehlt ein solcher Nachweis, könnte ein Produkt Schwachstellen enthalten, die später zu unbemerkten Manipulationen oder Datenabflüssen führen. Ein dokumentierter Sicherheitslebenszyklus kann dagegen Vertrauen in die Integrität, Belastbarkeit und Wartbarkeit eines Produkts schaffen. Die Vereinbarung entsprechender Nachweise kann beispielsweise über standardisierte Sicherheitsanforderungen in Ausschreibungsunterlagen, die Vorlage von Entwicklungsrichtlinien nach ISO/IEC 27034 oder NIST SP 800-218, oder die Anerkennung von Zertifikaten wie Common Criteria erfolgen. Alternativ kann die Institution bei kleineren Anbietern auch stichprobenartige Sicherheitsreviews, Entwicklerbefragungen oder Auditberichte als geeignete Nachweisvarianten akzeptieren.

Control: BES.4.5.2 - Mandantentrennung

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kern"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
Übergeordnetes Control:
BES.4.5 Security by Design
UUID: ffafe5ae-04e1-4aef-ae3f-2a3eeb193743
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Outsourcing KANN eine festgelegte Mandantentrennung vereinbaren.

Guidance

Eine Mandantentrennung bezeichnet die Trennung schützenswerter Daten und Verarbeitungskontexte zwischen verschiedenen Mandanten, also den Kunden des Anbieters. Eine festgelegte Mandantentrennung meint hier, dass der Anbieter Informationen über die konkret von ihm zur Mandantentrennung getroffenen Maßnahmen bereitstellt. Hierzu gehören insbesondere Informationen darüber, welche Daten oder Funktionen als mandantenabhängige oder mandantenübergreifende Daten behandelt werden.

Links

related: BES.7.4.11 Dokumentierte Mandantentrennung

Control: BES.4.6 - Security by Default

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
UUID: eaea6c10-713f-41d4-95f1-128784ef15d5
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.4.6.1 Authentifizierung des Kunden
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.6.3 Manipulationsschutz

Statement

Beschaffungsmanagement für Einkäufe SOLLTE Security by Default vereinbaren.

Guidance

Der Detaillierungsgrad der Kriterien kann sich hierbei nach Umfang und Klassifizierung der Beschaffung richten. Bei einfachen Beschaffungen von geringer Bedeutung kann es ausreichend sein grundlegende Sicherheitsmechanismen wie Verschlüsselung und Authentifizierung zu vereinbaren, während bei umfangreichen oder anderweitig risikobehafteten Beschaffungen eine Vereinbarung einzelner Sicherheitsmechanismen sinnvoll ist.

Control: BES.4.6.1 - Authentifizierung des Kunden

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
Übergeordnetes Control:
BES.4.6 Security by Default
UUID: 812c1589-0233-4e24-a69b-d9a4b02e3c1e
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE eine Authentifizierung vor dem Zugriff auf schützenswerte Informationen oder Dienste vereinbaren.

Guidance

Sinnvoll ist es sich hierbei auf konkrete Authentifizierungsmethoden (z.B. Kundenkennwort, OTP oder Passkeys) zu einigen, mit denen authentifiziert wird, bevor der Lieferant jemandem Zugriff auf Daten oder Prozesse wie den Versand einer neuen SIM-Karte gibt, um Angriffe wie SIM Swapping zu verhindern.

Control: BES.4.6.2 - Verschlüsselung durch den Anbieter

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kern"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
Übergeordnetes Control:
BES.4.6 Security by Default
UUID: adac1038-a7a7-4346-8c7e-22e322cf8f2b
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Outsourcing SOLLTE die Verschlüsselung schützenswerter Informationen durch den Anbieter vereinbaren.

Guidance

Hiermit ist die Ablageverschlüsselung (at rest) und die Transportverschlüsselung (in transit) gemeint. Die Transportverschlüsselung ist dabei sowohl für die Verbindung zum Outsourcing-Dienstleister, als auch bei der Übertragung innerhalb des Dienstleisternetzes vorzunehmen.

Links

related: DLS.2.2 Transportverschlüsselung

Control: BES.4.6.3 - Manipulationsschutz

Tags: "Lieferketten" "Cryptography" "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
Übergeordnetes Control:
BES.4.6 Security by Default
UUID: 4e08941c-a1c7-4718-934f-c1e8c3e17864
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für IT-Produkte KANN Schutzmechanismen gegen Manipulationen auf dem Lieferweg vereinbaren.

Guidance

Bei physischen Produkten können hierfür Siegel oder schwer fälschbare Kennzeichnungen verwendet werden, während bei Software und Daten kryptographische Prüfsummen oder digitale Signaturen eingesetzt werden können.

Control: BES.4.7 - ISMS beim Dienstleister

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
UUID: b70e7569-2d18-482b-8f7f-720cd0b1fcb7
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Outsourcing SOLLTE ein Managementsystem für Informationssicherheit (ISMS) vereinbaren.

Guidance

Ohne klare Vorgaben zum Managementsystem könnte ein Anbieter vertrauliche Daten unverschlüsselt übertragen, Sicherheitslücken in seiner Infrastruktur nicht rechtzeitig schließen oder sicherheitsrelevante Vorfälle nicht transparent melden. Durch abgestimmte Sicherheitsstandards kann dagegen die Vertraulichkeit von Daten gewahrt, die Integrität von Prozessen gesichert und die Nachvollziehbarkeit bei Vorfällen verbessert werden. Das Vorhandensein lässt sich durch ein Zertifikat nachweisen, z.B. nach ISO/IEC 27001:2022 oder BSI IT-Grundschutz.

Control: BES.4.8 - Konformitätsnachweise

Tags: "Lieferketten" "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
UUID: 3e56f7c0-63b1-4017-8e30-3a78c1f06693
Aufwand: 4
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.4.8.1 Zertifizierung
- BES.4.8.2 Cloud-Konformität
- BES.4.8.3 IT-Grundschutz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse

Statement

Beschaffungsmanagement für Einkäufe SOLLTE Nachweise des Lieferanten zur Erfüllung der Sicherheitskriterien vereinbaren.

Guidance

Nachweise können z.B. durch eine passende Zertifizierung (etwa nach IT-Grundschutz bei Dienstleistern oder CCRA bei IT-Produkten), ein Testat (z.B. C5-Testat für Cloud-Anbieter), oder durch die Vorlage von Sicherheitskonzepten, Risikoanalysen und Pentesting-Ergebnissen erbracht werden.

Control: BES.4.8.1 - Zertifizierung

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
Übergeordnetes Control:
BES.4.8 Konformitätsnachweise
UUID: 6cecab39-d08d-49a1-922e-b3f9ea7d5af4
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Einkäufe KANN ein Zertifikat oder Testat nach {{ insert: param, bes.4.8.1-prm1 }} vereinbaren.

Guidance

Ein Zertifikat ist eine unabhängige Bestätigung der Konformität, die von einer akkreditierten Konformitätsbewertungsstelle (wie z.B. einer Zertifizierungsstelle) ausgestellt wird, nachdem diese die Konformität eines Produkts, einer Dienstleistung, eines Prozesses oder eines Managementsystems mit bestimmten Normen oder Anforderungen bestätigt hat. Die Art des Zertifikates richtet sich dabei nach der Art der geplanten Beschaffung. IT-Produkte können z.B. nach Common Criteria zertifiziert werden. Bei Dienstleistungen kann ein zertifiziertes Managementsystem für Informationssicherheit (nach IT-Grundschutz oder ISO/IEC 27001) vereinbart werden. Ein Testat wäre z.B. C5.

Control: BES.4.8.2 - Cloud-Konformität

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
Übergeordnetes Control:
BES.4.8 Konformitätsnachweise
UUID: ccb6ba42-3bb5-4ef8-b089-70a6e383f96c
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Cloud-Dienste SOLLTE einen Konformitätsnachweis durch Dritte vereinbaren.

Guidance

Beispielsweise durch ein C5 Testat. Hierbei ist zu prüfen, ob der Geltungsbereich und der Schutzbedarf die genutzten Clouddienste erfasst (Auswertung des Nachweises). Dies gilt auch für Subdienstleister.

Control: BES.4.8.3 - IT-Grundschutz-Analyse der Infrastruktur

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
Übergeordnetes Control:
BES.4.8 Konformitätsnachweise
UUID: 989d9e29-9064-4366-a887-bc17c1440e35
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Outsourcing KANN eine IT-Grundschutz-Analyse der potenziell zu nutzenden Infrastruktur des Dienstleisters vereinbaren.

Guidance

Bei einer IT-Grundschutz-Analyse im Rahmen des Outsourcings wird an der potenziell zu nutzenden Infrastruktur des Dienstleisters eine IT-Grundschutz-Analyse (Strukturanalyse, Schutzbedarfsfeststellung, ...) durchgeführt. Anschließend werden die sich daraus ergebenden Sicherheitsanforderungen als Beschaffungskriterien an den Dienstleister gestellt. Dies bietet sich an, wenn entweder ein besonders hohes Sicherheitsniveau angestrebt wird, oder der Dienstleister bislang über kein ISMS verfügt, obwohl die Institution umfangreiche Prozesse auslagern möchte.

Control: BES.4.8.4 - Offenlegung der Risikoanalyse

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
Übergeordnetes Control:
BES.4.8 Konformitätsnachweise
UUID: ff58fdb4-bc6e-42fc-9e28-eb89a32bc656
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Outsourcing KANN eine Offenlegung der Risikoanalyse aus dem ISMS des Dienstleisters, soweit eine Risikoanalyse nach IT-Grundschutz-Vorgehensweise notwendig ist, vereinbaren.

Guidance

Eine Offenlegung ist hierzu nur erforderlich, soweit die Informationen für die Risikoanalyse des Auftraggebers erforderlich sind.

Control: BES.4.9 - Sicherheitsüberprüfung (extern)

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.4 Auswahl von Produkten und Dienstleistungen
UUID: ec083939-6e37-46be-978e-7b0c894ab768
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Einkäufe KANN Sicherheitsüberprüfungen für Personen, die vom Lieferanten mit der Vertragsdurchführung beauftragt werden, vereinbaren.

Guidance

Eine Sicherheitsüberprüfung meint die Verifikation von Identität, beruflicher Qualifikation und Verlässlichkeit von allen Personen mit Zugriff auf schützenswerte Informationen, hier konkret des beauftragten Personal des Lieferanten. Die Sicherheitsüberprüfung kann je nach Vereinbarung vom Lieferanten oder dem Auftraggeber ausgeführt werden. Die Verlässlichkeit kann z.B. anhand eines polizeilichen Führungszeugnisses und einer OSINT-Recherche verifiziert werden. Hierbei besteht ein enger Bezug zum Persönlichkeits- und Datenschutzrecht der Betroffenen.

Links

related: PERS.3.6.1 Sicherheitsüberprüfung (intern)

Control: BES.5.1 - Kompetenzen

Tags: "Lieferketten" "Kompetenzmanagement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: b06b3614-ed43-4d03-a3af-700d7416f550

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE Kompetenzen in Informationssicherheit, die von den Mitarbeitern des Lieferanten verlangt werden, vereinbaren.

Guidance

Dient dem Ziel, Risiken durch unzureichend geschultes Personal zu minimieren. Ohne solche Vorgaben könnte es dazu kommen, dass Dienstleister vertrauliche Daten versehentlich preisgeben, schwache Passwörter verwenden oder Phishing-Angriffe nicht erkennen. Durch die Vereinbarung von Mindestkompetenzen kann erreicht werden, dass Dienstleister Sicherheitsrichtlinien verstehen, Bedrohungen frühzeitig identifizieren und im Einklang mit den Schutzinteressen der Institution handeln. Im Kontext bedeutet Kompetenzen in Informationssicherheit, dass Mitarbeiter des Lieferanten über Wissen, Fähigkeiten und Verhalten verfügen, die erforderlich sind, um mit vertraulichen Informationen und IT-Systemen angemessen sicher umzugehen. Dies kann grundlegendes Verständnis für sichere Passwörter und mobile Geräte umfassen, aber auch Kenntnisse zu branchenspezifischen Sicherheitsverfahren oder zum Umgang mit sensiblen Kundendaten. Eine sinnvolle Umsetzung kann zum Beispiel beinhalten, dass die Institution in den Verträgen mit Lieferanten konkrete Mindestanforderungen an Schulungen und Zertifikate definiert, etwa: (1) Einführungsschulungen zu IT-Sicherheitsgrundlagen, (2) regelmäßige Auffrischungen zu Themen wie Social Engineering oder sichere Datennutzung, (3) Nachweise über spezielle Fachkenntnisse, wenn besonders sensible Daten verarbeitet werden. Praktisch kann eine Institution durch standardisierte Schulungsprogramme, die Überprüfung von Zertifikaten (z. B. ISO/IEC- oder BSI-bezogene Qualifikationen) oder durch kurze Wissens-Checks im Rahmen der Dienstleister-Onboarding-Prozesse sicherstellen, dass vereinbarte Kompetenzen tatsächlich vorhanden sind.

Control: BES.5.2 - Service Level Agreement

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: 31fea405-1180-4c99-b080-a90a2ee6f574

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Outsourcing SOLLTE die Einhaltung einer bestimmten Dienstgüte anhand von {{ insert: param, bes.5.2-prm1 }} vereinbaren.

Guidance

Dienstgüte (engl. Service Quality oder Service Level) beschreibt das messbare Leistungsniveau, das ein externer Anbieter dauerhaft erbringen soll. Sie wird üblicherweise in Service Level Agreements (SLA) festgelegt und kann Aspekte wie Reaktionszeiten, Verfügbarkeiten, Fehlerraten oder Sicherheitsstandards betreffen. Die Kriterien können z. B. Verfügbarkeit (in %), maximale Wiederherstellungszeiten (Recovery Time Objective, RTO), Datensicherheitsmaßnahmen, Supportzeiten oder Nachweisintervalle für Penetrationstests sein. Der Zweck dieser Vorgabe liegt darin, Risiken unklarer Leistungs- oder Sicherheitsverantwortung zu vermeiden, die im Falle unpräziser oder fehlender Dienstgütezusagen zu Ausfällen, Datenverlusten oder unzureichenden Sicherheitsreaktionen führen könnten. Eine klar definierte und überprüfbare Dienstgüte kann dagegen Transparenz schaffen, die Vergleichbarkeit von Anbietern erleichtern und die Resilienz ausgelagerter Prozesse erhöhen. Dabei sind möglichst objektivierte, quantitative Kriterien deutlich nachvollziehbarer und eindeutiger als einfache Beschreibungen wie "gut". Ein Beispiel ist eine Mindestverfügbarkeit von 99% für einen Server, auf dem hochverfügbare Daten gespeichert werden. Neben einzuhaltenden Mindestkriterien bietet es sich hier auch an optionale Qualitätskriterien festzulegen, bei deren Erfüllung höhere Preise akzeptiert werden, um ein "Race to the bottom" im Wettbewerb der Anbieter um die Institution zu vermeiden, da ein rein preisorientierter Wettlauf auf Kosten der Sicherheit gehen könnte.

Control: BES.5.3 - Compliance-Verpflichtungen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: 9c0e2a1c-59f9-4390-9d1c-6ec3417892a8

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE die Übereinstimmung mit Compliance-Verpflichtungen vereinbaren.

Guidance

Hierzu gehören beispielsweise der Schutz personenbezogener Daten, geistige Eigentumsrechte von interessierten Parteien oder Dritten. Aufgrund unterschiedlicher Rechtssetzung und -durchsetzung sind dabei insbesondere Verarbeitungsstandorte zwischen Inland, EU und außereuropäischem Ausland zu unterscheiden.

Control: BES.5.4 - Informationssicherheitskontrollmechanismen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: d2df7724-3a8a-4125-bd43-fa78cfe61d7b

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE Informationssicherheitskontrollmechanismen vereinbaren.

Guidance

Genaue und vollständige Beschreibung der Mechanismen, insbesondere zur Zugriffskontrolle durch Mehr-Faktor-Authentifizierung, Verschlüsselung von Daten beim Transport und bei der Speicherung, Härtung von Systemen, Überwachung sicherheitsrelevanter Ereignisse oder zum Schwachstellenmanagement.

Control: BES.5.5 - Nutzungsregelungen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: cc1f6483-3c4d-4258-8f4c-f1d4dbff69c8

Aufwand: 3

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE Regelungen zur Nutzung der Daten und damit verbundenen Assets vereinbaren.

Guidance

Hierzu zählen z.B. Zugriffsregelungen und Regelungen darüber unter welchen Bedingungen (Ort, Zeit, etc.) Daten genutzt werden dürfen. Darüber hinaus gehören auch Regelungen dazu, wann eine Nutzung aus Sicht der Institution explizit nicht akzeptabel ist.

Control: BES.5.5.1 - Datenlokationen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

Übergeordnetes Control:

BES.5.5 Nutzungsregelungen

UUID: 5fc9434d-4d26-4383-ba5a-d921563f01ce

Aufwand: 4

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Dienstleistungen KANN die Verarbeitung von Daten ausschließlich an von der Institution erlaubten Datenlokationen vereinbaren.

Guidance

Ziel ist es zu verhindern, dass vertrauliche Informationen in Staaten mit schwachem Datenschutz oder unter fremder Rechtsaufsicht verarbeitet werden. Ohne diese Festlegung könnte ein Dienstleister Daten an Subunternehmer in Drittländern weitergeben, wo staatliche Zugriffe oder unzureichende Sicherheitsmaßnahmen die Vertraulichkeit und Integrität der Daten gefährden könnten. Durch eine konsequente Beschränkung der Datenlokationen kann die Institution hingegen nachvollziehbare Sicherheits- und Rechtsrahmen schaffen, die Transparenz gegenüber Betroffenen erhöhen und das Risiko unkontrollierter Datenabflüsse verringern. Unter „Datenlokation“ ist in diesem Kontext der physische oder virtuelle Standort gemeint, an dem Daten gespeichert, verarbeitet oder übertragen werden – also Rechenzentren, Cloud-Regionen oder spezifische Länderzonen. Eine „erlaubte Datenlokation“ kann eine innerhalb der EU liegende Cloud-Region, ein zertifiziertes Rechenzentrum im eigenen Land oder ein dedizierter Bereich innerhalb eines Cloud-Anbieters sein. Die Institution kann dies umsetzen, indem sie (1) in Dienstleistungsverträgen präzise Angaben zu zulässigen Ländern oder Regionen vereinbart, (2) von Dienstleistern Nachweise wie technische Standortkontrollen oder Auditberichte einfordert und (3) bei Cloud-Diensten gezielt Konfigurationen wie „Data Residency“-Optionen, Geofencing oder restriktive Auswahl von Regionen einsetzt.

Links

required: ASST.3.10 Autorisierung von Datenlokationen

Control: BES.5.5.2 - Autorisierung der Zugriffsberechtigung

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

Übergeordnetes Control:

BES.5.5 Nutzungsregelungen

UUID: adb32e38-f59a-42fa-b1a0-67abd118c585

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE Regelungen zur Autorisierung der Zugriffsberechtigung für Personal des Lieferanten anhand von {{ insert: param, bes.5.5.2-prm1 }} vereinbaren.

Guidance

Dies kann beispielsweise durch eine explizite Liste der Personen oder Rollen des Zulieferers, welche berechtigt sind, die Informationen der Institution und andere zugehörige Vermögenswerte zu nutzen, umgesetzt werden.

Control: BES.5.6 - Vergabe von Unteraufträgen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: 893be21d-b437-462d-9d29-193e2b6f62cc

Aufwand: 4

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette

Statement

Beschaffungsmanagement für Einkäufe SOLLTE Regelungen für die Vergabe von Unteraufträgen vereinbaren.

Guidance

Unter einem „Unterauftrag“ versteht man in diesem Kontext die vollständige oder teilweise Weitergabe vertraglich geschuldeter Leistungen an Dritte, z.B. einem Subunternehmer (Subcontractor). Relevant ist, dass die Institution nicht nur mit dem direkten Vertragspartner in einer vertraglichen Beziehung steht, sondern durch Unteraufträge auch indirekt Abhängigkeiten und Risiken entstehen könnten. Ohne klare Vereinbarungen könnte es dazu kommen, dass Unterauftragnehmer geringere Sicherheitsstandards einhalten, vertrauliche Informationen unzureichend schützen oder den vereinbarten Leistungsumfang nicht vollständig erfüllen. Beispielsweise könnte ein IT-Dienstleister einen Teil der Softwareentwicklung an ein externes Team in einem Land mit niedrigeren Datenschutzstandards auslagern, was zu Datenabfluss, Urheberrechtsverletzungen oder unkontrollierten Zugriffswegen führt. Auch Lieferkettenmanipulationen, etwa durch den Austausch von Hardware-Komponenten gegen kompromittierte Bauteile, können so unbemerkt ihren Weg in kritische Systeme finden. Umgesetzt werden kann die Anforderung beispielsweise dadurch, dass (1) die Institution in Verträgen festhält, ob und in welchem Rahmen Unteraufträge zulässig sind. Eine weitere praxisnahe Maßnahme kann sein, (2) Subunternehmer nur nach vorheriger schriftlicher Zustimmung

der Institution zuzulassen und dabei (3) bestimmte Kategorien wie kritische IT-Dienstleistungen oder Datenverarbeitung ausdrücklich zu kennzeichnen. Technisch kann vertraglich vereinbart werden, dass Subunternehmer mindestens gleichwertige Sicherheitsstandards nachweislich erfüllen und dies regelmäßig auditiert werden kann.

Control: BES.5.6.1 - Weitergabe der Beschaffungskriterien

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit
Übergeordnetes Control:
BES.5.6 Vergabe von Unteraufträgen
UUID: 58f15c9a-d587-4971-8239-d99a01478dca
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE die Weitergabe der Beschaffungskriterien an Unterauftragnehmer vereinbaren.

Guidance

Dient dazu, sicherzustellen, dass die bei der Auswahl von Produkten, Dienstleistungen oder Lieferanten berücksichtigten Anforderungen entlang der gesamten Lieferkette eingehalten werden. Werden diese Kriterien nicht weitergegeben, kann es dazu kommen, dass sicherheitsrelevante Eigenschaften verloren gehen, etwa wenn ein Unterauftragnehmer günstigere, aber unsichere oder nicht konforme Komponenten beschafft. So könnte beispielsweise ein IT-Dienstleister ohne Kenntnis der geforderten Verschlüsselungsstandards Speichermedien einsetzen, die keine wirksame Datenverschlüsselung bieten, oder ein Bauunternehmen minderwertige Zutrittskontrollsysteme verbauen, weil die eigentlichen Sicherheitsvorgaben nicht bekannt waren. Auch Lieferverzögerungen, rechtliche Probleme durch fehlende Zertifizierungen oder das Einschleusen von Schadsoftware über ungesicherte Lieferungen können die Folge sein. Um die Weitergabe zu vereinfachen, können die Kriterien in einem maschinell verarbeitbaren Format (z.B. OSCAL Catalog oder Profile) ausgetauscht werden.

Control: BES.5.6.2 - Autorisierung von Unterauftragnehmern

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

Übergeordnetes Control:

BES.5.6 Vergabe von Unteraufträgen

UUID: 4b719eae-3c29-4579-ad77-653ab02ee880

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Einkäufe KANN die Autorisierung von Unterauftragnehmern durch den Auftraggeber vereinbaren.

Guidance

Unterauftragnehmer sind in diesem Zusammenhang Dritte, die vom beauftragten Hauptdienstleister zur Erfüllung vertraglicher Leistungen hinzugezogen werden. Die Autorisierung von Unterauftragnehmern durch den Auftraggeber kann sicherstellen, dass keine unkontrollierten oder ungeprüften Dritten in die Leistungserbringung eingebunden werden. Ohne eine solche Regelung könnte ein Hauptauftragnehmer eigenmächtig Subunternehmen einsetzen, die unzureichende Sicherheitsstandards einhalten, intransparent agieren oder in kritische Abhängigkeiten geraten. Durch die vorherige Zustimmung des Auftraggebers kann das Risiko unzureichender Qualifikation oder fehlender Vertrauenswürdigkeit reduziert werden und es kann eine gezielte Steuerung erfolgen, wer Zugang zu vertraulichen Informationen oder kritischen Prozessen erhält.

Control: BES.5.6.3 - Nachverfolgbarkeit der Lieferkette

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

Übergeordnetes Control:

BES.5.6 Vergabe von Unteraufträgen

UUID: 95512f8d-eca6-4928-a56f-1a58e5fcf3f0

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für IT-Produkte KANN die Nachverfolgbarkeit der gesamten Lieferkette bis zum Hersteller für {{ insert: param, bes.5.6.3-prm1 }} vereinbaren.

Guidance

Kritische Komponenten sind in diesem Kontext Bauteile oder Softwareelemente, deren Kompromittierung erhebliche Auswirkungen auf Sicherheit, Verfügbarkeit oder Integrität der eingesetzten Systeme haben könnte, z. B. kryptographische Module, Firmware von Netzwerkgeräten oder sicherheitsrelevante Steuerungseinheiten. Ohne nachvollziehbare Herkunft könnten Komponenten aus unsicheren Produktionsumgebungen stammen, in denen Hintertüren eingebaut oder Schadcode eingeschleust wurde; ebenso könnten gefälschte Ersatzteile eingesetzt werden, deren Qualität und Funktionssicherheit unzureichend ist. „Nachverfolgbarkeit“ (Traceability) bedeutet in diesem Zusammenhang die Möglichkeit, Herkunft, Transport- und Verarbeitungsschritte einer Komponente lückenlos und verifizierbar zu dokumentieren. Geeignete Maßnahmen können z. B. die Anforderung eines „Chain of Custody“-Protokolls, die Nutzung digital signierter Herkunftszertifikate oder die Einbindung seriöser, auditierter Distributoren sein. Auch der Einsatz von Datenbanken anerkannter Prüfinstanzen, in denen verifizierte Hersteller gelistet sind, kann eine Möglichkeit sein, die Nachverfolgbarkeit zu unterstützen.

Control: BES.5.7 - Schulung

Tags: "Lieferketten" "Kompetenzmanagement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: c95ea1ad-f766-43e2-a07d-1eb50cc58907

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Einkäufe KANN eine Schulung zur Nutzung gelieferter Sicherheitsmechanismen vereinbaren.

Guidance

Sicherheitsmechanismen sind in diesem Kontext technische oder organisatorische Schutzfunktionen, die in gelieferten Produkten, Systemen oder Diensten bereits vorgesehen sind, beispielsweise Verschlüsselungsfunktionen, Zugriffskontrollen oder Protokollierungsfunktionen. Ziel der Anforderung ist es, dass diese Schutzfunktionen von den Mitarbeitenden der Institution auch tatsächlich verstanden und korrekt angewandt werden. Ohne entsprechende Schulung könnte es passieren, dass vorhandene Sicherheitsfunktionen ungenutzt bleiben oder falsch bedient werden, wodurch Daten kompromittiert oder unbefugt zugänglich werden könnten. Durch gezielte Unterweisungen kann das Potenzial solcher Mechanismen ausgeschöpft und die Widerstandsfähigkeit gegenüber Angriffen oder Fehlbedienungen erhöht werden. Die Umsetzung kann pragmatisch gestaltet werden: (1) Eine Institution kann bei der Lieferung von IT-Systemen mit dem Hersteller oder Dienstleister eine kurze Einweisung in die sicherheitsrelevanten Funktionen vereinbaren, beispielsweise zur richtigen Konfiguration einer Multifaktor-Authentisierung. (2) Bei komplexeren Produkten kann die Institution Trainingsmaterialien wie Handbücher, Videos oder interaktive Tutorials anfordern, die auf den Einsatz der bereitgestellten Sicherheitsfunktionen zugeschnitten sind. (3) Zusätzlich kann es hilfreich sein, eine kurze Praxisübung im Rahmen der Abnahme durchzuführen, in der Schlüsselmechanismen wie sichere Passwortänderung oder Rechtevergabe ausprobiert werden. Die Schulung kann je nach Bedarf als Vor-Ort-Einweisung, Remote-Sitzung oder durch strukturierte E-Learning-Module erfolgen.

Control: BES.5.8 - Rechte für geistiges Eigentum

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: fbf79e86-d03e-44bb-9fec-87ad6ade595c

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE für geistiges Eigentum, das während der Vertragslaufzeit entwickelt wird, die Eigentumsrechte vereinbaren.

Guidance

Geistiges Eigentum meint hier alle während der Vertragslaufzeit entstehenden immateriellen Schutzgüter wie Softwarecode, Datenmodelle, Konzepte, technische Dokumentationen oder urheberrechtlich geschützte Inhalte, die im Rahmen der Dienstleistungserbringung entwickelt oder verbessert werden. Der Sinn und Zweck einer vertraglichen Regelung der Eigentumsrechte liegt darin, sicherzustellen, dass die Institution dauerhaft Kontrolle und Nutzungsrechte über Ergebnisse behält, die für ihren Betrieb oder ihre Weiterentwicklung relevant sind. Ohne klare Festlegung könnte es zu Konflikten kommen, wenn ein Dienstleister etwa nach Projektende die weitere Nutzung einer entwickelten Lösung untersagt oder hohe Lizenzgebühren verlangt; eine vertragliche Klarheit kann dagegen rechtliche Auseinandersetzungen und Abhängigkeiten verhindern. Eine Umsetzung kann über konkrete Vertragsklauseln erfolgen, die präzise definieren, welche Partei Eigentum oder Nutzungsrechte an entwickelten Ergebnissen erhält und ob bestimmte Elemente (z. B. Standardbibliotheken des Dienstleisters) ausgenommen sind. Dazu kann die Institution (1) standardisierte Vertragsvorlagen mit abgestuften Rechtemodellen nutzen, (2) ein internes Prüfschema für alle externen Verträge etablieren, das die Einbindung der Rechtsabteilung vorsieht, und (3) bei komplexen Entwicklungsleistungen technische Dokumentationspflichten verankern, damit Eigentums- und Nutzungsrechte nachvollziehbar abgesichert sind. Praktisch kann es helfen, im Vertrag eine Übergabepflicht sämtlicher Quelltexte, Dokumentationen oder Zugangsdaten vorzusehen und diese an definierte Projektmeilensteine zu koppeln.

Control: BES.5.9 - Umgang mit Änderungen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: 114cc12e-3b48-4632-ae06-d50a461dcd3a

Aufwand: 4

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.5.9.1 Autorisierung von Änderungen

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE Regelungen für den Umgang mit Änderungen vereinbaren.

Guidance

Unkontrollierte oder unklare Änderungen bringen Risiken für die Verfügbarkeit, Integrität oder Vertraulichkeit von Informationen mit sich – etwa wenn ein Dienstleister plötzlich eine neue Softwareversion einführt, ohne die Auswirkungen auf Schnittstellen zu prüfen. Vereinbarte Prozesse für den Umgang mit Änderungen können dagegen sicherstellen, dass Abhängigkeiten transparent bleiben und Risiken im Vorfeld bewertet werden. Zur Umsetzung kann eine Institution mit Dienstleistern definieren, dass Änderungen vorab angekündigt und dokumentiert werden, z. B. durch ein Ticket- oder Freigabe-System, das beide Seiten einsehen können. Es kann hilfreich sein, verschiedene Kategorien von Änderungen (z. B. Standardänderungen, Notfalländerungen, größere Releases) zu vereinbaren und abhängig von der Kritikalität unterschiedliche Prüf- und Genehmigungsschritte festzulegen. Transparenz kann durch regelmäßige Änderungsberichte oder Dashboards erreicht werden, die auch historische Änderungen nachvollziehbar machen. Praktische Maßnahmen können sein: (1) Einführung eines Test- und Abnahmefensters vor produktiven Änderungen, (2) Einsatz von Versionskontrolle oder Änderungsprotokollen, um Auswirkungen gezielt zurückverfolgen zu können, (3) Einrichtung klarer Kommunikationswege, damit die Institution rechtzeitig von geplanten Änderungen erfährt und eigene Schutzmaßnahmen – etwa zusätzliche Backups – vorbereiten kann.

Control: BES.5.9.1 - Autorisierung von Änderungen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

Übergeordnetes Control:

BES.5.9 Umgang mit Änderungen

UUID: a47e5549-802f-4d91-a69e-a537a813ba19

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Dienstleistungen KANN die Autorisierung von Änderungen durch den Auftraggeber vereinbaren.

Guidance

Die Autorisierung von Änderungen bedeutet in diesem Kontext, dass die Institution mit einem Dienstleister vereinbart, dass geplante Anpassungen – etwa an Prozessen, Konfigurationen, Infrastruktur oder Vertragsbedingungen die zur Vertragserfüllung verwendet werden – vor ihrer Umsetzung explizit durch den Auftraggeber bestätigt werden. Damit ist nicht nur die formale Vertragsänderung gemeint, sondern auch technische oder organisatorische Änderungen, die mittelbar Auswirkungen auf Sicherheit, Verfügbarkeit oder Integrität von Daten und Diensten haben können. Der Zweck dieser Regelung liegt darin, die Kontrolle über den Einflussbereich des Dienstleisters zu behalten: Ohne solche Vereinbarungen könnte ein Dienstleister eigenmächtig Anpassungen vornehmen, die unerwartete Schwachstellen einführen oder die Datenlokation verändern könnten. Zur Umsetzung kann die Institution mit dem Dienstleister praktikable Verfahren zur Änderungsfreigabe vereinbaren. Dies kann z. B. durch (1) die Einführung eines Freigabe-Workflows in einem Ticket- oder Change-Management-System erfolgen, (2) die Verpflichtung zu einer schriftlichen Änderungsmitteilung mit klaren Auswirkungen auf Sicherheit und Betrieb, sowie (3) die Festlegung, dass kritische Änderungen erst nach einer formellen Zustimmung des Auftraggebers in einem definierten Zeitfenster umgesetzt werden können. Ergänzend kann der Dienstleister angehalten werden, geplante Änderungen in einer Änderungsübersicht mit Versionsstand und Rückfalloptionen zu dokumentieren, so-

dass die Institution bewerten kann, ob Risiken oder Abhängigkeiten entstehen.

Links

related: TEST.4.1 Autorisierung von Änderungen

Control: BES.5.10 - Behandlung von Vorfällen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: 61055c24-1924-4b3f-804c-d96e2a683821

Aufwand: 3

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen

Statement

Beschaffungsmanagement für Einkäufe SOLLTE Regelungen für die Behandlung von Vorfällen vereinbaren.

Guidance

Ein Vorfall bezeichnet in diesem Zusammenhang jedes sicherheitsrelevante Ereignis, das zu einer Beeinträchtigung der Vertraulichkeit, Integrität oder Verfügbarkeit von Informationen oder IT-Diensten führen kann, etwa Datenabflüsse, unbefugte Zugriffe oder längerfristige Systemausfälle. Der Sinn und Zweck der Regelung liegt darin, mit Vertragspartnern abgestimmte Verfahren zu haben, um im Ernstfall schnell und koordiniert reagieren zu können. Ohne klare Vereinbarungen könnte wertvolle Zeit verloren gehen, es könnten unklare Zuständigkeiten entstehen oder Meldungen verzögert erfolgen. Mit abgestimmten Prozessen kann dagegen die Schadensbegrenzung beschleunigt, Transparenz über den Vorfall geschaffen und eine wirksame Ursachenanalyse ermöglicht werden. Hierzu gehört insbesondere die Benachrichtigung des Vertragspartners und die Zusammenarbeit zur Behebung von Vorfällen.

Control: BES.5.10.1 - Erreichbarkeit über Meldewege

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

Übergeordnetes Control:

BES.5.10 Behandlung von Vorfällen

UUID: f2e723f5-6a1a-4358-bce2-458523049346

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE die Erreichbarkeit des Lieferanten über bestimmte Meldewege vereinbaren.

Guidance

Die Meldewege bezeichnen in diesem Zusammenhang klar definierte Kommunikationskanäle, über die ein Lieferant zuverlässig erreichbar ist. Das kann beispielsweise eine dedizierte E-Mail-Adresse für Sicherheitsvorfälle, ein 24/7-Telefonkontakt, ein Ticket-System oder ein abgesicherter Webzugang sein. Der Sinn dieser Vereinbarung liegt darin, dass kritische Ereignisse, wie etwa ein entdeckter Datenabfluss oder technische Störungen in ausgelagerten Systemen, nicht ins Leere laufen. Ohne abgestimmte Erreichbarkeit könnte eine Meldung verzögert oder gar nicht ankommen, wodurch Schaden an vertraulichen Informationen unbemerkt bleiben könnte. Mit verbindlich vereinbarten Kanälen kann die Institution hingegen sicherstellen, dass relevante Informationen zeitnah und nachweisbar beim Lieferanten ankommen und bearbeitet werden. Die Umsetzung dieser Anforderung kann durch mehrere Maßnahmen unterstützt werden: (1) Eine Institution kann im Vertrag mit dem Lieferanten eine feste Ansprechstelle und Eskalationsstufen für bestimmte Ereignisse benennen lassen. (2) Es kann ein technischer Meldeweg wie ein verschlüsseltes E-Mail-Postfach oder ein Ticketportal vorgesehen werden, das eindeutig den Zweck "Sicherheitsvorfälle" trägt und regelmäßig überwacht wird.

Control: BES.5.10.2 - Melden von Vorfällen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

Übergeordnetes Control:

BES.5.10 Behandlung von Vorfällen

UUID: d359fe31-8bf1-47ae-bbcc-e572b1998d52

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Einkäufe SOLLTE eine Verpflichtung zur unverzüglichen Information des Auftraggebers über ihn betreffende Vorfälle vereinbaren.

Guidance

Der Sinn dieser Regelung liegt darin, dass der Auftraggeber seine Handlungsfähigkeit behält und Risiken frühzeitig einschätzen kann. Ein verzögerter Informationsfluss könnte dazu führen, dass Schäden sich unbemerkt ausweiten oder notwendige Reaktionen, wie etwa die Unterbindung von Angriffspfaden, verspätet erfolgen. Eine rechtzeitige Mitteilung kann hingegen Transparenz schaffen und es ermöglichen, dass Gegenmaßnahmen in Koordination mit dem Auftraggeber wirksam eingeleitet werden. Die praktische Umsetzung kann durch klare vertragliche Regelungen erfolgen, in denen Eskalationswege und Fristen für Meldungen definiert werden. Dazu kann ein gemeinsames Kontakt- und Kommunikationsverfahren etabliert werden, etwa ein 24/7 erreichbarer Ansprechpartner oder eine dedizierte Notfalladresse für sicherheitsrelevante Meldungen. Technisch kann eine Schnittstelle (z. B. ein abgesicherter Meldekanal oder Ticket-System) eingerichtet werden, über die Vorfälle dokumentiert und weitergeleitet werden können.

Control: BES.5.10.3 - Schwachstellenbehebung

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

Übergeordnetes Control:

BES.5.10 Behandlung von Vorfällen

UUID: d7946adc-4cf2-4fc9-aad7-9d43c6855384

Aufwand: 3

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.5.10.3.1 Schwachstellenmeldeprozess

Statement

Beschaffungsmanagement für Einkäufe SOLLTE eine Verpflichtung für Lieferanten, die den Auftraggeber betreffende Schwachstelle zeitnah zu beheben, vereinbaren.

Guidance

Die Verpflichtung bezieht sich hierbei auf die gesamte Lebensdauer der Dienstleistungen oder Produkte. Je nach Vertrag kann die Behebung von Schwachstellen z.B. durch Sicherheitsupdates oder den Austausch von Komponenten gewährleistet werden.

Control: BES.5.10.3.1 - Schwachstellenmeldeprozess

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit
Übergeordnetes Control:
BES.5.10.3 Schwachstellenbehebung
UUID: ebc08e41-e728-4447-93fa-233fbad7f2fa
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für IT-Produkte KANN einen Schwachstellenmeldeprozess nach {{ insert: param, bes.5.10.3.1-prm1 }} vereinbaren.

Guidance

Die Anforderung ist erfüllt, wenn der Prozess zur Meldung und Behandlung von Schwachstellen für das zu beschaffende Produkt vertraglich zugesichert ist, unabhängig von der Frage durch wen die Klausel in den Vertrag eingebracht wurde. Der Schwachstellenmeldeprozess kann direkt durch den Lieferanten oder durch Weitergabe der Verpflichtung an den Hersteller gewährleistet sein. Für Details siehe BSI TR-03183-3.

Control: BES.5.10.4 - Konfliktlösungsprozesse

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

Übergeordnetes Control:

BES.5.10 Behandlung von Vorfällen

UUID: 3535784d-dd78-4fd2-be25-4a2e183087b2

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Einkäufe KANN Prozesse zur Lösung von Konflikten zwischen den Vertragsparteien vereinbaren.

Guidance

Ein „Konflikt zwischen den Vertragsparteien“ bedeutet hier jede Form von Uneinigkeit, die im Zuge eines Vertragsverhältnisses auftreten kann – etwa über die Auslegung von Leistungszusagen, den Umgang mit Verzögerungen, Qualitätsabweichungen oder Verantwortlichkeiten bei Sicherheitsvorfällen. Solche Konfliktlösungsprozesse können helfen, Missverständnisse strukturiert zu klären und Rechtsstreitigkeiten vorzubeugen. Das Ziel der Anforderung ist es, Risiken durch unklare Verantwortlichkeiten und eskalierende Streitigkeiten zu verringern: Ein ungelöster Konflikt könnte dazu führen, dass sicherheitsrelevante Leistungen nicht rechtzeitig erbracht werden, Vertragsinhalte unterschiedlich interpretiert werden oder sensible Daten im Streitfall unkontrolliert preisgegeben werden. Umgekehrt kann eine klar geregelte Konfliktlösungsroutine Transparenz schaffen, die Handlungsfähigkeit der Institution sichern und einen fairen Interessenausgleich fördern. Praktisch umgesetzt werden kann dies durch verschiedene Maßnahmen: (1) In Verträgen kann eine Schlichtungsklausel vorgesehen werden, die definiert, dass bei Meinungsverschiedenheiten zunächst ein moderiertes Gespräch oder ein Mediationsverfahren durchgeführt werden kann. (2) Es kann hilfreich sein, feste Eskalationspfade zu vereinbaren, zum Beispiel mit einer dreistufigen Struktur aus Projektleitung, Management-Ebene und unabhängiger Stelle. (3) Die Institution kann Checklisten nutzen, um im Konfliktfall die relevanten Dokumentationen – etwa Leistungsnachweise oder Kommunikationsprotokolle – geordnet vorzulegen. (4) Technische Hilfen wie gemeinsame Ticket- oder

Kollaborationssysteme können Transparenz schaffen und verhindern, dass Konflikte durch unklare Informationslagen eskalieren.

Control: BES.5.10.5 - Konsequenzen bei Verstößen

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

Übergeordnetes Control:

BES.5.10 Behandlung von Vorfällen

UUID: 119a13e9-ea12-41a3-a974-2d1cba295fb8

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Einkäufe KANN Abhilfemaßnahmen für den Fall von Verstößen durch den Lieferanten vereinbaren.

Guidance

Hierzu können Abhilfemaßnahmen wie die Abschaltung angreifbarer Systeme, die Information betroffener Personen sowie Entschädigungen für die betroffene Institution oder betroffene Dritte in einer festgelegten Höhe gehören.

Control: BES.5.11 - Recht auf Audit

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: 4725e406-7802-4a0a-98a5-2195ba2d26d1

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Outsourcing SOLLTE ein Recht des Auftraggebers zur Überprüfung der Sicherheitsprozesse und -maßnahmen, die im Zusammenhang mit dem Vertrag stehen, vereinbaren.

Guidance

Je nach Vereinbarung kann die Umsetzung durch ein vom Auftraggeber durchgeführtes Audit, eine Revision (Second Party Audit) oder eine Auditierung durch Dritte (Third Party Audit), z.B. im Rahmen einer Zertifizierung, erfolgen.

Control: BES.5.12 - Informationspflichten

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: 24f08281-8abf-4a70-8502-72b86f1ca02a

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE eine Pflicht des Lieferanten, den Auftraggeber regelmäßig über die Wirksamkeit der Sicherheitsmaßnahmen zu informieren, vereinbaren.

Guidance

Im konkreten Kontext bedeutet Wirksamkeit, dass die vereinbarten Sicherheitsmaßnahmen des Lieferanten nicht nur formal existieren, sondern nachweislich den angestrebten Schutzzweck erfüllen – beispielsweise durch messbare Ergebnisse, dokumentierte Prüfberichte oder Nachweise aus internen Kontrollen. Der Auftraggeber ist hierbei die Institution, die eine Dienstleistung einkauft und deren Informationswerte geschützt werden sollen, während der Lieferant der erbringende externe Dienstleister ist, dessen Sicherheitspraktiken Einfluss auf diese Informationswerte haben. Regelmäßige Informationen können etwa Statusberichte, Prüfprotokolle oder Kennzahlen zu Sicherheitsvorfällen und deren Behandlung umfassen.

Control: BES.5.13 - Bereitstellung von Datensicherungen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: 25e60ed2-9a85-4d03-be14-050253846f38

Aufwand: 3

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.5.13.1 Datenbereitstellung

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE eine Verpflichtung des Lieferanten, Sicherungskopien regelmäßig bereitzustellen, vereinbaren.

Guidance

Der Zweck dieser Anforderung liegt in der Absicherung gegen Datenverlust durch technische Defekte, menschliche Fehler oder Schadsoftware. Ein fehlendes Backup könnte dazu führen, dass wichtige Kundendaten, Vertragsunterlagen oder Konfigurationsstände dauerhaft verloren gehen. Durch die vertragliche Verpflichtung zur Bereitstellung von Sicherungskopien kann die Institution ihre Datenhoheit behalten und Ausfälle oder Manipulationen deutlich schneller abfangen. Die Umsetzung kann beispielsweise so erfolgen, dass der Lieferant verpflichtet wird, Backups auf einem separaten, verschlüsselten Speichermedium bereitzustellen, welches der Institution in vereinbarten Intervallen übergeben wird. Zur Umsetzung kann ein Lieferant beispielsweise quartalsweise Berichte zu durchgeführten Penetrationstests, Schwachstellen-Scans oder Notfallübungen bereitstellen. Ebenso kann er standardisierte Dashboards mit Kennzahlen zu Sicherheitsvorfällen, Patchständen oder Awareness-Maßnahmen freigeben. Hilfreich kann auch sein, dass der Lieferant auf Anfrage gezielt Audit-Reports oder Zertifikate (z. B. SOC-2-Berichte, ISO 27001-Auditberichte) zur Verfügung stellt.

Control: BES.5.13.1 - Datenbereitstellung

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

Übergeordnetes Control:

BES.5.13 Bereitstellung von Datensicherungen

UUID: 8efd929d-ccc8-422f-b5ae-915fbfc41ddc

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Outsourcing KANN die Bereitstellung der beim Dienstleister verarbeiteten Daten in einem standardisierten Format vereinbaren.

Guidance

Kann das Risiko verringern, dass im Falle eines Anbieterwechsels, einer Vertragsbeendigung oder einer Notfallwiederherstellung Daten nur in proprietären oder unvollständig dokumentierten Formaten vorliegen. Ohne ein solches Format könnte eine Institution vor dem Problem stehen, dass bei einem unerwarteten Ausfall des Dienstleisters die Daten erst zeitaufwendig konvertiert werden müssen, was den Geschäftsbetrieb verzögert oder kritische Prozesse unterbricht.

Control: BES.5.14 - Löschregeln

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.5 Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

UUID: b75b1a85-9a93-4f76-a9c4-846a0409490e

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Outsourcing SOLLTE die Löschung von Daten während der Vertragslaufzeit im Einklang mit den Compliance-Verpflichtungen der Institution vereinbaren.

Guidance

Compliance-Verpflichtungen werden in der Praktik GC ermittelt. Die Umsetzung kann z.B. durch individuelle vertragliche Festlegung oder durch die Auswahl eines Dienstleisters, dessen Löschregelungen im Einklang mit den Compliance-Verpflichtungen stehen, erfolgen.

Links

related: BES.6.2 Löschung von Daten

Control: BES.6.1 - Entziehung der Zugangsberechtigungen

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.6 Auswahl von Produkten und Dienstleistungen - Kündigung
UUID: 0e6eb46f-3941-4f64-9fd6-709517a01ad1
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE die Entziehung der für den Vertrag relevanten Zugangsberechtigungen für den Fall einer Kündigung vereinbaren.

Guidance

„Zugangsberechtigungen“ meint hier die Gesamtheit aller physischen, logischen und administrativen Rechte, die externen Dienstleistern den Zugriff auf Systeme, Daten, Gebäude oder digitale Ressourcen der Institution ermöglichen. Dazu gehören sowohl Benutzerkonten und technische Schnittstellen als auch Zutrittskarten oder Remote-Zugänge über VPN. Der Sinn und Zweck der Vorschrift liegt darin, dass unautorisierte Zugriffe nach einer Vertragsbeendigung verhindert werden können. Ein ehemaliger Dienstleister könnte ansonsten weiterhin über aktive Accounts sensible Daten einsehen oder Systeme manipulieren, was zu Datenabfluss, Sabotage oder unbemerkten Veränderungen führen könnte.

Links

related: DLS.4.1 Dekommissionierung

Control: BES.6.2 - Löschung von Daten

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.6 Auswahl von Produkten und Dienstleistungen - Kündigung

UUID: 90d55cb8-c0ff-4805-8b45-77aac247c786

Aufwand: 3

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.6.2.1 Löschverfahren

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE die Löschung aller beim Dienstleister vorhandenen Daten für den Fall einer Kündigung vereinbaren.

Guidance

Kündigung meint hier sowohl ordentliche als auch außerordentliche Kündigungen. Hierzu können z.B. die Rückgabe von Authentifizierungstoken oder Löschung aller Auftraggeberdaten nach Ablauf der gesetzlichen Aufbewahrungsfristen gehören. Relevant sind dabei neben Inhaltsdaten auch Metadaten, Lizenzen und weitere Zugriffsrechte.

Links

related: BES.5.14 Löschregeln

Control: BES.6.2.1 - Lösungsverfahren

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.6 Auswahl von Produkten und Dienstleistungen - Kündigung
Übergeordnetes Control:
BES.6.2 Löschung von Daten
UUID: d0ba4d21-940d-4b06-b446-aeccfdb2b53a
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Dienstleistungen KANN ein Verfahren zur nicht wiederherstellbaren Löschung für den Fall einer Kündigung vereinbaren.

Guidance

Ein Verfahren zur nicht wiederherstellbaren Löschung bedeutet in diesem Kontext, dass Daten nach Beendigung einer Dienstleistungsbeziehung so entfernt werden, dass auch mit spezialisierten forensischen Methoden keine Rekonstruktion mehr möglich ist. Typische Verfahren reichen von mehrfachen Überschreibungen mit Zufallswerten über kryptographisches Löschen (Zerstörung der Schlüssel, die zur Entschlüsselung notwendig wären) bis hin zur physikalischen Zerstörung der Speichermedien. Die Regelung zielt darauf ab, das Risiko zu mindern, dass vertrauliche Daten nach einer Vertragskündigung bei einem Dienstleister verbleiben und unbefugt genutzt oder versehentlich offengelegt werden könnten. Ein Datenleck nach einem Providerwechsel könnte beispielsweise zu Identitätsdiebstahl, Industriespionage oder Reputationsschäden führen. Die Vereinbarung einer sicheren, nicht wiederherstellbaren Löschung kann sicherstellen, dass Informationen tatsächlich entfernt sind und keine Restkopien unkontrolliert in Umlauf geraten.

Links

related: ASST.7.3.2 Lösungsverfahren

Control: BES.6.3 - Übertragbarkeit von Daten

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.6 Auswahl von Produkten und Dienstleistungen - Kündigung

UUID: 4e0fd86f-d5b5-41a8-a25d-0a61630fc37c

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE die Übertragbarkeit von Daten, Konfigurationen und der Funktionalität für den Fall einer Kündigung vereinbaren.

Guidance

Ohne eine solche Regelung kann es zu erheblichen Betriebsstörungen kommen, etwa wenn ein Dienstleister im Streitfall Daten nur in proprietären Formaten bereitstellt oder deren Übergabe verzögert. Dies könnte dazu führen, dass eine Institution den Betrieb nicht nahtlos mit einem neuen Anbieter fortsetzen kann, etwa bei Cloud-Diensten, Hosting oder SaaS-Lösungen. Auch kann der Verlust von Metadaten, Zugriffshistorien oder Konfigurationsdateien eintreten, was die Nachvollziehbarkeit und Funktionsfähigkeit stark einschränken könnte. Unter „Übertragbarkeit von Daten“ (Data Portability) versteht man in diesem Kontext die technische und organisatorische Fähigkeit, alle relevanten Daten in einem vollständigen, strukturierten und maschinenlesbaren Format an die Institution oder einen Nachfolger zu übertragen. Es geht dabei nicht nur um die Rohdaten, sondern auch um begleitende Informationen, die für die Wiederaufnahme des Betriebs an anderer Stelle erforderlich sind (Metadaten). Die Angemessenheit dieser Maßnahme bemisst sich daran, wie stark die Tätigkeit der Institution von den ausgelagerten Prozessen abhängt und wie groß die Auswirkungen einer verzögerten oder unvollständigen Rückgabe wären.

Links

related: BES.5.13.1 Datenbereitstellung

Control: BES.6.4 - Übertragung von Supportdienstleistungen

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.6 Auswahl von Produkten und Dienstleistungen - Kündigung

UUID: 4a487564-f53e-420d-bcc3-e7e35edcf162

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Dienstleistungen KANN die Übergabe der Supportdienstleistungen für den Fall einer Kündigung vereinbaren.

Guidance

Die Übergabe der Supportdienstleistungen beschreibt in diesem Kontext die geordnete und dokumentierte Weitergabe von relevanten Informationen, Ressourcen und Zugängen durch einen externen Dienstleister an die Institution oder einen neuen Dienstleister, wenn ein Vertrag endet. Dazu gehören z. B. Dokumentationen zu Konfigurationen, Wartungsprotokolle, Zugangsdaten, Lizenzinformationen oder Ansprechpartnerketten. Ziel ist es, dass der Betrieb der unterstützten Systeme nach Vertragsende ohne Unterbrechung oder Informationsverlust fortgesetzt werden kann. Die Anforderung dient dazu, Risiken abzufedern, die entstehen, wenn bei einer Kündigung der Dienstleister abrupt ausscheidet. Ohne geregelte Übergabe könnte es passieren, dass wichtige Betriebsinformationen verloren gehen, der Zugriff auf Systeme blockiert wird oder die Institution abhängig von individuellem Wissen einzelner Personen bleibt. Die Übergabe kann entweder an die Institution selbst oder an einen von der Institution gewählten neuen Vertragspartner erfolgen. Um die Anforderung praktisch umzusetzen, kann eine Institution in Verträgen explizit eine Exit- oder Übergabeklausel verankern, die Inhalte, Formate und Fristen der Übergabe beschreibt. Diese Klausel kann beispielsweise definieren, dass (1) aktuelle System- und Betriebsdokumentationen vollständig zu übergeben sind, (2) Zugangsdaten in einem abgestimmten Verfahren gesichert bereitgestellt werden und (3) technische Ansprechpartner für eine Übergangsphase verfügbar bleiben.

Links

related: DLS.4.1 Dekomissionierung

Control: BES.6.5 - Behandlung aufzubewahrender Aufzeichnungen

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.6 Auswahl von Produkten und Dienstleistungen - Kündigung

UUID: a397ee7e-3766-4454-9805-c2b31ffcb80e

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE Kontrollmechanismen zur Behandlung aufzubewahrender Aufzeichnungen für den Fall einer Kündigung vereinbaren.

Guidance

Der Begriff Kontrollmechanismen kann in diesem Kontext verstanden werden als vertraglich vereinbarte Verfahren, technische Maßnahmen oder organisatorische Vorkehrungen, die es der Institution ermöglichen, die Vollständigkeit, Integrität und Vertraulichkeit der betreffenden Aufzeichnungen sicherzustellen. Aufzubewahrende Aufzeichnungen bezeichnet hierbei jede Form von Daten oder Dokumenten – in physischer oder digitaler Form – die aufgrund gesetzlicher, vertraglicher oder interner Vorgaben über das Vertragsende hinaus (zumindest für einen bestimmten Zeitraum) vom Dienstleister aufbewahrt werden. Dabei kann es sich beispielsweise um Vertragsunterlagen, Protokolldateien oder Gesprächsprotokolle handeln, die etwa aus steuerlichen Gründen aufzubewahren sind.

Control: BES.6.6 - Rückgewähr von Assets

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.6 Auswahl von Produkten und Dienstleistungen - Kündigung

UUID: 005f0ce7-9372-49b6-b78b-c09a5e2f56f0

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE die Rückgewähr von Assets für den Fall einer Kündigung vereinbaren.

Guidance

Rückgewähr bedeutet hier, dass sämtliche von der Institution bereitgestellte Werte – wie etwa IT-Systeme, Datenträger oder Papierkopien – bei Beendigung des Vertragsverhältnisses an die Institution zurückgegeben werden. Der Zweck liegt darin, unkontrollierten Weitergebrauch oder Missbrauch von Informationen und Ressourcen zu verhindern. So könnte etwa ein externer Dienstleister nach einer Kündigung weiterhin Zugriff auf sensible Daten behalten oder unbeabsichtigt alte Backup-Medien in seinem Besitz behalten, was zu Datenabflüssen oder unautorisierten Offenlegungen führen könnte. Eine klare Regelung kann dagegen sicherstellen, dass sämtliche Ressourcen nachvollziehbar wieder unter die alleinige Kontrolle der Institution gelangen und Vertraulichkeit sowie Integrität gewahrt bleiben. Für die Umsetzung kann es hilfreich sein, die Rückgabepflicht vertraglich zu konkretisieren und präzise Abläufe zu definieren. So kann die Institution (1) Inventarlisten führen, in denen alle übergebenen physischen Geräte, Datenträger oder Zutrittsmedien eindeutig aufgeführt werden, (2) Checklisten für die geordnete Rückführung bei Vertragsende einsetzen und (3) eine Rückgabequittung oder Übergabebestätigung durch den Dienstleister einfordern, die den ordnungsgemäßen Erhalt dokumentiert. Ergänzend kann die Institution Rückgabefristen und Verantwortlichkeiten im Vertrag festlegen sowie technische Maßnahmen wie die Sperrung von verlorenen oder nicht zurückgegebenen Zutrittskarten einplanen. Auch kann eine Abnahmeprüfung der zurückgegebenen Assets durch die Institution erfolgen, um sicherzustellen, dass diese vollständig und funktionsfähig übergeben wurden.

Links

related: DLS.4.1 Dekomissionierung

Control: BES.7.1 - Eingangskontrolle

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.7 Abnahme
UUID: abea6f59-f58b-47c3-b908-7ae68410fde3
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck

Statement

Beschaffungsmanagement für Einkäufe SOLLTE erbrachte oder gelieferte Leistungen anhand von {{ insert: param, bes.7.1-prm1 }} vor der ersten Verwendung testen.

Guidance

Durch eine Prüfung anhand von Akzeptanzkriterien wird sichergestellt, dass die erbrachten Dienstleistungen oder IT-Produkte den geforderten Beschaffungskriterien entsprechen. Die Akzeptanzkriterien können also den Beschaffungskriterien entsprechen oder deren Prüfung konkretisieren. Hierzu können verschiedene Methoden eingesetzt werden, etwa Stichproben, Sicherheitstests oder die Nachverfolgung der Lieferkette anhand von Seriennummern. Dabei besteht ein enger Zusammenhang zu den Praktiken Dienstleistersteuerung, sowie Änderungen und Tests.

Control: BES.7.1.1 - Test der Kompatibilität

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.7 Abnahme
Übergeordnetes Control:
BES.7.1 Eingangskontrolle
UUID: a2157baa-d3d7-4527-a9e9-7325a2b7b9ff
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Outsourcing SOLLTE die Kompatibilität des Dienstes mit dem Informationsverbund im Hinblick auf die Schnittstellen, die Netzanbindung, das Administrationsmodell und das Datenmanagementmodell testen.

Guidance

Die Regelung dient dazu, ungewollte Brüche oder Inkompatibilitäten zu vermeiden, die im Betrieb zu Sicherheits- oder Funktionsproblemen führen können. Ohne eine solche Überprüfung könnte z. B. eine unklare Rechtevergabe dazu führen, dass ein Dienstleister umfassendere Zugriffe erhält als notwendig, oder eine fehlerhafte Schnittstellenintegration könnte den Ausfall wichtiger Anwendungen nach sich ziehen. Umgekehrt kann eine saubere Prüfung sicherstellen, dass Outsourcing-Dienste nahtlos integriert, technisch handhabbar und im Betrieb kontrollierbar bleiben. Für die Bewertung der Kompatibilität sind dabei vier Aspekte besonders kritisch: Schnittstellen sind die technischen Übergabepunkte, an denen Systeme Daten austauschen oder Funktionen ansprechen; Netzanbindung bezeichnet die physische oder logische Verbindung zwischen dem Dienstleister und dem Informationsverbund der Institution; das Administrationsmodell beschreibt, wer welche Rechte zur Einrichtung, Änderung und Überwachung von Systemkomponenten hat; und das Datenmanagementmodell legt fest, wie Daten gespeichert, strukturiert, repliziert und gelöscht werden.

Control: BES.7.1.2 - Netzcheck

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.7 Abnahme
Übergeordnetes Control:
BES.7.1 Eingangskontrolle
UUID: 2e2346ed-c3fd-4c96-89f7-7ed920eb8d1a
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Outsourcing SOLLTE die Umsetzung der geforderten Beschaffungskriterien für die Netzanbindung vor der Netzanbindung testen.

Guidance

Netzanbindung meint hier jede Form der logischen oder physischen Kopplung von Netzwerken – etwa über VPN, MPLS, dedizierte Leitungen oder Cloud-Interconnects. Der Sinn dieser Vorschrift liegt darin, Risiken aus unsicheren oder ungetesteten Dienstleisterverbindungen zu minimieren. So könnte ein ungeprüfter Zugang über eine unsauber konfigurierte VPN-Schnittstelle Schadsoftware einschleusen oder interne Systeme unautorisiert zugänglich machen. Umgekehrt kann die vorgelagerte Prüfung sicherstellen, dass Verschlüsselung, Bandbreite, Trennung sensibler Netze oder auch Logging-Vorgaben wie vorgesehen funktionieren und dadurch ein sicherer, nachvollziehbarer Betrieb gewährleistet wird. Die Umsetzung kann durch mehrere Maßnahmen erfolgen: (1) Vor der Inbetriebnahme kann ein technischer Funktionstest durchgeführt werden, bei dem Firewalls, Routing und VPN-Tunnel anhand von Testaccounts überprüft werden. (2) Ein Abnahmetest durch die Institution kann beinhalten, dass simulierte Angriffe oder Fehlkonfigurationen (z. B. offene Ports) nachgestellt werden, um die Widerstandsfähigkeit des Dienstleisters zu prüfen. (3) Prozessual kann eine Checkliste genutzt werden, die verbindlich vorgibt, dass Sicherheitsanforderungen wie Verschlüsselungsstandards, Protokollierung, Redundanz oder die Einhaltung von Latenzgrenzen dokumentiert und validiert sind, bevor der „Go-Live“ erfolgt. Zusätzlich kann es hilfreich sein, die Ergebnisse der Tests nachvollziehbar in einem Freigabeprotokoll festzuhalten, das sowohl die Institution als auch der Dienstleister unterzeichnen. Auf diese Weise kann die

Institution sicherstellen, dass die Netzanbindung nicht nur formell, sondern auch praktisch den definierten Kriterien entspricht.

Control: BES.7.2 - Prozesse vor Netzanbindung

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.7 Abnahme
UUID: 1421e376-1f13-4381-a30f-597ec113d205
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Outsourcing SOLLTE vor Anbindung des Datennetzes der Nutzenden an das Datennetz der Anbietenden alle sicherheitsrelevanten Maßnahmen im Einklang mit den Regelungen und Verfahren des Managementsystems verankern.

Guidance

Der Sinn der Vorschrift liegt darin, Risiken durch unkontrollierte Netzwerkanbindungen zu minimieren, die bei Outsourcing deutlich höher sind als bei Standard-Dienstleistungsverträgen. Ohne vorherige Verankerung von Prozessen und technischen Lösungen, die für die sichere Anbindung zum Outsourcing-Dienstleister erforderlich sind, könnte etwa Schadsoftware aus dem Anbietenden-Netz ungehindert in das Netz der Institution gelangen oder unbefugte Zugriffe könnten entstehen, wenn Authentifizierungsverfahren nicht abgestimmt sind. Umgekehrt kann eine klare Festlegung vorab bewirken, dass nur geprüfte, verschlüsselte und überwachte Schnittstellen genutzt werden, was eine vertrauenswürdige Zusammenarbeit ermöglicht. Da Outsourcing regelmäßig mit tiefen technischen Integrationen verbunden ist, unterscheidet es sich von herkömmlichen Lieferantenbeziehungen, bei denen keine direkte Netzwerkkopplung erfolgt. Eine Institution kann diese Anforderung praktisch umsetzen, indem sie vor der Anbindung (1) eine technische Schnittstellenbeschreibung einfordert, die Protokolle, Ports und Authentifizierungsmechanismen dokumentiert, (2) die Kommunikation auf gesicherte Kanäle wie VPN oder verschlüsselte Direktleitungen beschränkt, und (3) Verfahren zur Netzsegmentierung etabliert, sodass der Zugriff nur auf explizit freigegebene Systeme möglich ist. Ergänzend kann eine Checkliste für Dienstleisterprüfung genutzt werden, in der Sicherheitszertifikate, Protokolle zur Patch-Pflege oder geplante Monitoring-Mechanismen abgefragt werden. Ein prozessualer Tipp kann darin bestehen, die

Netzfregabe erst nach einem gemeinsamen Test der Sicherheitsmechanismen freizuschalten und dies in einem Freigabeprotokoll zu dokumentieren. So kann eine Institution sicherstellen, dass Outsourcing-Verbindungen kontrolliert, nachvollziehbar und mit einem definierten Sicherheitsniveau umgesetzt werden.

Links

related: TEST.1.1 Verfahren und Regelungen

Control: BES.7.3 - Anhörung Prozessbeteiligter

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.7 Abnahme

UUID: 805426be-1d47-46f0-88ab-0014e484fb9a

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Outsourcing SOLLTE alle am ausgelagerten Prozess beteiligten Mitarbeiter oder Rollen anhören.

Guidance

Je nach Prozess können hierzu z.B. IT-Betriebspersonal oder Cybersicherheitsexperten der Institution oder von weiteren Dienstleistern, oder die Rechtsabteilung gehören.

Control: BES.7.4 - Vollständigkeit der Unterlagen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.7 Abnahme
UUID: 1e4fa113-4c3b-4853-9b12-86f02abd1706
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.5 Netzverbindungen ab Werk
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- BES.7.4.10 Serviceprofil
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud

Statement

Beschaffungsmanagement für Einkäufe SOLLTE Informationen, die für eine bestimmungsgemäße Verwendung im Informationsverbund erforderlich sind, dokumentieren.

Guidance

Dient in erster Linie dazu, sicherheitsrelevante Eigenschaften, Abhängigkeiten und Einsatzbedingungen nachvollziehbar festzuhalten. Ohne diese Informationen könnte es zu Fehlkonfigurationen, unsachgemäßem Betrieb oder unentdeckten Schwachstellen kommen, etwa wenn sicherheitskritische Firmware-Updates, empfohlene Hardening-Anleitungen oder Hinweise zu bekannten Sicherheitslücken nicht beachtet werden. So könnte beispielsweise ein Netzwerkgerät ohne die dokumentierten Herstellerhinweise zu sicheren Standardpasswörtern betrieben werden,

wodurch Angreifer einfachen Zugriff erlangen könnten. Für diesen Kontext bedeutet „Informationen, die für eine bestimmungsgemäße Verwendung der Beschaffung im Informationsverbund erforderlich sind“ sämtliche sicherheitsrelevanten Dokumente, Konfigurationshinweise, Updateanweisungen und Supportinformationen, die erforderlich sind, damit beschaffte Produkte und Dienste so verwendet werden können, wie in den Beschaffungskriterien vorgesehen. Am einfachsten kann diese Anforderung erfüllt werden, indem die erforderlichen Informationen vom Lieferanten oder Hersteller mitgeliefert werden. Alternativ ist es auch möglich, dass die Institution die Dokumentation selbst vornimmt, z.B. in Zusammenarbeit mit dem Lieferanten, durch Untersuchung der Lieferung oder durch Ablage von Informationen, welche der Hersteller auf seiner Webseite bereitgestellt hat. Eine praktische Umsetzung kann darin bestehen, dass die Institution im Rahmen des Beschaffungsprozesses gezielt nach sicherheitsrelevanten Unterlagen fragt und diese zentral ablegt, etwa in einem internen Dokumentationssystem, auf das die zuständigen Administratoren und IT-Sicherheitsverantwortlichen zugreifen können. Hierbei kann es hilfreich sein, Checklisten einzusetzen, die beim Wareneingang oder der Inbetriebnahme prüfen, ob etwa Handbücher mit sicherheitsrelevanten Konfigurationsempfehlungen, Updatepläne, Zertifikate oder Kompatibilitätslisten vorliegen. Auch kann die Institution eine eindeutige Referenzierung der Unterlagen vornehmen, damit später nachvollziehbar ist, welche Version der Herstellerinformationen bei Inbetriebnahme zugrunde lag. Um die Nutzbarkeit zu erhöhen, kann eine Kurzfassung der relevanten Sicherheitspunkte in die interne Betriebsdokumentation übernommen werden, während die Originalunterlagen für Detailfragen hinterlegt bleiben. Bei wiederkehrenden Beschaffungen ähnlicher Komponenten kann zudem eine Vorlagenstruktur helfen, in der die typischen Unterlagenarten und deren Ablageorte definiert sind. So wird sichergestellt, dass die sicherheitsrelevanten Informationen nicht nur vorhanden, sondern auch im Bedarfsfall schnell auffindbar und anwendbar sind.

Control: BES.7.4.1 - Beschreibung der Sicherheitsarchitektur

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.7 Abnahme

Übergeordnetes Control:

BES.7.4 Vollständigkeit der Unterlagen

UUID: fca365f8-601e-4e9f-8b8a-1cc54c2936fb

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für IT-Produkte SOLLTE eine Beschreibung der Sicherheitsarchitektur dokumentieren.

Guidance

Die technische Sicherheitsarchitektur bezeichnet in diesem Kontext die strukturierte Darstellung der sicherheitsrelevanten Komponenten und Mechanismen eines IT-Produkts. Dazu gehören z. B. die eingesetzten kryptografischen Verfahren, die Segmentierung von Netzwerken, Schnittstellen zu anderen Systemen, Rollen- und Berechtigungskonzepte sowie Schutzmechanismen gegen Schadsoftware oder Manipulation. Sie bildet somit eine nachvollziehbare Übersicht, wie die Sicherheit im Produkt technisch verankert ist und wie diese in die bestehende IT-Landschaft integriert werden kann. Die Dokumentation kann verhindern, dass eine Institution Systeme übernimmt, deren Schutzmechanismen unklar oder unzureichend sind. Ohne eine solche Transparenz könnte es passieren, dass kritische Schwachstellen verborgen bleiben oder Sicherheitsmechanismen aufgrund mangelnden Verständnisses nicht korrekt konfiguriert werden. Eine sinnvolle Umsetzung kann beispielsweise so erfolgen: (1) Ein Anbieter kann verpflichtet werden, vor Abnahme ein Architekturdiagramm mit hervorgehobenen Sicherheitskomponenten bereitzustellen. (2) Die Institution kann bei Pilotinstallationen Checklisten verwenden, um die dokumentierten Sicherheitsmaßnahmen mit der realisierten Konfiguration abzugleichen. (3) Ergänzend kann ein standardisiertes Template genutzt werden, das Mindestangaben wie eingesetzte Protokolle, Verschlüsselungsmechanismen, Rollenmodelle und Logging-

Kapazitäten abfragt, sodass einheitliche und vergleichbare Unterlagen entstehen. Auch ein Abgleich mit bewährten Referenzarchitekturen kann helfen, die Vollständigkeit und Plausibilität der Angaben zu prüfen.

Control: BES.7.4.2 - Beschreibung von Sicherheitsmechanismen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.7 Abnahme

Übergeordnetes Control:

BES.7.4 Vollständigkeit der Unterlagen

UUID: 223cfe79-7b19-4c57-9535-b36c486f810f

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für IT-Produkte SOLLTE eine Beschreibung der gelieferten Sicherheitsmechanismen dokumentieren.

Guidance

Hierzu zählt z.B. eine Information des Herstellers, dass die Verschlüsselung nach BSI TR-02102 erfolgt.

Control: BES.7.4.3 - Empfohlene Konfiguration

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.7 Abnahme
Übergeordnetes Control:
BES.7.4 Vollständigkeit der Unterlagen
UUID: 17260753-9f50-4480-bfbc-226a362b0ab6
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für IT-Produkte SOLLTE eine vom Hersteller oder Lieferanten für den sicheren Betrieb empfohlene Konfiguration dokumentieren.

Guidance

Eine vom Hersteller oder Lieferanten empfohlene Konfiguration ist eine dokumentierte Vorgabe, welche Einstellungen, Dienste und Sicherheitsparameter für den sicheren Betrieb vorgesehen sind. Diese Empfehlung ist im Fachkontext oft als Secure Baseline Configuration bekannt und kann z. B. Angaben zu Benutzerrechten, Netzwerkschnittstellen oder Update-Mechanismen enthalten. Der Sinn und Zweck dieser Anforderung liegt darin, dass IT-Produkte nicht im unsicheren Auslieferungszustand betrieben werden, sondern in einer geprüften und abgestimmten Form. Ohne solche Empfehlungen könnte ein System mit unnötig offenen Ports betrieben werden oder ein Administratorkonto ohne Passwortschutz bestehen, was Angreifern leichtes Spiel böte. Eine dokumentierte und nachvollziehbar empfohlene Konfiguration kann hingegen dafür sorgen, dass Schwachstellen von Beginn an reduziert werden und ein sicherer Ausgangszustand für den weiteren Betrieb geschaffen wird. Konkret kann dies durch (1) die Ablage der Herstellerempfehlungen in einer zentralen Wissensdatenbank, (2) die Überführung dieser Vorgaben in technische Checklisten für Systemadministratoren oder (3) die Nutzung von Skripten oder Vorlagen zur automatischen Einrichtung von Betriebssystemen, Netzwerkgeräten oder Anwendungen erfolgen. Zusätzlich kann es hilfreich sein, Abweichungen zur Empfehlung zu dokumentieren, um spätere Prüfungen oder Audits nachvollziehbar zu gestalten.

Links

related: KONF.2.1 Grundkonfiguration für Systeme

related: KONF.10.1 Grundkonfiguration für Anwendungen

Control: BES.7.4.4 - Dokumentation der Komponenten

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.7 Abnahme
Übergeordnetes Control:
BES.7.4 Vollständigkeit der Unterlagen
UUID: 06967239-6b5a-4329-bf28-e910cebefd45
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- BES.7.4.4.1 Software Bill of Materials (SBOM)

Statement

Beschaffungsmanagement für Einkäufe SOLLTE eine Beschreibung der verwendeten Hardware- und Softwarekomponenten dokumentieren.

Guidance

Hierzu zählen Angaben zum Hersteller und der Leistungsfähigkeit und Zusammensetzung der verbauten Hardware- und Softwarekomponenten. Für die Softwarekomponenten kann die Beschreibung standardisiert nach BSI TR-03183-2 erfolgen.

Control: BES.7.4.4.1 - Software Bill of Materials (SBOM)

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.7 Abnahme
Übergeordnetes Control:
BES.7.4.4 Dokumentation der Komponenten
UUID: f89b0154-ccb8-401f-b352-9135e685a4e7
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für IT-Produkte KANN für jede gelieferte Software die entsprechende Software Bill of Materials (SBOM) nach {{ insert: param, bes.7.4.4.1-prm1 }} dokumentieren.

Guidance

Je nach Produkt können hierzu auch die Firmware, das Betriebssystem oder mehrere Softwarebestandteile einer Anwendung gehören. Ein anerkannter Standard für SBOM ist die BSI TR-03183-2.

Links

related: DEV.4.3 Softwarebestandteile (SBOM)

related: TEST.3.1.7 Analyse der Zusammensetzung

Control: BES.7.4.5 - Netzverbindungen ab Werk

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.7 Abnahme

Übergeordnetes Control:

BES.7.4 Vollständigkeit der Unterlagen

UUID: f901b96c-6a92-46aa-834d-0b398d46482e

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für IT-Produkte SOLLTE eine Liste der Internetserver, mit denen das IT-Produkt von sich aus Verbindung aufnimmt, mit Zweck der Verbindung, Zieladresse(n), Port-Nummern dokumentieren.

Guidance

Geräte und Software verbinden sich oft schon im Auslieferungszustand oder bei der normalen Nutzung über das Internet mit Diensten, z.B. zur Übermittlung von Telemetrie- und Diagnosedaten oder zur Bereitstellung von Cloud-Funktionen. Eine Liste der Verbindungen hilft, die Übersicht zu behalten, welche Kommunikationsbeziehungen zu welchem Zweck das IT-Produkt aufnimmt. Die Liste kann vom Lieferanten gestellt werden oder durch Untersuchung des Produktes selbst ermittelt werden. Eine eigene Untersuchung ist jedoch deutlich aufwändiger, da sichergestellt werden muss, dass auch Verbindungen erfasst werden, die z.B. nur bei einem Absturz der Anwendung aufgebaut werden.

Control: BES.7.4.6 - Shared Responsibility

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.7 Abnahme

Übergeordnetes Control:

BES.7.4 Vollständigkeit der Unterlagen

UUID: e7afc3eb-feac-4cad-8ad4-a46a867f45d8

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE die Verteilung der Zuständigkeiten und deren Abgrenzung dokumentieren.

Guidance

Beim Outsourcing gibt es verteilte Zuständigkeiten zwischen Dienstleister und Institution (sog. Shared Responsibility). Hierbei ist z.B. relevant, welche Verarbeitungen in der Zuständigkeit des Dienstleisters liegen und welche weiterhin bei der Institution vorgenommen werden, z.B. Infrastructure-as-a-Service vs. Software-as-a-Service.

Control: BES.7.4.7 - Organisatorische Schnittstellen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.7 Abnahme

Übergeordnetes Control:

BES.7.4 Vollständigkeit der Unterlagen

UUID: c8752d5c-3fbf-4853-95f8-d5d87df73b7e

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE die organisatorischen Schnittstellen des Dienstleisters dokumentieren.

Guidance

Beispielsweise Meldewege für Notfälle, Sicherheitsvorfälle, Eskalationsstufen.

Control: BES.7.4.8 - Technische Schnittstellen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.7 Abnahme
Übergeordnetes Control:
BES.7.4 Vollständigkeit der Unterlagen
UUID: e0b880c1-c7a8-491a-a8c4-df081ed9a8d4
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Dienstleistungen SOLLTE die vom Dienstleister bereitgestellten technischen Schnittstellen und deren Sicherheitsfunktionalität dokumentieren.

Guidance

Die Dokumentation der vom Dienstleister bereitgestellten technischen Schnittstellen und deren Sicherheitsfunktionalität dient in erster Linie dazu, Transparenz über potenzielle Angriffspunkte und Integrationsrisiken zu schaffen. Fehlende oder unzureichend beschriebene Schnittstellen können zu gravierenden Vorfällen führen: So könnte etwa eine unsauber dokumentierte API unbemerkt unverschlüsselte Daten übertragen oder unautorisierte Zugriffe ermöglichen.

Control: BES.7.4.9 - Auslagerungsregister

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.7 Abnahme

Übergeordnetes Control:

BES.7.4 Vollständigkeit der Unterlagen

UUID: ca2e05d8-da09-45f2-b9e7-48e3ef4b032c

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Outsourcing SOLLTE Informationen über den Dienstleister, die Kritikalität des Prozesses, abgeschlossene Verträge und Vereinbarungen sowie Zeitpunkt und Inhalt von Änderungen an den Vereinbarungen nach Vertragsschluss dokumentieren.

Guidance

Hierzu genügt ein zentrales Auslagerungsregister, welches zu allen ausgelagerten Prozessen die geforderten Informationen enthält. Als Angaben zum Dienstleister gehören dessen Unternehmensbezeichnung und Erreichbarkeiten.

Control: BES.7.4.10 - Serviceprofil

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.7 Abnahme
Übergeordnetes Control:
BES.7.4 Vollständigkeit der Unterlagen
UUID: 406b5a6e-fb23-4a70-8d6d-2a5965513eb4
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Beschaffungsmanagement für Cloud-Dienste SOLLTE für jeden geplanten oder genutzten Cloud-Dienst ein Serviceprofil mit dem Namen des Services und des Anbieters dokumentieren.

Guidance

Mögliche Inhalte um zuvor identifizierte Anforderungen ergänzen : Bezeichnung, Kurzbeschreibung, Kategorie, Sub- bzw. Sekundärservices, Varianten, technische Parameter, Service-Parameter/SLA, SLA-Messung, Gültigkeit des Services (Zeitraum), Service-Übergabe, Methoden der Kostenermittlung, Preis/Verrechnung, Ansprechpartner für den Service, Berechtigte und Anforderer sowie Voraussetzungen und Abhängigkeiten zu anderen Diensten.

Control: BES.7.4.11 - Dokumentierte Mandantentrennung

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.7 Abnahme

Übergeordnetes Control:

BES.7.4 Vollständigkeit der Unterlagen

UUID: d59ad53c-00d4-4bfd-8af9-bf09722731c5

Aufwand: 4

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Outsourcing KANN die beim Dienstleister implementierten Maßnahmen zur Mandantentrennung nach Vertragsschluss dokumentieren.

Guidance

Die Dokumentation der beim Dienstleister implementierten Maßnahmen zur Mandantentrennung trägt dazu bei, die Risiken unzureichender Abgrenzung zwischen verschiedenen Kundeninstanzen transparent zu bewerten und im Bedarfsfall nachzuweisen. Ohne eine solche Transparenz könnte es zu Datenabflüssen oder unbefugtem Zugriff durch andere Mandanten kommen, etwa wenn virtuelle Maschinen auf derselben Hardware betrieben werden und Schwachstellen in der Virtualisierung ausgenutzt werden könnten. Eine dokumentierte Trennungskontrolle kann nachweisen, dass Speicher, Rechenleistung oder Netzwerksegmente isoliert sind und dadurch die Vertraulichkeit und Integrität der eigenen Daten erhalten bleibt. Im Kontext bedeutet Mandantentrennung die technische und/oder organisatorische Gewährleistung, dass Daten, Prozesse und Ressourcen verschiedener Kunden innerhalb einer geteilten Infrastruktur so voneinander abgegrenzt sind, dass unbeabsichtigte oder absichtliche Zugriffe ausgeschlossen werden können. Damit ist nicht nur die physische, sondern auch die logische Separation gemeint. Die Umsetzung kann sinnvoll erfolgen, indem eine Institution nach Vertragsschluss gezielt vom Dienstleister beschriebene Schutzmechanismen abfragt und dokumentiert, beispielsweise Isolierungsverfahren auf Hypervisor-Ebene, Verschlüsselung pro Mandant oder die

Vergabe getrennter Schlüsselmaterialien. Praktisch kann es hilfreich sein, in Service-Reports nachvollziehbare Testnachweise zu verlangen, etwa Ergebnisse von Penetrationstests, die speziell auf Mandantengrenzen zielen.

Links

related: BES.4.5.2 Mandantentrennung

Control: BES.7.4.12 - Software Bill of Materials (SBOM) - Cloud

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: BES.7 Abnahme

Übergeordnetes Control:

BES.7.4 Vollständigkeit der Unterlagen

UUID: 7a3321a5-9f54-4ada-955d-647aeb0e51b5

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Cloud-Dienste KANN für jede gelieferte Software-as-a-Service (SaaS) die entsprechende Software Bill of Materials (SBOM) nach {{ insert: param, bes.7.4.12-prm1 }} dokumentieren.

Guidance

Ein anerkannter Standard für SBOM ist die BSI TR-03183-2.

Control: BES.8.1 - Bereithaltung alternativer Lieferanten

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.8 Kompensierende Kontrollmechanismen
UUID: 7a7af54d-83c0-4a32-900f-e4ff9ac02450
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Einkäufe KANN die Bereithaltung alternativer Lieferanten verankern.

Guidance

Das Bereithalten alternativer Lieferanten kann dazu beitragen, Abhängigkeiten zu reduzieren und die Resilienz der Liefer- und Beschaffungskette zu erhöhen. Das ist insbesondere dann von großer Bedeutung, wenn ein einzelner, wichtiger Lieferant kurzfristig ausfällt – etwa durch Produktionsstörungen, Insolvenzen, Lieferengpässe, politische Sanktionen oder Cyberangriffe auf dessen Systeme. In solchen Fällen könnte die institutionseigene Versorgung mit kritischen Gütern oder Dienstleistungen gefährdet sein, was wiederum Ausfälle, Qualitätsmängel oder Vertragsstrafen nach sich ziehen könnte. Gerade bei sicherheitskritischen Komponenten, Spezialsoftware oder Ersatzteilen mit langen Vorlaufzeiten könnte das Fehlen einer zweiten Bezugsquelle zu erheblichen Betriebsunterbrechungen führen. Der Begriff „alternative Lieferanten“ meint in diesem Kontext qualifizierte Drittanbieter, die vergleichbare Produkte oder Leistungen in einer wirtschaftlich und technisch angemessenen Qualität und Menge wirksam bereitstellen können. „Angemessenheit“ bezieht sich hier auf den Grad, in dem ein alternativer Lieferant die Mindestanforderungen der Institution hinsichtlich Qualität, Sicherheit, Verfügbarkeit und Kompatibilität erfüllt, während „Wirksamkeit“ bedeutet, dass dieser im Bedarfsfall tatsächlich kurzfristig und ohne erhebliche Zusatzrisiken einspringen kann. Zur praktischen Umsetzung kann eine Institution zunächst identifizieren, für welche Materialien, Systeme oder Services ein Ausfall besonders kritisch wäre, und für diese gezielt alternative Bezugsquellen evaluieren. Dazu kann gehören, eine Lieferantenliste mit geprüften Zweit-

bietern zu pflegen, Rahmenverträge vorzubereiten oder vereinbarte Notfallmengen zu definieren, die im Bedarfsfall abgerufen werden können. Eine Möglichkeit ist es, Testbestellungen bei alternativen Anbietern durchzuführen, um Qualität, Liefersgeschwindigkeit und Kommunikationswege zu erproben. Ebenso kann es hilfreich sein, technische Spezifikationen so zu gestalten, dass mehrere Anbieter kompatible Produkte liefern können, um Lock-in-Effekte zu vermeiden.

Control: BES.8.2 - Verfahren zur Übertragung von Geschäftsprozessen

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.8 Kompensierende Kontrollmechanismen
UUID: e69b2846-6b36-4b3e-8fbc-e1ccd17f4f48
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Outsourcing KANN Verfahren zur Übertragung von Geschäftsprozessen für den Fall einer geplanten oder ungeplanten Beendigung des Vertrages verankern.

Guidance

Es empfiehlt sich diese Alternativen in einem Maßnahmenkatalog zu dokumentieren. Darin können z.B. alternative Dienstleister festgehalten werden, welche über das notwendige Niveau an Informationssicherheit verfügen, um den Prozess, welcher an den bisherigen Dienstleister ausgelagert wird, in gleichem Maße umzusetzen.

Control: BES.8.3 - Ressourcensouveränität

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.8 Kompensierende Kontrollmechanismen
UUID: c928db22-3ace-445e-b501-7ebb8fbd9c2d
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Outsourcing KANN ausreichende interne Ressourcen für den Fall einer geplanten oder ungeplanten Beendigung des Vertrages zuweisen.

Guidance

Die Bereithaltung ausreichender interner Ressourcen zielt hier darauf ab, für den Fall einer plötzlichen Einstellung der beschafften Dienste ausreichend ausgestattet zu sein, um einer übermäßigen Abhängigkeit gegenüber den Anbietenden von Outsourcing vorzubeugen. Zu den notwendigen Ressourcen gehört sowohl Personal, welches für die bei einem Ausfall des Dienstleisters erforderlichen Aufgaben qualifiziert ist, als auch die für diese Aufgaben erforderliche Infrastruktur (z.B. IT-Systeme, Anwendungslizenzen, Zugänge und Berechtigungen).

Control: BES.8.4 - Individuelle Implementierung kritischer Komponenten

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.8 Kompensierende Kontrollmechanismen
UUID: c3ef1d10-5c10-4411-9a02-bb352211bc88
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für IT-Produkte KANN eine eigens für die Institution entwickelte Implementierung kritischer Komponenten vereinbaren.

Guidance

Dient dazu das Risiko zu mindern, dass sicherheitsrelevante Funktionen oder Integrationspunkte ungeeignet, unvollständig oder von Drittanbietern unzureichend abgesichert bereitgestellt werden. Kritische Komponenten sind dabei jene Hardware- oder Software-Bestandteile, deren Ausfall, Kompromittierung oder Fehlfunktion wesentliche Geschäftsprozesse beeinträchtigen oder sensible Daten gefährden könnte – etwa Kryptomodule, Authentifizierungsmechanismen, Schnittstellen zur Anbindung an interne Systeme oder sicherheitsrelevante Konfigurationsbausteine. Ohne gezielte Einflussnahme bei der Beschaffung könnte es beispielsweise vorkommen, dass ein Standardprodukt mit unsicheren Voreinstellungen geliefert wird, ein Modul nicht die für den Einsatzzweck erforderliche Verschlüsselung unterstützt oder herstellerseitige Updates nicht zeitnah bereitgestellt werden. Andererseits bergen selbst entwickelte Komponenten gegenüber Standardbeschaffungen das Risiko, dass die Eigenentwicklungen unzureichend getestet oder im Einsatz erprobt wurden. Daher ist vor einer Eigenentwicklung eine Risikoabschätzung sinnvoll. Typischerweise lohnt eine Eigenentwicklung sich nur wenn erhebliche Ressourcen für deren Absicherung vorhanden sind und der Vertraulichkeit oder Integrität eine stark erhöhte Bedeutung im Vergleich zu Standardprodukten zukommt. Eine Institution kann bei der Umsetzung dieser Anforderung gezielt in den Beschaffungsvertrag aufnehmen, dass bestimmte Komponenten nach definierten Vorgaben angepasst, gehärtet oder erweitert werden – beispielsweise eine erweiterte Protokollierungs-

funktion in einer Verwaltungssoftware, eine abgesicherte Firmware-Konfiguration bei Netzwerkgeräten oder die Integration zusätzlicher Prüfmechanismen in eine Schnittstellen-API.

Control: BES.8.5 - Treuhand

Tag: "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: BES.8 Kompensierende Kontrollmechanismen
UUID: a5f72086-9f22-4376-9b24-25ca429542d6
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Beschaffungsmanagement für Dienstleistungen KANN ESCROW- bzw. Treuhandverträge vereinbaren.

Guidance

ESCROW- bzw. Treuhandverträge regeln die Verwertungs- und Bearbeitungsrechte (z.B. für eine Software sowie Herausgabefälle des Quellcodes) für den Fall, dass es zu Streitigkeiten oder Ausfällen der Dienstleister kommt. Hierzu gehören auch ggf. zur Nutzung erforderliche Begleitunterlagen oder Zugangsmittel wie Schlüssel oder Passwörter. Außerdem ist es zweckmäßig, vertraglich festzulegen, wie häufig Daten (z.B. Quellcode) hinterlegt und dokumentiert werden. Auch eine Regelung bzgl. der Geheimhaltungspflichten im Vertrag ist zu empfehlen.

Control: DET.1.1 - Verfahren und Regelungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.1 Grundlagen
UUID: 03e9ac6f-3dbc-438b-9671-6754e617c105
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DET.1.1.1 Dokumentation
- DET.1.1.2 Zuweisung der Aufgaben
- DET.1.1.3 Bekanntgabe

Statement

Detektion MUSS Verfahren und Regelungen zur Detektion von Sicherheitsvorfällen verankern.

Guidance

Durch die steigende Menge und Komplexität von Datenverarbeitungen sind Sicherheitsvorfälle auch bei bester Prävention zu erwarten. Ein Verfahren zur Detektion stellt sicher, dass Sicherheitsvorfälle zeitnah entdeckt werden können. Hierzu gehört, wie aktiv und passiv Sicherheitsvorfälle erkannt werden, sowie wer bei der Erkennung dabei wofür zuständig ist. Die Umsetzung kann in einem eigenen Prozess, oder integriert in andere Prozesse und Aufgaben erfolgen. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Control: DET.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.1 Grundlagen

Übergeordnetes Control:

DET.1.1 Verfahren und Regelungen

UUID: 609e4af3-91aa-47e9-a293-a6d4ec446ae2

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Detektion MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: DET.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.1 Grundlagen

Übergeordnetes Control:

DET.1.1 Verfahren und Regelungen

UUID: e77e84bc-da99-4a39-97da-41393c6422ac

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Detektion MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, det.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es, die Zuweisung anhand von Rollen (z. B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: DET.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.1 Grundlagen

Übergeordnetes Control:

DET.1.1 Verfahren und Regelungen

UUID: cd662f68-72c0-4de0-8969-2be2da7049de

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Detektion MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: DET.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.1 Grundlagen

UUID: 9801627a-0646-41fe-81d8-945e7b58da50

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Detektion MUSS die Verfahren und Regelungen {{ insert: param, det.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante Überprüfung der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: DET.2.1 - Meldeverfahren

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.2 Meldung von Ereignissen
UUID: d1646dc3-5cdb-44a5-999a-d41785bdd34b
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.2.1.2 Meldeformulare
- DET.2.1.3 Rückmeldungen

Statement

Detektion SOLLTE ein Meldeverfahren verankern.

Guidance

Zweck ist es einerseits Nutzenden das schnelle Melden von potenziellen Sicherheitsproblemen zu ermöglichen und andererseits die zuständigen Stellen zu einer schnellen Reaktion auf Vorfälle anzuhalten.

Control: DET.2.1.1 - Sofortmaßnahmen Nutzender

Tag: "Kompetenzmanagement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.2 Meldung von Ereignissen
Übergeordnetes Control:
DET.2.1 Meldeverfahren
UUID: 89191db5-45b5-4e35-91b6-eb277d2427ac
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE Regelungen für Sofortmaßnahmen durch Nutzende verankern.

Guidance

Beispiele für Sofortmaßnahmen sind der sofortige Stopp weiterer Tätigkeiten an betroffenen Systemen, die Dokumentation von Beobachtungen oder zu meldende Informationen (W-Fragen). Hierfür kann die IT-Notfallkarte „Verhalten bei IT-Notfällen“ des BSI genutzt werden.

Control: DET.2.1.2 - Meldeformulare

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.2 Meldung von Ereignissen

Übergeordnetes Control:

DET.2.1 Meldeverfahren

UUID: d6a025c2-5cca-49d0-ab04-54cd419e147e

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE Meldeformulare für Vorfallsmeldungen installieren.

Guidance

Die Angabe des Meldezeitpunktes oder der Name des Meldenden, kann auch durch ein Formular automatisch ausgefüllt werden.

Control: DET.2.1.3 - Rückmeldungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.2 Meldung von Ereignissen

Übergeordnetes Control:

DET.2.1 Meldeverfahren

UUID: c961b1c8-2f6a-4e6d-9126-e2005c44f728

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE ein Verfahren für Rückmeldungen verankern.

Guidance

Rückmeldungen an Personen, die potenzielle Vorfälle gemeldet haben, sind hilfreich, da sie zum besseren Verständnis beitragen, worauf bei künftigen Meldungen zu achten ist und wie die Meldenden zur Bearbeitung des Vorfalls beitragen können. Ohne Rückmeldung könnte Unsicherheit entstehen, ob ein Vorfall überhaupt aufgenommen oder ernst genommen wurde, was zu Frustration oder einer sinkenden Bereitschaft zur Meldung künftiger Ereignisse führen könnte. Eine zeitnahe und angemessene Rückmeldung kann dagegen die Nutzenden in ihrem sicherheitsbewussten Verhalten bestärken, die Relevanz ihrer Meldung verdeutlichen und Missverständnisse vermeiden. So kann beispielsweise eine Rückmeldung nach einem gemeldeten Phishing-Versuch klarstellen, ob es sich um einen bekannten Angriff handelte oder ob zusätzliche Maßnahmen wie das Zurücksetzen eines Passworts empfohlen werden. Ebenso kann eine Rückmeldung nach einem gemeldeten Systemausfall erläutern, ob dieser sicherheitsrelevant war oder eine rein technische Störung vorlag. Ein Rückmeldeverfahren kann in diesem Kontext als ein strukturierter Ablauf definiert werden, über den die meldende Person nach Eingang ihrer Meldung eine Information über den Status, die Relevanz und – falls sinnvoll – empfohlene Folgeschritte erhält. Ein automatisiertes Ticketsystem kann beispielsweise sofortige Eingangsbestätigungen generieren und Statusänderungen kommunizieren. Ebenso kann eine abgestufte Rückmeldepflicht sinnvoll sein, bei der kritische Vorfälle eine priorisierte persönliche Rückmeldung durch Fachpersonal erhalten, während unkritische Meldungen standardisierte Mitteilungen bekommen. Technische Hilfsmittel wie Mail-Vorlagen, interne Chatbots oder Self-Service-Portale können die Effizienz erhöhen

Control: DET.2.2 - Security Operations Center

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.2 Meldung von Ereignissen
UUID: 1af88c3b-a13c-4d74-a099-f230c9f71f55
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Detektion KANN die Erkennung, Beurteilung und initiale Behandlung von Vorfällen {{ insert: param, det.2.2-prm1 }} zuweisen.

Guidance

Ein Security Operations Center (SOC) ist eine organisatorische Einheit, deren dedizierte Aufgabe die Überwachung von sicherheitskritischen Ereignissen, sowie die Reaktion auf Sicherheitsvorfälle ist. Für die Definition eines sicherheitskritischen Ereignisses, siehe Glossar (Namensräume des Grundschutz++). Aufgrund der Komplexität und besonderen Bedeutung der Aufgabe leisten Spezialisten für Detektion und Reaktion auf Sicherheitsvorfälle einen wichtigen Beitrag zur effektiven Informationssicherheit einer Institution. Werden diese Aufgaben von speziell hierfür geschultem Personal übernommen und nicht „nebenbei“ von Betriebspersonal, so werden Zielkonflikte zwischen Informationssicherheit und reibungslosem Betrieb vermieden und die Qualität der Sicherheitsbeurteilungen steigt. Kann durch ein selbst betriebenes SOC oder einen Dienstleister realisiert werden.

Control: DET.2.3 - Ständiger Bereitschaftsdienst

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.2 Meldung von Ereignissen
UUID: 3f07d773-fef4-4bf1-9ec4-d803e7767a4b
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion KANN einen ständigen Bereitschaftsdienst verankern.

Guidance

Dies erfordert, dass 24/7 eine Person bereitgehalten wird, welche bei sicherheitsrelevanter Alarmierung umgehend die Behebung des Vorfalls aufnimmt. Welche Ereignisse kritisch sind, ist dabei von der Kritikalität der betroffenen Systeme oder Anwendungen abhängig. Für die Definition eines sicherheitskritischen Ereignisses, siehe Glossar (Namensräume des Grundschutz++).

Control: DET.3.1 - Protokollierung sicherheitsrelevanter Ereignisse

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
UUID: dc58d353-86e1-4070-9f86-b7f0e0f93305
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DET.3.1.1 Authentifizierungen
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten

Statement

Detektion für Anwendungen SOLLTE Sicherheitsrelevante Ereignisse mindestens für {{ insert: param, det.3.1-prm1 }} protokollieren.

Guidance

Für die Definition eines Sicherheitsrelevanten Ereignisses, siehe Glossar (Namensräume des Grundschutz++). Relevant sind hierbei insbesondere die Protokollierung auf zentralen Diensten und Servern. Dazu gehören auch vorhandene Cloud-Anwendungen oder -Dienste. Hier besteht ein enger Bezug zur Praktik Änderungen und Tests.

Control: DET.3.1.1 - Authentifizierungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: c25354d3-ed8f-4bac-ad0c-f0641d1b7f84
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Detektion für IT-Systeme SOLLTE Authentifizierungen bei Erfolg und Fehlschlag protokollieren.

Guidance

Relevant sind dabei z.B. die lokale Anmeldung, Anmeldung und Zugriffe auf Schnittstellen des Systems über das Netz, oder auch die physische Authentifizierung an einem Zutrittskontrollsystem.

Control: DET.3.1.2 - Ausgeführte Kommandozeilenbefehle

Tag: "Living off the land"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: cd3be1eb-6b18-4e69-98c5-a584e7daa9f2
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Detektion für IT-Systeme SOLLTE ausgeführte Kommandozeilenbefehle protokollieren.

Guidance

Angreifer nutzen Kommandozeilenfunktionen wie Bash oder Windows PowerShell, um mit Bordmitteln schädliche Befehle auszuführen. Hier sind vor allem Living-off-the-Land-Binaries (LOLBins) und Nutzlasten (Malware Payloads) zu nennen.

Control: DET.3.1.3 - Anbindung von Peripheriegeräten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: b0d1ef63-3c21-4d01-a5ad-82c23f113994
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Detektion für IT-Systeme SOLLTE das Anschließen von Peripheriegeräten protokollieren.

Guidance

Das Protokollieren der Anbindung von Peripheriegeräten kann helfen, Manipulationsversuche an IT-Systemen frühzeitig zu erkennen und nachzuvollziehen. Ohne ein solches Protokoll könnte beispielsweise ein unbefugtes Speichermedium angeschlossen und vertrauliche Daten unbemerkt entwendet werden, oder es könnte Schadsoftware über ein USB-Gerät eingeschleust werden. Auch manipulierte Eingabegeräte könnten genutzt werden, um Tastatureingaben auszulesen oder unbemerkt Befehle einzuschleusen. Unter Peripheriegeräten sind in diesem Kontext externe Komponenten (aus Hardware oder virtuell) zu verstehen, die ein IT-System erweitern oder mit diesem verbunden werden – etwa USB-Sticks, externe Festplatten, Smartphones im Lade- oder Datenmodus, Drucker oder auch spezialisierte Geräte wie Diagnose- oder Messinstrumente. Zur praktischen Umsetzung kann eine Institution beispielsweise auf Betriebssystemfunktionen zurückgreifen, die Geräteanschlüsse im System-Log erfassen, oder ergänzende Endpoint-Management-Lösungen einsetzen, die eine zentralisierte Protokollierung erlauben.

Control: DET.3.1.4 - Systemfehler

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: f04839ae-7df6-4518-a726-994a329e910a
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Detektion für IT-Systeme SOLLTE Fehlermeldungen des Systems protokollieren.

Guidance

Die Protokollierung von Fehlermeldungen kann eine wesentliche Grundlage für die Früherkennung von Sicherheits- und Stabilitätsproblemen in IT-Systemen bilden. Ohne ein systematisches Logging könnte ein kritischer Hardwaredefekt, eine beschädigte Systemdatei oder ein fehlgeschlagener Sicherheits-Update-Prozess unentdeckt bleiben und dadurch die Integrität oder Verfügbarkeit von IT-Systemen gefährden. Ebenso könnte ein Angreifer, der wiederholt unautorisierte Befehle ausführt oder Dienste fehlerhaft anspricht, unbemerkt bleiben, wenn die resultierenden Fehlermeldungen nicht nachvollzogen werden. Auf technischer Ebene kann es zweckmäßig sein, das native Logging des Betriebssystems zu aktivieren und so zu konfigurieren, dass Fehlermeldungen konsistent erfasst werden – beispielsweise über Syslog-Dienste oder Windows-Event-Logs. Eine zentrale Log-Sammlung kann helfen, auch bei verteilten Systemen eine einheitliche Auswertung vorzunehmen.

Control: DET.3.1.5 - Störungen der Netzerreichbarkeit

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: 39faab52-c5ca-4971-8f00-6eb34319cb55
Aufwand: 3
Sicherheitsstufe: erhöht

Statement

Detektion für IT-Systeme KANN Störungen der Netzerreichbarkeit protokollieren.

Guidance

Eine Störung der Netzerreichbarkeit kann ein Indiz für Überlastungen, Fehler oder Angriffe im Netz sein. Wann eine Störung vorliegt, kann anhand von Schwellwerten, z.B. durch das Ausbleiben eines regelmäßigen Heartbeat-Paketes, getestet werden.

Control: DET.3.1.6 - Systemspezifische Ereignisse

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: 42287f3d-c1ce-4109-bda1-87d1fd892993
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für IT-Systeme KANN {{ insert: param, det.3.1.6-prm1 }} protokollieren.

Guidance

Bestimmte systemspezifische Ereignisse meint hier, dass von der Institution konkret festgehalten wurde, welche für das System relevanten Ereignisse im Einzelnen protokolliert werden. Beispiele sind Aktionen mit spezifisch konfigurierten privilegierten Berechtigungen, Prozessaktivitäten des Betriebssystems, wie das Starten eines Systemprozesses, Dateierzeugung oder das Laden eines Treibers, die Modifikation von Systemkonfigurationsdateien oder die Installation oder Deinstallation von Systemdiensten und Anwendungen, sowie das Herunterfahren oder Neustarten des Systems. Die Festlegung, welche dieser oder weiterer systemspezifischer Ereignisse protokolliert werden, obliegt der Institution und hängt von der jeweiligen Systemumgebung und dem Schutzbedarf ab.

Control: DET.3.1.7 - Was, Wann, Wo

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: c4cb825e-c401-44a5-8ecf-de12b33e6a16
Aufwand: 5
Sicherheitsstufe: normal-SdT

Statement

Detektion für Anwendungen SOLLTE zu jedem sicherheitsrelevanten Ereignis mindestens Zeitpunkt, die Quelle und das Zielobjekt protokollieren.

Guidance

Für die Definition eines Sicherheitsrelevanten Ereignisses, siehe Glossar (Namensräume des Grundschutz++). Damit einem Ereignis zuverlässig ein bestimmter Zeitpunkt zugewiesen werden kann, ist eine einheitliche Zeitquelle für die Systemuhr (meist über NTP oder PTP) als Voraussetzung erforderlich. Bei der Protokollierung der Herkunft oder Quelle (z.B. Gerätenamen, IP-Adresse) besteht ein enger Zusammenhang zu Compliance-Anforderungen, etwa zum Datenschutz.

Links

required: KONF.4.5 Zeitquellen

Control: DET.3.1.8 - Privilegierte Ereignisse

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: e7d500ff-393c-4c14-baed-c87b676efe5c
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Detektion für Anwendungen SOLLTE privilegierte Ereignisse einschließlich der Aktivierung, Deaktivierung oder Blockierung privilegierter Funktionen protokollieren.

Guidance

Privilegierte Ereignisse sind Vorgänge, bei denen besonders weitreichende Rechte genutzt werden – beispielsweise die Vergabe oder Entziehung von Administratorrechten, das Deaktivieren von Virenscannern oder Änderungen an Firewallregeln. Gerade solche Eingriffe könnten einen erheblichen Einfluss auf die Verfügbarkeit und Integrität von Daten haben. Ohne eine gezielte Aufzeichnung könnten sicherheitsrelevante Änderungen unentdeckt bleiben – etwa, wenn ein Angreifer unbefugt einen privilegierten Account übernimmt und Spuren verwischt, oder wenn ein interner Benutzer kritische Funktionen deaktiviert, wodurch Schutzmaßnahmen umgangen werden.

Control: DET.3.1.9 - Fehler der Anwendung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: 8a99b098-7642-4fec-996c-cbe94e7f88e6
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Detektion für Anwendungen SOLLTE Fehlermeldungen der Anwendung protokollieren.

Guidance

Fehlermeldungen können wichtige Hinweise auf technisches Versagen oder menschliches Fehlverhalten liefern. Insbesondere, wenn Fehlermeldungen neuartig sind, oder gehäuft auftreten, können sie Indiz für Probleme sein, die behandlungsbedürftig sind. Denken Sie insbesondere auch an Fehlermeldungen in automatisierten Prozessen, da diese möglicherweise sonst nicht zur Kenntnisnahme gelangen.

Control: DET.3.1.10 - Nutzungsstatistik

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: bcc48221-ad2b-4989-a754-23a167a08176
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Detektion für Anwendungen KANN eine Nutzungsstatistik protokollieren.

Guidance

Bei der statistischen Protokollierung werden z.B. Anzahl oder Durchschnittswerte gespeichert, nicht jedoch die genaue Herkunft oder der Zeitstempel bestimmter Ereignisse. Nutzungsstatistiken wahren die Privatsphäre der einzelnen Nutzenden, ermöglichen jedoch eine Erkennung von Fehlern oder Anomalien in der Nutzung. Beispiele sind die Anzahl von Anfragen für eine bestimmte Ressource (etwa Webserver-URL oder DNS-Name), Anzahl der Anfragen einer bestimmten Anfrageart, Geräte- oder Anwendungskategorien (etwa pro Browseragent oder Betriebssystemversion), Anzahl bestimmter Antworttypen (z.B. Webserver-Fehlercodes), sowie Zugriffsversuche. Hierdurch können Betriebsprobleme wie Caching Fehler oder DoS-Angriffe erkannt werden.

Control: DET.3.1.11 - Anwendungsspezifische Ereignisse

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: 80fa36d5-71d4-4a2e-9795-54cedffa44ae
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Detektion für Anwendungen KANN {{ insert: param, det.3.1.11-prm1 }} protokollieren.

Guidance

Die Festlegung, welche spezifischen Ereignisse protokolliert werden, obliegt der Institution und hängt von der jeweiligen Systemumgebung und dem Schutzbedarf ab. Beispiele sind Änderungen an Zugangskonten im Verzeichnisdienst, Telekommunikationsverbindungen, ein Verstoß gegen eine konfigurierte Policy, unautorisierter Zugriff, API-Aufrufe zwischen verschiedenen Anwendungskomponenten, Transaktionen in einem Finanzsystem oder einer E-Commerce-Anwendung, Konfigurationsänderungen oder ein Absturz der Anwendung. Die Protokollierung dieser Ereignisse kann helfen, die Behandlung durch das Betriebspersonal anzustoßen oder Indizien für Ermittler zu sichern.

Control: DET.3.1.12 - Datenverarbeitungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: ca3be46d-c9ce-45b0-8da9-e4f83f123e6d
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für Daten KANN die Verarbeitung von Daten protokollieren.

Guidance

Bei Daten mit hohem Schutzbedarf kann es sinnvoll sein, bestimmte Verarbeitungen (z.B. Zugriffe, Veränderungen, Löschung, Datenexporte) zu protokollieren. Änderungen können mit Versionsverwaltungssystemen automatisch protokolliert werden. Beispiele sind Zugriffe auf Dateifreigaben, Webportale oder Datenbank-Abfragen durch eine Anwendung, der Export von Verbindungsdaten auf dem TK-Server, oder der Versand von Nachrichten mit bestimmten Schlüsselwörtern.

Control: DET.3.1.13 - Integration von Cloud-Diensten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
Übergeordnetes Control:
DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
UUID: 681494bd-8d1d-4b34-84f6-abab2f4ea751
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für Cloud-Dienste KANN Ereignisse in der Cloud im Audit Log der Institution protokollieren.

Guidance

Daten in Cloud-Diensten könnten von Angreifern über das Internet angegriffen werden, ohne dass Ereignisse im internen Netz hierauf Rückschlüsse geben. Dies könnte zum Beispiel durch Phishing geschehen, wodurch ein OAuth Token für den Cloud-Zugang missbraucht wird. Die Integration der Logs des Cloud-Dienstleisters in die institutionseigene Protokollierung kann hier helfen, z.B. bei Authentifizierung oder Berechtigungsänderungen, sowie bei Zugriff oder Veränderung von Daten. Insbesondere die Integration des Loggings mit einer bedingten Zugriffsrichtlinie kann hier helfen, z.B. indem Zugriffe von ungewöhnlichen IP-Adressen oder Browser Agents auf Angriffe hinweisen können. Die Integration von Cloud-Protokollen in ein internes Logging birgt oft erhebliche Herausforderungen, darunter die Bewältigung des enormen Volumens und der Vielfalt an Datenformaten, was durch selektive Protokollierung, Datennormalisierung und -anreicherung angegangen werden kann. Die Absicherung der Datenpipeline gegen Man-in-the-Middle-Angriffe kann durch die Einhaltung der technischen Anforderungen an die beteiligten IT-Systeme und Anwendungen bewältigt werden, z.B. Verschlüsselung und Authentifizierung. Da Cloud-Anbieter oftzusätzliche Gebühren für den Datentransfer (Egress-Kosten) verlangen bietet es sich an, die Protokolle vor der Übertragung zu filtern, um die Kosten für die Verbesserung der Sicherheit gering zu halten.

Control: DET.3.2 - Filterung nicht benötigter Inhalte

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
UUID: fa239d57-3934-4664-bc2d-53aca634eaef
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion KANN die Protokollierung nicht benötigter Inhalte anhand von {{ insert: param, det.3.2-prm1 }} einschränken.

Guidance

Je nach Anwendung und Konfigurationseinstellungen könnten Protokolle auch Daten enthalten, die dort nicht benötigt werden, z.B. um die Vertraulichkeit der Daten zu wahren oder aufgrund von Compliance-Anforderungen. Dem kommt eine noch höhere Bedeutung zu, wenn die Protokolle zwischen Institutionen ausgetauscht, oder bei Cloud-Dienstleistern gespeichert oder analysiert werden. Maßnahmen können z.B. Anonymisierung von IP-Adressen oder anderen personenbezogenen Daten oder Geschäftsgeheimnissen, sowie enge Löschfristen sein. Für Verkehrsdaten kann der BfDI Leitfaden Speicherung Verkehrsdaten als Grundlage genutzt werden. Soweit möglich, ist es sinnvoll, die Filterung minimalinvasiv zu gestalten, d.h. nur diejenigen Daten auszufiltern, deren Speicherung nicht rechtlich oder tatsächlich möglich ist, die restlichen Angaben zum Ergebnis jedoch zu protokollieren.

Control: DET.3.3 - Speicherkapazität

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
UUID: 558dc6ab-ba8e-47bb-ba24-ddf09be49ec0
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE den für die Protokollierung zur Verfügung stehenden Speicherplatz {{ insert: param, det.3.3-prm1 }} überprüfen.

Guidance

Diese Vorschrift zielt darauf ab, die Verfügbarkeit der Protokolldaten sicherzustellen. Das ist essenziell, da eine unterbrochene oder lückenhafte Aufzeichnung die Früherkennung von Angriffen unmöglich machen könnte, was dazu führen könnte, dass kritische forensische Beweise für eine Untersuchung fehlen. Die Umsetzung dieser Anforderung kann auf verschiedene Arten erfolgen. Es könnte ein Skript oder ein automatisierter Dienst eingesetzt werden, der den Füllstand des Speicherplatzes in regelmäßigen Abständen, zum Beispiel alle 15 Minuten oder einmal pro Stunde, prüft. Alternativ kann eine Überprüfung bei einem definierten Schwellenwert durchgeführt werden, etwa wenn 80 % oder 90 % des zugewiesenen Speicherplatzes belegt sind. Zur Behebung könnte bei Kapazitätsengpässen eine automatische Archivierung älterer Protokolldaten auf einem separaten, kostengünstigeren Speicher gestartet werden, um den primären Speicher zu entlasten. Es kann aber auch eine Rotationsstrategie für Log-Dateien konfiguriert werden, die bei Erreichen einer bestimmten Größe oder eines Alters die ältesten Dateien löscht oder archiviert.

Control: DET.3.4 - Revisionssicherheit

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
UUID: 1cd947a7-70a2-41c9-b3fd-90f3ef75838c
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE Änderungen am Audit Log revisionssicher dokumentieren.

Guidance

Wenn die Protokollaufzeichnung unzureichend vor Veränderung geschützt ist, könnten Innentäter diese manipulieren oder löschen, um nicht erkannt oder belangt zu werden. Hierzu gehört auch, dass Administrierende die Protokolldaten zu ihren eigenen Tätigkeiten manipulieren oder löschen könnten. Die Integrität kann durch die Erstellung und getrennte Aufbewahrung von kryptografischen Hashes oder ein Versionskontrollsystem sichergestellt werden. Um sicherzustellen, dass nur autorisierte Personen die Protokolle verändern können, können z.B. Verschlüsselung und getrennte Aufbewahrung des Schlüssels, einmalig beschreibbare Datenträger, oder ein Protokollierungsserver/SIEM mit stark eingeschränkten Zugriffsrechten eingesetzt werden. Auch die Aufzeichnung in einer öffentlichen Transparenzdatei ist möglich, wenn die Protokolle keine vertraulichen Daten enthalten.

Control: DET.3.5 - Unbestreitbarkeit

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.3 Protokollierung
UUID: 1d98ecfc-cf7a-4cf5-a108-169802a7b364
Aufwand: 3
Sicherheitsstufe: erhöht

Statement

Detektion für Daten KANN Nachweise für den Zusammenhang {{ insert: param, det.3.5-prm1 }} mit {{ insert: param, det.3.5-prm2 }} dokumentieren.

Guidance

Für Handlungen, die eine besondere Bedeutung für die rechtliche Compliance oder die korrekte Verarbeitung von Daten in kritischen Geschäftsprozessen haben, kann es sinnvoll sein, eine zweifelsfreie Zuordnung des Ereignisses zu einer Person zu gewährleisten. Beispiele können das Senden von Nachrichten als Geschäftsleitung, die Überweisung hoher Beträge auf Konten im Ausland oder der Zugang einer Nachricht mit großer rechtlicher Bedeutung sein. Für einen zweifelsfreien Nachweis reicht die einfache Zuordnung zu einem Zugangskonto oft nicht aus, da das Konto auch von anderen missbraucht worden sein könnte. Zum Nachweis können verschiedene Maßnahmen eingesetzt werden: Digitale Signaturen auf Basis asymmetrischer Kryptographie können die Urheberschaft von Dokumenten verifizieren, während Zeitstempel von vertrauenswürdigen Zeitservern die chronologische Integrität sicherstellen. Eine dezentrale Speicherung der Logs auf verschiedenen Systemen erschwert Manipulationsversuche; ergänzend erhöht die Implementierung einer Blockchain-Technologie mit verketteten Hashwerten die Fälschungssicherheit erheblich. Hardwarebasierte Sicherheitsmodule (HSMs) können kryptografische Schlüssel vor unbefugtem Zugriff schützen.

Control: DET.4.1 - Überwachung der Protokollierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.4 Überwachung von Aktivitäten

UUID: 33c4b36a-263c-4380-9cc4-ab89c3995c22

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE die Funktionsfähigkeit der Protokollierung überwachen.

Guidance

Zu den Kriterien kann beispielsweise die Aktivierung oder Deaktivierung des Loggings auf Systemen, sowie die Datenmenge eingehender Logs in einem bestimmten Zeitraum gehören.

Control: DET.4.2 - Automatische Angriffserkennung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: d1691e68-55a6-4b71-8d55-08a10eaeb4a5
Aufwand: 5
Sicherheitsstufe: normal-SdT

Statement

Detektion für IT-Systeme SOLLTE diese auf Anzeichen für Angriffe durch {{ insert: param, det.4.2-prm1 }} überwachen.

Guidance

Wenn professionelle Tätergruppen Zugriff auf Systeme und Daten erhalten, nutzen sie diese zunehmend schneller für ihre Zwecke aus, z.B. um Daten abfließen zu lassen oder Ransomware zu verteilen. Zur Umsetzung können sowohl netz- als auch hostbasierte Erkennungssysteme (NIDS und HIDS) verwendet werden. Für die Detektion bei IT-Systemen ohne Installationsmöglichkeit wie Appliances, IoT-Geräte oder OT-Systeme kann ein kombinierter Ansatz aus Netzwerk- und Loganalyse sinnvoll sein. Angriffe können signaturbasiert, sowie durch Verhaltensanalyse und Anomalien erkannt werden. Die Anforderung kann auch mit bereits vorhandenen oder im System integrierten Angriffserkennungsmechanismen erfüllt werden. Zweckmäßig ist es Schwellwerte und Kategorien (Info, Warnung, Alarm) so festzulegen, dass Probleme frühzeitig erkannt werden können, aber beim Betriebspersonal keine Alarmmüdigkeit (alert fatigue) aufkommt. Hierzu ist es hilfreich die Ergebnisse regelmäßig auszuwerten und wenn nötig Korrekturmaßnahmen zu ergreifen.

Control: DET.4.3 - Überwachung der Angriffserkennung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.4 Überwachung von Aktivitäten

UUID: c31c5572-5982-4840-8dc3-ada7052bbb6a

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE die Funktionsfähigkeit der automatisierten Angriffserkennung überwachen.

Guidance

Hierzu gehört insbesondere die Aktivierung oder Deaktivierung der Angriffserkennung, oder das Stoppen zugehöriger Dienste.

Control: DET.4.4 - Änderungen an Sicherheitsrichtlinien

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.4 Überwachung von Aktivitäten

UUID: a71bbf22-4b3a-41d0-8ec8-6de7a9790040

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE Änderungen an Sicherheitsrichtlinien einschließlich deren Aktivierung oder Deaktivierung überwachen.

Guidance

Wird die Aktivität von automatisierten Sicherheitswerkzeugen nicht überwacht, so könnten Angreifer diese Schutzmechanismen unbemerkt deaktivieren und die Person so in falscher Sicherheit wiegen. Zudem installieren Angreifer gerne permanente Hintertüren über neue Konten oder Gruppenwechsel. Automatisierte Sicherheitsrichtlinien sind z.B. Ausnahmelisten von Antivirus- oder EDR, über den Verzeichnisdienst hinzugefügte Gruppenzugehörigkeiten zu sicherheitsrelevanten Gruppen (z.B. Admin), NAC oder Firewallregeln.

Control: DET.4.5 - Unerwünschte Datenabflüsse

Tag: "Data Leak"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: 67fb7507-f287-48da-a16d-f07d46b0aeb0
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Detektion KANN unerwünschte Datenabflüsse überwachen.

Guidance

Unerwünschte Datenabflüsse beziehen sich hier auf jede unautorisierte Übertragung sensibler Informationen aus internen IT-Systemen oder Anwendungen nach außen (engl. data leakage oder data exfiltration). Darunter fallen sowohl absichtliche als auch unbeabsichtigte Transfers, etwa über Endgeräte, Netzwerkkanäle oder Cloud-Schnittstellen, wobei Data Loss Prevention (DLP) als Sammelbegriff für technische und organisatorische Maßnahmen dient, die solche Abflüsse erkennen oder verhindern können. Die Überwachung kann gewährleisten, dass vertrauliche Inhalte nicht unbemerkt der Kontrolle entzogen werden. Herkunft und Ziel solcher Abflüsse können zusätzlich Indikatoren für kompromittierte Zugangskonten oder Fehlkonfigurationen liefern. Der Zweck der Vorschrift liegt darin, potenzielle Datenabflüsse frühzeitig sichtbar zu machen, sodass aufkommende Risiken wie der Verlust von personenbezogenen Datensätzen oder vertraulichen Forschungsunterlagen erkannt werden können; andernfalls könnte ein Angreifer persistente Kommunikationskanäle nutzen, um über längere Zeit unbemerkt Daten abzuziehen. Eine wirksame Überwachung kann dabei Anomalien identifizieren, die auf Missbrauch, Malware-Aktivität oder Fehlbedienungen hindeuten, und kann die Integrität sowie Vertraulichkeit schützenswerter Informationen erhöhen. Mögliche Varianten der Umsetzung können auf datei- und inhaltsbasierter DLP-Analyse, Netzwerk-DLP über definierte inspection points, Monitoring von Cloud-Workloads mittels API-gestützter DLP-Funktionen oder Endpoint-DLP basierend auf Richtlinien für Kopieren, Drucken oder Übertragungen über Wechselmedien beruhen.

Control: DET.4.6 - Anomale Nutzung der Anwendung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: e0194ca3-39a2-4c07-9e7e-c4aad16597c6
Aufwand: 3
Sicherheitsstufe: erhöht

Untergeordnete Controls

- DET.4.6.1 Verhaltensanalyse von Zugangskonten

Statement

Detektion für Anwendungen KANN die Nutzung der Anwendung auf Anomalien überwachen.

Guidance

Beispiele sind massenhafte Downloads von Dateiservern oder Cloud-Diensten, Datenbankabfragen die eine ungewöhnlich hohe Menge von Daten oder Einträgen, die unerreichbar sein sollen, zurückliefern, oder automatische E-Mail-Weiterleitungen an externe Domains.

Control: DET.4.6.1 - Verhaltensanalyse von Zugangskonten

Tags: "Advanced Persistent Threats (APT)" "Command & Control" "Data Exfiltration" "Insider Threat" "Living off the land"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.4 Überwachung von Aktivitäten

Übergeordnetes Control:

DET.4.6 Anomale Nutzung der Anwendung

UUID: cd3e1fde-3095-4518-b906-ca18824839b8

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Detektion für Verzeichnisdienste KANN das Verhalten von Zugangskonten überwachen.

Guidance

User and Entity Behaviour Analytics (UEBA) nutzt moderne Verfahren einschließlich KI, um Anomalien im Verhalten von Zugangskonten oder Systemen zu erkennen, z.B. Anmeldungen zu ungewöhnlichen Zeiten, von ungewöhnlichen Orten, durch Verwendung veralteter Authentifizierungsverfahren wie NTLMv1 oder die Ausführung ungewöhnlicher Anwendungen. Ungewöhnliches Verhalten kann Anzeichen für netzbasierte Angriffe oder Innentäter sein. Allerdings gilt es hierbei auch rechtliche Vorgaben zum Datenschutz und betriebliche Mitbestimmungsrechte zu beachten. Ein sinnvoller Maßstab für die Ausgestaltung von Umfang und Detailltiefe der Überwachung können die Geschäfts- und Sicherheitsziele sein. Sinnvoll ist es hierbei begleitende Maßnahmen zur Compliance einzuführen, beispielsweise das manuelle Analysen nur unter bestimmten Voraussetzungen oder Beteiligungen vorgenommen werden.

Control: DET.4.7 - Auslaufen von Domains

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: 631793e6-cc3f-49cf-a6aa-f7672688f007
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für Webserver KANN das Auslaufen von Domains überwachen.

Guidance

Wenn Registrierungsfristen und Verlängerungszeiträume nicht im Blick behalten werden, könnte eine Domain aus Versehen verfallen und damit einhergehend Erreichbarkeitsprobleme, Vertrauensverluste oder gar Sicherheitslücken entstehen. Als Beispiele können Domains dienen, die für Webauftritte, E-Mail-Systeme oder API-Endpunkte genutzt werden. Ebenso kann es sich um Subdomains handeln, die für interne Tools, Testumgebungen oder automatisierte Monitoringdienste registriert sind. Auch Domains, die nur der Weiterleitung auf Hauptpräsenzen dienen oder die für Zertifikatsverwaltung (z. B. ACME-Challenges) verwendet werden, können unter diese Überwachung fallen. Jede dieser Anwendungsfälle kann potenziell betroffen sein, wenn die Registrierung unbemerkt abläuft. Hilfreich ist hierfür ein zentrales Inventar aller genutzten Domains in dem Registrierungsdaten (Ablaufdatum, Registrar, Kontaktemail) erfasst werden. Automatisierte Scripts oder Aufgabentickets können eingerichtet werden, die in festgelegten Abständen (z. B. 60, 30 und 7 Tage vor Ablauf) eine Benachrichtigung auslösen. Auch Monitoring-Plattformen mit DNS-Plugins können verwendet werden, um Fristen zu prüfen und Erinnerungen zu generieren. Zusätzlich kann eine Prozessbeschreibung definiert werden, in der Verantwortlichkeiten und Eskalationswege bei nahendem Domainablauf festgehalten sind, um schnelle Entscheidungen und Verlängerungen zu ermöglichen.

Control: DET.4.8 - Ausstellung neuer HTTPS-Zertifikate

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: 25f3ecb6-15f9-483f-a195-a976e36e89b8
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für Webserver KANN die rechtzeitige Ausstellung neuer HTTPS-Zertifikate für Server, die im Internet erreichbar sind, überwachen.

Guidance

Dies kann mittels Certificate Transparency teilautomatisiert werden. Mit "rechtzeitig" ist hier vor Ablauf des Zertifikats gemeint.

Control: DET.4.9 - Manipulations-Checkup

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: 77b66ddb-2066-47f6-b6f7-b5b447287b59
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für IT-Systeme KANN das System auf Manipulationsversuche {{ insert: param, det.4.9-prm1 }} überprüfen.

Guidance

Falls Systeme einem erhöhten Manipulationsrisiko ausgesetzt sind (z.B. wegen öffentlicher Aufstellung), die Vertraulichkeit oder Integrität des Systems oder damit verbundener Daten oder Netze jedoch nicht vernachlässigenswert ist, so ist eine regelmäßige Überprüfung auf Manipulationen empfehlenswert. Hierfür können Gerätesiegel verwendet werden. Maßnahmen bei Feststellung einer Manipulation können z.B. das Zurücksetzen auf den Werkszustand oder die Aussonderung sein.

Control: DET.4.10 - Host-basierte Köder

Tags: "Zero Trust" "Advanced Persistent Threats (APT)" "Honeypot"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: dcdb44ac-280a-424b-bd4f-9264137d6895
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für IT-Systeme KANN Host-basierte Köder installieren.

Guidance

Köder sind Anwendungen, Dateien oder Datensätze auf dem IT-System, welche die Aufmerksamkeit von Angreifern auf sich ziehen, um diese zu entdecken, nachzuverfolgen oder von echten Zielen abzulenken. Sie werden auch als Canaries oder Tripwire bezeichnet. Beispielsweise kann das Sicherheitsteam eine gefälschte, aber verlockende Datei (z. B. „IBAN-Kontodaten.xlsx“) im System platzieren und eine Überwachung einrichten, die sie benachrichtigt, wenn die Datei berührt wird - da legitime Benutzer nicht darauf zugreifen können, signalisiert jede Interaktion potenziell unbefugte Aktivitäten. Ein weiteres Beispiel ist eine Datei „unattended.xml“, da sie für Angreifer nützliche Anmeldedaten für automatische Installationen enthalten könnte. Indem Sie eine gefälschte Version mit harmlosen Daten erstellen und den Zugriff auf die Datei oder Anmeldeversuche mit diesen Zugangsdaten überwachen, erhalten Sie eine frühzeitige Warnung, wenn jemand Ihr System auf der Suche nach einfachen Möglichkeiten zur Erlangung von Administratorrechten durchforstet, so dass Sie reagieren können, bevor es zu einem schwerwiegenden Verstoß kommt. Allerdings kann es hierbei zu falsch-positiv Vorfallsmeldungen kommen, insbesondere wenn die Köder dort platziert werden wo sie für legitime Nutzende leicht zugänglich sind.

Links

related: DET.4.11.2 Netzwerk-Honeypots

Control: DET.4.11 - Anomalien in Netzen und am Perimeter

Tags: "Command & Control" "Lateral Movement" "Data Exfiltration"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.4 Überwachung von Aktivitäten

UUID: e6cf2c48-c49f-4c10-9cca-252d903b0979

Aufwand: 5

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen
- DET.4.11.2 Netzwerk-Honeypots
- DET.4.11.3 Netzverkehrsfluss

Statement

Detektion für Netze SOLLTE den Netzwerkverkehr auf Anomalien überwachen.

Guidance

Beispiele sind ausgehende Netzverbindungen zu als böartig bekannten oder gänzlich unbekannten DNS-Domains oder IP-Adressen, Anzeichen für DNS-Tunneling (ungewöhnlich lange Subdomains oder Spitzenwerte für TXT-Mengen), ungewöhnlich hohes Datenvolumen zu Cloud-Speicherlösungen, sowie unautorisierte Portscans oder Brute Force Angriffe auf Fernwartungsschnittstellen wie RDP oder SSH sein. Hierdurch können Verbindungen zu Angreiferservern (C2 Beacons), die Ausbreitung von Angriffen über das Netz, oder Datenabflüsse erkannt werden.

Control: DET.4.11.1 - Authentifizierungsversuche an externen Schnittstellen

Tags: "Zero Trust" "Advanced Persistent Threats (APT)" "Command & Control"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
Übergeordnetes Control:
DET.4.11 Anomalien in Netzen und am Perimeter
UUID: 1fc84b56-0931-439d-9b5a-4642926e0d04
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für Externe Netzanschlüsse KANN Authentifizierungsversuche auf unauthorisierte Verbindungen {{ insert: param, det.4.11.1-prm1 }} überprüfen.

Guidance

Ohne solche Überprüfungen könnte ein Angreifer unbemerkt wiederholt Zugangsdaten erraten (Brute-Force- oder Wörterbuchangriffe) oder unautorisierte Geräte an Schnittstellen wie VPN-Gateways, Firewalls oder externen Modems anbinden. Auch ein unbemerktes Einschleusen von Schadsoftware über offene Remote-Desktop- oder SSH-Verbindungen könnte langfristig unentdeckt bleiben. Eine kontinuierliche Auswertung von Anmeldeversuchen kann dagegen Auffälligkeiten wie ungewöhnlich viele Fehlversuche, Anmeldungen aus geografisch atypischen Regionen oder Verbindungsaufbau außerhalb üblicher Betriebszeiten aufzeigen und so eine wirksame Schutzwirkung entfalten. Als Frist können Intervalle wie "täglich", "wöchentlich" oder "in Echtzeit" je nach Kritikalität des Anschlusses angemessen sein. Verbindungen sind hier unautorisiert, wenn Anzeichen vorliegen, dass sie von unautorisierten Personen oder von unautorisierten Systemen stammen. Die Überprüfung kann manuell oder durch automatische Analyse von Logdateien erfolgen. Empfehlenswert ist eine kontinuierliche Überwachung. Dabei kann z.B. nach ungewöhnlichen vielen fehlgeschlagenen Anmeldungen, veralteten Berechtigungen, Einwahlen von Adminaccounts, ungewöhnlichen Einwahlorten/IP-Adressbereichen/User Agents oder Uhrzeiten gesucht werden. Als Reaktion kommen z.B. Sperren betroffener Adressbereiche, die Abschaltung angegriffener Schnittstellen oder stärkere

Authentifizierungsmechanismen wie Mehr-Faktor-Authentifizierung in Betracht.

Control: DET.4.11.2 - Netzwerk-Honeypots

Tags: "Zero Trust" "Advanced Persistent Threats (APT)" "Honeypot"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
Übergeordnetes Control:
DET.4.11 Anomalien in Netzen und am Perimeter
UUID: 7715c6ec-8cf9-446c-807a-783d61ebd539
Aufwand: 3
Sicherheitsstufe: erhöht

Statement

Detektion für Netze KANN Netzwerk-Honeypots installieren.

Guidance

Honeypots sind Systeme, die das Verhalten eines Betriebsservers simulieren, um bei netzbasierten Angriffen Informationen über den Angriff zu erhalten. Geeignet sind z.B. vermeintliche Rechnungsbearbeitungssysteme oder Datenbank-Server. Alarmierungsereignisse können hier z.B. Login-Versuche oder unerwartete API-Abfragen sein. Allerdings kann es hierbei zu falsch-positiv Vorfallsmeldungen kommen, insbesondere wenn die Honeypots dort platziert werden, wo sie für legitime Nutzende leicht zugänglich sind, oder wenn legitime Netzwerkskans bereits eine Alarmierung auslösen. Daher ist es sinnvoll, die konkreten Einsatzgegebenheiten in einer Risikoanalyse zu betrachten und den möglichen Detektionsmehrwert mit den potenziellen Risiken solcher falsch-positiv Meldungen abzuwägen.

Links

related: DET.4.10 Host-basierte Köder

Control: DET.4.11.3 - Netzverkehrsfluss

Tag: "Lateral Movement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
Übergeordnetes Control:
DET.4.11 Anomalien in Netzen und am Perimeter
UUID: 80109af2-9ed7-4aca-807e-aae712dc8e18
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für Netze KANN auf kritische Netzverkehrsflüsse anhand von {{ insert: param, det.4.11.3-prm1 }} überwachen.

Guidance

Ein Netzverkehrsfluss ist eine Aufzeichnung von Verkehrsdaten einer Netzwerkverbindung (wie Quell-/Ziel-IP, Ports, Protokoll, übertragene Datenmenge und Zeitdauer). Die Aufzeichnung des gesamten Verkehrs (Packet Capture) des vollständigen Inhalts aller Datenpakete ist hierzu nicht erforderlich, sodass die zu untersuchende Datenmenge überschaubar bleibt. Allerdings sind hier Compliance-Anforderungen zur Datenspeicherung relevant. Für datenschutzrechtliche Fragen zu Verkehrsdaten kann der BfDI Leitfaden Speicherung Verkehrsdaten als Grundlage genutzt werden. Beispiele für Kriterien sind die Aufzeichnung an wichtigen Netzgrenzen (DMS-Internet), in kritischen Netzen, zwischen Serversystemen oder bei Leistungsproblemen.

Control: DET.4.12 - Monitoring der Netzverfügbarkeit

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: 3757d23d-e17e-4bae-857e-c045505d579a
Aufwand: 5
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DET.4.12.1 Auslastung des Netzes

Statement

Detektion für Netze SOLLTE die Verfügbarkeit des Netzes anhand von {{ insert: param, det.4.12-prm1 }} überwachen.

Guidance

Die Verfügbarkeit von Netzen, insbesondere des Internetanschlusses, sowie im Kern- und Verteilernetz, ist von zentraler Bedeutung für die Verfügbarkeit von IT-Infrastrukturen. Ein Monitoring ermöglicht es dem Betriebspersonal, bei Netzproblemen reagieren zu können, bevor Beschwerden von Nutzenden aufkommen. Kann durch Hello-Pakete von Netzkomponenten oder die Erreichbarkeit von Diensten über das Netz umgesetzt werden.

Control: DET.4.12.1 - Auslastung des Netzes

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.4 Überwachung von Aktivitäten

Übergeordnetes Control:

DET.4.12 Monitoring der Netzverfügbarkeit

UUID: c17dd877-0922-4ca8-a38b-1d2f9ae04f0d

Aufwand: 4

Sicherheitsstufe: erhöht

Statement

Detektion für Netze KANN die Auslastung des Netzes anhand von {{ insert: param, det.4.12.1-prm1 }} überwachen.

Guidance

Die Überwachung der Netzauslastung ermöglicht eine schnelle Reaktion bei Verfügbarkeitsproblemen. Wichtige Indikatoren sind Auslastung der verfügbaren Bandbreite, Netzlatenz und Packverluste. Unerwartet hoher Datenverkehr kann auch ein Indiz für einen unautorisierten Zugriff auf große Datenmengen sein. Zur Umsetzung ist es zweckmäßig zunächst Normwerte zu ermitteln (Baselining).

Control: DET.4.13 - Verfügbarkeit des Hostsystems

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: b186a9e9-cce6-4bb5-8e70-ac17499c71d8
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Detektion für Hostsysteme SOLLTE die Netzerreichbarkeit anhand von {{ insert: param, det.4.13-prm1 }} überwachen.

Guidance

Schwellwerte (engl. thresholds) sind hier Grenzwerte, die als Maßstab für die normale oder erwartete Netzerreichbarkeit des Hostsystems dienen. Diese Schwellwerte könnten beispielsweise eine bestimmte Anzahl an Fehlversuchen zur Erreichbarkeit in einem definierten Zeitfenster oder eine überdurchschnittlich hohe Anzahl an Verbindungsanfragen sein, die auf ungewöhnliche Netzwerkaktivität hindeuten. Ein Server könnte beispielsweise aufgrund eines Denial-of-Service-Angriffs (DoS) nicht mehr erreichbar sein, wodurch Dienste für Nutzende ausfallen. Ebenso könnte eine unerwartete Nichterreichbarkeit auf einen Hardwaredefekt, einen Konfigurationsfehler oder einen internen Angriff hindeuten, bei dem der Server vom Netz getrennt wurde, um Spuren zu verwischen. Die Überwachung anhand von Schwellwerten kann der Institution dabei helfen, solche Vorfälle frühzeitig zu erkennen und zu reagieren, bevor sie größeren Schaden anrichten. Die Überwachung kann über ein internes Monitoring-System umgesetzt werden, das kontinuierlich die Erreichbarkeit der Server mittels sogenannter Health-Checks oder Probes prüft. Dabei kann beispielsweise ein automatisches Ping-Verfahren eingesetzt werden, das in regelmäßigen Abständen die Antwortzeit des Servers misst. Die festgelegten Schwellwerte könnten zum Beispiel die maximal erlaubte Anzahl an aufeinanderfolgenden fehlgeschlagenen Ping-Antworten oder die durchschnittliche Antwortzeit sein.

Control: DET.4.14 - Verfügbarkeit der Anwendung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: 170aaef0-d7a1-49be-a219-7ef13c8be738
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Detektion für Anwendungen SOLLTE die Netzerreichbarkeit anhand von {{ insert: param, det.4.14-prm1 }} überwachen.

Guidance

Dabei wird die Erreichbarkeit des Dienstes der Anwendung selbst, z.B. auf den bereitstellenden Servern, nicht nur die Erreichbarkeit des Systems überwacht.

Control: DET.4.15 - Ressourcenauslastung von Hostsystemen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: 7cfa26e7-7fe5-4a6a-999b-489c9785821e
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Detektion für Hostsysteme SOLLTE die Ressourcenauslastung anhand von {{ insert: param, det.4.15-prm1 }} überwachen.

Guidance

Hierzu zählt z.B. die Auslastung der CPU, des Arbeitsspeichers, des Festspeichers. Dazu ist es sinnvoll vorab Schwellwerte zu ermitteln (KPI Baselining). Mögliche Reaktionsmaßnahmen bei zu hoher Auslastung sind z.B. die Lastverteilung auf mehrere Host-Rechner oder die Beschränkung der Ressourcennutzung pro Client.

Control: DET.4.16 - Ressourcenauslastung der Server-Dienste

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: f094dca7-3bfb-477b-8a50-da1587033e4d
Aufwand: 3
Sicherheitsstufe: erhöht

Statement

Detektion für Anwendungen KANN die Ressourcenauslastung der für die Anwendung verwendeten Server-Dienste anhand von {{ insert: param, det.4.16-prm1 }} überwachen.

Guidance

Hierzu zählt z.B. die Auslastung der CPU, des Arbeitsspeichers, des Festspeichers und Anzahl der verbundenen Clients. Dazu ist es sinnvoll vorab Schwellwerte zu ermitteln (KPI Baselineing). Mögliche Reaktionsmaßnahmen bei zu hoher Auslastung sind z.B. die Lastverteilung auf mehrere Host-Rechner oder die Beschränkung der Ressourcennutzung pro Client.

Control: DET.4.17 - Anwendungsbasiertes Kapazitätsmanagement

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: 93561982-927d-461c-a0eb-c9aec0b1159d
Aufwand: 3
Sicherheitsstufe: erhöht

Statement

Detektion für Anwendungen KANN die Ressourcenauslastung systemübergreifend anhand von {{ insert: param, det.4.17-prm1 }} überwachen.

Guidance

Hierbei kann nicht nur die aktuelle Auslastung einzelner Server, sondern die Auslastung der Anwendung insgesamt, auch über einen längeren Zeitverlauf inklusive Lastspitzen und Durchschnittswerten, betrachtet werden.

Control: DET.4.18 - Öffentliche Blocklisten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: e180774d-4880-4ef4-bc08-5c06e034dbc9
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für E-Mail KANN öffentliche Blocklisten auf Einträge für eigene E-Mail-Server { { insert: param, det.4.18-prm1 } } überprüfen.

Guidance

Die Überprüfung von E-Mail-Blocklisteneinträgen ist entscheidend, um sicherzustellen, dass Nachrichten zuverlässig zugestellt und nicht als Spam klassifiziert werden. Dazu kann zunächst mit Tools wie MXToolbox oder MultiRBL geprüft werden, ob und auf welchen Listen der Server geführt wird, um anschließend die genauen Ursachen zu ermitteln – häufig spielen kompromittierte Konten, unzureichende Authentifizierungsmethoden oder veraltete E-Mail-Listen eine Rolle. Nach der Identifikation können Admins die grundlegenden Probleme beheben, beispielsweise durch Implementierung von SPF-, DKIM- und DMARC-Protokollen, Bereinigung von E-Mail-Listen oder Beseitigung technischer Schwachstellen, bevor bei den jeweiligen Blocklistenbetreibern ein Antrag auf Entfernung gestellt werden kann, wobei in der Regel Nachweise für die durchgeführten Verbesserungen erforderlich sind; zur langfristigen Prävention kann eine regelmäßige Überwachung der Senderreputation, sowie die Einhaltung bewährter E-Mail-Praktiken beitragen, oder die Nutzung eines seriösen E-Mail-Dienstleisters in Betracht gezogen werden.

Control: DET.4.19 - Unautorisierte Sendeanlagen

Tag: "Rogue Access Point"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.4 Überwachung von Aktivitäten
UUID: d85d0d64-bc5c-4a11-91d8-7c567abd5b21
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für Räume KANN diesen nach unautorisierten Sendeanlagen durch {{ insert: param, det.4.19-prm1 }} überwachen.

Guidance

Bleiben unautorisierte Sendeanlagen unbemerkt, so könnten hierüber Abhörversuche stattfinden oder Störungen legitimer Sender und Empfänger auftreten. Bedenklich sind beispielsweise versteckte Wanzen in Büromöbeln, manipulierte Peripheriegeräte mit eingebauten Sendern, ohne Erlaubnis mitgebrachte Access Points, modifizierte Smartphones mit verdeckten Fernzugriffsfunktionen oder getarnte IoT-Geräte mit Netzwerkverbindung, die sensible Informationen abgreifen und nach außen übertragen könnten. Zum Aufspüren können Wireless Intrusion Detection Systems (WIDS) genutzt werden, welche Sendeanlagen auffinden und unbekannte Sender melden. Um unautorisierte Sender effektiv zu erkennen sind auch begleitende Maßnahmen sinnvoll: Die Implementierung von Zugangsbeschränkungen und Mitnahmeverboten für nicht geprüfte elektronische Geräte; die Schulung des Personals zur Erkennung verdächtiger Objekte; sowie die Dokumentation aller autorisierten Geräte in einem Inventar, um unbekannte Signalquellen schnell identifizieren zu können.

Control: DET.5.1 - Zeitnahes Schwachstellenmanagement

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
UUID: 43918e89-a15c-490e-9cb5-94444c7e9299
Aufwand: 4
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DET.5.1.1 Risikobasierte Priorisierung

Statement

Detektion SOLLTE Verfahren und Regelungen zur Erkennung und Behandlung von Schwachstellen verankern.

Guidance

Relevant können hierbei verschiedene Arten von Schwachstellen sein (z.B. Physisch und im Netz, Orte, Adressbereiche, Anwendungen und Ports). Zur Erkennung können Schwachstellenscans, Pentests und ein Abgleich der eigenen Infrastruktur mit öffentlichen Schwachstellendatenbanken genutzt werden. Zur Beurteilung der Kritikalität können Scoring-Systeme wie CVSS oder Berichte der betroffenen Hersteller oder Dienstleister herangezogen werden. Zur Behandlung können z.B. Sicherheitspatches, die Deaktivierung betroffener (Teil-)Funktionen oder Komponenten oder die Isolierung betroffenen Systeme oder Anwendungen in Frage kommen. Für Details siehe ISO/IEC 30111.

Control: DET.5.1.1 - Risikobasierte Priorisierung

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
Übergeordnetes Control:
DET.5.1 Zeitnahes Schwachstellenmanagement
UUID: a9af82d7-44b8-412c-b8a0-becbda9b1da9
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion KANN erkannte Schwachstellen anhand von {{ insert: param, det.5.1.1-prm1 }} innerhalb {{ insert: param, det.5.1.1-prm2 }} überprüfen.

Guidance

Bei einer risikobasierten Priorisierung wird nicht nur die Ausnutzbarkeit der Schwachstelle im Allgemeinen, z.B. durch einen CVS-Score, zur Priorisierung herangezogen, sondern die Beurteilung erfolgt durch eine Kombination solcher generellen Informationen mit dem individuellen Risikoprofil der betroffenen Assets. Dies ermöglicht es, Schwachstellen deutlich passgenauer zu beurteilen und die wirklich kritischen Schwachstellen zuerst zu patchen oder mitigieren. Hierzu können CVSS-Score, Informationen aus der Threat Intelligence und aus der Risikobewertung von Geschäftsprozessen kombiniert werden. Hierbei können auch automatisierte Verfahren angewendet werden, z.B. Multiplikation von Kennzahlen zur Risikobewertung und von CVSS in Kombination mit Schwellwerten. Ergebnisdokument kann z.B. eine Risikomatrix, oder eine eigene CVE-Bewertungsrubrik sein.

Control: DET.5.2 - Schwachstellenregister

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
UUID: f7550d0a-cf51-4586-a4e8-0c3831a10a79
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE Schwachstellen bei Entdeckung inklusive betroffener Komponenten, Kritikalität und Status dokumentieren.

Guidance

Da die Aktualität des Schwachstellenregisters von großer Bedeutung ist, ist die manuelle Pflege von Schwachstellen in einem Dokument nicht empfehlenswert. Stattdessen können automatisiert gepflegte Datenbanken oder spezielle Schwachstellenmanagement-Tools genutzt werden. Das Schwachstellenregister kann auch als verteiltes Register gepflegt werden (z.B. in Schwachstellenscannern, Patchmanagement-Servern, etc.), allerdings ist hierbei eine einheitliche Beurteilung und Priorisierung aufwändiger.

Control: DET.5.3 - Schwachstellenscans

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
UUID: 7f84ed26-e585-402f-bc0e-40904319cfc8
Aufwand: 5
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DET.5.3.1 Autorisierung kritischer Scans
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.3.3 Historische Analyse

Statement

Detektion SOLLTE eine Vorgehensweise zum Scan nach Schwachstellen einschließen, die deren Auswertung und Behandlung verankern.

Guidance

Über das Netz erreichbare Schwachstellen bergen das Risiko, dass hierüber Angriffe in IT-Systeme und Anwendungen eindringen, Daten auslesen oder sich über das Netz verbreiten. Schwachstellenscans finden solche Lücken, indem sie Anfragen zu bekannten Schwachstellen im Netz stellen und die Antworten auswerten. Regelmäßige Scans tragen dazu bei, dass Sicherheitslücken entdeckt werden, bevor sie ausgenutzt werden.

Control: DET.5.3.1 - Autorisierung kritischer Scans

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.5 Management von Schwachstellen

Übergeordnetes Control:

DET.5.3 Schwachstellenscans

UUID: d19ef635-5438-4b4e-b75b-479764f39069

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE kritische Scans durch {{ insert: param, det.5.3.1-prm1 }} autorisieren.

Guidance

Schwachstellenscans könnten aufgrund ihres Umfangs oder der breiten Abdeckung ihrer Aktivitäten selbst Fehlerzustände provozieren oder Schwachstellen auslösen. Wenn Scans besondere Berechtigungen benötigen - z.B. lokale Administrationsrechte oder Zugriff auf ein abgeschottetes Netz sensibler, betriebskritischer Systeme, so kann eine Autorisierung solcher Scans, vor der eine Abwägung der damit verbundenen Risiken vorgenommen wird, angezeigt sein.

Control: DET.5.3.2 - Korrelation komplexer Angriffswege

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
Übergeordnetes Control:
DET.5.3 Schwachstellenscans
UUID: 1221903d-e402-49b0-a7ac-763a11683a4b
Aufwand: 3
Sicherheitsstufe: erhöht

Statement

Detektion KANN Schwachstellen anhand eines Abgleichs mehrerer Scans miteinander überprüfen.

Guidance

Fortschrittliche Angreifer könnten mehrere, scheinbar unkritische Schwachstellen nacheinander ausnutzen, die erst in Kombination einen gefährlichen Angriff, etwa die Ausführung von Code aus der Ferne, erlauben. Um solche komplexen Angriffe zu erkennen, können Messergebnisse verschiedener Schwachstellenscanner miteinander abgeglichen werden. Komplexe Angriffswege können mit Methoden wie Attack Trees erkannt und bewertet werden.

Control: DET.5.3.3 - Historische Analyse

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
Übergeordnetes Control:
DET.5.3 Schwachstellenscans
UUID: f64131d9-e0cd-4c01-937a-ea93d7a92371
Aufwand: 3
Sicherheitsstufe: erhöht

Statement

Detektion KANN Schwachstellen in öffentlich erreichbaren Systemen oder Anwendungen anhand bekannter Anzeichen im Audit Log testen.

Guidance

Die historische Analyse von Logdateien ermöglicht es, vergangene Systemaktivitäten systematisch zu untersuchen, um potenzielle Sicherheitsvorfälle zu identifizieren, die zum Zeitpunkt ihres Auftretens unbemerkt blieben. Nach der Entdeckung einer Schwachstelle kann so rückwirkend festgestellt werden, ob und wie diese bereits ausgenutzt wurde. Die Umsetzung kann durch Etablierung eines zentralisierten Log-Managements mit langer Aufbewahrungsdauer, Implementierung automatisierter Such- und Korrelationsalgorithmen zur Erkennung bekannter Angriffsmuster und Anomalien in den Logdaten, sowie durch forensische Analyse der Zeitstempel, Quell-IPs, Benutzeraktivitäten und Zugriffsversuche erfolgen. Bei der Feststellung von Schwachstellen in öffentlich zugänglichen Systemen ist es sinnvoll die Audit-Logs gezielt nach Indikatoren zu durchsuchen, die auf entsprechende Angriffsmuster hindeuten - darunter ungewöhnliche Zugriffszeiten, auffällige Authentifizierungsversuche, verdächtige Datenbankabfragen oder charakteristische Command-Injection-Versuche, wodurch potenzielle Kompromittierungen retrospektiv aufgedeckt und in ihrem vollen Umfang bewertet werden können.

Control: DET.5.4 - Regelmäßige Penetrationstests

Tags: "Pentest" "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
UUID: 622f98fa-a211-4c1e-b655-5e9dd6c0d507
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für IT-Systeme KANN die tatsächliche Abwehrfähigkeit nach {{ insert: param, det.5.4-prm1 }} {{ insert: param, det.5.4-prm2 }} überprüfen.

Guidance

Ein Penetrationstest, oft auch als Pentest bezeichnet, ist eine von Sicherheitsexperten simulierte Cyberattacke, um Schwachstellen und Sicherheitslücken aufzudecken. Ziel ist es, komplexe Schwachstellen in konkreten Informationsumgebungen aufzuspüren, bevor sie von echten Angreifern ausgenutzt werden könnten. Dabei werden verschiedene Methoden und Techniken eingesetzt, die auch von Angreifern verwendet werden könnten, z.B. Informationssammlung, Scan und Ausnutzen von Schwachstellen, seitliches Ausbreiten über das Netz, sowie Versuche, durch Täuschung und Manipulation von Personen an Informationen oder Zugriff zu gelangen. Anerkannte Vorgehensweisen, die für Penetrationstests angewendet werden können, sind z.B. der BSI Praxis-Leitfaden für IS-Penetrationstests, OSSTMM, NIST SP 800-115, PTES (Penetration Testing Execution Standard), OWASP für Webanwendungen oder der Leitfaden für Penetrationstests von Large-Language-Modellen des Expertenkreises KI-Sicherheit. Pentests können von externen Dienstleistern oder internem Personal vorgenommen werden. Entscheidend für ein gutes Ergebnis ist hierbei neben einer standardisierten, strukturierten Vorgehensweise die Qualifikation der ausführenden Personen, da Penetrationstests die Ausforschung komplexer Angriffsmöglichkeiten erfordern, die weit über den isolierten Einsatz einzelner Werkzeuge hinausgehen können. Pentesting von Außen enthält sowohl die Suche nach angreifbaren Schwachstellen aus dem Internet, als auch die vorhergehende Recherche, um angreifbare Informationen aufzuspüren (Open Source Intelligence). Zur konsequenten Überprüfung gehört auch, dass deren gefundene Schwachstellen im Rahmen des Schwachstellenmanagements zeitnah behandelt

werden. Zweckmäßig ist es daher, gefundene Schwachstellen bestimmten zuständigen Personen oder Rollen zur Behebung zuzuweisen und diese innerhalb der Fristen des Schwachstellenmanagements zu schließen.

Links

related: TEST.3.1.10 Penetrationstest bei Änderungen

Control: DET.5.5 - Red Teaming

Tags: "Pentest" "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
UUID: ea34243d-adc3-4208-ab4e-25247aa8c009
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion für IT-Systeme KANN die tatsächliche Abwehrfähigkeit {{ insert: param, det.5.5-prm1 }} durch unabhängig agierende Sicherheitsexperten überprüfen.

Guidance

Red Teaming ist ein strukturierter, realitätsnaher Sicherheitstest, bei dem ein sogenanntes Red Team – also ein unabhängiges, offensiv agierendes Expertenteam – versucht, unter realen Bedingungen in IT-Systeme, Netzwerke oder Anwendungen einzudringen, um Schwachstellen und Reaktionslücken aufzudecken. Dadurch wird nicht nur die technische Abwehr getestet, sondern auch organisatorische und menschliche Faktoren, etwa die Wirksamkeit von Incident-Response-Prozessen, Alarmierungsketten oder die Reaktion des Security Operations Center (SOC). Solche regelmäßigen Überprüfungen durch unabhängige Red Teams ermöglichen einen objektiven und unvoreingenommenen Blick auf die aktuellen Stärken und Schwächen der Sicherheitsmaßnahmen, wodurch Schwachstellen frühzeitig erkannt werden können. Unabhängig ist ein Red Team dabei, wenn es organisatorisch und personell getrennt vom Betriebspersonal und dessen Weisungshierarchie (Blue Team) agiert, sodass keine Interessenkonflikte die objektive Bewertung gefährden.

Control: DET.5.6 - Threat Hunting

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
UUID: ff549367-0992-4b06-a2c0-246915632cb1
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Detektion KANN den Informationsverbund durch Sicherheitsexperten auf Anzeichen für Angriffe {{ insert: param, det.5.6-prm1 }} überprüfen.

Guidance

Threat Hunting bezeichnet eine proaktive Suche nach Anzeichen für Sicherheitsvorfälle durch Analyseexperten, da fortschrittliche Angriffe durch automatisierte Systeme zur Angriffserkennung häufig nicht detektiert werden können. Im Unterschied zum Penetrationstest steht dabei nicht das Aufsuchen von Schwachstellen, sondern das Finden bereits erfolgreicher Angriffe oder Bedrohungen in den eigenen Systemen und Anwendungen im Vordergrund.

Control: DET.5.7 - Analyse verdeckter Kanäle

Tags: "Pentest" "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
UUID: 8f64e735-9870-4a8d-8b7b-220b93baddba
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion KANN den Informationsverbund auf verdeckte Kommunikationskanäle {{ insert: param, det.5.7-prm1 }} überprüfen.

Guidance

Ein verdeckter Kanal (Covert Channel) ist ein heimlicher Kommunikationskanal, mit dem Angreifer legitime Verbindungen ausnutzen, um verdeckt Daten zu übertragen. Viele dieser verdeckten Kanäle können durch darauf spezialisierte Erkennungswerkzeuge (sog. Warden) erkannt werden. Aufgrund der Vielzahl denkbarer verdeckter Kommunikationswege können solche Kanäle jedoch kaum vollständig verhindert werden. Ergänzende Maßnahmen wie Traffic Normalization können sie jedoch ausbremsen oder unerkant eliminieren. Relevant sind dabei sowohl Speicherkanäle (Storage Channel) als auch Zeitkanäle (Timing Channel).

Links

related: DET.5.6 Threat Hunting

Control: DET.5.8 - Bedrohungsanalyse

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
UUID: 2134a13a-50a6-44b7-8df1-3ce041ef376a
Aufwand: 5
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DET.5.8.1 Auswertung öffentlicher Quellen

Statement

Detektion SOLLTE verfügbare Informationen zu Bedrohungen, die für den Informationsverbund relevant sind, {{ insert: param, det.5.8-prm1 }} überprüfen.

Guidance

Bedrohungsaufklärung (Threat Intelligence) dient dem Sammeln und Analysieren von Informationen über bestehende oder aufkommende Bedrohungen, um fundierte Maßnahmen zur Verhinderung von Schäden zu ermöglichen und die Auswirkungen solcher Bedrohungen zu reduzieren. Sie kann in drei Schichten unterteilt werden: strategische Bedrohungsaufklärung (Austausch von Informationen auf hoher Ebene über die sich verändernde Bedrohungslandschaft), taktische Bedrohungsaufklärung (Informationen über Angreifermethoden, beteiligte Werkzeuge und Technologien) und operative Bedrohungsaufklärung (Details zu spezifischen Angriffen, einschließlich technischer Indikatoren). Die gesammelten Bedrohungsinformationen können analysiert und später genutzt werden, indem Prozesse implementiert werden können, um die aus Bedrohungsaufklärungsquellen gesammelten Informationen in die Risikomanagementprozesse einzubeziehen. Sie können als zusätzlicher Input für technische Präventiv- und Erkennungskontrollen wie Firewalls, Intrusion-Detection-Systeme oder Anti-Malware-Lösungen dienen sowie als Eingabe für die Testprozesse und -techniken der Informationssicherheit verwendet werden. Die Institution kann Bedrohungsinformationen auf gegenseitiger Basis mit anderen teilen, um die allgemeine Bedrohungsaufklärung zu verbessern. Dies kann einen kooperativen Ansatz zur Stärkung der gemeinsamen Sicherheitslage fördern.

Control: DET.5.8.1 - Auswertung öffentlicher Quellen

Tag: "Data Leak"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
Übergeordnetes Control:
DET.5.8 Bedrohungsanalyse
UUID: 42bf3e91-d270-4a79-8ae9-a22918f94ad7
Aufwand: 5
Sicherheitsstufe: erhöht

Untergeordnete Controls

- DET.5.8.1.1 Unautorisierte Publikation

Statement

Detektion KANN öffentliche Quellen auf Hinweise zu eigenen Schwachstellen anhand von {{ insert: param, det.5.8.1-prm1 }} {{ insert: param, det.5.8.1-prm2 }} überprüfen.

Guidance

Öffentliche Quellen können Hinweise zu aktuellen Schwachstellen geben oder sogar auf die Vorbereitung von Angriffen geben, beispielsweise auf die Nachahmung von Webseiten oder Marken, sowie Typosquatting. Auch Datenleaks wie API-Keys oder falsch konfigurierte Cloud-Systeme können hierüber aufgedeckt werden. Relevante öffentliche Quellen können z.B. Schwachstellendatenbanken, Fachmedien, Security Mailing Listen, Dark Web Foren, Code Repositories, Suchmaschinen oder Soziale Medien sein. Als Kriterien zur Auswahl können verschiedene Suchbegriffe oder Suchmuster herangezogen werden, z.B. Bezeichnungen verwendeter Betriebssysteme oder Komponenten, eigene DNS-Domains, E-Mailadressen, API-Schnittstellen, Markennamen. Die Umsetzung kann durch eigenes Personal oder Threat Intelligence Dienstleister erfolgen.

Control: DET.5.8.1.1 - Unautorisierte Publikation

Tag: "Data Leak"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
Übergeordnetes Control:
DET.5.8.1 Auswertung öffentlicher Quellen
UUID: c179bae3-7990-4308-b42b-53297a581402
Aufwand: 3
Sicherheitsstufe: erhöht

Statement

Detektion KANN öffentliche Quellen automatisiert auf Hinweise zur unautorisierten Veröffentlichung vertraulicher Daten überwachen.

Guidance

Unautorisierte Veröffentlichungen liegen vor, wenn vertrauliche Daten ohne Autorisierung der Institution öffentlich gemacht wurden, z.B. personenbezogene Kundendaten oder Geschäftsgeheimnisse. Typische Quellen sind Soziale Netzwerke und Code-Sharing-Plattformen. Kann z.B. durch die automatisierte Suche nach unkritischen, aber in den Quelldaten vorhandenen Begriffen umgesetzt werden.

Control: DET.5.9 - Externe Schwachstellenmeldungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
UUID: cb35b6b0-15c3-488f-8759-ad66fe4883fa
Aufwand: 4
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DET.5.9.1 Bonusprogramm

Statement

Detektion SOLLTE eine Vorgehensweise zur Entgegennahme und Behandlung von externen Schwachstellenmeldungen verankern.

Guidance

Ohne klar geregelten Umgang könnte eine Institution wertvolle Hinweise übersehen oder verzögert reagieren, was die Wahrscheinlichkeit eines Angriffs auf ungepatchte Ziele erhöht. Denkbar sind etwa Szenarien, in denen eine unbekannte Schwachstelle in einer öffentlich erreichbaren Webanwendung durch Dritte entdeckt wird und die Institution zwar kontaktiert wird, aber ohne geregelten Prozess keine Reaktion erfolgt – was einen erfolgreichen Angriff begünstigen könnte. Eine Institution kann diese Anforderung umsetzen, indem sie z. B. eine leicht auffindbare Kontaktmöglichkeit für Schwachstellenmeldungen bereitstellt – etwa eine dedizierte E-Mail-Adresse wie security@..., ein webbasiertes Formular oder die Eintragung eines „Security.txt“-Hinweises im Webauftritt (nach IETF RFC 9116). Sinnvoll kann es sein, klare Erwartungshaltungen zu kommunizieren, etwa welche Informationen eine Meldung enthalten sollte oder wie Rückmeldungen an Hinweisgeber erfolgen können. Auch ein internes Verfahren zur Kategorisierung und Priorisierung der eingehenden Hinweise kann helfen, Meldungen effizient zu bearbeiten. Eine Institution kann zudem in Erwägung ziehen, standardisierte Rückmeldungen vorzubereiten, um zeitnah bestätigen zu können, dass eine Meldung eingegangen ist, selbst wenn die inhaltliche Analyse noch aussteht. Sinnvoll ist auch ein freiwilliger Verhaltenskodex (z. B. ein „Responsible Disclosure Policy“-Hinweis) auf der eigenen Website, um Hinweisgebern einen rechtlich sicheren Rahmen für ihre Meldungen zu verdeutlichen. So entsteht ein klarer, reproduzierbarer Prozess, der externe Informationen in die eigene Sicherheits-

arbeit einbindet und das Risiko minimiert, dass relevante Hinweise verloren gehen oder ungenutzt bleiben. Für Details siehe ISO/IEC 29147.

Control: DET.5.9.1 - Bonusprogramm

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
Übergeordnetes Control:
DET.5.9 Externe Schwachstellenmeldungen
UUID: aeb9f98e-0aad-44c1-8ab1-2f7276e387de
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion KANN ein Bonusprogramm für externe Schwachstellenmeldungen verankern.

Guidance

Ein Bonusprogramm für externe Schwachstellenmeldungen (englisch häufig Bug Bounty Program) bezeichnet ein strukturiertes Verfahren, bei dem eine Institution freiwilligen Sicherheitsforschenden oder interessierten Dritten eine Belohnung für das Melden bislang unbekannter Sicherheitslücken anbietet. Dabei geht es nicht nur um finanzielle Prämien, sondern auch um nicht-monetäre Anerkennungen wie öffentliche Danksagungen oder Zertifikate. Sinn und Zweck liegt darin, externen Sicherheitsforschern oder -experten einen Anreiz zu geben, um Schwachstellen frühzeitig zu finden und zu melden. Zur Umsetzung kann eine Institution (1) transparente Regeln definieren, welche Systeme oder Anwendungen einbezogen sind (in scope) und welche nicht, (2) einen abgestuften Belohnungsrahmen anbieten, der den Schweregrad einer Schwachstelle berücksichtigt, sowie (3) die rechtlichen Rahmenbedingungen durch eine sogenannte „Safe-Harbor-Policy“ festlegen, die den Meldenden Schutz vor rechtlichen Schritten zusichert, solange diese verantwortungsvoll handeln. Ergänzend kann die Institution durch einfache organisatorische Hilfsmittel wie Ticketnummern, automatische Eingangsbestätigungen und zeitnahe Rückmeldungen Vertrauen schaffen und den weiteren Ablauf für externe Meldende nachvollziehbar gestalten.

Control: DET.5.10 - Zeitnahes Patchmanagement

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
UUID: b2c08460-0038-4f49-b459-dba756e55ae9
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.10.5 Test gemäß Änderungsmanagement

Statement

Detektion SOLLTE ein zeitnahes Patchmanagement verankern.

Guidance

Patches (Updates oder Sicherheitsaktualisierungen) sind neue Versionen, die Sicherheitslücken schließen. Je nach Aufbau der betroffenen Assets kann es bei der Aktualisierung auch erforderlich sein, Abhängigkeiten (Bibliotheken, Upstream Software) ebenfalls zu aktualisieren. Dies kann durch automatisierte Installation oder nach einem Test umgesetzt werden. Die Umsetzung kann auch den schrittweisen Rollout von Patches vorsehen, sodass bei Fehlern im Patch nicht alle Systeme gleichzeitig betroffen sind und auch komplexe Fehlerbilder durch Rückmeldungen frühzeitig erkannt werden können. Dies kann zum Beispiel nach dem One-Many-All-Prinzip oder Blue-Green-Deployment erfolgen. Zur Beurteilung der Kritikalität von Patches kann die Kritikalität der mit dem Patch verbundenen Schwachstellen, das Risikoprofil der zu patchenden Assets oder eine Korrelation komplexer Angriffswege herangezogen werden.

Control: DET.5.10.1 - Autorisierte Bezugsquellen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
Übergeordnetes Control:
DET.5.10 Zeitnahes Patchmanagement
UUID: 681afb8d-1864-4d86-9e69-3ecd9c14fbb8
Aufwand: 5
Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE Bezugsquellen für Patches autorisieren.

Guidance

Eine Quelle ist unzuverlässig, wenn zukünftig mit Verstößen gegen die Schutzziele Vertraulichkeit, Verfügbarkeit oder Integrität durch die Entität zu rechnen ist (d.h. eine Prognose der Vertrauenswürdigkeit). Dies ist insbesondere der Fall, wenn erhebliche Verstöße gegen die Schutzziele durch die Entität begangen worden sind oder Anzeichen dafür vorliegen, dass bei einer Verwendung mit solchen Verstößen zu rechnen ist.

Control: DET.5.10.2 - Automatisierte Überwachung von Systemupdates

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
Übergeordnetes Control:
DET.5.10 Zeitnahes Patchmanagement
UUID: d652bc78-8f87-42ef-a52a-7bdd9a43212f
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Detektion für IT-Systeme SOLLTE den Patchstatus durch {{ insert: param, det.5.10.2-prm1 }} überwachen.

Guidance

Der Patchstatus des Informationsverbundes kann dabei durch Kennzahlen bestimmt werden, z.B. durchschnittliche Zeit bis zum Patch (Mean Time To Patch), Prozentsatz aktuell gepatchter Assets, Anzahl offener/geschlossener Ausnahmen.

Control: DET.5.10.3 - Automatisierte Überwachung von Anwendungsupdates

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
Übergeordnetes Control:
DET.5.10 Zeitnahes Patchmanagement
UUID: 1aec3d83-b204-4999-88f5-abf1e140a925
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Detektion für Anwendungen KANN den Patchstatus durch {{ insert: param, det.5.10.3-prm1 }} überwachen.

Guidance

Eine nicht gepatchte Anwendung könnte als Einfallstor für Angreifer dienen, die bekannte Schwachstellen ausnutzen, um sich Zugang zu Systemen oder Daten zu verschaffen. Die Umsetzung kann beispielsweise auf einem Patch Management System (PMS) oder einem Vulnerability Management System (VMS) basieren. Ein Patch-Managementsystem kann beispielsweise so konfiguriert werden, dass es kontinuierlich die Versionen der installierten Software mit einer zentralen Datenbank für verfügbare Updates abgleicht. Auch die Nutzung eines Schwachstellen-Scanners, der im Netzwerk nach ungepatchten Anwendungen sucht, ist eine wirksame Maßnahme. Ein solcher Scanner könnte beispielsweise wöchentlich oder sogar täglich einen Scan durchführen und die Ergebnisse in einem Dashboard visualisieren. Wichtige prozessuale Tipps sind die Einrichtung von Benachrichtigungsworkflows, die sicherstellen, dass kritische Patch-Status-Änderungen sofort an die richtigen Personen eskaliert werden, sowie die Integration der Überwachungsergebnisse in ein zentrales Incident Response System. Dies kann helfen, die Reaktionszeit zu verkürzen, sodass die Anwendungen schnellstmöglich aktualisiert werden.

Links

related: TEST.1.1 Verfahren und Regelungen

Control: DET.5.10.4 - Integritätsprüfung von Patches

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.5 Management von Schwachstellen

Übergeordnetes Control:

DET.5.10 Zeitnahes Patchmanagement

UUID: 8eb6cebe-6ea5-4f78-a9b3-ce5a29f3bcc7

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE Patches vor der Installation auf Integrität testen.

Guidance

Wenn Patches durch Fehler bei der Übertragung oder sogar bewusst von Angreifern verändert wurden, kann dies nach der Installation zu nicht behebbaren Fehlerzuständen oder zur Verbreitung von Schadcode führen. Kann durch einen Abgleich von Prüfsummen umgesetzt werden, z.B. durch automatisierte Installationsroutinen oder einen manuellen Abgleich mit der Herstellerwebseite.

Links

related: TEST.3.1.2 Integritätstest

Control: DET.5.10.5 - Test gemäß Änderungsmanagement

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.5 Management von Schwachstellen
Übergeordnetes Control:
DET.5.10 Zeitnahes Patchmanagement
UUID: 7f1d3645-70d4-4c0d-a3c6-ecb497e3f45b
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Detektion KANN Patches entsprechend der Anforderungen der Praktik „Änderungen und Tests“ ausführen.

Guidance

Stellt sicher, dass Patches zusammen mit anderen Änderungen geprüft werden und trennt zwischen „Routine“- und „Notfall“-Änderungen.

Links

related: TEST.1.1 Verfahren und Regelungen

Control: DET.6.1 - Beurteilung von Ereignissen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.6 Vorfallserkennung
UUID: a8c7d445-54b4-40e2-aab5-b46e30549ec5
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DET.6.1.1 Automatisierte Feststellung
- DET.6.1.2 Automatische Alarmierung
- DET.6.1.3 Dokumentation von Ergebnissen

Statement

Detektion SOLLTE ein Verfahren zur Beurteilung von sicherheitsrelevanten Ereignissen anhand von {{ insert: param, det.6.1-prm1 }} verankern.

Guidance

Aus einer größeren Menge von sicherheitsrelevanten Ereignissen kann durch Filterung und Korrelation eine kleinere Menge sicherheitskritischer Ereignisse destilliert werden. Dies bedeutet, dass aus allen möglichen Sicherheitsereignissen (wie Zugriffsversuche, Systemänderungen, Netzwerkverkehr) besonders auf die potenziell gefährlicheren oder wichtigeren Ereignisse geachtet wird. Für die Definition eines sicherheitskritischen Ereignisses, siehe Glossar (Namensräume des Grundschutz++). Die Filterung erfolgt sinnvollerweise automatisiert, z.B. durch SIEM, EDR. Die Überwachung kann anhand von bestimmten Begriffen (z.B. "login from unknown device", "blocked malware", "permission changed") oder durch Anomalieerkennung erfolgen. Aufgrund der Vielzahl an möglichen Ereignissen sind detaillierte Kriterien nur schwer festzulegen. Die Kriterien können sich daher auch an einem überschaubaren Schema, etwa einer Abschätzung der Auswirkungen auf die Geschäftsprozesse und gesetzlichen Meldepflichten, orientieren. Sobald ein solches kritisches Ereignis erkannt wird, erfolgt eine Bewertung durch definierte Personen oder Rollen. Diese entscheiden, ob das Ereignis tatsächlich als Sicherheitsvorfall eingestuft werden kann.

Control: DET.6.1.1 - Automatisierte Feststellung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.6 Vorfallserkennung

Übergeordnetes Control:

DET.6.1 Beurteilung von Ereignissen

UUID: 92f55893-595b-4d3d-80eb-ef8e7b5ed1cb

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE kritische Vorfälle anhand von {{ insert: param, det.6.1.1-prm1 }} durch {{ insert: param, det.6.1.1-prm2 }} protokollieren.

Guidance

Zur Erfüllung der Anforderung ist es nicht erforderlich, dass alle denkbaren Sicherheitsvorfälle automatisch erkannt werden, sondern nur, dass diejenigen Vorfälle, die in der vorhandenen Infrastruktur automatisch feststellbar sind und mit einem hohen Risiko verbunden sind, automatisch festgestellt werden. Beispiele sind hier ein Virenbefall des zentralen Verzeichnisdienstes, unautorisierte Datenabflüsse oder das Aufbrechen eines Fensters im Sicherheitsbereich. Ressourcen meint hier z.B. Systeme, Zugangskonten, Datenkategorien.

Control: DET.6.1.2 - Automatische Alarmierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.6 Vorfallserkennung

Übergeordnetes Control:

DET.6.1 Beurteilung von Ereignissen

UUID: f45e08b7-8f42-469a-aa22-63b93daba60e

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Detektion SOLLTE bei sicherheitskritischen Ereignissen eine Alarmierung von {{ insert: param, det.6.1.2-prm1 }} durch {{ insert: param, det.6.1.2-prm2 }} ausführen.

Guidance

Für die Definition eines sicherheitskritischen Ereignisses, siehe Glossar (Namensräume des Grundschutz++). Bewährt hat sich hierzu der Einsatz eines Security Information and Event Management Systems (SIEM), das die Audit Logs verschiedener Hersteller auf Ereignisse überprüfen und diese korrelieren kann. Passen Sie Schwellwerte und Kriterien so an, dass keine Alarmmüdigkeit (alert fatigue) beim Personal aufkommt.

Links

required: DET.6.1.1 Automatisierte Feststellung

Control: DET.6.1.3 - Dokumentation von Ergebnissen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.6 Vorfallserkennung

Übergeordnetes Control:

DET.6.1 Beurteilung von Ereignissen

UUID: 02e94d9c-cd23-4cb4-a6ef-7ccd7efb0869

Aufwand: 4

Sicherheitsstufe: erhöht

Statement

Detektion KANN Analyseergebnisse dokumentieren.

Guidance

Die Aufzeichnung von Beurteilungsergebnissen und Entscheidungen bei Sicherheitsvorfällen dient als rechtssichere Nachweisführung und ermöglicht retrospektive Analysen zur kontinuierlichen Prozessverbesserung. Sie stellt außerdem sicher, dass die Vorfälle während und nach der Behandlung strukturiert aufgearbeitet werden können. Zweckmäßig ist es dabei, möglichst viele hilfreiche Informationen automatisch mitzuerfassen, z.B. welche Fehlermeldung genau aufgetreten ist oder welche Schwellwerte bis zu welchem Wert genau überschritten worden sind. Kann auch durch ein SIEM umgesetzt werden, welches Informationen zu kritischen Ereignissen abspeichert. Die Umsetzung kann mit einem standardisierten Dokumentationssystem erfolgen, das alle relevanten Metadaten erfasst: Zeitstempel, beteiligte Personen, Begründungen für Entscheidungen sowie konkrete Maßnahmen.

Control: DET.6.2 - Beurteilung von Eingängen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DET.6 Vorfallserkennung
UUID: 0ec29d00-cea9-4337-8f83-b680453b21b2
Aufwand: 4
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DET.6.2.1 Dynamische Sandbox-Analyse
- DET.6.2.2 Datenträgerschleuse

Statement

Detektion SOLLTE ein Verfahren zur Beurteilung von Datei-Eingängen verankern.

Guidance

Kann beispielsweise ein Virens Scanner eine Datei nicht überprüfen, weil sie mit einem Passwort geschützt ist, erhalten Nutzende die Datei erst, wenn sie durch das für Detektion zuständige Personal freigegeben wurde. Dazu muss die Datei aus einer vertrauenswürdigen Quelle stammen und keine Anzeichen für einen Angriff vorliegen.

Control: DET.6.2.1 - Dynamische Sandbox-Analyse

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.6 Vorfallserkennung

Übergeordnetes Control:

DET.6.2 Beurteilung von Eingängen

UUID: 5e302b5d-0a5b-4821-8d46-1e2f7fc40c3f

Aufwand: 4

Sicherheitsstufe: erhöht

Statement

Detektion KANN verdächtige Dateien in einer isolierten Umgebung mindestens anhand von aufgebauten Netzverbindungen, Systemaufrufen und Dateizugriffen testen.

Guidance

Eine dynamische Sandbox Analyse ist die Ausführung des verdächtigen Codes in einer isolierten Umgebung, aus der eine Anwendung nicht durch Ausführung von Systembefehlen ausbrechen kann (Sandbox Detonation). Sie ermöglicht die sichere Untersuchung potenziell schädlicher Dateien in einer isolierten Umgebung, um deren tatsächliches Verhalten zu beobachten. Eine dynamische Analyse kann verschiedene verdächtige Aktivitäten erfassen: Dateisystemoperationen wie das Erstellen, Ändern oder Löschen von Dateien; Registry-Modifikationen, besonders in Autostart-Bereichen; Netzwerkverhalten einschließlich externer Verbindungsversuche und Datenexfiltration; Prozessverhalten wie Injektionstechniken oder unerwartete Kindprozesse; Speicheroperationen; Persistenzmechanismen wie Dienste oder geplante Aufgaben; Anti-Analyse-Techniken zur Erkennung virtueller Umgebungen; sowie ungewöhnliche API-Aufrufe wie kryptografische Funktionen oder Sicherheitsumgehungen. Die Sandbox kann dabei mit ausreichender Laufzeit, Netzwerksimulation und Snapshot-Funktionen ausgestattet werden, um auch verzögerte oder umgebungs-spezifische Schadfunktionen zu erkennen.

Control: DET.6.2.2 - Datenträgerschleuse

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DET.6 Vorfallserkennung

Übergeordnetes Control:

DET.6.2 Beurteilung von Eingängen

UUID: 51911fce-93f1-455a-b690-d5ddc90c9129

Aufwand: 3

Sicherheitsstufe: erhöht

Statement

Detektion KANN Datenträgerschleusen installieren.

Guidance

Eine Datenträgerschleuse ist ein vom restlichen Netz der Institution getrenntes System zur Erkennung von Schadprogrammen.

Control: DLS.1.1 - Verfahren und Regelungen

Tag: "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.1 Grundlagen
UUID: 41ed06ba-0c2f-4c7e-abef-96b13e838061
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DLS.1.1.1 Dokumentation
- DLS.1.1.2 Zuweisung der Aufgaben
- DLS.1.1.3 Bekanntgabe

Statement

Dienstleistersteuerung MUSS ein Verfahren zur Steuerung und geordneten Beendigung von Dienstleistungsverträgen verankern.

Guidance

Hierzu gehört die Kontrolle der Einhaltung von Vereinbarungen zur Sicherheit mit Dienstleistern und (falls erforderlich) einen geeigneten Weg für die Beendigung von Verträgen vorzubereiten. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Control: DLS.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DLS.1 Grundlagen

Übergeordnetes Control:

DLS.1.1 Verfahren und Regelungen

UUID: 83e77b46-999a-4ba3-b525-4deba0625aec

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Dienstleistersteuerung MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: DLS.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DLS.1 Grundlagen

Übergeordnetes Control:

DLS.1.1 Verfahren und Regelungen

UUID: d630bd91-1daa-4467-865c-e3ce5b437fdb

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Dienstleistersteuerung MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, dls.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es die Zuweisung anhand von Rollen (z.B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: DLS.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DLS.1 Grundlagen

Übergeordnetes Control:

DLS.1.1 Verfahren und Regelungen

UUID: d16beace-2e32-4d1c-8af1-f7dc721e251f

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Dienstleistersteuerung MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: DLS.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DLS.1 Grundlagen

UUID: 79e6ddcd-767f-4cf3-85a7-4928198c0318

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Dienstleistersteuerung MUSS die Verfahren und Regelungen {{ insert: param, dls.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante Überprüfung der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: DLS.2.1 - Mehr-Faktor-Authentifizierung

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.2 Nutzung von digitalen Dienstleistungen
UUID: 8bbca369-db4c-421d-b930-f4257acc1b83
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Dienstleistersteuerung für Dienstleistungen SOLLTE Mehr-Faktor-Authentifizierung bei Login in Online-Dienste aktivieren.

Guidance

Online-Dienste wie die Verwaltung von TK-Rufnummern oder Cloud-Office-Anwendungen sind ein beliebtes Ziel für Angriffe durch Phishing oder Datenleaks. Sichern Sie diese Zugänge mit Mehr-Faktor-Authentifizierung (z.B. OTP) ab.

Control: DLS.2.2 - Transportverschlüsselung

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.2 Nutzung von digitalen Dienstleistungen
UUID: c9cd4b7e-8f76-4884-afb7-dcfd3d228624
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Dienstleistersteuerung für Daten SOLLTE den Transport bei der Übertragung zum Anbieter nach {{ insert: param, dls.2.2-prm1 }} verschlüsseln.

Guidance

„Transport“ bedeutet hier der technische Vorgang der Datenübertragung zwischen der Institution und dem Dienstleister, also etwa über das Internet oder dedizierte Leitungen. Der Sinn dieser Vorschrift liegt darin, die Vertraulichkeit und Integrität von Informationen zu schützen, wenn sie in fremde Infrastrukturen überführt werden. Ohne eine solche Maßnahme könnte ein Angreifer Daten während der Übertragung abfangen oder manipulieren, beispielsweise über „Man-in-the-Middle“-Angriffe oder durch Abhören unsicherer Netze. Da beschaffte Dienstleistungen typischerweise außerhalb der direkten Kontrolle der Institution liegen, gibt es hier eine eigene Vorgabe, um die besondere Risikosituation beim Übergang von interner zu externer Infrastruktur gezielt abzusichern. Eine Institution kann die Anforderung praktisch umsetzen, indem sie (1) den Einsatz von Protokollen wie TLS in allen Web- und API-basierten Schnittstellen zum Anbieter sicherstellt, (2) für administrative Zugänge oder besonders sensible Datenübertragungen zusätzlich VPN-Verbindungen nutzen kann, und (3) Zertifikatsprüfungen so konfiguriert, dass unsichere oder abgelaufene Zertifikate nicht akzeptiert werden.

Links

related: BES.4.6.2 Verschlüsselung durch den Anbieter

Control: DLS.2.3 - Vollverschlüsselung

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.2 Nutzung von digitalen Dienstleistungen
UUID: 30a1e505-c2a4-44d9-8c8e-6584142d5d64
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Dienstleistersteuerung für Daten KANN diese, wenn der Anbieter deren Inhalt zur Vertragserbringung nicht kennen muss, für diesen nicht entschlüsselbar vor der Übertragung zum Dienstleister verschlüsseln.

Guidance

Hierbei handelt es sich um eine Verschlüsselung at-rest, bei welcher der Dienstleister keinen Zugang zum Schlüssel erhält. Die Umsetzung kann z.B. auf Dateiebene oder durch Container erfolgen.

Control: DLS.3.1 - Einhaltung der Sicherheitsvorgaben

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.3 Kontrolle von Dienstleistern
UUID: 5b17bd9b-ff38-46eb-a1ef-7b38429f128b
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DLS.3.1.1 Audit oder Zertifikat

Statement

Dienstleistersteuerung für Dienstleistungen SOLLTE die Einhaltung der Sicherheitsvorgaben durch den Dienstleister {{ insert: param, dls.3.1-prm1 }} überprüfen.

Guidance

Hierzu ist zu prüfen, ob Anzeichen vorliegen, dass der Dienstleister die im Vertrag geforderten Vorgaben nicht einhält und falls erforderlich Gegenmaßnahmen einzuleiten. Die Prüfung kann z.B. Zertifikate, regelmäßige Stichproben oder das Monitoring von Datenleaks vorsehen.

Control: DLS.3.1.1 - Audit oder Zertifikat

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.3 Kontrolle von Dienstleistern
Übergeordnetes Control:
DLS.3.1 Einhaltung der Sicherheitsvorgaben
UUID: 12c2c250-86b8-46a0-bccd-d0b2f59b6bae
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Dienstleistersteuerung für Outsourcing SOLLTE die Einhaltung der Sicherheitsvorgaben anhand eines {{ insert: param, dls.3.1.1-prm1 }} {{ insert: param, dls.3.1.1-prm2 }} überprüfen.

Guidance

„Audit“ bezeichnet in diesem Zusammenhang eine systematische, unabhängige Überprüfung der vereinbarten Sicherheitsmaßnahmen durch fachkundige Dritte, beispielsweise in Form interner oder externer Prüfungen mit dokumentierten Ergebnissen. Ein „Zertifikat“ ist ein formaler Nachweis einer akkreditierten Prüfstelle, dass ein Dienstleister ein anerkanntes Sicherheitsframework eingehalten hat, wie etwa IT-Grundschutz oder ISO/IEC 27001. Ein „vergleichbarer Sicherheitsnachweis“ kann auch ein Prüfbericht, ein BSI C5-Testat oder eine Bestätigung unabhängiger Gutachter sein, sofern er inhaltlich nachvollziehbar darlegt, dass definierte Sicherheitsanforderungen wirksam umgesetzt wurden. Ohne Nachweise könnte ein Dienstleister vereinbarte Sicherheitsmaßnahmen vernachlässigen, was zu unbemerkten Datenabflüssen, unzureichendem Patch-Management oder Ausfällen durch mangelhafte Notfallvorsorge führen könnte. Durch nachvollziehbare Prüfungen kann dagegen erreicht werden, dass Sicherheitsstandards eingehalten werden, Schwachstellen frühzeitig sichtbar werden und ein belastbares Vertrauen in die Dienstleisterbeziehung entsteht.

Control: DLS.3.2 - Checkup

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.3 Kontrolle von Dienstleistern
UUID: ca07f3db-7a2f-4156-b1de-4fa648393557
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Dienstleistersteuerung für Outsourcing KANN die risikoorientierte Entscheidung über Outsourcing auf Grundlage der Geschäftsprozessprofile auf Änderungen der Gefährdungslage oder Prozessinhalte { { insert: param, dls.3.2-prm1 } } überprüfen.

Guidance

Die risikoorientierte Entscheidung über Outsourcing kann in diesem Kontext als wiederkehrende Bewertung der Abhängigkeiten und Gefahren verstanden werden, die durch externe Dienstleister in den Geschäftsprozessen einer Institution entstehen. Der Parameter regelmäßig kann je nach Kritikalität der ausgelagerten Prozesse sinnvoll mit Werten wie halbjährlich, jährlich oder nach definierten Ereignissen (z. B. Einführung neuer regulatorischer Vorgaben oder Sicherheitsvorfälle) ausgefüllt werden. Änderungen der Gefährdungslage beziehen sich auf die dynamische Entwicklung von Bedrohungen wie Cyberangriffe, Lieferkettenstörungen oder neue regulatorische Anforderungen, während Änderungen der Prozessinhalte vor allem die Anpassung oder Erweiterung der durch Dienstleister erbrachten Leistungen umfassen. Der Zweck dieser Vorschrift liegt darin, frühzeitig sicherzustellen, dass die bisherigen Risikoeinschätzungen und Dienstleistervereinbarungen weiterhin tragfähig sind und nicht durch externe Veränderungen entwertet werden. Ohne eine solche Überprüfung könnte beispielsweise ein Dienstleister aufgrund verschärfter Bedrohungen unzureichenden Schutz bieten oder durch eine stillschweigende Ausweitung von Leistungen in Bereiche gelangen, die ursprünglich nicht risikobewertet wurden. Eine regelmäßige Kontrolle kann dagegen dafür sorgen, dass Risiken durch Outsourcing transparent bleiben und rechtzeitig nachjustiert werden. Zur praktischen Umsetzung kann eine Institution beispielsweise (1) eine Checkliste führen, die bei jeder Neubewertung konkrete Aspekte wie Datenlokation, technische Sicherheits-

maßnahmen oder Zertifikatsgültigkeiten abfragt und (2) ein automatisiertes Monitoring nutzen, das öffentliche Sicherheitsnachweise wie Testate nach BSI C5 oder SOC-Reports erfasst und in die Bewertung einbindet. Auch die Nutzung von Incident-Datenbanken oder branchenspezifischen Threat-Feeds kann helfen, Gefährdungslagen aktuell einzuschätzen. Ein bewährter Tipp ist es, nicht nur formale Unterlagen zu prüfen, sondern auch technische Stichproben durchzuführen, etwa in Form von Konfigurationsprüfungen oder Penetrationstests, sofern dies durch den Dienstleister gestattet wird. Damit kann die Institution sicherstellen, dass die theoretische Risikoabwägung durch reale Prüfungen gestützt wird und sich an tatsächlichen Veränderungen orientiert.

Control: DLS.3.3 - Strategie-Check

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.3 Kontrolle von Dienstleistern
UUID: cc89b4a1-02a9-48b6-aac9-2b6c2e0d7062
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Dienstleistersteuerung für Outsourcing KANN die Strategie auf Vollständigkeit und Korrektheit in Bezug auf die betrachteten Geschäftsprozesse bei Änderungen der Geschäftsprozessprofile überprüfen.

Guidance

Vollständigkeit bedeutet hier, dass die Gesamtheit der ausgelagerten Prozesse erfasst, beschrieben und in ihrer Abhängigkeit zu internen Prozessen berücksichtigt ist. Korrektheit meint, dass die Beschreibungen, Schnittstellen und Verantwortlichkeiten zwischen Institution und Dienstleister sachlich richtig, aktuell und belastbar dokumentiert sind. Zur Umsetzung kann eine Institution strukturierte Verfahren einführen, die bei Änderungen in den Prozessprofilen automatisch eine Prüfung des Outsourcing-Setups auslösen. Dies kann z. B. durch Abgleich der aktuellen Servicebeschreibungen mit Prozesslandkarten erfolgen, sodass fehlende oder doppelt definierte Zuständigkeiten sichtbar werden.

Links

required: BES.1.4 Outsourcing-Strategie

Control: DLS.3.4 - Anhörung

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.3 Kontrolle von Dienstleistern
UUID: a36c3091-9132-49dc-9186-d335cb153360
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Dienstleistersteuerung für Outsourcing SOLLTE den Dienstleister zu Sicherheitsmaßnahmen für betroffene Zielobjekte anhören.

Guidance

Betroffen sind alle Zielobjekte, zu denen vom Dienstleister (Teil-)Leistungen erbracht werden. Für eine Anhörung ist es erforderlich, dass der Dienstleister über die geplanten Maßnahmen informiert ist und ausreichend Gelegenheit zur Stellungnahme erhält.

Control: DLS.3.5 - Blockierung unzuverlässiger Dienstleister

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DLS.3 Kontrolle von Dienstleistern

UUID: b2b77218-8ec2-415d-8f12-06c7f4cb3f7a

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Dienstleistersteuerung SOLLTE unzuverlässige Dienstleister oder Subdienstleister blockieren.

Guidance

Ein Dienstleister gilt als unzuverlässig, wenn zukünftig mit Verstößen gegen die Schutzziele Vertraulichkeit, Verfügbarkeit oder Integrität durch ihn zu rechnen ist (d.h. eine Prognose der Vertrauenswürdigkeit). Dies ist insbesondere dann der Fall, wenn erhebliche Verstöße gegen die Schutzziele bereits durch ihn begangen wurden oder Anzeichen dafür vorliegen, dass bei einer weiteren Verwendung mit solchen Verstößen zu rechnen ist. Beispielsweise kann dies eintreten, wenn die Verwendung des DNS-Servers eines wirtschaftlichen Konkurrenten diesem die schützenswerten Adressen von der Institution besuchter Internetseiten ausliefert oder eine Behörde Software mit Internetzugriff einsetzen möchte, die jedoch von einem Hersteller stammt, dessen Hauptsitz in einem öffentlich für politische Spionage bekannten Staat liegt. Dies kann durch eine Liste blockierter Vertragspartner umgesetzt werden. Eine Umsetzung für Subdienstleister kann z.B. durch die Benennung autorisierter Subdienstleister, oder die Weitergabe von Kriterien für Subdienstleister an den Dienstleister erfolgen.

Links

related: BES.3.2 Auswahlkriterien

Control: DLS.3.6 - Portabilität

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.3 Kontrolle von Dienstleistern
UUID: 2563b59c-b3da-4bdd-99cd-3eedb94c0abb
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Dienstleistersteuerung für Outsourcing KANN die Portabilität des ausgelagerten Prozesses {{ insert: param, dls.3.6-prm1 }} überprüfen.

Guidance

Hierunter ist zu verstehen, dass regelmäßig ein Test durchgeführt wird, bei dem die Funktionsfähigkeit des ausgelagerten (Teil-) Prozesses in einer Umgebung, die nicht bei diesem Dienstleister liegt, überprüft wird. Ziel ist es sicherzustellen, dass der Prozess bei einem Ausfall des Dienstleisters an anderer Stelle zeitnah gestartet werden kann.

Control: DLS.4.1 - Dekommissionierung

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.4 Dekommissionierung von Dienstleistern
UUID: a78062a0-7fff-43a7-906a-6db806cf6822
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DLS.4.1.1 Unabhängigkeit
- DLS.4.1.2 Berechtigungen deaktivieren

Statement

Dienstleistersteuerung für Dienstleistungen SOLLTE eine Vorgehensweise zur Dekommissionierung vor Vertragsende verankern.

Guidance

Der Begriff Dekommissionierung bezeichnet hier das strukturierte und nachweisbare Vorgehen, wie eine Institution die Nutzung eines Dienstes oder die Zusammenarbeit mit einem Dienstleister kontrolliert beendet, ohne dass Informationssicherheit, Verfügbarkeit oder Nachvollziehbarkeit beeinträchtigt werden. Der Sinn dieser Vorgabe liegt darin, Risiken wie den unkontrollierten Verbleib sensibler Daten bei einem Dienstleister oder unerkannte Abhängigkeiten von dessen Infrastruktur zu vermeiden. Ohne ein definiertes Vorgehen könnte etwa ein Anbieter weiterhin Zugriff auf produktive Systeme behalten oder Kopien vertraulicher Daten in seiner Umgebung zurückhalten, was ein erhebliches Risiko darstellen könnte. Die praktische Umsetzung kann in mehreren abgestuften Maßnahmen bestehen: (1) Ein geplanter Abschalttermin kann genutzt werden, um Systeme, Schnittstellen und Berechtigungen kontrolliert zurückzubauen und anschließend durch ein Freigabeprotokoll zu bestätigen. (2) Ein Prozessleitfaden kann die frühzeitige Identifikation von zu dekommissionierenden Schnittstellen, Zugangsdaten und Subdienstleistern vorsehen, damit deren Abschaltung rechtzeitig koordiniert werden kann. (3) Eine Checkliste kann sicherstellen, dass auch weniger offensichtliche Abhängigkeiten – etwa hinterlegte API-Tokens, Support-Zugänge oder im Monitoring integrierte Endpunkte – im

Abschlussprozess berücksichtigt werden. (4) Technisch kann die Nutzung von zentral verwalteten Zugriffskonten und Logging-Systemen die Überprüfung erleichtern, ob ein Dienstleister nach der Deaktivierung tatsächlich keinen Zugriff mehr hat. Auf diese Weise kann die Institution die Dienstleistersteuerung auch vorzeitig geordnet beenden, ohne dass Informationssicherheitsrisiken unkontrolliert fortbestehen.

Links

related: BES.6.1 Entziehung der Zugangsberechtigungen

Control: DLS.4.1.1 - Unabhängigkeit

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.4 Dekommissionierung von Dienstleistern
Übergeordnetes Control:
DLS.4.1 Dekommissionierung
UUID: d37125e2-68cd-4e75-9da9-d4af0b4dd051
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Dienstleistersteuerung für Outsourcing SOLLTE die Unabhängigkeit der Verarbeitung schützenswerter Informationen vor der Außerbetriebnahme testen.

Guidance

„Unabhängigkeit der Verarbeitung“ meint hier die Fähigkeit, dass die Nutzung von Informationen in Geschäftsprozessen der Institution nicht von den Systemen, Verfahren oder Interessen des externen Dienstleisters abhängig ist, sodass ihre Integrität, Verfügbarkeit und Vertraulichkeit auch nach einer Außerbetriebnahme des Outsourcings gewährleistet bleibt. Die Vorschrift dient dem Zweck, die Risiken zu minimieren, die entstehen können, wenn ein Dienstleister seine Leistung einstellt, Verträge beendet werden oder ein abruptes Ende der Zusammenarbeit erfolgt. Ohne Vorkehrungen könnte dies dazu führen, dass kritische Daten unzugänglich bleiben, unkontrolliert gelöscht werden oder in Abhängigkeit von proprietären Formaten verloren gehen. Zur Umsetzung kann die Institution verschiedene Maßnahmen prüfen: (1) Ein systematischer Test, ob Daten in standardisierten, portablen Formaten exportierbar sind und in eigenen oder alternativen Systemen fehlerfrei weiterverarbeitet werden können. (2) Ein Probelauf, bei dem die Verbindung zum Dienstleister gezielt getrennt wird, um zu überprüfen, ob die Institution ihre Geschäftsprozesse auch ohne aktive Anbindung fortführen kann. (3) Ein kontrolliertes Abschalten einzelner vom Dienstleister erbrachter Dienste, um zu verifizieren, ob vorbereitete Ersatzprozesse oder interne Systeme die Funktion übernehmen. (4) Eine Teststellung für die Rückgabe von Datenbeständen am Ende der Vertragslaufzeit, bei der die Vollständigkeit, Konsistenz und Nutzbarkeit der gelieferten Daten geprüft wird. Mit solchen Maßnahmen kann die Institution sicherstellen, dass die Verarbeitung schützenswer-

ter Informationen eigenständig aufrechterhalten werden kann.

Control: DLS.4.1.2 - Berechtigungen deaktivieren

Tags: "Lieferketten" "Exit-Strategie"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DLS.4 Dekommissionierung von Dienstleistern
Übergeordnetes Control:
DLS.4.1 Dekommissionierung
UUID: 3449b68e-a78f-4090-9092-6e1a65dd7c2a
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Dienstleistersteuerung für Dienstleistungen SOLLTE für den Vertrag benötigte Berechtigungen bei Vertragsende unverzüglich deaktivieren.

Guidance

Berechtigungen sind hier alle Zugangs-, Zutritts- und Zugriffsrechte, die von der Institution für Mitarbeitende, Organisationseinheiten oder Subunternehmer des Dienstleisters eingerichtet oder geändert wurden. Hierzu können diese Rechte gelöscht, deaktiviert oder reduziert werden, soweit sie nicht mehr (z.B. für andere Verträge) benötigt werden.

Links

related: BER.1.1 Verfahren und Regelungen

Control: DEV.1.1 - Verfahren und Regelungen

Tag: "Security by Design"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.1 Grundlagen
UUID: 1ab03687-f510-4fc1-86c1-484135aa354b
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DEV.1.1.1 Dokumentation
- DEV.1.1.2 Zuweisung der Aufgaben
- DEV.1.1.3 Bekanntgabe

Statement

Entwicklung MUSS Verfahren und Regelungen zur Entwicklung von IT-Produkten verankern.

Guidance

Für ein Verfahren zur Softwareentwicklung siehe BSI TR-03185. Entwickelt die Institution im Informationsverbund keine IT-Produkte, so sind diese und alle anderen Anforderungen der Praktik entbehrlich. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Control: DEV.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.1 Grundlagen

Übergeordnetes Control:

DEV.1.1 Verfahren und Regelungen

UUID: 4bfb4a1-d915-45f4-9654-dfd721933f03

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Entwicklung MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: DEV.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.1 Grundlagen

Übergeordnetes Control:

DEV.1.1 Verfahren und Regelungen

UUID: a2cc6c12-cf80-4284-896c-5a12482c452a

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Entwicklung MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, dev.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es die Zuweisung anhand von Rollen (z.B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: DEV.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.1 Grundlagen

Übergeordnetes Control:

DEV.1.1 Verfahren und Regelungen

UUID: b36d2214-c54e-4921-a0ec-2d98e2dfb047

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Entwicklung MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: DEV.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.1 Grundlagen

UUID: 9751d813-fcc6-4511-8847-b2c6d45b4fcf

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Entwicklung MUSS die Verfahren und Regelungen {{ insert: param, dev.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante Überprüfung der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: DEV.2.1 - Security by Design Architektur

Tag: "Security by Design"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.2 Softwareentwicklung - Security by Design
UUID: c16e1dd2-8fa8-43db-83e9-32c6efd86d8e
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Entwicklung SOLLTE die Architektur nach dem Prinzip "Security by Design" verankern.

Guidance

Unter "Security by Design" ist zu verstehen, dass Sicherheitsprinzipien und -mechanismen integrale Bestandteile der Architektur sind, anstatt nur nachträglich "angeflanscht" zu werden. Hierzu gehören Sicherheitsprinzipien wie Modularisierung, Verschlüsselung und Authentifizierung beim Entwurf der Architektur. Die Umsetzung kann durch Threat Modeling realisiert werden. Für Details siehe BSI TR-03185. Bei der Umsetzung von Security by Design empfiehlt sich auch ein Blick in die Praktik Konfiguration, spezifisch die Anforderungen zu Verschlüsselung, Authentifizierung, etc.

Control: DEV.2.2 - Dokumentation der (Software-)Architektur

Tag: "Security by Design"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.2 Softwareentwicklung - Security by Design
UUID: 79eb639b-25ed-4ce3-9d8f-c57b573c1ee3
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE die Architektur dokumentieren.

Guidance

Die Architektur bezeichnet im konkreten Kontext die strukturierte Beschreibung der grundlegenden Komponenten einer Software sowie deren Schnittstellen, Abhängigkeiten und das Datenmodell. Sie stellt dar, wie Module, Datenflüsse und externe Systeme ineinandergreifen, und bildet damit das Gerüst für Wartung, Weiterentwicklung und Sicherheitsbewertungen. Ohne dokumentierte Architektur könnte eine Institution nach Jahren vor der Situation stehen, dass nur einzelne Entwickler den Aufbau verstehen, was den Wissenstransfer erschwert und bei Personalwechseln erhebliche Risiken birgt. Eine unklare oder fehlende Dokumentation könnte zudem dazu führen, dass Abhängigkeiten von proprietären Technologien übersehen werden, wodurch sich ein Vendor Lock-in entwickelt, der die Institution langfristig bindet. Umgekehrt kann eine nachvollziehbare Architektur Dokumentation sicherstellen, dass Schwachstellenanalysen effizient durchgeführt werden, dass Sicherheitslücken frühzeitig erkannt werden und dass neue Entwickler schneller eingearbeitet werden können. Zur Umsetzung der Anforderung kann eine Institution standardisierte Diagrammtypen wie UML oder C4 einsetzen, um Abhängigkeiten und Schnittstellen verständlich abzubilden. Hilfreich kann es sein, die Architektur in mehreren Sichten zu dokumentieren, etwa eine logische Sicht (Funktionen und Module), eine technologische Sicht (Server, Container, Frameworks) und eine sicherheitsrelevante Sicht (z. B. Trust Boundaries). Die Dokumentation kann in Versionskontrollsystemen wie Git gepflegt werden, sodass Änderungen an Architekturentscheidungen nachvollziehbar bleiben. Ergänzend kann es praktikabel sein, automatisierte Werkzeuge einzusetzen.

zen, die Code-Strukturen analysieren und Diagramme generieren, wodurch Konsistenz zwischen Dokumentation und Implementierung unterstützt werden kann.

Control: DEV.2.3 - Ausführbarkeit mit minimalen Rechten

Tag: "Security by Design"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.2 Softwareentwicklung - Security by Design
UUID: 88b87ec7-be5f-4740-a226-6b23994f86b4
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE die fehlerfreie Ausführung mit den geringst möglichen Berechtigungen verankern.

Guidance

Die Anwendung ermöglicht die Ausführung mit den geringst möglichen Berechtigungen, wenn sie nur die Berechtigungen benötigt, die für die gerade intendierte Funktionalität erforderlich sind (also z.B. auch ohne Kamerazugriff funktioniert, wenn Nutzende nur vorhandene Bilder betrachten möchten). Sind einzelne Berechtigungen nicht vorhanden, so funktioniert die Anwendung mit entsprechenden Einschränkungen weiterhin (Graceful Degradation).

Control: DEV.2.4 - Einschränkung Zugriffs auf Quellcode

Tag: "Security by Design"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.2 Softwareentwicklung - Security by Design
UUID: 37367710-3072-43af-a7bf-6c6cec49db0f
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Entwicklung SOLLTE den schreibenden Zugriff auf Quellcode einschränken.

Guidance

Eine Einschränkung des schreibenden Zugriffes auf den Quellcode auf die zur Aufgabenerfüllung erforderlichen Personen oder IT-Systeme hilft, unbefugte Änderungen am Quellcode zu verhindern. Nach dem Grundsatz der geringstmöglichen Berechtigung benötigen schreibenden Zugriff nur Personen wie Entwickler oder Maintainer, zu deren Aufgaben die Arbeit am Code gehört.

Control: DEV.2.5 - Einschränkung des Zugriffs auf Zugangsdaten

Tag: "Security by Design"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.2 Softwareentwicklung - Security by Design
UUID: 3a2e18f2-8f77-4f7d-9fc9-cfadb576c04
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE den lesenden und schreibenden Zugriff auf Zugangsdaten einschränken.

Guidance

Von der Anwendung verwendete Zugangsdaten können z.B. API-Schlüssel oder Datenbankmeldeinformationen sein. Statt diese im Quellcode zu hinterlegen ist es besser, sie in Umgebungsvariablen oder sogenannten Vaults zu speichern. Hierbei hilft es auch, solche Daten mit .gitignore-Regeln aus der Versionskontrolle auszuschließen.

Control: DEV.2.6 - Widerstandsfähigkeit gegen gängige Angriffsmuster

Tag: "Security by Design"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.2 Softwareentwicklung - Security by Design
UUID: 65ec8cf9-f2aa-4eb5-85a6-914c3da3e148
Aufwand: 4
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- DEV.2.6.1 Eingabevalidierung
- DEV.2.6.2 Ausgabekodierung

Statement

Entwicklung für Anwendungen SOLLTE Schutzfunktionen gegen gängige Angriffsmuster installieren.

Guidance

Gängige Angriffsmuster sind wiederkehrende Vorgehensweisen von Angreifenden, die in der Praxis häufig auftreten, z. B. SQL-Injection, Cross-Site-Scripting (XSS) oder Pufferüberläufe. Welche Angriffsmuster für die konkrete Anwendung gängig sind, hängt von Funktionalität und Architektur der Anwendung ab, z.B. Prompt Injection bei generativer KI. Die Vorschrift zielt darauf ab, dass Produkte bereits in der Entstehung so gestaltet werden, dass typische Schwachstellen systematisch erschwert werden. Ohne entsprechende Vorkehrungen könnte ein Angreifer etwa durch manipulierte Eingaben vertrauliche Daten auslesen oder unautorisiert Funktionen steuern. Werden Schutzfunktionen frühzeitig eingebaut, kann die Stabilität des Produkts erhöht, die Angriffsfläche reduziert und das Vertrauen der Nutzenden gestärkt werden. Zur Umsetzung können etablierte Programmierpraktiken wie das Verwenden sicherer Standardbibliotheken, das Einschränken von Nutzerrechten im Code oder das Einführen von Fallback-Mechanismen bei fehlerhaften Eingaben verwendet werden. Ergänzend kann die Institution Secure Coding Guidelines nutzen, die häufige Angriffsmuster adressieren und Entwickelnden praxisnahe Hilfen bieten.

Control: DEV.2.6.1 - Eingabevalidierung

Tags: "Security by Design" "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.2 Softwareentwicklung - Security by Design
Übergeordnetes Control:
DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
UUID: 467ae9d3-922b-44eb-9527-d617416e5330
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE Eingabedaten auf eingeschleuste Befehle testen.

Guidance

Bei der Eingabevalidierung (Input Validation) wird getestet, ob die Eingabedaten eingeschleuste Befehle enthalten, z.B. SQL-Injection, Kommandozeilenbefehle oder Prompt Injection bei generativer KI. Welche Eingaben betroffen sein könnten, kann durch eine Taint Analyse herausgefunden werden. Alternativ können auch alle Eingabedaten validiert werden (Server Side Validation).

Links

related: KONF.12.1 Eingabevalidierung

Control: DEV.2.6.2 - Ausgabekodierung

Tags: "Security by Design" "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.2 Softwareentwicklung - Security by Design
Übergeordnetes Control:
DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
UUID: dee85b12-b7f9-445e-802a-bbe13d67538e
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE eine Ausgabekodierung ausführen.

Guidance

Ausgabekodierung (Output Encoding) ist wichtig, da sie spezielle Zeichen neutralisiert und so Angriffe wie Cross-Site Scripting (XSS) oder HTML-Injektionen verhindert, die ansonsten Schadcode ausführen könnten. Empfehlenswert ist kontextabhängiges Encoding und Escaping, basierend auf standardisierten Frameworks wie OWASP ESAPI.

Control: DEV.3.1 - Replay-Angriffe

Tags: "Authentication and Authorization" "Replay Attacks" "Session Hijacking" "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.3 Softwareentwicklung - Härtung

UUID: 2eeb41fa-2354-4ea3-a641-c7e5a33a3087

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE Replay-Angriffe blockieren.

Guidance

Wenn die Anwendung Anfragen von anderen Anwendungen oder IT-Systemen entgegennimmt (z.B. per API), dann besteht die Gefahr, dass Angreifer eine vorherige Anfrage erneut verwenden um unbefugt Zugang zu erhalten. Maßnahmen können sein: (1) Identifikatoren, die nur einmal gültig sind (Nonce, Sequenznummern), (2) kryptographische Mechanismen wie MAC und Digitale Signaturen, Challenge-Response-Authentifizierung, OTP.

Control: DEV.3.2 - Routinen zur Fehlerbehandlung

Tags: "Security by Design" "Error Handling" "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.3 Softwareentwicklung - Härtung

UUID: e06f7f69-4c90-4e39-b6be-a9428548e824

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE spezifische und allgemeine Routinen zur Fehlerbehandlung ausführen.

Guidance

Behandeln Sie Fehler (Exceptions) möglichst nahe an der Quelle (z.B. Buffer Overflows, fehlende Dateien) und sehen sie eine Routine vor, die unerwartete Fehler abfängt. Geben Sie passende Fehlermeldungen aus und protokollieren Sie Fehler.

Control: DEV.3.3 - Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen

Tags: "Security by Design" "Error Handling" "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.3 Softwareentwicklung - Härtung

UUID: 2b3f6962-b23f-4698-984e-f5b942ab2fdd

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE die Ausgabe schützenswerter Daten durch Fehlermeldungen deaktivieren.

Guidance

Werden sensible Daten in Fehlermeldungen oder Log-Einträgen verwendet, kommt es leicht zur Offenlegung dieser Informationen gegenüber Unbefugten. Hierzu gehören auch Hinweise auf das Vorhandensein oder Nicht-Vorhandensein eines Nutzerkontos.

Control: DEV.3.4 - Passwort-Hashing

Tags: "Produktbeschreibung" "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.3 Softwareentwicklung - Härtung

UUID: 6b7d5613-a32c-4a47-8a4f-766053da0e74

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE das Hashing von Passwörtern, die zur Authentifizierung an der Anwendung verwendet werden vor der Verarbeitung oder Speicherung aktivieren.

Guidance

Ziel ist der Schutz vor Angriffen, welche Passwörter beim Transport oder aus dem Speicher auslesen und sich hiermit anmelden. Dies kann durch Hash und Salt gemäß BSI TR-02102 vermieden werden.

Control: DEV.4.1 - Nutzerinformation bei kritischen Ereignissen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.4 Softwareentwicklung - Code
UUID: 15c87c6f-7b62-4dcf-88a5-f38bb5a00ce5
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE bei sicherheitskritischen Ereignissen die betroffenen Nutzenden informieren.

Guidance

Z.B. bei Anmeldung von neuen Geräten, Zurücksetzen des Passwortes, ungewöhnlichen Standorten oder der Änderung von Stammdaten.

Control: DEV.4.2 - Bibliotheksquellen

Tags: "Lieferketten" "Secure Compiling Practices"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.4 Softwareentwicklung - Code
UUID: 54b5a504-5b17-4fea-8514-079d99eb0102
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE die Einbindung externer Softwarebibliotheken und -Schnittstellen aus unzuverlässigen oder unbekannten Quellen untersagen.

Guidance

Eine Quelle ist unzuverlässig, wenn zukünftig mit Verstößen gegen die Schutzziele Vertraulichkeit, Verfügbarkeit oder Integrität durch sie zu rechnen ist (d.h. eine Prognose der Vertrauenswürdigkeit). Dies ist insbesondere der Fall, wenn erhebliche Verstöße gegen die Schutzziele durch sie begangen worden sind oder Anzeichen dafür vorliegen, dass bei einer Verwendung mit solchen Verstößen zu rechnen ist.

Links

related: BES.3.3 Unzuverlässige Lieferanten

Control: DEV.4.3 - Softwarebestandteile (SBOM)

Tags: "Produktbeschreibung" "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.4 Softwareentwicklung - Code
UUID: 5b695087-3a35-441a-b8c9-9937a681a996
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE die Bestandteile mit Hilfe einer Software Bill of Materials (SBOM) vor dem Release dokumentieren.

Guidance

Details siehe BSI TR-03183-2. Anwendungen zur Modulverwaltung und Software Composition Analysis (SCA) können dabei unterstützen SBOMs als Teil eines CI/CD Prozesses automatisiert zu sammeln.

Links

related: BES.7.4.4.1 Software Bill of Materials (SBOM)

related: TEST.3.1.7 Analyse der Zusammensetzung

Control: DEV.4.4 - Integrität externer Softwarebibliotheken

Tag: "Secure Compiling Practices"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.4 Softwareentwicklung - Code

UUID: 62b75210-9470-456f-a191-9bbe48da5313

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE die Integrität externer Softwarebibliotheken vor dem Release testen.

Guidance

Gemeint ist damit sowohl die technische Unversehrtheit (z. B. durch kryptografische Prüfungen wie Hash- oder Signaturvalidierung) als auch die inhaltliche Zuverlässigkeit (z. B. keine eingeschleusten Schadfunktionen oder versteckte Abhängigkeiten). Der Sinn und Zweck dieser Anforderung liegt darin, die Risiken durch unsichere oder manipulierte Fremdkomponenten zu reduzieren. So könnte ein Angreifer Schadcode in eine weit verbreitete Bibliothek einschleusen, die dann unbemerkt in der Anwendung landet, oder eine Abhängigkeit könnte im Hintergrund auf nicht mehr gepflegte Versionen verweisen. Eine wirksame Integritätsprüfung kann verhindern, dass fehlerhafte oder kompromittierte Bausteine in produktive Anwendungen gelangen und kann damit auch die Abhängigkeit von nicht vertrauenswürdigen Quellen abmildern. Zur Umsetzung können (1) Hashwerte oder digitale Signaturen von Bibliotheken mit den Referenzwerten der Hersteller verglichen werden, (2) der Bezug externer Pakete über offizielle, verifizierte Repositories, statt über inoffizielle Quellen stattfinden, und (3) in der Build-Pipeline eine automatisierte Integritätsprüfung eingerichtet sein, die verdächtige oder unvollständige Bibliotheken blockiert. Ergänzend kann eine institutionseigene Allowlist gepflegt werden, die geprüfte Versionen von Bibliotheken enthält, sodass Entwickler nicht unkontrolliert beliebige Abhängigkeiten einbinden. Ein praktischer Tipp kann sein, die Prüfmechanismen möglichst früh im Entwicklungsprozess zu automatisieren, um spätere manuelle Nacharbeiten oder Verzögerungen vor einem Release zu vermeiden.

Control: DEV.4.5 - Updates externer Softwarebibliotheken

Tags: "Lieferketten" "Secure Compiling Practices"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.4 Softwareentwicklung - Code

UUID: 3d451248-af76-44a4-87b9-8a86cdf4c28

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE externe Softwarebibliotheken auf Sicherheitsupdates vor dem Release testen.

Guidance

Werden veraltete Softwarebibliotheken in eine veröffentlichte Software eingebunden, so können diese Sicherheitslücken oder Fehler enthalten, die in den aktuellen Versionen bereits behoben sind. Prüfen Sie daher vor einer Freigabe der Software ob eingebundene Bibliotheken aktualisiert wurden.

Control: DEV.4.6 - Compileroptionen

Tag: "Secure Compiling Practices"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.4 Softwareentwicklung - Code
UUID: 615f77e2-9734-4778-ba5a-95a6b80a92d9
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE Compileroptionen für Sicherheitsfunktionen vor dem Release aktivieren.

Guidance

Compileroptionen wie Stack Canaries, PIE, PIE, CFI können automatisch Schutzmechanismen in Programme einbauen. Bewährte Praxis ist es, diese Compileroptionen zu aktivieren, sofern es keine entgegenstehenden besonderen Gründe gibt, darauf im Einzelfall zu verzichten. Werden interpretierte Programmiersprachen verwendet, so ist die Anforderung analog auf die Interpreter-Optionen anzuwenden.

Control: DEV.4.7 - Deterministischer Binärcode

Tag: "Secure Compiling Practices"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.4 Softwareentwicklung - Code
UUID: 973bc793-3acb-4d77-9b7e-9599090c3779
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Entwicklung für Anwendungen KANN eine reproduzierbare Vorgehensweise zur Erstellung eines bestimmten Binärcodes aus dem Quellcode dokumentieren.

Guidance

Ein bestimmter Binärcode meint hier eine reproduzierbare Anwendung (Reproducible builds). Das bedeutet, dass jeder, der denselben Quellcode und dieselbe Build-Umgebung verwendet, bitweise identische Binärdateien erstellt, was die Integrität der Software gegen Manipulationen oder Malware sichert. Dies geschieht durch die genaue Beschreibung der Build-Umgebung und die Vermeidung von zufälligen Faktoren wie Zeitstempeln, die sich auf die erzeugten Artefakte auswirken könnten.

Control: DEV.4.8 - Default-Zugangsdaten

Tags: "Produktbeschreibung" "Security by Default"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.4 Softwareentwicklung - Code
UUID: 00fa92b3-76a1-40ac-b7ad-d4c0a4e0ae64
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE Default-Zugangsdaten vor dem Release dokumentieren.

Guidance

Falls die Software Default-Zugangsdaten wie Passwörter oder Zertifikate enthält, so ist eine sichere Nutzung der Software nur möglich, wenn Nutzende hiervon Kenntnis erhalten um die Zugangsdaten ändern zu können. Sind keine Default-Zugangsdaten erforderlich, so ist die Anforderung entbehrlich.

Control: DEV.4.9 - Voreinstellungen nach dem Prinzip "Security by Default"

Tags: "Produktbeschreibung" "Security by Default"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.4 Softwareentwicklung - Code

UUID: fa1f8609-00d9-4d70-84cb-b3616efea279

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE Voreinstellungen nach dem Prinzip "Security by Default" aktivieren.

Guidance

Voreinstellungen sind die Parameter der Anwendung, mit denen diese im Auslieferungszustand (oder bei Cloud-Anwendungen beim Anlegen eines neuen Zugangskontos) ausgeführt wird. Welche Parameter hier konkret sicher sind ergibt sich aus der Praktik Konfiguration für die jeweilige Art von Zielobjekten.

Control: DEV.4.10 - Protokollierung von Codeänderungen

Tag: "Change Management"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.4 Softwareentwicklung - Code

UUID: e2458854-ad5a-433f-896c-e3eef23b6952

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE Änderungen am Quellcode einschließlich Zeitpunkt, Inhalt der Änderung, ändernder Person und der Begründung der Änderung protokollieren.

Guidance

Im Kontext dieser Anforderung bezeichnet Quellcode den in einer Programmiersprache geschriebenen, von Menschen lesbaren Anteil einer Anwendung, während eine Änderung jede Anpassung, Ergänzung oder Entfernung dieses Codes umfasst. Unter Begründung ist die dokumentierte fachliche oder technische Motivation zu verstehen, die erläutert, warum eine Änderung notwendig war, beispielsweise zur Fehlerbehebung, Funktionserweiterung oder Verbesserung der Sicherheit. Der Zeitpunkt entspricht dabei einem präzisen Zeitstempel, der eine eindeutige zeitliche Nachvollziehbarkeit erlaubt, und die ändernde Person ist diejenige, die die Modifikation fachlich veranlasst oder technisch durchgeführt hat – nicht zwingend dieselbe Rolle wie ein Freigebender oder Reviewer. Die Protokollierung kann verhindern, dass unautorisierte oder fehlerhafte Anpassungen unentdeckt bleiben, und sie kann im Streitfall eine klare Nachvollziehbarkeit bieten. Ohne diese Nachweise könnte es zu unklaren Verantwortlichkeiten, erhöhtem Manipulationsrisiko oder schwer nachvollziehbaren Fehlfunktionen kommen. Eine Institution kann diese Anforderung durch Nutzung von Versionsverwaltungssystemen wie Git oder Subversion umsetzen, indem sie für jede Änderung standardisierte Commit-Meldungen mit Zeitstempel, Autor und Begründung erzwingt. Ergänzend kann ein Workflow etabliert werden, bei dem Änderungen erst nach einem Merge- oder Pull-Request mit dokumentierter Beschreibung in den Hauptzweig gelangen. Sinnvoll ist es zudem, einfache Vorlagen

oder Textbausteine für Begründungen bereitzustellen, sodass Änderungen einheitlich und vollständig erklärt werden können. Für Transparenz kann zusätzlich ein automatisches Änderungsprotokoll generiert werden, das regelmäßig exportiert oder archiviert wird, um auch ohne Zugriff auf das Versionsverwaltungssystem auswertbar zu bleiben.

Control: DEV.4.11 - Test bei Änderungen am Quellcode

Tag: "Change Management"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.4 Softwareentwicklung - Code
UUID: 080fdbcd-0a91-4374-9d1a-c7a1eb078e97
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE Änderungen am Quellcode im Einklang mit den Verfahren und Regelungen für Änderungen und Tests testen.

Guidance

„Änderungen am Quellcode“ (engl. source code changes) bezeichnet im gegebenen Kontext sämtliche Modifikationen, die an den Programmbestandteilen einer Anwendung vorgenommen werden, also etwa neue Funktionen, Fehlerkorrekturen oder Anpassungen an Schnittstellen. Fehlerhafte oder ungetestete Anpassungen könnten etwa zu Sicherheitslücken, Datenverlust oder Instabilitäten im Betrieb führen, wohingegen eine strukturierte Prüfung verhindern kann, dass bekannte Schwachstellen erneut auftreten oder unbeabsichtigte Seiteneffekte entstehen. Solche Änderungen sind daher als Teil des Change Managements zu betrachten, dessen Anforderungen im Einzelnen in der Praktik Änderungen und Tests zu finden sind. Zur praktischen Umsetzung kann eine Institution jede Änderung automatisiert durch Static Application Security Testing (SAST) prüfen, wodurch potenzielle Schwachstellen direkt im Quellcode erkannt werden können. Ergänzend ist es sinnvoll Dynamic Application Security Testing (DAST) einzusetzen, um die lauffähige Anwendung in einer Testumgebung gegen typische Angriffe wie SQL-Injection oder Cross-Site-Scripting zu überprüfen. Sinnvolle Maßnahmen können dabei sein: (1) Aufbau einer Continuous-Integration-Pipeline, die automatisierte Unit-, Integrations- und Sicherheitstests einbindet und Ergebnisse konsolidiert darstellt, (2) Durchführung von manuellen explorativen Tests in einer isolierten Testumgebung, um auch unerwartete Nutzungsmuster zu prüfen, (3) Einsatz von Regressionstests, die sicherstellen können, dass neue Änderungen keine bestehenden Funktionen beeinträchtigen. Eine Institution kann damit die Qualitätssicherung stärken und gleichzeitig Angriffsflächen durch fehler-

hafte Änderungen reduzieren.

Links

required: TEST.1.1 Verfahren und Regelungen

Control: DEV.5.1 - Verankerung des Zeitraums für Updates

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.5 Softwareentwicklung - Updates
UUID: 649b5b3b-fd58-4bec-84bb-71c93b264f94
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE die Bereitstellung von Sicherheitsupdates mindestens für {{ insert: param, dev.5.1-prm1 }} verankern.

Guidance

Hierbei wird festgelegt, für welchen konkreten Zeitraum Sicherheitsaktualisierungen (Patches) für das Produkt mindestens bereitgestellt werden. Dazu gehört auch eine Definition von welchem Zeitpunkt aus der Zeitraum berechnet wird, z.B. Erstveröffentlichung des Produkts. Denken Sie dabei daran, ob ggf. Compliance-Verpflichtungen einzuhalten sind, z.B. § 475b Abs. 3 Nr. 2 BGB für Verbraucherverträge.

Control: DEV.5.2 - Information über Zeitraum für Updates

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.5 Softwareentwicklung - Updates
UUID: ca255009-1c23-47a7-b0f6-a79693b47b95
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE Auftraggeber über den festgelegten Zeitraum für Sicherheitsupdates informieren.

Guidance

Stellen Sie den Empfängern der Software Informationen darüber bereit, wie lange Sicherheitsaktualisierungen gewährleistet werden und wie diese bezogen werden können.

Links

required: DEV.5.1 Verankerung des Zeitraums für Updates

Control: DEV.5.3 - Integritätsprüfung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.5 Softwareentwicklung - Updates
UUID: 878e31fd-614f-4034-8d96-2604e4ed6b92
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE Nutzende über Möglichkeiten zur Verifikation der Integrität von Installations-, Update- und Patchdateien informieren.

Guidance

Dies kann z.B. durch die Veröffentlichung von Prüfsummen über einen authentifizierten Kanal wie eine Webseite mit X.509-Zertifikat erfolgen.

Control: DEV.6.1 - Freigabe nach Änderungen und Tests

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: DEV.6 Freigabe

UUID: f89b3d65-b38d-4269-80a1-2d5c6b8a9ad9

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Entwicklung SOLLTE die Freigabe zur Nutzung im Einklang mit den entsprechenden Verfahren und Regelungen für Änderungen und Tests autorisieren.

Guidance

Eine Freigabe zur Nutzung (Release) meint hier die formelle und autorisierte Überführung einer entwickelten oder geänderten IT-Komponente (wie Software, Systemkonfiguration, Dienstleistung) von einer Test- oder Entwicklungsumgebung in eine Produktions- oder Betriebsumgebung, um den Endbenutzern zur Verfügung zu stehen. Die Vorschrift zielt darauf ab, sicherzustellen, dass nur getestete und abgestimmte Änderungen in den Betrieb gelangen. Ohne diese Autorisierung könnte ungetesteter Code oder eine nicht genehmigte Systemänderung zu schwerwiegenden Betriebsunterbrechungen, Datenverlust oder Sicherheitslücken führen. Eine formalisierte Freigabe kann die Integrität und Verfügbarkeit von Systemen schützen, indem sie die Einhaltung der etablierten Verfahren und Regelungen für Änderungen und Tests sicherstellt.

Links

related: TEST.1.1 Verfahren und Regelungen

Control: DEV.7.1 - Sichere Bereitstellung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.7 Bereitstellung und Betrieb
UUID: 8a9a1a39-1ead-4c8a-bcda-5bf14c970df1
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Entwicklung SOLLTE die Bereitstellung im Einklang mit den entsprechenden Verfahren und Regelungen für Änderungen und Tests verankern.

Guidance

Die Bereitstellung ist der Prozessschritt, durch den eine neu entwickelte oder geänderte Softwareversion, ein Dienst oder ein System in die Produktionsumgebung überführt und dort aktiv für die Endnutzer oder Geschäftsprozesse zugänglich gemacht wird. Die Anforderungen aus der Praktik Änderungen und Tests (also zum Change Management) betreffen auch die Bereitstellung. Eine geordnete Bereitstellung minimiert das Risiko, dass ungetestete oder nicht genehmigte Änderungen in Betrieb gehen, was sonst zu Dienstunterbrechungen, Datenverlust oder der Ausnutzung von Sicherheitslücken führen könnte.

Links

related: TEST.1.1 Verfahren und Regelungen

Control: DEV.7.2 - Zertifikatsmonitoring

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: DEV.7 Bereitstellung und Betrieb
UUID: 61b03a52-d68e-4bda-b715-91cac2e70e87
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Entwicklung für Anwendungen SOLLTE die Ausstellung neuer Zertifikate für die von der Anwendung verwendeten Domains überwachen.

Guidance

Anwendungen die über das Netz kommunizieren nutzen typischerweise X.509-Zertifikate zur Authentifizierung (z.B. per TLS). Die Ausstellung neuer Zertifikate bei Zertifizierungsstellen kann ein Angriffsversuch Dritter sein, die vorgeben wollen die Anwendung zu betreiben. Dies kann mittels Certificate Transparency automatisiert werden.

Control: GEB.1.1 - Verfahren und Regelungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.1 Grundlagen
UUID: 4b6dfe84-071c-4b8a-94d9-83faa99b8ee8
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GEB.1.1.1 Dokumentation
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.1.1.3 Bekanntgabe

Statement

Gebäudemanagement MUSS Verfahren und Regelungen zum physischen Schutz von Standorten, an denen schützenswerte Informationen verarbeitet oder gespeichert werden, verankern.

Guidance

Ein Verfahren zum Gebäudemanagement stellt sicher, dass die zum Betrieb von Geschäftsprozessen erforderliche Infrastruktur vorhanden ist und schützt Zielobjekte dort vor dem Zugriff Unbefugter und vor Elementarschäden wie Feuer, Wind und Wetter. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Control: GEB.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.1 Grundlagen
Übergeordnetes Control:
GEB.1.1 Verfahren und Regelungen
UUID: 347d743d-a919-4397-9951-703303e6c613
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: GEB.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.1 Grundlagen

Übergeordnetes Control:

GEB.1.1 Verfahren und Regelungen

UUID: 3a95d0e2-6727-4b21-bf13-24d08781e26b

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, geb.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es, die Zuweisung anhand von Rollen (z. B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: GEB.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.1 Grundlagen

Übergeordnetes Control:

GEB.1.1 Verfahren und Regelungen

UUID: 474e316d-e4e3-4ff2-840f-c4a271f7be88

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: GEB.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.1 Grundlagen

UUID: 01900ff7-5532-4e7d-a8d3-999e46bf3d29

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement MUSS die Verfahren und Regelungen {{ insert: param, geb.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: GEB.1.3 - Autorisierung von Standorten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.1 Grundlagen
UUID: b25c2cfd-431c-4996-9041-47ae0e516432
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GEB.1.3.1 Abnahme von Standorten

Statement

Gebäudemanagement für Standorte SOLLTE Standorte für die Stationierung von Assets autorisieren.

Guidance

Die gezielte Autorisierung von Standorten für die Stationierung von Assets kann dazu beitragen, dass Informationen und Systeme nur an physischen Orten verarbeitet oder aufbewahrt werden, die zuvor auf ihre Sicherheitsanforderungen hin geprüft wurden. So kann beispielsweise verhindert werden, dass sensible Server in unkontrollierten Räumen ohne Zutrittskontrolle oder redundante Stromversorgung betrieben werden – ein Fehlen dieser Maßnahmen könnte im Ernstfall zu Datenverlust bei einem Kurzschluss oder unbefugtem Zugriff durch Dritte führen. Ebenso kann die Prüfung und Freigabe durch eine zuständige Rolle dafür sorgen, dass neue Außenstellen erst dann in den Betrieb gehen, wenn etwa Brandmelde-, Videoüberwachungs- oder Netzwerksicherheitsanforderungen erfüllt sind; andernfalls könnte eine unerkannte technische Schwachstelle in einem Zweigstellenrechner dazu führen, dass Schadcode sich ins gesamte Unternehmensnetz ausbreitet. Auch bei der Nutzung von Cloud- oder Colocation-Rechenzentren kann eine formale Freigabe sicherstellen, dass vorab vertraglich vereinbarte Sicherheits- und Compliance-Anforderungen – wie beispielsweise ISO-27001-Zertifizierung oder Verschlüsselung im Ruhezustand – tatsächlich gegeben sind, andernfalls könnte es zu Datenschutzverletzungen oder Regulierungsstrafen kommen. Zur praktischen Umsetzung kann ein Standort-Freigabeprozess definiert werden, der folgende Elemente enthält: eine Checkliste für physische Sicherheitskriterien (Zutrittskontrolle, Umwelt- und Brandschutz), eine technische Abnahmematrix (Netzwerksegmentie-

rung, Monitoring, Backup-Anbindung) sowie die Benennung einer verantwortlichen Person oder Rolle, die das Go-No-Go-Entscheidungsrecht hält. Bei Änderungen am Standort oder an den Assets kann diese Rolle regelmäßige Reviews anstoßen, wodurch nachträgliche Kontrollen möglich werden. Automatisierte Workflow-Tools können dabei unterstützen, Prüf- und Genehmigungsschritte nachvollziehbar zu dokumentieren und Eskalationspfade abzubilden.

Links

related: ASST.3.10 Autorisierung von Datenlokalationen

Control: GEB.1.3.1 - Abnahme von Standorten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.1 Grundlagen

Übergeordnetes Control:

GEB.1.3 Autorisierung von Standorten

UUID: 127de8f4-d265-4b66-83a1-a9d2c5113a17

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE Standorte vor Autorisierung anhand von {{ insert: param, geb.1.3.1-prm1 }} testen.

Guidance

Eine Abnahme anhand von Sicherheitskriterien stellt sicher, dass Sicherheitsaspekte bereits in der Planungsphase vor der ersten Nutzung eines Standortes berücksichtigt werden. Die Kriterien ergeben sich aus den weiteren Anforderungen dieser Praktik, sowie aus Compliance-Verpflichtungen. Denken Sie hierbei an den Schutz vor Elementarschäden, den Zutrittsschutz, den voraussichtlichen Versorgungsbedarf mit Strom, Netzanbindung, eine strukturierte Verkabelung und Wasserleitungen, sowie die Gebäudeautomatisierung. Kann z.B. mit Building Information Modeling (BIM) umgesetzt werden. Wurde ein Standort bereits bezogen, so gilt die Anforderung als umgesetzt, wenn die Erfüllung der Kriterien nachträglich (z.B. durch eine Begehung) sichergestellt wurde.

Control: GEB.1.4 - Exponierte Bereiche

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.1 Grundlagen
UUID: d5806bcc-a072-4a2e-8fd1-2ff0d30e96d6
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE schützenswerte Assets oder zugehörige Infrastrukturen nur außerhalb exponierter oder besonders gefährdeter Bereiche platzieren.

Guidance

Wenn schützenswerte Räume wie Datenträgerarchive, Hostsysteme oder zentrale Infrastrukturen wie die Strom- und Netzversorgung in besonders exponierten Gebäudeteilen oder unter freiem Himmel lokalisiert werden, erhöht dies das Risiko für Ausfälle. Beispiele für gefährdete Bereiche sind ein überflutungsgefährdeter Keller, an der Gebäudekante direkt neben einer Bundesstraße oder an einer von Außen leicht einsehbaren Stelle. Welche Bereiche gefährdet sind kann oft von lokalen oder nationalen staatlichen Stellen bezogen werden. Wenn der gesamte Standort besonders exponiert oder gefährdet ist, kann dies nur durch die Nutzung anderer Standorte umgesetzt werden.

Control: GEB.1.5 - Strukturpläne

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.1 Grundlagen
UUID: e51b3488-c9ce-4709-b2d1-c995eee3336a
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE Strukturpläne dokumentieren.

Guidance

Strukturpläne enthalten Grundrisse und Verlaufswege für physische Perimeter oder Versorgungseinrichtungen. Beispielsweise enthalten Gebäudepläne üblicherweise Zeichnungen der einzelnen Etagen und der Gebäudestrukturen darin. Diese Pläne sind hilfreich um Schwachstellen oder Störquellen aufzudecken und zielgerichtet zu behandeln. Dazu gehören Versorgungsleitungen, Netzanschlüsse, sowie Aus- und Zugänge für den regulären Betrieb und für Notfälle.

Control: GEB.2.1 - Installation von Perimetern

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.2 Physischer Perimeter
UUID: b801be80-6655-485d-bba9-3f1ca8953755
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE Sicherheitsperimeter installieren.

Guidance

Die Installation physischer Sicherheitsperimeter dient dem grundlegenden Schutz von Informationsressourcen und kritischer Infrastruktur vor unbefugtem Zugriff und physischen Bedrohungen. Ein effektiver Sicherheitsperimeter kann als mehrschichtige Barriere fungieren, die sensible Bereiche vor verschiedenen Risiken wie Einbruch, Diebstahl oder Sabotage schützt. Ohne angemessene physische Sicherheitsmaßnahmen könnten unbefugte Personen z.B. Zugang zu Serverräumen erlangen und dort Datenträger entwenden, Schadcode installieren oder Hardwarekomponenten manipulieren. Auch Naturereignisse wie Überschwemmungen oder Brände könnten ohne geeignete Perimeter leichter zu Datenverlust oder Betriebsunterbrechungen führen. Bei der Implementierung physischer Sicherheitsperimeter kann eine Kombination verschiedener Sicherheitsebenen erwogen werden, beginnend mit äußeren Barrieren wie Zäunen, Schranken oder gesicherten Eingangsbereichen, die den Zugang zum Gelände regulieren. Im Gebäudeinneren können Zugangskontrollsysteme mit unterschiedlichen Authentifizierungsmethoden (Chipkarten, biometrische Verfahren, PIN-Codes) eingesetzt werden, um den Zutritt zu sensiblen Bereichen auf autorisierte Mitarbeiter zu beschränken. Die Effektivität dieser Maßnahmen kann durch ergänzende Systeme wie Videoüberwachung, Alarmanlagen oder Bewegungsmelder verstärkt werden, wobei ein ausgewogenes Verhältnis zwischen Sicherheitsanforderungen und Praktikabilität für den Arbeitsalltag zu finden ist. Bei der Planung kann eine Risikobewertung helfen, um festzulegen, welche Bereiche besonders schutzbedürftig sind und entsprechend abgesichert werden, etwa durch Sicherheitszonen mit gestaffelten Zugangsrechten oder spezielle Brandschutzbereiche für kritische IT-Infrastruktur.

Control: GEB.2.2 - Dokumentation öffentlicher Bereiche

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.2 Physischer Perimeter
UUID: 1147b820-ea85-4137-aad4-d7a5462baaaa
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Gebäude SOLLTE Bereiche, die ohne Authentifizierung zugänglich sind, mit Begründung dokumentieren.

Guidance

Gebäude sind als stabiler und klar ersichtlicher Sicherheitsperimeter besonders geeignet. Viele Institutionen benötigen für ihre Aufgaben jedoch Bereiche, die ohne Authentifizierung zugänglich sind, z.B. Empfangs- oder Lieferzonen, Bürgerbüros, Kundenräume. Hierdurch könnte es leicht zu versehentlichen oder zielgerichteten Schäden an Assets, unbefugten Zutritten oder dem Abfluss vertraulicher Daten kommen. Daher ist es sinnvoll, diese Bereiche zu dokumentieren und die Gründe für ihre Bereitstellung nachzuhalten, um sicherzustellen, dass der Sicherheitsperimeter auch im Gebäude korrekt verläuft und geschützt ist.

Control: GEB.2.3 - Erkundung aus dem öffentlichen Raum

Tag: "Recon"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.2 Physischer Perimeter

UUID: 11a3fb3c-b21e-4d11-b9d1-11ad23cea2b1

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE Hör- und Sehschutz gegen den öffentlichen Raum testen.

Guidance

Erkundung aus dem öffentlichen Raum ist die systematische Sammlung von Informationen, die ausschließlich von öffentlich zugänglichen Bereichen aus durchgeführt wird, um die Schwachstellen eines Standortes zu bewerten, ohne in Sperrzonen einzudringen. Hierbei könnten z.B. Sicherheitssysteme, Zugangspunkte und Personalroutinen ausgeforscht werden; Gespräche in offenen Bereichen wie Lobbys oder Raucherzonen aufgezeichnet werden, in denen sensible Informationen versehentlich preisgegeben werden könnten; zusätzliche Techniken wie das Durchsuchen von Mülltonnen (Dumpster Diving), drahtlose Signalanalyse und Social Engineering von öffentlichen Aussichtspunkten aus könnten zahlreiche Informationen ungewollt preisgeben. Hierbei sind sowohl Einblicke von öffentlichen Straßen, Plätzen oder sonstigen Flächen außerhalb des Perimeters relevant, als auch die Erkundung von höher gelegenen Positionen, z.B. gegenüberliegenden Hochhäusern oder Flugmaschinen wie Drohnen, bis hin zu Satellitenaufnahmen. Maßnahmen können z.B. Begehungen des Perimeters oder von höher gelegenen Räumlichkeiten, die Auswertung öffentlicher Satellitenbilder oder eigene Drohnenflüge sein. Kann auch durch einen physischen Penetration Test sichergestellt werden.

Control: GEB.2.4 - Elektromagnetische Abschirmung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.2 Physischer Perimeter
UUID: 9835ce0d-94a4-4acc-96cf-489f20750808
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN die Elektromagnetische Abschirmung testen.

Guidance

Die elektromagnetische Abschirmung von Standorten dient dem Schutz vertraulicher Informationen vor unbefugter Erfassung durch elektromagnetische Abstrahlung. Computersysteme, Netzwerkgeräte und andere elektronische Ausrüstungen senden elektromagnetische Signale aus, die außerhalb des Gebäudes abgefangen werden könnten. Dies könnte zur ungewollten Offenlegung sensibler Daten führen, wie etwa bei Van-Eck-Phreaking, bei dem Bildschirminhalte aus der Ferne rekonstruiert werden können. Ein Angreifer könnte beispielsweise mit speziellem Equipment die ausgesendeten Signale eines Monitors oder Netzkabels abfangen und daraus Passwörter, Finanzdaten oder Geschäftsgeheimnisse extrahieren, ohne physischen Zugang zum Gebäude zu benötigen. Bei der Umsetzung kann eine mehrstufige Strategie verfolgt werden. Die Räumlichkeiten können mit speziellen abschirmenden Materialien wie metallischen Geweben, leitfähigen Farben oder Folienbeschichtungen ausgekleidet werden, die als "Faradayscher Käfig" wirken. Fenster können mit metallbeschichteten Gläsern oder speziellen Folien versehen werden, die elektromagnetische Strahlung blockieren. Sicherheitsbereiche können nach Sensitivität der dort verarbeiteten Daten in verschiedene Zonen eingeteilt werden, wobei nur die kritischsten Bereiche vollständig abgeschirmt werden.

Control: GEB.3.1 - Überwachung von Zutrittspunkten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.3 Physischer Zutritt

UUID: 0fcd1c71-d16d-4531-94f0-6023bf19b3e9

Aufwand: 3

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände

Statement

Gebäudemanagement für Standorte SOLLTE Zutrittspunkte auf unbefugte Zutritte überwachen.

Guidance

Eine kontinuierliche Überwachung der Zugangsmöglichkeiten, z.B. verschlossener Türen und Fenster an der Gebäudeaußenseite, verhindert, dass sich Unbefugte Zutritt verschaffen. Der hierzu erforderliche Personalbedarf hängt von Gebäudegröße und Schutzbedarf ab. Um den für eine kontinuierliche Überwachung erforderlichen Personalbedarf wirtschaftlich zu decken ist es zweckmäßig, Unterstützungssysteme wie Videokameras oder Einbruchsalarme einzusetzen. Die Umsetzung kann z.B. erfolgen durch Umzäunung, Kameraüberwachung, Bewegungsmelder und einen Wachdienst.

Control: GEB.3.1.1 - Videoüberwachung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.3 Physischer Zutritt

Übergeordnetes Control:

GEB.3.1 Überwachung von Zutrittspunkten

UUID: 842a359b-f8fe-4c81-82e3-50d949dc4bbd

Aufwand: 4

Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN Zutritte per Video überwachen.

Guidance

Die Auswertung der Videoaufzeichnungen kann je nach Risikoprofil und Geschäftsprozessen anlassbezogen und stichpunktartig, kontinuierlich durch Wachpersonal oder durch Verwendung von KI-Videoanalyse, z.B. zur Erkennung von „tail-gating“ oder zurückgelassenen Gegenständen, erfolgen. Hier besteht ein enger Zusammenhang zu Compliance-Verpflichtungen zum Datenschutz (z.B. Informationspflichten), insbesondere im öffentlichen Raum.

Control: GEB.3.1.2 - Überprüfung mitgeführter Gegenstände

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.3 Physischer Zutritt
Übergeordnetes Control:
GEB.3.1 Überwachung von Zutrittspunkten
UUID: 012da5ef-7ee9-4bf2-bb39-eebd2ae7b17b
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN das Mitführen von Gegenständen überwachen.

Guidance

Die Überwachung des Mitführens von Gegenständen (z.B. am Empfang) kann an Standorten mit besonderen Sicherheitsrisiken dazu beitragen, unerlaubtes Einschleusen von Diebstahlwerkzeugen, schädlichen Datenträgern oder gefährlichen Gegenständen zu verhindern. Durch eine stichprobenartige Kontrolle von Taschen, Rucksäcken oder Paketlieferungen kann erkannt werden, ob unbeaufsichtigt Materialien wie USB-Sticks, externe Festplatten oder andere Speichermedien ins Gebäude gelangen, die vertrauliche Informationen unbemerkt abziehen könnten. Ebenso kann das Verfahren auf Metallgegenstände oder Flüssigkeiten ausgeweitet werden, um das Risiko von Diebstahl, Sabotage oder physischen Angriffen zu reduzieren. Beispielsweise könnte ein nicht registrierter Besucher eine Videokamera einschleusen und damit sensible Produktionsprozesse filmen, oder ein unbeaufsichtigter Paketbote könnte Malware-belastete Hardware mitliefern – durch die Kontrolle am Empfang kann solchen Szenarien vorgebeugt werden. Die Umsetzung kann stichprobenartig oder durchgehend erfolgen: Einmal täglich kann eine Auswahl von Taschen stichprobenartig geöffnet und mit einer Liste erlaubter Gegenstände abgeglichen werden; hierbei kann ein einfaches Check-in-Formular eingesetzt werden, in das Besucherinnen und Besucher freiwillig ihre mitgeführten Gegenstände eintragen können. Ergänzend kann ein abschließender Scan mit einem Metalldetektor oder ein kurzer Blick in unverschlossene Fächer erfolgen, was den Aufwand gering hält und den Durchfluss am Empfang weniger beeinträchtigt.

Hier besteht ein enger Bezug zu den Persönlichkeitsrechten der Betroffenen. Eine klar kommunizierte Hausordnung oder ein Informationsblatt kann helfen die Maßnahmen zu erläutern, sodass Besucher erkennen, dass die Kontrollen dem Schutz aller Beteiligten dienen. Gegenstände, die vorübergehend nicht mitgeführt werden dürfen, können gegen Quittung sicher deponiert werden. Auf diese Weise entsteht eine nachvollziehbare Historie, die im Fall eines Vorfalls als Nachweis dienen kann.

Control: GEB.3.2 - Anmelde- und Empfangsbereiche

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.3 Physischer Zutritt
UUID: 46bec5e4-88b9-45d1-ae2a-56b534ad94ad
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE Anmelde- und Empfangsbereiche installieren.

Guidance

Die Einrichtung definierter Anmelde- und Empfangsbereiche dient der Kontrolle des physischen Zugangs zum Standort. Diese Bereiche können als erste Verteidigungslinie fungieren, indem sie einen klaren Trennpunkt zwischen öffentlichen und geschützten Zonen etablieren. Durch die strukturierte Implementierung solcher Bereiche können unbefugte Zutritte vermieden werden, die andernfalls zu Sicherheitsverletzungen führen könnten. Ein fehlendes oder unzureichendes Empfangsmanagement könnte beispielsweise dazu führen, dass nicht autorisierte Personen unkontrolliert Zugang zu sensiblen Bereichen erhalten, vertrauliche Dokumente einsehen, Firmengeheimnisse entwenden oder sogar physische Sabotageakte durchführen. Bei der Umsetzung können verschiedene Ansätze verfolgt werden, die je nach Institution und sonstigen angewendeten Sicherheitsanforderungen variieren. Der Anmeldebereich kann mit einem digitalen Besuchermanagementsystem ausgestattet werden, welches die Authentifizierung und Registrierung von Besuchern erleichtert und eine lückenlose Dokumentation ermöglicht. Ergänzend hierzu kann die räumliche Gestaltung durch klare Beschilderung, bauliche Trennung mittels Schranken oder Drehkreuzen sowie die strategische Positionierung des Empfangsbereichs optimiert werden. Zudem kann die Schulung des Empfangspersonals in Sicherheitsprotokollen und die Einführung von Besucherausweisen mit temporären Zugriffsrechten die Effektivität dieser Sicherheitsmaßnahme verstärken. Die Integration mit anderen Sicherheitssystemen wie Videoüberwachung oder elektronischen Zutrittskontrollsystemen kann ebenfalls in Betracht gezogen werden, um ein umfassendes Sicherheitskonzept zu gewährleisten.

Control: GEB.3.3 - Authentifizierung vor Zutritt

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.3 Physischer Zutritt
UUID: 5ac8362d-3e6b-4922-8e12-66a80d8d883b
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.3.3 Besucheranmeldung

Statement

Gebäudemanagement für Standorte SOLLTE Zutritte im Einklang mit den Festlegungen des Identitäts- und Berechtigungsmanagements authentifizieren.

Guidance

Der Zweck der Authentifizierung von Zutritten liegt in der grundlegenden Absicherung physischer Zugänge gegen unbefugte Nutzung. Dies kann verhindern, dass Unbefugte Zugang zu sensiblen Bereichen oder Informationen erhalten. Ohne angemessene Zutrittskontrolle könnte beispielsweise ein nicht autorisierter Besucher in einen Serverraum gelangen und dort Hardware manipulieren, Datenträger entwenden oder Netzkabel umstecken. Ebenso könnte ein ehemaliger Mitarbeiter ohne wirksame Authentifizierung weiterhin auf Systeme zugreifen und vertrauliche Daten entwenden oder geschäftskritische Informationen kompromittieren. Bei der Umsetzung kann ein mehrstufiger Ansatz verfolgt werden, der verschiedene Authentifizierungsfaktoren kombiniert: Wissen (z.B. PIN-Codes, Passwörter), Besitz (z.B. Chipkarten, Tokens, Schlüssel) und biometrische Merkmale (z.B. Fingerabdruck, Gesichtserkennung). Die Stärke der Authentifizierung kann dabei an die Schutzbedürftigkeit des zu schützenden Bereichs angepasst werden – für hochsensible Bereiche können Zwei- oder Mehr-Faktor-Authentifizierungen implementiert werden. Als ergänzende Maßnahme kann ein Monitoring der Zutrittsereignisse eingerichtet werden, das ungewöhnliche Zugriffsversuche erkennt und meldet. Zudem kann die regelmäßige Überprüfung und Aktualisierung der Zutrittsberechtigungen dazu beitragen, dass nur aktuell berechtigte Personen Zugang erhalten. Die Formulierung "im Einklang

mit den Festlegungen des Identitäts- und Berechtigungsmanagements“ bedeutet, dass die Authentifizierung so erfolgt, wie in der Praktik IDM festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist.

Links

related: BER.6.4 Mehr-Faktor-Authentisierung am Perimeter

related: DET.3.1.1 Authentifizierungen

Control: GEB.3.3.1 - Zugangskontrollanlage

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.3 Physischer Zutritt

Übergeordnetes Control:

GEB.3.3 Authentifizierung vor Zutritt

UUID: 5bc938de-7123-4793-8ba4-3183c2264acf

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN Zutritte durch {{ insert: param, geb.3.3.1-prm1 }} im Einklang mit den Festlegungen des Identitäts- und Berechtigungsmanagements authentifizieren.

Guidance

Der Einsatz einer automatischen Zugangskontrollanlage zur Authentifizierung von Personen dient primär dem Schutz von sensiblen Bereichen, vertraulichen Informationen und kritischer Infrastruktur. Durch diese Maßnahme kann sichergestellt werden, dass nur autorisierte Personen Zutritt zu geschützten Bereichen erhalten, wodurch das Risiko von Industriespionage, Datendiebstahl oder Sabotage erheblich reduziert werden kann. Ohne eine solche Kontrolle könnte es beispielsweise zu unbefugtem Zutritt durch Fremde kommen, die sich als Mitarbeiter ausgeben, oder zu einem "Tailgating"-Vorfall, bei dem Unbefugte autorisierten Personen unbemerkt folgen und sich so Zugang verschaffen. Bei der Implementierung einer automatischen Zugangskontrollanlage kann eine mehrfaktorielle Authentifizierung in Betracht gezogen werden, die auf einer Kombination aus Besitz (z.B. Chipkarte, Token), Wissen (PIN-Code, Passwort) und/oder biometrischen Merkmalen (Fingerabdruck, Gesichtserkennung) basiert. Die Zugangsrechte können granular nach Personengruppen, Zeitfenstern und Bereichen differenziert werden, was die Sicherheit weiter erhöht. Für eine effektive Umsetzung kann die regelmäßige Überprüfung der Protokolle der Zugangskontrollanlage auf ungewöhnliche Aktivitäten hilfreich sein, ebenso wie regelmäßige Sensibilisierungsmaßnahmen für Mitarbeiter bezüglich der korrekten Nutzung der Anlage und der Vermeidung von Sicherheitslücken wie dem gemeinsamen Nutzen von Zugangsmitteln. Die Formulierung "im Einklang mit den Festlegungen des Identitäts- und Berechtigungsmanagements" bedeutet, dass die

Authentifizierung so erfolgt, wie in der Praktik IDM festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist.

Control: GEB.3.3.2 - Dokumentation von Zutritten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.3 Physischer Zutritt
Übergeordnetes Control:
GEB.3.3 Authentifizierung vor Zutritt
UUID: a0b89dd6-4aec-41bd-b4bf-01e704072ed5
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN Zutritte und Austritte mit Identität und Zeitpunkt dokumentieren.

Guidance

Im Kontext dieser Anforderung bedeutet Identität die eindeutige Zuordnung einer Person zu einem Zutritt oder Austritt, etwa durch Namensangabe, Personalnummer oder ein elektronisches Identifikationsmerkmal wie eine Chipkarte. Der Zeitpunkt ist die präzise Erfassung von Datum und Uhrzeit, an dem ein Zutritts- oder Austrittsvorgang stattfindet. Diese beiden Informationen können so kombiniert werden, dass nachvollziehbar wird, wer zu welchem Zeitpunkt ein Gebäude oder einen bestimmten Bereich betreten oder verlassen hat. Dies gilt sowohl für Mitarbeitende als auch für Besuchende. Für die Umsetzung kann eine Institution z.B. elektronische Zutrittskontrollsysteme einsetzen, die beim Karten- oder Transpondereinsatz automatisch Identität und Zeitpunkt speichern. Auch ein biometrisches Terminal kann die Anforderung erfüllen, wenn es die Daten mit Zeitstempel dokumentiert. Als einfachere Variante kann ein digital geführtes Besucherbuch genutzt werden, in das Namen und Uhrzeit bei Ein- und Austritt eingetragen werden. Eine Institution kann ergänzend festlegen, dass Daten regelmäßig exportiert und manipulationssicher archiviert werden, sodass spätere Prüfungen möglich sind. Hilfreich kann zudem sein, bei Zutrittskarten eine Schnittstelle zur HR-Verwaltung einzurichten, damit Identitäten bei Austritt von Mitarbeitenden automatisch deaktiviert werden und die Dokumentation lückenfrei bleibt. Diese Protokolle dienen als wichtige Grundlage für forensische Analysen und können zur Aufklärung von Diebstahl, Sabotage oder unbefugtem Datenzugriff beitragen.

Control: GEB.3.3.3 - Besucheranmeldung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.3 Physischer Zutritt

Übergeordnetes Control:

GEB.3.3 Authentifizierung vor Zutritt

UUID: ce537201-8949-41a6-855b-c7671d226853

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE Besuche durch {{ insert: param, geb.3.3.3-prm1 }} autorisieren.

Guidance

Der Begriff „Besuche“ bezeichnet in diesem Kontext physische Zutritte externer Personen wie Dienstleister, Lieferanten oder Gäste, die sich nicht dauerhaft im Gebäude aufhalten und daher besondere Anforderungen an die Zutrittsregelung stellen. Die Autorisierung von Besuchen meint hier, dass ein Besuch vor Betreten der Räumlichkeiten durch eine verantwortliche Stelle vorab geprüft, freigegeben und dokumentiert wird – dies kann formell (z. B. digitaler Antrag) oder informell (z. B. Genehmigung per E-Mail) erfolgen. Der Zweck dieser Vorschrift liegt darin, unkontrollierten Zutritt und damit verbundene Risiken zu verhindern: Unangemeldete Besucher könnten beispielsweise unbefugt vertrauliche Informationen einsehen oder technische Anlagen manipulieren. Eine klare Autorisierung kann dagegen sicherstellen, dass nur berechtigte Personen Zutritt erhalten und gleichzeitig nachvollziehbar bleibt, wer sich wann und aus welchem Grund im Gebäude aufgehalten hat. Für die Umsetzung kann eine Institution etwa ein digitales Besuchermanagementsystem einsetzen, das Einladungen erstellt, Genehmigungen einholt und Einlasscodes zeitlich begrenzt vergibt. Alternativ kann ein analoges Verfahren genutzt werden, bei dem Besucherausweise am Empfang ausgegeben und gegen Vorlage eines Ausweisdokuments registriert werden. Um Warteschlangen am Empfang zu verringern, kann die Autorisierung des Besuchs auch im Voraus abgewickelt werden, z.B. über eine mobile QR-Vorregistrierung mit Verifizierung der Identität über den digitalen Ausweis. Eine einfache, aber wirksame Maßnahme kann auch die Vorabstimmung über Besucherlisten sein, die tagesaktuell an Empfang oder Sicherheitspersonal über-

mittelt werden.

Control: GEB.3.4 - Berechtigungsmarkierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.3 Physischer Zutritt
UUID: 63985f87-b50e-4c73-9962-f026b5e6d840
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Nutzende von Standorten KANN zum Tragen von gut sichtbaren Berechtigungsmarkierungen innerhalb des Sicherheitsperimeters anweisen.

Guidance

Unter Berechtigungsmarkierungen sind physische Kennzeichen wie Ausweise, Badges, Namensschilder oder Kartenhalter zu verstehen, die eine eindeutige Zuordnung einer Person zu ihrer Zugangsberechtigung ermöglichen. Sie können zudem farblich, mit Fotos oder Barcodes gestaltet sein, um unterschiedliche Zutrittsrechte auf einfache Weise erkennbar zu machen. Der Sinn einer solchen Vorgabe liegt darin, dass unbefugte Personen leichter auffallen und damit potenzielle Gefährdungen frühzeitig erkannt werden. So könnte ein Vorfall entstehen, wenn sich Unbefugte unbemerkt Zutritt zu kritischen Bereichen verschaffen, indem sie sich in einer Gruppe mit berechtigten Personen bewegen. Dagegen kann eine sichtbare Berechtigungsmarkierung helfen, Anomalien rasch zu erkennen und eine unauffällige, aber effektive Zugangskontrolle im Alltag zu unterstützen. Dies gilt sowohl für Mitarbeitende als auch für Besuchende. Für die Umsetzung kann eine Institution beispielsweise darauf achten, dass Markierungen gut sichtbar an Kleidung oder einem Schlüsselband getragen werden können. Sie kann auch unterschiedliche Farbkennungen nutzen, um klar zwischen Besuchenden, Dienstleistern und Mitarbeitenden zu unterscheiden. Für Besuche kann ein einfaches Verfahren eingeführt werden, mit dem Besuchende beim Betreten des Gebäudes ein temporäres Ausweisdokument erhalten, das bei Verlassen wieder zurückzugeben ist. Um die Akzeptanz zu erhöhen, kann das Gebäudemanagement praktikable Trageoptionen wie Clips, Lanyards oder magnetische Halterungen bereitstellen, die den Alltag nicht behindern.

Control: GEB.3.5 - Einbruchhemmung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.3 Physischer Zutritt
UUID: 02f648cd-8aec-4bfb-b751-dab8974d874c
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN einbruchhemmende Bauteile nach {{ insert: param, geb.3.5-prm1 }} installieren.

Guidance

Befinden sich am Standort Assets oder Geschäftsprozesse mit erhöhtem Schutzbedarf, so ist es sinnvoll, diese auch gegen hartnäckigere Einbruchsversuche zu schützen, z.B. größere Serverräume oder Datenträgerarchive, sowie Standorte im Fokus der Öffentlichkeit oder von ideologischen Gewalttätern. Die passenden Maßnahmen richten sich nach dem Risikoprofil der zu schützenden Assets, sowie der potenziellen Täter. So kann der Einbau rundum einbruchssicherer Bauteile wie Wände und Türen nach DIN EN 1627 RC3 oder besser sinnvoll sein. Für massive Bedrohungen von Außen bieten sich Poller oder hydraulische Straßensperren, ausgelegt für ein bestimmtes Gewicht bei einer bestimmten Geschwindigkeit, an. Die Anforderung ist auch dann erfüllt, wenn der Standort bereits von Dritten nach Normen wie DIN EN 1627 RC3 erbaut und abgenommen wurde.

Control: GEB.3.6 - Einbruchmeldeanlagen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.3 Physischer Zutritt
UUID: 01193c74-a4fc-4669-816c-651fcdca362e
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN Einbrüche nach {{ insert: param, geb.3.6-prm1 }} überwachen.

Guidance

Für Standorte mit erhöhtem Schutzbedarf ist eine Einbruchmeldeanlage sinnvoll. Die Anforderung gilt erst dann als umgesetzt, wenn alle vorhandenen Türen, Fenster und sonstige geschützte Öffnungen über die Einbruchmeldeanlage auf Verschluss, Verriegelung und Durchbruch überwacht werden.

Control: GEB.3.7 - Kontrolle der Zutrittskontrolle

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.3 Physischer Zutritt
UUID: 407e3436-9719-4c45-a009-183c7818d376
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE die angewendeten Zutrittskontrollmaßnahmen {{ insert: param, geb.3.7-prm1 }} überprüfen.

Guidance

Die Funktionsfähigkeit von Zugangskontrollen wie Wachdiensten und Schließanlagen ist essenziell, um den Zutritt Unbefugter wirksam verhindern zu können. Regelmäßige Überprüfungen können beispielsweise durch angekündigte oder unangekündigte Rundgänge, die stichprobenartige Auswertung von Kameraaufzeichnungen und Logbüchern oder die Analyse verschiedener Kennzahlen erfolgen.

Control: GEB.4.1 - Einrichtung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.4 Sicherheitsbereiche
UUID: b545c003-c5ea-4d18-bcf5-d5651f9eba7c
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN geschlossene Sicherheitsbereiche installieren.

Guidance

Ein Sicherheitsbereich ist ein klar abgegrenzter physischer Raum, für die ein eigener Perimeter eingerichtet wird und dessen Betreten ausschließlich autorisiertem Personal oder unter engen Voraussetzungen gestattet wird. Solche Bereiche dienen dem Schutz von Personen, Anlagen, sensiblen Informationen oder betriebskritischen Prozessen. Standorte oder Teile eines Standortes mit erhöhtem Schutzbedarf können so vor unbefugten Eingriffen geschützt werden, z.B. Serverräume, Arbeitsplätze für Administrierende oder die Institutionsleitung. Zur Umsetzung können z.B. Zutrittskontrollanlagen oder Bewachung eingesetzt werden. Wenn es sich um Hochsicherheitsbereiche handelt, kann der Zutritt mit einem Mehr-Faktor-Verfahren (z.B. Smartcard mit PIN) davor geschützt werden, dass Unbefugte sich durch entwendete Schlüssel oder Authentifizierungstoken Zugang verschaffen.

Control: GEB.4.2 - Gesonderte Autorisierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.4 Sicherheitsbereiche
UUID: 94d3b9c2-9040-4bb6-9153-54d5c488a085
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN die Zutrittsberechtigung zu diesem Sicherheitsbereich durch {{ insert: param, geb.4.2-prm1 }} autorisieren.

Guidance

Eine zuständige Person oder Rolle kann beispielsweise die Sicherheitsbeauftragte, der Standortleiter, eine definierte Facility-Management-Rolle oder ein zentrales Berechtigungsmanagement sein. Die Anforderung bedeutet, dass der Zutritt zu einem definierten Sicherheitsbereich – also einem räumlich abgegrenzten Bereich, in dem sensible Werte wie IT-Systeme, Netzwerktechnik oder vertrauliche Unterlagen geschützt werden – nicht automatisch, sondern nur durch eine bewusste Autorisierung erteilt werden kann. Sinn und Zweck dieser Regelung liegt darin, unbefugte Zugriffe zu verhindern, die etwa durch unkontrollierte Weitergabe von Schlüsseln oder Zutrittskarten entstehen könnten. Ein Vorfall könnte sein, dass ein ehemaliger Mitarbeiter noch Zugang erhält und vertrauliche Unterlagen entwendet; durch eine klare Autorisierung kann sichergestellt werden, dass nur tatsächlich berechtigte Personen Zutritt erhalten. Zur Umsetzung kann eine Institution ein abgestuftes Verfahren einrichten, bei dem die Autorisierung dokumentiert und nachvollziehbar erfolgt. Dies kann z. B. durch ein zentrales elektronisches Zutrittskontrollsystem erfolgen, bei dem eine zuständige Rolle die Rechte gezielt freischalten und zeitlich begrenzen kann. Auch eine papierbasierte Liste mit Zutrittsberechtigungen kann sinnvoll sein, solange sie regelmäßig geprüft und aktualisiert wird. Praktisch hilfreich kann es sein, wenn (1) jede Berechtigung mit einem Enddatum versehen wird, (2) der Widerruf von Berechtigungen in die Prozesse für Personaländerungen integriert wird, und (3) das Gebäudemanagement regelmäßig Berichte über aktive Berechtigungen an die zuständige Person liefert. So kann sichergestellt werden, dass Zutrittsrechte nicht veralten und jederzeit eine klare Zuordnung von Personen zu Sicherheitsbereichen besteht.

Control: GEB.4.3 - Schleusen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.4 Sicherheitsbereiche
UUID: b524ac99-b28f-486c-8269-3e589f21cc2d
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN Schleusen an Zugangspunkten installieren.

Guidance

Eine Schleuse bezeichnet im Gebäudemanagement eine bauliche oder technische Einrichtung, die den Zutritt an einem Zugangspunkt so regelt, dass jeweils nur eine Person oder ein definiertes Objekt kontrolliert den Bereich passieren kann. Typische Formen sind Personenvereinzelungsanlagen wie Drehkreuze, Sicherheitsschleusen mit zwei Türen, die nie gleichzeitig geöffnet sind, oder Materialschleusen für Lieferungen. Der Sinn einer solchen Einrichtung liegt darin, unkontrolliertes Eindringen oder das Einschleusen unbefugter Personen zu verhindern. Ohne Schleusen könnte etwa jemand einer berechtigten Person unbemerkt folgen („Tailgating“) oder mehrere Personen gleichzeitig eine Zugangskarte verwenden. Mit Schleusen kann dagegen sichergestellt werden, dass jede Person oder jedes Transportgut einzeln überprüft wird und Manipulationsversuche erkannt werden. Für die Umsetzung kann eine Institution verschiedene Maßnahmen wählen: (1) Eine Schleuse kann mit Zutrittskontrollsystemen gekoppelt werden, sodass Türen erst nach erfolgreicher Authentifizierung (z. B. Kartenleser oder biometrische Erkennung) freigegeben werden. (2) Sensoren wie Gewichtssensoren oder 3D-Kameras können zusätzlich eingesetzt werden, um das Mitführen weiterer Personen zu erkennen. (3) Bei Material- oder Lieferrantenschleusen kann ein Zwei-Personen-Prinzip implementiert werden, sodass ein Mitarbeiter der Institution den Vorgang begleitet. Auch prozessuale Ergänzungen wie regelmäßige Tests der Schleusenfunktionen, klare Regelungen zum Verhalten bei Fehlalarmen oder Hinweisschilder für Besucher können die Wirksamkeit erhöhen. So kann der Zugang zum Gebäude an kritischen Punkten kontrolliert und ein hohes Maß an physischer Sicherheit erzielt werden.

Control: GEB.4.4 - Vereinzelungsanlage

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.4 Sicherheitsbereiche
UUID: b1e5f020-7243-4c70-b21a-85f55b68353c
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN Vereinzelungsanlagen an Zugangspunkten installieren.

Guidance

Eine Vereinzelungsanlage ist eine technische Einrichtung, die den gleichzeitigen Zutritt mehrerer Personen verhindert und so den Zugang zu besonders sensiblen Bereichen kontrolliert. Typische Beispiele sind Drehkreuze, Personenschleusen oder Sicherheitsschleusen mit Gewichtssensoren. Der Sinn dieser Maßnahme liegt darin, unbefugtes Betreten durch sogenanntes „Tailgating“ (eine Person folgt unberechtigt einer berechtigten Person) oder durch Einschleusen mehrerer Personen mit einem Zugangsausweis zu verhindern. Ohne solche Einrichtungen könnte es passieren, dass fremde Personen unerkannt in Serverräume oder Entwicklungsbereiche gelangen. Mit einer Vereinzelungsanlage kann hingegen zuverlässig sichergestellt werden, dass nur eine eindeutig identifizierte Person Zutritt erhält. Für die Umsetzung kann eine Institution mehrere Möglichkeiten nutzen: (1) Drehkreuze oder Sensorschleusen können an Hauptzugängen zu Bereichen mit kritischen Informationen eingesetzt werden, wobei sie mit Zutrittskontrollsystemen wie Chipkarten- oder Biometrie-Lesern kombiniert werden können. (2) Eine Zwei-Türen-Schleuse kann eingerichtet werden, die erst die zweite Tür freigibt, wenn die erste korrekt geschlossen ist und die Person authentifiziert wurde. (3) Sensorische Zusatzkontrollen wie Gewichtserkennung oder Volumendetektion können dabei helfen, dass keine zweite Person unerkannt mit hindurchgeht. Zudem kann die Wirksamkeit erhöht werden, wenn diese Systeme mit klaren Nutzungsregeln, wie Schulungen zum richtigen Durchschreiten und Hinweisschildern, ergänzt werden. Auch ein regelmäßiger Funktionstest der Anlagen kann helfen, Manipulation oder Fehlfunktionen frühzeitig zu erkennen.

Control: GEB.5.1 - Clean Desk

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.5 Gemeinsame Arbeitsbereiche
UUID: b5fcf9c6-b6e5-4018-bb9b-64344a2e0a4e
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Räume SOLLTE zum Aufräumen von vertraulichen Dokumenten und Datenträgern vor dem Verlassen des Arbeitsplatzes anweisen.

Guidance

Ein aufgeräumter Arbeitsplatz („Clean Desk Policy“) kann dazu beitragen, Informationssicherheit und Datenschutz am Arbeitsplatz zu stärken, indem sie verhindert, dass vertrauliche Unterlagen, Datenträger oder elektronische Geräte unbefugt eingesehen oder entwendet werden. Durch konsequentes Aufräumen am Ende des Arbeitstages oder bei längeren Abwesenheiten kann das Risiko von Datenlecks, Industriespionage oder versehentlicher Offenlegung sensibler Informationen minimiert werden. Gleichzeitig kann eine aufgeräumte Arbeitsumgebung die Konzentration und Effizienz der Mitarbeitenden fördern, da unnötige Ablenkungen reduziert werden und das Wiederfinden wichtiger Unterlagen beschleunigt wird. Hierzu gehören sowohl physische Unterlagen wie Akten, Notizzettel oder Ausdrucke mit personenbezogenen oder geschäftskritischen Daten, als auch elektronische Datenträger oder Bildschirminhalte.

Control: GEB.5.2 - Screen Lock

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.5 Gemeinsame Arbeitsbereiche
UUID: 56f4e238-cbce-4353-b4a8-bc3ee1c665c5
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Räume SOLLTE zum Sperren von IT-System vor dem Verlassen des Arbeitsplatzes anweisen.

Guidance

Diese Vorgehensweise hilft dabei, unbefugten Zugriff auf sensible Informationen zu verhindern, die auf dem Bildschirm angezeigt werden könnten. Ansonsten könnte es zu unbefugten Zugriffen auf Daten oder die Systeme selber kommen, wenn diese unbewacht und ungesperrt zurückgelassen werden.

Control: GEB.5.3 - Lieferzugang

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.5 Gemeinsame Arbeitsbereiche
UUID: bf559e67-d53f-4ef3-928b-5d9774e7b87c
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE einen Zugang für die Abwicklung von Lieferungen ohne unbefugten Zugang zum restlichen Standort installieren.

Guidance

Ein Zugang für die Abwicklung von Lieferungen ist ein baulich abgegrenzter Bereich (engl. delivery access point), der es ermöglicht, Waren, Material oder technische Geräte geschützt vor sonstigen äußeren Einflüssen anzunehmen bzw. abzugeben, ohne dass Lieferpersonal oder externe Dienstleister unkontrollierten Zutritt zu sicherheitsrelevanten Bereichen in der Institution erhalten. Unbefugter Zugang meint hierbei jeden Zutritt durch Personen, die für den betroffenen Standort oder bestimmte Schutzbereiche keine Zutrittsberechtigung besitzen (engl. unauthorized access). Der Sinn dieser Vorgabe liegt darin, Risiken durch unkontrollierte physische Zugänge zu minimieren: Ein Lieferant könnte etwa versehentlich oder absichtlich in interne Büro- oder Technikbereiche gelangen und dadurch vertrauliche Informationen, IT-Geräte oder Zugangsdaten einsehen oder entwenden. Eine bauliche und organisatorische Trennung kann dagegen gewährleisten, dass Lieferungen gesteuert angenommen, geprüft und weiterverarbeitet werden, ohne sicherheitskritische Bereiche zu gefährden. Beispielsweise kann es je nach Standort sinnvoll sein: (1) separate Schleusen- oder Annahmebereiche mit kontrollierter Türverriegelung, (2) Gegensprechanlagen oder Kameraeinrichtungen zur Identifikation von Lieferanten, (3) zeitlich begrenzte oder zonenbeschränkte Zutrittsberechtigungen über elektronische Zugangssysteme, sowie (4) baulich getrennte Lieferzonen mit Sichtschutz und gesichertem Übergabepunkt einzurichten.

Control: GEB.5.4 - Schutz gegen Manipulation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.5 Gemeinsame Arbeitsbereiche
UUID: 59810143-17bf-49b6-91d0-1266cb7eb9da
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für IT-Systeme KANN Manipulationsschutzvorkehrungen installieren.

Guidance

Manipulationsschutzvorkehrungen sind physische oder technische Schutzmaßnahmen („tamper protection measures“), die darauf ausgelegt sind, unbefugte Eingriffe, Veränderungen oder Beschädigungen an IT-Systemen oder deren Infrastruktur frühzeitig zu verhindern oder zumindest erkennbar zu machen. Der Begriff „gemeinsame Arbeitsbereiche“ („shared workspaces“) umfasst Räumlichkeiten, in denen mehrere Personen, Teams oder Abteilungen gleichzeitig arbeiten, wodurch sich naturgemäß ein erhöhtes Risiko unkontrollierter Zugriffe auf technische Einrichtungen ergibt. Der Zweck dieser Anforderung liegt darin, die Integrität und Verfügbarkeit der eingesetzten Systeme zu wahren und Manipulationen vorzubeugen, die durch unbeaufsichtigte physische Zugriffe oder verdeckte Eingriffe erfolgen könnten. Ein ungeschütztes Gerät in einem frei zugänglichen Raum könnte beispielsweise durch das unbemerkte Einstecken manipulierter USB-Geräte oder das Entfernen von Netzkabeln kompromittiert werden, während ein gezielter Eingriff in eine Serversteckdose zu Systemausfällen führen könnte. Eine Manipulationsschutzvorkehrung kann hier den Nachweis eines Eingriffs ermöglichen oder diesen bereits im Ansatz verhindern. Beispielsweise kann sinnvoll sein: (1) die Verwendung manipulationssicherer Gehäuse oder Gehäusesiegel, (2) der Einsatz von abschließbaren IT-Racks oder gesicherten Anschlussfeldern, (3) die Integration physischer Sensoren, die bei Gehäuseöffnung Alarmmeldungen erzeugen, oder (4) die Kennzeichnung und regelmäßige Sichtprüfung von Geräten auf Manipulationsspuren. Auch der gezielte Einbau von IT-Komponenten in erhöhten, kameragesicherten oder besonders einsehbaren Bereichen kann eine praktikable Schutzwirkung entfalten.

Control: GEB.5.5 - Physische Mikrosegmentierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.5 Gemeinsame Arbeitsbereiche
UUID: ae6ec98f-fe6f-4334-904c-9f17235c45e5
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für IT-Systeme KANN eine physische Mikrosegmentierung installieren.

Guidance

Bei der physischen Mikrosegmentierung in der Sicherheitsarchitektur geht es darum, unterschiedliche physische Grenzen innerhalb gemeinsam genutzter Einrichtungen zu schaffen, um verschiedene Sicherheitsbereiche zu isolieren und zu schützen. Dies ist besonders wichtig für Umgebungen, in denen Assets mit verschiedenen Sicherheitseigenschaften nebeneinander existieren. Bei dieser Strategie werden bauliche Maßnahmen eingesetzt, wie z. B. getrennte Eingänge, dedizierte Versorgungssysteme, Fallen, abgeschottete HLK-Anlagen, physisch getrennte Netzwerkinfrastrukturen und zugangskontrollierte Zonen, um die seitliche Bewegung von Bedrohungen zu verhindern und gleichzeitig die Einhaltung von Vorschriften zu gewährleisten. Zu den üblichen Anwendungen gehören Bürogebäude mit mehreren Mietparteien, in denen verschiedene Institutionen eine Trennung benötigen, Colocation-Rechenzentren mit kundenspezifischer Geräteisolierung, gemeinsam genutzte Regierungseinrichtungen mit unterschiedlichen Klassifizierungsanforderungen und Campus-Umgebungen, in denen miteinander verbundene Gebäude unterschiedliche Sicherheitsperimeter aufrechterhalten müssen - all dies unterstützt ein umfassendes Risikomanagement und die Eindämmung von Vorfällen. Maßnahmen können z.B. intelligenten Schlössern an Käfigtüren und Sensoren an den Seitenwänden von Serverracks sein.

Control: GEB.6.1 - Zugang zu Ausgabesystemen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.6 Platzierung von Assets
UUID: 9c8e26af-7fd2-4a30-ac89-232a0bc418a1
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für IT-Systeme SOLLTE den Zugang zu nicht-öffentlichen Ausgabesystemen einschränken.

Guidance

Ausgabesysteme sind z.B. Monitore oder Drucker. Nicht-öffentlich sind diese, wenn darauf schützenswerte Inhalte ausgegeben werden, z.B. Arbeitsplätze von internen Sachbearbeitern, Netzdrucker der Personalabteilung.

Control: GEB.6.2 - Geschützte Aufstellung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.6 Platzierung von Assets
UUID: 4bd461c1-265d-4823-8b2c-4c435af0943a
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GEB.6.2.1 Hostsysteme

Statement

Gebäudemanagement für IT-Systeme SOLLTE diese geschützt vor dem Zugriff von Unbefugten platzieren.

Guidance

„Unbefugter Zugriff“ bedeutet in diesem Kontext jeder physische Zutritt oder jede Manipulation durch Personen, die keine rechtmäßige Berechtigung für die Nutzung, Wartung oder Überwachung dieser Systeme besitzen. Der Sinn und Zweck dieser Vorgabe liegt im Schutz vor Verlust, Manipulation oder Unterbrechung des Betriebs durch unkontrollierte physische Einwirkungen. Ohne geeignete Schutzmaßnahmen könnte ein unbefugter Dritter Systeme entwenden, manipulieren oder absichtlich beschädigen; ebenso könnte durch unkontrollierten Zutritt das Risiko von Stromausfällen oder Fehlbedienungen entstehen. Eine angemessene bauliche Platzierung kann hingegen sicherstellen, dass nur autorisierte Personen Zugang erhalten und die Verfügbarkeit sowie Integrität der Systeme langfristig gewährleistet bleibt. Eine Umsetzung kann durch baulich-technische Maßnahmen wie verschließbare Serverschränke mit dokumentierter Schlüsselverwaltung oder den Einsatz von Zugangskontrollen mit elektronischen Schließsystemen erfolgen.

Control: GEB.6.2.1 - Hostsysteme

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.6 Platzierung von Assets

Übergeordnetes Control:

GEB.6.2 Geschützte Aufstellung

UUID: 25dfb04d-3274-446e-9bb0-f2fb1a2e511a

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Hostsysteme SOLLTE diese ausschließlich in Serverräumen platzieren.

Guidance

Sinn und Zweck dieser Anforderung liegt darin, die Risiken durch unkontrollierten physischen Zugriff oder Umwelteinflüsse zu reduzieren: Ohne räumliche Trennung könnte ein Mitarbeiter versehentlich gegen ein frei im Büro aufgestelltes Hostsystem stoßen und es beschädigen, oder ein Besucher könnte unbemerkt Manipulationen vornehmen. Durch Platzierung in einem Serverraum kann hingegen erreicht werden, dass Geräte vor unbefugtem Zugriff geschützt sind und kontrollierte Umgebungsbedingungen wie Temperatur oder Luftfeuchtigkeit den zuverlässigen Betrieb fördern. Praktisch kann es hilfreich sein, Hostsysteme in standardisierten Serverschränken unterzubringen, die zusätzlich verschließbar sind, und regelmäßig zu prüfen, ob keine Fremdgeräte unautorisiert im Serverraum abgestellt wurden. Auf diese Weise kann die Institution sicherstellen, dass Hostsysteme physisch geschützt und unter stabilen Betriebsbedingungen betrieben werden.

Control: GEB.6.3 - Netzkomponenten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.6 Platzierung von Assets
UUID: 525d2727-f932-4f27-bffc-7a8104194bc8
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Netze SOLLTE für die Funktionsfähigkeit des Netzes erforderliche Systeme ausschließlich in Räumen für technische Infrastruktur platzieren.

Guidance

„Für die Funktionsfähigkeit des Netzes erforderliche Systeme“ sind in diesem Kontext alle physischen und logischen Komponenten, deren Betrieb direkt die Verfügbarkeit, Integrität oder Steuerbarkeit von Netzwerken beeinflusst — etwa aktive Netzwerkkomponenten (engl. network devices) wie Router, Switches, Firewalls oder Netzwerkmanagementsysteme (engl. Network Management Systems, NMS). Die Definition von „Räumen für technische Infrastruktur“ ist in den Definitionen für Zielobjekte zu finden. Diese Räume sind typischerweise mit einer kontrollierten physischen Zugangsbeschränkung, Klimatisierung, Brandfrüherkennung und einer stabilen Stromversorgung (z. B. über USV-Anlagen) ausgestattet. Die Anforderung gewährleistet somit, dass netzkritische Systeme räumlich von allgemeinen Arbeits- oder Aufenthaltsbereichen getrennt sind, um deren Sicherheit und Stabilität zu gewährleisten.

Control: GEB.6.4 - Normgerechte Rechenzentren

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.6 Platzierung von Assets
UUID: 280b1dd1-f839-473f-8e71-3cd871fc55b1
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Serverräume KANN diese ausschließlich in Rechenzentren nach {{ insert: param, geb.6.4-prm1 }} platzieren.

Guidance

Rechenzentren entsprechen einer anerkannten Norm, wenn sie nach den einschlägigen technischen, sicherheitsrelevanten und organisatorischen Standards für Rechenzentren errichtet und erhalten werden, wie sie etwa in ISO/IEC 22237, EN 50600 oder vergleichbaren Vorgaben beschrieben sind. In der Fachsprache wird häufig von „compliant data centers“ gesprochen. Solche Rechenzentren verfügen über definierte Schutzklassen hinsichtlich physischer Sicherheit, Energieversorgung, Klimatisierung, Brandfrüherkennung und Zutrittskontrolle. Sie gewährleisten kontrollierte Umgebungsbedingungen und eine hohe Verfügbarkeit (Availability Class) für serverbasierte IT-Systeme. Die Platzierung von Serverräumen ausschließlich in diesen Umgebungen kann sicherstellen, dass physische und infrastrukturelle Risiken minimiert werden, etwa durch den Wegfall von unsicheren Eigenbauten oder provisorischen Standorten. Der Zweck dieser Vorgabe liegt in der Risikoreduktion durch Standardisierung und geprüfte baulich-technische Schutzmaßnahmen. Ohne solche Umgebungen könnte beispielsweise ein Stromausfall, eine unzureichende Klimatisierung oder ein lokaler Brand unbemerkt zum Ausfall kritischer Systeme führen, während ein unzureichend gesicherter Standort auch unbefugten physischen Zugriff ermöglichen könnte. Die Nutzung normgerechter Rechenzentren kann demgegenüber die Verfügbarkeit und Integrität der Systeme erhöhen, da Ausfälle und Umwelteinflüsse frühzeitig erkannt und kontrolliert behandelt werden können. Eine Institution kann dies etwa durch die Unterbringung ihrer Server in einem zertifizierten Colocation-Rechenzentrum (z. B. ISO/IEC 27001 und EN 50600-konform), durch die Nutzung eines Tier III- oder Tier IV-Datacenters nach Uptime Institute-Standard oder durch den Umzug bestehender Systeme in eine baulich und betrieblich geprüfte Hosting-

Umgebung umsetzen.

Control: GEB.7.1 - Schlüsselbeauftragte

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.7 Schlüsselverwaltung
UUID: 989b0846-7561-4d14-99d0-ce46a749cde0
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE die Verwaltung von Schlüsseln {{ insert: param, geb.7.1-prm1 }} zuweisen.

Guidance

Bei der Verwaltung von Schlüsseln werden physische Schlüssel und digitale Zugangsmittel wie RFIDs für Gebäude, Räume oder Schränke ausgegeben, zurückgenommen und deren Nutzung dokumentiert. Mögliche Ausprägungen für zuständige Personen oder Rollen können (1) Facility-Management, (2) IT-Sicherheitsbeauftragte, (3) Empfangs- oder Pförtnerdienste oder (4) ein zentrales Schlüsselmanagement-Team sein. Der Zweck der Vorschrift liegt darin, Risiken durch unkontrollierte Schlüsselvergabe zu reduzieren. Ohne klare Zuweisung könnte es zu unbefugtem Zutritt, Diebstahl oder Manipulation an kritischen Bereichen kommen. Durch eine geregelte Schlüsselverwaltung kann hingegen nachvollziehbar und kontrolliert gesteuert werden, wer physischen Zugang zu sicherheitsrelevanten Bereichen erhält. Zur Umsetzung können Institutionen (1) Schlüssellisten auf Papier oder in Form einer Berechtigungsmatrix führen, die regelmäßig gepflegt und abgeglichen wird, (2) Reserveschlüssel zentral und sicher verwahren, damit im Verlustfall ein geregelter Ersatz möglich ist, und (3) sicherstellen, dass nicht mehr benötigte Schlüssel zeitnah zurückgenommen und dokumentiert werden. Technisch kann die Verwaltung durch nummerierte Schlüsselanhänger oder anonymisierte Kennzeichnungen unterstützt werden, sodass keine Rückschlüsse auf den Einsatzort möglich sind. Auch ein einfaches Verfahren, bei dem die Rücknahme von Schlüsseln mit Datum und Unterschrift bestätigt wird, kann Transparenz schaffen und spätere Unklarheiten verhindern.

Control: GEB.7.2 - Verwahrung von Schlüsseln

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.7 Schlüsselverwaltung
UUID: b4af7248-ff08-4cb7-99b5-cd5f589ec1df
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE zur Verwahrung von Schlüsseln anweisen.

Guidance

Eine Verwahrung ist eine Aufbewahrung von Zugangsschlüsseln derart, dass Unbefugte keinen Zugriff hierauf haben. Dies kann durch das Mitführen der Schlüssel, oder durch eine verschlossene Aufbewahrung, z.B. in einem Schlüsselschrank, umgesetzt werden.

Control: GEB.7.3 - Schlüsselaudit

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.7 Schlüsselverwaltung
UUID: 97d89e25-dbe3-4da7-bcfb-07537a05d6bf
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE die vorhandenen Schlüssel {{ insert: param, geb.7.3-prm1 }} überprüfen.

Guidance

Ohne eine solche Kontrolle könnten z. B. verlorene, vergessene oder unregistrierte Schlüssel im Umlauf bleiben, was zu einem unerkannten Sicherheitsrisiko führt. Ein Vorfall könnte darin bestehen, dass ein ehemaliger externer Dienstleister noch Zugang zu Räumen hat, in denen vertrauliche Unterlagen oder wertvolle Geräte aufbewahrt werden, oder dass ein entwendeter Schlüssel später unbemerkt für Einbruch und Diebstahl genutzt wird. Praktisch kann eine Institution dies umsetzen, indem sie ein aktuelles Schlüsselinventar führt und dieses in festgelegten Abständen mit den tatsächlich im Umlauf befindlichen Schlüsseln abgleicht. Sinnvoll ist auch, bei der Überprüfung nicht nur auf Vollständigkeit, sondern auf Plausibilität zu achten – beispielsweise ob Schlüssel für inzwischen nicht mehr genutzte Räume weiterhin im Umlauf sind. Bei normalen Schutzbedarf genügt eine stichprobenartige Kontrolle, Schlüssel mit höherem Schutzbedarf (z.B. für Sicherheitsbereiche) dagegen bedürfen in der Regel einer häufigeren, vollständigen Kontrolle.

Control: GEB.8.1 - Gesonderte Aufbewahrung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.8 Verwahrung von Speichermedien
UUID: fa8a00b9-9190-44f2-875a-68024ff491bd
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GEB.8.1.1 Archiv

Statement

Gebäudemanagement für Standorte SOLLTE geschäftskritische Speichermedien in verschließbaren Schutzeinrichtungen platzieren.

Guidance

Vertrauliche Speichermedien, die ungesichert herumliegen (sowohl analoge Dokumente als auch digitale Datenträger) sind ein leichtes Ziel für Diebstahl und können versehentlich verloren gehen oder beschädigt werden; eine angemessene Sicherung erfolgt durch Aufbewahrung in abschließbaren Schränken, in Safes oder in dedizierten, gesicherten Räumlichkeiten, wobei die Anforderung auch dann als erfüllt gilt, wenn ein fest verbautes Behältnis genutzt wird, beispielsweise ein Safe-Raum.

Control: GEB.8.1.1 - Archiv

Tag: "Langzeitarchivierung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.8 Verwahrung von Speichermedien
Übergeordnetes Control:
GEB.8.1 Gesonderte Aufbewahrung
UUID: 59be69ee-346c-4a89-b93d-558cfd50f57f
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN geschäftskritische Speichermedien in Datenträgerarchiven platzieren.

Guidance

Geschäftskritische Datenträger lagern in gesicherten, klimatisierten Archiven mit Zugriffskontrolle, Brandschutz und nachvollziehbarer Aus-/Rückgabedokumentation.

Control: GEB.8.2 - Staub und Schmutz

Tag: "Langzeitarchivierung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.8 Verwahrung von Speichermedien
UUID: 219884d2-ef52-4103-bd5f-b5d76bab03d7
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Datenträgerarchiv KANN Maßnahmen zum Schutz der Datenträger vor Staub und Schmutz verankern.

Guidance

Werden analoge und digitale Datenträger länger im Archiv aufbewahrt, so besteht das Risiko der schleichenden Zersetzung durch Staub und Schmutz. Maßnahmen sind z.B. staubdichte und antistatische Lagerung in Schutzschränken, Klimatisierung, Schutzkleidung, trockene Reinigung.

Control: GEB.8.3 - Schutz der Datenträger vor Brandschäden

Tag: "Langzeitarchivierung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.8 Verwahrung von Speichermedien
UUID: 7fa6a340-5f12-41a3-b9df-a44dfcc6e0be
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN feuerfeste Behältnisse nach {{ insert: param, geb.8.3-prm1 }} installieren.

Guidance

Datenträgerarchive sind bei Bränden besonders schützenswert, da hier häufig die langfristig kritischen Daten gelagert werden. Kann durch Brandschutzschränke oder Datensafes umgesetzt werden, die nach DIN EN 1047-1 oder ISO 11799 zertifiziert sind.

Control: GEB.8.4 - Überwachung schonender Klimatisierung

Tag: "Langzeitarchivierung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.8 Verwahrung von Speichermedien
UUID: b76d96fa-3c33-470e-a624-1fe1aff44cc9
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Datenträgerarchiv KANN für die Datenträger schonende Temperatur und Luftfeuchtigkeit anhand von {{ insert: param, geb.8.4-prm1 }} überwachen.

Guidance

IT-Infrastruktur benötigt typischerweise eine Umwelttemperatur von nicht viel mehr als 25°C und eine Luftfeuchtigkeit von nicht über 60%. Bei höheren Werten altern Komponenten schneller und das Risiko von Ausfällen durch Abwärme oder Spannungsüberschläge steigt. Grenzwerte können anhand der Herstellerangaben der im Raum eingesetzten Datenträger ermittelt werden. Die Überwachung kann mit klimatechnischen Sensoren im Raum realisiert werden.

Control: GEB.9.1 - Normgerechte Stromversorgung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.9 Versorgungseinrichtungen
UUID: 30ed7bd0-4d41-4bc3-880d-cc0e66fd592e
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung

Statement

Gebäudemanagement für Standorte SOLLTE eine norm- und bedarfsgerechte Stromversorgung und -verkabelung installieren.

Guidance

Eine Stromversorgung ist normgerecht, wenn Normen zur Bereitstellung und Verkabelung wie DIN VDE 0100 eingehalten werden. Bedarfsgerecht ist eine Stromversorgung, wenn sie den Strombedarf der IT-Systeme und anderen Geräte im Gebäude deckt und Reserven für Erweiterungen oder Notfälle bietet. Das betrifft sowohl zentrale Versorgungsanschlüsse, Unterverteilungen als auch die Zuleitung in die einzelnen Räume. Die Anforderung ist auch dann erfüllt, wenn eine den Compliance-Vorschriften für Strom entsprechende Versorgung bereits im Gebäude vorhanden ist. Im Fall von Rechenzentren ist auch auf die Möglichkeit der Notabschaltung der Stromversorgung (für einzelne elektrische Verbraucher) zu achten. Hier ist eine sinnvolle Parzellierung und Zielgerichtetheit bei der Notabschaltung von Bedeutung.

Control: GEB.9.1.1 - Vorausschauende Lastanalyse

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.9 Versorgungseinrichtungen

Übergeordnetes Control:

GEB.9.1 Normgerechte Stromversorgung

UUID: a73bc9c8-bd58-4816-9e18-d41e94c20341

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN die bedarfsgerechte Stromversorgung {{ insert: param, geb.9.1.1-prm1 }} vorausschauend überprüfen.

Guidance

Die prädiktive Lastanalyse in Stromversorgungssystemen bezieht sich auf die ausgefeilte Analyse von elektrischen Lastmustern, einschließlich Oberschwingungen der Stromqualität, um den zukünftigen Stromverbrauch und Qualitätsprobleme vorherzusagen, bevor sie auftreten. Sie kann in Bereichen, in denen die Stromversorgung von höchster Bedeutung ist, helfen, die kontinuierliche Verfügbarkeit der IT-Infrastruktur durch Überwachung und Vorhersage potenzieller Stromanomalien sicherzustellen, die die Systemintegrität gefährden könnten. Im Gegensatz zu reaktiven Ansätzen, die Probleme erst nach ihrem Auftreten angehen, werden bei der vorausschauenden Lastanalyse fortschrittliche Algorithmen zur Analyse historischer Stromverbrauchsdaten, harmonischer Verzerrungen und Spannungsschwankungen eingesetzt, um Muster zu erkennen, die auf bevorstehende Stromversorgungsprobleme hinweisen. Die Implementierung kann mit Netzqualitätsanalysatoren an kritischen Infrastrukturspunkten, Integration mit SCADA-Systemen und durch Analyse mit Algorithmen des maschinellen Lernens, die Netzanomalien mit bestimmten Betriebsbedingungen korrelieren, geschehen. Eine regelmäßige Validierung der Vorhersagemodelle anhand tatsächlicher Vorfälle hilft die Analyse zu verbessern, während die Integration mit automatisierten Energieverwaltungssystemen einen dynamischen Lastausgleich während vorhergesagter Stressperioden ermöglichen kann, wodurch sowohl die Stromqualität, als auch die Systemverfügbarkeit ohne menschliches Eingreifen aufrechterhalten werden.

Control: GEB.9.1.2 - Dedizierte Elektrounterverteilung

Tag: "Hochverfügbarkeit"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.9 Versorgungseinrichtungen
Übergeordnetes Control:
GEB.9.1 Normgerechte Stromversorgung
UUID: 59df8c81-694d-4612-a439-63deaae5c4d9
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN eine ausschließlich für diesen Standort bestimmte Elektrounterverteilung die direkt von der Niederspannungshauptverteilung (NSHV) versorgt wird installieren.

Guidance

Eine eigene, direkt aus der NSHV gespeiste Unterverteilung trennt kritische Abgänge (IT/USV/Kälte), stellt Selektivität und eindeutige Kennzeichnung sicher, ermöglicht Zustandsüberwachung und hält Ausbaureserven vor.

Control: GEB.9.1.3 - Redundante Stromversorgung

Tag: "Hochverfügbarkeit"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.9 Versorgungseinrichtungen
Übergeordnetes Control:
GEB.9.1 Normgerechte Stromversorgung
UUID: eaaa8977-05e5-4eaa-a5b7-ea490eb543cd
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN eine redundante Stromversorgung für {{ insert: param, geb.9.1.3-prm1 }} installieren.

Guidance

Wenn die Stromzufuhr ausfällt, könnten geschäftskritische Anwendungen unerwartet ausfallen oder Daten verlorengehen. Die Redundanz der Stromquelle kann z.B. durch einen im System integrierten Akku, durch eine eigenständige unterbrechungsfreie Stromversorgung (USV) oder durch die Anbindung an ein sekundäres Stromnetz gewährleistet werden. Bei Bedarf kann sie auch die Übergangszeit bis zum Anlauf einer längerfristigen Netzersatzanlage überbrücken. Beim Betrieb einer USV ist auf die Einhaltung eines akzeptablen Temperaturbereichs der Batterie zu achten. Bei relevanten Änderungen an den Verbrauchern könnte es vorkommen, dass die USV-Systeme nicht mehr ausreichend dimensioniert sind. Da der Leistungsbedarf von Klimaanlage oft zu hoch für eine USV ist, empfiehlt es sich zumindest die Steuerung der Anlagen an die unterbrechungsfreie Stromversorgung anzuschließen. Eine regelmäßige Wartung (u.U. nach Vorgabe des Herstellers) der USV und eine Trennung der Leistungselektronik von der Batterie ist empfohlen. Bei sehr hohem Schutzbedarf empfiehlt sich eine redundante Auslegung der USV. Die minimale Stützzeit (Autonomiezeit) ergibt sich als $\text{Stützzeit} = \text{Wartezeit auf mögliche Wiederkehr der Stromversorgung} + 2 \cdot \text{Zeit zum Herunterfahren der Komponenten}$. Bei sehr hohem Schutzbedarf empfiehlt sich eine redundante Auslegung der USV. Die Verkabelungswege sind redundant, wenn die Leitungen über verschiedene Wege geführt sind, sodass z.B. eine versehentliche Trennung nicht beide Leitungen betrifft.

Control: GEB.9.1.4 - Langanhaltende Sekundärversorgung

Tag: "Hochverfügbarkeit"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.9 Versorgungseinrichtungen
Übergeordnetes Control:
GEB.9.1 Normgerechte Stromversorgung
UUID: 9de758ff-88f1-4350-b937-354a5e4e5fc5
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN eine redundante Stromversorgung für {{ insert: param, geb.9.1.4-prm1 }} installieren.

Guidance

Eine längere Stützzeit bezeichnet im Kontext der Stromversorgung die Fähigkeit, elektrische Energie über einen Zeitraum von mehreren Stunden oder sogar Tagen aufrechtzuerhalten, typischerweise durch den Einsatz einer Netzersatzanlage (NEA) oder vergleichbarer Infrastruktur. Während eine kurzzeitige Überbrückung durch unterbrechungsfreie Stromversorgungen (USV) lediglich Sekunden bis Minuten abdeckt, kann eine NEA längere Stromausfälle abfangen und die Betriebsfähigkeit kritischer Systeme dauerhaft sicherstellen. Risiken bestehen darin, dass ein Standort bei einem längerfristigen Netzausfall ohne redundante Stromversorgung seine sicherheitskritischen Prozesse nicht mehr betreiben könnte, was etwa zu Datenverlusten, Produktionsstillständen oder Ausfällen der Zutrittskontrolle führen könnte. Eine redundante Stromversorgung kann dem entgegenwirken, indem sie kritische Infrastrukturen wie Rechenzentren, Kommunikationssysteme oder Zutrittssysteme auch bei großflächigen Netzstörungen handlungsfähig hält. Zur Betriebsfähigkeit gehört auch die regelmäßige Wartung und Überprüfung des Betriebsmittelvorrats. Eine Institution kann die Anforderung umsetzen, indem sie geeignete technische Maßnahmen einplant: (1) Installation einer Netzersatzanlage mit automatischer Umschaltung auf Diesel- oder Gasgeneratoren, (2) Bereitstellung von Kraftstoffvorräten für eine definierte Stützzeit von beispielsweise 24, 48 oder 72 Stunden, (3) regelmä-

ßige Lasttests, um sicherzustellen, dass die Anlage die notwendige Kapazität unter Realbedingungen liefern kann. Ergänzend kann eine Institution durch redundante Einspeisungen vom Energieversorger oder die Kombination mehrerer NEA-Module eine Ausfallsicherheit erhöhen. Prozessual kann sie Wartungspläne etablieren, die auch die Prüfung von Kraftstoffqualität, Starterbatterien und Umschalteneinrichtungen umfassen. Praktische Umsetzungstipps sind etwa, NEA-Anlagen in geschützten Gebäudebereichen mit ausreichender Belüftung und Brandschutz vorzusehen, die Abgasführung nach außen zu gewährleisten und einen sicheren, vor Manipulation geschützten Tankstandort zu wählen.

Control: GEB.9.2 - Lasttest

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.9 Versorgungseinrichtungen
UUID: 56b79b13-09ed-4d7a-adea-bc8cb2cf97dd
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN die Belastbarkeit der Stromversorgung {{ insert: param, geb.9.2-prm1 }} überprüfen.

Guidance

Die Maßnahmen richten sich nach den geltenden Anforderungen an die Stromversorgung. Beispiele sind ein monatlicher USV-Selbsttest oder ein halbjährlicher Volllastbetrieb des Generators für mindestens 30 Minuten.

Control: GEB.9.3 - Notaus

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.9 Versorgungseinrichtungen
UUID: 1520f194-770f-4da5-9ac8-1094105e2d80
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN eine Notausschaltung für die Versorgungseinrichtungen installieren.

Guidance

Eine Notausschaltung bezeichnet in diesem Kontext eine zentral verfügbare, technisch implementierte Vorrichtung, mit der im Gefahrenfall die Energieversorgung kritischer Versorgungseinrichtungen wie Strom, Gas oder Klimaanlage unmittelbar und vollständig unterbrochen werden kann. Der Sinn und Zweck einer solchen Einrichtung liegt darin, Gefahren für Menschen, Technik und Informationen schnell eingrenzen zu können: Ein unkontrollierter Brand könnte sich durch weiterlaufende Klimageräte verstärken, ein Stromschlag durch beschädigte Leitungen könnte Menschen gefährden, oder ein Wasserschaden durch defekte Kühlung könnte weitere Systeme zerstören. Gleichzeitig kann eine sofortige Unterbrechung der Energiezufuhr Folgeschäden eindämmen, indem Brandlast reduziert oder die Ausbreitung toxischer Gase verhindert werden kann. Zur Umsetzung kann eine Institution beispielsweise (1) physische Notausschalter an klar gekennzeichneten, jederzeit zugänglichen Stellen nahe den Ausgängen oder im Leitstand installieren, (2) die Schalter so konzipieren, dass sie nur für definierte Versorgungskreise wie IT-Serverräume oder Technikzonen wirken und nicht die gesamte Einrichtung unkontrolliert lahmlegen, und (3) ergänzende visuelle Hinweise oder Leitsymbole anbringen, die die Bedienung im Ernstfall erleichtern.

Control: GEB.9.4 - Überspannungsschutz

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.9 Versorgungseinrichtungen

UUID: dc956422-730a-46c3-987b-3f2cb5ea22f3

Aufwand: 4

Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN Überspannungsschutzeinrichtungen installieren.

Guidance

Überspannungsschutzeinrichtungen sind technische Komponenten, die elektrische und elektronische Systeme vor plötzlich auftretenden Spannungsspitzen im Stromnetz oder in Datenleitungen schützen. Sie wirken, indem sie kurzzeitig auftretende Energie in sichere Bahnen ableiten oder begrenzen, sodass angeschlossene Geräte nicht beschädigt werden. Der Sinn und Zweck liegt darin, sensible IT- und Kommunikationssysteme sowie die Infrastruktur der Institution vor Schäden zu bewahren. Ohne Schutz könnte ein Spannungssprung aus dem Stromnetz eine zentrale Serveranlage zerstören oder den Ausfall von Brandmelde- und Zutrittskontrollsystemen verursachen, wohingegen ein korrekt eingesetzter Überspannungsschutz kann die Betriebsfähigkeit und Datenintegrität sicherstellen. Diese Anforderung bezieht sich ausschließlich auf Überspannungen aus dem Netzbetrieb oder aus benachbarten Stromkreisen; für den äußeren Blitzschutz gilt eine verwandte Anforderung. Zur Umsetzung können an kritischen Punkten Überspannungsschutzeinrichtungen installiert werden: (1) in zentralen Verteilungen, um das gesamte Gebäude gegen Netzstörungen abzusichern, (2) in Unterverteilungen oder einzelnen Stromkreisen, die besonders sensible IT-Systeme versorgen, und (3) an Kommunikations- oder Datenleitungen, etwa für Netzwerk- oder Telefonverkabelungen. Eine Institution kann durch gestufte Schutzkonzepte („Grobenschutz“ im Hauptverteiler, „Feinschutz“ in Nähe der Endgeräte) eine höhere Wirksamkeit erreichen. Es kann sinnvoll sein, bei Neubauten Steckdosen mit integriertem Feinschutz vorzusehen oder bei Bestandsanlagen nachträglich modulare Schutzgeräte in die Verteilungen einzusetzen. Prozessual kann regelmäßige Prüfung der eingebauten Schutzmodule helfen, da viele Modelle nach einem Ereignis verbraucht sind und ausgetauscht werden müssen.

Auch eine Dokumentation der Einbauorte kann den Überblick erleichtern und gewährleisten, dass keine kritischen Systeme ungeschützt bleiben.

Links

related: GEB.10.4 Blitzschutzeinrichtungen

Control: GEB.9.5 - Strukturierte Datenverkabelung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.9 Versorgungseinrichtungen
UUID: 3324eb2a-6548-46c1-9d15-96192fdae5a9
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GEB.9.5.1 Physisch geschützte Verlegung

Statement

Gebäudemanagement für Standorte SOLLTE eine norm- und bedarfsgerechte Datenverkabelung installieren.

Guidance

Normgerecht ist eine Datenverkabelung, wenn Normen für Verkabelungssysteme wie DIN EN 50173 und DIN EN 50174, sowie bei Glasfaser DIN EN 60794 eingehalten werden. Sie ist auch bedarfsgerecht, wenn die verwendete Verkabelung ausreicht, um festgelegte Bandbreite und Antwortzeit zu erreichen. Das betrifft sowohl zentrale Netzanschlüsse, als auch Unterverteiler und die Zuleitung in die einzelnen Räume. Zur Umsetzung ist es sinnvoll ein Kabelverlegungsdiagramm und eine standortspezifische Inspektionscheckliste zu erstellen oder erstellen zu lassen.

Control: GEB.9.5.1 - Physisch geschützte Verlegung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.9 Versorgungseinrichtungen

Übergeordnetes Control:

GEB.9.5 Strukturierte Datenverkabelung

UUID: 71c569f6-99e4-4fd4-8648-84b9c8a0539e

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE eine geschützte Kabelverlegung installieren.

Guidance

Freigelegte Glasfaser- oder Kupferleitungen könnten angezapft oder durchtrennt werden. Die Implementierung kann z.B. erfolgen durch: Das Verlegen von Backbone-Kabeln in Metallrohren oder verschlossenen Kabelschränken; manipulationssichere Siegel an Stellen, an denen die Kabel die Sicherheitsbereiche verlassen.

Control: GEB.9.6 - Zugang zu Räumen für technische Infrastruktur

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.9 Versorgungseinrichtungen
UUID: 7260f1aa-7b3b-42aa-a4f2-c85bd8047a4b
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Räume für technische Infrastruktur SOLLTE den Zugang zu Räumen für technische Infrastruktur auf {{ insert: param, geb.9.6-prm1 }} einschränken.

Guidance

Hierzu gehören insbesondere Versorgungsverteiler, z.B. für Netzverteilung, Frischwasser, Abwasser, Stromversorgung und andere zentrale Versorgungseinrichtungen. sind essenziell für die Einsatzfähigkeit und den Schutz des Gebäudes. Der Zugang zu diesen Verteilern kann z.B. durch Schließanlagen, Bewachung und Einbruchmeldesysteme realisiert werden.

Control: GEB.9.7 - Zweckentfremdung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.9 Versorgungseinrichtungen
UUID: efa82caa-8318-4679-a865-48cc380ac9d2
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Räume für technische Infrastruktur SOLLTE die Verwendung der Räume zu anderen Zwecken untersagen.

Guidance

Werden Räume für technische Infrastruktur zu weiteren Zwecken, z.B. als Arbeitsplatz, Durchgangsbereich oder Abstellraum genutzt, so erhöht dies das Risiko versehentlicher Schäden oder des Zugriffs Unbefugter auf die Infrastruktur.

Control: GEB.10.1 - Klimatisierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.10 Schutz vor Elementarschäden
UUID: dfdda615-4afc-4889-b7a0-95c91240add7
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.1.2 Klimamessung
- GEB.10.1.3 Redundante Klimatisierung

Statement

Gebäudemanagement für Standorte SOLLTE eine ausreichende Klimatisierung von Räumlichkeiten anhand von {{ insert: param, geb.10.1-prm1 }} installieren.

Guidance

Klimatisierung meint das Erzeugen und Aufrechterhalten von Temperatur und Luftfeuchtigkeit innerhalb bestimmter Schwellwerte. Zur Bestimmung der Schwellwerte können verschiedene Angaben herangezogen werden, u.a. Herstellerangaben für die am Standort betriebenen Systeme, Compliance-Vorgaben zur Arbeitsplatzsicherheit, branchenspezifische Normen und Standards (z.B. DIN EN ISO 7730), Energieeffizienzrichtlinien und Umweltvorschriften, sowie wissenschaftliche Erkenntnisse zu optimalen Arbeitsbedingungen. Die Implementierung kann umfassen: Die Gestaltung von Räumen mit klarer Trennung von Zu- und Abluftwegen, um Innenzirkulation zu vermeiden; Beseitigung von Hindernissen in kritischen Luftstromwegen; Implementierung geeigneter Einschlusslösungen für bestimmte Anwendungsfälle (z. B. heiße/kalte Servergänge oder Reinnräume in der Fertigung); Optimierung der Geräteplatzierung zur Maximierung einer effizienten Luftverteilung; regelmäßige Wartung der Belüftungssysteme, einschließlich Filteraustausch und Kanalreinigung; strategische Platzierung von Ablenkblechen oder Deflektoren zur Lenkung des Luftstroms; saisonale Anpassung der HLK-Einstellungen an sich ändernde äußere Bedingungen; Einsatz drehzahlvariabler Ventilatoren und intelligenter Steuerungen, um dynamisch auf sich ändernde Lasten zu reagieren; regelmäßige Wärmebilddaufnahmen, um entstehende Probleme zu erkennen. Den größten Nutzen bringt es in der

Regel zunächst die größten Hindernisse zu beseitigen, sowie die Abdichtung unerwünschter Luftwege und die Optimierung der wichtigsten lufttechnischen Anlagen zu beachten. In Serverräumen empfiehlt sich oft eine gedrehte Rack-Ausrichtung, sodass die Luftzufuhr der Geräte aus kalten Gängen erfolgt, während die Abluft direkt in warmen Gänge geleitet wird, wodurch eine Rezirkulation verhindert und die Kühlung aufrechterhalten wird. Gleichzeitig verbessert diese Konfiguration die Betriebspraktikabilität durch die Positionierung der Kabelanschlüsse für einen bequemen Zugang der Techniker, ohne die Luftstrommuster zu unterbrechen.

Control: GEB.10.1.1 - Luftstrom-Analyse

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.10 Schutz vor Elementarschäden

Übergeordnetes Control:

GEB.10.1 Klimatisierung

UUID: 0abf44e0-ee1c-46fc-a106-fa58b1f5f245

Aufwand: 4

Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Serverräume KANN den Klimatisierungsbedarf anhand einer Luftstrom-Analyse {{ insert: param, geb.10.1.1-prm1 }} überprüfen.

Guidance

Luftstromanalyse ist die systematische Bewertung von Luftbewegungsmustern zur Optimierung der Kühleffizienz und zur Vermeidung von Geräteausfällen. Dabei wird untersucht, wie die kalte Luft in der Einrichtung verteilt wird, es werden potenzielle Hotspots oder Bereiche mit Stagnation identifiziert, und es wird ein ordnungsgemäßer Wärmeaustausch durch die Überwachung der Einlass- und Auslasstemperaturen in den Serverracks sichergestellt. Zu den möglichen Methoden gehören CFD-Modelle (Computational Fluid Dynamics) zur Simulation von Luftströmungsmustern vor der Implementierung, der Einsatz von Temperatur- und Luftströmungssensoren an strategischen Stellen, Rauchtests zur visuellen Verfolgung der Luftbewegungspfade und Druckdifferenzmessungen zur Überprüfung der Integrität des Containments. Ein gut ausgeführtes Luftstrommanagement steht außerdem in direktem Zusammenhang mit geringeren Kühlkosten (oft 20-30 % Einsparungen), einer längeren Lebensdauer der Geräte und einer höheren Rechenleistung pro Quadratmeter. Zu den bewährten Lösungen zur besseren Zirkulation gehören die Eingrenzung von Warm- und Kaltgängen, um eine Vermischung der Luftströme zu verhindern, die Aufrechterhaltung optimaler Rack-Einlasstemperaturen, die Sicherstellung einer angemessenen Perforation der Bodenfliesen in Doppelbodenumgebungen, die Optimierung der Serverplatzierung, um einen Bypass-Luftstrom zu vermeiden, und die Durchführung regelmäßiger Wärmebilduntersuchungen, um sich entwickelnde Probleme zu erkennen. Besonderer Aufmerksamkeit bedarf das Kabelmanagement, da eine ungeordnete Verkabelung den Luftstrom um bis zu 60 % behindern kann; ebenso ist es sinnvoll

Abdeckplatten aller ungenutzten Rack-Räume abzudichten, um eine innere Zirkulation heißer Luft zu verhindern.

Control: GEB.10.1.2 - Klimamessung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.10 Schutz vor Elementarschäden

Übergeordnetes Control:

GEB.10.1 Klimatisierung

UUID: 338031dd-f3c6-4245-b411-7c46852edfcb

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Serverräume SOLLTE Lufttemperatur und Luftfeuchtigkeit anhand von {{ insert: param, geb.10.1.2-prm1 }} überwachen.

Guidance

IT-Infrastruktur benötigt typischerweise eine Umwelttemperatur von nicht viel mehr als 25°C und eine Luftfeuchtigkeit von nicht über 60%. Bei höheren Werten altern Komponenten schneller und das Risiko von Ausfällen durch Abwärme oder Spannungsüberschläge steigt. Ermitteln Sie Grenzwerte anhand der Herstellerangaben der im Raum eingesetzten Komponenten. Die Überwachung kann mit klimatechnischen Sensoren in den Geräten selbst oder im Raum realisiert werden. Eine saisonale Anpassung der Lüftungsanlagen kann erforderlich sein, insbesondere in Einrichtungen, die mit Eco-Modus arbeiten.

Control: GEB.10.1.3 - Redundante Klimatisierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.10 Schutz vor Elementarschäden

Übergeordnetes Control:

GEB.10.1 Klimatisierung

UUID: ab66de05-230a-46cf-9beb-29368a3768e2

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN redundante Klimasysteme installieren.

Guidance

Redundant ist eine Klimatisierung, wenn alle zu ihrer Funktionsfähigkeit erforderlichen Komponenten und Anbindungen redundant sind, d.h. kein einzelner Fehlerpunkt zu einem Ausfall führen würde (Single Point of Failure).

Control: GEB.10.2 - Brandschutz

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.10 Schutz vor Elementarschäden
UUID: 56c85ba9-d534-4b2a-b895-06b24de6ab92
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.2.8 Brandschutzprüfung

Statement

Gebäudemanagement für Standorte SOLLTE Brandschutz nach den entsprechenden Normen verankern.

Guidance

Maßnahmen können z.B. die Verwendung nicht brennbarer Baumaterialien (u.a. DIN 4102, DIN EN 13501), brandsichere Elektroinstallation, Feuerlöscher (DIN 14406), Rauchabzugsanlagen (DIN 18232) sowie Brandmelde- (DIN EN 54) und Löschanlagen (DIN EN 671) sein. Bei der Planung kann die örtliche Feuerwehr hinzugezogen werden. Gesetzliche Anforderungen hierzu sind in der Praktik Compliance zu berücksichtigen.

Control: GEB.10.2.1 - Baulicher Brandschutz

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.10 Schutz vor Elementarschäden

Übergeordnetes Control:

GEB.10.2 Brandschutz

UUID: d2545c9e-2476-4841-a9a6-dafa9b471f1b

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Räume SOLLTE bauliche Brandschutzeinrichtungen nach den entsprechenden Normen installieren.

Guidance

Relevant ist für das Brandverhalten von Bauprodukten und Bauarten die europäische Normenreihe DIN EN 13501 mit ihren sieben Klassen (A1, A2, B, C, D, E, F).

Control: GEB.10.2.2 - Brandabschnitte

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.10 Schutz vor Elementarschäden

Übergeordnetes Control:

GEB.10.2 Brandschutz

UUID: 9bba280a-5874-46eb-bbc5-4696d3ee5ed6

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Räume SOLLTE Brandabschnitte nach den entsprechenden Normen installieren.

Guidance

Brandabschnitte sind baulich abgegrenzte Bereiche in Gebäuden, die im Brandfall verhindern sollen, dass das Feuer auf andere Bereiche übergreift. Sie werden durch feuerfeste Wände, Decken und andere raumabschließende Bauteile voneinander getrennt. Hier besteht ein enger Zusammenhang zu Compliance-Anforderungen: Größe und Anzahl von Brandabschnitten werden auch durch die Bauordnung und andere Vorschriften festgelegt, abhängig von der Nutzung und Größe des Gebäudes. Für die Informationssicherheit relevant ist darüber hinaus, ob die Auswahl der Brandabschnitte den darin befindlichen Informationen und damit verbundenen Assets ausreichenden Schutz gewährt, um deren Verfügbarkeit aufrechtzuerhalten.

Control: GEB.10.2.3 - Rauchdichtheit

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.10 Schutz vor Elementarschäden
Übergeordnetes Control:
GEB.10.2 Brandschutz
UUID: 1cccb05d-47e6-431e-8668-c70be6ec17c6
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Räume KANN alle raumbildende Teile rauchdicht installieren.

Guidance

Hierunter ist zu verstehen, dass alle raumbildenden Teile (Wände, Türen und falls benötigt Fenster) rauchdicht sind.

Control: GEB.10.2.4 - Brandwiderstandsklassen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.10 Schutz vor Elementarschäden

Übergeordnetes Control:

GEB.10.2 Brandschutz

UUID: 4411c989-a51f-4aa9-8d79-e0b3fd492fb9

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Räume KANN feuerfeste Materialien für alle raumbildenden Teile , sodass sie Feuern für {{ insert: param, geb.10.2.4-prm1 }} standhalten, installieren.

Guidance

Der Einsatz feuerfester Materialien für raumbildende Teile – also Wände, Decken, Türen und gegebenenfalls auch Bodenaufbauten – kann das Risiko erheblich reduzieren, dass sich ein Brand innerhalb eines Gebäudes schnell ausbreitet oder sicherheitsrelevante Bereiche in kurzer Zeit unbenutzbar werden könnten. Ohne geeignete Materialien könnte ein kleiner Kabelbrand beispielsweise binnen Minuten auf benachbarte Räume mit Servern, Schaltanlagen oder Dokumenten übergreifen und kritische Infrastruktur unbrauchbar machen. Mit feuerfesten Materialien kann eine Institution die Zeitspanne verlängern, in der Personen evakuiert, Brandbekämpfungsmaßnahmen eingeleitet oder Systeme geordnet heruntergefahren werden können. Der Begriff „feuerfest“ bedeutet im baulichen Kontext nicht absolute Unzerstörbarkeit, sondern eine definierte Widerstandsfähigkeit gegen Feuer über eine bestimmte Frist (z. B. 30, 60 oder 90 Minuten), die durch Normen wie die europäische Klassifizierung REI angegeben wird. Diese Frist beschreibt, wie lange ein Bauteil seine tragende Funktion (R), Dichtheit (E) und Wärmedämmung (I) im Brandfall aufrechterhalten kann. Zur praktischen Umsetzung können im Gebäudemanagement verschiedene Maßnahmen berücksichtigt werden: Wände und Decken können aus nicht brennbaren Baustoffen wie Beton oder speziellen Gipsfaserplatten ausgeführt werden, Türen können durch Brandschutztüren mit entsprechender Klassifizierung ersetzt werden, und Kabel- sowie Rohrdurchführungen können mit geprüften Brandschutzmanschetten oder -schotts ausgestattet werden. Auch abgehängte Decken oder Zwischen-

wände in Leichtbauweise können mit feuerhemmenden Platten verkleidet werden, um die Widerstandsdauer zu erhöhen. Eine Institution kann bei Umbauten oder Neubauten frühzeitig auf geprüfte Baustoffe achten und im Bestand gezielt besonders gefährdete Räume wie Serverräume, Archive oder Batterieräume nachrüsten.

Control: GEB.10.2.5 - Vermeidung von Brandlasten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.10 Schutz vor Elementarschäden

Übergeordnetes Control:

GEB.10.2 Brandschutz

UUID: 3c49b485-9113-4009-a2dc-598c9d9a3f5f

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE das ungesicherte Hinterlassen von Brandlasten untersagen.

Guidance

Befinden sich Brandlasten wie Kartons, brennbare Dämmstoffe, Batterien oder Holzmöbel in der Nähe (oder sogar in) Räumen für technische Infrastruktur oder zentraler Versorgungseinrichtungen, so erhöhen sich Wahrscheinlichkeit und durchschnittliches Schadensausmaß von Bränden. Dies gilt auch für das Rauchen von Zigaretten oder Zigarren. Der einzuhaltende Abstand ergibt sich aus der Größe der Brandlast und dem Schutzbedarf des Ortes von dem Abstand zu halten ist - wenn möglich ist ein Abstand von mindestens einem Zwischenraum sinnvoll.

Control: GEB.10.2.6 - Brandmeldeanlagen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.10 Schutz vor Elementarschäden

Übergeordnetes Control:

GEB.10.2 Brandschutz

UUID: 92dfd98d-40ed-4854-a3d8-00a84fe77cec

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE das Entstehen von Bränden überwachen.

Guidance

Die Umsetzung kann durch Brandmeldezentralen oder dezentrale Brandmeldealarmierung erfolgen, siehe DIN EN 54 und DIN VDE 0833-2.

Control: GEB.10.2.7 - Brandunterdrückung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.10 Schutz vor Elementarschäden

Übergeordnetes Control:

GEB.10.2 Brandschutz

UUID: 7520aa89-9296-4ae3-a60d-5c781dd06732

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Serverräume KANN Brandunterdrückungssysteme installieren.

Guidance

Kann z.B. durch eine Anlage zur Sauerstoffreduktion unter 15 Volumenprozent umgesetzt werden, da Feuer sich so kaum entzünden kann. Siehe ISO 20338. Denken Sie dabei auch an den Schutz des Personals, siehe Arbeitstättenverordnung (ArbStättV).

Control: GEB.10.2.8 - Brandschutzprüfung

Tag: "Inspektion"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.10 Schutz vor Elementarschäden
Übergeordnetes Control:
GEB.10.2 Brandschutz
UUID: 3b904a6b-c440-4360-ab4a-37b76fc639a7
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Gebäudemanagement für Standorte SOLLTE die Wirksamkeit der Brandschutzmaßnahmen {{ insert: param, geb.10.2.8-prm1 }} überprüfen.

Guidance

Eine regelmäßige Überprüfung von Brandmeldeanlagen, Rauchmeldern und organisatorische Maßnahmen stellt sicher, dass diese weiterhin funktionieren. Hier besteht ein enger Zusammenhang zu Compliance-Verpflichtungen, die Brandschutzprüfungen fordern.

Control: GEB.10.3 - Wasserschutz

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.10 Schutz vor Elementarschäden
UUID: 6f00e3ab-1053-42c0-8c40-0a9d79b0656d
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor

Statement

Gebäudemanagement für Standorte SOLLTE zwischen Assets und Witterungs- sowie Wassergefahrenstellen mindestens eine physische Schutzmaßnahme vor Wasser nach den entsprechenden Normen installieren.

Guidance

Relevant ist hierbei sowohl Wasser von oben (Regen und Schnee), als auch von unten (Überflutungen, gesammeltes Regenwasser). Maßnahmen können z.B. witterungsbeständige Baumaterialien, Abdichtungen, Überdachungen, Entwässerungssysteme oder eine erhöhte Positionierung, die eher nicht in überfluteten Bereichen liegen wird, sein. Schränke und Gehäuse können auch mit einer geeigneten IP-Schutzklasse (z.B. IP65) gegen Wasser geschützt werden.

Control: GEB.10.3.1 - Doppelter baulicher Wasserschutz

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.10 Schutz vor Elementarschäden

Übergeordnetes Control:

GEB.10.3 Wasserschutz

UUID: 6b169c24-0f22-4ef3-bfe5-3a95e49e4131

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN zwischen Wassergefahrenstellen und Assets mindestens zwei bauliche Schutzmaßnahmen vor Wasser nach den entsprechenden Normen installieren.

Guidance

Relevant ist hierbei sowohl Wasser von oben (Regen und Schnee), als auch von unten (Überflutungen, gesammeltes Regenwasser). Maßnahmen können z.B. witterungsbeständige Baumaterialien, Abdichtungen, Abkofferungen, Überdachungen, oder Entwässerungssysteme sein. Schränke und Gehäuse können auch mit einer geeigneten IP-Schutzklasse (z.B. IP65) gegen Wasser geschützt werden.

Control: GEB.10.3.2 - Leckagesensor

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: GEB.10 Schutz vor Elementarschäden

Übergeordnetes Control:

GEB.10.3 Wasserschutz

UUID: a7d0e63e-e589-4587-bf0b-043e36515dac

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN Wassereinbrüche überwachen.

Guidance

Maßnahmen können z.B. Wassersensorstreifen unter Doppelböden sein, die SNMP-Traps an ein Building Management System (BMS) senden.

Control: GEB.10.4 - Blitzschutzeinrichtungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.10 Schutz vor Elementarschäden
UUID: 3a8c199a-408d-4ac6-9355-b850d4f5188a
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- GEB.10.4.1 Niederohmigkeit

Statement

Gebäudemanagement für Standorte SOLLTE Blitzschutzeinrichtungen nach {{ insert: param, geb.10.4-prm1 }} installieren.

Guidance

Blitzschutzeinrichtungen sind bauliche oder technische Maßnahmen, die Gebäude, Anlagen und darin befindliche Systeme vor den direkten und indirekten Auswirkungen eines Blitzeinschlags schützen. Der Zweck dieser Regelung liegt darin, Risiken durch Blitzeinschläge zu reduzieren: Ein direkter Einschlag könnte Gebäudestrukturen beschädigen, Brände verursachen oder elektrische Systeme zerstören. Indirekte Einschläge könnten durch Überspannungen Datenverluste oder den Ausfall kritischer Systeme hervorrufen. Die Installation nach anerkannten Standards kann hier Schäden an Bausubstanz, Stromversorgung und Informationssystemen verhindern und die Verfügbarkeit sensibler Infrastruktur sichern. Ein anerkannter Standard ist hier die DIN EN 62305, die Anforderungen an Planung, Errichtung und Prüfung von Einrichtungen wie Fangstangen oder Erdungsanlagen definiert. Sie kennt verschiedene Schutzklassen. Für Standorte mit normalem Schutzbedarf wird Schutzklasse II oder besser gemäß DIN EN 62305 empfohlen. Für Räume für technische Infrastruktur oder Rechenzentren ist mindestens die Blitzschutzzone 2 (LPZ 2) sinnvoll.

Control: GEB.10.4.1 - Niederohmigkeit

Tag: "Inspektion"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.10 Schutz vor Elementarschäden
Übergeordnetes Control:
GEB.10.4 Blitzschutzeinrichtungen
UUID: a70149a9-75af-4784-8011-e1433c72dcfc
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Standorte KANN Blitzschutzeinrichtungen {{ insert: param, geb.10.4.1-prm1 }} auf Niederohmigkeit überprüfen.

Guidance

Eine niedrige Ohmzahl in Erdungs- und Potentialausgleichseinrichtungen gewährleistet, dass Blitzströme schnell und wirksam abgeleitet werden. Siehe DIN VDE 0100-443 u. -534. Beachten Sie dabei auch die Prüfpflicht aus der Betriebssicherheitsverordnung (BetrSichV).

Links

related: GEB.9.4 Überspannungsschutz

Control: GEB.10.5 - Ableitfähiger Fußbodenbelag

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: GEB.10 Schutz vor Elementarschäden
UUID: face1ab3-e01f-41eb-8870-f2020a5640bc
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Gebäudemanagement für Räume für technische Infrastruktur KANN im Nahfeld von Systemen einen ableitfähigen Fußbodenbelag installieren.

Guidance

Ein ableitfähiger Boden ist ein Fußbodenbelag, der es ermöglicht, statische Aufladungen abzuleiten, beispielsweise durch eine geerdete Verbindung. Er zeichnet sich durch einen elektrischen Widerstand zwischen 10^6 und 10^9 Ohm aus. Ableitfähige Böden werden in Bereichen eingesetzt, in denen elektrostatische Entladungen (ESD) vermieden werden müssen. Die Umsetzung kann nach DIN EN 14041 oder DIN IEC 61340-4-1 erfolgen.

Control: ASST.1.1 - Verfahren und Regelungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.1 Grundlagen
UUID: b3a2e5a0-380a-4770-86e6-ea1d8d586ad7
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ASST.1.1.1 Dokumentation
- ASST.1.1.2 Zuweisung der Aufgaben
- ASST.1.1.3 Bekanntgabe

Statement

Informationen und Assets MUSS Verfahren und Regelungen zum Management von Informationen und damit verbundener Assets verankern.

Guidance

Informationsmanagement ist der systematische Umgang mit Informationen während ihres gesamten Lebenszyklus, einschließlich von Regelungen, Prozessen und technischen Verfahren zur Erhebung, Verarbeitung, Speicherung, sowie Löschung und Vernichtung. Dazu gehören z.B. Schutzbedarf, Verarbeitung in den Geschäftsprozessen, Aufbewahrungs- und Löschfristen. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Control: ASST.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.1 Grundlagen

Übergeordnetes Control:

ASST.1.1 Verfahren und Regelungen

UUID: a35e9d4f-11a0-4d7e-a3b6-e4e71d7c56ca

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: ASST.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.1 Grundlagen

Übergeordnetes Control:

ASST.1.1 Verfahren und Regelungen

UUID: c2e8fafc-2e0d-40ad-b3ec-c572bf70a2b7

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, asst.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es die Zuweisung anhand von Rollen (z.B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: ASST.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.1 Grundlagen

Übergeordnetes Control:

ASST.1.1 Verfahren und Regelungen

UUID: 36165531-a3f9-4efc-a667-8b5cb57e0938

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: ASST.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.1 Grundlagen

UUID: 28b3c126-8ba5-4fcc-8cb1-84b79f1bff4d

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets MUSS die Verfahren und Regelungen {{ insert: param, asst.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante Überprüfung der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: ASST.2.1 - Inventar der Informationen

Tag: "Inventories"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.2 Inventarisierung
UUID: c07f7e22-1641-41e2-a29c-f1180ff9f601
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ASST.2.1.1 Informationsverantwortung

Statement

Informationen und Assets SOLLTE ein Inventar der Informationen und damit verbundener Assets dokumentieren.

Guidance

Um die Informationssicherheit zu schützen ist es erforderlich, die zu schützenden Werte systematisch zu erfassen und ihre Verwendung über den gesamten Lebenszyklus nachzuhalten. Sinnvoll ist es hierbei, den Detaillierungsgrad des Inventars angepasst an Schutzbedarf und Risikoprofil des Informationsverbundes zu wählen. Das Inventar kann eine Übersicht der für Geschäftsprozesse relevanten Kategorien von schützenswerten Informationen, z.B. für Kunden Vor- und Nachname, Adresse, IBAN, Telefonnummer, Kundenkennwort als Grundlage haben. Es muss sich allerdings nicht um eine einzige Liste von Informationen und Assets handeln. Um eine leichtere, automatische Pflege des Inventars zu ermöglichen ist es vielmehr sinnvoll, eine Reihe dynamischer Inventare oder Datenbestände möglichst nahe an der Quelle der Informationen zu verwenden, z.B. eine Verzeichnisdatenbank für Zugangskonten und Systeme, eine Anwendung zum Assetmanagement für physische Assets, sowie Dateisysteme oder Datenbanken für einzelne Dateien und Daten. Falls ein datenschutzrechtliches Verarbeitungsverzeichnis für die Erfassung von personenbezogenen Daten besteht, kann es ebenfalls in das Inventar einbezogen werden. Für physische Dokumente kann ein Aktenbestandsverzeichnis eingesetzt werden. Zur Erfassung von Netzen siehe Praktik Architektur. Zur Erfassung von Identitäten, Zugangskonten und Berechtigungen siehe Praktik Berechtigung. Für kurzlebige Informationen, z.B. virtuelle Maschinen, nur on-demand automatisch eingerichtet und

wieder gelöscht werden oder händische Notizen, die nicht systematisch verarbeitet werden, ist keine Inventur erforderlich. Für Details zum IT-Assetmanagement siehe ISO/IEC 19770-1.

Links

related: ARCH.2.4 Inventar der Netze

Control: ASST.2.1.1 - Informationsverantwortung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.2 Inventarisierung

Übergeordnetes Control:

ASST.2.1 Inventar der Informationen

UUID: eae7145a-228e-47ca-9a09-7a4a3b74ac55

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Daten SOLLTE die Zuständigkeit für deren Verarbeitung {{ insert: param, asst.2.1.1-prm1 }} zuweisen.

Guidance

Hiermit ist das Eigentum oder die institutionsinterne Zuständigkeit für die Nutzung und den damit einhergehenden Schutz der jeweiligen Informationen und Assets (Asset Ownership) gemeint. Klare Zuweisungen stellen sicher, dass den Beteiligten nicht nur ihre prozessualen Aufgaben, sondern auch ihre Zuständigkeit für die konkreten Informationen bewusst und die damit verbundenen Pflichten bewusst sind. Dies kann durch dezentrales Nachhalten der Verantwortung nachgehalten werden. Alternativ kann auch eine Gruppierung der Informationen nach Assets wie Anwendungen oder Diensten umgesetzt werden, so dass die Zuständigen für das Asset dadurch auch die Zuständigkeit für die Informationen enthalten, die dort verarbeitet werden.

Control: ASST.2.2 - Inventar der Systeme

Tags: "Inventories" "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.2 Inventarisierung
UUID: b10fc10c-a3be-4b30-977a-6a2d020760d6
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme

Statement

Informationen und Assets SOLLTE ein Inventar der IT-Systeme einschließlich Identifikationsbezeichnung und letztem bekannten Verbleib dokumentieren.

Guidance

Hierbei sind neben physischen Endgeräten auch Hostsysteme, virtuelle Systeme, IoT-Geräte, Funkgeräte und Fahrzeuge relevant, wenn diese für die Verarbeitung von Daten aus dem Informationsverbund bestimmt sind. Als Identifikationsbezeichnung ist z.B. die Identifikationsnummer gemeint. Hierzu können z.B. eine Gerätenummer, Hardware-MAC-Adresse oder ein DNS-Name zählen, anhand derer das System eindeutig und nachvollziehbar identifiziert wird. Mit Verbleib ist hier z.B. der physische Standort, die Person, das Virtualisierungssystem oder die Netzadresse gemeint, wo das IT-System zu finden ist. Kann durch Integration in das Inventar der Informationen umgesetzt werden. Ein Asset-Inventar kann im einfachsten Fall händisch gepflegt werden. Empfehlenswert ist jedoch, auch automatisierte Systeme zum Erfassen von Asset-Inventar (z.B. Verzeichnisdienste, CMDB, DHCP-Logging, Passive Asset Discovery Tools, EDR oder MDM) einzusetzen.

Control: ASST.2.2.1 - Aufdecken unautorisierter IT-Systeme

Tag: "Rogue Access Point"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.2 Inventarisierung
Übergeordnetes Control:
ASST.2.2 Inventar der Systeme
UUID: 02a49908-868b-45de-9ce5-56cb230ab8ee
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Netze SOLLTE das Aufdecken unautorisierter IT-Systeme verankern.

Guidance

Ziel ist sicherzustellen, dass keine unautorisierten Assets im Informationsverbund betrieben werden. Hierzu können z.B. aktive Netzscans (z.B. mit Nmap), passive Analysen des Netzwerkverkehrs oder spezielle Werkzeuge zur Erkennung von unbekannten WLAN-Access-Points (z.B. Kismet) genutzt werden. Zur Behandlung können die gefundenen IT-Systeme beispielsweise aus dem Netz entfernt, in eine Quarantäne verschoben oder nach Überprüfung autorisiert werden.

Links

related: DET.4.19 Unautorisierte Sendeanlagen

Control: ASST.2.3 - Inventar der Anwendungen

Tag: "Inventories"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.2 Inventarisierung
UUID: d55d7e49-436e-4783-9ad0-5f92619da743
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.2.3.2 Software Bill of Materials (SBOM)

Statement

Informationen und Assets SOLLTE ein Inventar der Anwendungen einschließlich Produktname, Versionsstand, Herkunft und Lizenzierung dokumentieren.

Guidance

Ein zentrales Inventar der Anwendungen, oft auch als Application Inventory oder Teil des Software Asset Management (SAM) bezeichnet, dient als grundlegende, strukturierte Übersicht aller in der Institution eingesetzten Applikationen. Relevant sind dabei sowohl lokal installierte Anwendungen, als auch solche, die auf Cloud-Servern oder in verteilten Diensten betrieben werden. Hierbei beschreibt die Herkunft nicht nur den Hersteller, sondern auch den Lieferanten oder die Bezugsquelle, um die Vertrauenswürdigkeit bewerten zu können. Die Lizenzierung erfasst die rechtliche Grundlage für die Nutzung, einschließlich des Lizenzmodells (z.B. pro Benutzer, pro Gerät, Abonnement), der Anzahl erworbener Lizenzen und deren Gültigkeitsdauer. Häufig sind weitere Angaben sinnvoll, z.B. Beschaffungs- und Installationszeitpunkt, URL, App-Store, Schnittstellen wie z.B. Cloud-APIs oder Datenexporte in andere Anwendungen, auch auf Dateiserver. Ohne eine solche Übersicht könnte die Institution unwissentlich Software mit bekannten, kritischen Schwachstellen einsetzen oder durch den Einsatz nicht lizenzierter Produkte hohe finanzielle und rechtliche Risiken eingehen. Ein gepflegtes Inventar kann hingegen bei neuen Sicherheitswarnungen eine schnelle Auswirkungsanalyse ermöglichen. Zur praktischen Umsetzung kann die Institution eine zentrale Liste, beispielsweise in einer Datenbank oder einem spezialisierten SAM-Tool, aufbauen, die durch verschiedene Quellen gespeist

wird. Eine automatisierte Erfassung kann durch technische Werkzeuge erfolgen, wie zum Beispiel durch (1) Netzwerks-Scanner, die installierte Applikationen auf Endgeräten identifizieren, (2) Agenten-basierte Systeme, die kontinuierlich Software-Änderungen melden, oder (3) die Auswertung von Daten aus zentralen Software-Verteilungssystemen. Die Dokumentation kann auch durch eine Liste mit Verweisen umgesetzt werden (z.B. auf die Lizenzdateien und Schnittstellenkonfiguration).

Control: ASST.2.3.1 - Autorisierung von Anwendungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.2 Inventarisierung

Übergeordnetes Control:

ASST.2.3 Inventar der Anwendungen

UUID: 3d12c2e5-94bd-48d2-bf9c-a5797e4f0378

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für IT-Systeme SOLLTE die Nutzung von Anwendungen auf diesen durch {{ insert: param, asst.2.3.1-prm1 }} autorisieren.

Guidance

Der Sinn dieser Regelung liegt in der Minimierung von Risiken, die durch unkontrollierte Nutzung entstehen. Durch nicht autorisierte Anwendungen könnte beispielsweise Schadsoftware in die Systeme der Institution eingeschleust, könnten durch Sicherheitslücken in veralteter Software Angriffsvektoren geöffnet oder könnten durch den Einsatz nicht konformer Tools sensible Informationen unkontrolliert abfließen. Ein strukturierter Autorisierungsprozess kann somit die Integrität der IT-Systeme wahren und sicherstellen, dass nur geprüfte, für den Geschäftszweck erforderliche und aus rechtlicher Sicht unbedenkliche Anwendungen zum Einsatz kommen, was die gesamte Angriffsfläche der Institution signifikant reduziert. Relevant sind dabei sowohl lokal installierte Anwendungen, als auch solche, die auf Cloud-Servern oder in verteilten Diensten betrieben werden. Je nach Geschäftsprozessen oder Risikoprofil kann die Autorisierung einzeln für jedes System und jede Anwendung, oder für bestimmte Kategorien von Systemen oder Anwendungen vorgenommen werden (z.B. "Alle Office-Produkte eines bestimmten Herstellers auf Notebooks mit einem bestimmten Betriebssystem). Hierbei ist es sinnvoll, Standard-Anwendungen zu bestimmen, die für alle Nutzenden freigegeben sind und die Verwendung darüber hinausgehender Anwendungen pro Nutzer oder Organisationseinheit zu autorisieren.

Control: ASST.2.3.2 - Software Bill of Materials (SBOM)

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.2 Inventarisierung

Übergeordnetes Control:

ASST.2.3 Inventar der Anwendungen

UUID: ddd9f433-8d27-4ed5-9061-e77fc9564dbc

Aufwand: 4

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ASST.2.3.2.1 Software Discovery

Statement

Informationen und Assets für Anwendungen SOLLTE die Software Bill of Materials (SBOM) dokumentieren.

Guidance

Eine Software Bill of Materials (SBOM) ist in diesem Zusammenhang eine strukturierte Liste aller Komponenten, Bibliotheken und Abhängigkeiten, die in einer Anwendung enthalten sind, einschließlich ihrer Versionen und Herkunft. Sie kann dabei sowohl Open-Source- als auch proprietäre Bestandteile erfassen und in maschinenlesbaren Formaten (z. B. SPDX, CycloneDX) vorliegen. Der Zweck dieser Dokumentation liegt darin, Transparenz über die eingesetzten Softwarebestandteile zu schaffen, sodass Abhängigkeiten, potenzielle Schwachstellen oder veraltete Komponenten nachvollziehbar bleiben. Ohne diese Transparenz könnte es bei Sicherheitsvorfällen, Lizenzkonflikten oder fehlender Wartbarkeit zu erheblichen Problemen kommen, während eine gepflegte SBOM die schnelle Identifikation von Risiken, die Minimierung von Vendor Lock-in und die Nachvollziehbarkeit der Software-Lieferkette unterstützen kann. Hierzu kann die BSI TR-03183-2 verwendet werden.

Control: ASST.2.3.2.1 - Software Discovery

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.2 Inventarisierung

Übergeordnetes Control:

ASST.2.3.2 Software Bill of Materials (SBOM)

UUID: be8d7b56-9709-4d1b-aeaa-cb5fa1b0cca1

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Informationen und Assets KANN die Aktualität des Inventars der Anwendungen durch ein automatisiertes Verfahren {{ insert: param, asst.2.3.2.1-prm1 }} überprüfen.

Guidance

Die automatische Aktualisierung des Anwendungsinventars (etwa bei Installationen, Konfigurationsänderungen und Deinstallationen) dient in erster Linie der vollständigen Transparenz über die IT-Landschaft. Ein aktuelles Anwendungsinventar kann als Grundlage für Compliance-Nachweise, Lizenzmanagement und Schwachstellenanalysen dienen. Die Automatisierung dieses Prozesses verringert dabei den manuellen Verwaltungsaufwand und erhöht die Datenqualität, da menschliche Fehler oder Versäumnisse bei der Dokumentation vermieden werden können. Konkrete Anwendungsfälle können die automatische Erfassung einer neu installierten ERP-Software im Inventar, die Dokumentation einer Konfigurationsänderung an einer Firewall-Anwendung oder die Entfernung einer nicht mehr genutzten Datenbanksoftware aus dem Inventar sein. Auch Updates von Anwendungen, Änderungen an Zugriffsberechtigungen oder Konfigurationsanpassungen aufgrund neuer Sicherheitsanforderungen können als relevante Ereignisse für eine Inventaraktualisierung betrachtet werden. Für die Umsetzung können Software Asset Management (SAM) Tools eingesetzt werden, die über Agenten oder regelmäßige Netzwerk-Scans Änderungen erkennen. Eine Alternative kann die Integration von Deployment- und Konfigurationsmanagement-Systemen mit der CMDB (Configuration Management Database) sein, wodurch jede Änderung automatisch im zentralen Inventar gespiegelt wird. Die Implementierung von Event-Triggern in der IT-Infrastruktur kann ebenfalls dazu beitragen, dass bei definierten Ereignissen eine sofortige Inventaraktuali-

sierung ausgelöst wird. Einen hohen Mehrwert für alle Sicherheitsbereiche kann es haben, Inventardaten aus verschiedenen Quellen automatisiert miteinander abzugleichen, z.B. aus Verzeichnisdiensten, AMDB, EDR und CMDB. Eine regelmäßige Validierung der Prozesse durch Stichprobenkontrollen kann dabei helfen, die Vollständigkeit und Genauigkeit der automatisierten Inventarisierung zu gewährleisten.

Control: ASST.2.4 - Klassifizierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.2 Inventarisierung
UUID: 41530972-ff04-4df0-a2b5-8bab6859becb
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Daten SOLLTE diese einer Schutzbedarfsklasse zuweisen.

Guidance

Klassifizierung dient dazu, Daten entsprechend ihrer Schutzbedürftigkeit systematisch zu ordnen, um angemessene Schutzmaßnahmen zielgerichtet umzusetzen und Risiken effektiv zu reduzieren. Unter Klassifizierung versteht man dabei die Einteilung von Daten in Kategorien, etwa "öffentlich", "intern", "vertraulich" oder "Verschlussache - Nur für den Dienstgebrauch". Beispielsweise ist eine öffentlich zugängliche Marketingbroschüre weniger sensibel als personenbezogene Kundendaten, Betriebs- und Geschäftsgeheimnisse oder staatliche Verschlussachen. Anzahl der Klassen und Umfang der Beschreibungen können sich an den ermittelten Risiken und der Menge der verarbeiteten Informationen orientieren. Die Kriterien zur Klassifizierung können sich daran orientieren, mit welchen Schäden eine Kompromittierung der Vertraulichkeit, Integrität oder Verfügbarkeit verbunden wäre, z.B. geschätzte Umsatzverluste, Gefahr für die Allgemeinheit, Schädigung der Rechte und Freiheiten betroffener Personen. Für Assets ist es sinnvoll, diese im Einklang mit der Klassifikation der Informationen ebenfalls in Klassen zu unterteilen, für deren Verarbeitung sie gebraucht werden. Je nach Aufgaben der Institution und Arten von verarbeiteten Informationen bietet es sich an, ein bestehendes Klassifikationschema 1:1 zu verwenden - etwa das Schema der Verschlussachenanweisung (VSA) - oder ein eigenes Schema zu erstellen, in dem mehrere bestehende Schemata auf die eigenentwickelten Klassen abgebildet werden.

Control: ASST.3.1 - Nutzungsvereinbarungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: ec6bc7aa-7f8c-4cb1-a564-73e39401051f
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit

Statement

Informationen und Assets für Nutzende SOLLTE diese zu den Regelungen der Nutzung von Informationen und anderen Assets anweisen.

Guidance

Wenn Nutzende nicht angewiesen werden bestimmte Nutzungsregelungen einzuhalten, dann könnte es zu ungewollten Verstößen gegen die Sicherheitsverfahren kommen. Auch Maßregelungen bei Verstößen werden erschwert, wenn unklar ist, ob Verstöße für die Nutzenden vorher als solche erkennbar waren. Dies gilt insbesondere für externe Personen, die nur durch die Nutzung von Assets mit den Regelungen in Berührung kommen könnten, z.B. Kunden oder Drittunternehmen. Die konkreten Regelungen ergeben sich aus den Maßnahmen zur Umsetzung der anderen Anforderungen dieser Praktik und den Anforderungen zur Sensibilisierung.

Links

related: SENS.1.1 Verfahren und Regelungen

Control: ASST.3.1.1 - Weitergabe nur bei Erforderlichkeit

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
Übergeordnetes Control:
ASST.3.1 Nutzungsvereinbarungen
UUID: 32afe7a4-d3d4-43d2-a37b-8ecd45ea69f5
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Nutzende SOLLTE zur Weitergabe von Informationen nur bei Erforderlichkeit anweisen.

Guidance

Das Need-to-Know-Prinzip ist ein Sicherheitskonzept, das den Zugriff auf Informationen auf das absolut notwendige Maß beschränkt. Es besagt, dass Personen nur dann Zugang zu bestimmten Daten erhalten, wenn diese Informationen für die Erfüllung ihrer konkreten Aufgaben erforderlich sind. Ziel ist es, das Risiko von Datenmissbrauch, -verlust oder unbefugtem Zugriff zu minimieren.

Links

related: SENS.5.2 Weitergabe von Informationen

Control: ASST.3.2 - Entfernung nicht erforderlicher Rest- oder Zusatzdaten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: 5316fe85-7996-41dc-a475-4d5cfeda250c
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Daten SOLLTE die Entfernung nicht erforderlicher Rest- oder Zusatzdaten verankern.

Guidance

Hierunter können z.B. Metainformationen wie Bearbeiternamen oder Geostandorte fallen. Handelt es sich um strukturierte Daten, so ist eine automatisierte Entfernung leicht möglich. Für unstrukturierte Daten hat sich eine Kombination aus automatischer Filterung / Regex und manueller Überprüfung bewährt.

Control: ASST.3.3 - Kennzeichnung

Tag: "Archivierung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: 627d3364-806b-4ea0-8ef0-43dfefd0b027
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets SOLLTE die Kennzeichnung von Informationen verankern.

Guidance

Kennzeichnungen helfen dabei sicherzustellen, dass vertrauliche, personenbezogene oder besonders kritische Daten im gesamten Lebenszyklus angemessen behandelt werden – von der Erstellung über die Verarbeitung bis hin zur Archivierung oder Löschung. Hierzu gehört sowohl die Kennzeichnung physikalischer Systeme oder Speichermedien als auch die virtuelle Kennzeichnung, z.B. durch Metadaten oder die Kopfzeile eines Dokumentes. Eine klare Kennzeichnung kann dazu beitragen, unbeabsichtigte Offenlegung, unsachgemäße Weitergabe oder unsichere Verarbeitung zu vermeiden, die Sensibilisierung für den Umgang mit verschiedenen Informationsarten fördern und rechtlichen oder regulatorischen Anforderungen (z. B. DSGVO, Geheimschutz) Rechnung tragen. Beispiele sind Informationen, die einer bestimmten Schutzbedarfsklasse (z. B. „vertraulich“, „intern“) zugeordnet sind. Auch personenbezogene Daten, Forschungsergebnisse, Finanzinformationen, Sicherheitskonzepte oder technische Spezifikationen können einer Kennzeichnungspflicht unterliegen. Die Art der Kennzeichnung kann visuell erfolgen, etwa durch Wasserzeichen, farbige Markierungen, Aufkleber, sowie Kopf-/Fußzeilen oder Metadaten in Dateien. Wichtig ist, dass die Kennzeichnung verständlich, konsistent und leicht erkennbar ist, um ihre Schutzwirkung zu entfalten. Zur Umsetzung ist es nicht erforderlich, dass alle Daten, Systeme oder Speichermedien gekennzeichnet sind sondern nur solche, deren Risikoprofil eine solche Kennzeichnung erforderlich macht - hier ist insbesondere die Vertraulichkeit oder Verfügbarkeit relevant. Dokumentvorlagen, automatisierte Klassifizierungsfunktionen in gängigen Office-Programmen oder Richtlinien in einem DMS können helfen die Einhaltung zu gewährleisten.

Control: ASST.3.4 - Kennzeichnung ohne vertrauliche Daten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: e6bdfec9-97ef-405a-a90f-e5b63f900e21
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für IT-Systeme SOLLTE Kennzeichnung ohne vertrauliche Daten verankern.

Guidance

Enthalten Kennzeichnungen vertrauliche Daten wie den Namen des zugeordneten Mitarbeiters, des Standortes, der Netzstruktur oder der Abteilung, so könnten diese Angaben von Angreifern ausgelesen werden, z.B. über das Netz, per Bluetooth oder durch physisches Ablesen. Die so abgeflossenen Daten könnten Angreifer zur weiteren Ausforschung der Institution oder des Zugangs zu Daten missbrauchen.

Control: ASST.3.5 - Tainting

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: 11c6919e-1dac-4816-9b42-88218c04c62b
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für Daten KANN eine Markierung durch eingebettete Daten oder Funktionen zur Wiedererkennung zuweisen.

Guidance

Zielt darauf ab, die Nachverfolgbarkeit und Kontextbindung von Daten zu ermöglichen, insbesondere in komplexen IT-Systemen, in denen Daten über viele Verarbeitungsschritte hinweg genutzt, kombiniert oder verteilt werden. Durch die Einbettung spezifischer, erkenntlicher Merkmale (z.B. Metadaten, Marker oder Funktionsventhalten) kann ein Datensatz identifizierbar gemacht werden, ohne dass seine Funktion oder Nutzbarkeit wesentlich eingeschränkt wird. Dies kann bei der Erkennung unerlaubter Datenweitergaben, der Nachverfolgung von Datenflüssen oder bei Sicherheitsanalysen hilfreich sein, insbesondere wenn potenziell sensible oder schützenswerte Daten im Spiel sind. Für welche Daten Tainting gezielt eingesetzt wird kann sich nach deren Klassifizierung oder einer spezifischen Risikoanalyse richten. Beispiele für Tainting-Mechanismen können sein: das Einfügen eines unsichtbaren Wasserzeichens in ein Dokument, das Anhängen kryptografisch prüfbarer Metadaten an Datensätze, Dummy-Datensätze oder das Verwenden von Datencontainern, die sich beim Zugriff oder bei der Weitergabe protokollierend verhalten. Auch das Markieren von Datenbankeinträgen mit zusätzlichen Attributen, die Rückschlüsse auf Herkunft, Vertrauensstufe oder Kontext erlauben, kann eine Form des Taintings darstellen. Ebenso kann bei Programmcode eine Markierung durch sogenannte Taint-Tracking-Systeme erfolgen, die überwachen, welche Eingaben in sicherheitskritische Operationen einfließen. Für die Umsetzung kann der Einsatz strukturierter Datenformate (wie XML oder JSON mit Markierungsfeldern), der Aufbau kontrollierter Datenflüsse mit Protokollierung oder das Nutzen von Middleware-Komponenten mit Tainting-Funktionalität in Betracht gezogen werden. Wichtig ist dabei, dass die Tainting-Informationen robust, interpretierbar und möglichst schwer entfernbar ge-

staltet werden, um ihre Wirksamkeit zu sichern. Die Wahl geeigneter Methoden hängt stark vom Anwendungskontext, den Schutzbedarfen und den bestehenden Systemarchitekturen ab.

Control: ASST.3.6 - Verifikation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: fdf57ca0-77d0-4725-9709-19c0f1082a31
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für Informationen KANN die Korrektheit anhand anderer Informationsquellen testen.

Guidance

Wenn die Korrektheit bestimmter Informationen von hoher Bedeutung ist, hilft eine Verifikation aus zweiter Quelle dabei, fundierte und belastbare Entscheidungen in sicherheitsrelevanten Situationen treffen zu können. Durch Verifikation wird das Risiko verringert, dass Fehlinformationen in Geschäftsprozessen oder dem Sicherheitsmanagement weiterverarbeitet werden und sich Fehler so fortsetzen oder Vorfälle übersehen werden. Sie kann insbesondere dazu beitragen, Fehlalarme zu erkennen, Täuschungsversuche (z.B. durch gefälschte Logdaten) zu identifizieren oder die Wirksamkeit von Gegenmaßnahmen zu bewerten. Die Anforderung stärkt somit die Integrität und Qualität der sicherheitsbezogenen Lagebewertung. Beispiele für Ereignisse können sicherheitsrelevante Systemmeldungen, Alarme aus Intrusion Detection Systemen (IDS), Hinweise auf Datenabflüsse oder ungewöhnliches Nutzerverhalten sein. Informationsquellen können externe Dienstleister, Zeugen, Sicherungskopien oder Sensoren in der physischen Sicherheit sein. Die Verifikation kann sich in solchen Fällen z.B. auf die Gegenprüfung eines IDS-Alarmes durch Logdaten anderer Systeme oder durch Replizierbarkeit des Ereignisses in einer Testumgebung beziehen. In der Praxis kann eine Verifikation unter anderem durch Korrelation mehrerer unabhängiger Datenquellen erfolgen. Auch das Einführen von Plausibilitätsprüfungen, standardisierten Analyseverfahren oder temporären Reproduktionsversuchen kann hilfreich sein. Eine strukturierte Dokumentation der Informationsquellen und ihrer typischen Aussagekraft kann ebenfalls zur Umsetzung beitragen.

Control: ASST.3.7 - Pseudonymisierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: 6c943ac9-6cd1-4fd2-98b0-6bef3f492022
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für Informationen KANN die Pseudonymisierung vor der Weitergabe verankern.

Guidance

Bei der Pseudonymisierung werden Informationen so verändert, dass sie für den Empfänger nicht mehr dem ursprünglichen Informationswert oder Datensatz zugeordnet werden können, ohne zusätzliche Informationen hinzuzuziehen. Die Weitergabe meint hier jegliche Form des Teilens von Informationen über die Grenzen des Informationsverbundes hinaus – etwa an externe Dienstleister, Behörden oder Partnerinstitutionen – unabhängig davon, ob dies elektronisch, schriftlich oder mündlich geschieht. Anwendungsbeispiele sind personenbezogene Daten oder institutionsinterne IP-Adressbereiche, die zu Diagnosezwecken herausgegeben oder zum Zugriff auf Cloud-Dienste von der Institution verwendet werden. Problematisch ist hierbei oft die funktionsenthaltende Pseudonymisierung, d.h. die Pseudonymisierung derart, dass es bei der beabsichtigten Verwendung zu keinen Problemen durch die Pseudonymisierung kommt. Typische Umsetzungsmaßnahmen können beinhalten: (1) den Einsatz technischer Pseudonymisierungsverfahren wie Hashing oder Tokenisierung, (2) die getrennte, zugriffsbeschränkte Speicherung von Zuordnungstabellen („mapping tables“) in gesicherten Datenräumen oder Datenbanken, und (3) den Einsatz kontrollierter Schlüsselverwaltung, die nur autorisierten Personen eine Re-Identifizierung erlaubt. Auch kann eine Pseudonymisierung in Prozessen oder Schnittstellen fest verankert werden, etwa durch automatisierte Filtermechanismen bei Exporten oder vor externen Übertragungen.

Control: ASST.3.8 - Anonymisierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: 09e9470c-c4d4-466a-9629-5efa6ddb4cd8
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für Informationen KANN die Anonymisierung vor der Weitergabe verankern.

Guidance

Bei der Anonymisierung werden Informationen so verändert, dass sie für den Empfänger nicht mehr dem ursprünglichen Informationswert oder Datensatz zugeordnet werden können. Dabei werden gezielt rückverfolgbare Merkmale entfernt oder verfremdet, sodass eine Zuordnung zu einem bestimmten Informationswert der Institution (z.B. einer Person, Systemkonfiguration oder Zugangskonto) nicht mehr möglich ist. Davon abzugrenzen ist die Pseudonymisierung („pseudonymization“), bei der eine Identifizierbarkeit theoretisch weiterhin besteht, etwa durch separate Zuordnungstabellen oder Schlüssel. Die Weitergabe meint hier jegliche Form des Teilens von Informationen über die Grenzen des Informationsverbundes hinaus – etwa an externe Dienstleister, Behörden oder Partnerinstitutionen – unabhängig davon, ob dies elektronisch, schriftlich oder mündlich geschieht. Beispiele sind die Bildung summarischer Statistiken aus personenbezogenen Daten oder die Ersetzung eines Gerätenamens durch eine zufällige Zeichenkette vor der Herausgabe zu Diagnosezwecken.

Control: ASST.3.9 - Aktualisierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: 9d95707e-8cb2-4442-a202-14d2442920ff
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für Daten KANN deren Aktualisierung verankern.

Guidance

Wenn gespeicherte Daten nicht regelmäßig mit Veränderungen abgeglichen werden, nimmt das Risiko von Fehlern in den Daten zu. Ein Abgleich mit Quellen kann durch automatische Vergleichsprozesse (z.B. anhand von Checksummen) vorgenommen werden oder durch eine Versionsverwaltung erleichtert werden.

Control: ASST.3.10 - Autorisierung von Datenlokationen

Tags: "Lieferketten" "Shadow IT"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: 52eee4a3-f5cf-444d-ad0c-9c83c693481b
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Daten SOLLTE Datenlokationen durch {{ insert: param, asst.3.10-prm1 }} autorisieren.

Guidance

Autorisierte Datenlokationen sind virtuelle oder physische Orte, an denen die Speicherung oder anderweitige Verarbeitung der jeweiligen Datenkategorie durch die Institution erlaubt wird. Physische Orten sind z.B. Serverstandorte in der EU, aber auch die organisatorische Regelung zu Standorten wie dem Mobile Arbeitsplatz oder Auslandsreisen außerhalb der EU gemeint. Regelungen könnten hier z.B. sein: "Verarbeitung als vertraulich markierter Daten nur innerhalb von Institutsgebäuden", "Personenbezogene Daten nur innerhalb der EU". Je nach Datenart bestehen auch häufig Compliance-Verpflichtungen (z.B. DSGVO, Staatenliste im Sinne von § 13 Abs. 1 Nr. 17 SÜG), durch die erlaubte Datenlokationen beschränkt sind. Virtuelle Datenlokationen (z.B. VoIP-Netz, dom0, Hauptgebäude) sind Verarbeitungssphären.

Links

related: BES.2.2 Dokumentation des Rechtsraums und der Datenlokation

Control: ASST.3.11 - Autorisierung von Systemen

Tags: "Data Leak" "Shadow IT"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: 65e6f130-1000-47a4-a551-386d23f6f188
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ASST.3.11.1 Autorisierung von Peripheriegeräten

Statement

Informationen und Assets für Daten SOLLTE für die Informationsverarbeitung verwendete Systeme durch {{ insert: param, asst.3.11-prm1 }} autorisieren.

Guidance

Autorisierte Systeme können einzeln oder als Kategorien von IT-Systemen und Peripherie benannt werden, auf denen bestimmte Daten verarbeitet werden dürfen. Hierzu gehört auch, welche Peripheriegeräte angeschlossen werden dürfen, z.B. z.B. keine Speicherung sensibler Erreichbarkeiten auf einem einfachen Mobiltelefon oder Verarbeitung hochvertraulicher Daten nur auf stationären Endgeräten. Relevant ist dabei auch, ob Bring Your Own Device (BYOD) untersagt oder unter bestimmten Voraussetzungen gestattet ist. Kann entweder einmalig für alle Daten, oder getrennt nach Datenkategorien (z.B. keine personenbezogenen Daten auf Ausleihgeräten) umgesetzt werden.

Links

related: SENS.2.4 Nutzung unautorisierter Assets

Control: ASST.3.11.1 - Autorisierung von Peripheriegeräten

Tags: "Data Leak" "Shadow IT"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.3 Regelungen zum Gebrauch

Übergeordnetes Control:

ASST.3.11 Autorisierung von Systemen

UUID: 75a9c947-c417-4dc7-a942-c27340f20ade

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Daten SOLLTE auch Peripheriegeräte autorisieren.

Guidance

Peripheriegeräte sind externe Hardware-Komponenten sowie virtuelle Geräte, die an IT-Systeme angeschlossen oder eingebunden werden, darunter USB-Sticks, externe Festplatten, Drucker, Kameras, Smartphones, Tablets, virtuelle Laufwerke, software-definierte Netzwerkadapter und emulierte Hardware. Die Autorisierung solcher Geräte schützt vor Sicherheitsrisiken, da unkontrollierte Peripherie Malware einschleusen, Daten exfiltrieren oder als Einfallstor für Angriffe dienen kann; so kann ein privater USB-Datenträger Schadsoftware enthalten, die sich beim Anschluss ausbreitet, oder ein nicht autorisierter Drucker vertrauliche Dokumente in ungeschützten Bereichen ausgeben. Die Umsetzung erfolgt zweckmäßig über eine zentrale Geräteregistrierung, in der alle zulässigen Geräte mit eindeutigen Kennungen erfasst werden; abhängig vom Risikoprofil kann die Autorisierung gerätespezifisch oder für ganze Gerätegruppen erfolgen (etwa für alle beschafften Tastaturen und Mäuse). Administrative Prozesse umfassen ein Antragsverfahren für neue Peripheriegeräte mit Sicherheitsbewertung, die regelmäßige Überprüfung und Aktualisierung der Gerätelisten sowie die Definition von Gerätekategorien mit abgestuften Autorisierungsebenen, beispielsweise vollständig gesperrte USB-Ports für externe Nutzer, eingeschränkte Freigaben für Standardarbeitsplätze und erweiterte Berechtigungen für Administratoren. Technisch wird dies durch Device-Control-Lösungen unterstützt, die nur autorisierte Geräte anhand von Hardware-IDs, Herstellerzerti-

fikaten oder digitalen Signaturen erkennen und freischalten; ergänzend erhöhen Logging-Mechanismen zur Nachverfolgung sämtlicher Peripheriegeräte-Aktivitäten die Transparenz und Auditierbarkeit der Prozesse. Die Autorisierung selbst erfolgt durch die Personen oder Rollen, die in der Organisation für die Freigabe der betreffenden Systeme verantwortlich sind.

Links

related: KONF.3.7 Einschränkung angeschlossener Peripherie

Control: ASST.3.12 - Autorisierung von Personen oder Institutionen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: 523f8482-4664-41ac-b131-6525c5cfa255
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Daten SOLLTE den Zugriff von Personen oder Institutionen im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement autorisieren.

Guidance

Ziel dieser Regelung ist es, sicherzustellen, dass nur berechtigte Stellen auf sensible Werte zugreifen, wodurch unautorisierte Einsichtnahme, Manipulation oder Missbrauch verhindert werden kann. Ohne eine klare Kopplung an Identitäts- und Berechtigungsmanagement könnte es zu unkontrollierten Datenabflüssen, Einsicht durch Dritte oder langfristigen Abhängigkeiten von bestimmten Dienstleistern kommen, die den Zugriff einseitig steuern könnten. Eine korrekte Umsetzung kann hingegen Transparenz schaffen und den Zugriff auf Informationen nachvollziehbar, reversibel und sicher gestalten. Umfasst sowohl die Autorisierung eigenen Personals, als auch die Autorisierung externer Dienstleister oder Partner. Die Formulierung "im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement" bedeutet, dass die Autorisierung so erfolgt, wie in der Praktik Berechtigung (BER) festgelegt.

Links

related: BER.1.1 Verfahren und Regelungen

Control: ASST.3.13 - Lagerung physischer Assets

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: b820e891-c4b8-4673-abec-d3c6d51522d2
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Administrierende SOLLTE zur Lagerung physischer Assets in einem dazu vorgesehenen Lager anweisen.

Guidance

Lagerung meint hier die Aufbewahrung nicht an Nutzende ausgegebener physischer Assets. Die Lagerung kann in verschlossenen Lagerräumen, Schränken oder bei Dienstleistern erfolgen.

Control: ASST.3.14 - Reserve physischer Assets

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.3 Regelungen zum Gebrauch

UUID: c4fd01b1-f0ff-4e91-bef8-dbe0eb1f3d10

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets SOLLTE eine Reserve physischer Assets verankern.

Guidance

Die Beschaffung und Installation von Systemen und deren Peripherie nimmt gewöhnlich eine längere Zeit in Anspruch, weshalb es sinnvoll ist, Ersatzgeräte für Ausfälle bereitzuhalten. Die Menge der Ersatzgeräte reicht aus, wenn sie den voraussichtlichen Bedarf deckt, der bis zur Lieferung und Installation der nächsten Beschaffung vergeht. Der voraussichtliche Bedarf kann aus dem bisherigen Bedarf unter Anpassung an Veränderungen (z.B. Wachstum der Nutzerzahlen) berechnet werden. Typische Assets wären hier z.B. IT-Clients (Desktop PCs/Laptops), Smartphones oder andere häufig genutzte Endgeräte.

Control: ASST.3.15 - Ausleihe physischer Assets

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.3 Regelungen zum Gebrauch
UUID: 04f05ed2-ec82-4abd-80b3-1669ea62976a
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Informationen und Assets KANN einen ausreichenden Ausleihbestand verankern.

Guidance

Wenn bei bestimmten Ereignissen wie Auslandsreisen, Veranstaltungen oder Sicherheitsvorfällen die regulären Endgeräte nicht verwendet werden können (z.B. aufgrund der Regelungen zu Datenlokationen oder der Vorfallsbehandlung), dann ist es sinnvoll Endgeräte bereitzuhalten, die nur mit den für die Ereignisse notwendigen Anwendungen und Daten ausgestattet sind. Die Menge der Ausleihgeräte ist ausreichend, wenn sie den Bedarf deckt. Der Bedarf kann anhand einer Prognose ermittelt werden, die sich wiederum auf bekannte Statistiken (z.B. Anzahl der Nutzenden, Anzahl der Teilnehmer von Schulungsveranstaltungen, Anzahl Auslandsreisen pro Jahr) stützen kann.

Control: ASST.4.1 - Autorisierung von Schnittstellen

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.4 Regelungen zum Transfer
UUID: ddfc1b03-9014-4317-a7bb-09980b234457
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für Daten KANN Schnittstellen, über die Informationen ausgetauscht werden, durch {{ insert: param, asst.4.1-prm1 }} autorisieren.

Guidance

Schnittstellen können hier sowohl physikalisch (z.B. Briefversand, regelmäßige Meetings an einem geschützten Ort) als auch virtuell (API, verschlüsselter Cloudspeicher) sein.

Control: ASST.4.2 - Vertraulichkeit und Integrität beim Transport

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.4 Regelungen zum Transfer
UUID: 5ac7299f-708d-4a07-886f-1dd1228526c7
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Daten SOLLTE Vertraulichkeit und Integrität beim Transport verankern.

Guidance

Transport meint hier sowohl die Datenübertragung per Netz als auch auf physischen Datenträgern (Sneakernet) oder den physischen Transport ganzer Systeme. Zur Umsetzung kann z.B. in Netzen die Transportverschlüsselung und -signierung von E-Mails, Ende-zu-Ende-Verschlüsselung mit PGP genutzt werden. Beim physischen Transport können die vorherige Verschlüsselung von Speichermedien, die Verwahrung von Assets an der Person, Verwahrungsprotokolle, manipulationssichere Verpackungen, Geolocation Tracking oder vertrauenswürdige Kuriere genutzt werden. Die Auswahl der Maßnahmen richtet sich nach dem Schutzbedarf der ausgetauschten Informationen und der Transportart.

Control: ASST.4.3 - Autorisierung von Veröffentlichungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.4 Regelungen zum Transfer
UUID: fa86f5b3-1e36-40bd-a61e-c58e7eba11c0
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets SOLLTE Veröffentlichungen durch {{ insert: param, asst.4.3-prm1 }} autorisieren.

Guidance

„Veröffentlichungen“ bezieht sich hier auf jede Form der öffentlichen oder externen Verbreitung von Informationen, sei es durch Pressemitteilungen, Social-Media-Beiträge, wissenschaftliche Publikationen, öffentliche Datensätze oder zur Erfüllung gesetzlicher Informationspflichten. Hierbei besteht das Risiko, dass vertrauliche Informationen unbeabsichtigt veröffentlicht werden. Kriterien zur Veröffentlichung können z.B. das Entfernen von Geschäftsgeheimnissen oder die Freigabe durch bestimmte Stellen innerhalb oder außerhalb der Institution sein. Der Hauptzweck dieser Anforderung ist die Schaffung einer Gatekeeping-Funktion, um den Informationsfluss zu steuern, der die Institution verlässt, und so das Risiko unbefugter oder schädlicher Offenlegungen zu mindern. Ohne diese Kontrolle könnte eine Institution versehentlich sensible Geschäftsdaten, geistiges Eigentum oder vertrauliche Kundeninformationen offenlegen, was zu schwerwiegendem Reputationsschaden, finanziellem Verlust oder rechtlichen Strafen führen könnte. So könnte ein nicht genehmigter Social-Media-Beitrag Details über ein noch nicht veröffentlichtes Produkt preisgeben, ein Forscher könnte versehentlich einen Datensatz mit vertraulichen Informationen veröffentlichen, oder ein Finanzbericht könnte vorzeitig veröffentlicht werden und Marktvolatilität verursachen. Ein sinnvoller Ansatz könnte die Einrichtung eines gestuften Genehmigungsprozesses sein, der auf der Sensibilität der Informationen basiert und sich am Konzept der Vertraulichkeitsanforderungen orientiert. Eine öffentliche Ankündigung von geringer Sensibilität erfordert möglicherweise nur die Genehmigung durch einen Abteilungsleiter, während ein Finanzbericht mit hohem Risiko die Unterschrift mehrerer Führungskräfte,

einschließlich des Leiters der Rechtsabteilung und des CISO, erfordert. Um dies zu erleichtern, können Institutionen technische Maßnahmen ergreifen, wie z. B. ein digitales Workflow-System, in dem der Veröffentlichungsstatus eines Dokuments nachverfolgt und verwaltet wird. Dieses System könnte Funktionen umfassen wie: (1) automatisches Routing von Dokumenten an die entsprechenden Genehmiger, (2) eine sichere Überwachung aller Genehmigungen und Ablehnungen, und (3) ein zentrales Repository für alle genehmigten und veröffentlichten Materialien. Aus prozessualer Sicht ist es von Vorteil, eine Veröffentlichungs-Checkliste zu erstellen, die sicherstellt, dass alle relevanten rechtlichen und Compliance-Prüfungen vor der Veröffentlichung durchgeführt werden.

Control: ASST.4.4 - Nachweis des Zugangs

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.4 Regelungen zum Transfer
UUID: 7d11d172-7a6a-41ce-a4a6-733cbc34b874
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für Daten KANN einen Nachweis des Zugangs protokollieren.

Guidance

Ein Zugangsnachweis stellt sicher, dass bestimmte Nachrichten ihren Empfänger tatsächlich erreicht haben und dieser Zugang im Streitfall nachvollziehbar belegt werden kann. Dies ist insbesondere in rechtlich relevanten Kontexten oder bei Revisionen von Bedeutung – etwa wenn Fristen, Genehmigungen oder vertrauliche Informationen übermittelt werden. Kriterien können sich an der Nachvollziehbarkeit der Integrität der Informationen oder ihrer Rechtswirkung orientieren, z.B. wenn sie einen Vertragsabschluss oder die Bekanntgabe eines Verwaltungsaktes, auslösen. Beispiele hierfür sind arbeitsrechtlich relevante Dokumente wie Abmahnungen oder Kündigungen, Sicherheitsanweisungen, Änderungen an internen Richtlinien, Zugangsdaten zu sicherheitsrelevanten Systemen oder auch technische Anordnungen mit verbindlichem Charakter. Die Kriterien können zusammen mit anderen Kriterien dokumentiert sein, beispielsweise im Rahmen eines Informationssicherheitskonzepts oder Kommunikationsleitfadens. Die Umsetzung dieser Anforderung kann durch verschiedene technische und organisatorische Maßnahmen erfolgen. Dazu gehören u. a. die Nutzung von E-Mail-Systemen mit Empfangsbestätigung, das Verwenden von Systemprotokollen oder speziellen Portalen mit Zugriffsnachweis. Wichtig ist dabei, dass der Nachweis manipulationssicher gespeichert und nachvollziehbar archiviert wird – bis zum Ablauf einer definierten Aufbewahrungsfrist, z. B. drei oder fünf Jahre, je nach rechtlicher oder organisatorischer Vorgabe. Sinnvoll ist es hierbei nicht nur die Tatsache des Zugangs zu einem bestimmten Zeitpunkt sondern auch für den Nachweis relevante Inhalte zu dokumentieren, z.B. Titel, sowie Versand- und Zieladressen der Nachricht. Sie kann je nach Medium auch den Inhalt der Nachricht enthalten.

Control: ASST.4.5 - Vereinbarungen zum Austausch

Tag: "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.4 Regelungen zum Transfer
UUID: c419af7f-3559-42d5-bb68-be72eac2c509
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Daten SOLLTE Regelungen zum Transfer verankern.

Guidance

Beispielsweise kann es für Geschäfts- und Betriebsgeheimnisse wie Patente sinnvoll sein, eine explizite Vertraulichkeitsvereinbarung abzuschließen, bevor genaue Informationen weitergegeben werden. Hierzu kann z.B. gehören nach welchen Kriterien ausgetauschte Informationen zu klassifizieren sind oder wie in eine bestimmte Klasse eingestufte Daten zu schützen oder verarbeiten sind. Die Vereinbarung über anzuwendende Sicherheitsanforderungen kann anhand von vorformulierten Vertragstexten erfolgen oder über den Austausch von Sicherheitsanforderungen in strukturierten Datenformaten wie OSCAL. Letzteres hat den Vorteil, dass weiterführende Daten etwa zum Umsetzungsstand ebenfalls leichter gepflegt und ausgetauscht werden können.

Control: ASST.5.1 - Wartungsbedarf dokumentieren

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.5 Wartung
UUID: 432cc626-f971-493b-b983-9bad32ed84e0
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für IT-Systeme SOLLTE den Wartungsbedarf für Systemkomponenten und die zum Betrieb erforderliche Infrastruktur dokumentieren.

Guidance

Wartungsbedarf meint die regelmäßig oder anlassbezogen erforderlichen Maßnahmen zur Instandhaltung, Aktualisierung und Funktionssicherung von Systemkomponenten und der Betriebsinfrastruktur eines IT-Systems. Unter Systemkomponenten sind hier sowohl Hardware-Elemente (Server, Netzwerkkomponenten, Speichergeräte) als auch Software-Elemente (Betriebssysteme, Middleware, Anwendungen) zu verstehen; die Infrastruktur umfasst unterstützende Einrichtungen wie Stromversorgung, Klimatisierung, Kommunikationsschnittstellen oder Brandabschottungen für Kabel- und Rohrdurchführungen. Ziel der Dokumentation ist es, einen strukturierten Überblick über alle Abhängigkeiten, Wartungszyklen und Zuständigkeiten zu schaffen, um sicherzustellen, dass Betrieb und Sicherheit des Systems über den gesamten Lebenszyklus hinweg gewährleistet bleiben. Die Dokumentation des Wartungsbedarfs kann verhindern, dass kritische Komponenten ungeplant ausfallen oder Sicherheitslücken durch versäumte Updates bestehen bleiben. Ohne klare Wartungsinformationen könnte beispielsweise ein Firmware-Update bei einer Netzkomponente übersehen werden, was Angreifern das Eindringen über bekannte Schwachstellen erleichtern könnte. Umgekehrt kann eine dokumentierte Wartungsplanung dazu beitragen, Systemverfügbarkeit und Integrität zu sichern, indem sie planbare Wartungsfenster und Zuständigkeiten ermöglicht. Durch das Zusammenführen der Herstellerangaben mit den vor Ort bekannten Rahmenbedingungen kann frühzeitig erkennbar werden, wann Eingriffe nötig sind, welche Abhängigkeiten bestehen und welche Fachkenntnisse oder Werkzeuge erforderlich sein können. Zum Ressourcenbedarf kann ebenso gehören, dass ein Testsystem bereitgestellt wird, dass adminis-

trative Zugänge vorbereitet werden oder dass ein Wartungsdienstleister während der Arbeiten abgesichert fernzugreifen kann. Für die praktische Umsetzung kann es hilfreich sein, einen zentralen Wartungskalender mit Ampel-Logik zu führen, der sich aus dem Konfigurations- oder Asset-Management speist. Eine Ticket- oder Change-Management-Lösung kann automatisch Termine auslösen, Erinnerungen versenden und Reports erzeugen.

Links

related: BES.7.4 Vollständigkeit der Unterlagen

Control: ASST.5.2 - Geregelte Wartungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.5 Wartung
UUID: f4508940-fad1-49ff-b7f7-d6612790f145
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für IT-Systeme SOLLTE die Wartung {{ insert: param, asst.5.2-prm1 }} ausführen.

Guidance

„Wartung“ bezeichnet hier sämtliche planmäßigen oder zustandsabhängigen Maßnahmen zur Erhaltung der Funktionsfähigkeit, Sicherheit und Integrität von IT-Systemen, Anwendungen und den zugehörigen physischen wie logischen Assets („maintenance“). Verschleißende Systeme und Infrastrukturen könnten zu Fehlerzuständen und hierdurch zu Ausfallzeiten und Sicherheitsrisiken führen. Das betrifft auch die für das IT-System verwendete Stromversorgung, USV, Klimatechnik, sowie Brandabschottungen für Kabel- und Rohrdurchführungen. Beispiele hierfür können vielfältig sein: Ein Server kann turnusmäßig mit Firmware-Updates versorgt oder nach einer bestimmten Betriebsdauer auf Staubablagerungen überprüft werden; Netzwerkkomponenten können per Lifecycle-Plan aktualisiert oder lüfterseitig gereinigt werden; USV-Batterien können nach Herstellerempfehlung getauscht werden; Software-Module können per Patch-Management in ein Wartungsfenster eingeplant werden. Eine „regelmäßige Wartung“ bedeutet hierbei ein turnusmäßiges Vorgehen nach festen Zeitintervallen (Vorausbestimmte Instandhaltungsstrategie), während prädiktive Wartung den tatsächlichen Abnutzungs- oder Belastungszustand auswertet, um Eingriffe bedarfsgerecht zu planen (Prädiktive Instandhaltungsstrategie). Beide Ansätze verfolgen das Ziel, Sicherheits- und Betriebsrisiken zu minimieren, die aus dem Ausfall oder der Fehlfunktion technischer Komponenten resultieren könnten.

Control: ASST.5.3 - Autorisierung von Wartungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.5 Wartung
UUID: 59a96eb8-75ad-420d-aab5-4d448f5c12ae
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für IT-Systeme KANN Wartungen durch {{ insert: param, asst.5.3-prm1 }} autorisieren.

Guidance

Wartung ist die planbare oder anlassbezogene Änderung an Komponenten (z. B. Patches, Konfigurationsänderungen, Hardwaretausch, Firmware-Updates). Dies betrifft auch den Transfers des Systems oder von Komponenten für Reparatur oder Austausch an einem anderen Ort. Unklare oder fehlende Freigaben für Wartungen könnten zu unkoordinierten Änderungen, ungeplanten Ausfällen, Datenverlust oder der Einschleusung von Schadcode durch interne wie externe Dienstleister führen; außerdem könnten unpassende Zeitfenster oder inkompatible Firmwarestände Vertraulichkeit, Integrität und Verfügbarkeit beeinträchtigen. Zur Umsetzung kann die Institution ein schlankes Freigabeverfahren gestalten, z.B. (1) ein standardisiertes Wartungs-Ticket mit Pflichtangaben (Asset-ID, Maßnahme, Risiko-Einschätzung, Zeitfenster, Back-out-Plan, Ansprechpartner), das über CMDB-Bezüge (Konfigurationsdatenbank) automatisch an Asset-/Service-Owner geroutet und dort freigegeben werden kann; (2) technische Gates, sodass produktive Änderungen erst im Status „autorisiert“ durch CI/CD-Pipelines (Build-/Deployment-Kette), Change-Flags oder Just-in-Time-Privilegien mit zeitlich begrenzten Admin-Konten ausgeführt werden können; (3) ein Katalog vordefinierter, niedrig-riskanter Standardwartungen (z. B. Signatur-Updates, agentenlose Log-Rotation), die vorab genehmigt und ohne Einzelfallprüfung ausgelöst werden können.

Control: ASST.5.4 - Behandlung als Änderungen und Tests

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.5 Wartung
UUID: 45437d44-0d0c-402f-934a-5cb48552b203
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für IT-Systeme SOLLTE zur Wartung erforderliche Änderungen im Einklang mit den Verfahren und Regelungen zum Management von Änderungen verankern.

Guidance

Werden bei Wartungsarbeiten Änderungen vorgenommen, so sind die Verfahren und Regelungen zum Management von Änderungen auch hier anzuwenden. Ein nicht abgestimmter oder ungetesteter Eingriff könnte etwa zu Systemausfällen, Datenverlust oder dem Einbringen von Schwachstellen führen, während ein geordnetes Änderungsmanagement solche Risiken deutlich reduzieren kann. Sinnvoll ist oft ein kurzer Wartungsleitfaden, in dem typische Abläufe (z. B. Vorab-Backup, Rollback-Option, Dokumentation des Ergebnisses) hinterlegt werden. Auf diese Weise kann jede Wartung reproduzierbar, überprüfbar und ressourcenschonend gestaltet werden, ohne sich auf konkrete Herstellerprodukte festzulegen.

Links

required: TEST.1.1 Verfahren und Regelungen

Control: ASST.5.5 - Wartungsfenster

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.5 Wartung
UUID: afaa993d-da28-4f69-93a0-41cb472e8e42
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für IT-Systeme SOLLTE bei voraussichtlichen Verfügbarkeiteinschränkungen durch bevorstehende Wartungen die Nutzenden über Dauer und Umfang der Einschränkungen informieren.

Guidance

Wenn durch Wartungsarbeiten die Verfügbarkeit von Systemen, Anwendungen oder Daten in Geschäftsprozessen beeinträchtigt werden könnte, ist eine Information über die bevorstehende Wartung sinnvoll. Dazu gehört, dass über die Dauer (Beginn und Ende), sowie über den Umfang der Einschränkungen (z.B. betroffene Anwendungen, Netze oder Funktionen) informiert wird. Beispiele sind Firmware- oder Betriebssystemupdates von zentralen Speichersystemen oder Netzkomponenten, der Austausch von Komponenten an zentralen Stromverteilern oder eine Wartung an den Klimasystemen eines nicht redundant ausgelegten Serverraumes.

Links

related: TEST.5.1 Information betroffener Kreise

Control: ASST.5.6 - Wartung durch Externe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.5 Wartung
UUID: bcf1c916-4509-4461-b9a7-08803a4e96b1
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für Mitarbeitende KANN bei Wartungen, die von Externen ohne Sicherheitsüberprüfung vorgenommen werden, zur Beaufsichtigung durch internes Personal anweisen.

Guidance

Eine Sicherheitsüberprüfung bezeichnet hier die systematische Bewertung der Vertrauenswürdigkeit und Zuverlässigkeit von externen Dienstleistern oder deren Personal durch background checks, Referenzprüfungen oder formelle Sicherheitsclearance-Verfahren. Externe ohne Sicherheitsüberprüfung umfasst alle Dienstleister, Wartungstechniker oder Support-Personal von Drittanbietern, die nicht durch entsprechende Verfahren zur Vertrauenswürdigkeit validiert wurden. Beaufsichtigung durch internes Personal ist die kontinuierliche Anwesenheit und Überwachung von qualifizierten eigenen Mitarbeitenden während der gesamten Dauer der Wartungsarbeiten, um sowohl fachliche Aufsicht als auch Sicherheitskontrolle zu gewährleisten. Dazu gehört, dass die begleitenden Mitarbeitenden sicherstellen, dass Externe ausschließlich auf die für ihre Wartungsaufgabe notwendigen Systembereiche zugreifen und keine unauthorisierten Aktionen wie das Kopieren von Dateien oder die Installation nicht genehmigter Software durchführen. Externe Wartungskräfte ohne Sicherheitsüberprüfung könnten sonst vertrauliche Informationen einsehen, kopieren oder manipulieren, Malware einschleusen oder unbeabsichtigt Systemkonfigurationen beschädigen. Durch begleitendes internes Personal kann eine Institution kontinuierliche Aufsicht über alle durchgeführten Aktivitäten sicherstellen und gleichzeitig den Wissenstransfer für zukünftige Wartungsarbeiten fördern. Bei einer Fernwartung kann dies z.B. durch das Logging von Diagnose- und Wartungsaktivitäten, sowie die anschließende Überprüfung, dass alle Wartungsverbindungen getrennt sind, geschehen.

Links

related: SENS.8.4 Begleitung Externer

Control: ASST.5.7 - Dokumentation von Wartungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.5 Wartung
UUID: a2ecedcb-3515-4d40-b4d3-b745142af15b
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für IT-Systeme SOLLTE Wartungen mit Asset, Anlass, Zeitpunkt, Beteiligten, durchgeführten Maßnahmen und Ergebnissen dokumentieren.

Guidance

Die Dokumentation von Wartungen an IT-Systemen kann Nachvollziehbarkeit, Verantwortlichkeit und Beweisfähigkeit herstellen; ohne sie könnten unerkannte Konfigurationsänderungen, verdeckte Schwachstellen oder verlängerte Ausfälle entstehen. Zur Umsetzung kann die Institution ein schlankes, einheitliches Wartungsprotokoll verwenden, das je Vorgang erfasst: (1) eindeutig referenziertes Asset/CI, Umgebung und betroffener Service, (2) Anlass, Art der Wartung (präventiv/korrektiv/notfall) und geplanter Zeitraum, (3) Verantwortliche, Beteiligte/Dienstleister und Kontakt, (4) geplante Maßnahmen, Backout-Plan sowie definierte Vor-/Nach-Checks, (5) tatsächlich durchgeführte Schritte („as-built“), verwendete Versionen/Images und geänderte Parameter, (6) Messergebnisse/Logs/Screenshots/Hashes als Nachweis, (7) Auswirkungen (Downtime, Kapazität), Abnahme/Testresultat und Freigabe, (8) Verweise auf Tickets/Changes/Störungsmeldungen, (9) Datum/Zeit mit Zeitzone und Protokollversion. Die Erfassung kann in einem vorhandenen Ticket- oder CMDB-Werkzeug stattfinden.

Links

related: TEST.4.1.2 Dokumentation der Freigabe

Control: ASST.6.1 - Abhandenkommen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.6 Rücknahme von Assets
UUID: 7dba0afd-96c5-4484-8b48-12fc45294247
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets SOLLTE eine Vorgehensweise beim Abhandenkommen von Assets verankern.

Guidance

Eine Vorgehensweise beim Abhandenkommen von Assets ist ein strukturierter, dokumentierter Reaktionsprozess, der alle notwendigen Schritte und Verantwortlichkeiten für den Umgang mit verloren gegangenen, gestohlenen oder anderweitig außer Kontrolle geratenen Informationswerten nach Eintritt des Verlustereignisses festlegt. Ohne strukturierte Prozesse könnte ein verlorenes Laptop mit Kundendaten zu anhaltenden Datenschutzverletzungen führen, ein gestohlenes Smartphone könnte dauerhaft unbefugten Zugang zu Unternehmensressourcen ermöglichen, oder vergessene Dokumente könnten unkontrolliert Geschäftsgeheimnisse preisgeben. Eine etablierte Vorgehensweise kann durch schnelle Reaktionszeiten und koordinierte Sofortmaßnahmen das bereits eingetretene Schadenspotential begrenzen und die Wiederherstellung der Informationssicherheit beschleunigen. Die Vorgehensweise zur Behandlung kann z.B. die Ortung, Sperrung oder Löschung per Fernzugriff, das Melden bei Ermittlungsbehörden oder lokalen Fundbüros, die Änderung aller betroffenen Zugangsdaten, sowie die Sperre von Authentisierungsmitteln und der enthaltenen SIM-Karte beim Provider beinhalten.

Links

required: DET.2.1 Meldeverfahren

related: REA.1.1 Verfahren und Regelungen

related: SENS.8.1 Risiken der Nutzung von mobilen Endgeräten

Control: ASST.6.2 - Rückkehr abhandengekommener Assets

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.6 Rücknahme von Assets
UUID: 74259c1e-dc72-42dc-b2b7-b93d700616e7
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets SOLLTE eine Vorgehensweise bei Rückkehr von abhandengekommenen Assets verankern.

Guidance

"Abhandengekommene Assets" bezeichnen Informationswerte, die ungewollt oder ungeplant außerhalb der direkten Kontrolle der Institution geraten sind - beispielsweise durch Verlust, Diebstahl, vergessene Mitnahme oder andere unbeabsichtigte Ereignisse. Eine "Vorgehensweise bei Rückkehr" meint einen strukturierten Prozess zur systematischen Wiederaufnahme und sicherheitstechnischen Bewertung solcher Assets nach ihrer Wiederbeschaffung oder ihrem Wiederauffinden. Diese Anforderung zielt auf die Risikominimierung bei der Wiederintegration potenziell kompromittierter Assets ab, da während der unkontrollierten Abwesenheit Manipulationen, unautorisierten Zugriffe oder Datenabflüsse aufgetreten sein könnten. Ohne strukturierte Rückkehrprozesse kann die unkontrollierte Wiederverwendung zurückgekehrter Assets zu Sicherheitslücken, Malware-Infektionen oder Datenschutzverletzungen führen. Umsetzungen können bei der Asset-Rückkehr (1) eine vollständige Identitätsprüfung anhand eindeutiger Kennzeichnungen wie Seriennummern oder Asset-Tags, (2) eine technische Integritätsprüfung durch Malware-Scans, Firmware-Vergleiche und Hardwareanalysen sowie (3) eine Datenintegrität-Bewertung mittels kryptografischer Prüfsummen oder forensischer Analysen umfassen. Als Alternative zur tiefergehenden Analyse von Systemen und Daten bietet sich auch die Löschung oder Entsorgung an. Prozessual kann die Einrichtung einer zentralen Asset-Return-Stelle mit definierten Eskalationswegen bei Auffälligkeiten, die Dokumentation aller Rückkehrfälle in einem Asset-Management-System und die Implementierung von Quarantäne-Verfahren für verdächtige Assets erfolgen.

Control: ASST.6.3 - Konformitätsprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.6 Rücknahme von Assets
UUID: f3ccc5ee-2b5d-47a0-80cb-3ad5b510b50d
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für IT-Systeme KANN bei Rücknahme die Konformität mit den einschlägigen Anforderungen testen.

Guidance

Assets sind nicht konform, wenn Sie die für sie geltenden Anforderungen nicht oder nicht mehr erfüllen, z.B. weil die Hardware manipuliert wurde oder keine Sicherheitsupdates mehr bereitgestellt werden. Die Prüfung kann durch automatische Prüfsysteme oder mit manuellen Verfahren, z.B. Sichtkontrolle von Siegeln, gewährleistet werden. Auch die Nutzung von Stichprobenkontrollen ist möglich. Zur Behandlung kann entweder die Ursache der Nichtkonformität beseitigt werden, oder alternative Lösungen können angewendet werden, z.B. kann das Gerät auf Werkszustand zurückgesetzt und neu installiert werden. Ist dies nicht möglich so bleibt keine andere Behandlungsmöglichkeit als das Assets nicht weiter zu verwenden.

Control: ASST.6.4 - Zurücksetzen auf Ausgangszustand

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.6 Rücknahme von Assets
UUID: 0ca16c9c-e998-420b-9006-417e155d30d6
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für IT-Systeme SOLLTE bei Rücknahme das Zurücksetzen in einen definierten Ausgangszustand ausführen.

Guidance

Mit definierter Ausgangszustand ist hier ein Zustand gemeint, in dem alle während der Nutzung möglicherweise angefallenen vertraulichen Daten wieder gelöscht oder vernichtet sind. Dies kann in vielen Fällen am einfachsten durch Überschreiben der Speichermedien, kryptografisches Löschen oder das vollständige Zurücksetzen auf Werkseinstellungen erfolgen. Zur Umsetzung einer Vernichtung siehe DIN 66399. Alternativ kann auch ein vordefiniertes Systemimage installiert werden, wodurch das System für die erneute Ausgabe vorbereitet wird, wenn das Systemimage alle vorher auf dem System vorhandenen Daten überschreibt oder diese vollständig verschlüsselt waren.

Control: ASST.7.1 - Nicht mehr benötigte Anwendungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.7 Löschen und Vernichten
UUID: dd5c811a-37c3-450f-b391-029bbe503afa
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Anwendungen SOLLTE eine Deinstallation nicht mehr benötigter Anwendungsinstanzen verankern.

Guidance

„Nicht mehr benötigte Anwendungsinstanzen“ sind installierte, aber aktuell nicht mehr genutzte Softwarekomponenten, Applikationen oder Dienste (engl. application instances), die auf Servern, Endgeräten oder virtuellen Umgebungen verbleiben, obwohl ihre betriebliche Funktion entfallen ist. Diese können produktiv, testweise oder temporär eingerichtet gewesen sein. Eine Deinstallation ist hier als geregelter Prozess der vollständigen und nachvollziehbaren Entfernung solcher Komponenten zu verstehen, einschließlich ihrer Konfigurationen, temporären Daten und zugehörigen Zugriffsrechte. Der Zweck liegt in der Vermeidung von Sicherheits- und Integritätsrisiken, die durch ungenutzte oder veraltete Software entstehen könnten – etwa weil diese weiterhin Angriffsflächen bietet, unbemerkte Schwachstellen enthält oder unbeabsichtigte Datenabflüsse begünstigen könnte. Die Entfernung kann somit die Systemhärtung und Transparenz über tatsächlich aktive Anwendungen fördern. Dies kann durch Systeme automatisiert geschehen, die bei der Zuordnung von Anwendungen zu Personen eine automatische Installation oder Deinstallation erledigt. Wenn Anwendungen nicht länger benötigt werden, dann sind auch die für die Anwendung erforderlichen Berechtigungen nicht länger erforderlich. Hierzu gehören sowohl lokale als auch Cloud-Zugänge. Steht die Anwendungsinstanz in der Cloud nicht unter der Kontrolle der Institution, so sind stattdessen soweit möglich alle Daten in der Cloud zu löschen.

Control: ASST.7.2 - Aufbewahrungs- und Löschfristen

Tag: "Archivierung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.7 Löschen und Vernichten
UUID: 2574ffa3-fa96-4eed-8a9a-e67216d499d9
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ASST.7.2.1 Langfristige Archivierung

Statement

Informationen und Assets für Daten SOLLTE die Aufbewahrung für {{ insert: param, asst.7.2-prm1 }} verankern.

Guidance

Klar festgelegte und in Prozessen verankerte Löschfristen helfen Sicherheits- und Compliance-Risiken zu minimieren, indem Informationen entsorgt werden, wenn sie nicht mehr benötigt werden. Dies gilt sowohl für Originaldaten als auch für Kopien und archivierte Aufzeichnungen, einschließlich Protokolldateien. Hier besteht ein enger Bezug zu Compliance-Verpflichtungen, sowohl zur Aufbewahrung (z.B. für Nachweispflichten aus dem Steuerrecht) als auch zur Löschung (z.B. aus dem Datenschutzrecht). Die Auswahl der Methode zum Löschen hängt von der Vertraulichkeit der Daten, verwendeten Anwendungen oder Speichermedien und ggf. bestehenden Compliance-Verpflichtungen ab. Eine Herausforderung stellt dabei der Umgang mit Datenkopien in Datensicherungen dar. Da das nachträgliche Herausfiltern bestimmter Daten aus Datensicherungen häufig sehr aufwändig ist, ist es empfehlenswert die Versionierung der Datensicherungen so zu gestalten, dass die Daten zum Ablauf der Löschfrist ohnehin mit neueren Datensicherungen überschrieben wurden oder ältere Kopien der Datensicherung insgesamt gelöscht sind. Für kurzlebige Daten bietet es sich an diese nicht in eine einzige zentrale Datensicherung aufzunehmen, sondern je nach Schutzbedarf an Integrität und Verfügbarkeit dieser Daten gar keine oder eine Datensicherung für kurzlebige Daten, z.B. Diagnosedaten mit Personenbezug, vorzuhalten.

Control: ASST.7.2.1 - Langfristige Archivierung

Tag: "Archivierung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.7 Löschen und Vernichten
Übergeordnetes Control:
ASST.7.2 Aufbewahrungs- und Löschfristen
UUID: d26539e6-62c3-469a-87f3-87ab15fd9213
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für Daten KANN die langfristige Archivierung mindestens für {{ insert: param, asst.7.2.1-prm1 }} verankern.

Guidance

Archivierung meint hier die langfristige Aufbewahrung derjenigen Daten, die über längere Zeit benötigt werden, z.B. über mehr als 10 Jahre. Hierbei kann es sich beispielsweise um Nachweise der Einhaltung rechtlicher Verpflichtungen, Daten zur Nachvollziehbarkeit von Angriffen (Audit Log), oder zur Geltendmachung von Ansprüchen handeln. Dabei kann es sich sowohl um analoge Dokumente als auch um digitale Daten handeln. Die meisten Institutionen verarbeiten Daten, die aufgrund von Compliance-Verpflichtungen langfristig gespeichert werden, z.B. handels- und steuerrechtlich relevante Dokumente oder Eigentumsurkunden.

Links

related: NOT.4.5 Archivierung langfristig benötigter Daten

Control: ASST.7.3 - Geregeltes Löschen oder Vernichten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.7 Löschen und Vernichten
UUID: 7dc77e01-b62b-4e7f-bb4c-d9c67551d8fa
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Löschverfahren
- ASST.7.3.3 Zugelassene Löschanwendungen

Statement

Informationen und Assets für Daten SOLLTE diese bei Erreichen der Aufbewahrungs- und Löschfrist durch {{ insert: param, asst.7.3-prm1 }} löschen.

Guidance

Ereignisse können z.B. der Ablauf der festgelegten Löschfrist, die Veräußerung von Assets oder deren Weitergabe an einen Dienstleister sein. Relevant sind hierbei neben physischen und virtuellen Medien auch die Datenträger in IT-Systemen wie Notebooks und Fahrzeugen. Sicheres Löschen bedeutet, Daten so zu entfernen, dass sie mit vertretbarem Aufwand (auch forensisch) nicht mehr rekonstruierbar sind. Je nach Medium geschieht das z. B. durch verifizierbares Überschreiben, kryptografisches Löschen (Schlüsselvernichtung) oder physische Zerstörung (inklusive zugehöriger Metadaten, Caches und Datensicherungen). Die Anforderung ist auch erfüllt, wenn sie durch einen Dienstleister durchgeführt wird, der hierzu verpflichtet ist.

Control: ASST.7.3.1 - Standardisierte Vernichtung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.7 Löschen und Vernichten

Übergeordnetes Control:

ASST.7.3 Geregeltes Löschen oder Vernichten

UUID: 93178616-6931-48e6-ae7-d51742868d4f

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Daten SOLLTE ein standardisiertes Verfahren zur Vernichtung bei Veräußerung nach {{ insert: param, asst.7.3.1-prm1 }} gemäß {{ insert: param, asst.7.3.1-prm2 }} verankern.

Guidance

Anerkannte Standards für die Vernichtung sind DIN 66399 sowie ISO/IEC 21964; die Sicherheitsstufe beschreibt die Intensität der Vernichtung, wobei eine möglichst kleinteilige Zerkleinerung die Wahrscheinlichkeit einer Rekonstruktion aus Fragmenten minimiert. Die konkrete Vorgehensweise richtet sich nach der Art des Speichermediums: Papier wird nach Sicherheitsstufe P-3 gemäß ISO/IEC 21964-2 vernichtet, optische Speichermedien nach Sicherheitsstufe O-3 gemäß ISO/IEC 21964-2 und sonstige Speichermedien nach Sicherheitsstufe E-3 oder H-3 gemäß ISO/IEC 21964-2. Für Speichermedien, die vor der Nutzung vollständig verschlüsselt waren und deren kryptografische Schlüssel unwiederbringlich gelöscht wurden, ist eine physische Vernichtung nicht erforderlich.

Control: ASST.7.3.2 - Lösungsverfahren

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.7 Löschen und Vernichten

Übergeordnetes Control:

ASST.7.3 Geregeltcs Löschen oder Vernichten

UUID: aeea856c-cbc3-47a2-bc60-56515be30f12

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets für Daten SOLLTE ein Verfahren zur endgültigen Löschung verankern.

Guidance

Hierunter ist ein nachvollziehbarer, dokumentierter technischer und prozessualer Ablauf zur endgültigen Entfernung oder Unkenntlichmachung von Informationen zu verstehen; „Endgültig“ bedeutet, dass Daten mit vertretbarem Aufwand nicht wiederhergestellt werden können. Ohne klare Verfahren könnte Alt- oder Schattendatenbestand bei Geräteübergabe, in Backups oder Cloud-Objektspeichern verbleiben, was zu Datenschutzverletzungen, Erpressungsversuchen oder regulatorischen Sanktionen führen könnte. Hierzu gehören sowohl Nutzdaten von IT-Systemen und Anwendungen, als auch Konfigurationsdateien oder Daten, die in begleitenden Dokumenten wie Betriebshandbüchern oder Informationswikis abgelegt sind.

Control: ASST.7.3.3 - Zugelassene Löschanwendungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: ASST.7 Löschen und Vernichten

Übergeordnetes Control:

ASST.7.3 Geregeltas Löschen oder Vernichten

UUID: 2fe24be6-1c6b-4a72-8f40-263e1cffc815

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Informationen und Assets für Daten KANN die Daten durch {{ insert: param, asst.7.3.3-prm1 }} löschen.

Guidance

Für eine aktuelle Liste der zugelassenen Löschanwendungen siehe BSI-Schrift 7164: Liste der zugelassenen IT-Sicherheitsprodukte und -systeme. Sicheres Löschen bedeutet, Daten so zu entfernen, dass sie mit vertretbarem Aufwand (auch forensisch) nicht mehr rekonstruierbar sind. Je nach Medium geschieht das z. B. durch verifizierbares Überschreiben, kryptografisches Löschen (Schlüsselvernichtung) oder physische Zerstörung (inklusive zugehöriger Metadaten, Caches und Datensicherungen).

Control: ASST.7.4 - Wiederherstelltest

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.7 Löschen und Vernichten
UUID: 08759519-9e68-4c39-964e-e2461161b8cc
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für Daten KANN den Erfolg des Löschvorgangs testen.

Guidance

Der Test kann mit Software oder Hardware, die vermeintlich gelöschte Daten von Speichermedien wiederherstellen kann, durchgeführt werden. Bei vernichteten Speichermedien ist der Test entbehrlich.

Control: ASST.7.5 - Vernichtungseinrichtungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.7 Löschen und Vernichten
UUID: 85366b94-56c1-4c46-a34b-52b96d7ab1d4
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Informationen und Assets für Standorte KANN an allen Standorten, an denen körperliche Dokumente verarbeitet werden, Vernichtungseinrichtungen vor dem Zugriff unbefugter geschützt installieren.

Guidance

Die Installation von Vernichtungseinrichtungen dient dem Schutz sensibler Daten vor unbefugtem Zugriff, Missbrauch oder unkontrollierter Weitergabe. Ziel ist es, die Vertraulichkeit, Integrität und Verfügbarkeit von Informationen auch über ihren gesamten Lebenszyklus hinweg sicherzustellen – einschließlich der ordnungsgemäßen Entsorgung. Unter Vernichtungseinrichtungen versteht man mechanische oder elektronische Geräte, die Dokumente so zerkleinern oder unlesbar machen, dass eine Rekonstruktion unmöglich ist; typische Beispiele sind Aktenvernichter mit Schutzklasse P-4 oder höher oder Entsorgungsbehälter mit gesichertem Zugriff (z.B. abschließbare Sicherheitsbehälter). Dies kann auch so realisiert werden, dass Datenträger gesammelt und zentral gelöscht oder vernichtet werden. Kann durch die Institution selbst oder Dienstleister für die Aktenvernichtung umgesetzt werden. Bei der Verwendung von Dienstleistern ist es sinnvoll, deren Professionalität zu verifizieren, z.B. durch ein Zertifikat. Bei der Umsetzung ist es sinnvoll darauf zu achten, dass solche Einrichtungen nicht nur ausreichend dimensioniert und technisch geeignet sind, sondern auch physisch gegen unbefugten Zugriff geschützt werden – etwa durch Aufstellung in abgeschlossenen Räumen oder durch Zugangskontrolle.

Control: ASST.7.6 - Autorisierung von Veräußerungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.7 Löschen und Vernichten
UUID: 28fe533e-5e43-496d-abca-0a7ada987143
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets SOLLTE Veräußerungen von Assets durch {{ insert: param, asst.7.6-prm1 }} autorisieren.

Guidance

Veräußerung bezeichnet in diesem Kontext jede endgültige Abgabe oder Eigentumsübertragung (Verkauf, Spende, Rückgabe an Leasing, Recycling) eines Assets. Die Autorisierung kann verhindern, dass schutzbedürftige Informationen unkontrolliert den Besitz wechseln, Compliance-Vorgaben übersehen werden und Verantwortlichkeiten verwischen. Ohne geregelte Freigabe könnte ein ausgemusterter Laptop mit Restdaten verkauft, ein Speicherarray mit verbleibenden Schlüsseln weitergegeben oder eine nicht übertragbare Softwarelizenz abgegeben werden, was zu Datenabfluss, Vertragsverletzungen und Reputationsschäden führen könnte. Zur Umsetzung kann die Institution einen schlanken, nachvollziehbaren Freigabe-Workflow etablieren: Ein Veräußerungsantrag kann Asset-ID/Inventarnummer, Asset-Owner, Schutzbedarf/Klassifizierung, Datenträgerart, vorgesehenes Verwertungsverfahren, gewählte Datenlösch-/Vernichtungsmethode, Lizenz-/Vertragsrestriktionen, Übergabedatum und Empfänger erfassen; die Freigabe kann vor Übergabe erfolgen und revisionssicher protokolliert werden. Eine Entscheidungsmatrix kann die Genehmigungstiefe nach Schutzbedarf steuern, z. B. (1) „öffentlich“: fachliche Freigabe, (2) „intern“: Asset Owner + IT-Freigabe, (3) „vertraulich/streng“: Vier-Augen-Prinzip aus zuständige Person oder Rolle und Informationssicherheitsbeauftragte/r.

Control: ASST.7.7 - Beschriftungen entfernen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: ASST.7 Löschen und Vernichten
UUID: 15560885-fab0-4b10-91ac-b1db78ada82b
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Informationen und Assets SOLLTE alle der Institution zuzuordnenden Beschriftungen vor der Veräußerung von Assets löschen.

Guidance

Die „Beschriftung“ eines Assets ist jede physische oder digitale Kennzeichnung, die eine eindeutige Zuordnung des Gegenstands oder Datenträgers zu Werten der Institution ermöglicht. Darunter fallen unter anderem Eigentumskennzeichnungen (engl. asset tags), Seriennummern, Barcodes, Gravuren, Aufkleber mit Logo, aber auch digitale Metadaten wie Gerätebezeichnungen, E-Mail-Konten, Hostnamen oder eingebettete Wasserzeichen. Das Löschen dieser Beschriftungen vor der Veräußerung stellt sicher, dass Dritte nicht unmittelbar auf den ursprünglichen Eigentümer schließen oder unautorisierte Rückschlüsse auf interne Strukturen, Sicherheitsarchitekturen oder Verantwortlichkeiten ziehen. Ohne diese Bereinigung könnte ein weiterveräußertes Gerät durch verbleibende Markierungen auf die Institution hinweisen und so gezielt für Social-Engineering-Angriffe oder Reputationsschäden genutzt werden. Eine solche Zuordnung könnte zudem dazu führen, dass vertrauliche Informationen über Inventar, Sicherheitsstandards oder IT-Bestände unbeabsichtigt offengelegt werden. Zudem könnte eine verbleibende Beschriftung zu Missverständnissen über Eigentumsverhältnisse oder Haftung führen, falls das Asset in einen Vorfall verwickelt wird. Konkret können unter den zu entfernenden Beschriftungen beispielsweise Eigentumsaufkleber mit der Inventarnummer, Etiketten mit Standort- oder Abteilungsbezeichnungen, Markierungen für interne Verwendungszwecke (z.B. "Testgerät", "intern"), aber auch digital eingebettete Informationen wie institutionelle Metadaten in Office-Dokumenten oder gespeicherte WLAN-Profile auf mobilen Geräten verstanden werden. Auch optische Hinweise wie eingravierte Logos auf Gehäusen oder institutionelle Startbildschirme bei Laptops können darunterfallen. Zur Umsetzung kann es hilfreich sein, vor der Veräußerung eine Sichtprüfung durchzuführen

und standardisierte Checklisten zu nutzen, um typische Beschriftungen systematisch zu identifizieren. Je nach Beschaffenheit des Assets kann der Einsatz von Reinigungsmitteln, Etikettenentfernern oder speziellen Werkzeugen in Betracht gezogen werden. Auch softwaregestützte Verfahren, etwa das Zurücksetzen auf Werkseinstellungen und das Prüfen auf verbleibende Metadaten, sind relevant. Nicht zuletzt kann die Einbindung von ISB oder des Datenschutzbeauftragten in Zweifelsfällen Klarheit darüber schaffen, ob eine bestimmte Kennzeichnung potenziell sicherheitsrelevant ist.

Control: KONF.1.1 - Verfahren und Regelungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.1 Grundlagen
UUID: 88097b92-337f-4adf-b7b9-ebd62e78ce7f
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.1.1.1 Dokumentation
- KONF.1.1.2 Zuweisung der Aufgaben
- KONF.1.1.3 Bekanntgabe

Statement

Konfiguration MUSS Verfahren und Regelungen zum Konfigurationsmanagement verankern.

Guidance

Die Umsetzung kann in einem eigenen Prozess, oder integriert in andere Prozesse und Aufgaben erfolgen. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Control: KONF.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.1 Grundlagen

Übergeordnetes Control:

KONF.1.1 Verfahren und Regelungen

UUID: b3d8d01f-bb8a-4f65-87ad-5f2b78f19169

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Konfiguration MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: KONF.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.1 Grundlagen

Übergeordnetes Control:

KONF.1.1 Verfahren und Regelungen

UUID: 38cab308-1e4a-4b41-a544-ed8ad0e9aed6

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Konfiguration MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, konf.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es die Zuweisung anhand von Rollen (z.B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: KONF.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.1 Grundlagen

Übergeordnetes Control:

KONF.1.1 Verfahren und Regelungen

UUID: f76fcd02-3443-4184-baba-615028bcb8c0

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Konfiguration MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: KONF.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.1 Grundlagen

UUID: 2cd0c200-73ef-4fb3-a7e9-244dcb477c1c

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Konfiguration MUSS die Verfahren und Regelungen {{ insert: param, konf.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: KONF.1.3 - Management von Werkzeugen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.1 Grundlagen
UUID: b7e62d50-22e1-4900-a24e-33a3b84af297
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration SOLLTE verwendete Konfigurationswerkzeuge einschließlich Verwendungszweck und Herkunft dokumentieren.

Guidance

Der Begriff Konfigurationswerkzeuge bezeichnet in diesem Zusammenhang alle technischen Hilfsmittel, mit denen Systemeinstellungen erstellt, verändert oder verwaltet werden – beispielsweise Skriptsprachen, Automatisierungs-Frameworks, Versionsverwaltungswerkzeuge oder grafische Konfigurationsoberflächen. Unter Verwendungszweck wird verstanden, welche Funktion das jeweilige Werkzeug innerhalb des Betriebs erfüllt, etwa für automatisierte Serverbereitstellung, Netzwerkkonfiguration oder Datenbankparametersteuerung. Mit Herkunft ist die Herkunft des Werkzeugs gemeint, d. h. ob es sich um Eigenentwicklungen, quelloffene Software oder kommerzielle Produkte handelt und aus welchen Quellen diese bezogen werden. Die Dokumentation dieser Punkte kann Transparenz schaffen und Nachvollziehbarkeit erhöhen, wodurch Fehlkonfigurationen oder Manipulationen schneller erkannt werden können. Ohne klare Übersicht könnte unklar bleiben, mit welchen Mitteln kritische Systeme verändert wurden, was die Ursachenanalyse im Störfall erheblich erschweren könnte. Eine saubere Dokumentation kann verhindern, dass nicht vertrauenswürdige oder nicht mehr gepflegte Werkzeuge unbemerkt im Betrieb verbleiben und so potenzielle Angriffsvektoren entstehen. Für die Umsetzung kann die Institution eine strukturierte Werkzeugliste führen, in der pro Eintrag neben Name, Version und Hersteller auch Zweck und Beschaffungsquelle vermerkt werden. Diese Liste kann in einem Konfigurations- oder Inventarsystem gepflegt werden, sodass Aktualisierungen automatisiert oder zumindest standardisiert erfolgen können. Praktisch kann es helfen, jedes neue Werkzeug vor Einsatz über ein Freigabeverfahren einzutragen und zu kennzeichnen, ob es intern geprüft wurde. Eine einfache Möglichkeit besteht darin,

bestehende Versionskontrollsysteme oder zentrale Wiki-Seiten zu nutzen, die alle relevanten Informationen versioniert und nachvollziehbar speichern können. Dies kann auch durch eine Markierung der administrativen Werkzeuge im Inventar der Anwendungen umgesetzt werden.

Control: KONF.1.4 - Einschränkung des Zugriffs auf Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.1 Grundlagen
UUID: ec046c76-92a1-4742-a056-4a11e51b2049
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration SOLLTE den Zugriff auf dokumentierte Konfigurationen einschränken.

Guidance

„Dokumentierte Konfigurationen“ sind hierbei festgehaltene Einstellungen von IT-Systemen, Anwendungen, Netzwerken oder Sicherheitskomponenten, die in schriftlicher oder elektronischer Form vorliegen und den Sollzustand einer IT-Umgebung definieren. Der Zweck der Vorschrift liegt darin, die Integrität und Vertraulichkeit solcher Konfigurationsinformationen zu schützen. Ein unkontrollierter Zugriff könnte beispielsweise dazu führen, dass ein Unbefugter Passworteinstellungen oder Firewall-Regeln manipuliert. Aus der Konfiguration von IT-Systemen könnte ein Angreifer zudem wichtige Informationen zu möglichen Schwachstellen ablesen (z.B. bei technisch notwendiger Verwendung schwacher Verschlüsselungsalgorithmen oder unsicherer Authentisierungsprotokolle wie NTLM). Ein strikter Zugriffsschutz (z.B. durch restriktive Berechtigungen oder Verschlüsselung) verhindert den unberechtigten Zugriff zu diesen sensiblen Informationen. Praktisch hilfreich kann auch sein, Konfigurationen verschlüsselt abzulegen und bei elektronischen Repositories sogenannte „Branch Protection“-Mechanismen einzusetzen, sodass Änderungen nur über geprüfte Freigabeprozesse übernommen werden können. Auf Papier vorliegende Konfigurationen kann die Institution in verschlossenen Schränken oder Archiven mit eingeschränktem Personenkreis verwahren.

Control: KONF.1.5 - Verschlüsselung von Konfigurationsgeheimnissen

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.1 Grundlagen

UUID: 195fff6c-f5c2-466c-8a28-81b3167dad8d

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Konfiguration SOLLTE Konfigurationsgeheimnisse verschlüsseln.

Guidance

Konfigurationsgeheimnissen sind sensitive, nicht-öffentliche Daten, die von Systemen, Applikationen oder Diensten zur Laufzeit benötigt werden, um auf andere Ressourcen zuzugreifen oder ihre eigene Funktionalität sicherzustellen. Bekannte Beispiele sind Anmeldeinformationen wie Passwörter, Datenbank-Verbindungszeichenfolgen (Connection Strings), API-Schlüssel oder private Schlüssel von Zertifikaten; im Englischen wird hierfür übergreifend der Fachbegriff Secrets verwendet. Der Zweck dieser Vorschrift ist die Sicherstellung der Vertraulichkeit dieser hochsensiblen Informationen. Ungeschützt im Klartext hinterlegt, könnte ein Angreifer bei einem unautorisierten Zugriff auf Konfigurationsdateien, Quellcode-Verzeichnisse oder Backups diese Geheimnisse direkt auslesen und damit weitreichenden Zugriff auf angebundene Systeme oder Daten erlangen.

Control: KONF.2.1 - Grundkonfiguration für Systeme

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.2 Konfiguration von Systemen
UUID: 8bd05aba-b395-43cf-a38e-f4e8656df7c4
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.2.1.1 Versionierung der Systemkonfiguration

Statement

Konfiguration für IT-Systeme SOLLTE eine Grundkonfiguration dokumentieren.

Guidance

Eine Grundkonfiguration (engl. baseline configuration) bezeichnet hier einen dokumentierten Ausgangszustand, der alle sicherheitsrelevanten Einstellungen, Dienste und Komponenten umfasst und als verbindlicher Referenzpunkt für den Betrieb und die Härtung dient. Sie stellt damit eine Art „Zielzustand“ dar, anhand dessen spätere Änderungen überprüft oder Abweichungen erkannt werden können. Ohne eine solche Referenz könnte es bei Installationen, Updates oder Wiederherstellungen zu unsicheren Abweichungen kommen, etwa wenn unnötige Dienste aktiv bleiben, Standardkonten nicht deaktiviert sind oder Kommunikationsschnittstellen unkontrolliert offenstehen; umgekehrt kann eine saubere Grundkonfiguration sicherstellen, dass Systeme konsistent, nachvollziehbar und auf Basis etablierter Sicherheitsanforderungen betrieben werden. Hierzu gehört z.B. die Konfiguration der Uhrensynchronisation, von DNS und Verzeichnisdiensten, die Änderung von Default-Zugangsdaten oder der automatische Abruf benötigter Lizenzen. Die Umsetzung einer Grundkonfiguration kann durch verschiedene Maßnahmen unterstützt werden: (1) Es ist sinnvoll, Herstellerdokumentationen zu sichten und empfohlene Härtungseinstellungen (z. B. Deaktivierung unsicherer Protokolle) als Ausgangspunkt zu übernehmen. (2) Ergänzend können Empfehlungen des BSI oder Benchmarks wie die CIS Benchmarks herangezogen werden, um systematisch sicherheitskritische Parameter zu prüfen und einzupflegen. (3) Für komplexe Umgebungen kann ein Konfigurationsskript oder ein Automatisierungs-Tool (z. B. Ansible, Puppet, Chef) genutzt werden, um eine reproduzierbare Baseline einzuspielen und Abhängigkeiten der Komponenten kon-

sistent zu berücksichtigen. Auf diese Weise kann die Institution sicherstellen, dass jede Installation oder Wiederherstellung eines Systems auf einer überprüfbaren und einheitlichen Basis erfolgt.

Control: KONF.2.1.1 - Versionierung der Systemkonfiguration

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.2 Konfiguration von Systemen
Übergeordnetes Control:
KONF.2.1 Grundkonfiguration für Systeme
UUID: 3b25d629-b441-4365-96fb-d06e2e35b89d
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE eine Versionierung vorheriger Konfigurationen verankern.

Guidance

Die Versionierung bezeichnet hier die strukturierte Nachvollziehbarkeit von Änderungen an Konfigurationen, also das Speichern, Dokumentieren und bei Bedarf Wiederherstellen älterer Zustände eines IT-Systems. Sie unterscheidet sich von einem einfachen Backup dadurch, dass nicht nur eine Kopie vorliegt, sondern explizit eine fortlaufende Historie mit Vergleichen, Rücksetzpunkten (rollback points) und optional Kommentaren geführt wird. Der Zweck liegt darin, dass eine ungewollte oder fehlerhafte Anpassung an einer Konfiguration im Betrieb schnell erkannt und – wenn erforderlich – präzise auf einen definierten, funktionsfähigen Zustand zurückgesetzt werden kann. Ohne eine solche Versionierung könnte eine fehlerhafte Änderung unbemerkt bleiben oder nur schwer rückgängig gemacht werden. Praktisch umgesetzt kann dies z. B. durch den Einsatz von Konfigurationsmanagement-Tools erfolgen, die automatisch Änderungen versionieren und mit Prüfsummen sichern. Alternativ kann eine Institution auch Konfigurationsdateien regelmäßig in ein Versionsverwaltungssystem wie Git einspielen. Zusätzlich kann es hilfreich sein, Konfigurationsänderungen über standardisierte Änderungsprozesse einzupflegen, sodass jede Anpassung nachvollziehbar protokolliert wird. Eine weitere Möglichkeit kann die Einrichtung von Skripten sein, die Konfigurationsstände automatisch aus Geräten exportieren und revisionssicher ablegen. Zur Umsetzung können Anwendungen zur Geheimnisverwaltung, oft als Secrets-Manager oder Vault bezeichnet, eingesetzt werden. Solche Anwendungen speichern alle Geheimnisse zentral und hochverschlüsselt und stel-

len sie erst bei Bedarf zur Laufzeit über eine authentifizierte und gesicherte Schnittstelle (API) zur Verfügung. Eine weitere, weit verbreitete Praxis ist die Auslagerung von Secrets aus den Konfigurationsdateien in Umgebungsvariablen (Environment Variables) des ausführenden Systems, wodurch eine strikte Trennung von Code und Konfiguration erreicht wird. Alternativ kann auch die Konfigurationsdatei selbst oder zumindest die Abschnitte, die Geheimnisse enthalten, verschlüsselt werden, wobei dies erfordert, dass der zur Entschlüsselung notwendige Schlüssel seinerseits sicher an die Applikation übergeben wird.

Links

related: TEST.2.1 Versionshistorie

Control: KONF.2.2 - Kryptographische Verfahren in IT-Systemen

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.2 Konfiguration von Systemen

UUID: e4570c64-4790-4a5c-95e4-4c168d447566

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE kryptographische Verfahren nach {{ insert: param, konf.2.2-prm1 }} im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement aktivieren.

Guidance

Kryptographie wird für die Authentifizierung, Verschlüsselung und Integritätsprüfung in Systemen verwendet, z.B. bei der Verschlüsselung von Speichermedien, bei der Anmeldung am System, Transportverschlüsselung von Systemupdates oder Integritätsprüfung von Systemfunktionen. Die Formulierung "im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement" bedeutet, dass die Funktionen so zu konfigurieren sind, wie in der Praktik Berechtigung (BER) festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist.

Links

related: BER.1.1 Verfahren und Regelungen

Control: KONF.2.3 - Änderung von Default-Zugangsdaten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.2 Konfiguration von Systemen
UUID: 14a61781-67a3-41c7-9f73-89d5809ea2b0
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE die Änderung von Default-Zugangsdaten ausführen.

Guidance

"Default-Zugangsdaten" sind werkseitig voreingestellte Benutzername-Passwort-Kombinationen wie "root" oder "administrator", sowie vergleichbare Authentifizierungsmerkmale, die bei der Erstinbetriebnahme von IT-Systemen unverändert vorhanden sind. Diese Daten sind in der Regel öffentlich dokumentiert oder leicht im Internet auffindbar. Ihr Fortbestehen im Produktivbetrieb könnte ein erhebliches Risiko darstellen, da ein Angreifer mit minimalem Aufwand Zugriff auf Systeme erlangen könnte. Ein klassischer Vorfall könnte sein, dass ein öffentlich erreichbarer Router mit unveränderten Standardzugängen übernommen wird. Die Änderung kann demgegenüber sicherstellen, dass nur berechtigte Personen Zugriff erlangen, und kann damit unbefugte Manipulationen oder Datendiebstahl wirksam erschweren. Eine Institution kann die Anforderung umsetzen, indem bei der Inbetriebnahme jedes Systems ein Prozess etabliert wird, der die Standardzugangsdaten unmittelbar ersetzt. Dies kann beispielsweise (1) durch verpflichtende Initial-Setup-Routinen erfolgen, die eine Passwortänderung erzwingen, oder (2) durch zentrale Checklisten oder automatisierte Inventarisierung, die offene Standardzugänge identifizieren und schließen. Die Anforderung ist auch dann erfüllt, wenn diese Zugänge deaktiviert oder durch Zugänge mit von der Institution verwalteten Zugangsdaten ersetzt werden.

Control: KONF.2.4 - Deaktivierung nicht benötigter Systemfunktionen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.2 Konfiguration von Systemen
UUID: 24c072af-d71b-4d57-8b8f-119194e5cb8a
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen

Statement

Konfiguration für IT-Systeme SOLLTE nicht benötigte Systemfunktionen deaktivieren.

Guidance

Die Deaktivierung von Funktionen, die für Betrieb oder aus Sicherheitssicht nicht benötigt werden, hilft, die Angriffsfläche und Fehlerkomplexität zu verringern, z.B. unnötige Identitäten, ggf. nicht benötigte Schnittstellen wie Bluetooth, nicht verwendete Netzprotokolle wie NTLMv1 Authentifizierung, schwache Verschlüsselungsalgorithmen wie TLS1.1, die Anzeige von Nachrichteninhalten auf dem Sperrbildschirm oder nicht benötigte System- oder Telemetriedienste. Relevant sind dabei sowohl Betriebssystem- als auch Firmwarefunktionen.

Control: KONF.2.4.1 - Nicht benötigte Zertifikate

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.2 Konfiguration von Systemen
Übergeordnetes Control:
KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
UUID: 4a22520b-123c-422a-a871-0bc5b20b9ec3
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE nicht benötigte Zertifikate deaktivieren.

Guidance

Hierbei ist insbesondere an die vom Betriebssystem als vertrauenswürdig eingestuf-ten Zertifizierungsstellen zu denken, wenn sie nicht länger benötigt werden. Verfügt das IT-System über keine Zertifikate, so ist die Anforderung entbehrlich.

Control: KONF.2.4.2 - Externe Cloud-Anbindungen

Tag: "Data Leak"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.2 Konfiguration von Systemen
Übergeordnetes Control:
KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
UUID: 35875b35-0c23-473e-b1d6-1741c315dc88
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE nicht benötigte Cloud-Anbindungen deaktivieren.

Guidance

Eine Cloud-Anbindung ist eine technische Schnittstelle, über die ein IT-System Daten oder Dienste mit einer externen Cloud-Plattform austauscht. Dazu können sowohl direkte API-Integrationen wie die Anmeldung an Cloud-Verzeichnisdienste, aber auch automatische Synchronisationsmechanismen, Hintergrund-Updates über Cloud-Server oder agentenbasierte Remote-Management-Funktionen zählen. Nicht benötigte Anbindungen können dadurch identifiziert werden, dass sie weder für den produktiven Betrieb noch für Wartung, Support oder Sicherheitsfunktionen erforderlich sind. Der Sinn und Zweck dieser Regelung liegt darin, die Angriffsfläche zu reduzieren und unkontrollierte Datenflüsse zu vermeiden. Ein nicht genutzter, aber weiterhin aktiver Cloud-Connector könnte etwa unbemerkt sensible Metadaten an Drittdienste übertragen oder als Einfallstor für Schadsoftware missbraucht werden; die gezielte Deaktivierung kann dagegen unnötige Risiken eliminieren und die Übersichtlichkeit der Systemarchitektur erhöhen.

Control: KONF.2.5 - Überprüfung der Konfiguration

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.2 Konfiguration von Systemen

UUID: a37d5c17-d296-4810-ac13-4a15e7b40e97

Aufwand: 4

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.2.5.1 Automatische Konfigurationsverwaltung

Statement

Konfiguration für IT-Systeme SOLLTE die Übereinstimmung der tatsächlichen Konfiguration mit dem Referenzzustand `{{ insert: param, konf.2.5-prm1 }}` überprüfen.

Guidance

Referenzzustand („baseline configuration“) bezeichnet hier die dokumentierte und freigegebene Konfiguration eines IT-Systems, also die gewünschte und autorisierte Einstellung von Parametern, Diensten und Komponenten. Die tatsächliche Konfiguration ist die aktuelle technische Umsetzung dieser Einstellungen auf dem System selbst. Der Abgleich beider Zustände dient vor allem der Vermeidung von Configuration Drift – d.h. dass Systeme schleichend von der definierten Soll-Konfiguration abweichen. Dies könnte auftreten, wenn Änderungen nicht zentral dokumentiert oder automatisierte Installationen nicht einheitlich umgesetzt werden. Ohne diese Kontrolle könnte es zu unbemerkten Fehlkonfigurationen kommen, die Sicherheitslücken öffnen oder Betriebsstörungen verursachen. Durch regelmäßige Vergleiche kann eine Institution sicherstellen, dass Systeme konsistent, vertrauenswürdig und wartbar bleiben. Eine praktische Umsetzung kann auf verschiedenen Ebenen erfolgen. Technisch kann eine Institution (1) Konfigurations-Management-Werkzeuge einsetzen, die Referenzzustand-Definitionen mit Systemzuständen automatisch abgleichen, (2) Skripte oder Policies nutzen, die regelmäßig Konfigurationsdateien oder Systemeinstellungen auslesen und protokollieren, oder (3) Hash- oder Signaturverfahren anwenden, um Veränderungen an Konfigurationsdateien nachzuweisen. Prozessual kann es hilfreich sein, Änderungen zentral zu dokumentieren und automatische Reports über Abweichungen an Verantwortliche weiterzuleiten, damit diese

reagieren können. Zusätzlich kann eine Institution Pilotprüfungen an Stichproben-Systemen durchführen, um die Wirksamkeit automatischer Abgleiche zu validieren. Durch diese Maßnahmen kann eine Institution eine belastbare Routine etablieren, die Configuration Drift reduziert und nicht nur technische Abweichungen sichtbar macht, sondern auch menschliche Fehler oder unautorisierte Eingriffe frühzeitig erkennen kann.

Links

required: KONF.2.1 Grundkonfiguration für Systeme

Control: KONF.2.5.1 - Automatische Konfigurationsverwaltung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.2 Konfiguration von Systemen
Übergeordnetes Control:
KONF.2.5 Überprüfung der Konfiguration
UUID: fceb6b0b-2cf9-4644-9f48-c6b307b2d0ad
Aufwand: 5
Sicherheitsstufe: erhöht

Untergeordnete Controls

- KONF.2.5.1.1 Automatische Konfigurationsverwaltung

Statement

Konfiguration für IT-Systeme KANN die Überprüfung der Konfiguration durch {{ insert: param, konf.2.5.1-prm1 }} aktivieren.

Guidance

Eine automatische Konfigurationsverwaltung ermöglicht eine einheitliche Konfiguration, z.B. für Passwortvorgaben, Verschlüsselung oder automatische Updates. Insbesondere bei der Verwaltung zahlreicher Endgeräte oder einer Bring Your Own Device Strategie (BYOD) bietet eine solche Verwaltung den einzig praktikablen Ansatz die Sicherheitsparameter der Geräte zu kontrollieren. Dies kann über selbst betriebenes zentrales Managementsystem (UEM oder MDM), Cloud-Dienste wie Intune oder Konfigurationsmanagement-Werkzeuge wie Ansible umgesetzt werden. Bei Abweichungen kann entweder ein automatisierter Mechanismus die erforderliche Konfiguration vornehmen, oder eine manuelle Entscheidung über die passende Behandlung erfolgen.

Control: KONF.2.5.1.1 - Automatische Konfigurationsverwaltung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.2 Konfiguration von Systemen
Übergeordnetes Control:
KONF.2.5.1 Automatische Konfigurationsverwaltung
UUID: c209d678-2ee3-48f9-8fce-016b4f49481c
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Endgeräte SOLLTE die Verwaltung durch ein Mobile Device Management (MDM) verankern.

Guidance

Die Konfigurationsanforderungen für Mobile Device Management (MDM) sind im BSI-Mindeststandard für MDM umfassend beschrieben. Es ist empfehlenswert, diese Mindestanforderungen heranzuziehen. Ergänzend wird empfohlen, sicherheitsrelevante Kriterien bereits bei der Produktauswahl zu berücksichtigen, vertrauenswürdige Apps durch Reputationsdienste zu prüfen, kompromittierte Geräte (z. B. durch Jailbreak oder Root) automatisiert zu erkennen und Geofencing zur kontextbezogenen Richtliniendurchsetzung einzusetzen.

Control: KONF.2.6 - Souveräne Werkzeuge

Tag: "Hochverfügbarkeit"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.2 Konfiguration von Systemen
UUID: 9b18fd2e-8300-49d5-b244-88df6674c5c6
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN Souveräne Werkzeuge installieren.

Guidance

„Souveräne Werkzeuge“ sind Anwendungen, Systeme und physische Werkzeuge, die technisch, rechtlich und organisatorisch unabhängig von externen Herstellern, Cloud-Anbietern oder staatlicher Einflussnahme betrieben werden können. Das umfasst vor allem Lösungen, die lokal kontrollierbar und ohne zwingende Abhängigkeit zu externen Plattformen nutzbar sind. Der Sinn der Vorschrift liegt darin, die Handlungsfähigkeit und Sicherheit der Institution zu stärken: Ein rein cloudbasierter Konfigurationsdienst könnte durch einen plötzlichen Ausfall, eine staatlich erzwungene Sperrung oder durch nachträglich geänderte Lizenzbedingungen die Betriebsfähigkeit gefährden. Die Nutzung souveräner Werkzeuge kann dagegen die Verfügbarkeit kritischer Systeme erhöhen, die Datenhoheit bewahren und Manipulationsmöglichkeiten von Dritten minimieren. Souveräne Konfigurationssysteme machen unabhängig vor Ausfällen, Datenschutzverletzungen oder einseitigen Änderungen der Nutzungsbedingungen durch externe Dienstleister. Eine Institution kann diese Anforderung beispielsweise so umsetzen: (1) Es kann auf quelloffene Konfigurations-Frameworks zurückgegriffen werden, die lokal installiert und betrieben werden. (2) Virtualisierte oder containerisierte Varianten dieser Werkzeuge werden in der eigenen Infrastruktur betrieben, sodass keine unkontrollierten externen Abhängigkeiten entstehen. (3) Ergänzend kann ein internes Repository für Konfigurationsmodule eingerichtet werden, um eine vertrauenswürdige, geprüfte und nachvollziehbare Quellenbasis sicherzustellen.

Control: KONF.2.7 - Alternative Administrationszugänge

Tag: "Hochverfügbarkeit"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.2 Konfiguration von Systemen
UUID: 076ffb7b-6f9e-4f71-8752-cfaa290ee306
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN alternative Administrationszugänge installieren.

Guidance

Das ist zum Beispiel von Bedeutung bei zentralen Systemen wie Firewalls und Router, bei deren Ausfall eine Fernwartung nicht mehr möglich ist. Hierzu können alternative Werkzeuge, sowie alternative Protokolle, Schnittstellen und Zugangskonten verwendet werden. Alternative Werkzeuge sind z.B. Kommandozeilenwerkzeuge, API-Schnittstellen oder die Konsole virtualisierter oder physischer Server, statt der Grafischen Benutzeroberfläche. Bei Cloud-Diensten kann dies z.B. durch Vorhalten von sowohl Browser-Zugang als auch CLI-Zugang geschehen. Alternative Zugangskonten sind z.B. Break-Glass-Accounts, deren Zugangsdaten nur bei Notfällen aus einem Safe entnommen werden.

Control: KONF.2.8 - Abgesicherter und authentisierter Bootprozess

Tags: "Cryptography" "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.2 Konfiguration von Systemen

UUID: 8d460d82-f7db-42c5-b213-625df4381ff3

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN einen abgesicherten und authentisierten Bootprozess aktivieren.

Guidance

Dies empfiehlt sich für eingebettete Systeme (Embedded Systems), indem z.B. der Bootloader die Integrität des Betriebssystems überprüft und es nur dann lädt, wenn es als korrekt eingestuft wurde. Ebenso empfiehlt es sich ein mehrstufiges Boot-Konzept mit kryptographisch sicherer Überprüfung der Einzelschritte zu realisieren, sichere Hardware-Vertrauensanker zu verwenden, bei ARM & UEFI-basierten Systemen jeweils (ARM) Secure Boot zu nutzen.

Control: KONF.3.1 - Kryptographischer Hardwarespeicher

Tags: "Produktbeschreibung" "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.3 Physischer Schutz

UUID: 5c63c101-f2d6-479c-963c-0280bd2fb8a7

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE einen kryptographischen Hardwarespeicher aktivieren.

Guidance

Ein kryptographischer Hardwarespeicher bezeichnet in diesem Kontext eine gesicherte, hardwarebasierte Komponente, die kryptographische Schlüssel oder andere besonders sensible Geheimnisse in einer isolierten und manipulationsgeschützten Umgebung verwahrt. Der Einsatz solcher Speicher kann das Risiko deutlich reduzieren, dass kryptographische Schlüssel bei einem Softwareangriff kompromittiert werden, und kann gleichzeitig die Integrität sicherheitskritischer Prozesse wie Verschlüsselung, Signatur oder Authentifizierung erhöhen. Als Standards können hierzu etwa eine Trusted Execution Environment (TEE), Secure Elements (SE) or Dedicated Security Components (DSC) infrage kommen. Vgl. ISO/IEC 11889 (TPM 2.0), ISO/IEC 19790 / FIPS 140-3 oder ETSI EN 303 645 (für IoT).

Control: KONF.3.2 - Speicherverschlüsselung

Tags: "Produktbeschreibung" "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.3 Physischer Schutz
UUID: e760f62d-1c68-4665-b07b-5b2846550d59
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE integrierte Festspeichermedien verschlüsseln.

Guidance

Die Verschlüsselung von Datenträgern erschwert es Angreifern, Daten von verlorenen oder gestohlenen Geräten auszulesen. Die Verschlüsselung kann in Hard- oder Software (z.B. Windows BitLocker®, Apple FileVault®, Linux® dm-crypt) erfolgen. Für anerkannte kryptographische Algorithmen siehe BSI TR 02102.

Control: KONF.3.3 - SIM-PIN

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.3 Physischer Schutz
UUID: f2184ae3-ca55-4b77-9727-46deb4b9d0ff
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE bei Mobilfunkanschluss eine SIM-PIN aktivieren.

Guidance

Eine SIM-PIN ist eine persönliche Identifikationsnummer, die direkt auf der SIM-Karte gespeichert wird und beim Starten oder Einlegen der Karte abgefragt wird. Sie dient nicht der Benutzeranmeldung am Endgerät selbst, sondern schützt den Mobilfunkanschluss auf Netzebene. Ohne aktivierte SIM-PIN könnte ein Angreifer bei Verlust oder Diebstahl einer SIM-Karte unmittelbar den Mobilfunkanschluss verwenden, etwa für kostenpflichtige Anrufe oder zum Abfangen von SMS-TANs. Die Aktivierung einer SIM-PIN kann somit eine missbräuchliche Nutzung deutlich erschweren, indem ein zusätzliches Hindernis für den unbefugten Zugriff auf Mobilfunkdienste geschaffen wird. Gilt auch für stationäre Systeme mit SIM oder Systeme die eine eSIM verwenden, da eine PIN je nach Diensteanbieter SIM-Swapping vorbeugen kann. Falls das System keine SIM-Karte verwendet, ist die Anforderung entbehrlich.

Control: KONF.3.4 - Physischer Diebstahlschutz

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.3 Physischer Schutz
UUID: 0984599f-2227-4f74-befe-5a1e11b656b0
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Endgeräte KANN einen physischen Diebstahlschutz installieren.

Guidance

Ein physischer Diebstahlschutz bezeichnet im vorliegenden Kontext sämtliche Vorrichtungen oder Maßnahmen, die ein Entwenden von Endgeräten wie Laptops, Tablets oder Arbeitsplatzrechnern erschweren. Hierzu gehören insbesondere physische Schlösser, die mithilfe eines Stahlkabels mit einer dafür vorgesehenen Öffnung am Endgerät verbunden werden können, sodass das Endgerät an einem festen Gegenstand fixiert bleibt. Der Sinn dieser Vorgabe liegt darin, das Risiko zu reduzieren, dass ein Gerät durch unbefugte Dritte entwendet und dadurch der Zugriff auf gespeicherte Informationen oder Zugangsdaten ermöglicht wird. Ein Vorfall könnte entstehen, wenn ein Angreifer ein ungesichertes Notebook während einer Konferenz oder in einem Büro mitnimmt und darüber unverschlüsselte Daten ausliest. Ein angemessen eingesetzter Diebstahlschutz kann die Gelegenheit zum Zugriff verringern, den Aufwand für einen Angreifer erhöhen und so die Wahrscheinlichkeit für den Verlust sensibler Informationen deutlich reduzieren. Zur praktischen Umsetzung kann eine Institution unterschiedliche Maßnahmen wählen. So kann ein Laptop-Kabelschloss genutzt werden, um mobile Geräte temporär an Arbeitsplätzen zu sichern, oder ein Schließfachschrank kann für Aufbewahrung außerhalb der Nutzungszeiten vorgesehen sein. Für stationäre Systeme kann eine feste Verschraubung mit dem Schreibtisch oder die Unterbringung in abschließbaren Möbeln erfolgen. Ergänzend kann eine Institution darauf achten, Geräte mit serienmäßig integrierten Vorrichtungen (z. B. Verriegelungsöffnungen für Kabelschlösser) zu beschaffen, um eine flexible Sicherung zu ermöglichen. Auch das Kennzeichnen von Geräten durch gravierte Inventarnummern oder gut sichtbare Eigentumsaufkleber kann eine zusätzliche Abschreckungswirkung entfalten.

Control: KONF.3.5 - Standortbestimmung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.3 Physischer Schutz
UUID: 4a18939a-0972-4ac7-9584-18ffde38db6
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN eine Funktion zur Bestimmung des Standortes aus der Ferne `{{ insert: param, konf.3.5-prm1 }}` aktivieren.

Guidance

Der Begriff automatisierter Mechanismus bezeichnet im gegebenen Kontext ein technisches Verfahren, das ohne manuelle Eingriffe die Standortbestimmung eines IT-Systems ermöglicht. Dies kann etwa durch GALILEO- oder GPS-Sensoren, durch WLAN- oder Mobilfunkortung, sowie durch Auswertung netzwerktechnischer Parameter erfolgen. Der Rückgriff auf die Standortbestimmung mittels Mobilfunksignal oder WLANs in der Nähe ist nur empfehlenswert, wenn das System die Satellitenbestimmung nicht unterstützt. Der Sinn dieser Vorschrift liegt darin, potenzielle Risiken durch unkontrollierte Standortänderungen oder verdeckte Verlagerungen von IT-Systemen zu reduzieren. Ein Vorfall könnte eintreten, wenn ein Server oder Endgerät unbemerkt aus einem gesicherten Bereich entfernt wird und dadurch sensible Daten oder Konfigurationen kompromittiert werden. Im positiven Fall kann die Standortbestimmung Transparenz über den Verbleib kritischer Systeme schaffen und so die Reaktionsfähigkeit bei Diebstahl oder Verlust erhöhen. Ein praktischer Ansatz kann sein, dass Systeme beim Start ihre Position automatisch protokollieren, so dass Abweichungen vom erwarteten Standort erkannt werden. Alternativ kann eine Softwarelösung eingesetzt werden, die Netzwerkverbindungen auf bestimmte Geozonen überprüft. Beachten Sie hierbei auch den Zusammenhang mit den Verfahren und Regelungen zum Informations- und Assetmanagement, sowie zur Detektion von Sicherheitsvorfällen, etwa dass Standortdaten regelmäßig in ein zentrales Monitoring-Tool eingespielt und mit erlaubten Standorten abgeglichen werden. Um technische Ressourcenauslastung und Datenschutz angemessen auszubalancieren ist es zweckmäßig dies nur für besonders schutzbedürftige Geräte vorzusehen und

klar festzulegen, ob die Standortbestimmung kontinuierlich, ereignisbezogen oder stichprobenartig erfolgt.

Control: KONF.3.6 - Fernlöschung oder -sperre

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.3 Physischer Schutz
UUID: 4757578a-1000-49e7-96fa-d91affa2c768
Aufwand: 5
Sicherheitsstufe: erhöht

Untergeordnete Controls

- KONF.3.6.1 Automatische Fernlöschung oder -sperre

Statement

Konfiguration für Endgeräte KANN eine Funktion zur Fernlöschung oder -sperre aktivieren.

Guidance

Eine automatische Fernlöschung meint hier die technische Möglichkeit, gespeicherte Daten eines Endgeräts über eine externe Steuerung dauerhaft zu entfernen, während eine Fernsperre das Gerät durch zentral initiierte Befehle unbenutzbar macht, ohne die Daten selbst zu löschen. Funktionen zur Fernlöschung (Remote Wiping) sind insbesondere relevant auf allen mobilen Endgeräten, damit bei Bedarf (z.B. wenn das Endgerät verloren geht oder gestohlen wird) alle Daten auf dem Gerät aus der Ferne gelöscht werden können. Ohne eine solche Funktion könnte ein verlorenes, vergessenes oder unzureichend zurückgesetztes Gerät Daten preisgeben oder unbefugt weiterverwendet werden. Für stationäre Endgeräte ist die Anforderung entbehrlich.

Control: KONF.3.6.1 - Automatische Fernlöschung oder -sperre

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.3 Physischer Schutz

Übergeordnetes Control:

KONF.3.6 Fernlöschung oder -sperre

UUID: ffc45c05-597f-4be9-9358-124b4a008e50

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für Endgeräte KANN eine automatische Fernlöschung oder -sperre bei Inaktivität nach `{{ insert: param, konf.3.6.1-prm1 }}` aktivieren.

Guidance

Beide Mechanismen können bei längerer Inaktivität ausgelöst werden, also wenn ein Endgerät über einen bestimmten Zeitraum hinweg nicht mehr mit den Systemen der Institution in Kontakt steht oder nicht genutzt wird. Als angemessene Frist für eine solche Inaktivität können z. B. 30 Tage, 60 Tage oder 90 Tage definiert werden, abhängig vom Sicherheitsbedarf und der Einsatzumgebung. Dies kann verhindern, dass ungenutzte Geräte mit sensiblen Daten in Umlauf bleiben oder in falsche Hände geraten. Ein automatisches Entfernen oder Sperren kann hier das Risiko eines Datenabflusses erheblich reduzieren und gleichzeitig eine Kontrolle über den Gerätelebenszyklus sichern. Zur Umsetzung kann die Institution beispielsweise Mobile-Device-Management-Lösungen einsetzen, die nach Ablauf der gewählten Frist automatisiert Fernlöschung oder Fernsperre auslösen. Alternativ kann eine Endpoint-Security-Lösung integriert werden, die periodisch prüft, ob das Gerät eine Verbindung zum Netz herstellt, und bei Überschreiten des Schwellenwerts eine definierte Aktion anstößt. Auch ein Prozess, bei dem Inaktivität zunächst mit einer Warnmeldung angekündigt wird, bevor tatsächlich gesperrt oder gelöscht wird, kann die Benutzerfreundlichkeit erhöhen.

Control: KONF.3.7 - Einschränkung angeschlossener Peripherie

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.3 Physischer Schutz
UUID: e699dfd7-ecc7-4ca6-bce8-3cd1ba44804d
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE angeschlossene Peripherie einschränken.

Guidance

Peripherie bezeichnet angeschlossene Geräte, die über Schnittstellen wie USB, Bluetooth oder andere Ports mit dem IT-System kommunizieren. Gemeint sind sowohl physische Peripheriegeräte wie Drucker, USB-Sticks oder Netzanbindungen, als auch die Installation virtueller Peripherie z.B. virtuelle Druckertreiber. Einschränkung bedeutet hierbei, dass die Nutzung von Peripheriegeräten verhindert wird, die nicht von der Institution autorisiert wurden, abhängig vom Einsatzzweck des Systems. Der Sinn und Zweck dieser Regelung liegt darin, Angriffsflächen zu verringern und das Einschleusen oder Abfließen von Daten zu erschweren. So könnte ein unkontrollierter Anschluss externer USB-Sticks Schadsoftware einschleusen oder sensible Daten unbemerkt kopieren, während eine restriktive Konfiguration unautorisierte Datenabflüsse wirksam verhindern kann.

Links

required: ASST.3.11.1 Autorisierung von Peripheriegeräten

Control: KONF.3.8 - Einschränkung von Wechselmedien

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.3 Physischer Schutz
UUID: 54314ee4-e904-4ae2-b348-7460f6ebb338
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE das automatische Einbinden von Wechselmedien einschränken.

Guidance

Funktionen, die Wechselmedien automatisch einbinden und Inhalte darauf öffnen oder ausführen könnten zur unkontrollierter Verbreitung von Schadcode beitragen. Betrifft z.B. CD/DVD-Laufwerke, Bandlaufwerke oder USB-Sticks. Dies Kann umgesetzt werden, indem die Einbindung in das Betriebssystem durch spezielle Managementanwendungen blockiert wird oder auch durch systemeigene Sicherheitsfunktionen, z.B. indem alle Dateien auf Wechselmedien als nicht ausführbar markiert sind (Mount-Option „noexec“). Verfügt das IT-System über keine Anschlussmöglichkeit für Wechsellaufwerke, so ist die Anforderung entbehrlich.

Control: KONF.4.1 - Anbindung an Verzeichnisdienst

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.4 Vertrauenswürdige Basisdienste
UUID: 99b370b9-b48c-4f68-b88c-d44ef31f83e0
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.4.1.1 Weiterleitung von Anmeldeinformationen

Statement

Konfiguration für IT-Systeme SOLLTE die Anbindung an einen Verzeichnisdienst aktivieren.

Guidance

Anbindung meint hier die Authentifizierung und Autorisierungsprüfung von Zugangs-konten über einen Verzeichnisdient (häufig auch als Directory Service bezeichnet). Dies ermöglicht die zentrale Verwaltung von Identitäten und deren Berechtigungen. Dies bedeutet, dass Zugriffsrechte für alle angebotenen Systeme zentral verwaltet und bei Bedarf umgehend angepasst werden können, was die Einhaltung des Prinzips der geringsten Rechte (Principle of Least Privilege) unterstützt. Ein häufiger Ansatz zur technischen Umsetzung ist die Verwendung von Protokollen wie LDAP (Lightweight Directory Access Protocol) oder der Einsatz von Single Sign-On (SSO) Lösungen, die eine einmalige Authentifizierung des Nutzers für mehrere Systeme ermöglichen. Institutionen können dabei die Anbindung neuer Systeme durch Automatisierung im Rahmen des Provisioning-Prozesses sicherstellen, um menschliche Fehler zu reduzieren. Beispielsweise könnte ein Standard-Skript bei der Installation eines neuen Servers dessen automatische Anbindung an den Verzeichnisdienst veranlassen. In Windows Betriebssystemen erfolgt die Konfiguration des Betriebssystems über entsprechende Gruppenrichtlinien (Group Policy Object) aus dem Active Directory.

Control: KONF.4.1.1 - Weiterleitung von Anmeldeinformationen

Tags: "Produktbeschreibung" "Lateral Movement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.4 Vertrauenswürdige Basisdienste
Übergeordnetes Control:
KONF.4.1 Anbindung an Verzeichnisdienst
UUID: 6089e247-2518-4c90-b991-df8cbb24585f
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE die Weiterleitung mehrfach verwendbarer Anmeldeinformationen deaktivieren.

Guidance

„Weiterleitung mehrfach verwendbarer Anmeldeinformationen“ (auch als Credential Forwarding oder Credential Delegation bekannt) meint technische Mechanismen, bei denen die Anmeldeinformationen eines Zugangskontos (z.B. Kennworthashes oder Kerberos-Tickets) an ein zweites System weitergereicht werden, um sich dort ebenfalls zu authentifizieren, ohne die Daten erneut eingeben zu müssen. Ziel der Deaktivierung ist hier die Unterbrechung von Angriffsketten, die auf dem Diebstahl von Zugangsdaten basieren. Ein Angreifer könnte sonst nach der Kompromittierung eines weniger kritischen Systems, wie einem Webserver, die dorthin weitergeleiteten Anmeldeinformationen eines Administrators aus dem Arbeitsspeicher auslesen und sich mit diesen Rechten unbemerkt im gesamten Netzwerk weiter ausbreiten (Laterale Bewegung). Das gezielte Deaktivieren des Credential Forwarding kann die Angriffsfläche erheblich reduzieren und solche „Pass-the-Hash“- oder „Pass-the-Ticket“-Angriffe effektiv eindämmen, da Anmeldeinformationen mit hohen Privilegien gar nicht erst auf unsichere Systeme gelangen. Stattdessen kann die Authentifizierung ausschließlich temporäre, eingeschränkte Tickets oder Tokens verwenden. Hierzu gehören z.B. Windows Remote Credential Guard oder RestrictedAdmin, sowie unter Linux SSH-Agent Forwarding oder GSSAPI. Eine Token-basierte Authentifizierung ist eine Strategie zur Verbesserung der Informationssicherheit. Nachdem

Benutzende ihre Anmeldedaten eingegeben haben, werden diese überprüft und ein einmaliges verschlüsseltes Token generiert, mit dem sie anschließend auf Online-Ressourcen zugreifen können, ohne bei jeder Anfrage ihren Benutzernamen und ihr Passwort eingeben zu müssen. Bei SSH-Verbindungen kann die unsichere „Agent Forwarding“-Funktion serverseitig in der Konfigurationsdatei deaktiviert werden.

Control: KONF.4.2 - DNS-Anbindung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.4 Vertrauenswürdige Basisdienste
UUID: 490400dc-4769-4127-9869-720a3ce1585c
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.4.2.1 DNS-Verschlüsselung

Statement

Konfiguration für IT-Systeme SOLLTE die vom System verwendeten DNS-Server autorisieren.

Guidance

Autorisierte DNS-Server sind hier Resolving-Server, die von der Institution autorisiert wurden. Dies können entweder DNS-Server der Institution selbst oder externe DNS-Server zuverlässiger Anbieter sein.

Control: KONF.4.2.1 - DNS-Verschlüsselung

Tags: "Produktbeschreibung" "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.4 Vertrauenswürdige Basisdienste
Übergeordnetes Control:
KONF.4.2 DNS-Anbindung
UUID: ccb6bfb1-1b49-4d03-9705-2d05bca018b5
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE DNS-Verbindungen durch {{ insert: param, konf.4.2.1-prm1 }} verschlüsseln.

Guidance

DNS-Verschlüsselung, im Englischen oft als DNS over TLS (DoT) oder DNS over HTTPS (DoH) bezeichnet, ist ein Verfahren, bei dem Anfragen zur Namensauflösung im Internet kryptographisch geschützt werden, um deren Vertraulichkeit und Integrität sicherzustellen. Erfolgen diese Anfragen unverschlüsselt, könnte ein Angreifer im Netz die aufgerufenen Webseiten und Dienste eines Nutzers mitlesen und protokollieren. Schlimmer noch, ein Angreifer könnte die Antworten manipulieren, um den Nutzer unbemerkt auf gefälschte Webseiten umzuleiten, beispielsweise für Phishing-Angriffe. Die Aktivierung der DNS-Verschlüsselung kann einem solchen Ausspähen und Manipulieren der Namensauflösung effektiv entgegenwirken und stellt sicher, dass die Kommunikation zwischen dem Client und dem DNS-Server authentisch und nicht einsehbar ist. Nutzt das System kein DNS, so ist die Anforderung entbehrlich.

Control: KONF.4.3 - Authentifizierung von Fernwartungsfunktionen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.4 Vertrauenswürdige Basisdienste
UUID: 6fa4659a-8472-4d26-9f3b-a3edfa412a8c
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE Fernwartungsfunktionen im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement authentifizieren.

Guidance

Unter Fernwartungsfunktionen versteht man technische Zugänge, die es ermöglichen, IT-Systeme aus der Ferne zu administrieren oder Fehler zu beheben, etwa über Protokolle wie RDP, SSH oder proprietäre Remote-Support-Lösungen. Fernwartungsfunktionen könnten für eine Institution erhebliche Risiken bergen, wenn ihre Nutzung nicht eindeutig authentifiziert wird. Ohne verlässliche Identitäts- und Berechtigungsprüfung könnte ein Unbefugter über eine Remote-Schnittstelle auf Systeme zugreifen, Konfigurationen manipulieren oder Schadsoftware einschleusen. Die Formulierung "im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement" bedeutet, dass die Authentifizierung so erfolgt, wie in der Praktik Berechtigung (BER) festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist.

Links

related: BER.1.1 Verfahren und Regelungen

Control: KONF.4.4 - Einschränkung von Fernwartungsfunktionen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.4 Vertrauenswürdige Basisdienste
UUID: 2e782e35-d708-49c3-b022-76616ae204be
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE Fernwartungsfunktionen im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement einschränken.

Guidance

Fernwartungszugänge, etwa über RDP, SNMP oder Anwendungen zur Fernsteuerung des Systems erlauben typischerweise eine Vielzahl von Eingriffen in Systemkonfiguration und Datenverarbeitungen. Beispiele sind die Remote-Zwischenablage und die automatische Einbindung von Peripheriegeräten, Wechseldatenträgern und Netzlaufwerken. Unautorisierte Fernwartungszugänge könnten für Angriffe missbraucht werden. Die Formulierung "im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement" bedeutet, dass die Authentifizierung so erfolgt, wie in der Praktik Berechtigung (BER) festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist.

Links

related: BER.1.1 Verfahren und Regelungen

Control: KONF.4.5 - Zeitquellen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.4 Vertrauenswürdige Basisdienste
UUID: 92eee157-2b9b-4a80-8f17-4b124590d72f
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE Zeitquellen autorisieren.

Guidance

Eine einheitliche Zeitquelle für die Systemuhr (meist über NTP oder PTP) ist essenziell für die einheitliche Auswertung von Logdateien, sowie für moderne kryptographische Verfahren. Es empfiehlt sich zu definieren, welche NTP-Server von welchen NTP-Clients genutzt werden sollen und ob NTP-Server im Broadcast-Modus oder im Client-Server-Modus arbeiten. Letzteres (Client-Server) ist hierbei Best Practice. In bestimmten Fällen empfiehlt es sich außerdem, dass sich NTP-Server bei der Kommunikation gegenüber Clients authentisieren und demnach NTP-Clients nur authentifizierte NTP-Daten akzeptieren.

Control: KONF.5.1 - Authentifizierung am System

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.5 Authentifizierung
UUID: cc0d5002-8ef3-434c-b19f-15f0f226a6cb
Aufwand: 1
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.1.2 Pre-Boot-Authentifizierung

Statement

Konfiguration für IT-Systeme SOLLTE den Zugriff auf das System im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement authentifizieren.

Guidance

Betrifft sowohl die lokale Anmeldung über eine Benutzeroberfläche als auch den Zugriff über Fernwartungsprotokolle oder -anwendungen wie RDP, SNMP, wenn diese vorhanden sind. Die Umsetzung erfolgt im einfachsten Fall durch einen Login, bzw. eine Bildschirmsperre für das IT-System. Biometrische Daten wie Fingerabdrücke können gefälscht werden und sind nicht so leicht zu ändern wie Passwörter. Setzen Sie Biometrie daher nicht als einzigen Authentifizierungsfaktor ein, sondern wenn, dann nur zur Ergänzung (Mehr-Faktor-Authentifizierung). Die Formulierung "im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement" bedeutet, dass die Authentifizierung so erfolgt, wie in der Praktik Berechtigung (BER) festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist. Die Anforderung ist entbehrlich, wenn das System keinen Zugriff auf schützenswerte Daten erlaubt, z.B. bei Nutzung als Kiosk.

Links

related: BER.1.1 Verfahren und Regelungen

Control: KONF.5.1.1 - Authentifizierung an der Firmware

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.5 Authentifizierung
Übergeordnetes Control:
KONF.5.1 Authentifizierung am System
UUID: e9bd0b40-47ed-4e4d-a747-ad71884f076f
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE den Zugriff auf die Firmware im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement authentifizieren.

Guidance

Durch unautorisierte Änderungen an Einstellungen der Firmware (UEFI oder Embedded System) könnten Fehlerzustände entstehen oder Sicherheitsfunktionen wie TPM deaktiviert werden. Dies kann je nach Firmware durch lokale Zugangspasswörter oder zentrale Berechtigung umgesetzt werden. Hierbei sind insbesondere Einstellungen von Sicherheitsfunktionen oder der Netzanbindung relevant. Die Formulierung "im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement" bedeutet, dass die Authentifizierung so erfolgt, wie in der Praktik Berechtigung (BER) festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist.

Links

related: BER.1.1 Verfahren und Regelungen

Control: KONF.5.1.2 - Pre-Boot-Authentifizierung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.5 Authentifizierung
Übergeordnetes Control:
KONF.5.1 Authentifizierung am System
UUID: 89f6db4b-b55b-4218-aad6-6f5c33a49ee6
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Endgeräte KANN den Zugriff vor dem Start des Betriebssystems authentifizieren.

Guidance

Diese Authentifizierung vor dem Start, oft als "Pre-Boot Authentication" (PBA) oder "Hardware-based Authentication" bezeichnet, verhindert, dass ein Gerät gestartet wird, bevor sich Nutzende mit Anmeldeinformationen, wie zum Beispiel einem Passwort oder einem biometrischen Merkmal, autorisiert haben. Ohne diese Authentifizierung könnte ein Angreifer versuchen, das Gerät direkt zu booten, die Festplatte zu kopieren oder zu manipulieren, um sensitive Daten zu extrahieren. Eine gängige Methode ist die Verwendung einer Festplattenverschlüsselung (Full Disk Encryption, FDE) mit einer Pre-Boot-Authentifizierung. Eine Institution könnte auch eine Mehr-Faktor-Authentifizierung (MFA) vor dem Start des Betriebssystems einsetzen, beispielsweise indem ein Hardware-Token oder ein biometrischer Scan zusätzlich zum Passwort erforderlich ist, was die Sicherheit weiter erhöht.

Control: KONF.5.2 - Keine Mehrfachanmeldung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.5 Authentifizierung
UUID: 71f7d8c3-4e50-45b8-a01a-5ee7b957d31b
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE die gleichzeitige Anmeldung mehrerer Zugangskonten deaktivieren.

Guidance

Wenn Nutzende mit verschiedenen Identitäten simultan im System angemeldet sind, erhöht sich das Risiko von versehentlichen Datenvermischungen oder Falscheingaben deutlich. Dies kann besonders in sensiblen Bereichen wie im Finanzwesen oder Gesundheitswesen schwerwiegende Folgen haben, wo vertrauliche Kundendaten oder Patienteninformationen unbeabsichtigt zwischen verschiedenen Kontexten übertragen werden könnten. Bei Vorfällen wird so auch erschwert herauszufinden, von welchem Zugangskonto bestimmte Ereignisse stammen.

Control: KONF.6.1 - Minimal erforderliche Berechtigungen für Anwendungen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.6 Rollen und Berechtigungen

UUID: cc6a9a9d-cb65-4e22-aad5-d93f73e522b8

Aufwand: 3

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.1.3 Isolierte Arbeitsumgebungen

Statement

Konfiguration für IT-Systeme SOLLTE erforderliche Berechtigungen für Anwendungen einschränken.

Guidance

Ziel ist es, Angriffsflächen zu minimieren und unerwünschte Seiteneffekte zu vermeiden. Durch restriktive Rechtevergabe pro App lässt sich das Risiko für Zugriffe auf sensible Bereiche stark senken. Gleichzeitig trägt dieses Prinzip dazu bei, eine klare Trennung zwischen den einzelnen Systemkomponenten zu bewahren und unkontrollierte Wechselwirkungen zu verhindern. Beispiele sind Lese- und Schreibrechte für Verzeichnisse, insbesondere für Systemverzeichnisse, Berechtigungen zum Zugriff auf Sensoren oder Peripheriegeräte, sowie der Netzzugriff. Um die Umsetzung zu erleichtern können Berechtigungsprofile erstellt werden, die je nach Anwendungs-kategorie (z. B. Office, Multimedia, Tools) eine Basislinie an Privilegien definieren. Diese Profile können in einer zentralen Verwaltungssoftware (z. B. über Gruppenrichtlinien oder ein Mobile-Device-Management) hinterlegt und automatisch auf neue Installationen angewendet werden. Vor der Freigabe einer Softwareinstallation kann ein Reviewprozess etabliert werden, bei dem anhand von Funktionsdokumentationen geprüft wird, welche minimalen Rechte erforderlich sind. Darüber hinaus kann der Einsatz von Sandboxing- oder Virtualisierungstechnologien unterstützen, indem An-

wendungen in einer isolierten Umgebung mit genau festgelegten Schnittstellen betrieben werden können. Tools zur Rechteanalyse (etwa zur Ermittlung der tatsächlich genutzten APIs und Dateizugriffe) können helfen, überflüssige Freigaben im Nachgang weiter einzuschränken.

Control: KONF.6.1.1 - Datenkapselung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
Übergeordnetes Control:
KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
UUID: 6bb18861-0616-4cde-afed-7929b71ba16c
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN Datenkapselung aktivieren.

Guidance

Bei der Datenkapselung, im Englischen als data encapsulation bekannt, handelt es sich um einen Schutzmechanismus, bei dem Daten logisch vor dem Zugriff des restlichen Systems verborgen werden. Hierdurch wird der direkte Zugriff unterbunden und ausschließlich über definierte, sichere Schnittstellen bereitgestellt. Zweck ist es, die Angriffsfläche auf sensible Daten zu verringern und deren Integrität sowie Vertraulichkeit zu wahren. Ohne eine solche Kapselung könnte beispielsweise eine Schadsoftware auf einem Server direkt auf Konfigurationsdateien oder im Arbeitsspeicher gehaltene Anmeldeinformationen anderer Anwendungen zugreifen und diese manipulieren oder ausleiten. Durch eine wirksame Datenkapselung kann die Institution sicherstellen, dass Zugriffe nur über vorab genehmigte und protokollierte Wege erfolgen, was eine unautorisierte Modifikation oder einen unbemerkten Abfluss von Daten erschwert. Technisch erfolgt dies zum Beispiel durch einen abgeschlossenen Speicherbereich auf einem mobilen Gerät für persönliche Informationen wie Kontakte oder Kalender (PIM-Container). Die Kapselung erfordert eine separate Authentisierung vor dem Zugriff auf die gekapselten Daten und eine vom Betriebssystem unabhängige Daten- & Transportverschlüsselung innerhalb der Kapselung.

Control: KONF.6.1.2 - Isolierung von Anwendungen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
Übergeordnetes Control:
KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
UUID: d380c6d8-1ab0-4e4b-bcca-2e620b40d934
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN die Isolierung von {{ insert: param, konf.6.1.2-prm1 }} aktivieren.

Guidance

Die Isolation von Anwendungen (auch Kapselung oder Application Sandboxing genannt) dient dazu, die Angriffsfläche eines Systems zu reduzieren und die Vertraulichkeit, Integrität sowie Verfügbarkeit kritischer Komponenten besser zu schützen. Durch eine klare Trennung der Anwendungs- und Systemprozesse und von deren Ressourcenzugriffen (Netzwerk, Datei- oder Geräte-I/O) kann eine kompromittierte Applikation nicht unbegrenzt auf weitere Systemressourcen zugreifen, sondern ist auf genau definierte Schnittstellen beschränkt. Bestimmte Anwendungen meint hier, dass konkret festgelegt wird, welche Anwendungen konkret isoliert ausgeführt werden. Dies ermöglicht es, Fehlfunktionen oder Angriffe einzudämmen, Schadsoftware leichter zu erkennen und Verantwortlichkeiten einzelner Module transparent zu halten. Dies kann z.B. durch Containerisierung oder eine Microservice-Architektur, in der jede Komponente nur über REST- oder Message-Queue-Schnittstellen kommuniziert umgesetzt werden. Auch klassische Virtualisierung (Gastsysteme mit Hypervisor) oder Betriebssystemfunktionen wie SELinux/AppArmor-Profile und chroot-jails zählen dazu, weil sie Applikationen auf genau festgelegte Ressourcen beschränken. Im Kontext der Containerisierung empfiehlt es sich ebenfalls eine feste Zuordnung von Containern zu Container-Hosts vorzunehmen.

Control: KONF.6.1.3 - Isolierte Arbeitsumgebungen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
Übergeordnetes Control:
KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
UUID: cfe748d3-22ff-4f2c-8bb0-d22338c67f45
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Endgeräte KANN die Isolation verschiedener Arbeitsumgebungen für verschiedene Verwendungen aktivieren.

Guidance

Verschiedene Verwendungen sind z.B. die berufliche und private Nutzung, oder die Nutzung als IT-System mit erhöhtem Schutzbedarf und das Surfen im Internet. Arbeitsumgebungen sind getrennt, wenn die zu schützenden Daten ausschließlich in der geschützten Umgebung verbleiben. Beispielimplementierungen sind Apple® Configuration Profile oder Android™ Work Profile. Je nach Aufbau des Systems können hierzu z.B. Trennung auf Betriebssystemebene, netzbasierte Trennung, Virtualisierung oder Container eingesetzt werden.

Control: KONF.6.2 - Gemeinsam genutzte Verzeichnisse

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
UUID: ec10cb70-9101-4293-ab4c-92d57f84af77
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Endgeräte SOLLTE die Zugriffsrechte gemeinsam verwendeter Verzeichnisse einschränken.

Guidance

Relevant sind hierbei sowohl speziell eingerichtete Verzeichnisse für die gemeinsame Bearbeitung von Dateien als auch Verzeichnisse, die vom System für gemeinsame Dateien verwendet werden, z.B. /tmp. Unter Linux kann das Sticky-Bit verwendet werden, um den Zugriff auf die Dateien in diesem Verzeichnis einzuschränken, so dass nur noch der Eigentümer einer Datei (oder der Eigentümer des Verzeichnisses) diese Datei löschen oder umbenennen darf.

Control: KONF.6.3 - Kiosk-Modus

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
UUID: 1b90a130-be97-42bf-8d30-8458a1d743ee
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Endgeräte KANN das automatische Zurücksetzen auf einen definierten Zustand nach der Nutzung aktivieren.

Guidance

Ein Kiosk-Modus (auch als Gast-Zugang bezeichnet) kann dazu dienen, die Integrität und den definierten Ausgangszustand eines Systems dauerhaft sicherzustellen, indem nach jeder Sitzung oder in regelmäßigen Abständen ein vollständiger Rücksetzvorgang angestoßen wird. Damit soll verhindert werden, dass ungewollte Änderungen – etwa durch Malware, böswillige Manipulation oder versehentlich abgelegte Nutzerdaten – dauerhaft auf dem System verbleiben. Gleichzeitig kann so gewährleistet werden, dass jede neue Nutzersession in einer standardisierten, getesteten Umgebung beginnt, was sowohl den Support-Aufwand reduziert als auch Datenschutzaspekte stärkt, da keine personenbezogenen Daten auf dem Gerät zurückbleiben können. Typische Anwendungsfälle können öffentliche Terminals in Bibliotheken oder Behörden, digitale Informationsstelen in Museen und Einkaufszentren sowie Schulungs- oder Präsentationsrechner in Unternehmen sein. In solchen Szenarien kann das System beim Ausloggen oder nach einer festgelegten Zeit (z. B. nachts) automatisch auf ein sauberes Basis-Image zurückgesetzt werden. Denkbar ist auch ein Einsatz in Fabrikumgebungen, um Versuchs- und Prüfsysteme immer wieder in einen definierten Ausgangszustand zu bringen, oder in Testlaboren für Software, wo nach jedem Testlauf eine reine Umgebung erforderlich ist. Für die produktneutrale Umsetzung kann man beispielsweise mit Virtualisierungstechnologien arbeiten, die mittels Snapshot-Rollback beim Neustart eine saubere VM-Instanz bereitstellen. Alternativ kann ein Live-Betriebssystem vollständig im Arbeitsspeicher laufen oder das Dateisystem über Overlay-Techniken (z. B. OverlayFS, AUFS) nur virtuell überschrieben werden – alle Änderungen verwerfen sich beim Neustart au-

tomatisch. Auch der Einsatz von read-only-Partitionen kombiniert mit einem Schreibbereich in RAM kann eine einfache Lösung sein. Skriptbasierte Cron-Jobs oder Systemd-Timer können den Rücksetzprozess zu definierten Zeiten anstoßen. Externes Logging und Konfigurationsmanagement (etwa über Ansible oder Puppet) kann dabei helfen, wichtige Ereignisse und Konfigurationsänderungen zu protokollieren, ohne den Kiosk-Modus zu beeinträchtigen.

Control: KONF.6.4 - Privilegierte Systemfunktionen

Tags: "Produktbeschreibung" "Living off the land"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
UUID: f129ae20-1423-4df0-a735-db8365592cd1
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.6.4.1 Rollenbasierte Privilegierung

Statement

Konfiguration für IT-Systeme SOLLTE privilegierte Funktionen einschränken.

Guidance

Sind privilegierte Funktionen nicht eingeschränkt, so könnten Innentäter oder Angreifer über das Netz unbefugte Manipulationen vornehmen, Fehlkonfigurationen ausgelöst werden oder sich Schadcode automatisch einnisten. Privilegierte Funktionen können z.B. ein lokales Berechtigungsmanagement, die Installation von Anwendungen, der Schreibzugriff auf Systemverzeichnisse oder die Änderung der Systemkonfiguration sein.

Control: KONF.6.4.1 - Rollenbasierte Privilegierung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
Übergeordnetes Control:
KONF.6.4 Privilegierte Systemfunktionen
UUID: b20ab43c-96f3-4bc4-8a4c-1dca837bb41f
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN rollenbasiertes Berechtigungsmanagement aktivieren.

Guidance

Rollenbasierte Administration schränkt die Berechtigungen administrativer Zugangskonten anhand von Rollen so ein, dass nur die jeweils erforderlichen Funktionen freigeschaltet sind. Dies kann z.B. mit Windows PowerShell Just Enough Administration (JEA) oder SELinux, AppArmor oder Sudoers umgesetzt werden.

Control: KONF.6.5 - Dynamische Zugriffskontrolle im System

Tags: "Produktbeschreibung" "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.6 Rollen und Berechtigungen

UUID: ced10fd0-a74e-4376-8dac-f3381c6a9482

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN dynamische Zugriffskontrolle im System aktivieren.

Guidance

Eine dynamische Zugriffskontrolle (engl. Dynamic Access Control, DAC) bezeichnet ein Verfahren, bei dem Zugriffsentscheidungen nicht ausschließlich auf statischen Berechtigungen (z. B. Benutzerrollen oder ACLs) beruhen, sondern zusätzlich kontextabhängige Bedingungen wie Gerätezustand, Sensitivität der Daten, Standort, Zeitfenster oder Sicherheitsklassifikation auswerten. Dabei bleibt die Policy, also die zugrundeliegende Regelmenge zur Zugriffsbewertung, fest definiert und nachvollziehbar dokumentiert – lediglich die Entscheidung über den konkreten Zugriff erfolgt dynamisch anhand dieser Bedingungen. Ziel ist eine feinere Steuerung des Datenzugriffs auf Basis aktueller Risikosituationen, ohne dass Administratoren Berechtigungen manuell anpassen müssen. Solche Mechanismen können etwa verhindern, dass ein Benutzer sensible Daten von einem nicht verwalteten Endgerät ausliest, während er im internen Netz regulär Zugriff hätte. Da DAC komplex sein kann ist es zweckmäßig, auch auf Funktionen zur Auditierung und Protokollierung der DAC zu achten.

Control: KONF.6.6 - Getrennte Datenhaltung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
UUID: 55e2c264-c09d-4967-83ab-f4430f898099
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.6.6.1 Mandantenfähigkeit

Statement

Konfiguration für Anwendungen SOLLTE Zugriffe eines Zugangskontos auf Daten anderer Zugangskonten einschränken.

Guidance

Dies kann je nach Anwendung z.B. durch eine in der Anwendung integrierte Rollen- und Rechteverwaltung, Zugriffsrechte auf Dateisystemebene oder durch die Verwendung unterschiedlicher Systeme oder Netze pro Zugang realisiert werden.

Control: KONF.6.6.1 - Mandantenfähigkeit

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
Übergeordnetes Control:
KONF.6.6 Getrennte Datenhaltung
UUID: 2f0d27ba-6f8f-4f1e-9f5b-29cd79d7b08d
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Anwendungen SOLLTE wenn die Anwendung mehrere Mandanten bedient, für jeden Mandanten eine eigene Berechtigungskonfiguration aktivieren.

Guidance

Der Ausdruck "mehrere Mandanten" (im Englischen auch multi-tenancy genannt) bezieht sich auf eine Softwarearchitektur, bei der eine einzige Instanz einer Anwendung gleichzeitig die Bedürfnisse mehrerer, voneinander unabhängiger Kundengruppen (Mandanten) bedient. Eine eigene Berechtigungskonfiguration bedeutet, dass jeder Mandant eine separate, von den anderen getrennte Sammlung von Zugriffsregeln und -rechten erhält. Dies dient dem Schutz vor Datenlecks, da ein Angreifer, der sich unrechtmäßig Zugang zu einem Mandanten verschafft, dadurch nicht automatisch die Berechtigungen für andere Mandanten übernimmt. Eine separate Konfiguration kann verhindern, dass ein Fehlverhalten oder eine Fehlkonfiguration bei einem Mandanten die Sicherheit aller anderen beeinträchtigt. Technische Möglichkeiten hierfür sind die Verwendung von mandantenspezifischen Datenbank-Schemata oder die logische Trennung von Daten innerhalb einer gemeinsamen Datenbank durch Mandanten-IDs. Darüber hinaus kann die Institution sicherstellen, dass die Authentifizierung und Autorisierung für jeden Mandanten streng getrennt sind, zum Beispiel durch die Nutzung unterschiedlicher API-Schlüssel oder Single-Sign-On-Konfigurationen pro Mandant.

Control: KONF.6.7 - Privilegierte Funktionen der Anwendung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
UUID: 91968d63-7ef1-4625-a3a5-039c340577b1
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Anwendungen SOLLTE privilegierte Funktionen einschränken.

Guidance

Sind privilegierte Funktionen nicht eingeschränkt, so könnten Innentäter oder Angreifer über das Netz unbefugte Manipulationen vornehmen, Fehlkonfigurationen ausgelöst werden oder sich Schadcode automatisch einnisten. Privilegierte Funktionen können z.B. ein Berechtigungsmanagement der Anwendung, der Zugriff auf Daten mehrerer Zugangskonten, das Hinzufügen oder Entfernen akzeptierter X.509-Zertifikate, ein Moderationsrecht oder die Änderung der Sicherheitskonfiguration der Anwendung sein.

Control: KONF.6.8 - Berechtigungen des Webserver-Prozesses

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
UUID: 342916fa-e073-4db3-906c-af2563081e6e
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webserver SOLLTE die Berechtigungen des Webserver-Prozesses einschränken.

Guidance

Wird der laufende Prozess über das Web kompromittiert, so verhindert eine Einschränkung der Rechte eine weitere Ausbreitung des Angriffs. Relevant sind dabei Zugriffsrechte für Dateisystem und Systemfunktionen. Zweckmäßig ist es hierzu, die Berechtigungen so einzuschränken, dass der Serverdienst a) keinen Zugriff auf Dateien außerhalb des WWW-Wurzelverzeichnisses hat, b) Schreibzugriffe innerhalb des WWW-Wurzelverzeichnisses nur in explizit autorisierten Unterverzeichnissen hat, c) keine Programme oder Shell-Befehle außerhalb der vorgesehenen Interpreter ausführen kann, d) keine privilegierten Berechtigungen besitzt. Unterverzeichnisse die Schreibrechte benötigen könnten sind etwa /uploads, /cache, /tmp.

Control: KONF.6.9 - Zugriff auf Code

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
UUID: c6624f60-f990-4900-84ef-747d5a6e81c6
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webserver SOLLTE den Zugriff auf Quelldateien einschränken.

Guidance

Quelldateien sind in diesem Zusammenhang alle Dateien, die zur Funktionsweise einer Webanwendung benötigt werden, deren Auslieferung an den Browser von Nutzenden aber nicht erforderlich ist. Dazu gehören Programmier- oder Skriptcode, Konfigurationsdateien, Datenbankverbindungen und sensible Daten wie APIs oder Anmeldeinformationen. Das Verhindern des direkten Zugriffs auf diese Dateien dient der Prävention von Informationslecks und der Minderung des Risikos unautorisierter Offenlegung. Eine nicht restriktive Konfiguration könnte beispielsweise die Offenlegung von Code-Teilen, die Logik der Anwendung oder sogar hartkodierten Passwörtern ermöglichen, was zu einer weitreichenden Kompromittierung des Systems führen könnte. Die Umsetzung kann durch platzieren dieser Dateien außerhalb des WWW-Wurzelverzeichnisses erfolgen. Weiterhin kann der Zugriff auf bestimmte Dateitypen wie .php, .ini, .env oder .sql mittels Webserver-Regeln (z.B. in .htaccess für Apache oder location-Blöcke in Nginx) explizit verweigert werden, wodurch auch versehentlich im öffentlichen Verzeichnis abgelegte Quelldateien geschützt sind. Bei der Wahl eines Content-Management-Systems oder Frameworks kann eine sichere Standardkonfiguration die Umsetzung erleichtern. Zusätzlich können serverseitige Skripte so konfiguriert werden, dass sie nur aus vordefinierten, sicheren Verzeichnissen ausgeführt werden dürfen, was als Secure Execution Path bekannt ist.

Control: KONF.6.10 - Auflistung von Verzeichnisinhalten

Tags: "Produktbeschreibung" "Data Leak"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
UUID: ce8d6ad1-d414-48a3-b273-50fa01fd2ee6
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webserver SOLLTE die Auflistung von Verzeichnisinhalten einschränken.

Guidance

Über das Auflisten von Verzeichnisinhalten erhalten Angreifer Einblick in die interne Struktur des Systems und potenziell sensibler Daten. Zur Umsetzung kann in der Konfiguration des Webserver (z.B. Apache, Nginx) die Directory-Listing-Funktion deaktiviert werden. Alternativ kann über Dateien wie .htaccess der Zugriff auf die notwendigen Verzeichnisse eingeschränkt werden.

Control: KONF.6.11 - Einschränkung von Uploads

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
UUID: 80201ed2-a627-4240-86c1-0d91415f96b5
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webserver SOLLTE Uploads einschränken.

Guidance

Uploads sind Dateien, die von Nutzenden auf den Server übertragen werden. Diese könnten Schadprogramme enthalten oder den Speicher füllen. Sinnvolle Beschränkungen sind z.B. der Upload nur nach Anmeldung, eine maximale Dateigröße, erlaubte Dateitypen und deren Speicherorte.

Control: KONF.6.12 - Konferenzmoderation

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
UUID: 862961f1-924d-4557-9f81-e31730162561
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für VK-Anwendungen SOLLTE Konferenzmoderation aktivieren.

Guidance

Bei Konferenzen kann es vorkommen, dass ungewollt Teilnehmende zu hören sind. Dies kann versehentlich geschehen oder im Rahmen eines Angriffes.

Control: KONF.6.13 - Dynamische Zugriffskontrolle in der Anwendung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.6 Rollen und Berechtigungen

UUID: 55dfbf64-f1f3-4765-a0d3-78f0a1f00654

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für Anwendungen KANN dynamische Zugriffskontrolle in der Anwendung aktivieren.

Guidance

Dynamische Zugriffskontrolle („dynamic access control“, DAC) bezeichnet hier eine Form der Autorisierungsprüfung innerhalb einer Anwendung, bei der die Entscheidung über den Zugriff nicht ausschließlich anhand statischer Rollen oder Benutzergruppen erfolgt, sondern zusätzlich kontextabhängige Bedingungen („contextual attributes“) berücksichtigt werden. Solche Bedingungen können beispielsweise der aktuelle Standort der Anmeldung, die Gerätekategorie, der Zeitpunkt des Zugriffs oder die Sensitivität der angeforderten Daten sein. Die zugrunde liegende Zugriffsrichtlinie („policy“) bleibt dabei fest definiert – die Dynamik betrifft ausschließlich die Bewertung der in ihr vorgesehenen Parameter. Dadurch unterscheidet sich DAC auf Anwendungsebene von klassischen „role-based access control“ (RBAC)-Mechanismen, indem sie feinere, situative Entscheidungen erlaubt, ohne dass Berechtigungen für den Einzelfall manuell vergeben werden. Die Möglichkeit, eine dynamische Zugriffskontrolle in der Anwendung zu aktivieren, kann wesentlich dazu beitragen, unbefugte oder unangemessene Zugriffe zu verhindern, wenn sich Sicherheitsbedingungen ändern. Ohne solche Mechanismen könnte ein Benutzer etwa trotz eines kompromittierten Geräts oder außerhalb sicherer Netzbereiche weiterhin auf vertrauliche Daten zugreifen, was zu Datenabfluss oder Manipulation führen könnte. Die dynamische Kontrolle kann hingegen sicherstellen, dass Zugriffe nur gewährt werden, wenn aktuelle Kontextparameter mit den definierten Sicherheitsrichtlinien übereinstimmen, wodurch das Risiko situativer Angriffe deutlich reduziert werden kann. Bei-

spiele sind Anwendungen (1) eine Policy-Engine wie XACML-kompatible Systeme zur regelbasierten Entscheidungsfindung verwenden, (2) Attributquellen wie Identity Provider oder Endpoint-Sicherheitslösungen zur Kontextbewertung einbinden oder (3) adaptive Autorisierungsmechanismen, etwa über Open Policy Agent.

Control: KONF.6.14 - Browser Sandboxing

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
UUID: 9b157336-4f35-43f5-90e2-704c00d452e5
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webbrowser SOLLTE Browser Sandboxing aktivieren.

Guidance

Sandboxing bedeutet, dass jede Instanz und jeder Verarbeitungsprozess nur auf die eigenen Ressourcen zugreifen kann. Die Isolation kann durch eigene Threads oder eigene Prozesse realisiert sein.

Control: KONF.6.15 - Virtualisierte Browser-Umgebung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.6 Rollen und Berechtigungen
UUID: 2717f887-571c-4830-a5de-a87c44bbca23
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Webbrowser KANN Virtualisierte Browser-Umgebung aktivieren.

Guidance

Eine Browser-Umgebung ist virtualisiert, wenn der Code des Browser nicht im Betriebssystem des Clients, sondern in einem dediziert hierzu virtualisierten Betriebssystem ausgeführt wird, z.B. ReCoBS.

Control: KONF.6.16 - Datenaustausch in der Virtualisierung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.6 Rollen und Berechtigungen

UUID: 55db7b45-c04c-42c6-b803-eacd27aee6c7

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für Virtualisierungslösungen KANN den Datenaustausch zwischen virtualisierten Client einschränken.

Guidance

Der Datenaustausch zwischen virtualisierten Anwendungen umfasst jegliche direkte oder indirekte Kommunikationswege wie virtuelle Netzwerke, geteilte Speicherbereiche oder Copy-and-Paste-Funktionen über die Virtualisierungsplattform. Der Sinn dieser Anforderung liegt darin, unbeabsichtigte oder böswillige Datenübertragungen zwischen isolierten Anwendungen einzuschränken. Ohne diese Einschränkungen könnte Schadsoftware von einer kompromittierten VM unbemerkt auf eine andere übergreifen oder sensible Informationen könnten durch Fehlkonfigurationen ungewollt in eine fremde VM gelangen. Eine klare Abgrenzung kann hingegen sicherstellen, dass selbst bei Kompromittierung einer Anwendung deren Wirkungskreis begrenzt bleibt und Vertraulichkeit, Integrität sowie Stabilität anderer Anwendungen erhalten bleiben. Die praktische Umsetzung kann durch mehrere Maßnahmen erfolgen, die sich technisch wie prozessual ergänzen. So kann eine Institution (1) virtuelle Netzwerke segmentieren, sodass VMs nur über explizit eingerichtete Firewalls miteinander kommunizieren können, (2) gemeinsame Speicherbereiche oder Zwischenablagen deaktivieren, sofern diese nicht zwingend benötigt werden, und (3) die Nutzung von Schnittstellen wie USB-Passthrough oder Drag-and-Drop bewusst unterbinden oder nur für klar definierte Administrations-VMs freigeben. Darüber hinaus kann es sinnvoll sein, die Konfiguration regelmäßig mit Härungsleitfäden abzugleichen. Ein pragmatischer Tipp ist es, beim Aufsetzen neuer VMs die Standardkonfigurationen bewusst restriktiv zu wählen und nur jene Austauschfunktionen schrittweise zu

aktivieren, die für den Geschäftsbetrieb wirklich erforderlich sind.

Control: KONF.7.1 - Echtzeitscanner

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.7 Schutz vor Schadcode
UUID: 7356791e-0f8c-4f3a-82f9-37f55a2d66b2
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE eine automatische Prüfung auf Schadcode bei Installation oder Öffnung von Dateien aktivieren.

Guidance

Schadcode kann sich sowohl auf lokalen Speichermedien, als auch auf Netzlaufwerken oder Wechseldatenträgern befinden. Für Netzlaufwerke kann die Anforderung auch umgesetzt werden, indem Dateien bei der Speicherung auf dem zentralen System auf Schadcode geprüft werden. Die Anwendung zur Schadcodeprüfung kann z.B. auch als EDR, XDR oder IDS bezeichnet werden. Moderne Systeme zur Erkennung von Schadcode verwenden eine Kombination aus Virensignaturen, Heuristiken, als auch Anomalieerkennung. Falls das System die Installation von Anwendungen nicht unterstützt, so ist dieser Teilschritt entbehrlich.

Links

related: DET.4.2 Automatische Angriffserkennung

Control: KONF.7.2 - Regelmäßige Scans

Tags: "Produktbeschreibung" "Lateral Movement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.7 Schutz vor Schadcode
UUID: 3fefd9d3-8925-4c08-b2b3-c92775b0279a
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE einen regelmäßigen Scan von Dateien auf dem System nach potenziellem Schadcode aktivieren.

Guidance

Schadcode kann sich sowohl auf lokalen Speichermedien, als auch auf Netzlaufwerken oder Wechseldatenträgern befinden. Für Netzlaufwerke kann die Anforderung auch umgesetzt werden, indem Dateien bei der Speicherung auf dem zentralen System auf Schadcode geprüft werden. Die Anwendung zur Schadcodeprüfung kann z.B. auch als EDR, XDR oder IDS bezeichnet werden. Moderne Systeme zur Erkennung von Schadcode verwenden eine Kombination aus Virensignaturen, Heuristiken, als auch Anomalieerkennung. Falls das System die Installation von Anwendungen nicht unterstützt, so ist dieser Teilschritt entbehrlich.

Links

related: DET.4.2 Automatische Angriffserkennung

Control: KONF.7.3 - Host-basierte Angriffserkennung

Tags: "Produktbeschreibung" "Lateral Movement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.7 Schutz vor Schadcode
UUID: c6ea1218-1fc7-472f-96e5-df42b2acafa9
Aufwand: 3
Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN Host-basierte Angriffserkennung aktivieren.

Guidance

Host-basierte Angriffserkennung, im Englischen auch als Host-based Intrusion Detection (HID) oder Host-based Intrusion Prevention (HIP) bezeichnet, bezieht sich auf Mechanismen, die auf den einzelnen IT-Systemen, wie Servern oder Workstations, selbst operieren, um böswillige Aktivitäten zu erkennen und zu verhindern. Im Gegensatz zu netzwerkbasierenden Systemen, die den Datenverkehr überwachen, fokussiert sich die Host-basierte Erkennung auf interne Systemereignisse, wie die Integrität von Dateisystemen, Änderungen an kritischen Konfigurationsdateien, oder die Erkennung von unbekannten Prozessen. Der Hauptzweck dieser Anforderung besteht darin, eine zusätzliche Sicherheitsebene zu schaffen, die direkt am Endpunkt (Host) agiert, was die Erkennung von Angriffen ermöglicht, die bereits die äußeren Schutzmechanismen überwunden haben könnten, beispielsweise wenn ein Angreifer eine bekannte Schwachstelle ausnutzt, um einen Prozess mit erhöhten Rechten auszuführen. Diese Maßnahmen können dabei helfen, interne Lateralbewegungen eines Angreifers zu erkennen und somit die Ausbreitung eines Vorfalls zu verlangsamen oder zu stoppen, bevor es zu einem größeren Schaden kommt.

Links

related: DET.4.2 Automatische Angriffserkennung

Control: KONF.7.4 - Angriffserkennung anhand von Netzverkehr

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.7 Schutz vor Schadcode

UUID: e6dd6f93-4901-41bd-86ed-ba88ff5c5bf3

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN Angriffserkennung anhand von Netzverkehr aktivieren.

Guidance

Hierbei wird eine netzwerkbasierte Bedrohungsanalyse direkt auf dem IT-System durchgeführt. Dieser Ansatz, oft als Host-based Network Intrusion Detection System (H-NIDS) oder Endpoint Detection and Response (EDR) bezeichnet, ermöglicht eine tiefere Sicht in das Systemverhalten. Statt nur den Datenstrom am Perimeter zu überwachen, kann so die Institution verdächtige Aktivitäten wie das Scannen von Netzwerk-Ports, den Aufbau ungewöhnlicher Verbindungen zu Command-and-Control-Servern oder den Versuch der Datenexfiltration erkennen. Ohne diese Erkennung könnte sich ein Angreifer, der bereits in das Netzwerk eingedrungen ist, unentdeckt von System zu System bewegen oder sensible Daten unbemerkt nach außen senden. Die dezentrale Erkennung auf den Clients kann zudem dabei helfen, interne Lateral-Movement-Versuche zu identifizieren, da der Datenverkehr zwischen den Systemen überwacht wird, selbst wenn er das interne Netzwerk nicht verlässt. Um diese Anforderung umzusetzen, kann die Institution spezialisierte EDR- oder Endpoint-Security-Lösungen nutzen, die eine integrierte Funktion zur Netzwerküberwachung bieten. Es kann ebenfalls eine regelbasierte Erkennung über lokale Host-Firewalls oder Sicherheitsagenten aktiviert werden, die bestimmte Muster im Netzwerkverkehr blockieren oder protokollieren. Bei der Einführung solcher Maßnahmen ist es entscheidend, die Performance des Clients zu berücksichtigen. Daher kann die Konfiguration so optimiert werden, dass sie nur kritische Protokolle oder Ports überwacht, um die Systemressourcen zu schonen.

Links

related: DET.4.2 Automatische Angriffserkennung

Control: KONF.7.5 - Alarmierung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.7 Schutz vor Schadcode
UUID: a0afaca3-947c-4b5b-8bc0-c29f623075e0
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE eine Benachrichtigung bei potenziellem Schadcode aktivieren.

Guidance

Durch die Aktivierung einer Benachrichtigung kann eine Institution schnell auf verdächtige Aktivitäten reagieren, noch bevor sich der Schadcode vollständig im System etablieren und erheblichen Schaden anrichten könnte. Eine Möglichkeit zur Umsetzung ist der Einsatz von Endpoint Detection and Response (EDR)-Lösungen, die in der Lage sind, Verhaltensanomalien in Echtzeit zu erkennen und sofortige Benachrichtigungen auszulösen. Eine effektive Umsetzung erfordert, dass die Benachrichtigungen sowohl an die Endnutzer als auch an die zuständigen IT-Sicherheitsteams gesendet werden, um eine umfassende und koordinierte Reaktion zu ermöglichen. Dabei können Automatisierungsregeln im Security Information and Event Management (SIEM) die Benachrichtigungen an die richtigen Personen eskalieren und so die Reaktionszeit verkürzen.

Links

related: DET.4.2 Automatische Angriffserkennung

Control: KONF.7.6 - Automatische Updates

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.7 Schutz vor Schadcode
UUID: 9ec7a448-9f0e-45bb-b71d-537fe2ef7f0c
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE Automatische Updates der Mechanismen zur Schadcodeerkennung aktivieren.

Guidance

Da Schadprogramme und Angriffsmethoden ständig abgeändert werden um bekannte Erkennungsmuster zu umgehen, sind aktuelle Erkennungsfunktionen entscheidend um laufende Angriffe erkennen zu können, z.B. Signatur-Update oder Aktualisierungen der Lernfunktion zur Anomalieerkennung. Dies kann durch automatische Aktualisierungen der Signaturen und Mechanismen zur Angriffserkennung umgesetzt werden, z.B. als tagesaktueller Download von Viren-Signaturen. Die Anforderung kann auch durch einen schrittweisen Rollout der Erkennungsfunktionen umgesetzt werden, um einen Test in der Institution zu ermöglichen.

Control: KONF.7.7 - Regelmäßiger Funktionstest

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.7 Schutz vor Schadcode
UUID: 3cc8cb7f-eeb1-4d12-a87b-3081587e4b93
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN die Funktionsfähigkeit des Schadcodeschutzes `{{ insert: param, konf.7.7-prm1 }}` überprüfen.

Guidance

Die Funktionsfähigkeit des Schadcodeschutzes beschreibt den operativen Zustand der eingesetzten Schutzmechanismen (engl. Malware Protection, oft auch Antivirus oder Endpoint Detection and Response, kurz EDR), der über die reine Installation der Software hinausgeht. Sie umfasst die korrekte Ausführung der Schutzdienste, die Aktualität der Erkennungssignaturen und Verhaltensregeln sowie die Fähigkeit, auf Bedrohungen aktiv zu reagieren und diese zu protokollieren. Eine regelmäßige Überprüfung dieser Funktionsfähigkeit kann die Institution vor unbemerkten Sicherheitslücken schützen. Ein deaktivierter oder fehlerhafter Schutzmechanismus könnte beispielsweise dazu führen, dass Ransomware unbemerkt Daten verschlüsselt oder ein Trojaner Anmeldeinformationen abgreift, obwohl eine Schutzsoftware installiert ist. Durch die proaktive Verifikation kann hingegen sichergestellt werden, dass diese wesentliche Verteidigungslinie durchgehend intakt ist und auf Angriffsversuche reagieren kann. Zur konkreten Umsetzung kann die Institution auf verschiedene, sich ergänzende Maßnahmen zurückgreifen. Eine zentrale Verwaltungskonsole der eingesetzten Schutzlösung kann genutzt werden, um den Status aller angebundenen Systeme automatisiert zu überwachen und Alarmer auszulösen, wenn Systeme sich nicht mehr melden, veraltete Signaturen aufweisen oder Dienste beendet wurden. Ergänzend kann die tatsächliche Erkennungsleistung proaktiv durch den Einsatz einer standardisierten Testdatei wie dem EICAR-Teststring verifiziert werden; dieser kann automatisiert auf den Systemen platziert werden, um zu prüfen, ob der Schadcodeschutz wie erwartet anschlägt und eine Meldung generiert. Auf Systemen ohne zentrale Anbindung kann die Funktionsfähigkeit mittels Skripten überprüft werden,

die lokal den Dienststatus und das Alter der Signaturdateien auslesen und in einer überwachten Logdatei dokumentieren.

Links

related: DET.4.3 Überwachung der Angriffserkennung

Control: KONF.7.8 - Dual-Engine-Strategie

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.7 Schutz vor Schadcode

UUID: a86b7cf5-33c8-40b5-81cd-db942cc27b74

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN für die Erkennung von Schadcode unterschiedliche Scan-Engines aktivieren.

Guidance

Hiermit ist gemeint, dass die Angriffserkennung mittels (zwei oder mehr) verschiedenen Scan-Engines durchgeführt wird, um die Erkennungswahrscheinlichkeit zu erhöhen. Hierdurch kann es zu Performanceeinbußen oder einer höheren Fehlerkennungsquote kommen.

Control: KONF.7.9 - Einschränkung der Installation

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.7 Schutz vor Schadcode

UUID: 6bb8fed8-6745-4b58-81cb-ddff66da28d9

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE die Installation von Anwendungen einschränken.

Guidance

Es empfiehlt sich z.B. die zu installierende Software nicht unkontrolliert in das Wurzeldateisystem des Betriebssystems zu installieren. Wenn die zu installierende Software aus dem Quellcode kompiliert werden soll, dann empfiehlt es sich diese nur unter einem unprivilegierten Konto zu entpacken, zu konfigurieren und zu übersetzen.

Control: KONF.7.10 - Einschränkung der Ausführung

Tags: "Produktbeschreibung" "Living off the land"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.7 Schutz vor Schadcode
UUID: 02df7412-74de-45a2-abfd-aa8cf94ff93d
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE die Ausführung nicht autorisierter Anwendungen einschränken.

Guidance

Wenn Anwendungen an beliebigen Speicherorten installiert und ausgeführt werden, z.B. im Wurzeldateisystem des Betriebssystems oder an Speicherorten zusammen mit Daten der Nutzerumgebung, dann könnte dies zahlreiche Sicherheitsrisiken mit sich bringen. Unbefugte oder schadhafte Anwendungen könnten unbemerkt an unautorisierte Orte platziert werden, wo sie außerhalb etablierter Sicherheitskontrollen agieren und beispielsweise Privilege-Escalation-Angriffe durchführen können. Zudem wird das Risiko der Manipulation von Anwendungsdateien erhöht, da Angreifer gezielt nach nicht-geschützten Speicherorten suchen, um dort eigenen Code zu hinterlegen oder legitime Anwendungen zu modifizieren. Eine solche Situation kann zu "Living-off-the-Land"-Angriffen führen, bei denen Angreifer vorhandene legitime Programme missbrauchen, um Schadaktionen auszuführen, was die Erkennung erheblich erschwert. Die Beschränkung von Ausführungsspeicherorten (Execution Control) zielt darauf ab, die Angriffsfläche zu reduzieren und eine bessere Kontrolle über ausführbare Programme zu ermöglichen. Zur technischen Umsetzung dieser Anforderung kann eine Institution verschiedene Maßnahmen implementieren. Application Allowlisting kann eingesetzt werden, um nur vertrauenswürdige Anwendungen aus definierten Verzeichnissen auszuführen, beispielsweise mittels AppLocker unter Windows oder SELinux unter Linux-Systemen. Zusätzlich können Software Restriction Policies (SRPs) konfiguriert werden, um Ausführungsrechte auf bestimmte Verzeichnispfade zu begrenzen, wobei eine Trennung zwischen Systemverzeichnissen und Nutzerverzeichnissen empfehlenswert ist. Weitere wirksame Techniken umfassen die Implementierung von Code Signing, wodurch nur digital signierte Anwendungen

ausgeführt werden können, sowie die Nutzung von Container-Technologien wie Docker, die eine isolierte Ausführungsumgebung bieten. Dabei kann auf das Inventar der Anwendungen als Grundlage zurückgegriffen werden.

Control: KONF.7.11 - Einschränkung von Softwarebibliotheken

Tags: "Produktbeschreibung" "Lieferketten"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.7 Schutz vor Schadcode

UUID: 8de44b0e-0241-4519-9dc3-e941800b4168

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN die Ausführung nicht autorisierter Softwarebibliotheken einschränken.

Guidance

Softwarebibliotheken sind wiederverwendbare Codesammlungen, die Entwicklern fertige Funktionalitäten bieten, ohne diese selbst programmieren zu müssen. Unautorisierte Bibliotheken stellen Sicherheitsrisiken dar, weil sie absichtlich eingeschleusten Schadcode enthalten könnten, der Daten ausspioniert oder Systeme kompromittiert. Sie durchlaufen seltener reguläre Sicherheitsüberprüfungen und könnten für Supply-Chain-Angriffe genutzt werden, bei denen harmlos erscheinender Code mit versteckten Schadfunktionen in Paketmanager eingeschleust wird. Zudem erhalten unautorisierte Bibliotheken häufig keine regelmäßigen Sicherheitsupdates, sodass bekannte Schwachstellen unbehoben bleiben. Mangelnde Dokumentation und unklare Abhängigkeiten von anderen ungeprüften Quellen erhöhen das Risiko zusätzlich. Beispiele sind Dateien der Typen .dll, .ocx, und .so. Die Umsetzung kann durch Sicherheitsfunktionen erfolgen, die nur das Laden autorisierter Bibliotheken in Systemprozessen erlaubt. Verfügt das IT-System über keine Möglichkeit zur Installation von Anwendungen, so ist die Anforderung entbehrlich.

Control: KONF.7.12 - Einschränkung von Skripten

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.7 Schutz vor Schadcode
UUID: f835dc6a-5af1-424d-994a-219141d268d7
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN die Ausführung nicht autorisierter Skripte einschränken.

Guidance

Skripte könnten Schadcode enthalten oder zu Fehlerzuständen auf dem System führen. Die Auswirkungen schädlicher Skripte können eingeschränkt werden, indem nur bestimmte Systemfunktionen für Skripte erlaubt werden. Die Umsetzung ist mit Funktionen wie dem Windows PowerShell Constrained Language Mode oder Linux Secure Computing Mode möglich. Verfügt das System über keine Möglichkeit zur Ausführung von Skripten, so ist die Anforderung entbehrlich.

Control: KONF.7.13 - Einschränkung von Systemaufrufen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.7 Schutz vor Schadcode
UUID: 0d1bb274-a8e2-4fdb-a94e-25dd0565fab1
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN Systemaufrufe pro Anwendung einschränken.

Guidance

Ein Systemaufruf (engl. system call) ist dabei die Methode, mit der eine Anwendung Zugriff auf die Ressourcen des Betriebssystems anfordert, z.B. um eine Datei zu öffnen, in das Netzwerk zu kommunizieren oder einen neuen Prozess zu starten. Diese feingranulare Einschränkung wird in der Branche auch als Capability-based Security oder Seccomp (Secure Computing Mode) bezeichnet. Der Zweck dieser Vorschrift ist die gezielte Reduzierung der Angriffsfläche, indem selbst eine vertrauenswürdige, aber kompromittierte Anwendung daran gehindert wird, schädliche Aktionen auszuführen. Ein Angreifer könnte beispielsweise die Prozess-ID (PID) einer Anwendung kapern und versuchen, über deren Kontext privilegierte Systemaufrufe durchzuführen, um sich im Netzwerk auszubreiten oder sensible Daten zu löschen. Die Einschränkung dieser Aufrufe kann die Folgen eines erfolgreichen Angriffs erheblich mildern und so die Ausbreitung von Malware oder die Manipulation von Systemprozessen verhindern.

Control: KONF.7.14 - Code-Signierung im Betriebssystemkern

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.7 Schutz vor Schadcode

UUID: 276b2d5d-5317-4cc6-b106-c65c764da6f6

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE Code-Signierung im Betriebssystemkern aktivieren.

Guidance

Laufende Kernprozesse des Systems können geschützt werden, indem nur signierter Code hierauf zugreifen darf. Beispiele sind unter Windows der der PPL-Schutz (Protected Process Light) des Local Credential Store (LSA-Schutz) oder unter Linux mit SELinux oder dem Secure Computing Mode.

Control: KONF.7.15 - Lokale Firewall

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.7 Schutz vor Schadcode
UUID: 73cfb678-122c-4bca-a8b0-70673e70d285
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE ein- und ausgehende Netzverbindungen einschränken.

Guidance

Eine lokale Firewall ist eine Anwendung, welche nur die zum Betrieb und zur Wartung des IT-Systems notwendigen ein- und ausgehenden Verbindungen zulässt. Bringt das Betriebssystem diese Funktionalität bereits vom Werkszustand her mit, so ist die Anforderung ebenfalls erfüllt, wenn sie entsprechend konfiguriert ist. Zweckmäßig ist hierbei ein Allowlist-Ansatz, der die gewünschte Verbindung möglichst genau beschreibt (z.B. anhand Server-IP und Port).

Control: KONF.7.16 - Anti-Exploit

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.7 Schutz vor Schadcode
UUID: 6056a588-6f3c-402e-a0ac-f1f169030659
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher

Statement

Konfiguration für IT-Systeme SOLLTE Systemfunktionen zum Schutz des Systems vor der Ausnutzung bekannter Sicherheitslücken aktivieren.

Guidance

Angreifer versuchen häufig, bekannte Sicherheitslücken oder offene Systemfunktionen zur Verbreitung oder Einnistung von Schadcode zu missbrauchen. Funktionen zum Schutz vor der Ausnutzung von Sicherheitslücken (Anti-Exploit) können helfen dies zu verhindern. Beispiele sind Data Execution Prevention (DEP), Defender Exploit Guard (WDEG) oder System Integrity Protection (SIP).

Control: KONF.7.16.1 - Anti-Exploit für den Arbeitsspeicher

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.7 Schutz vor Schadcode
Übergeordnetes Control:
KONF.7.16 Anti-Exploit
UUID: 1ce9e25d-e51a-453a-8383-ecdbac044b7a
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE den Schutz des Arbeitsspeichers vor der Ausnutzung bekannter Sicherheitslücken aktivieren.

Guidance

Gelingt es Angreifern Code auf dem System auszuführen, so könnten sie versuchen, über den Arbeitsspeicher des Systems den Schadcode weiter zu verbreiten oder Zugriff auf Daten zu erlangen. Hierzu gehören Angriffe wie Buffer Overflows, Return-Oriented Programming, Heap Spraying, Use-After-Free, Memory Scraping oder Side-Channel-Angriffe wie Spectre und Meltdown. Schutzmaßnahmen hiergegen können durch Software oder durch Hardware umgesetzt sein. Softwarebasiert sind z.B. Address Space Layout Randomization (ASLR), Data Execution Prevention (DEP), Stack Canaries. Hardwarebasiert sind z.B. Trusted Execution Environments (TEE).

Control: KONF.8.1 - Automatische Überprüfung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.8 Sicherheitsupdates
UUID: b26ab0d5-9daf-41e8-9b93-b8cfc58a2c4c
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.8.1.1 Automatische Sicherheitsupdates

Statement

Konfiguration für IT-Systeme SOLLTE das Vorliegen von Sicherheitsupdates überwachen.

Guidance

Eine Überwachung von Sicherheitsupdates bedeutet, dass die IT-Systeme selbstständig nach neuen Aktualisierungen suchen, die Schwachstellen in der Software beheben. Technisch können Systeme so konfiguriert werden, dass sie über zentrale Update-Server regelmäßig auf neue Patches prüfen. Es ist ratsam, einen automatisierten Prozess einzurichten, der bei Vorliegen von Updates diese automatisiert ausrollt oder eine Meldung an die zuständigen IT-Administratoren und ggf. die betroffenen Nutzer sendet. Diese Benachrichtigung kann über E-Mail, ein internes Ticket-system oder ein Dashboard erfolgen. Ein guter Tipp ist die priorisierte Behandlung von Updates, bei der kritische Sicherheits-Patches vor Routine-Updates installiert werden.

Control: KONF.8.1.1 - Automatische Sicherheitsupdates

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.8 Sicherheitsupdates
Übergeordnetes Control:
KONF.8.1 Automatische Überprüfung
UUID: 9a9b1174-5e40-49a5-8c4b-599c394a8de7
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE Sicherheitsupdates automatisch installieren.

Guidance

Dies kann durch direkten Download vom Hersteller oder einen eigenen Verteilerserver umgesetzt werden, so lange dieser ebenfalls automatisch aktuell gehalten wird. Damit Sicherheitsupdates des Betriebssystems auch tatsächlich wirken und Fehlerzustände vermieden werden ist typischerweise ein Neustart erforderlich, damit die Betriebssystemfunktionen und damit verbundene Anwendungen aus dem installierten Update neu geladen und in einen definierten Zustand versetzt werden. Manche Systeme unterstützen alternativ auch Live-Patching des Betriebssystems im laufenden Betrieb.

Control: KONF.8.2 - Automatische Updates der Anwendung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.8 Sicherheitsupdates

UUID: 5a8998f1-d49f-45aa-8b08-7eafd9b17415

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Anwendungen SOLLTE die automatische Installation von Sicherheitsupdates aktivieren.

Guidance

Dies kann durch direkten Download vom Hersteller oder einen eigenen Verteilerserver umgesetzt werden, so lange dieser aktuell gehalten wird.

Control: KONF.9.1 - Speicherplatzbegrenzung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.9 Verfügbarkeit von Ressourcen

UUID: d837fc6f-c113-445d-b8e5-021317d2ca90

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Konfiguration für IT-Systeme SOLLTE den Speicherplatz für die Nutzerumgebung einschränken.

Guidance

Nutzerumgebung meint hier alle Anwendungen und Dienste, die auf dem System betrieben werden, aber keine Systemdienste sind. Alternativ empfiehlt es sich Mechanismen des verwendeten Datei- oder Betriebssystems zu nutzen, die Benutzende bei einem bestimmten Füllstand der Festplatte warnen oder nur noch Administrierenden Schreibrechte einräumen.

Control: KONF.9.2 - Begrenzung der Rechenleistung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.9 Verfügbarkeit von Ressourcen
UUID: 3b0eb166-07b9-4b51-a1f5-75513b28015c
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Hostsysteme KANN die zur Verfügung stehende Rechenleistung anhand von {{ insert: param, konf.9.2-prm1 }} einschränken.

Guidance

Dies kann durch eine Beschränkung der Anzahl verwendeter Rechenkerne, der Rechenleistung pro Rechenkern oder durch eine indirekte Beschränkung (z.B. eine begrenzte Menge an Anfragen oder Eingabetoken in Anwendungen) umgesetzt werden.

Control: KONF.9.3 - Alternative Komponenten für kritische Funktionen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.9 Verfügbarkeit von Ressourcen

UUID: bd64ca41-01df-48ba-85ea-3241017cf750

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für IT-Systeme KANN alternative Komponenten für {{ insert: param, konf.9.3-prm1 }} installieren.

Guidance

Beispiele sind redundante Stromnetzteile, Ethernet-Anschlüsse oder eine Mobilfunkanbindung als Ausfallsicherheit für die kabelgebundene Netzanbindung.

Control: KONF.10.1 - Grundkonfiguration für Anwendungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.10 Konfiguration von Anwendungen
UUID: 23571325-0e60-4d28-96e1-ed57f794f790
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.10.1.1 Versionierung der Anwendungskonfiguration

Statement

Konfiguration für Anwendungen SOLLTE eine Grundkonfiguration dokumentieren.

Guidance

Eine Grundkonfiguration (engl. baseline configuration) bezeichnet in diesem Kontext einen dokumentierten Ausgangszustand einer Anwendung, der sowohl funktionale Anforderungen als auch sicherheitsrelevante Einstellungen berücksichtigt. Sie umfasst unter anderem Parameter wie Benutzerrechte, Logging-Einstellungen, Schnittstellenaktivierungen oder Verschlüsselungsoptionen und bildet damit die Referenz, auf die spätere Anpassungen zurückgeführt oder überprüft werden können. Fehlt eine nachvollziehbare Grundkonfiguration, könnte es bei Updates, Migrationen oder im Incident-Fall zu schwer erkennbaren Abweichungen kommen, die unerwünschte Sicherheitslücken hinterlassen. Eine klare Dokumentation kann dagegen die Nachvollziehbarkeit erhöhen, unerwünschte Änderungen sichtbar machen und den sicheren Betrieb der Anwendung unterstützen. Zur praktischen Umsetzung kann die Institution eine dokumentierte Konfigurationsvorlage entwickeln, die sowohl Herstellerempfehlungen als auch anerkannte Empfehlungen des BSI oder aus Benchmarks wie die des Center for Internet Security (CIS) berücksichtigt. Die Sicherheit von Anwendungen ist in besonderem Maße kontextbezogen: So könnten z.B. über E-Mail oder Messenger hoch vertrauliche Daten ausgetauscht werden oder auch öffentliche Informationen. Daher ist hier eine Vertiefung der Risikoanalyse empfehlenswert, die sich an der Verwendung der Anwendungen in Geschäftsprozessen orientiert. Dabei besteht ein enger Bezug zu Compliance-Anforderungen, zum Beispiel an finanzi-

elle Transaktionen oder den Datenschutz, je nachdem welche Datenverarbeitungen mit der Anwendung vorgenommen werden.

Control: KONF.10.1.1 - Versionierung der Anwendungskonfiguration

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.10 Konfiguration von Anwendungen
Übergeordnetes Control:
KONF.10.1 Grundkonfiguration für Anwendungen
UUID: cb46badf-b942-4007-ab50-e941711b3c58
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Anwendungen SOLLTE eine Versionierung vorheriger Konfigurationen verankern.

Guidance

Die Versionierung bezeichnet hier die strukturierte Nachvollziehbarkeit von Änderungen an Konfigurationen, also das Speichern, Dokumentieren und bei Bedarf Wiederherstellen älterer Zustände einer Anwendung. Sie unterscheidet sich von einem einfachen Backup dadurch, dass nicht nur eine Kopie vorliegt, sondern explizit eine fortlaufende Historie mit Vergleichen, Rücksetzpunkten (rollback points) und optional Kommentaren geführt wird. Der Zweck liegt darin, dass eine ungewollte oder fehlerhafte Anpassung an einer Anwendungskonfiguration im Betrieb schnell erkannt und – wenn erforderlich – präzise auf einen definierten, funktionsfähigen Zustand zurückgesetzt werden kann. Ohne diese Rückgriffsmöglichkeit könnte ein Konfigurationsfehler den gesamten Dienst außer Betrieb setzen, während eine Versionierung die Verfügbarkeit und Nachvollziehbarkeit stärken kann. Zur Umsetzung kann eine Institution technische Verfahren einsetzen, die eine automatische Ablage und Historisierung von Konfigurationsdateien unterstützen, beispielsweise durch (1) den Einsatz verteilter Versionskontrollsysteme wie Git oder Subversion (SVN) für textbasierte Konfigurationsdateien, (2) integrierte Konfigurationsarchivierung in gängigen Deployment- oder Container-Tools, oder (3) systemseitige Snapshot-Mechanismen, die gezielt für Konfigurationsverzeichnisse genutzt werden.

Control: KONF.10.2 - Kryptographische Verfahren in Anwendungen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.10 Konfiguration von Anwendungen
UUID: 94aac721-fbe3-44d0-a0ce-55ebded001ab
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Anwendungen SOLLTE kryptographische Verfahren nach {{ insert: param, konf.10.2-prm1 }} im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement aktivieren.

Guidance

Kryptographie wird für die Authentifizierung, Verschlüsselung und Integritätsprüfung in Anwendungen verwendet, z.B. bei der Anmeldung an der Anwendung oder digitalen Signierung von Nachrichten. Die Formulierung "im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement" bedeutet, dass die Authentifizierung so erfolgt, wie in der Praktik Berechtigung (BER) festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Schlüsselmanagement zu finden ist. Anerkannte kryptographische Verfahren sind in der BSI TR-02102 zu finden.

Links

related: BER.1.1 Verfahren und Regelungen

related: KONF.14.1 Verschlüsselung beim Transport

Control: KONF.10.3 - Änderung von Default-Zugangsdaten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.10 Konfiguration von Anwendungen
UUID: f154f8a8-8abb-4c9c-a3d8-f2d20d6fd339
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Anwendungen SOLLTE die Änderung von Default-Zugangsdaten ausführen.

Guidance

Hiermit sind Default-Passwörter, als auch vertrauenswürdige Authentisierungs-Schlüssel oder Zertifikate fallen, die per Default zur Anmeldung akzeptiert werden, gemeint.

Control: KONF.10.4 - Deaktivierung nicht benötigter Anwendungsfunktionen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.10 Konfiguration von Anwendungen
UUID: 990f4798-6926-41be-b09d-ee0162c530a0
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Anwendungen SOLLTE nicht benötigte Anwendungsfunktionen deaktivieren.

Guidance

Funktionen die für den Betrieb nicht benötigt werden stellen ein unnötiges Sicherheitsrisiko dar, da sie von Angreifern ausgenutzt werden oder durch Wechselwirkungen zu unvorhergesehenen Fehlern führen könnten. Hierzu gehören z.B. ungenutzte Cloud-Anbindungen, Module, Leistungsmerkmale oder Einstellungen. Installationspakete enthalten häufig eine Vielzahl von ausführbaren Dateien und Erweiterungen. Für den Betrieb nicht benötigte Anwendungskomponenten können Schwachstellen enthalten und sind ein unnötiges Sicherheitsrisiko.

Control: KONF.10.5 - Überprüfung der Konfiguration

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.10 Konfiguration von Anwendungen
UUID: 7f01dfb0-75b6-4248-a852-16ebca5f1c45
Aufwand: 4
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration

Statement

Konfiguration für Anwendungen SOLLTE die Übereinstimmung der tatsächlichen Konfiguration mit dem Referenzzustand `{{ insert: param, konf.10.5-prm1 }}` überprüfen.

Guidance

Referenzzustand („baseline configuration“) bezeichnet hier die dokumentierte und freigegebene Konfiguration der Anwendung, also die gewünschte und autorisierte Einstellung von Parametern, Diensten und Komponenten. Die tatsächliche Konfiguration ist die aktuelle technische Umsetzung dieser Einstellungen der Anwendung selbst. Der Abgleich beider Zustände dient vor allem der Vermeidung von Configuration Drift – d.h. dass Anwendungen schleichend von der definierten Grundkonfiguration abweichen. Dies könnte auftreten, wenn Änderungen nicht zentral dokumentiert oder automatisierte Installationen nicht einheitlich umgesetzt werden. Ohne diese Kontrolle könnte es zu unbemerkten Fehlkonfigurationen kommen, die Sicherheitslücken öffnen oder Betriebsstörungen verursachen. Durch regelmäßige Vergleiche kann eine Institution sicherstellen, dass Anwendungen konsistent, vertrauenswürdig und wartbar bleiben. Die Umsetzung kann technisch etwa mit Skripten erfolgen, die automatisiert Konfigurationsparameter auslesen und vergleichen. Auch der Einsatz von „Configuration Management“- oder „Compliance Scanning“-Werkzeugen kann unterstützen, indem sie Differenzen visualisieren und Reports erzeugen. Prozessual kann es hilfreich sein, Prüfintervalle nach Kritikalitätsklassen zu staffeln (z. B. sicherheitskritische Anwendungen wöchentlich, weniger kritische vierteljährlich) und Ergebnisse in Change-Management-Prozesse zurückzuführen.

Control: KONF.10.5.1 - Automatisierte Überprüfung der Konfiguration

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.10 Konfiguration von Anwendungen
Übergeordnetes Control:
KONF.10.5 Überprüfung der Konfiguration
UUID: 9e53c0f8-53e0-439b-a4ce-ee321f55ac52
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Anwendungen KANN die Überprüfung der Konfiguration durch
{ { insert: param, konf.10.5.1-prm1 } } aktivieren.

Guidance

Die automatische Auditierung der Systemkonfiguration ermöglicht eine kontinuierliche und effiziente Überprüfung, ob IT-Systeme sicher und regelkonform konfiguriert sind. Dabei wird die aktuelle Konfiguration automatisiert mit vordefinierten Soll-Vorgaben (etwa unternehmensinternen Richtlinien oder externen Benchmarks wie denen des Center for Internet Security (CIS)) abgeglichen. Dies ist besonders sinnvoll, da manuelle Prüfungen fehleranfällig, zeitaufwändig und in großen Infrastrukturen kaum durchführbar sind. Automatisierte Audits erhöhen die Transparenz, erkennen Abweichungen frühzeitig und erleichtern die Einhaltung von Compliance-Vorgaben. So wird die Angriffsfläche durch fehlerhafte oder unsichere Einstellungen erheblich reduziert.

Control: KONF.11.1 - Authentifizierung vor dem Zugriff

Tags: "Produktbeschreibung" "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.11 Vertrauensbeziehungen
UUID: 6bcd486c-909c-424c-9f78-35ed96588a5c
Aufwand: 1
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig

Statement

Konfiguration für Anwendungen SOLLTE Zugriffe auf schützenswerte Daten im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement authentifizieren.

Guidance

Ziel ist es, vertrauliche Daten vor dem Zugriff von Unbefugten zu schützen. Relevant sind hierbei sowohl Frontend-Zugänge wie Webportale, als auch Backend-Datenschnittstellen wie Datenbank-API. Dies kann durch eine anwendungsspezifische Authentifizierung, oder durch Nutzung eines zentralen Identity Providers (Single-Sign-On) erfüllt werden. Für die Authentifizierung kommen z.B. Passwörter, X.509-Zertifikate, OTP-Token in Frage. Zweckmäßig ist hierfür der Einsatz von Standardkomponenten wie OAuth 2.0 und die Verbindung mit einem zentralen Berechtigungsmanagement der Anwendung. Im Einklang mit den Anforderungen des Identitäts- und Berechtigungsmanagements bedeutet, dass für die Anwendung die Anforderungen aus der Praktik Identitäts- und Berechtigungsmanagement erfüllt sind, die dort festgelegt wurden. Hierzu gehört die Art der Authentifizierung (z.B. Passwort, Biometrie, Mehr-Faktor-Authentifizierung) ebenso wie die relevanten Parameter (Passwortkomplexität, etc.). Auf Daten die nicht vertraulich (z.B. öffentlich) sind kann auch ohne Authentifizierung Zugriff erlaubt sein. Die Formulierung "im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement" bedeutet, dass die Authentifizierung so erfolgt, wie in

der Praktik Berechtigung (BER) festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist. Verarbeitet die Anwendung gar keine vertraulichen Daten, dann ist die Anforderung entbehrlich.

Links

related: BER.1.1 Verfahren und Regelungen

Control: KONF.11.1.1 - Authentifizierung von geplanten Konversationen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.11 Vertrauensbeziehungen

Übergeordnetes Control:

KONF.11.1 Authentifizierung vor dem Zugriff

UUID: 07493cf7-5071-4749-b58a-586016679f1e

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Konfiguration für TK-Anwendungen SOLLTE den Zugriff auf geplante Konversationen im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement authentifizieren.

Guidance

Viele TK-Anwendungen bieten geplante Konversationen, z.B. in virtuellen Meeting-Räumen oder über Telefonkonferenzen, die über eine Rufnummer erreichbar sind. Wird der Zugriff hierauf nicht authentifiziert, so könnten unbemerkt Unberechtigte teilnehmen und Informationen abhören oder auf Meta-Informationen wie Teilnehmer oder Uhrzeiten zugreifen. Der Schutz kann z.B. durch Passwörter/PINs oder über die Anmeldung per Zertifikat oder Single-Sign-On geschehen. Die Formulierung "im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement" bedeutet, dass die Authentifizierung so erfolgt, wie in der Praktik Berechtigung (BER) festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist.

Links

related: BER.1.1 Verfahren und Regelungen

Control: KONF.11.1.2 - Authentifizierung von Netzverbindungen - clientseitig

Tags: "Produktbeschreibung" "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.11 Vertrauensbeziehungen

Übergeordnetes Control:

KONF.11.1 Authentifizierung vor dem Zugriff

UUID: 7bf1392f-5c43-43da-bb36-498b8a678e28

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Anwendungen SOLLTE die Gegenstelle vor dem Datenaustausch im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement authentifizieren.

Guidance

Stellt eine Anwendung Anfragen über das Netz oder nimmt eine Anwendung Anfragen über das Netz entgegen, so gewährleistet eine gegenseitige Authentifizierung der Kommunikationspartner (mutual authentication), dass diese autorisiert ist Anfragen zu stellen oder zu beantworten. Eine gängige Lösung ist die Prüfung von X.509-Zertifikaten beim Verbindungsaufbau mit TLS. Für die Umsetzung ist es nicht unbedingt erforderlich, dass sich die Gegenstelle bei jeder Anfrage/Abruf erneut authentifiziert, wenn bei der Authentifizierung eine sichere Verbindung per TLS aufgebaut wird. Mit Anfragen sind alle Zugriffe gemeint, sei es über eine Web-URL oder eigene API. Die Formulierung "im Einklang mit den zugehörigen Anforderungen zum Identitäts- und Berechtigungsmanagement" bedeutet, dass die Authentifizierung so erfolgt, wie in der Praktik Berechtigung (BER) festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist. Für lesende Zugriffe auf unkritische, öffentliche Daten ist die Authentifizierung der lesenden Anwendung entbehrlich.

Links

related: BER.1.1 Verfahren und Regelungen

Control: KONF.11.2 - Warteraum

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.11 Vertrauensbeziehungen
UUID: 5f29ed91-b7f8-401f-8986-1ea63cf09080
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für VK-Anwendungen SOLLTE einen virtuellen Warteraum aktivieren.

Guidance

Virtuelle Warteräume geben Konferenzmoderatoren die Möglichkeit, Teilnehmer vor Eintritt in einem virtuellen Warteraum persönlich zu authentifizieren.

Control: KONF.11.3 - Alternative Authentifizierung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.11 Vertrauensbeziehungen
UUID: 7d8e0d79-751c-4afe-bbe5-124004f01577
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Anwendungen KANN ein ebenso vertrauenswürdiges, alternatives Verfahren zur Authentifizierung aktivieren.

Guidance

Wenn Nutzende ihren Primärzugang (z.B. Passwort, Smartphone mit Authentifizierungs-App) nicht mehr haben, wird eine alternative Möglichkeit zur Authentifizierung benötigt. Damit dieser Alternativzugang den Schutz der Primärmethode nicht aushebelt, ist eine vergleichbare Zuverlässigkeit der Authentifizierung erforderlich. Lösungsmöglichkeiten je nach Schutzbedarf sind z.B. (1) ein Einmalpasswort, dass an die hinterlegte E-Mailadresse versendet wird, (2) die persönliche Vorstellung mit Ausweis, (3) die Verifikation über bestehende Sitzungen, (4) Rückfallantworten wie Sicherheitsfragen oder PUK.

Control: KONF.11.4 - Veröffentlichung von Domain-Infomationen

Tags: "Produktbeschreibung" "Data Leak" "Recon"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.11 Vertrauensbeziehungen
UUID: 24d7bd4d-9ae9-4871-b6da-4c5186351b46
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für DNS-Server SOLLTE die Veröffentlichung von Domain-Informationen anhand von {{ insert: param, konf.11.4-prm1 }} einschränken.

Guidance

Angreifer nutzen häufig DNS um das Netz zu erkunden (DNS-Reconnaissance). Veröffentlichen Sie Domain-Informationen nur, wenn diese zu einem Dienst gehören, der zur externen Nutzung gedacht ist. Nur intern benötigte DNS-Einträge dagegen bleiben intern. Kriterien können z.B. Domains oder Subdomain sein (intern.domain.com vs www.domain.com).

Control: KONF.11.5 - Erraten von Zugriffslinks

Tags: "Produktbeschreibung" "Brute-Force-Attacke"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.11 Vertrauensbeziehungen
UUID: 951aea5d-e4c2-47c8-9a21-b1d00e3d499f
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webanwendungen SOLLTE das Durchprobieren von Zugriffslinks durch {{ insert: param, konf.11.5-prm1 }} blockieren.

Guidance

Ermöglichen Links den Zugriff auf vertrauliche Daten ohne Authentifizierung, so könnten Angreifer versuchen diese zu finden, z.B. mit Durchprobieren von Meeting-Links oder Ressourcen-URLs. Mögliche Maßnahmen sind Nicht-Sequentielle IDs mit hoher Entropie, Rate Limiting von Anfragen oder CAPTCHA. Hierbei bietet sich eine Kombination von Maßnahmen an, die Anzahl erwarteter Zugriffe, Verfügbarkeits- und Usability-Kriterien ebenso beachtet wie das Risikoprofil der Anwendung. Bietet die Webanwendung keinerlei Zugriff auf schützenswerte Informationen ohne Authentifizierung, so ist die Anforderung entbehrlich.

Control: KONF.11.6 - Einschränkung unauthentifizierter Anschlüsse

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.11 Vertrauensbeziehungen

UUID: 09f3cad1-7245-42f4-a62c-e48ce193ce8a

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Konfiguration für TK-Anwendungen SOLLTE von unauthentifizierten Anschlüssen erreichbare Gegenstellen einschränken.

Guidance

Als unauthentifizierte Anschlüsse (engl. unauthenticated connections) sind hier alle Endpunkte zu verstehen, die eine Kommunikation ohne Anmeldung ermöglichen. Dies umfasst beispielsweise Notfalltelefone in Aufzügen, öffentlich zugängliche Telefone oder auch Faxgeräte in ungesicherten Bereichen. Aber auch an Konferenzraum-Systeme für Videokonferenzen oder den anonymen Gast-Zugang zu Online-Meetings ist zu denken. Die Anforderung zielt darauf ab, den Missbrauch dieser Kommunikationskanäle zu unterbinden, deren Nutzung nicht eindeutig einem authentifizierten Benutzer zugeordnet werden kann. Ohne eine Einschränkung der erreichbaren Gegenstellen – also der kontaktierbaren externen Domänen, Meeting-IDs oder Benutzerkonten – könnte ein Angreifer vertrauliche interne Besprechungen ausspähen oder ein unautorisierte Gast könnte von einem Konferenzraum aus sensible Daten per Bildschirmübertragung an externe Dritte weitergeben. Ohne eine solche Einschränkung könnte ein unberechtigter Nutzer auf Kosten der Institution kostenpflichtige Mehrwertdienste oder teure Auslandsnummern anwählen und so erheblichen finanziellen Schaden verursachen. Ebenso könnte eine missbräuchliche Nutzung zur Belästigung Dritter oder zur Absetzung von böswilligen Notrufen erfolgen, was die Verfügbarkeit kritischer Ressourcen beeinträchtigen könnte.

Control: KONF.11.7 - Übersicht angemeldeter Verbindungen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.11 Vertrauensbeziehungen

UUID: eca3e9a0-b7b5-4e74-9c3e-1108c268246e

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für Anwendungen KANN eine Übersicht angemeldeter Verbindungen aktivieren.

Guidance

Je nach Anwendung können dabei Informationen wie Geräte-Name, Betriebssystemtyp, Browser-Agent oder IP-Adresse angezeigt werden.

Control: KONF.11.8 - Einschränkung von Schnittstellen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.11 Vertrauensbeziehungen
UUID: e9c7f783-cc8f-499c-b556-8748f9420459
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen

Statement

Konfiguration für Anwendungen SOLLTE aktivierte Schnittstellen einschließlich denen zu anderen Anwendungen, Cloud-Funktionen oder Erweiterungen einschränken.

Guidance

Die Einschränkung von Schnittstellen hilft, ungewollte oder böswillige Zugriffe auf Anwendungen und Daten zu verhindern. Durch das Festlegen klarer Regeln welche Systeme oder Anwendungen über welche Schnittstellen auf welche Daten zugreifen können wir das "Need to know" Prinzip in der Kommunikation umgesetzt. Ferner kann ein solcher Ansatz dazu beitragen, die Integrität und Vertraulichkeit von Informationen zu wahren, indem nur autorisierte Kommunikationspartner berechtigt werden, Daten zu lesen, zu schreiben oder Funktionalitäten aufzurufen. Beispiele sind die Synchronisierung von Lesezeichen und Historie im Browser, die Anbindung von Cloud-Funktionen, etwa eine serverless Image-Processing-API, für die ein entsprechendes Rollenkonzept noch nicht hinterlegt und von der Sicherheitsverantwortlichen geprüft wurde, oder die Installation einer Browsererweiterungen. Erweiterungen (Plugins, AddOns), die nicht von der Institution für die Verwendung autorisiert wurden, können zu ungewollten Datenabflüssen führen und Schadcode enthalten. Zur Umsetzung kann es hilfreich sein, standardisierte Formulare oder digitale Workflows zu etablieren, in denen die Notwendigkeit, der Umfang und die Verantwortlichen für jede neue Schnittstelle dokumentiert werden. Die Einschränkung kann auch durch Komponenten außerhalb der Anwendung erfolgen, zum Beispiel durch

API-Gateways, die nur auf Whitelists registrierter Endpunkte reagieren, oder durch Einsatz von Zertifikaten und OAuth-Scopes. Um unautorisierte Erweiterungen technisch zu unterbinden kann die Deinstallation oder Deaktivierung der Erweiterungen, sowie das Setzen von Berechtigungen zur Installation nur für Administrierende umgesetzt werden.

Control: KONF.11.8.1 - Einschränkung von Zonentransfers

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.11 Vertrauensbeziehungen
Übergeordnetes Control:
KONF.11.8 Einschränkung von Schnittstellen
UUID: cf0655b0-3c6a-48a5-8f29-4445c26c3659
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für DNS-Server SOLLTE Zonentransfers einschränken.

Guidance

Zum Schutz vor DNS-Reconnaissance und DNS-Spoofing, da Zonendaten alle DNS-Einträger einer Domäne enthalten. Kann durch Einschränkung auf autorisierte IP-Adressen und TSIG umgesetzt werden.

Control: KONF.11.8.2 - Einschränkung von TK-Verbindungen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.11 Vertrauensbeziehungen
Übergeordnetes Control:
KONF.11.8 Einschränkung von Schnittstellen
UUID: 0467042c-2497-4f56-9514-404a36a90fd0
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen

Statement

Konfiguration für TK-Anwendungen SOLLTE unerwünschte TK-Verbindungen einschränken.

Guidance

Kann durch Session Border Controller (SBC) oder Filterung innerhalb von Anwendungen umgesetzt werden. SBC filtern die Signalisierung und Mediastreams auf dem Kommunikationsweg, insbesondere beim Verbindungsaufbau mittels SIP, H.323 oder MGCP.

Links

related: ARCH.5.1 Einschränkung und Inspektion von Verbindungen

Control: KONF.11.8.2.1 - Einschränkung der TK-Gegenstellen

Tags: "Produktbeschreibung" "PSTN"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.11 Vertrauensbeziehungen
Übergeordnetes Control:
KONF.11.8.2 Einschränkung von TK-Verbindungen
UUID: 756c0796-be3d-492d-a64e-3314f6d83805
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für TK-Anwendungen SOLLTE Verbindungen mit externen Gegenstellen einschränken.

Guidance

Telekommunikation mit externen Stellen ist essenziell für viele Geschäftsprozesse, aber auch beliebtes Ziel für Social Engineering und technische Angriffe. Kann z.B. durch eine Beschränkung auf europäische Rufnummernkreise oder den Ausschluss unerwünschter IP-Adressbereiche umgesetzt werden.

Control: KONF.11.9 - Verschlüsselung schützenswerter Daten (at-rest)

Tags: "Produktbeschreibung" "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.11 Vertrauensbeziehungen
UUID: d3e4416f-e997-4aec-a45b-eade4316d896
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Anwendungen KANN schützenswerte Daten bei der Speicherung (at-rest) verschlüsseln.

Guidance

Hierbei ist insbesondere an Zugangsdaten zu denken. Die Anforderung ist auch dann erfüllt, wenn Daten statt einer Verschlüsselung mit Hash und Salt versehen sind. Zur Umsetzung siehe BSI TR-02102.

Control: KONF.12.1 - Eingabevalidierung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: 4cf4ca7f-0b09-4777-83dc-5569c8e08f63
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.12.1.9 Journaling
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.11 Aktive Dateiinhalte

Statement

Konfiguration für Anwendungen SOLLTE die Validierung von Eingabedaten durch `{{ insert: param, konf.12.1-prm1 }}` aktivieren.

Guidance

Eingabevalidierung (engl. input validation) ist die technische und logische Überprüfung von Daten, die von Nutzenden, Schnittstellen oder externen Quellen an eine Anwendung übergeben werden. Ziel ist es, sicherzustellen, dass nur erwartete, syntaktisch und semantisch korrekte Eingaben verarbeitet werden – beispielsweise Zahlen in einem numerischen Feld, zulässige Dateiformate bei Uploads oder inhaltlich beschränkte Steuerzeichen in Formularen. Fehlende oder unzureichende Eingabevalidierung könnte es Angreifenden ermöglichen, schadhaften Code einzuschleusen (injection attacks wie SQL Injection oder Command Injection), Geschäftslogik

zu manipulieren oder Systeme über Ressourcenmissbrauch lahmzulegen. Eine saubere Validierung kann dagegen die Angriffsfläche deutlich reduzieren und die Verlässlichkeit der Anwendung erhöhen. Dabei hängt die Ausgestaltung stark vom Einsatzzweck ab: Während etwa bei einer Textverarbeitung größere Freiheiten gewährt werden können, erfordern sensible Szenarien wie SQL-Injection bei Datenbankabfragen, die Abwehr von prompt injection bei Large Language Models (LLM) oder die Verarbeitung von Zahlungsdaten sehr strikte Prüfungen. Je nach Anwendung und Risikoprofil können Plausibilitätsprüfungen, die Beschränkung der Eingabedaten auf vordefinierte Werte, Verifikationen der Daten bei einer dritten Stelle (z.B. eines Zahlungsmittels beim Zahlungsanbieter), Regular Expression Entry Patterns, oder Data Escaping als Maßnahmen sinnvoll sein.

Links

related: DEV.2.6.1 Eingabevalidierung

Control: KONF.12.1.1 - Zertifikatsprüfung

Tags: "Produktbeschreibung" "Phishing"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
Übergeordnetes Control:
KONF.12.1 Eingabevalidierung
UUID: 0e183da9-8671-492b-ba81-f95ff6d90a26
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webbrowser SOLLTE die automatische Validierung des Zertifikates einschließlich der vollständigen Zertifikatskette aktivieren.

Guidance

Zertifikatsprüfung (Certificate Validation) ist eine Funktion, bei der ein Browser das digitale Zertifikat einer Webseite vor dem Verbindungsaufbau verifiziert. Dabei wird sichergestellt, dass das Zertifikat von einer vertrauenswürdigen Zertifizierungsstelle (CA - Certificate Authority) ausgestellt, gültig und nicht abgelaufen oder widerrufen ist. Dabei wird die vollständige Zertifikatskette, einschließlich des Root-Zertifikates verifiziert. Ist das Zertifikat ungültig, so wird der Aufruf der Seite blockiert. Die korrekte Implementierung dieses Prozesses kann die Vertraulichkeit und Integrität der übertragenen Daten gewährleisten und schützt vor Man-in-the-Middle-Angriffen, bei denen Angreifer versuchen, den Datenverkehr abzufangen. Zur Umsetzung dieser Anforderung können Institutionen die zentrale Konfiguration von Browsern über Gruppenrichtlinien (Group Policies) oder Mobile Device Management (MDM)-Lösungen vornehmen.

Control: KONF.12.1.2 - Content Security Policy (CSP)

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
Übergeordnetes Control:
KONF.12.1 Eingabevalidierung
UUID: 65287ea4-9379-4088-adb0-774fb2b9ccbb
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webbrowser SOLLTE aufgerufene Inhalte anhand der von der Webseite bereitgestellten Content Security Policy einschränken.

Guidance

Eine Content Security Policy (CSP) ist ein Sicherheitsmechanismus, der es einer Webseite erlaubt, dem Webbrowser mitzuteilen, von welchen Quellen er aktive Inhalte wie Skripte oder auch passive Inhalte wie Bilder laden darf. Durch diesen als Whitelist funktionierenden Ansatz kann die Institution die Angriffsfläche ihrer Webanwendungen erheblich reduzieren. Ohne eine wirksame CSP könnten Angreifer durch Cross-Site-Scripting-Angriffe (XSS) bösartige Skripte in eine Webseite einschleusen, die dann im Browser des Nutzers ausgeführt werden und beispielsweise sensible Daten auslesen oder Aktionen im Namen des Opfers durchführen könnten. Die Aktivierung einer CSP blockiert die Ausführung von nicht vertrauenswürdigen Skripten und das Laden unerwünschter Ressourcen und schützt somit die Integrität und Vertraulichkeit der Web-Sitzung.

Control: KONF.12.1.3 - Same-Origin-Policy

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
Übergeordnetes Control:
KONF.12.1 Eingabevalidierung
UUID: faaaee02-ac74-49a0-af01-4e5659ea1053
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webbrowser SOLLTE aufgerufene Inhalte anhand der von der Webseite bereitgestellten Same-Origin-Policy einschränken.

Guidance

Die Same-Origin-Policy, oft auch als SOP bekannt, ist ein fundamentaler Sicherheitsmechanismus im Webbrowser, der sicherstellt, dass von einer Quelle (Origin) geladene Skripte oder Dokumente nicht mit Ressourcen einer anderen Quelle interagieren können, wobei eine Quelle durch die Kombination aus Protokoll, Hostname und Port definiert wird. Sinn und Zweck dieser strikten Trennung ist der Schutz vor Datenabfluss und unbefugten Interaktionen zwischen unterschiedlichen Webanwendungen innerhalb derselben Browsersitzung. Ohne diese Isolierung könnte eine schadhafte Webseite beispielsweise vertrauliche Informationen aus einer parallel geöffneten legitimen Anwendung, wie einem Online-Banking-Portal oder internen Firmentool, auslesen und an einen Angreifer senden. Die konsequente Durchsetzung der Same-Origin-Policy durch den Browser kann solche Cross-Site-Scripting-Angriffe (XSS) effektiv unterbinden und somit die Vertraulichkeit und Integrität der vom Nutzer verarbeiteten Daten gewährleisten.

Control: KONF.12.1.4 - Subresource Integrity-Prüfung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
Übergeordnetes Control:
KONF.12.1 Eingabevalidierung
UUID: 0e525ce3-95e3-4095-83f7-942eb6b09c50
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webbrowser SOLLTE aufgerufene Inhalte anhand der von der Webseite bereitgestellten Subresource Integrity-Prüfung einschränken.

Guidance

Unter Subresource Integrity (SRI), zu Deutsch etwa „Integrität von Unterressourcen“, versteht man einen Sicherheitsmechanismus von Webbrowsern, der sicherstellt, dass die vom Browser geladenen Ressourcen, wie z.B. JavaScript-Dateien oder CSS-Stylesheets, die von einem Drittanbieter (etwa einem Content Delivery Network, CDN) stammen, nicht unerwünscht manipuliert wurden. Technisch geschieht dies dadurch, dass die Webseite beim Einbinden der Ressource einen kryptografischen Hashwert (oder Digest) der erwarteten Datei als Attribut (z.B. integrity="...") mitsendet. Der Webbrowser kann dann nach dem Herunterladen der Ressource diesen Hashwert neu berechnen und mit dem bereitgestellten Wert vergleichen. Dies ist notwendig, da die Institution zwar die eigene Webseite kontrolliert, aber nicht die Server Dritter, von denen oft Bibliotheken geladen werden. Der Sinn und Zweck dieser Vorschrift liegt darin, die Sicherheit der Endnutzer zu erhöhen und Risiken durch manipulierte externe Inhalte zu minimieren. Ohne diese Prüfung könnte eine kompromittierte Drittanbieter-Ressource bösen Code in die Webseite der Institution einschleusen, was zu Vorfällen wie Datendiebstahl oder der Installation von Malware auf den Geräten der Nutzer führen könnte.

Control: KONF.12.1.5 - HTTP Strict Transport Security (HSTS)

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
Übergeordnetes Control:
KONF.12.1 Eingabevalidierung
UUID: 275e3b2d-5008-48ba-8d4f-72830bc8c730
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webbrowser SOLLTE aufgerufene Inhalte anhand der von der Webseite bereitgestellten HTTP Strict Transport Security (HSTS) Richtlinie einschränken.

Guidance

Die HTTP Strict Transport Security (HSTS) ist ein Web-Sicherheitsmechanismus – definiert in IETF RFC 6797 – der Webbrowser zwingt, eine ausschließlich verschlüsselte Verbindung (HTTPS) mit einem Webserver zu nutzen, selbst wenn der Nutzer oder eine Anwendung versucht, über das unsichere HTTP zuzugreifen. Konkret beinhaltet die HSTS-Richtlinie (oder Policy) einen speziellen HTTP-Antwort-Header, den der Webserver an den Browser sendet, der die Dauer (max-age) festlegt, für die der Browser die Verbindung nur über HTTPS herstellen soll. Die restriktive Konfiguration von Webbrowsern in Bezug auf diese Richtlinie kann die Schutzwirkung erhöhen, da so das Risiko eines Man-in-the-Middle (MITM)-Angriffs, bei dem ein Angreifer eine unverschlüsselte Verbindung abfangen oder den Nutzer auf eine unsichere Seite umleiten könnte, deutlich reduziert wird. Eine solche Konfiguration kann die Institution vor dem ungewollten Downgrade-Angriff (Downgrade Attack) schützen, bei dem die Verbindung von HTTPS auf das unsichere HTTP erzwungen wird.

Control: KONF.12.1.6 - JavaScript

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
Übergeordnetes Control:
KONF.12.1 Eingabevalidierung
UUID: f66bbf9d-76ba-423f-b2e5-25cc775c16c6
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Webbrowser KANN JavaScript einschränken.

Guidance

Schadcode in JavaScript kann unbefugt auf sensible Daten zugreifen oder die angezeigte Webseite manipulieren. Da viele Webseiten JavaScript zur Ausführung benötigen, ist die Deaktivierung von JavaScript mit erheblichen funktionalen Einschränkungen verbunden. Ein möglicher Kompromiss ist, dass Administrierende oder Nutzende Ausnahmen für einzelne Seiten hinzufügen können.

Control: KONF.12.1.7 - Filtern schädlicher Webinhalte

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
Übergeordnetes Control:
KONF.12.1 Eingabevalidierung
UUID: 568f6977-4f5c-44a4-92c7-1e6e09cc3631
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webanwendungen SOLLTE eine Filterung schädlicher Webinhalte aktivieren.

Guidance

Anfragen an Webanwendungen könnten dazu führen, dass diese sich anders verhalten als gewollt. Mögliche Folgen sind die unzulässige Preisgabe von Informationen, die Manipulation oder der Verlust von Daten sowie Betriebsstörungen. Typische Auslöser sind SQL Injection oder Cross-Site-Scripting. Solche potenziell schädlich wirkenden Inhalte können durch eine Web Application Firewall oder durch geeignete Eingabevalidierung in der Webanwendung gefiltert werden.

Links

related: ARCH.5.1.10 Webfilterung

Control: KONF.12.1.8 - Duplikate im Verzeichnisbaum

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
Übergeordnetes Control:
KONF.12.1 Eingabevalidierung
UUID: c9194ad7-5382-4810-a5b9-d4013a28f5a5
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Verzeichnisdienste SOLLTE Duplikate im Verzeichnisbaum blockieren.

Guidance

Da jedes Zugangskonto nur einmal benötigt wird können Duplikate von Attributen wie Name oder Organisationseinheit nur als Fehler oder Angriff vorkommen. In OpenLDAP kann dies beispielsweise durch Overlays realisiert werden. Dies gilt ausschließlich für Daten von Nutzenden.

Control: KONF.12.1.9 - Journaling

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
Übergeordnetes Control:
KONF.12.1 Eingabevalidierung
UUID: 87ccf38b-ac1d-4e14-a599-b536321b0f75
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Dateiserver SOLLTE Dateisystem-Journaling aktivieren.

Guidance

Beim Journaling werden Änderungen an Dateien zunächst in einem speziellen Protokoll (Journal) aufgezeichnet, bevor sie tatsächlich geschrieben werden, um Datenintegrität und Konsistenz sicherzustellen. Auf einem Dateiserver ist dies besonders wichtig, da es das Risiko von Datenverlusten bei plötzlichen Abstürzen oder Stromausfällen minimiert und eine schnelle Wiederherstellung ermöglicht.

Control: KONF.12.1.10 - HTTP-Response-Header

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
Übergeordnetes Control:
KONF.12.1 Eingabevalidierung
UUID: 34bf7846-28cb-41db-bd7b-2e81bee980b3
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webanwendungen SOLLTE HTTP-Response-Header aktivieren.

Guidance

Hierzu können z.B. Content-Security-Policy (CSP), X-Frame-Options, X-XSS-Protection, Referrer-Policy, Permissions-Policy, HSTS und X-Content-Type-Optionen gehören.

Control: KONF.12.1.11 - Aktive Dateiinhalte

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
Übergeordnetes Control:
KONF.12.1 Eingabevalidierung
UUID: fe822942-31a1-4961-832f-3523f7622754
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Office-Anwendungen SOLLTE aktive Inhalte in Office-Dateien deaktivieren.

Guidance

Aktive Inhalte (Makros) in Office-Dokumenten können Schadcode enthalten oder zu nicht nachvollziehbaren Datenfehlern führen. Viele Nutzende verwenden solche Funktionen jedoch für ihre Arbeit, so dass eine generelle Sperrung mit Einschränkungen verbunden ist. Autorisierte Ausnahmen bilden daher einen guten Kompromiss bei normalen Schutzbedarf. Dies kann durch den geschützten Modus (Protected View) umgesetzt werden. Werden bestimmte Makros dennoch häufig benötigt, so können Makros mit digitaler Signatur einer anerkannten Zertifizierungsstelle oder von vertrauenswürdigen Speicherorten zugelassen werden.

Control: KONF.12.2 - Verschlüsselungsstatus der aktuellen Verbindung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: 8e35ba9c-0926-4cef-bd95-ec79933a6ee2
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webbrowser SOLLTE eine Anzeige der Verschlüsselung der aktuellen Verbindung aktivieren.

Guidance

Die Anzeige der Verschlüsselung der aktuellen Verbindung im Webbrowser, auch bekannt als Connection Encryption Indicator oder oft durch ein [gesperrt]-Symbol dargestellt, ist ein essenzielles Merkmal für die Wahrnehmung der Vertrauenswürdigkeit einer Online-Kommunikation. Sie visualisiert, ob die Datenübertragung zwischen dem Browser des Benutzers und dem Webserver mittels eines kryptografischen Protokolls, typischerweise Transport Layer Security (TLS) (früher Secure Sockets Layer (SSL)), abgesichert ist. Diese Vorschrift zielt darauf ab, das Risiko des Abhörens von Daten durch Dritte (Eavesdropping) zu minimieren; denn ohne diese Anzeige könnte ein Benutzer unbemerkt sensible Informationen über eine ungesicherte Verbindung eingeben, was beispielsweise zur Kompromittierung von Anmeldedaten oder vertraulichen Geschäftsinformationen führen könnte.

Control: KONF.12.3 - Cookies

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: 77690b80-cd45-47dd-9540-b8de5d67cbbe
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webbrowser SOLLTE Cookies einschränken.

Guidance

Cookies sind Dateien, in denen Webseiten Daten auf dem System speichern. Sie können Authentifizierungstoken und andere personenbezogene Daten enthalten und durch Angriffe wie Cross-Site-Scripting (XSS) oder Session Hijacking kompromittiert werden. Die Speicherung von Cookies per Default auszuschalten könnte jedoch zu Funktionseinschränkungen führen. Nutzende oder Administrierende können Ausnahmen für bestimmte Webseiten, z.B. im Intranet, hinzufügen.

Control: KONF.12.4 - Speicherung von Zugangsdaten

Tags: "Produktbeschreibung" "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: 93d5129d-c905-439f-b7cf-2ddcd92fac5a
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webbrowser SOLLTE die Speicherung von Zugangsdaten {{ insert: param, konf.12.4-prm1 }} aktivieren.

Guidance

Werden Zugangsdaten gespeichert, so könnten Angreifer diese auslesen und missbrauchen. Daher ist es wichtig, Vertraulichkeit und Integrität sensibler Anmeldedaten zu gewährleisten. Durch die Nutzung einer geprüften Browser-Extension kann sichergestellt werden, dass Passwörter nur in einem verschlüsselten Vault abgelegt werden, der zentral verwaltet oder versioniert wird. Ein starkes Master-Passwort kann als Schlüssel dienen, sodass selbst bei Verlust des Geräts oder unautorisiertem Zugriff auf die lokale Datenbank die Daten ohne Kenntnis dieses Passworts nicht lesbar sind. Wird die Funktion komplett deaktiviert, kann das Risiko unkontrollierter Speicherung oder unsicherer Autovervollständigung minimiert werden – der Anwender kann sich stattdessen etwa auf einen externen Manager oder eine Single-Sign-On-Lösung verlassen. Konkret kann dies in der Praxis auf verschiedene Weisen aussehen: So kann eine Institution über Gruppenrichtlinien festlegen, dass nur eine offiziell freigegebene Extension (etwa einer Open-Source-Lösung oder eines kommerziellen Anbieters) installiert werden darf. Alternativ lassen sich browserinterne Passwort-Speicher mit einem Master-Passwort verschlüsseln – denkbar ist hier sowohl die Nutzung integrierter Funktionen von Browsern mit zuverlässiger Krypto-Engine als auch externer Tools wie plattformübergreifende Passwort-Manager, die eine Browser-Anbindung per Plugin bieten. In Szenarien mit besonders hohen Sicherheitsanforderungen kann die Speicherung ganz deaktiviert werden, etwa indem das entsprechende Feature per Policy abgeschaltet wird und Nutzer gezielt mit einem eigenständigen, von der Institution kontrollierten Tool arbeiten. Für die Umsetzung bietet es sich an, zunächst eine klare Richtlinie zu formulieren, die alle

Mitarbeitenden über die zugelassenen Speicherwege informiert und gleichzeitig erklärt, warum unautorisierte Methoden unerwünscht sein können. IT-Administratoren können über zentrale Management-Werkzeuge (GPOs, MDM-Systeme) die Installation autorisierter Extensions automatisieren und unerwünschte Funktionen deaktivieren. Es kann hilfreich sein, standardisierte Vorlagen für sichere Master-Passwörter zu kommunizieren und regelmäßige Schulungen anzubieten, in denen der Umgang mit dem Passwort-Manager, das Prüfen der Passwortstärke und das Einspielen von Updates erklärt werden. Schließlich kann eine optionale Passwort-Auditing-Funktion im Manager eingesetzt werden, mit der Nutzer Schwachstellen in ihren Passwörtern erkennen und verbessern können – so bleibt die gesamte Passwortlandschaft im Unternehmen übersichtlich und sicher.

Control: KONF.12.5 - Auto-Vervollständigung von Daten

Tags: "Produktbeschreibung" "Phishing" "Data Leak"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: 884ebdea-7054-48bf-932a-bb4f704baa8e
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webbrowser SOLLTE die Auto-Vervollständigung von Daten einschränken.

Guidance

Webseiten können Eingaben auch auslesen, bevor diese abgesendet werden. Die Deaktivierung der Auto-Vervollständigung verhindert, dass der Browser diese Daten automatisch eingibt.

Control: KONF.12.6 - Browser-Historie

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: 1eb77ea1-1c97-4027-9098-a874951b0f47
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Webbrowser KANN die dauerhafte Browser-Historie deaktivieren.

Guidance

Kann durch das Löschen der Historie beim Beenden oder durch Deaktivierung der Historie umgesetzt werden.

Control: KONF.12.7 - Erweiterte Attribute

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: 7ec374a6-4efc-45a4-b596-4e8fc1402daf
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Dateiserver SOLLTE erweiterte Attribute aktivieren.

Guidance

Erweiterte Attribute ermöglichen die Speicherung von Metadaten zu Dateien zur Speicherung von Zugriffsrechten und Statusindikatoren. Kann unter Linux durch Samba mit Extended Attributes und unter Windows durch Nutzung des NTFS-Dateisystems umgesetzt werden.

Control: KONF.12.8 - Teilnahme per Default ohne Bild und Ton

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: bbea53dc-e082-4ac7-80f7-a25e0bf04a76
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für VK-Anwendungen SOLLTE Bild und Ton per Default deaktivieren.

Guidance

Eine Konfiguration, bei der die Standardeinstellung (per default) für Bild und Ton deaktiviert ist, bedeutet, dass Nutzerinnen und Nutzer die Videokonferenz-Anwendungen (VK-Anwendungen) betreten, ohne dass ihre Kamera und ihr Mikrofon automatisch eingeschaltet sind. Diese Voreinstellung minimiert das Risiko, dass sensible oder private Informationen unbeabsichtigt geteilt werden. Einem Vorfall, bei dem vertrauliche Gespräche im Hintergrund unfreiwillig übertragen werden, könnte so effektiv vorgebeugt werden. Die Institution kann dadurch das Risiko unbeabsichtigter Datenexposition minimieren, indem die Kontrolle über die Aktivierung von Bild und Ton explizit bei den Nutzenden bleibt. Um diese Anforderung umzusetzen, kann die Institution die technischen Einstellungen in der Verwaltungs- oder Admin-Konsole der jeweiligen Anwendung anpassen, um die Standardwerte für alle Teilnehmenden zu ändern. Ebenfalls kann eine technische Richtlinie implementiert werden, die sicherstellt, dass die Applikation vor dem Start eines Meetings eine Checkliste anzeigt, die die Nutzenden explizit auffordert, Kamera und Mikrofon bewusst zu aktivieren.

Control: KONF.12.9 - Information über Aufzeichnung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: 46dd3e73-e1d5-4dee-9312-d52e9bb5c631
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für VK-Anwendungen SOLLTE eine Anzeige laufender Aufzeichnungen für alle Teilnehmenden aktivieren.

Guidance

Heimliche Aufzeichnungen verletzen die Vertraulichkeit der Kommunikation. Eine Aufzeichnung von Wort und Bild ohne den Willen der Aufgezeichneten kann zudem eine Persönlichkeitsrechtsverletzung bis hin zur Straftat (§ 201 StGB) darstellen. Dies gilt auch für Aufzeichnungen, die KI-gestützt ausgewertet werden. Falls die Möglichkeit zur Aufzeichnung deaktiviert ist, so ist diese Anforderung ebenfalls erfüllt.

Control: KONF.12.10 - Cookie-Attribute

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: 4ac2fe69-5f2d-47d8-acf7-2be1485f9f37
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Webanwendungen SOLLTE Cookie-Attribute aktivieren.

Guidance

"Secure" erzwingt die verschlüsselte HTTPS-Übertragung, wodurch Man-in-the-middle-Angriffe verhindert werden. "SameSite" sorgt dafür, dass Cookies nur zurückgesendet werden, wenn die Anfrage von der ursprünglichen Seite stammt. Hierdurch werden Cross-Site-Request-Forgery-Angriffe erschwert. "HttpOnly" verbietet es Client-seitigen Skripten auf das Cookie zuzugreifen, wodurch Cross-Site Scripting (XSS) erschwert wird.

Control: KONF.12.11 - Anonyme oder Pseudonyme Kommunikation

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: a06eca6b-f142-4808-b04d-c19adf178db4
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für TK-Anwendungen KANN die Übermittlung {{ insert: param, konf.12.11-prm1 }} zur Gegenstelle aktivieren.

Guidance

Wenn eine persönliche Identifikation von Kommunikationspartnern erforderlich ist, ist eine Verschleierung von Erreichbarkeiten sinnvoll. In der klassischen Telefonie kann hierfür die Rufnummerunterdrückung für ausgehende Anrufe (CLIR) oder eine Pseudonymisierung, z.B. durch Übermittlung der 0 statt der Nebenstelle, genutzt werden. Für die Verschleierung der Netzquelle können Proxy-Server oder Anonymisierungsgateways genutzt werden. Für weitere Details siehe "Kompendium für organisationsinterne Telekommunikationssysteme mit erhöhtem Schutzbedarf".

Control: KONF.12.12 - Verbindungsprotokoll

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: 31191a30-d1fd-4adf-a407-35e4fc782e79
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für TK-Anwendungen SOLLTE ein für Nutzende verfügbares Verbindungsprotokoll protokollieren.

Guidance

Ein solches Protokoll, oft auch als Call Detail Record (CDR) oder Connection Log bezeichnet, dokumentiert für Nutzende nachvollziehbar die Kommunikationsverbindungen, die sie über die Anwendung herstellen. Das Protokoll könnte dabei erfassen, wann eine Verbindung aufgebaut wurde, wie lange sie bestand, mit wem sie stattfand (z.B. die Rufnummer oder der Benutzername der Gegenstelle) und aus welcher Richtung (ein- oder ausgehend) sie kam. In der klassischen Telefonie ist dies die Auflistung der zuletzt ein- oder ausgehenden Anrufe. Eine solche Protokollierung kann als wichtige Maßnahme der Rechenschaftspflicht oder Accountability dienen. Durch die lückenlose Protokollierung der Aktivitäten der Nutzenden kann transparent nachvollzogen werden, welche Verbindungen zu welchem Zeitpunkt hergestellt wurden. Dies kann dabei helfen, ungewöhnliche oder nicht autorisierte Kommunikationsversuche zu erkennen und die Integrität der genutzten Systeme zu wahren. Ohne ein solches Protokoll könnte eine unberechtigte Nutzung oder ein Datenabfluss aus dem internen Netzwerk unentdeckt bleiben. Hierbei besteht ein enger Zusammenhang mit Compliance-Verpflichtungen zur Aufbewahrung und Löschung von Telekommunikationsdaten.

Control: KONF.12.13 - Sendebericht

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: 0ef855ab-834e-405e-99f4-a1bca3f09d15
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Faxe SOLLTE einen Sendebericht protokollieren.

Guidance

Ein Sendebericht ermöglicht es bei der Verwendung von Faxen nachzuweisen, dass das Fax tatsächlich an die Gegenstelle versendet wurde. Für einen rechtssicheren Nachweis ist es sinnvoll, wenn der Sendebericht außerdem weitere Angaben wie die versendete Seitenzahl, eine Vorschau der ersten Seite oder des gesamten Inhaltes, sowie den Status mit dem die Verbindung beendet wurde (z.B. OK) beinhaltet.

Control: KONF.12.14 - DNS-Falschinformationen

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.12 Kontrollierte Datenverarbeitung
UUID: d3856d40-5869-4b06-812b-4cc966f96d80
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für DNS-Server SOLLTE DNS-Antworten, die falsche Domain-Informationen liefern, deaktivieren.

Guidance

Falsch sind Domain-Informationen, wenn sie nicht der tatsächlichen Erreichbarkeit des Zieles entsprechen, sondern z.B. auf Werbeseiten umleiten. DNS-Server, die falsche Antworten liefern, können zu unerwarteten Fehlern in Anwendungen oder zum DNS-Hijacking führen. Sie sind an unerwarteten Websites, Zertifikatsfehlern oder mit DNS-Prüfsoftware zu erkennen. Gilt sowohl für die Konfiguration des eigenen Servers, als auch für die verwendeten DNS Upstream Server.

Control: KONF.13.1 - Filtern schädlicher Nachrichten

Tags: "Produktbeschreibung" "Phishing"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
UUID: 0571ae85-f5f8-485c-b3d7-44f8ddfa2d58
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.13.1.1 SPAM-Filter
- KONF.13.1.2 Interpretation aktiver Inhalte

Statement

Konfiguration für Interpersonelle Kommunikation SOLLTE eine Filterung schädlicher Nachrichteninhalte aktivieren.

Guidance

Unter Filterung schädlicher Nachrichteninhalte versteht man Verfahren, die Inhalte automatisch prüfen und unerwünschte, gefährliche oder manipulative Bestandteile erkennen, blockieren oder kennzeichnen können. Der Sinn dieser Vorgabe liegt darin, potenziell gefährliche Inhalte wie Phishing-Versuche, schadhaften Code oder gezielte Desinformation frühzeitig abzufangen. Ohne eine solche Filterung könnte Schadsoftware über Anhänge eingeschleust werden oder Mitarbeitende könnten durch manipulierte Links zu vertraulichen Datenabgaben verleitet werden. Mit einer wirksamen Filterung kann die Angriffsfläche reduziert, das Vertrauen in die Kommunikationskanäle erhöht und die Produktivität geschützt werden. Zur Umsetzung kann eine Institution technische Maßnahmen kombinieren: (1) E-Mail-Gateways oder Chat-Schnittstellen können mit Inhaltsfiltern ausgestattet werden, die bekannte Malware-Signaturen, verdächtige Links oder gefährliche Dateitypen erkennen. (2) Ergänzend kann heuristische Analyse und maschinelles Lernen eingesetzt werden, um Muster verdächtiger Inhalte zu identifizieren, auch wenn diese noch nicht in Signaturdatenbanken enthalten sind. (3) Regeln zur Blockierung bestimmter Dateianhänge (z. B. ausführbare Dateien) können eingerichtet werden, während sichere Alternativen für den Austausch bereitgestellt werden. (4) Schließlich kann ein klarer Prozess vorgesehen werden, um falsch-positive Erkennungen

manuell zu prüfen und legitime Kommunikation wieder freizugeben.

Control: KONF.13.1.1 - SPAM-Filter

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
Übergeordnetes Control:
KONF.13.1 Filtern schädlicher Nachrichten
UUID: ee57e250-bed1-484e-9ff7-8b7750562877
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Interpersonelle Kommunikation SOLLTE die Zustellung unerwünschter Nachrichten blockieren.

Guidance

Unter Zustellung unerwünschter Nachrichten ist das Blockieren oder Filtern von Spam, Phishing-Versuchen, Social-Engineering-Nachrichten oder belästigender Kommunikation zu verstehen. Diese Anforderung zielt darauf ab, die Integrität der Kommunikationskanäle zu wahren und das Risiko von Sicherheits- oder Vertrauensbrüchen zu reduzieren. Ohne geeignete Filtermechanismen könnte Schadsoftware per Anhang eingeschleust werden, sensible Informationen könnten durch täuschend echte Phishing-Nachrichten abgegriffen werden oder Mitarbeitende könnten durch gezielte Belästigungen in ihrer Arbeitsfähigkeit eingeschränkt werden. Zur Umsetzung kann eine Institution verschiedene Ansätze kombinieren: (1) Der Einsatz serverseitiger Filtermechanismen auf Mail-Gateways oder Collaboration-Plattformen kann zentral die meisten unerwünschten Nachrichten aussortieren. (2) Ergänzend können clientseitige Filterregeln aktiviert werden, die Benutzern zusätzliche Möglichkeiten zur Sortierung bieten, etwa über Whitelists und Blacklists. Praktisch kann es auch hilfreich sein, Quarantäneordner einzurichten, damit Anwender verdächtige Nachrichten selbständig einsehen und fälschlich blockierte Nachrichten zurückholen können.

Control: KONF.13.1.2 - Interpretation aktiver Inhalte

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
Übergeordnetes Control:
KONF.13.1 Filtern schädlicher Nachrichten
UUID: ecc5b98d-eb77-4902-a01a-a5348ecba8f0
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Interpersonelle Kommunikation SOLLTE die automatische Interpretation aktiver Inhalte deaktivieren.

Guidance

Unter aktiven Inhalten sind hier Elemente zu verstehen, die beim Empfang automatisch ausgeführt oder interpretiert werden könnten, wie z. B. eingebettete Skripte in E-Mails, dynamische Makros in Dokumenten oder der automatische Download von externen Bildern in Chat-Nachrichten. Hintergrund ist, dass eine empfangene Nachricht nicht nur reinen Text oder statische Informationen enthalten könnte, sondern zusätzliche versteckte Anweisungen, die beim Anzeigen sofort wirken. Ein typischer Vorfall könnte etwa sein, dass eine Mitarbeiterin eine HTML-E-Mail öffnet, die ein eingebettetes JavaScript enthält und dadurch unbemerkt Zugangsdaten abgegriffen werden. Durch Deaktivieren solcher Inhalte wird verhindert, dass Schadcode automatisch ausgeführt wird. Dies betrifft sowohl Inhalte in Freitext-Datenfeldern als auch an die Nachricht angehängte Dateien. Beispielsweise kann in Mail-Clients die Ausführung von Makros deaktiviert, die Darstellung externer Inhalte blockiert oder das Rendern von Skripten untersagt werden. Ebenso kann bei Messaging-Diensten die Anzeige von aktiven Inhalten durch Filter eingeschränkt werden, sodass nur reiner Text oder geprüfte Anhänge angezeigt werden. Ergänzend kann es hilfreich sein, benutzerseitige Tipps wie das standardmäßige Verwenden einer Nur-Text-Ansicht oder die klare Kennzeichnung von blockierten Inhalten zu etablieren. Institutionen können durch regelmäßige Konfigurationsprüfungen sicherstellen, dass Änderungen durch Updates oder neue Versionen die Deaktivierung nicht unbemerkt wieder aufheben.

Control: KONF.13.2 - Authentizität von Nachrichten

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
UUID: 04eaf9de-736e-4dfc-898e-04dc85fa36f0
Aufwand: 4
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur

Statement

Konfiguration für Interpersonelle Kommunikation SOLLTE eine automatische Verifikation der Authentizität von Nachrichten aktivieren.

Guidance

Die Authentizität von Nachrichten bezeichnet in diesem Zusammenhang die nachweisbare Echtheit und Unverfälschtheit einer digitalen Mitteilung im Rahmen der interpersonellen Kommunikation, also die Sicherheit, dass eine Nachricht tatsächlich von der angegebenen Quelle stammt und auf dem Übertragungsweg nicht manipuliert wurde. Im Fachjargon wird hier häufig von Message Authenticity oder auch von Origin Authentication gesprochen, wobei beide Begriffe eng mit kryptographischen Verfahren wie Digital Signatures oder Message Authentication Codes (MACs) verbunden sind. Der Sinn dieser Anforderung liegt darin, sicherzustellen, dass Angreifer keine falschen Identitäten vortäuschen oder den Inhalt von Nachrichten unbemerkt verändern können. Andernfalls könnte etwa eine gefälschte Anweisung in einem Chat zu Fehlhandlungen führen oder ein manipuliertes Dokument im E-Mail-Verkehr falsche Entscheidungen auslösen. Eine automatische Verifikation kann hingegen das Vertrauen in die Integrität und Herkunft der Kommunikation gewährleisten. Zur Umsetzung kann eine Institution beispielsweise digitale Signaturen einsetzen, die durch etablierte Standards wie S/MIME oder OpenPGP realisiert werden können, sodass E-Mail-Programme die Echtheit automatisch überprüfen. Auch der Einsatz von Ende-zu-Ende-Verschlüsselung mit eingebauter Authentizitätsprüfung,

etwa bei Protokollen wie Signal Protocol oder TLS mit Client-Zertifikaten, kann eine geeignete Maßnahme sein. Darüber hinaus kann die Integration einer zentralen Public Key Infrastructure (PKI) oder die Nutzung verteilter Vertrauensmodelle (z. B. Web of Trust) sicherstellen, dass Schlüsselpaare zuverlässig verwaltet werden und Anwender ohne manuelle Prüfungen von Zertifikaten auskommen.

Control: KONF.13.2.1 - Verifikation der Sendeberechtigung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
Übergeordnetes Control:
KONF.13.2 Authentizität von Nachrichten
UUID: c163be1f-8236-439c-a1d1-34fa7472c06a
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für E-Mail SOLLTE eine automatische Verifikation der Sendeberechtigung aktivieren.

Guidance

Mit dem Sender Policy Framework (SPF) kann geprüft werden, ob der Sender zum Versand von E-Mails für diese Mailadresse berechtigt war. E-Mails ohne SPF-Header sind unzureichend authentifiziert, so dass sie leicht für Spoofing oder Phishing missbraucht werden können. Allerdings werden noch immer E-Mails ohne SPF verschickt, so dass eine Blockierung zu funktionalen Einschränkungen führen könnte. Kompromissmaßnahmen können z.B. die Markierung der E-Mail mit einem Warnhinweis, Allowlisting, Greylisting, Quarantäne oder eine Filterung durch Anomalieerkennung sein.

Control: KONF.13.2.2 - Verifikation der Serversignatur

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
Übergeordnetes Control:
KONF.13.2 Authentizität von Nachrichten
UUID: 2e782128-57ea-4573-a44e-5538d0dd1240
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für E-Mail SOLLTE die Serversignatur eingehender E-Mails automatisch authentifizieren.

Guidance

Die DKIM-Signatur ist zu unterscheiden von einer PGP-Signatur, die in der Regel nicht automatisch vergeben wird. E-Mails ohne DKIM sind unzureichend authentifiziert, so dass sie leicht für Spoofing oder Phishing missbraucht werden können. Allerdings werden noch immer E-Mails ohne DKIM verschickt, so dass eine Blockierung zu funktionalen Einschränkungen führen könnte. Kompromissmaßnahmen können z.B. die Markierung der E-Mail mit einem Warnhinweis, Allowlisting, Greylisting, Quarantäne oder eine Filterung durch Anomalieerkennung sein. Die Formulierung "im Einklang mit den Festlegungen des Identitäts- und Berechtigungsmanagements" bedeutet, dass die Authentifizierung so erfolgt, wie in der Praktik IDM festgelegt. Hierzu gehört insbesondere die Verwendung aktueller kryptographischer Verfahren, wie sie im Thema Kryptographie zu finden ist.

Control: KONF.13.3 - Kryptographische Signatur des Mailservers

Tags: "Produktbeschreibung" "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
UUID: 0588d640-bda0-46d7-978e-6c742f098327
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für E-Mail SOLLTE die Kryptographische Signatur des Mailservers aktivieren.

Guidance

Die kryptographische Signatur des Mailservers ist ein digitaler Stempel des sendenden Mailservers selbst, mit dem die Authentizität des sendenden Mailservers belegt wird. Ein bekannter technischer Standard hierfür ist DomainKeys Identified Mail (DKIM). Diese Signatur wird durch den absendenden Mailserver (oder einen vorgeschalteten Dienst) unter Verwendung eines privaten kryptographischen Schlüssels erzeugt. Der Empfänger kann die Signatur mit einem öffentlich zugänglichen Schlüssel, der typischerweise im Domain Name System (DNS) der sendenden Domain hinterlegt ist, verifizieren. Diese Schutzmaßnahme kann die Glaubwürdigkeit der E-Mails erhöhen und trägt zur Prävention von Risiken bei, wie dem Spoofing des Absenders: Ein Angreifer könnte ohne eine solche Signatur die Identität der Institution vortäuschen, was zu Phishing-Vorfällen führen könnte.

Control: KONF.13.4 - Kryptographische Signatur durch Nutzende

Tags: "Produktbeschreibung" "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
UUID: 8cda47f9-692a-485d-bc73-a4c3b691c501
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für E-Mail KANN die kryptographische Signatur durch Nutzende aktivieren.

Guidance

Wird eine vom E-Mail vom Sendenden signiert, so können bei Empfang die Authentizität und Integrität der Nachricht verifiziert werden. Dies kann mit S/MIME oder PGP umgesetzt werden.

Control: KONF.13.5 - Publikation der Sendeberechtigung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
UUID: 4eedf96c-42cf-4d3e-902f-f3efce1f533a
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.13.5.1 Strenge Senderpolicy

Statement

Konfiguration für E-Mail SOLLTE die Publikation der eigenen Sendeberechtigung im DNS aktivieren.

Guidance

Dies wird typischerweise über spezielle DNS-Einträge wie den Sender Policy Framework (SPF) realisiert. Damit kann eine Institution im DNS festlegen, welche Mail-Server berechtigt sind, E-Mails im Namen ihrer Domäne zu versenden. Ein entsprechender DNS-Eintrag, der sogenannte SPF-Record, ermöglicht es empfangenden Mail-Servern, die Absender-Adresse einer eingehenden E-Mail zu überprüfen. Dies kann die Schutzwirkung gegen gängige Risiken wie E-Mail-Spoofing verbessern, bei dem sich ein Angreifer als legitimer Absender ausgibt, um die Empfänger zu täuschen. Ohne eine solche Konfiguration könnte ein Angreifer beispielsweise E-Mails mit gefälschter Absenderadresse verschicken, die scheinbar von der Geschäftsleitung stammen, um einen Nutzer zur Herausgabe von sensiblen Informationen zu verleiten (Phishing). Durch die Aktivierung von SPF kann das Risiko verringert werden, dass solche bösartigen Nachrichten die Postfächer von Nutzern erreichen. Es ist wichtig, den Eintrag sorgfältig zu erstellen, um alle legitimen Absender abzudecken, einschließlich Diensten von Drittanbietern. Ein häufiger Fehler ist, dass nicht alle autorisierten Mail-Server korrekt gelistet sind, was dazu führen könnte, dass legitime E-Mails fälschlicherweise als Spam markiert werden.

Control: KONF.13.5.1 - Strenge Senderpolicy

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
Übergeordnetes Control:
KONF.13.5 Publikation der Sendeberechtigung
UUID: b44ec8f5-20f7-43ad-94a6-545a12cc7a67
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für E-Mail SOLLTE eine strenge Senderpolicy aktivieren.

Guidance

Ein strenger Senderpolicy-Eintrag, auch "hard fail" (-all) genannt, weist empfangende Mailserver an, E-Mails, die von nicht autorisierten Servern stammen, zurückzuweisen oder als Spam zu markieren. Dies kann das Risiko von Phishing-Angriffen erheblich reduzieren, bei denen Angreifer versuchen, sich als vertrauenswürdige Institutionen auszugeben. Eine solche Konfiguration kann auch Spoofing verhindern, bei dem die Absenderadresse gefälscht wird, was dazu führen könnte, dass Kunden oder Mitarbeiter betrügerischen Anweisungen folgen, die scheinbar von der Institution selbst stammen. Zur Umsetzung einer strengen Senderpolicy kann die Institution sicherstellen, dass sie einen SPF-Eintrag in ihren DNS-Einstellungen hinterlegt. Dieser Eintrag sollte alle autorisierten Server explizit auflisten und mit dem "-all" Mechanismus enden, um eine strikte Ablehnung nicht konformer E-Mails zu signalisieren.

Control: KONF.13.6 - Publikation der Serversignatur

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
UUID: faf3fea5-b891-4d47-a2f7-74756b02a668
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für E-Mail SOLLTE die Publikation der Serversignatur im DNS aktivieren.

Guidance

Eine Serversignatur, auch bekannt als DKIM (DomainKeys Identified Mail), ist eine kryptografische Signatur, die der E-Mail-Dienst der Institution an jede ausgehende Nachricht anhängt. Sie stellt sicher, dass die E-Mail tatsächlich von der angegebenen Domain gesendet wurde und während der Übertragung nicht manipuliert wurde. Ohne diese Signatur könnte ein Angreifer E-Mails im Namen der Institution versenden (E-Mail-Spoofing), was zu Phishing-Angriffen, dem Diebstahl von Zugangsdaten oder der Verbreitung von Malware führen könnte. Das Aktivieren der Publikation im DNS bedeutet, den öffentlichen Teil dieses kryptografischen Schlüssels im Domain Name System (DNS) der Domain zu veröffentlichen. Empfangende E-Mail-Server können diesen öffentlichen Schlüssel verwenden, um die Signatur der E-Mail zu verifizieren und somit deren Echtheit zu bestätigen. Zur Umsetzung kann die Institution E-Mail-Server-Software so konfigurieren, dass sie DKIM-Signaturen automatisch zu ausgehenden Nachrichten hinzufügt. Dies kann oft durch die Installation und Konfiguration von speziellen DKIM-Filter-Plugins erreicht werden.

Control: KONF.13.7 - TLS-Reports

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
UUID: becbeefc-417d-42e4-b2a0-7a296c23fa9c
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für E-Mail KANN TLS-Reports {{ insert: param, konf.13.7-prm1 }} überprüfen.

Guidance

TLS-Reports, auch TLS-RPT (Transport Layer Security Reporting) genannt, sind Berichte, mit denen Betreiber von Mailservern einander Probleme beim E-Mail-Versand über TLS melden können. Sie können Informationen zu Verbindungsproblemen und möglichen Sicherheitsproblemen enthalten. Hierzu kann TLS-RPT (Transport Layer Security Reporting) genutzt werden.

Control: KONF.13.8 - DMARC-Reports

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
UUID: 96dd928d-e5ac-47ec-a2a2-320ae0359e73
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für E-Mail KANN DMARC-Reports {{ insert: param, konf.13.8-prm1 }} überprüfen.

Guidance

Mit DMARC kann der Empfänger dem Sender automatische Berichte über den DMARC-Status empfangener E-Mails bereitstellen. Diese Berichte liefern Hinweise auf fehlgeschlagene Authentifizierungsprüfungen, Fehlkonfigurationen oder Missbrauchsversuche. Eine automatisierte Auswertung unterstützt dabei, Zustellprobleme frühzeitig zu erkennen und geeignete Korrekturmaßnahmen abzuleiten.

Control: KONF.13.9 - Publikation der DMARC-Richtlinie

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
UUID: b4f12703-f0d8-400d-a979-933d7e29a833
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für E-Mail SOLLTE die Publikation der DMARC-Richtlinie aktivieren.

Guidance

Eine DMARC-Richtlinie legt fest, welchen Umgang sie sich von Empfängern wünschen, die E-Mails von ihrer Domain nicht authentifizieren können. Die Information der Empfänger kann über einen DMARC-Eintrag im DNS erfolgen.

Control: KONF.13.10 - Authentifizierung der Server-Zertifikate über DNS

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
UUID: ee341e2a-290d-4d5f-bf24-c95a265395f6
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für E-Mail SOLLTE die Authentifizierung der Server-Zertifikate über das DNS aktivieren.

Guidance

Die Authentifizierung der Server-Zertifikate über das DNS (Domain Name System) kann die Sicherheit der E-Mail-Kommunikation erheblich steigern. Dabei werden Zertifikatsinformationen in DNS-Einträgen genutzt, um die Echtheit der TLS/SSL-Zertifikate eines E-Mail-Servers zu überprüfen und sicherzustellen, dass man tatsächlich mit dem beabsichtigten Kommunikationspartner spricht. Techniken wie DANE (DNS-based Authentication of Named Entities) oder CAA (Certificate Authority Authorization) nutzen spezifische DNS-Resource Records (wie TLSA oder CAA Records), um entweder die verwendeten Zertifikate oder die autorisierten Zertifizierungsstellen im DNS zu hinterlegen. Dies kann verhindern, dass ein Angreifer eine gefälschte Identität vortäuschen oder eine Man-in-the-Middle-Attacke durchführen könnte, indem er ein nicht autorisiertes oder kompromittiertes Zertifikat präsentiert. Ohne diese zusätzliche Überprüfung könnte ein Angreifer beispielsweise den E-Mail-Verkehr der Institution abfangen und mitlesen, während er sich als der legitime Server ausgibt. Die Aktivierung dieser DNS-basierten Überprüfung kann also die Vertraulichkeit und Integrität der übertragenen E-Mails schützen. Zur Umsetzung werden Informationen über eigene Serverzertifikate im DNS hinterlegt und die Prüfung eingehender E-Mails auf hinterlegte Einträge der sendenden Servers aktiviert.

Control: KONF.13.11 - MTA-STS

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.13 Senden und Empfangen von Nachrichten
UUID: 19e81bd5-20d6-41af-b172-5a3859738a62
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für E-Mail SOLLTE MTA-STS aktivieren.

Guidance

Die Mail Transfer Agent Strict Transport Security (MTA-STS) ist ein wichtiger Standard zur Erhöhung der Sicherheit im E-Mail-Verkehr, der die verschlüsselte Zustellung von Nachrichten durch die Erzwingung von Transport Layer Security (TLS) auf der Übertragungsebene gewährleistet. MTA-STS stellt dabei sicher, dass versendende Mail Transfer Agents (MTA) nur verschlüsselte Verbindungen zum Ziel-MTA aufbauen, wodurch Downgrade-Angriffe oder die Umleitung auf unsichere Kanäle wirksam unterbunden werden können. Der Zweck dieser Vorschrift liegt darin, die Vertraulichkeit und Integrität von E-Mail-Inhalten während der Übertragung zu schützen. Ohne MTA-STS könnte ein Angreifer die Kommunikation abfangen und den unverschlüsselten E-Mail-Verkehr mitlesen (Eavesdropping) oder die Nachricht manipulieren, bevor sie den Empfänger erreicht. Die Aktivierung kann das Risiko minimieren, dass E-Mails über unsichere oder unauthentifizierte Verbindungen übertragen werden, selbst wenn die Ziel-Institution TLS unterstützt, was einen robusten Schutz gegen gängige Man-in-the-Middle-Angriffe bietet. Obwohl DNS-Based Authentication of Named Entities (DANE) eine stärkere kryptografische Authentifizierung des TLS-Zertifikats des Ziel-MTA bietet, sollte MTA-STS zusätzlich aktiviert werden, da es eine alternative oder ergänzende Schutzschicht darstellt, falls DANE beim Kommunikationspartner noch nicht implementiert ist oder dessen DNS-Sicherheit (DNSSEC) nicht vertrauenswürdig ist.

Control: KONF.14.1 - Verschlüsselung beim Transport

Tags: "Produktbeschreibung" "Cryptography" "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.14 Verteilte Anwendungen
UUID: 99806244-514d-43e2-be34-4ac7ab0517ad
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung

Statement

Konfiguration für Anwendungen SOLLTE Kommunikation beim Transport über Netze nach {{ insert: param, konf.14.1-prm1 }} verschlüsseln.

Guidance

Werden Daten unverschlüsselt übertragen, so könnten sie abgehört oder unbemerkt manipuliert werden. Relevant sind hierbei alle von der Anwendung übertragenen Daten, inklusive Authentifizierung an der Benutzerschnittstelle oder API, Abruf von Daten, Server-Server-Replikation oder zur Datensicherung. Das betrifft sowohl Inhalts- als auch Metadaten. Die Umsetzung kann mit Algorithmen zur Transportverschlüsselung wie Transport Layer Security (TLS) oder Ende-zu-Ende-Verschlüsselung erfolgen. Für aktuelle Verschlüsselungsverfahren siehe BSI TR-02102. Die Konfiguration der Verschlüsselung kann sich daran orientieren, wie lange die transportierten Daten, z.B. Transaktionen, vertraulich zu behandeln sind. Eine Herausforderung hierbei sind Anwendungen, die über allgemeine Anbindungen mit anderen Institutionen kommunizieren, z.B. E-Mails oder Anrufe ins öffentliche Telefonnetz. Diese Anwendungen können nur ihren Teil der Verbindungsstrecke verschlüsseln, so dass der Rest der Strecke und damit die Verbindung an sich dennoch unverschlüsselt sein könnte. Überträgt die Anwendung keine schützenswerten Daten über das Netz, so ist die Anforderung entbehrlich.

Control: KONF.14.1.1 - Obligatorische Verschlüsselung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.14 Verteilte Anwendungen
Übergeordnetes Control:
KONF.14.1 Verschlüsselung beim Transport
UUID: b73c400e-b4f8-494c-ac02-619258f77a2d
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Anwendungen SOLLTE unverschlüsselte und anfällige Verbindungen über Netze deaktivieren.

Guidance

Obligatorische Verschlüsselung bedeutet, dass die Anwendung ausschließlich nach dem Stand der Technik verschlüsselt kommuniziert. Unverschlüsselte oder mit bekannten Methoden angreifbare Verbindungsanfragen werden dagegen abgelehnt. Die Verwendung obligatorischer Verschlüsselung im Internet ist aktuell sehr uneinheitlich: Viele E-Mail-Server z.B. verschlüsseln im Auslieferungszustand nur opportunistisch - also nur wenn der Verbindungsaufbau so funktioniert. Das macht Verbindungen anfällig für Downgrade-Angriffe. Diese lassen sich verhindern, indem unverschlüsselte Verbindungen vollständig deaktiviert werden. Andererseits kann es dadurch auch zu Verbindungsproblemen mit Servern kommen, die überhaupt keine Verschlüsselung mit aktuellen Protokollen unterstützen. Für aktuelle Verschlüsselungsverfahren siehe BSI TR-02102.

Control: KONF.14.1.2 - Ende-zu-Ende-Verschlüsselung

Tags: "Produktbeschreibung" "Cryptography" "Zero Trust"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.14 Verteilte Anwendungen
Übergeordnetes Control:
KONF.14.1 Verschlüsselung beim Transport
UUID: 3e17d0bd-cdec-4d89-b6a6-b2e018009e8f
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Anwendungen KANN die Kommunikation Ende-zu-Ende über Netze verschlüsseln.

Guidance

Eine Ende-zu-Ende-Verschlüsselung stellt sicher, dass auch Server auf dem Weg zwischen den Endpunkten die Kommunikation nicht auslesen können. Die Unterstützung von Ende-zu-Ende-Verschlüsselung unterscheidet sich zwischen verschiedenen Kommunikationsanwendungen noch immer erheblich: Viele E-Mail-Server verschlüsseln gar nicht oder nur bei Verwendung spezieller Erweiterungen so, während viele Messenger-Apps die Ende-zu-Ende-Verschlüsselung ohne Nutzerinteraktion automatisch erzwingen. Dies kann je nach Anwendung z.B. mittels OpenPGP, S/MIME oder Signal Protocol geschehen. Für aktuelle Verschlüsselungsverfahren siehe BSI TR-02102. Für weitere Details zur Telekommunikation siehe "Kompendium für organisationsinterne Telekommunikationssysteme mit erhöhtem Schutzbedarf".

Control: KONF.14.2 - Source Port Randomisierung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.14 Verteilte Anwendungen

UUID: 8cf919ad-46cd-4173-9def-7b84abd6f278

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Konfiguration für DNS-Server SOLLTE Source Port Randomisierung aktivieren.

Guidance

Die mehrfache Verwendung gleicher Source Ports erleichtert Angreifern das Erraten gültiger Antworten, z. B. bei DNS-Spoofing oder Cache-Poisoning-Angriffen. Sourceport-Randomisierung (IETF RFC 5452) erhöht die Anzahl möglicher Kombinationen und erschwert derartige Angriffe.

Control: KONF.14.3 - Iterative Beantwortung

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.14 Verteilte Anwendungen

UUID: 57cb3f3e-bb54-444c-a337-8f098ae085a2

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Konfiguration für DNS-Server SOLLTE die iterative Beantwortung von DNS-Anfragen aus dem Internet aktivieren.

Guidance

Bei iterativen Anfragen kommt die Antwort direkt vom autoritativen Server, statt auf zwischengespeicherte Antworten anderer DNS-Resolver zu vertrauen. Dies reduziert die Angriffsfläche für Cache Poisoning und erschwert DNS-Tunneling zur Datenexfiltration oder Command-and-Control-Kommunikation.

Control: KONF.14.4 - Caching

Tag: "Produktbeschreibung"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.14 Verteilte Anwendungen

UUID: f6f85541-a8ed-46ec-a1f7-ea0281519866

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für Anwendungen von Endgeräten KANN eine Zwischenspeicherung häufig verwendeter Daten aktivieren.

Guidance

Caches sind lokale Zwischenspeicher, die Zugriffe beschleunigen oder bei Netzstörungen ersetzen können. Kann durch Caching-Funktionen auf dem Client, auf Servern in Außenstellen (z.B. Windows BranchCache, Squid Proxy Cache oder CacheFS) oder Caching auf WAN-Netzkomponenten umgesetzt werden.

Control: KONF.14.5 - Zeitüberschreitung von Netzverbindungen

Tags: "Produktbeschreibung" "Phishing" "Replay Attacks" "Session Hijacking"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.14 Verteilte Anwendungen

UUID: 76f6f959-2505-43b4-9e22-3501e32bc0be

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Konfiguration für Anwendungen SOLLTE Netzverbindungen bei Zeitüberschreitung blockieren.

Guidance

Dauerhaft aufrecht erhaltene, ungenutzte Verbindungen erhöhen die Gefahr unbefugter Zugriffe auf die Anwendung oder eines Überlaufens von Systemressourcen.

Control: KONF.15.1 - Begrenzung des Speicherplatzes

Tags: "Produktbeschreibung" "Denial of Service"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.15 Ressourcenauslastung
UUID: 15596e08-6978-4e61-bf6c-63e24575788f
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Anwendungen von Hostsystemen KANN in der Anwendung zur Verfügung stehenden Speicherplatz pro {{ insert: param, konf.15.1-prm1 }} anhand von {{ insert: param, konf.15.1-prm2 }} einschränken.

Guidance

Dies ist besonders in Multi-Tenant-Architekturen relevant, wie sie häufig bei Cloud-Diensten oder SaaS-Anwendungen (Software as a Service) zum Einsatz kommen. Ein solcher maximaler Schwellwert (engl. threshold) könnte beispielsweise 5 GB oder 10 GB betragen und stellt die Obergrenze für den Speicherplatz dar, der einem einzelnen Konto oder Mandanten zugewiesen wird. Die Beschränkung des verfügbaren Speicherplatzes kann verhindern, dass ein einzelnes Konto oder ein Mandant die gesamten Ressourcen des Hostsystems belegt und so die Leistung für andere Nutzer negativ beeinflusst, was zu einer Denial-of-Service-Situation (DoS) führen könnte. Bei der Umsetzung ist es sinnvoll auch ein Benachrichtigungssystem zu etablieren, das Nutzer oder Administratoren informiert, wenn ein Schwellenwert kurz vor der Überschreitung steht. Zudem können automatisierte Prozesse zur Datenbereinigung (data lifecycle management) in Betracht gezogen werden, die ältere oder nicht mehr benötigte Dateien in solchen Fällen archivieren oder löschen, um den Speicherplatz effizient zu nutzen. Die Institution kann auch verschiedene Schwellenwerte für unterschiedliche Kontotypen oder Mandanten festlegen, basierend auf deren spezifischen Bedürfnissen.

Control: KONF.15.2 - Begrenzung der Rechenleistung

Tags: "Produktbeschreibung" "Phishing" "Denial of Service"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.15 Ressourcenauslastung

UUID: 62f53764-d215-4e55-9ad1-7790922620af

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für Anwendungen von Hostsystemen KANN die Rechenleistung einschränken.

Guidance

Kann durch eine Beschränkung der Anzahl verwendeter Rechenkerne, der Rechenleistung pro Rechenkern oder durch eine indirekte Beschränkung (z.B. eine begrenzte Menge an Anfragen oder Eingabetoken) umgesetzt werden. Beispielsweise kann in einem Verzeichnisdienst ein maximaler Schwellwert für die Zeit eingestellt werden, die eine Suchanfrage in Anspruch nehmen darf, um die Auslastung des Verzeichnisdienstes durch einzelne Anfragen nicht zu gefährden.

Control: KONF.15.3 - Denial of Service

Tags: "Produktbeschreibung" "Phishing" "Denial of Service"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: KONF.15 Ressourcenauslastung

UUID: 51947077-3600-48fc-83b0-5d5ff343d706

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Konfiguration für Anwendungen von Hostsystemen KANN Schutzmaßnahmen gegen Denial of Service aktivieren.

Guidance

Denial-of-Service-Angriffe zielen darauf ab, die Webanwendung für legitime Nutzende nicht mehr erreichbar zu machen. Webanwendungen im öffentlichen Interesse sind häufig Ziel derartiger Angriffe. Mechanismen wie Content Delivery Network und Load Balancer können die Lastfähigkeit der Anwendung erhöhen, während Filterfunktionen Angriffsmuster erkennen und aus den Anfragen herausfiltern können.

Control: KONF.15.4 - Überbuchung von virtualisierten Ressourcen

Tags: "Produktbeschreibung" "Hochverfügbarkeit"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: KONF.15 Ressourcenauslastung
UUID: 6cf041a5-163d-4faa-b817-42b35ad681c2
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Konfiguration für Virtualisierungslösungen KANN die Überbuchung von virtualisierten Ressourcen deaktivieren.

Guidance

Die Überbuchung (engl. overcommitment) beschreibt in Virtualisierungslösungen die Zuweisung von mehr virtuellen Ressourcen – etwa CPU-Kernen, Arbeitsspeicher oder Speicherplatz – an virtuelle Instanzen, als physisch tatsächlich vorhanden sind. Dies kann kurzfristig zu einer höheren Auslastung und Dichte von virtuellen Instanzen führen, birgt jedoch das Risiko, dass die zugrunde liegende Hardware unter Last nicht mehr alle angefragten Ressourcen bereitstellen kann. Der Zweck der Anforderung liegt darin, die Stabilität, Verfügbarkeit und Vorhersehbarkeit der virtualisierten Umgebung sicherzustellen. Ohne diese Begrenzung könnte es unter hoher Auslastung zu Leistungseinbrüchen, Systemabstürzen oder inkonsistenten Speicherzuständen kommen, während eine restriktive Konfiguration die Zuverlässigkeit und die Berechenbarkeit der Performance einer virtuellen Infrastruktur deutlich verbessern kann. Eine Institution kann die Umsetzung dieser Vorgabe durch verschiedene Maßnahmen erreichen: (1) In der Hypervisor-Konfiguration kann die Vergabe virtueller CPUs und Arbeitsspeicher exakt auf die physisch vorhandenen Ressourcen begrenzt werden. (2) Es kann sinnvoll sein, Profile oder Templates für virtuelle Maschinen zu nutzen, die konservative Standardwerte vorgeben, sodass die Gefahr unbeabsichtigter Überbuchung reduziert wird.

Control: NOT.1.1 - Verfahren und Regelungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.1 Grundlagen
UUID: 4ae6245b-7608-4c82-94ca-6d8c4678d41f
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- NOT.1.1.1 Dokumentation
- NOT.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.3 Bekanntgabe
- NOT.1.1.4 Business Continuity Management System

Statement

Notfallplanung MUSS Verfahren und Regelungen zur Vorsorge für Notfälle der Informationssicherheit verankern.

Guidance

Für ein Managementsystem der Informationssicherheit ist es erforderlich, dass auch für Notfälle vorgesorgt wird, z.B. durch eine Datensicherung, so dass bei einer Naturkatastrophe wichtige Daten wiederhergestellt werden können. Dies kann durch den Aufbau eines dafür vorgesehenen Managementsystems (BCMS) oder die Umsetzung der einzelnen Anforderungen dieser Praktik geschehen. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte, die bei der Festlegung des Verfahrens zu berücksichtigen sind, ergeben sich aus den Anforderungen dieser Praktik. Es empfiehlt sich ebenfalls Wiederherstellungsmöglichkeiten und Alternativen für administrative Zugänge zu betrachten.

Control: NOT.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: NOT.1 Grundlagen

Übergeordnetes Control:

NOT.1.1 Verfahren und Regelungen

UUID: 2bd99490-8b1e-46bc-8c4a-e9069b61818a

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Notfallplanung MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: NOT.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: NOT.1 Grundlagen

Übergeordnetes Control:

NOT.1.1 Verfahren und Regelungen

UUID: 1077ed85-d0a3-462b-b8fd-107a050b0538

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Notfallplanung MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, not.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, so dass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es die Zuweisung anhand von Rollen (z.B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: NOT.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: NOT.1 Grundlagen

Übergeordnetes Control:

NOT.1.1 Verfahren und Regelungen

UUID: 49ceb0bc-d0bb-42c4-a664-afec3db5de06

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Notfallplanung MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: NOT.1.1.4 - Business Continuity Management System

Info

Control der Klasse "BSI-Stand-der-Technik-Kern"
Gruppe: NOT.1 Grundlagen
Übergeordnetes Control:
NOT.1.1 Verfahren und Regelungen
UUID: 9cfedbf2-6dc8-4ca5-8d93-26610884e3b7
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Notfallplanung KANN ein {{ insert: param, not.1.1.4-prm1 }}BCMS nach {{ insert: param, not.1.1.4-prm2 }} verankern.

Guidance

BCMS steht für Business Continuity Management System, ein Management-System, das Institutionen dabei hilft, die Kontinuität ihrer Geschäftsprozesse bei Störungen oder Krisen sicherzustellen. Es umfasst die Planung, Umsetzung und kontinuierliche Verbesserung von Strategien und Verfahren, um die Resilienz der Institution zu erhöhen und Ausfallzeiten zu minimieren. Beispiele sind der BSI-Standard 200-4 oder die DIN ISO/IEC 22301. Idealerweise werden die Anforderungen der Praktik Notfallplanung durch ein BCMS erbracht. Wenn ein BCMS aufgebaut wird, können die Anforderungen dieser Praktik in das BCMS integriert erfüllt werden. Das BSI empfiehlt dazu in einem ersten Schritt ein Reaktiv-BCMS aufzubauen und mit steigendem Reifegrad ein Standard-BCMS über die Zwischenstufe Aufbau-BCMS anzustreben. Nähere Informationen können dem BSI-Standard 200-4 Kapitel 2.6 BCMS-Stufenmodell (Reaktiv-, Aufbau- und Standard-BCMS) entnommen werden.

Control: NOT.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: NOT.1 Grundlagen

UUID: e7154319-da30-43a0-8b6c-754a1c6c54e3

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Notfallplanung MUSS die Verfahren und Regelungen {{ insert: param, not.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: NOT.2.1 - Verfahren und Regelungen zur BAO

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.2 Besondere Aufbauorganisation
UUID: 7af5bb1b-6d06-443e-8db2-db99e758f03a
Aufwand: 4
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- NOT.2.1.1 Rollen
- NOT.2.1.2 Alarmierung
- NOT.2.1.3 Stabsraum
- NOT.2.1.4 Stabsübung

Statement

Notfallplanung SOLLTE Verfahren und Regelungen für eine Besondere Aufbauorganisation (BAO) zur Behandlung von Notfällen und Krisen verankern.

Guidance

Eine BAO ermöglicht, in Notfällen und Krisen schnellstmöglich auf das Schadensereignis zu reagieren. Eine BAO gehört zu den originären Aufgaben eines BCMS. Wird bzw. wurde ein BCMS nach BSI-Standard 200-4 aufgebaut (unabhängig von der Stufe), so sind die BAO-betreffenden Anforderungen in der Regel erfüllt und werden im Rahmen des BCMS anhand des BSI-Standards 200-4 detaillierter definiert. Nähere Informationen können dem BSI-Standard 200-4 in Kapitel 5 Aufbau und Befähigung der BAO (R+AS) entnommen werden. Die einzelnen Regelungen können den untergliederten Anforderungen entnommen werden.

Control: NOT.2.1.1 - Rollen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.2 Besondere Aufbauorganisation
Übergeordnetes Control:
NOT.2.1 Verfahren und Regelungen zur BAO
UUID: d7b3f904-e7a2-4c80-a739-b41b28e86d7d
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE Aufgaben für die BAO einschließlich BAO-Stab und Notfallteams {{ insert: param, not.2.1.1-prm1 }} zuweisen.

Guidance

Die BAO besteht in der Regel aus einem Stab, der die Koordination und Entscheidungsfindung in einem Schadensereignis übernimmt. Der Stab koordiniert ferner die Tätigkeiten der Notfallteams, die die ausgefallenen Ressourcen wieder anlaufen lassen (= in einen Notbetrieb bereitstellen) und die zeitkritischen Geschäftsprozesse in einem Notbetrieb durchführen und bearbeiten. Nähere Informationen können dem BSI-Standard 200-4 in Kapitel 5.1 Aufbau der BAO (R+AS) entnommen werden.

Control: NOT.2.1.2 - Alarmierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: NOT.2 Besondere Aufbauorganisation

Übergeordnetes Control:

NOT.2.1 Verfahren und Regelungen zur BAO

UUID: f4ae1960-680b-4ebe-8b71-3f88f7b841fc

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE die Alarmierung der BAO verankern.

Guidance

In einem Schadensereignis ist es entscheidend, dass die BAO schnellstmöglich alarmiert wird und somit auch schnellstmöglich Entscheidungen treffen kann. Hierzu bedarf es entsprechender vorab vorbereiteter Alarmierungspfade bzw. Pläne. Diese legen fest, wer die BAO (typischerweise zuerst den Stab und anschließend passende Teams) anhand welcher Kriterien alarmieren kann. In der Praxis haben sich hier abgestufte Verfahren etabliert, die anhand von gezielten Fragen eine Vorfilterung ermöglichen. Nähere Informationen hierzu können dem BSI-Standard 200-4 Kapitel 5.2 Detektion, Alarmierung und Eskalation (R+AS) entnommen werden.

Control: NOT.2.1.3 - Stabsraum

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: NOT.2 Besondere Aufbauorganisation

Übergeordnetes Control:

NOT.2.1 Verfahren und Regelungen zur BAO

UUID: 35391782-f6dc-4eee-b673-bf893500d8b2

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Notfallplanung KANN einen Stabsraum für den Stab installieren.

Guidance

Damit der Stab der BAO im Schadensereignis handlungsfähig ist, benötigt er einen Stabsraum. Der Stabsraum kann ein Raum vor Ort oder eine virtuelle Arbeitsumgebung sein. Nähere Informationen können dem BSI-Standard 200-4 Kapitel 5.6.3 Festlegung eines Stabsraums (R+AS) entnommen werden.

Control: NOT.2.1.4 - Stabsübung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: NOT.2 Besondere Aufbauorganisation

Übergeordnetes Control:

NOT.2.1 Verfahren und Regelungen zur BAO

UUID: c733baed-3cf9-4752-8121-354766e49ab0

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Notfallplanung KANN die Funktionsfähigkeit der BAO {{ insert: param, not.2.1.4-prm1 }} durch Stabsübungen überprüfen.

Guidance

Da Notfälle nur selten vorkommen, die tatsächliche Funktionstüchtigkeit der BAO dann aber von großer Bedeutung für die Informationssicherheit ist, sind regelmäßige Übungen der BAO sinnvoll. Insbesondere die festgelegte Stabsstruktur (Aufgaben und Rollen), sowie das Funktionieren der Ausstattung sind im Ernstfall von großer Bedeutung. Zur Erprobung ist es zweckmäßig bei jeder Übung typische Szenarien im vollständig besetzten Stab durchzuführen und Notfallteams nur je nach passendem Szenario in die Übung einzubeziehen. Ist eine BAO erst aufgebaut worden, genügen für die Stabsübung in der Regel relativ simple Übungsszenarien wie ein Brand im Rechenzentrum oder ein Ransomware-Vorfall. Mit wachsendem Reifegrad der BAO kann anschließend die Komplexität und Realitätsnähe der Übung steigen. Nähere Informationen können dem BSI-Standard 200-4 Kapitel 13.6 Stabsübung (R+AS) entnommen werden.

Links

related: NOT.3.4 Funktionstest

Control: NOT.3.1 - Wiederanlaufplan

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.3 Notfallvorsorge
UUID: cf62902b-ea95-4721-a4be-e58a8a98d0bc
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE einen Wiederanlaufplan für zeitkritische Systeme und Anwendungen dokumentieren.

Guidance

Ein Wiederanlaufplan legt fest, wie eine ausgefallene (IT)-Ressource auf ein vorgeesehenes Notbetriebsniveau innerhalb einer Wiederanlaufzeit durch Notfallteams zur Verfügung gestellt wird. Besteht ein BCMS, dann werden die kritischen Ressourcen innerhalb der Business Impact Analyse identifiziert und in dieser entsprechende Wiederanlaufzeiten festgelegt. Die ausgewählten BC-Strategien des BCMS bieten ferner den Rahmen für die Wiederanlaufplanung. Besteht kein BCMS, dann können die zeitkritischen IT-Ressourcen anhand der Schutzbedarfsfeststellung (erhöhter Schutzbedarf in der Verfügbarkeit) identifiziert werden. Die Wiederanlaufzeit kann dann nur grob anhand der Ergebnisse der Informationssicherheitseinstufung geschätzt werden. Zeitkritisch sind IT-Systeme und Anwendungen genau dann, wenn ihre fortlaufende Verfügbarkeit für die Aufrechterhaltung des Geschäftsbetriebes auch im Notfall zwingend erforderlich ist. Nähere Informationen können dem BSI-Standard 200-4 Kapitel 12 Wiederanlauf- und Wiederherstellungsplanung (AS) entnommen werden.

Control: NOT.3.2 - Geschäftsfortführungsplan

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.3 Notfallvorsorge
UUID: 8bc54377-0002-4533-bbdd-44777e4f5d2f
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Notfallplanung KANN einen Geschäftsfortführungsplan für zeitkritische Geschäftsprozesse dokumentieren.

Guidance

Ein Geschäftsfortführungsplan (GFP) legt fest, wie ein Geschäftsprozess in einem Notfall in einem Notbetrieb durchgeführt wird. Der Notbetrieb weicht in der Regel vom Normalbetrieb ab, z.B. indem ein geringes Geschäftsniveau (Notbetriebsniveau) angesetzt wird und/oder abweichende Ressourcen eingesetzt werden. Abweichende Ressourcen könnten darin bestehen, dass ein zuvor digital unterstützter Prozess wieder analog durchgeführt wird. Geschäftsfortführungspläne liegen in der grundlegenden Verantwortung eines BCMS und sind daher im Rahmen des ISMS nur optional. Die Ausgestaltung, Planung und näheren Anforderungen der Geschäftsfortführung werden in der Regel im Rahmen des BCMS durchgeführt. Nähere Informationen können dem BSI-Standard 200-4 Kapitel 11 Geschäftsfortführungsplanung (R+AS) entnommen werden.

Control: NOT.3.3 - Sensibilisierung zum Vorgehen im Notfall

Tag: "Kompetenzmanagement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.3 Notfallvorsorge
UUID: eae617b-d2db-48b3-8042-67098ad56bc5
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung für Nutzende SOLLTE zur Vorgehensweise in Notfällen und Krisen sensibilisieren.

Guidance

Eine Sensibilisierung für die Vorgehensweise in Notfällen und Krisen (Contingency Training) stellt sicher, dass alle zuständigen Stellen ihre Aufgaben bei einem Schadensereignis kennen. Zweckmäßig ist es, die Detailtiefe der Sensibilisierung auf die unterschiedlichen Aufgaben bei einem Schadensereignis zuzuschneiden. Beispielsweise genügt es für manche Mitarbeitenden zu wissen, welche Erreichbarkeit bei einem Schadensereignis von ihnen erwartet wird.

Control: NOT.3.4 - Funktionstest

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.3 Notfallvorsorge
UUID: 0c39ea3f-c7aa-47dc-9adb-dfaeac52d716
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Notfallplanung KANN die tatsächliche Funktionstüchtigkeit von Notfallplänen {{ insert: param, not.3.4-prm1 }} überprüfen.

Guidance

Eine regelmäßige Überprüfung hilft zu erkennen, ob die verschiedenen Notfallpläne (z. B. Wiederanlaufplan, Geschäftsfortführungsplan) und Notbetriebsressourcen tatsächlich funktionieren und die Zuständigen die Verfahrensweisen beherrschen. Mit der tatsächlichen Funktionstüchtigkeit ist gemeint, dass nicht nur die Aktualität der Pläne theoretisch betrachtet wird, sondern soweit möglich auch die konkreten Ressourcen geprüft werden (z.B. laufen die Meldewege wie vorgesehen, lassen sich Ausfallleitungen aktivieren, sind Ersatzgeräte nutzbar). Ist hierzu noch nicht die erforderliche Reife erlangt, können in einem ersten Schritt Planbesprechungen, die nur virtuell einen Plan überprüfen, eingesetzt werden. Nähere Informationen können dem BSI-Standard 200-4 Kapitel 13.9 Funktionstest (R optional +AS) und 13.5 Planbesprechung (R optional +AS) entnommen werden.

Links

related: NOT.2.1.4 Stabsübung

Control: NOT.3.5 - Ausweich-Telekommunikation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.3 Notfallvorsorge
UUID: c5c11340-1ae0-4244-8277-b5a5c69d919f
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE Ausweich-Telekommunikationsdienste verankern.

Guidance

„Ausweich-Telekommunikationsdienste“ sind alternative, im Notfall nutzbare Kommunikationswege oder -infrastrukturen, die den Fortbestand kritischer Kommunikationsprozesse gewährleisten können, wenn die primären Dienste kompromittiert oder ausgefallen sind (out-of-band communication). Der Sinn und Zweck der Regelung liegt nicht nur darin, den Informationsaustausch kritischer Geschäftsprozesse im Notfall sicherzustellen, sondern dient auch der sicherheitsbezogenen Koordination und Entscheidungsfindung bei schwerwiegenden Störungen oder Angriffen, etwa bei Ausfällen von Festnetz- oder VoIP-Diensten durch technische Defekte, Naturereignisse oder Cyberangriffe. Eine unzureichende Vorsorge könnte dazu führen, dass im Krisenfall keine Lageabstimmung, Notfallkommunikation oder Meldung an Sicherheitsbehörden möglich ist, oder dass Angreifer die eingeleiteten Gegenmaßnahmen über bereits kompromittierte Dienste mitlesen. Ausweich-Telekommunikationsdienste können z.B. über den Anschluss anderer Anbieter, Mobilfunk oder Satellitenanschlüsse umgesetzt werden. Hierbei ist sowohl an den Netzanschluss kritischer IT-Systeme als auch an die Erreichbarkeit der im Notfall zuständigen Mitarbeiter und Dienstleister zu denken.

Control: NOT.3.6 - Sicherheitsmechanismen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.3 Notfallvorsorge
UUID: f0645a33-62db-46f5-9153-1ee8833eba34
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE alternative Sicherheitsmechanismen , die in Notfällen greifen, verankern.

Guidance

In Notfällen besteht das Risiko, dass manche Sicherheitsvorkehrungen nicht zur Verfügung stehen. Alternative oder ergänzende Sicherheitsvorkehrungen können in Notfällen helfen die Balance zwischen Vertraulichkeit, Integrität und Verfügbarkeit aufrechtzuerhalten (z.B. Einmalpasswörter, die in einem Safe hinterlegt werden). Hierbei ist insbesondere daran zu denken, dass alternative Sicherheitsvorkehrungen nicht die im Normalbetrieb verwendeten Sicherheitsvorkehrungen untergraben.

Control: NOT.4.1 - Dokumentation der Quellen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: db78cca2-d85a-443d-8198-b5fa84d58b9d
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE die zu sichernden Daten dokumentieren.

Guidance

Datensicherungen dienen der Wiederherstellung von Daten nach Vorfällen. Aufgrund der besonderen Bedeutung fordert auch die ISO/IEC 27001 die Sicherung von Informationen in Übereinstimmung mit themenspezifischen Regelungen zur Datensicherung. Hierzu gehört die Regelung, welche Daten konkret gesichert werden (Quellen, Kategorien oder Klassifikation der Daten, Umfang). Relevant sind dabei auch Daten, die bei Dienstleistern oder in der Cloud aufbewahrt werden. Die Datensicherung kann auch durch die Sicherung ganzer IT-Systeme, Datenträger oder Netzlaufwerke umgesetzt werden. Es empfiehlt sich auch zu prüfen, wie die Institution ihre Daten, welche bei einem Outsourcing Dienstleister liegen, sichern will. Es ist möglich eine Datensicherung durch den Dienstleister oder auch bei sich selbst zu erstellen.

Control: NOT.4.2 - Sicherung des Systems

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: a77c3a5e-44fc-482c-974a-e4d9dc7cd255
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung für IT-Systeme SOLLTE deren Datensicherung {{ insert: param, not.4.2-prm1 }} ausführen.

Guidance

Zu den erforderlichen Daten können z.B. Konfigurationsdateien des Betriebssystems, Firmware, Lizenzen, Treiber und die Systemdokumentation gehören. Bei gleichartigen Systemen kann die Anforderung auch durch die Sicherung einer Kopie erfolgen, wenn mit dieser alle IT-Systeme dieser Art funktionsfähig wiederhergestellt werden können. Die Anforderung kann auch durch die Wiederherstellung aus einem Versionskontrollsystem erfolgen.

Control: NOT.4.3 - Sicherung der Anwendung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: dcfb7d28-71df-45f4-ada5-a284415e8c90
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung für Anwendungen SOLLTE deren Datensicherung {{ insert: param, not.4.3-prm1 }} ausführen.

Guidance

Hierzu können z.B. sowohl die Daten einer Backend-Datenbank, als auch Konfigurationsdateien oder Sicherheitseinstellungen gehören. Bei einer Verzeichnisdatenbank z.B. sind typischerweise sowohl die eigentlichen Verzeichniseinträge wie Benutzer & Gruppenzugehörigkeiten, als auch Metadaten wie Benutzerattribute, Gruppenrichtlinien und Informationen zur Integration von Drittdiensten erforderlich, um die Verzeichnisdatenbank funktionsfähig wiederherzustellen.

Control: NOT.4.4 - Automatische Datensicherung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: 20fa9557-7db9-4367-9592-35ca5d8e8be7
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung für Daten SOLLTE die Datensicherung durch {{ insert: param, not.4.4-prm1 }} ausführen.

Guidance

Ein automatisierter Mechanismus (engl. automated mechanism) ist hier ein technisches Verfahren, das ohne manuelles Zutun in festgelegten Intervallen oder bei bestimmten Ereignissen Sicherungskopien von Daten erstellt und dokumentiert. Er kann z. B. über Skripte, Backup-Software oder systemeigene Dienste umgesetzt werden, die regelmäßig und zuverlässig ausgeführt werden. Der Zweck solcher Mechanismen liegt darin, menschliche Fehlerquellen und Auslassungen zu vermeiden, denn eine manuelle Sicherung könnte in Stresssituationen übersehen werden oder unvollständig sein. Die Vorgabe kann so verhindern, dass im Falle von Schadsoftwarebefall oder Hardwareausfall kritische Daten unwiederbringlich verloren gehen, und sie kann eine schnelle Wiederherstellung der Arbeitsfähigkeit nach einem Vorfall ermöglichen. Ohne Automatisierung könnte eine Institution etwa nach einem Ransomware-Angriff feststellen, dass keine aktuelle Sicherung vorliegt. Die Anforderung ist auch dann erfüllt, wenn zusätzlich manuelle Datensicherungen durchgeführt werden.

Control: NOT.4.5 - Archivierung langfristig benötigter Daten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: 90012325-5827-4ad9-bee7-6877a37cecf
Aufwand: 4
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation

Statement

Notfallplanung für Daten SOLLTE die Archivierung langfristig benötigter Daten {{ insert: param, not.4.5-prm1 }} ausführen.

Guidance

Archivierung meint hier die langfristige Aufbewahrung derjenigen Daten, die über längere Zeit benötigt werden, z.B. als Nachweis der Einhaltung rechtlicher Verpflichtungen oder zur Geltendmachung von Ansprüchen. Dabei kann es sich sowohl um analoge Dokumente als auch um digitale Daten handeln. Die meisten Institutionen verarbeiten Daten, die aufgrund von Compliance-Verpflichtungen langfristig gespeichert werden, z.B. handels- und steuerrechtlich relevante Dokumente oder Eigentumsurkunden. Langfristige Daten könnten durch technische Änderungen oder Vorfälle verloren gehen. Zur Umsetzung siehe BSI TR-03125. Sind keine Daten langfristig (z.B. über mehr als 10 Jahre) erforderlich, so ist die Anforderung entbehrlich. Es empfiehlt sich darüber hinaus ein verlustfreies Bildkompressionsverfahren zu nutzen, um eine beweis- und revisionssichere Archivierung zu gewährleisten.

Links

related: ASST.7.2.1 Langfristige Archivierung

Control: NOT.4.5.1 - Zum Archiv gehörende Assets

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
Übergeordnetes Control:
NOT.4.5 Archivierung langfristig benötigter Daten
UUID: 5fda3188-8ad6-4981-953c-975696be1bfc
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung für Daten SOLLTE die Archivierung von Assets, die zur Verwendung von archivierten Daten erforderlich sind, {{ insert: param, not.4.5.1-prm1 }} ausführen.

Guidance

Je nach Art der Daten können zu deren Nutzung z.B. bestimmte (physische oder virtuelle) Assets wie Systeme oder Anwendungen erforderlich sein, z.B. bestimmte Datenbankversionen, kompatible Betriebssysteme und Lizenzen, Anwendungen zur kryptographischen Entschlüsselung der Daten, Konfigurationsdateien oder Betriebsparameter. Wenn Daten für eine lange Zeit aufbewahrt werden, könnte es vorkommen, dass sie nicht mehr lesbar und reproduzierbar sind, weil diese Assets nicht mehr existieren und auch nicht mehr beschafft werden können.

Control: NOT.4.5.2 - Zum Archiv gehörende Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
Übergeordnetes Control:
NOT.4.5 Archivierung langfristig benötigter Daten
UUID: c8feda1f-4d2c-4831-9822-04be256e9e51
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung für Daten SOLLTE die Archivierung von Dokumentationen, die zur Verwendung von archivierten Daten erforderlich sind, {{ insert: param, not.4.5.2-prm1 }} ausführen.

Guidance

Hierbei geht es darum, nicht nur die Daten selbst, sondern auch alle begleitenden Informationen („metadata“ oder „supporting documentation“) regelmäßig zu sichern, um deren spätere Nutzbarkeit zu gewährleisten. Dokumentationen sind in diesem Zusammenhang beispielsweise Bedienungsanleitungen, technische Spezifikationen, Konfigurationsdateien oder Verfahrensanweisungen, die notwendig sind, um archivierte Daten auch nach Jahren noch korrekt zu interpretieren oder wiederherzustellen. Die Frequenz ist dabei abhängig von der Kritikalität der Daten und der Änderungsfrequenz der begleitenden Dokumente. Ohne solche begleitenden Unterlagen könnte ein Datenbestand zwar vorliegen, aber praktisch unbrauchbar sein, da die nötigen Kontexte oder technischen Details fehlen.

Control: NOT.4.6 - Geschützte Aufbewahrung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: ac46110b-7f7f-4111-b7e8-5abf648563b9
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE eine geschützte Aufbewahrung von Datensicherungen verankern.

Guidance

Eine geschützte Aufbewahrung von Datensicherungen bedeutet, dass Sicherungskopien nicht nur vorhanden sind, sondern auch vor Verlust, Manipulation, versehentlicher Löschung oder unbefugtem Zugriff bewahrt werden. Dabei wird berücksichtigt, dass Datensicherungen häufig ein attraktives Ziel für Angriffe darstellen und gleichzeitig im Notfall die einzige Möglichkeit zur Wiederherstellung von Systemen und Daten sein können. Beispiele für Schutzmaßnahmen sind die Ablage von Sicherungsmedien in feuer- und wasserfesten Tresoren, die Nutzung getrennter Räumlichkeiten oder externer Rechenzentren mit physischen Sicherheitsvorkehrungen sowie die Verschlüsselung von Backups, wenn diese an externen Standorten oder in Cloud-Umgebungen gespeichert werden. Auch organisatorische Maßnahmen wie eine klare Regelung, wer Zugriff auf die Sicherungen erhält, tragen zum Schutz bei.

Control: NOT.4.7 - Versionierte Datensicherung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: 7c3570d6-8230-42ca-a79e-d198cc7e7744
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE eine Versionierung der Datensicherung verankern.

Guidance

Versionierung ist die Aufbewahrung nach Zeitpunkten getrennter Versionen der Datensicherung, um auch Daten wiederherstellen zu können, die in der letzten Sicherung bereits gelöscht waren. Bewährt hat sich eine Aufbewahrung von je drei Versionen für die letzten Stunden, dann Tage, dann Wochen, dann Monate – soweit nach Compliance-Anforderungen (z.B. Datenschutz) möglich.

Control: NOT.4.8 - Verschlüsselte Datensicherung

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: b443fd60-5e58-454b-8d57-baec8a876d22
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE die Datensicherung durch {{ insert: param, not.4.8-prm1 }} verschlüsseln.

Guidance

Die Datensicherung enthält typischerweise eine große Menge schützenswerter Daten. Durch Verschlüsselung wird die Vertraulichkeit und Integrität geschützter Informationen auch nach einem schwerwiegenden Vorfall gewährleistet. Dies kann besonders bei einem Datenleck (engl. Data Breach) oder Diebstahl von Speichermedien helfen, da die Offenlegung sensibler Daten selbst bei unbefugtem Zugriff verhindert werden kann. Für anerkannte Algorithmen siehe BSI TR-02102. Technisch kann die Festplattenverschlüsselung auf dem Sicherungsspeicher (Disk Encryption) genutzt werden, aber auch die dateibasierte Verschlüsselung jedes einzelnen Sicherungs-Archives. Wichtig ist es, dabei auch auf die Verwaltung der kryptographischen Schlüssel (Key Management) zu achten, damit diese weder einem unbeugten Zugriff ausgesetzt sind, noch der Zugriff auf die Datensicherung im Ernstfall durch fehlende Zugangsdaten unmöglich wird.

Control: NOT.4.9 - Speichermedien

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: 10c6fc65-f0f6-4ed2-9f47-65458aeb1e51
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE dedizierte Speichermedien, die für den festgelegten Aufbewahrungszeitraum geeignet sind, installieren.

Guidance

Dedizierte Speichermedien (engl. dedicated storage media) sind physische oder virtuelle Datenträger, die ausschließlich für Sicherungs- oder Wiederherstellungszwecke genutzt werden und nicht mit produktiven Systemen vermischt sind. Der festgelegte Aufbewahrungszeitraum (engl. retention period) bezeichnet den Zeitraum, in dem gespeicherte Sicherungen oder Kopien revisionssicher und lesbar verfügbar bleiben sollen, beispielsweise mehrere Monate für kurzfristige Recovery-Szenarien oder mehrere Jahre zur Abdeckung regulatorischer Anforderungen. Die Vorschrift zielt darauf ab, dass im Notfall tatsächlich auf funktionierende und vollständige Sicherungen zurückgegriffen werden kann; sie adressiert Risiken wie, dass Daten im Ernstfall durch unzuverlässige oder beschädigte Medien unbrauchbar sein könnten, oder dass durch unzureichende Haltbarkeit von Speichermedien eine Wiederherstellung scheitern könnte. Je nach Zeitraum und Platzbedarf bieten sich z.B. solider Festspeicher, Festplatten, Magnetbänder oder Cloudspeicher an. Bei der Nutzung von Cloudspeichern sind allerdings auch die zusätzlichen Anforderungen an Cloud-Dienste zu berücksichtigen.

Control: NOT.4.10 - Getrennte Aufbewahrung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: c272387e-88de-4794-a223-c502c136a501
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE die Datensicherung getrennt von den Originaldaten platzieren.

Guidance

Originaldaten (engl. primary data) sind die produktiven oder operativen Daten, die unmittelbar für die laufenden Geschäftsprozesse verwendet werden. Die Anforderung adressiert damit, dass Kopien oder Sicherungen nicht am gleichen Ort wie die produktiven Systeme und deren Speicher verbleiben. Hintergrund ist, dass ein Vorfall wie ein Brand, ein Wasserschaden oder ein gezielter Einbruch gleichzeitig sowohl die produktiven Systeme als auch die dort aufbewahrten Sicherungen betreffen könnte, wodurch eine Wiederherstellung unmöglich wäre. Die physische Trennung kann dagegen die Verfügbarkeit und Wiederanlaufbarkeit der Daten nach einem Schadensereignis sicherstellen. Die Anforderung gilt auch für die Aufbewahrung bei Cloud-Diensten: Eine Aufbewahrung der Datensicherung bei einem Dienstleister, bei dem auch die Originaldaten liegen, erfüllt die Anforderung NICHT. Bei der getrennten Aufbewahrung von Datensicherung sind häufig praktische und sicherheitsrelevante Herausforderungen zu beachten: Ein ausgelagerter Speicherort ist in gleichem Maße schutzbedürftig gegenüber unbefugtem Zugriff wie der Standort der Originaldaten, da sich darauf oft vollständige und aktuelle Kopien sensibler Informationen befinden. Zudem sind längere Wiederanlaufzeiten möglich, wenn der externe Standort nicht unmittelbar erreichbar ist oder wenn logistische Verzögerungen beim Zugriff auf die ausgelagerten Datenträger auftreten. Auch die Gefahr von Inkonsistenzen steigt, wenn Backups zwar ausgelagert, aber nicht regelmäßig synchronisiert oder bei der Überprüfung beachtet werden.

Control: NOT.4.11 - Datenträgerarchiv

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: a7779b58-de2c-4f8c-aedd-008bdffcc823
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE ein Datenträgerarchiv installieren.

Guidance

Datenträgerarchive sind verschlossene Räume, die dediziert zur langfristigen Aufbewahrung von Datenträgern bestimmt sind. Die Anforderung gilt auch dann als umgesetzt, wenn zusätzlich zur Datensicherung im Datenträgerarchiv auch noch Kopien existieren, die nicht im Datenträgerarchiv aufbewahrt werden. Ein wesentlicher Mehrwert von Datenträgerarchiven ist die geschützte Aufbewahrung. Daher zählt ein Datenträgerarchiv nur dann als Mehrwert, wenn das Archiv sich auch in einem anderen Brandabschnitt befindet als die Originaldaten.

Control: NOT.4.12 - Georedundanz

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: d0538604-ab92-44f7-a018-a1b32195bc22
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Notfallplanung KANN die georedundante Aufbewahrung mindestens einer Kopie der Datensicherung verankern.

Guidance

Werden Datensicherungen in der Nähe von Originaldaten aufbewahrt, so könnten beide von Elementaren Gefährdungen wie Überflutungen betroffen sein. Georedundant bedeutet in der Regel 200km Luftlinie oder mehr von den Originaldaten entfernt. Details siehe BSI Kriterien für die Standortwahl von Rechenzentren. Die Anforderung kann auch durch die gegenseitige Aufbewahrung in georedundanten Rechenzentren erfüllt werden.

Control: NOT.4.13 - Datensouveränität

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: 13789041-edcf-4270-a8d1-49bdd0d54ab4
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung für Outsourcing SOLLTE die Datensicherung von Daten, die bei einem Dienstleister verarbeitet werden, nach {{ insert: param, not.4.13-prm1 }} {{ insert: param, not.4.13-prm2 }} ausführen.

Guidance

Dies dient dazu bei einem Ausfall des Dienstleisters die Daten schnell bei einem anderen Dienstleister oder intern weiterverwenden zu können (Interoperabilität in der Exitstrategie). Anerkannt ist hier ein Format, welches auch bei einem anderen Dienstleister verwendet werden kann. Mögliche anerkannte Standards zum Datenaustausch sind z.B. XML, JSON, YAML, CSV, ODF. Eine Sicherungskopie ist unter eigener Hoheit, wenn sie auf Datenträgern im Besitz der Institution aufbewahrt wird, über die dieser Dienstleister keine Kontrolle hat. Relevant sind dabei auch Konfigurationsdateien, Programmcode und Dokumentationen, die zur Verwendung der Daten erforderlich sind.

Control: NOT.4.14 - Offline-Kopie

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: 3772a701-e5d0-4aee-a393-ad539482eb72
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung für Daten SOLLTE eine Offline-Kopie {{ insert: param, not.4.14-prm1 }} ausführen.

Guidance

Eine Offline-Kopie ist eine Datensicherung, die physisch oder logisch von produktiven Systemen und dem laufenden Netzwerk getrennt ist („offline backup“ oder „air-gapped backup“). „Regelmäßig“ bedeutet, dass die Institution in Abhängigkeit von Verfügbarkeit und Kritikalität ihrer Daten feste Intervalle definiert, beispielsweise täglich, wöchentlich oder monatlich. Der Sinn und Zweck dieser Vorgabe liegt darin, sicherzustellen, dass im Falle von Schadsoftwarebefall oder gezielten Angriffen keine gleichzeitige Kompromittierung aller Sicherungskopien stattfinden kann; ein Angriff könnte sonst auch Backups verschlüsseln oder löschen. Eine Offline-Kopie kann dagegen die Wiederherstellung kritischer Systeme nach einem Ransomware-Angriff oder auch nach einem physischen Ausfall, etwa durch Stromschaden oder Brand, unterstützen. Eine Institution kann dies umsetzen, indem sie (1) Kopien in Papierform oder auf wechselbaren Medien wie externen Festplatten, RDX-Kassetten oder Bändern erstellt, die nach dem Backup-Vorgang vom Netzwerk getrennt und geschützt aufbewahrt werden, (2) Cloud-Backups so konfiguriert, dass sie durch Write-Once-Read-Many-(WORM)-Speicher geschützt und logisch von aktiven Systemen isoliert sind, oder (3) eine Rotation von Datenträgern einführt, bei der Kopien an einem separaten, physischen Standort verwahrt werden.

Control: NOT.4.15 - Vorgehen zur Wiederherstellung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: 895e5e39-01ca-4da0-86aa-d7c2594f7270
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Notfallplanung SOLLTE die Vorgehensweise zur Wiederherstellung dokumentieren.

Guidance

Die Dokumentation der Vorgehensweise zur Wiederherstellung dient dazu, im Notfall eine schnelle und geordnete Wiederinbetriebnahme von IT-Systemen und Daten zu ermöglichen. Ohne eine klare Beschreibung der Abläufe kann es zu Verzögerungen, Fehlern oder widersprüchlichen Handlungen kommen, was die Wiederherstellung erheblich erschwert. In einer solchen Dokumentation werden beispielsweise die Reihenfolge der Wiederherstellung kritischer Systeme, die benötigten Datensicherungen und Speicherorte, die erforderlichen Werkzeuge sowie die zuständigen Rollen und Kontaktwege beschrieben. Ergänzend kann auch festgehalten werden, wie die Funktionsfähigkeit nach der Wiederherstellung überprüft wird. Einfache Beispiele sind Schritt-für-Schritt-Anleitungen für die Rücksicherung bestimmter Anwendungen oder Checklisten, die während des Wiederherstellungsprozesses abgearbeitet werden.

Control: NOT.4.16 - Test der Datensicherung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: 09fe99af-64b5-478f-80c0-c4ea6f6d4561
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- NOT.4.16.1 Test der Wiederherstellung

Statement

Notfallplanung für Daten SOLLTE den Erfolg der Datensicherung {{ insert: param, not.4.16-prm1 }} überprüfen.

Guidance

Die Überprüfung der Vollständigkeit kann durch Statistiken des Datenumfangs plus Stichproben der Daten durchgeführt werden. Ein Integritätstest prüft, ob die gesicherten Daten ohne Änderungen im Vergleich zum Original vorliegen. Hierzu können je nach Daten auch Berechtigungen und Metadaten gehören, wenn diese für die Rücksicherung erforderlich sind (z.B. Wiederherstellung eines Laufwerks mit Ordern die verschiedene Zugriffsberechtigungen haben).

Control: NOT.4.16.1 - Test der Wiederherstellung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: NOT.4 Datensicherung

Übergeordnetes Control:

NOT.4.16 Test der Datensicherung

UUID: 77286239-41b4-49e0-86f7-1b64364d9759

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Notfallplanung für Daten SOLLTE die Wiederherstellung mindestens anhand von repräsentativen Stichproben {{ insert: param, not.4.16.1-prm1 }} überprüfen.

Guidance

Unter „Erfolg der Datensicherung“ ist hier die Vollständigkeit („completeness“) und Integrität („integrity“) der erstellten Backups zu verstehen. Eine fehlerhafte oder unvollständige Sicherung könnte unbemerkt bleiben, wenn nicht aktiv geprüft wird, während eine gezielte Validierung die Sicherheit bietet, dass sich die Daten bei Bedarf in unveränderter Form vorfinden lassen. Damit kann ein gravierender Datenverlust, etwa durch korrupte Sicherungsdateien oder abgebrochene Backup-Jobs, rechtzeitig erkannt und behoben werden. Die Anforderung zielt darauf ab, Risiken durch Scheinsicherheit zu reduzieren – etwa wenn Backup-Prozesse zwar automatisiert laufen, aber unbemerkt leere, fehlerhafte oder inkonsistente Datenbestände erzeugen könnten. Durch eine regelmäßige Überprüfung kann die Institution sicherstellen, dass die gesicherten Daten tatsächlich verwendbar bleiben, und damit das Risiko von Ausfallzeiten oder irreversiblen Informationsverlusten verringern. Konkret umgesetzt werden kann dies z. B., indem (1) Backup-Logs automatisch auf Fehlermeldungen oder Warnungen geprüft werden, (2) Prüfsummenverfahren wie Hashes (z. B. SHA-256) zur Integritätskontrolle eingesetzt werden und (3) stichprobenartige Vergleiche zwischen gesicherten und Originaldateien durchgeführt werden. Die Stichprobe kann sich dabei entweder auf die Wiederherstellung selber (= Wiederherstellung nur einiger Daten) als auch auf den deren Überprüfung (= Öffnen nur einiger Daten) beziehen. Stichproben sind repräsentativ, wenn die Zusammensetzung der Stichprobe von Test zu Test geändert wird und die Wahrscheinlichkeit der Stichprobenauswahl auch der Bedeutung der Daten entspricht. Zweckmäßig ist es

dazu, bei der Stichprobenauswahl den Schutzbedarf der Daten zu berücksichtigen: Für besonders wichtige Systeme wie Verzeichnisdienste und für den Geschäftsbetrieb unerlässliche Daten ist eine häufigere Überprüfung erforderlich als für Daten und Systeme, auf die im Notfall auch verzichtet werden kann. Die Anforderung ist auch erfüllt, wenn statt einer Stichprobe eine vollständige Wiederherstellung vorgenommen und geprüft wird. Die Anforderung ist auch dann erfüllt, wenn die Überprüfung durch aktive Verwendung der Daten nach einer Wiederherstellung erfolgt (z.B. durch Inbetriebnahme neuer Server-Container, die aus einer versionierten Datensicherung automatisch angelegt werden).

Control: NOT.4.17 - Anwendungstest

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: NOT.4 Datensicherung
UUID: 97025637-17d4-48fc-ace6-67f20e7ccee6
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Notfallplanung für Anwendungen KANN deren Funktionsfähigkeit nach Wiederherstellung {{ insert: param, not.4.17-prm1 }} überprüfen.

Guidance

Diese Anforderung zielt darauf ab, die Disaster-Recovery-Fähigkeiten einer Anwendung insgesamt zu gewährleisten. Durch regelmäßige Tests der Wiederherstellung aus Backups wird sichergestellt, dass im Ernstfall (Systemausfall, Datenverlust, Cyberangriff) eine funktionierende Wiederherstellung möglich ist. Dabei wird nicht nur die bloße Wiederherstellung getestet, sondern auch die Funktionalität der wiederhergestellten Anwendung verifiziert – inklusive Datenintegrität und korrekte Übernahme der Konfiguration.

Control: PERS.1.1 - Verfahren und Regelungen

Tag: "Kompetenzmanagement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.1 Grundlagen
UUID: 1ba30bb6-4b83-4e7c-b4f8-10d12531d50b
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- PERS.1.1.1 Dokumentation
- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.1.1.3 Bekanntgabe

Statement

Personal MUSS Verfahren und Regelungen zum Personalmanagement verankern.

Guidance

Der Prozess stellt sicher, dass qualifiziertes und zuverlässiges Personal für alle Aufgaben zur Verfügung steht und allen Beteiligten ihre Aufgaben und Zuständigkeiten bekannt sind. Hierbei sind Einstellung, Einarbeitung, Weiterbildung und Austritt von Mitarbeitenden zu berücksichtigen. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Control: PERS.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: PERS.1 Grundlagen

Übergeordnetes Control:

PERS.1.1 Verfahren und Regelungen

UUID: d7b763ba-c8c0-4c8d-8995-5192df0cce35

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Personal MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: PERS.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: PERS.1 Grundlagen

Übergeordnetes Control:

PERS.1.1 Verfahren und Regelungen

UUID: e72ceb25-e617-43c9-b40f-e9f908580d6b

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Personal MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, pers.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es die Zuweisung anhand von Rollen (z.B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: PERS.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: PERS.1 Grundlagen

Übergeordnetes Control:

PERS.1.1 Verfahren und Regelungen

UUID: 47787c01-426d-4e26-967e-9df678143ac0

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Personal MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: PERS.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: PERS.1 Grundlagen

UUID: f351ba29-d68c-43be-b5e2-0492942c98e4

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Personal MUSS die Verfahren und Regelungen {{ insert: param, pers.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: PERS.2.1 - Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.2 Aufgaben, Rollen, Zuständigkeiten
UUID: 0880e846-6ccf-4231-a71c-5d2b5d4bc97b
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Personal SOLLTE für alle Tätigkeiten im Geltungsbereich Aufgaben mit Abgrenzungen und Schnittstellen verankern.

Guidance

Aufgaben sind die konkreten Tätigkeiten, die für die Errichtung und Aufrechterhaltung des ISMS erforderlich sind, z.B. Netz überwachen, Pentest durchführen, Administration einer bestimmten Fachanwendung. Definieren Sie die Aufgaben so, dass Abgrenzung und Schnittstellen untereinander klar sind. Hierzu kann auf die Praktiken, Zielobjekte und deren Anforderungen zurückgegriffen werden.

Control: PERS.2.2 - Rollen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.2 Aufgaben, Rollen, Zuständigkeiten
UUID: 75dd9995-57e7-4d64-aad3-8b1b0f6b57ea
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Personal SOLLTE für alle Tätigkeiten im Geltungsbereich Rollen mit Zielen, Aufgaben, erforderlichen Kompetenzen und Qualifikationen verankern.

Guidance

Eine Rolle beschreibt eine Stelle oder Personalposition innerhalb des ISMS. Sie benennt die Aufgaben der Position und die dazu erforderlichen Qualifikationsvoraussetzungen. Beispiele: Teamleiter, Entwickler, Admin, Sicherheitsanalyst, Fachaufgabenverantwortlicher.

Links

required: PERS.2.1 Aufgaben

Control: PERS.2.3 - Rollentrennung

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.2 Aufgaben, Rollen, Zuständigkeiten
UUID: e21a20ee-0e0c-4e42-b2fd-9849257bf3da
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests

Statement

Personal SOLLTE für unvereinbare Aufgaben eine Rollentrennung verankern.

Guidance

Bei einer Aufgabentrennung (Separation of Duties) werden miteinander in Konflikt stehende Aufgaben und Verantwortungsbereiche getrennt, um die Möglichkeiten zu unbefugter oder unbeabsichtigter Änderung oder zum Missbrauch zu reduzieren. Unvereinbar sind zwei Aufgaben insbesondere, wenn zwischen ihnen (1.) ein Interessenkonflikt oder (2.) ein erhöhtes Risiko für Datenmissbrauch vorliegt. (1.) Interessenkonflikte können z.B. die Auditierung der eigenen Aufgaben oder der Ergebnisse von Vorgesetzten sein. (2.) Ein erhöhtes Risiko für Datenmissbrauch liegt z.B. vor, wenn sowohl Rechnungsstellung als auch -genehmigung in einer Hand liegen.

Control: PERS.2.3.1 - Rollentrennung - Verzeichnisdienst

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.2 Aufgaben, Rollen, Zuständigkeiten
Übergeordnetes Control:
PERS.2.3 Rollentrennung
UUID: 8cfe386c-0e94-4926-b82d-07d24441e434
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Personal SOLLTE zwischen Administration von Verzeichnisdiensten und Pflege der verwalteten Daten eine Rollentrennung verankern.

Guidance

Administrierende von Verzeichnisdiensten haben sehr weitreichende Rechte, einschließlich der Möglichkeit, Zugangskontrollen zu ändern. Durch eine Rollentrennung wird verhindert, dass eine Person die vollständige Kontrolle über die angebundene Infrastruktur und die Dateninhalte übernimmt. Dies reduziert das Risiko vorsätzlicher und fahrlässiger Schäden an zentraler Stelle.

Control: PERS.2.3.2 - Rollentrennung - Virtualisierung

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.2 Aufgaben, Rollen, Zuständigkeiten
Übergeordnetes Control:
PERS.2.3 Rollentrennung
UUID: e26fc4a9-c6cf-41f8-bfd7-e01cc950de47
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Personal SOLLTE zwischen Administration von virtuellen Systemen und Virtualisierungslösungen eine Rollentrennung verankern.

Guidance

Die Administration von virtuellen Systemen bezeichnet im hier relevanten Kontext die operative Verwaltung einzelner virtueller Gastsysteme (VMs, Container, etc.), einschließlich ihrer Bereitstellung, Konfiguration, Wartung und Zugriffskontrolle. Die Virtualisierungslösung hingegen ist hier die übergeordnete Plattform oder Hypervisor-Ebene, welche physische Ressourcen virtualisiert und mehreren virtuellen Gastsystemen bereitstellt. Diese Differenzierung entspricht dem Prinzip der Rollen- bzw. Funktionstrennung (separation of duties bzw. role separation), bei dem Aufgabenbereiche so abgegrenzt werden, dass keine Person gleichzeitig über kritische Systemebenen hinweg vollumfängliche Kontrolle besitzt. Damit wird ein wesentliches Sicherheitsprinzip technischer Infrastruktur auf die Virtualisierungsschichten übertragen. Der Zweck dieser Trennung liegt in der Begrenzung von Fehlerrisiken und der Prävention von Missbrauch – sowohl vorsätzlich als auch unbeabsichtigt. Eine Person, die zugleich die Virtualisierungsebene und virtuelle Systeme verwaltet, könnte durch Fehlkonfiguration, Nachlässigkeit oder Manipulation unbeabsichtigt erhebliche Auswirkungen auf eine Vielzahl von Systemen haben oder deren Nachvollziehbarkeit beeinträchtigen. Eine klare Rollentrennung kann dem vorbeugen, indem sie Kontrollmechanismen stärkt, die Integrität der Umgebung wahrt und Fehler früher erkennen lässt.

Control: PERS.2.3.3 - Rollentrennung - Audits

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.2 Aufgaben, Rollen, Zuständigkeiten
Übergeordnetes Control:
PERS.2.3 Rollentrennung
UUID: e105f038-c2ae-4411-b7bd-26d6b0188e5e
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Personal SOLLTE zwischen Implementierung von Sicherheitsanforderungen und deren Überprüfung eine Rollentrennung verankern.

Guidance

Fehlt eine Rollentrennung zwischen Umsetzung und Überprüfung von Sicherheitsmaßnahmen, so besteht ein Interessenkonflikt zwischen der Aufgabe korrekter Implementierung und dem Finden von weiterem Verbesserungspotenzial oder Mängeln bei einer Überprüfung.

Control: PERS.2.3.4 - Rollentrennung - Änderungen und Tests

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.2 Aufgaben, Rollen, Zuständigkeiten
Übergeordnetes Control:
PERS.2.3 Rollentrennung
UUID: de64f532-164e-4b94-b32f-481ccc0be507
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Personal SOLLTE zwischen Implementierung und Test eine Rollentrennung verankern.

Guidance

Liegen Implementierung von Funktionen und Änderungen, sowie deren Test in derselben Hand, so werden Probleme durch Nachlässigkeit oder Versehen leicht übersehen.

Control: PERS.2.4 - Zuständigkeiten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.2 Aufgaben, Rollen, Zuständigkeiten
UUID: 349d8caa-cd47-484d-8474-1497c7212382
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Personal SOLLTE Zuständigkeiten für die Rollen zuweisen.

Guidance

Damit die mit jeder Rolle verbundenen Aufgaben auch tatsächlich bearbeitet werden, ist es erforderlich, jeder Rolle eine oder mehrere Personen oder Organisationseinheiten zuzuweisen, die für die mit der Rolle verbundenen Aufgaben zuständig sind. Hierbei ist es wichtig darauf zu achten, dass alle Rollen von ausreichenden Personalressourcen abgedeckt werden. Je nach Rolle können dafür auch Vertretungsregelungen erforderlich sein.

Links

required: PERS.2.2 Rollen

Control: PERS.3.1 - Dienst- oder Arbeitsvertrag

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.3 Personalzugang
UUID: 6d824928-418e-4e14-bbfc-e2f60d14d816
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Personal für Mitarbeitende SOLLTE die vertrauliche Behandlung von Betriebs- und Geschäftsgeheimnissen im Dienst- oder Arbeitsvertrag vereinbaren.

Guidance

Ergänzend zu den gesetzlichen Verpflichtungen zur Wahrung von Betriebs- und Geschäftsgeheimnissen (z.B. aus dem GeschGehG) ist eine explizite Vertraulichkeitsvereinbarung (Non-disclosure Agreement, NDA) mit allen Externen und Mitarbeitenden sinnvoll, die Zugriff auf schützenswerte Informationen erhalten.

Control: PERS.3.2 - Verfahrensanweisungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.3 Personalzugang
UUID: 2bd3c14a-de1c-436e-9400-3ae619ab9b9a
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Personal für Mitarbeitende SOLLTE explizit zur Einhaltung von Verfahrensanweisungen bei Neuzugang anweisen.

Guidance

Wenn neue Mitarbeitende keine explizite Anweisung erhalten, dass Sicherheitsanweisungen existieren und einzuhalten sind, könnte es zu verspäteter Kenntnisnahme der Regelungen und dadurch zu Mängeln in der Einhaltung kommen. Das ist insbesondere bei Mitarbeitenden der Fall, die in manche Informationsverarbeitungsprozesse eingebunden sind, aber keinen Zugang zu Plattformen wie dem Intranet erhalten: Werden Verfahrensanweisungen nur im Intranet abgelegt, aber nicht bei Neuzugang explizit bekannt gegeben, so können diese Personen keine Kenntnis davon nehmen. Die Menge der Verfahrensanweisungen ergibt sich aus den für die jeweilige Tätigkeit relevanten gesetzlichen Anforderungen, sowie den Anforderungen zu den Handlungsworten „anweisen“ und „verbieten“.

Control: PERS.3.3 - Betriebs- und Geschäftsgeheimnisse

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.3 Personalzugang
UUID: 6f72a6a1-b8fc-42e4-b0aa-479b2ad48f40
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Personal für Mitarbeitende SOLLTE zum Umgang mit definierten Betriebs- und Geschäftsgeheimnissen bei Neuzugang anweisen.

Guidance

Eine Dienst- oder Arbeitsanweisung, die zu wahrende Betriebs- und Geschäftsgeheimnisse klar definiert, stellt sicher, dass Mitarbeitende ihre Pflichten genau kennen. Hierbei geht es insbesondere darum, klar zu definieren welche Informationen als Betriebs- und Geschäftsgeheimnisse zu behandeln sind, z.B. Kundendaten, Patente, alle nicht zur Veröffentlichung bestimmten oder mit bestimmten Schutzklassifizierungen versehene Dokumente. Außerdem relevant ist, dass diese Geheimnisse auch über das Ende des Vertragsverhältnisses hinaus zu wahren sind. Hier besteht ein enger Zusammenhang zum Informationsmanagement, wo z.B. auch geregelt wird, welche Anweisungen zum Schutz im Einzelnen einzuhalten sind (z.B. Markierung, Verwahrung). Damit die dort festgelegten Regelungen den Mitarbeitenden auch bekannt sind wird eine entsprechende Anweisung bei Neuzugang benötigt.

Control: PERS.3.4 - Stellenbeschreibungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.3 Personalzugang
UUID: 280066e0-d0e8-4b93-88e9-697852b5873f
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Personal SOLLTE Stellenbeschreibungen vor Ausschreibung zu besetzender Stellen dokumentieren.

Guidance

Eine Stellenbeschreibung ist hier ein Dokument, das die zentralen Aufgaben, Verantwortlichkeiten, Befugnisse und fachlichen sowie sicherheitsrelevanten Kriterien einer Position vor deren Ausschreibung festhält. Der Zweck dieser Anforderung liegt darin, klare Rollen und Verantwortlichkeiten zu definieren, um sowohl Fehlbesetzungen als auch unklare Zuständigkeiten zu vermeiden. Ohne eine dokumentierte Stellenbeschreibung könnte eine Institution Personen einstellen, deren Qualifikation oder Vertrauenswürdigkeit nicht den tatsächlichen sicherheitsrelevanten Kriterien entsprechen, was zu erhöhtem Missbrauchsrisiko oder unzureichender Aufgabenerfüllung führen könnte. Eine sauber ausgearbeitete Stellenbeschreibung kann dagegen Transparenz schaffen, spätere Konflikte reduzieren und die Sicherheit erhöhen, indem bereits im Auswahlprozess klar wird, welche Fachkenntnisse und Integritätsanforderungen benötigt werden. Beachten Sie dabei auch rechtliche Anforderungen wie das AGG. Zur Umsetzung kann eine Institution zunächst ein standardisiertes Format für Stellenbeschreibungen verwenden, in dem u.a. Aufgabenbereiche, Verantwortlichkeiten, sowie erforderliche fachliche und sicherheitsrelevante Qualifikationen erfasst werden. Eine abgestufte Vorlage kann bei unterschiedlichen Rollenarten (z.B. operative Mitarbeitende, Teamleitungen, Fachspezialisten) helfen, die Konsistenz zu wahren. Prozessual kann eine interne Prüfschleife eingerichtet werden, in der HR und die jeweilige Fachabteilung die Beschreibung autorisieren, bevor eine Stelle öffentlich ausgeschrieben wird. Außerdem kann es hilfreich sein, regelmäßig zu prüfen, ob bestehende Stellenbeschreibungen noch zu aktuellen Prozessen und eingesetzten Technologien passen, sodass keine veralteten oder unvollständigen Kriterien in die Rekrutierung einfließen.

Links

required: PERS.2.2 Rollen

Control: PERS.3.5 - Prüfung der Bewerbungsunterlagen

Tag: "Kompetenzmanagement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.3 Personalzugang
UUID: 6c7d319c-9299-4238-be20-11e057a5a7e1
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Personal SOLLTE die Qualifikation von Bewerbenden anhand der Bewerbungsunterlagen vor der Besetzung von Stellen testen.

Guidance

Die Prüfung von Unterlagen zur Qualifikation ist essenziell, um sicherzustellen, dass nur fachlich geeignete Personen Zugang zu sensiblen IT-Systemen und Daten erhalten. Fehlende Qualifikationen erhöhen das Risiko für Bedienfehler oder mangelndes Sicherheitsbewusstsein, was Schwachstellen und Angriffsflächen für Bedrohungen eröffnet. Zudem wird so das Risiko von gezielter Einschleusung von Angreifern verringert. Berücksichtigen Sie dabei die Persönlichkeitsrechte der Bewerbenden.

Control: PERS.3.6 - Vertrauenswürdigkeit von Bewerbenden

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.3 Personalzugang
UUID: 3c93daf0-eb43-4d81-88c5-58d0f21d68eb
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- PERS.3.6.1 Sicherheitsüberprüfung (intern)

Statement

Personal SOLLTE die Vertrauenswürdigkeit von Bewerbenden vor der Besetzung von Stellen testen.

Guidance

Hierbei sind sowohl die Identität der Person, als auch ihre Qualifikation anhand von Nachweisen zu verifizieren. Insbesondere ist zu prüfen, ob der vorgelegte Lebenslauf korrekt, plausibel und vollständig ist. Bei Unklarheiten oder Widersprüchen können die Angaben durch Rückfragen bei der Quelle der Qualifikationsnachweise verifiziert werden.

Control: PERS.3.6.1 - Sicherheitsüberprüfung (intern)

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.3 Personalzugang
Übergeordnetes Control:
PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
UUID: a0b61264-fa20-481e-8d7a-3b0e37cc0a80
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Personal KANN eine Sicherheitsüberprüfung vor der Besetzung von sicherheitsrelevanten Stellen ausführen.

Guidance

Eine Sicherheitsüberprüfung meint die Verifikation von Identität, beruflicher Qualifikation und Verlässlichkeit von allen Personen mit Zugriff auf schützenswerte Informationen, hier konkret der Mitarbeitenden. Bei einer Sicherheitsüberprüfung kann je nach Art der Tätigkeit ein Polizeiliches Führungszeugnis, eine finanzielle Hintergrundprüfung, ein Sicherheitsinterview, eine psychologische Eignungsprüfung, sowie eine Überprüfung von sozialen Beziehungen und Netzwerken sinnvoll sein. Hierbei besteht ein enger Bezug zum Persönlichkeits- und Datenschutzrecht der Betroffenen. Eine sicherheitsrelevante Stelle ist eine Funktion oder Rolle innerhalb einer Institution, die direkt Zugang zu sicherheitskritischen Informationen, IT-Systemen oder Konfigurationen hat und deren Handlungen die Vertraulichkeit, Integrität oder Verfügbarkeit dieser Systeme maßgeblich beeinflussen könnten. Dazu zählen insbesondere (1) der bzw. die Informationssicherheitsbeauftragte, (2) System-, Netzwerk- und Serveradministratoren sowie (3) weitere Administrator*innen mit erhöhten Rechten wie Domain-Admins, Datenbank-Admins oder Security-Engineers, ebenso wie (4) Personen mit Zugriff auf sicherheitskritische Schlüsselmaterialien etwa im Kryptografie- oder Identitätsmanagement. Nicht darunter fallen hingegen Tätigkeiten ohne sicherheitskritischen Systemzugang oder ohne Einfluss auf Sicherheitsfunktionen, etwa Reinigungs- oder Empfangstätigkeiten.

Links

related: BES.4.9 Sicherheitsüberprüfung (extern)

Control: PERS.3.7 - Einarbeitung

Tag: "Kompetenzmanagement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.3 Personalzugang
UUID: 5c23386c-7f57-436a-9906-9b34d4f94462
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Personal für Mitarbeitende SOLLTE eine Einarbeitung bei Neuzugang ausführen.

Guidance

Eine Einarbeitung ist eine strukturierte Vorgehensweise, bei der neue Mitarbeitende mit den relevanten Aufgaben, Zuständigkeiten, Systemen und Sicherheitsanforderungen ihrer Tätigkeit vertraut gemacht werden. Ziel ist es, ihnen nicht nur fachliche Grundlagen, sondern auch die spezifischen Abläufe und Schutzmaßnahmen der Institution zu vermitteln, sodass sie von Beginn an korrekt und sicher arbeiten können. Ohne eine solche Einarbeitung könnte es zu Fehlbedienungen von IT-Systemen kommen, die Sicherheitsvorfälle begünstigen, oder zu Verzögerungen bei der Umsetzung von Aufgaben, die die Verfügbarkeit kritischer Prozesse beeinträchtigen. Eine sorgfältige Einführung kann dagegen das Verständnis für Sicherheitsregeln fördern, den verantwortungsvollen Umgang mit sensiblen Informationen stärken und die Bindung der Mitarbeitenden an die Institution erhöhen. Um die Anforderung umzusetzen, kann die Institution verschiedene Maßnahmen kombinieren: (1) ein strukturiertes Onboarding-Dokument, das die wichtigsten Systeme, Zugriffsrechte und Sicherheitsrichtlinien erklärt, (2) eine begleitende Einführung durch erfahrene Kolleginnen und Kollegen, die praxisnahes Wissen vermitteln, (3) die direkte Integration sicherheitsrelevanter Hinweise in den Arbeitsalltag, etwa durch kurze Erläuterungen beim erstmaligen Zugriff auf sensible Anwendungen oder beim Anlegen von Berechtigungen. Ergänzend kann eine Checkliste genutzt werden, um sicherzustellen, dass alle relevanten Schritte nachvollziehbar abgeschlossen werden. Auch ein „Paten-System“ kann eingesetzt werden, bei dem neue Mitarbeitende für die ersten Wochen eine feste Ansprechperson haben, die Fragen klärt und auf mögliche sicherheitsrelevante Stolperfallen hinweist.

Control: PERS.4.1 - Qualifikationsbedarf

Tag: "Kompetenzmanagement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: PERS.4 Personalentwicklung

UUID: 9c551357-437f-4662-a8b5-0fac98831755

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Personal für Mitarbeitende SOLLTE den Bedarf an Qualifikationsmaßnahmen anhand der Aufgaben {{ insert: param, pers.4.1-prm1 }} überprüfen.

Guidance

Qualifikationsmaßnahmen sind z.B. Zertifizierte Weiterbildungen, interne Schulungen oder universitäre Kurse. Prüfen Sie den Bedarf anhand der Aufgaben der Mitarbeitenden und berücksichtigen Sie dabei die in den Geschäftsprozessen verwendeten IT-Produkte. Zweckmäßig ist es hierzu in jedem Team einen Jahresplan zur Teilnahme an Qualifikationsmaßnahmen zu erstellen.

Control: PERS.4.2 - Rollenspezifische Schulungen und Sensibilisierungen

Tag: "Kompetenzmanagement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: PERS.4 Personalentwicklung

UUID: f5c0d014-bafa-4672-ad7d-fdb1fb16f3c4

Aufwand: 2

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen

Statement

Personal für Nutzende SOLLTE rollenspezifische Schulungen und Sensibilisierungen im Einklang mit den Anforderungen der Praktik Sensibilisierung bei Neuzugang und {{ insert: param, pers.4.2-prm1 }} ausführen.

Guidance

Neue Mitarbeitende könnten ohne gezielte Einführung unbewusst vertrauliche Informationen preisgeben, unsichere Passwörter wählen oder Phishing-Mails öffnen, da ihnen relevante Schutzprinzipien oder Gefährdungen im Kontext ihrer Tätigkeit nicht bekannt sind. Ebenso könnte es bei länger Beschäftigten zu einer „Routineblindheit“ kommen, sodass beispielsweise ungewöhnliche Systemmeldungen nicht mehr ernst genommen oder sensible Daten versehentlich an unberechtigte Personen weitergegeben werden. „Rollenspezifisch“ bedeutet in diesem Zusammenhang, dass die Inhalte der Schulung auf die jeweilige Tätigkeit zugeschnitten werden – eine Person im IT-Bereich benötigt z. B. andere Sicherheitskenntnisse als jemand im Vertrieb oder in der Verwaltung. Beispiele für rollenspezifische Schulungen sind Kurse zum sicheren IT-Betrieb für Administrierende, OWASP® Top 10 Training für Webentwickler und Social Engineering Abwehrtraining für die Institutionsleitung. Eine Institution kann diese Anforderung etwa umsetzen, indem sie standardisierte E-Learning-Module bereitstellt, die durch kurze Praxisszenarien ergänzt werden. Hilfreich ist, die Dauer der Formate überschaubar zu halten, um die Akzeptanz hoch zu halten, und die Wirksamkeit regelmäßig durch Feedback oder kleine Tests zu prüfen. Ebenso kann es

sinnvoll sein, Fachbereiche in die Ausgestaltung einzubinden, damit Beispiele und Szenarien aus dem tatsächlichen Arbeitsalltag stammen. Mitarbeitende, die bereits eine passende Qualifikation erworben haben, können von der Schulung ausgenommen werden.

Links

required: PERS.2.2 Rollen

related: SENS.1.1 Verfahren und Regelungen

Control: PERS.4.2.1 - Produktspezifische Schulungen und Sensibilisierungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: PERS.4 Personalentwicklung

Übergeordnetes Control:

PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen

UUID: 5fa63606-a580-4995-a17e-41f05197ee2c

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Personal für Administrierende SOLLTE produktspezifische Schulungen zum Umgang mit administrativen Werkzeugen bei Neuzugang und dem Einsatz neuer IT-Produkte ausführen.

Guidance

Ziel ist es, den sicheren Umgang mit den in der Institution genutzten administrativen Werkzeugen zu erlernen (z.B. dem genutzten Verzeichnisdienst, Kommandozeilenbefehlen der genutzten Betriebssysteme, Wireshark oder Netzmanagement-Software). Hierzu gehört die Bedienung der jeweiligen Werkzeuge, Aspekte der sicheren Nutzung wie Verschlüsselung und Authentifizierung, die Vermeidung typischer Fehler, sowie der Umgang mit typischen Problemstellungen (Bugfixing). Verfügt die jeweilige Person bereits nachweislich über die Kenntnisse (z.B. passendes Zertifikat) so ist die Schulung für diese Person entbehrlich.

Links

required: PERS.2.2 Rollen

Control: PERS.5.1 - Maßregelung

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.5 Personalbetreuung
UUID: 3f47f4d9-18dc-4887-ba8b-83a32e8e52e0
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Personal SOLLTE ein Verfahren zur Maßregelung verankern.

Guidance

Legen Sie fest unter welchen Voraussetzungen (z.B. Benennung konkreter Pflicht, Nachweis des Verstoßes) welche Maßregelungsmaßnahmen zu ergreifen sind, wenn Mitarbeitende gegen Anweisungen zur Informationssicherheit verstoßen. Maßnahmen können von Mitarbeitergesprächen über der Entzug der Berechtigung zum Zugriff auf vertrauliche Daten bis hin zu Abmahnungen oder Kündigungen reichen. Für arbeitsrechtliche Maßnahmen gilt der Grundsatz der Verhältnismäßigkeit und das Verbot der Maßregelung bei zulässiger Rechtsausübung. Aufgrund des engen Bezugs zum Arbeitsrecht ist im Zweifel eine Rechtsberatung empfehlenswert.

Control: PERS.5.2 - Innentäter

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.5 Personalbetreuung
UUID: 096b2653-f7f6-45db-8a29-088f1bc40ceb
Aufwand: 5
Sicherheitsstufe: normal-SdT

Statement

Personal SOLLTE ein interdisziplinäres Verfahren zum Umgang mit potenziellen Innentätern verankern.

Guidance

Ein interdisziplinäres Verfahren zum Umgang mit potenziellen Innentätern integriert technische Aspekte und organisatorische Aspekte um zielgerichtete Verstöße durch Innentäter so früh wie möglich aufzuspüren und umfassend zu behandeln. Hierzu können beispielsweise die Analyse von Protokollen sowie der Einsatz technischer Detektionssysteme zur Identifikation unerlaubter Nutzung herangezogen werden. Ergänzend dazu dienen organisatorische Meldewege dazu, frühzeitig auf Anzeichen einer länger andauernden systemischen Unzufriedenheit bei Mitarbeitenden reagieren zu können. Maßnahmen bei Aufdeckung können von Mitarbeitergesprächen über den Entzug der Berechtigung zum Zugriff auf vertrauliche Daten bis hin zu Abmahnungen oder Kündigungen reichen. Berücksichtigen Sie bei der Festlegung die Persönlichkeitsrechte der Mitarbeitenden, insbesondere hinsichtlich Arbeitsüberwachung. Aufgrund des engen Bezugs zum Arbeitsrecht ist im Zweifel eine Rechtsberatung empfehlenswert.

Control: PERS.5.3 - Vertrauens-Check sicherheitskritischer Rollen

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: PERS.5 Personalbetreuung

UUID: 76a4233a-f1b4-4e5c-9c53-8c6b7d10ec88

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Personal SOLLTE die Vertrauenswürdigkeit für {{ insert: param, pers.5.3-prm1 }} {{ insert: param, pers.5.3-prm2 }} und anlassbezogen überprüfen.

Guidance

Die Vertrauenswürdigkeit bezeichnet im hier relevanten Kontext die Eignung und persönliche Integrität von Personen, die in besonders sicherheitskritischen Rollen tätig sind – also Funktionen mit erweiterten Zugriffsrechten, administrativen Befugnissen oder Zugang zu sensiblen Informationen und Systemen. Sicherheitskritische Rollen können beispielsweise Systemadministratoren, Personal mit privilegierten Rechten in Cloud-Diensten oder Mitarbeitende im Finanz- und Abrechnungswesen sein. Regelmäßig bedeutet in diesem Zusammenhang, dass eine Überprüfung nicht nur einmalig bei Einstellung, sondern in sinnvollen zeitlichen Abständen erfolgen kann – etwa alle zwei bis drei Jahre oder anlassbezogen, zum Beispiel bei Beförderungen oder einem Wechsel in eine sicherheitsrelevante Funktion. Der Sinn dieser Anforderung liegt darin, Risiken wie Insider-Bedrohungen, Manipulationen oder unbefugte Informationsweitergabe frühzeitig zu reduzieren. So könnte ein Mitarbeiter mit verschuldeten privaten Verhältnissen erpressbar werden und vertrauliche Daten weitergeben, wohingegen eine erneute Vertrauensprüfung kann frühzeitig auffällige Entwicklungen sichtbar machen und das Sicherheitsniveau stabilisieren. Eine Umsetzung kann durch verschiedene Maßnahmen erfolgen, die sowohl technische als auch prozessuale Ansätze kombinieren. Institutionen können beispielsweise (1) Selbstauskünfte oder aktuelle Führungszeugnisse anfordern, (2) regelmäßige Abgleiche mit internen HR-Daten wie Abmahnungen oder Compliance-Verstößen durchführen und (3) strukturierte Interviews oder Fragebögen einsetzen, die Veränderun-

gen in der Lebenssituation mit Relevanz für die Vertrauenswürdigkeit adressieren. Ergänzend kann eine technische Unterstützung durch revisionssichere Dokumentation in HR-Systemen erfolgen, sodass jede Überprüfung nachvollziehbar bleibt. Ein pragmatischer Tipp ist es, Überprüfungen an ohnehin bestehende HR-Prozesse – etwa jährliche Mitarbeitergespräche oder Rezertifizierungen von Zugriffsrechten – anzubinden, um sie effizient und konsistent in den Betriebsablauf zu integrieren. Auf diese Weise kann die Institution die Anforderung praxisnah erfüllen und gleichzeitig den administrativen Aufwand geringhalten.

Control: PERS.6.1 - Vorgehensweise für den Weggang

Tags: "Insider Threat" "Kompetenzmanagement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: PERS.6 Weggang von Mitarbeitenden
UUID: 3ad14c05-a8e1-45de-99bf-c3eecd11f3ae
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung

Statement

Personal für Nutzende SOLLTE eine Vorgehensweise für den Weggang verankern.

Guidance

Wenn Nutzende ohne gesteuertes Vorgehen aus dem Informationsverbund ausscheiden, könnten Zugänge oder Aufgaben unkontrolliert zurückgelassen werden, oder Informationen ungewollt an Dritte abfließen. Hierzu gehört z.B. Mitarbeitende an die Wahrung von Betriebs- und Geschäftsgeheimnissen zu erinnern. Außerdem sind von ausscheidenden Mitarbeitenden alle im Rahmen ihrer Tätigkeit erhaltenen Unterlagen, Schlüssel und Geräte sowie Ausweise und Zutrittsberechtigungen einzuziehen. Hierbei besteht ein enger Zusammenhang zum Berechtigungsmanagement.

Links

related: BER.2.5 Deaktivierung bei Weggang

Control: PERS.6.1.1 - Entzug von Berechtigungen gemäß BER

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: PERS.6 Weggang von Mitarbeitenden

Übergeordnetes Control:

PERS.6.1 Vorgehensweise für den Weggang

UUID: 4954a1d6-d1b5-4e95-9d74-a697e6030a14

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Personal für Nutzende SOLLTE bei Weggang den unverzüglichen Entzug aller Zugriffsrechte im Einklang mit den Regelungen und Verfahren zum Berechtigungs- und Identitätsmanagement verankern.

Guidance

Der unverzügliche Entzug bedeutet in diesem Kontext die sofortige und vollständige Deaktivierung aller Zugriffsrechte, sowohl auf physische Ressourcen (z. B. Gebäude, Serverräume, Schränke mit vertraulichen Unterlagen) als auch auf logische Systeme (z. B. Benutzerkonten in E-Mail-Diensten, ERP-Systemen, Cloud-Speichern). Physische Zugriffsrechte umfassen Schlüssel, Zugangskarten oder Codes, die eine Person nutzen kann, um in geschützte Bereiche zu gelangen. Logische Zugriffsrechte beziehen sich auf digitale Berechtigungen wie Passwörter, Tokens, VPN-Profile oder Single-Sign-On-Zugänge. Der Sinn dieser Vorgabe liegt darin, das Risiko unbefugter Zugriffe nach dem Ausscheiden von Mitarbeitenden oder externen Nutzenden zu minimieren. Ein entlassener Mitarbeitender könnte ansonsten noch Daten aus einer Cloud-Anwendung kopieren oder mit einer Zutrittskarte ein Rechenzentrum betreten. Werden die Rechte dagegen sofort entzogen, kann die Institution die Vertraulichkeit und Integrität sensibler Informationen sichern und zugleich Haftungsrisiken reduzieren. Eine Institution kann diese Anforderung durch abgestimmte technische und prozessuale Maßnahmen umsetzen. Dazu kann ein standardisierter Offboarding-Prozess etabliert werden, der mit der Personalabteilung synchronisiert ist und automatisch IT und Facility-Management informiert.

Links

required: BER.1.1 Verfahren und Regelungen

related: BER.5.8 Entzug von Berechtigungen

Control: PERS.6.1.2 - Neubesetzung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: PERS.6 Weggang von Mitarbeitenden

Übergeordnetes Control:

PERS.6.1 Vorgehensweise für den Weggang

UUID: 8c13947a-ea68-496e-8cdb-c5b807739cc2

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Personal für Mitarbeitende SOLLTE bei Weggang frei gewordene Zuständigkeiten zuweisen.

Guidance

Stellen Sie sicher, dass durch den Weggang von Mitarbeitenden keine Aufgaben des ISMS verwaizen – auch nicht bis zu einer geplanten Neueinstellung. Ordnen Sie stattdessen die Zuständigkeit für die Aufgaben/Rollen unverzüglich bestehendem Personal zu. Achten Sie dabei auch darauf, dass die festgelegten Rollentrennungen dabei nicht aufgehoben, bzw. durchbrochen werden. Um eine kontinuierliche Bearbeitung von Aufgaben sicherzustellen, ist eine Übergabe sinnvoll.

Links

required: PERS.6.1 Vorgehensweise für den Weggang

Control: SENS.1.1 - Verfahren und Regelungen

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.1 Grundlagen
UUID: 445eea0b-00dd-46b6-88f1-6fc12c56335b
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- SENS.1.1.1 Dokumentation
- SENS.1.1.2 Zuweisung der Aufgaben
- SENS.1.1.3 Bekanntgabe

Statement

Sensibilisierung MUSS Verfahren und Regelungen zur rollenspezifischen Schulung und Sensibilisierung verankern.

Guidance

Zweck ist es, internen und externen Nutzenden die korrekte Verarbeitung von schützenswerten Informationen sowie die sichere Bedienung von IT-Systemen und Anwendungen nahezubringen. Ohne Sensibilisierung könnte etwa ein Administrator durch Unachtsamkeit kritische Systemkonfigurationen offenlegen, eine Pflegekraft könnte Patientendaten in unsicheren Kanälen weitergeben oder ein Beschäftigter im Einkauf könnte auf täuschend echt wirkende Phishing-Mails hereinfliegen. Durch passgenaue Schulungen kann dagegen erreicht werden, dass Mitarbeitende die für ihre Aufgaben relevanten Gefahren frühzeitig erkennen, geeignete Schutzmaßnahmen anwenden und damit einen aktiven Beitrag zur Informationssicherheit leisten. Zweckmäßig ist es, im Rahmen der Ersteinweisung dazu Schulungen durchzuführen und um jährliche Information über aktuelle Neuerungen zu ergänzen. Zur Ergänzung und Erinnerung sind z.B. Poster oder Kampagnen sinnvoll. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Links

related: PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen

Control: SENS.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.1 Grundlagen

Übergeordnetes Control:

SENS.1.1 Verfahren und Regelungen

UUID: 8f4b78c1-44fa-4fc1-86d9-c56cee673a8f

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: SENS.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.1 Grundlagen

Übergeordnetes Control:

SENS.1.1 Verfahren und Regelungen

UUID: 9293fc7a-8459-4d4a-a1f3-08b01c03786d

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, sens.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es, die Zuweisung anhand von Rollen (z. B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: SENS.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.1 Grundlagen

Übergeordnetes Control:

SENS.1.1 Verfahren und Regelungen

UUID: 13bf93c2-4f1e-48dd-ab88-61baaa958a41

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: SENS.1.2 - Erfolgsmessung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.1 Grundlagen
UUID: 9d6cd1f9-6aa0-4042-a9dd-9d696a75a6de
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung SOLLTE den Erfolg der Sensibilisierung anhand {{ insert: param, sens.1.2-prm1 }} {{ insert: param, sens.1.2-prm2 }} überprüfen.

Guidance

Zur Erfolgsmessung sind sowohl quantitative als auch qualitative Kriterien heranzuziehen, die unabhängig nachvollziehbar und überprüfbar sind. Erfolg zeigt sich dabei sowohl im erworbenen Wissen der Zielgruppen zur Informationssicherheit als auch in der tatsächlich umgesetzten Praxis von Schutzmaßnahmen.

Control: SENS.2.1 - Schutzziele

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.2 Grundlegende Sensibilisierung
UUID: 3d48b1b4-4896-456f-8c7b-46e0b63a1e68
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zu den Schutzzielen Verfügbarkeit, Vertraulichkeit und Integrität sensibilisieren.

Guidance

Für die grundlegende Schulung kann z.B. auf den Online-Kurs des BSI zum IT-Grundschutz zurückgegriffen werden.

Control: SENS.2.2 - Meldewege

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.2 Grundlegende Sensibilisierung
UUID: 08dde2c0-4676-493f-bf6f-71453113b852
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zu den Meldewegen und Informationsquellen bei Fragen informieren.

Guidance

Zur Bekanntgabe von Meldewegen gehört, welche Meldewege (z.B. Adresse, Rufnummer, Ticketsystem) zur Verfügung stehen und welche weiteren Informationsquellen (z.B. Wissensmanagement im Intranet, Dienstanweisungen, Betriebshandbuch, Chatbots) relevante Informationen zur Informationssicherheit enthalten.

Links

related: SENS.2.8 Melden von Ereignissen

related: DET.2.1 Meldeverfahren

Control: SENS.2.3 - Verschlüsselung und Signatur

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.2 Grundlegende Sensibilisierung
UUID: a3f929a6-2655-4532-84c5-5c985de579bf
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Anwendungen SOLLTE zur Bedienung von Verschlüsselungs- und Signaturfunktionen sensibilisieren.

Guidance

Viele Anwendungen zur Kommunikation bieten Funktionen zur Verschlüsselung oder digitalen Signatur (z.B. Verifikation der Ende-zu-Ende-Verschlüsselung per QR-Code im Messenger, Digitale Signatur von E-Mails). Verschlüsselung kann symmetrisch (gleicher Schlüssel ist auf beiden Seiten bekannt) oder asymmetrisch (ein öffentlicher und ein privater Schlüssel) erfolgen. Digitale Signaturen ermöglichen es, die Herkunft einer Nachricht zu überprüfen und Manipulationen zu erkennen.

Control: SENS.2.4 - Nutzung unautorisierter Assets

Tags: "Bring Your Own Device" "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.2 Grundlegende Sensibilisierung
UUID: 1ca19eb8-f4a2-42b5-85f1-ce96fce606bf
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- SENS.2.4.1 Verbindung unautorisierter IT-Systeme

Statement

Sensibilisierung für Nutzende SOLLTE die Nutzung unautorisierter Assets untersagen.

Guidance

Die Nutzung unautorisierter Assets bezeichnet hier den Einsatz von IT-Systemen, Datenträgern, Anwendungen oder Cloud-Diensten, die nicht durch die Institution freigegeben und inventarisiert sind. Hierzu gehört auch der Anschluss privater Peripheriegeräte wie Tastaturen oder das Telefonieren mit nicht autorisierten Telefonen. Der Sinn und Zweck der Anforderung liegt darin, unkontrollierte Schatten-IT und damit verbundene Risiken zu reduzieren. So könnte etwa ein unautorisiertes USB-Gerät Schadsoftware einschleusen, oder eine nicht genehmigte Cloud-Anwendung könnte zu unbemerkten Datenabflüssen führen. Besteht ein Bedarf an Assets, dann können die festgelegten Meldewege genutzt werden. Bei der Beschaffung von Assets sind die Verfahren und Regelungen des Assetmanagements zu beachten.

Links

required: ASST.3.11 Autorisierung von Systemen

related: KONF.3.7 Einschränkung angeschlossener Peripherie

Control: SENS.2.4.1 - Verbindung unauthorisierter IT-Systeme

Tags: "Bring Your Own Device" "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.2 Grundlegende Sensibilisierung
Übergeordnetes Control:
SENS.2.4 Nutzung unauthorisierter Assets
UUID: 06cf0eba-817a-4dfb-8e8b-b51044cb5a90
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE die Verbindung unauthorisierter IT-Systeme mit internen Netzen oder Schnittstellen untersagen.

Guidance

Unauthorisierte IT-Systeme sind solche, die von der Institution nicht für den Einsatz in den Netzen der Institution vorgesehen sind. Werden solche Geräte mit internen Netzen verbunden, so besteht das Risiko, dass sich hierüber Schadcode verbreitet oder unerwünschte Netzverbindungen aufgebaut werden. Das betrifft sowohl kabelgebundene Verbindungen als auch Funkverbindungen wie WLAN oder Bluetooth.

Control: SENS.2.5 - Zuständigkeitsbereiche

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.2 Grundlegende Sensibilisierung
UUID: 2392c7c3-0d1f-4e7e-9a21-ffca2bf54798
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zu Schutzbedarf und Schnittstellen in ihrem Zuständigkeitsbereich sensibilisieren.

Guidance

Hiermit ist der Schutzbedarf des Zuständigkeitsbereichs des jeweiligen Nutzenden gemeint. Die Schnittstellen zu anderen Zuständigkeitsbereichen und deren entsprechender Schutzbedarf ist ebenfalls zu betrachten.

Control: SENS.2.6 - Umgehung von Sicherheitsfunktionen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.2 Grundlegende Sensibilisierung
UUID: 875e5c3d-64e7-403c-bfc7-456200e5e661
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE gegen die Umgehung von Sicherheitsfunktionen sensibilisieren.

Guidance

Selbst die ausgefeiltesten Sicherheitssysteme werden wirkungslos, wenn Anwender diese durch Eigeninitiative oder mangelndes Verständnis umgehen. Umgehungshandlungen könnten beispielsweise dazu führen, dass Schadprogramme durch Deaktivieren des Virenschutzes ins System gelangen, oder Angreifer über unsichere Verbindungen Zugang erhalten, wenn neue Verbindungen eigenmächtig geschaffen werden. Der Begriff "Umgehung von Sicherheitsfunktionen" umfasst dabei alle Handlungen, bei denen implementierte technische oder organisatorische Schutzmaßnahmen außer Kraft gesetzt, deaktiviert oder auf andere Weise ihrer Schutzwirkung beraubt werden, z.B. durch Rooting/Jailbreaking oder Verwendung nicht autorisierter Anwendungen oder Geräte. Wenn für eine Tätigkeit Funktionen benötigt werden, die durch Sicherheitsmechanismen verhindert werden, ist stattdessen eine Abstimmung über die festgelegten Meldewege sinnvoll.

Control: SENS.2.7 - Änderung von Konfigurationen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.2 Grundlegende Sensibilisierung

UUID: e849100d-2282-4c6a-b1c6-c6ec3999f9dc

Aufwand: 1

Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE gegen die unautorisierte Änderung sicherheitsrelevanter Konfigurationen sensibilisieren.

Guidance

Sicherheitsrelevante Konfigurationen umfassen dabei alle Einstellungen, die direkten Einfluss auf die Sicherheit haben, wie Firewall-Regeln, Benutzerrechte, Verschlüsselungsparameter, Netzwerkkonfigurationen oder Sicherheitssoftware-Einstellungen. Besteht ein Bedarf zur Änderung (z.B. Einschalten bislang deaktivierter Funktionen, Akzeptanz von Verschlüsselungszertifikaten) so ist stattdessen ein Gespräch mit den für Informationssicherheit zuständigen Stellen in der Institution sinnvoll um einen sicheren Betrieb zu ermöglichen.

Control: SENS.2.8 - Melden von Ereignissen

Tag: "Insider Threat"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.2 Grundlegende Sensibilisierung
UUID: fd77e4dd-401d-4b06-a297-bfeded7d53ef
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- SENS.2.8.1 Melden von Fehler- und Warnmeldungen

Statement

Sensibilisierung für Nutzende SOLLTE zum Melden von sicherheitsrelevanten Ereignissen anweisen.

Guidance

Ohne ein Bewusstsein für die Bedeutung solcher Meldungen könnte ein Vorfall wie ein Phishing-Versuch, ein auffälliges Verhalten in einem IT-System oder der Verlust eines mobilen Endgeräts unbemerkt bleiben und gravierende Auswirkungen nach sich ziehen. Umgekehrt kann eine geschulte Aufmerksamkeit verhindern, dass Schwachstellen unentdeckt bleiben, und kann so die Widerstandsfähigkeit der Institution stärken. Sicherheitsrelevante Ereignisse sind hier Beobachtungen oder Abweichungen, die auf eine mögliche Beeinträchtigung der Informationssicherheit hinweisen – beispielsweise technische Probleme wie Systemausfälle und Virenfunde, aber auch verdächtige Aktivitäten von Personen wie z.B. unbefugte Zugriffe auf Systeme oder Daten oder unbekannte Personen in Sicherheitsbereichen. Eine geeignete Umsetzung kann durch unterschiedliche Maßnahmen unterstützt werden: (1) einfache und klar sichtbare Meldewege, z. B. eine zentrale Funktionsmailadresse oder eine Notfallhotline, (2) kurze Schulungen oder Awareness-Kampagnen mit praxisnahen Beispielen, die verdeutlichen, welche Vorfälle gemeldet werden können, (3) niedrigschwellige Hilfsmittel wie Poster, Bildschirm-Hinweise oder Quick-Reference-Karten, die den Meldeprozess in Erinnerung rufen. Für eine Umsetzung kann die BSI IT-Notfallkarte „Verhalten bei IT-Notfällen“ genutzt werden.

Links

required: SENS.2.2 Meldewege

related: DET.2.1.1 Sofortmaßnahmen Nutzender

related: DET.2.1 Meldeverfahren

Control: SENS.2.8.1 - Melden von Fehler- und Warnmeldungen

Tag: "Error Handling"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.2 Grundlegende Sensibilisierung
Übergeordnetes Control:
SENS.2.8 Melden von Ereignissen
UUID: 143c39e7-3bee-42e6-9876-dc55973f2ed4
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zum Melden von Fehler- und Warnmeldungen sensibilisieren.

Guidance

Unerwartete Fehler- oder Warnmeldungen könnten ein Indiz für weitreichendere Störungen oder sogar einen Angriff sein. Das Melden von Fehler- oder Warnmeldungen ist daher im Zweifel eine gute Idee nicht nur um den Betrieb aufrechtzuerhalten, sondern auch um die Informationssicherheit zu gewährleisten.

Links

required: SENS.2.2 Meldewege

Control: SENS.3.1 - Schadprogramme

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.3 Schutz vor Schadprogrammen

UUID: f5f8738d-0c08-4b55-a01a-e8883d6401c8

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE gegen die Risiken von Schadprogrammen sensibilisieren.

Guidance

Viele Dateitypen, wie z. B. Office-Dateien mit Makros, Adobe PDF, .exe, .ps1, oder .vbs, können Schadcode enthalten, der bei Ausführung die Kontrolle über das System übernimmt und Angreifern zur weiteren Ausbreitung im Informationsverbund dient.

Control: SENS.3.2 - Öffnen in der Sandbox

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.3 Schutz vor Schadprogrammen
UUID: fbe194d0-d93c-4fdd-ab18-33df5558e8db
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Sensibilisierung für Nutzende KANN zum Öffnen verdächtiger Dateien ausschließlich auf einem isolierten IT-System (Sandbox) sensibilisieren.

Guidance

Eine Sandbox ist ein isoliertes IT-System, das bewusst so gestaltet ist, dass Dateien oder Programme in einer abgeschotteten Umgebung geöffnet und ausgeführt werden, ohne die produktive IT-Infrastruktur zu gefährden. Damit wird ein geschützter Bereich geschaffen, in dem verdächtige Dateien getestet und beobachtet werden, ohne dass Schadsoftware unkontrolliert in interne Systeme gelangt. Der Sinn dieser Anforderung liegt darin, das Risiko unbewusster Schadcode-Ausführung zu reduzieren: Ein unbedachtes Öffnen von E-Mail-Anhängen könnte beispielsweise zu Verschlüsselung durch Ransomware führen, oder ein manipuliertes Office-Dokument könnte eine unbemerkte Datenabflussschleuse öffnen. Als Sandbox kann auch ein virtuelles System auf dem Endgerät genutzt werden, wenn dieses von der Betriebssystemumgebung des Endgerätes isoliert ausgeführt wird.

Links

related: DET.6.2.2 Datenträgerschleuse

Control: SENS.3.3 - Umwandeln verdächtiger Dateien

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.3 Schutz vor Schadprogrammen
UUID: 8b0d3acb-43d2-460d-bd40-adeb68400c2f
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Sensibilisierung für Nutzende KANN zum Umwandeln verdächtiger Dateien in ein nicht-ausführbares Format vor der weiteren Verwendung sensibilisieren.

Guidance

Das gezielte Umwandeln potenziell schadhafter Dateien in ein nicht-ausführbares Format (engl. defanging) kann helfen, die Ausnutzung von Sicherheitslücken zu verhindern, bevor schädlicher Code aktiv werden kann. Eine Datei gilt dabei als verdächtig, wenn sie aus einer unbekannten oder unzuverlässigen Quelle stammt. Im Kontext dieser Anforderung bedeutet nicht-ausführbares Format (non-executable format), dass die Datei zwar geöffnet oder betrachtet, jedoch nicht direkt ausgeführt werden kann – Beispiele sind PDF ohne eingebettete aktive Inhalte, reines Textformat (.txt) oder Bildformate wie .png/.jpg. Die Umwandlung kann auf unterschiedliche Weise erfolgen, ohne dass dabei möglicher schadhafter Code in der Originaldatei ausgeführt wird. Verdächtige Office-Dokumente können automatisiert in ein PDF umgewandelt oder als Screenshot exportiert werden, bevor der Inhalt zur Ansicht freigegeben wird. Auch das Verwenden von sicheren Cloud-Vorschau-Ansichten, die keine direkte Ausführung erlauben, kann eingesetzt werden. Weitere praktikable Möglichkeiten sind das Umwandeln von ausführbaren Anhängen in komprimierte Archive mit deaktivierter automatischer Entpackung, oder die Nutzung spezieller Konverter-Tools, die potenziell gefährliche Dateiinhalte in ein sicheres Anzeigeformat übertragen. Hilfreich kann auch ein einfaches, intern bereitgestelltes Kurztutorial sein, das typische Umwandlungsschritte für verschiedene Dateitypen erklärt und aufzeigt, woran Nutzende potenzielle Risiken erkennen können.

Control: SENS.4.1 - Personengebundene Authentisierungsmittel

Tags: "Authentication and Authorization" "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.4 Authentisierung

UUID: fbdb73ce-38c5-466f-84a3-218a7d73eda9

Aufwand: 3

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel

Statement

Sensibilisierung für Nutzende SOLLTE zum Umgang mit Authentisierungsmitteln im Einklang mit den zugehörigen Anforderungen des Identitäts- und Berechtigungsmanagements sensibilisieren.

Guidance

Authentisierungsmittel sind alle Methoden oder Technologien, die zur Überprüfung der Identität verwendet werden, z.B. Passwörter, Zugangschipkarte, Ausweis. Um Missbrauch zu vermeiden ist es wichtig, diese (1) geschützt aufzubewahren und niemals weiterzugeben, (2) den Verdacht, dass ein Passwort oder Token kompromittiert sein könnte, sofort zu melden und (3) aufmerksam gegenüber ungewöhnlichen Login-Masken oder Aufforderungen zu sein, die Zugangsdaten außerhalb der gewohnten Systeme einzugeben.

Links

required: BER.7.5 Kriterien für die Qualität von Zufallszahlen

Control: SENS.4.1.1 - Verdeckte Eingabe

Tag: "Shoulder Surfing"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.4 Authentisierung
Übergeordnetes Control:
SENS.4.1 Personengebundene Authentisierungsmittel
UUID: 78719bfb-2d5c-492f-ba02-fc10a0bdf361
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zur verdeckten Eingabe von Zugangsdaten sensibilisieren.

Guidance

Werden Zugangsdaten unverdeckt eingegeben, so könnten diese durch Shoulder Surfing kompromittiert werden, etwa in überfüllten Bereichen, Aufzügen oder während Videokonferenzen. Die verdeckte Eingabe umfasst dabei alle Tätigkeiten, die verhindern, dass Unbefugte die Eingabe von Passwörtern, PINs oder anderen Authentifizierungsdaten visuell erfassen können, sei es durch direkte Sichtbarkeit oder durch das Verfolgen von Handbewegungen und Tastaturanschlägen. Beispiele sind die bewusste Positionierung des Körpers oder der Hand als natürlicher Sichtschutz bei der Eingabe, sowie die Nutzung von Sichtschutzfolien auf Bildschirmen in öffentlichen Bereichen oder beim mobilen Arbeiten.

Control: SENS.4.1.2 - Untersagung von Passwort Recycling

Tags: "Credential Stuffing" "Privilege Escalation" "Password Policy"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.4 Authentisierung
Übergeordnetes Control:
SENS.4.1 Personengebundene Authentisierungsmittel
UUID: 0573247f-65f3-4768-9d27-6c9c0f42c6cd
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE die Wiederverwendung von Passwörtern untersagen.

Guidance

Wiederverwendung von Passwörtern bezeichnet die Nutzung identischer Zugangsdaten für verschiedene Systeme, Dienste oder Anwendungen. Werden identische Passwörter auf unterschiedlichen Systemen eingesetzt, steigt die Wahrscheinlichkeit, dass ein Angreifer mit einem einzigen erlangten Passwort Zugriff auf weitere Konten erhält („Credential Stuffing“). Ein Vorfall könnte beispielsweise darin bestehen, dass ein externer Angreifer durch ein Datenleck bei einem Drittanbieter an ein altes Passwort gelangt und damit Zugang zu internen Diensten erhält, wenn die betroffene Person dieses Passwort mehrfach genutzt hat. Auch im internen Umfeld kann die Wiederverwendung von Passwörtern dazu führen, dass unbefugte Dritte über abgefangene oder mitgehörte Anmeldedaten Zugang zu sensiblen Bereichen erhalten. Die Anforderung zielt also auf eine Reduzierung der Angriffsfläche durch Verhinderung von Kettenreaktionen, die aus nur einem kompromittierten Passwort entstehen können. Mit „Wiederverwendung“ ist sowohl die Verwendung desselben Passworts an verschiedenen Zugangskonten oder IT-Systemen, also auch eine zeitlich wiederholte Nutzung früherer Passwörter gemeint.

Control: SENS.4.1.3 - Wahl von Passwörtern

Tags: "Authentication and Authorization" "Password Policy"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.4 Authentisierung
Übergeordnetes Control:
SENS.4.1 Personengebundene Authentisierungsmittel
UUID: 48c3a712-943d-403e-8e04-cfc11d92a387
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zur Wahl ausreichend komplexer Passwörter sensibilisieren.

Guidance

Ein Passwort ist ein geheimes Zeichenfolgenkürzel, das als Authentisierungsmerkmal dient und typischerweise aus Buchstaben, Ziffern und Sonderzeichen bestehen kann. Komplexität bedeutet hierbei, dass die Passwortstruktur hinreichend schwer zu Erraten oder durch automatisierte Verfahren zu berechnen ist, etwa durch eine gewisse Länge und die Verwendung unterschiedlicher Zeichenarten. Die Komplexität ist ausreichend, wenn sie den festgelegten Qualitätskriterien für Passwörter entspricht. Einfache oder mehrfach genutzte Passwörter könnten durch erraten, Wörterbuchangriffe oder Datenleaks kompromittiert werden und so zu unautorisierten Zugriffen, Datenverlusten oder Identitätsdiebstahl führen. Die bewusste Wahl starker und einzigartiger Passwörter kann hingegen die Widerstandsfähigkeit gegen Angriffe deutlich erhöhen und so einen wesentlichen Beitrag zum Schutz von Daten und IT-Systemen leisten. Zur Umsetzung kann eine Institution verschiedene Maßnahmen einsetzen: (1) praxisnahe Schulungen und E-Learnings, die anschaulich erläutern, warum Passwörter wie „Sommer2023“ leicht angreifbar sein könnten und wie kreative Passphrasen gebildet werden können, (2) begleitende Tipps in Anmeldemaschinen, die Hinweise zur Passwortgestaltung geben, ohne konkrete Vorgaben zu erzwingen, (3) die Empfehlung von Passwortmanagern, die den Umgang mit langen und individuellen Kennwörtern erleichtern, (4) prozessuale Begleitung durch Erinnerungen oder kurze Awareness-Kampagnen, etwa durch Plakate, Newsletter oder interaktive Quizformate. Für mehr Details siehe auch Thema Passwortgebrauch in

der Praktik Berechtigung.

Links

required: BER.6.8 Kriterien für die Qualität von Passwörtern

Control: SENS.4.1.4 - Passwörter nur im Passwortmanager

Tag: "Password Policy"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.4 Authentisierung
Übergeordnetes Control:
SENS.4.1 Personengebundene Authentisierungsmittel
UUID: 7734048a-d797-49f0-87e6-f9c08ce5f5e7
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE das Speichern oder Aufschreiben von Passwörtern außerhalb von Passwort-Managern untersagen.

Guidance

Weil Passwörter komplex sind und an vielen Stellen verwendet werden kommt es immer wieder dazu, dass sie unbedacht auf Zetteln oder in unverschlüsselten Tabellen notiert werden. Werden Passwörter etwa in Office-Listen, im Browser oder auf programmierbaren Tastaturen und Mäusen gespeichert, so könnten Angreifer diese auslesen und zur Ausbreitung auf Systemen und im Netz verwenden. In einem verschlüsselten Passwort-Manager, der nur mit einem Master-Passwort oder Hardwaretoken entsperrt werden kann, können Zugangsdaten dagegen sicher gespeichert werden. Ein Passwortmanager erleichtert es zudem Passwörter zu erzeugen und den richtigen Webseiten und Anwendungen zuzuordnen.

Control: SENS.4.1.5 - Biometrische Authentifikation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.4 Authentisierung
Übergeordnetes Control:
SENS.4.1 Personengebundene Authentisierungsmittel
UUID: 9065b5b9-cf47-40c1-9238-0f3e2f912fb9
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE gegen die Fälschbarkeit von biometrischen Authentifizierungsmerkmalen sensibilisieren.

Guidance

Ein Angreifer könnte z.B. einen Fingerabdruck von einer glatten Oberfläche abnehmen und damit ein Gerät missbräuchlich entsperren.

Control: SENS.4.1.6 - Keine Weitergabe personengebundener Authentisierungsmittel

Tags: "Authentication and Authorization" "Password Policy"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.4 Authentisierung
Übergeordnetes Control:
SENS.4.1 Personengebundene Authentisierungsmittel
UUID: b25f3f5e-0738-4794-b130-cc9a1e29084f
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE die Weitergabe von personengebundenen Authentisierungsmitteln untersagen.

Guidance

Personengebundene Authentisierungsmittel sind z.B. Passwörter, Private PKI-Schlüssel oder Mehr-Faktor-Authentifizierungstoken wie Smartcards.

Control: SENS.4.2 - Mehrfachnutzung von Zugängen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.4 Authentisierung
UUID: 4ee04b8f-c620-4fe0-aa8d-928407cbbd2d
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE gegen die Nutzung eines Zugangskontos durch mehrere Personen sensibilisieren.

Guidance

Insbesondere ist die Nutzung eines Benutzerkontos auf einem Endgerät durch mehrere natürliche Personen problematisch.

Links

related: BER.3.15 Keine Gruppenkonten

Control: SENS.4.3 - Abmelden nach Nutzung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.4 Authentisierung
UUID: 53963d32-edfa-47d4-99ef-1fcb41f00aa8
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zum Abmelden nach Nutzung sensibilisieren.

Guidance

Bleibt eine Sitzung unbeaufsichtigt angemeldet, könnte dies ausgenutzt werden, um Daten zu manipulieren, zu kopieren oder unbemerkt schädliche Aktionen auszuführen. Ein solches Risiko könnte z.B. in offenen Büroflächen, gemeinsam genutzten Arbeitsplätzen oder bei externen Einsätzen entstehen, etwa wenn jemand kurz den Platz verlässt und ein Dritter die Gelegenheit nutzt, um sensible Unterlagen herunterzuladen oder interne Kommunikationskanäle zu durchsuchen. Dies beinhaltet auch die Sperrung des genutzten IT-Systems nach Nutzung. „Abmelden“ bedeutet in diesem Kontext das gezielte Beenden einer aktiven Benutzeranmeldung – etwa durch Ausloggen aus einer Anwendung, Sperren des Betriebssystems oder Abmelden von einem Fernzugriff –, sodass keine offenen Berechtigungen mehr genutzt werden können. Technische Hinweise wie Tastenkombinationen zum schnellen Sperren des Bildschirms oder kurze Anleitungen für den Logout-Prozess in wichtigen Fachanwendungen können in der Nähe von Arbeitsplätzen, auf Intranetseiten oder in E-Learning-Modulen platziert werden, um die Erinnerung daran wachzuhalten.

Control: SENS.5.1 - Datenablage

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.5 Umgang mit Informationen
UUID: 283ea65f-9ace-452c-a2be-38a5c58d3fb3
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zum Einhalten einer strukturierten Datenablage sensibilisieren.

Guidance

Eine strukturierte Datenablage ist eine systematische Organisation von Daten in einer definierten Struktur, z.B. Aktenbestandverzeichnis, Content-Management-System. Dies ist wichtig für eine zentrale Zugriffssteuerung, Datensicherung und effiziente Suche.

Control: SENS.5.2 - Weitergabe von Informationen

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.5 Umgang mit Informationen
UUID: a59c2b01-6240-49ef-b608-a9e3d07476c6
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Informationen SOLLTE zu den Voraussetzungen der Weitergabe von Informationen sensibilisieren.

Guidance

Als "Voraussetzungen der Weitergabe" werden die rechtlichen, vertraglichen, technischen und organisatorischen Bedingungen verstanden, die vor der Übermittlung von Informationen an interne oder externe Empfänger erfüllt sein müssen, um Vertraulichkeit und Compliance zu gewährleisten. So werden unkontrollierte Informationslecks und Compliance-Verletzungen verhindert, indem ein Bewusstsein für die Voraussetzungen geschaffen wird, unter denen Informationen an Dritte übermittelt werden dürfen. Hierzu gehört insbesondere, welche Kategorien von Informationen (z.B. Kundendaten) welchen internen und externen Personengruppen (z.B. Dienstleister) über welche Kommunikationskanäle (z.B. E-Mail, telefonisch) unter welchen Voraussetzungen (z.B. Nennung des Kundenkennwortes) weitergegeben werden dürfen.

Links

related: ASST.3.1.1 Weitergabe nur bei Erforderlichkeit

Control: SENS.5.3 - Weitergabe von Erreichbarkeiten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.5 Umgang mit Informationen
UUID: 8469fae0-3bd3-41d2-a323-af26619e62d2
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Sensibilisierung für Nutzende KANN die Veröffentlichung oder Weitergabe von Erreichbarkeiten an unbefugte Dritte untersagen.

Guidance

Dient dem Schutz vor Social Engineering-Angriffen und der Minimierung von Angriffsflächen durch Informationspreisgabe. Erreichbarkeiten umfassen dabei alle Kontaktinformationen wie Telefonnummern, E-Mail-Adressen, Instant-Messaging-Handles, interne Durchwahlen oder physische Standortangaben von Mitarbeitenden, die Angreifer für gezielte Phishing-Kampagnen, Vishing-Anrufe oder physische Infiltrationsversuche nutzen könnten. Ein Vorfall könnte z.B. entstehen, wenn eine Direktwahl des IT-Betriebs in sozialen Netzwerken preisgegeben wird und Angreifer diese für Pretexting nutzen, um sich als IT-Support auszugeben und Zugangsdaten zu erschleichen, oder wenn durch die Veröffentlichung von Abteilungsstrukturen mit einzelnen Kontaktdaten Angreifer gezielt Führungskräfte für CEO-Fraud identifizieren könnten.

Control: SENS.5.4 - Rest- und Zusatzdaten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.5 Umgang mit Informationen
UUID: ff7cc34b-1d15-42f0-8d2d-2c9dd77d6474
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zur Vermeidung oder Entfernung von Rest- und Zusatzdaten vor dem Versand sensibilisieren.

Guidance

Rest- und Zusatzinformationen sind z.B. die Metadatenfelder in Office- oder PDF-Dateien, sowie die Änderungshistorie.

Control: SENS.5.5 - Löschfristen

Tag: "Password Policy"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.5 Umgang mit Informationen
UUID: 7aed1f72-5233-44dd-8531-b23337c89691
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zum Löschen oder Vernichten nach Ablauf der festgelegten Löschfristen anweisen.

Guidance

Werden sensible Informationen über die erforderliche Dauer hinaus gespeichert, könnte die Institution unnötigen Haftungsrisiken ausgesetzt sein – beispielsweise könnte eine Datenschutzbehörde Bußgelder verhängen, wenn personenbezogene Daten entgegen gesetzlicher Vorgaben zu lange vorgehalten werden. Darüber hinaus könnten nicht rechtzeitig gelöschte Geschäftsgeheimnisse oder Kundendaten bei einem Sicherheitsvorfall in falsche Hände geraten, was zu Reputationsschäden, Vertrauensverlust bei Kunden oder sogar zu Wirtschaftsspionage führen kann. Dies ist insbesondere wichtig bei sensiblen Daten wie Passwörtern im Passwortmanager oder Bankzugangsdaten in einer Kundendatenbank. Relevant ist dabei auch das Verständnis dafür, welche Löschfristen für welche Kategorien von Informationen konkret festgelegt sind und wie die Löschung oder Vernichtung vorzunehmen ist. Zu Details der Vorgehensweise siehe auch Praktik "Informations- und Assetmanagement". Dies gilt auch für den Umgang mit physischen Medien und auch an anderen Standorten, wie z.B. am Mobilen Arbeitsplatz.

Links

required: ASST.7.2 Aufbewahrungs- und Löschfristen

related: ASST.7.3 Geregelttes Löschen oder Vernichten

Control: SENS.5.6 - Papiervernichtung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.5 Umgang mit Informationen
UUID: 72ed03a1-0f7d-49af-ab2b-39a1b73e9b49
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zum Vernichten vertraulicher Dokumente nach Ablauf der Löschfrist sensibilisieren.

Guidance

Gemäß ISO/IEC 21964-2 existieren unterschiedliche Sicherheitsstufen für Vernichtung. Die Granularität der Vernichtung richtet sich dabei nach dem Schutzbedarf der Daten. Sinnvoll ist es daher, das Vorgehen zur Vernichtung an der Einstufung der Daten auszurichten.

Control: SENS.6.1 - Scan angenommener Wechseldatenträger

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.6 Umgang mit Datenträgern
UUID: a2cc232d-ff51-45f0-bfe3-be82d53ca390
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zum Virenskan angenommener Wechsel-
datenträger anweisen.

Guidance

Datenträger, wie USB-Sticks aus unbekannten oder externen Quellen, können Schadprogramme enthalten. Der Virenskan kann durch eine Datenträgerschleuse oder durch eine Virenprüfung im IT-System selbst umgesetzt werden.

Links

related: SENS.2.4 Nutzung unauthorisierter Assets

Control: SENS.6.2 - Verschlüsselung

Tag: "Physical Access Control"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.6 Umgang mit Datenträgern

UUID: ff90bcf5-8c4a-4329-b453-6e77b235687d

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zum Verschlüsseln von Wechseldatenträgern anweisen.

Guidance

Falls Wechseldatenträger zum Austausch vertraulicher Daten verwendet werden, so sind diese vor der ersten Verwendung vollständig zu verschlüsseln. Die Verschlüsselung kann in Hard- oder Software, oder auf Dateiebene erfolgen.

Links

related: SENS.2.4 Nutzung unauthorisierter Assets

Control: SENS.7.1 - Spezifische Sensibilisierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: d988364a-6e20-4f5f-ae5c-dacae6b26cd6
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zu zielobjektspezifischen Schutzmaßnahmen zielgruppengerecht sensibilisieren.

Guidance

Kann dazu beitragen, dass Personen Risiken, die mit ihrer konkreten Tätigkeit, ihrem Arbeitsumfeld oder den von ihnen genutzten Systemen verbunden sind, frühzeitig erkennen und angemessen reagieren können. Ziel ist es auf die spezifischen Schutzbedarfe der jeweiligen Zielobjekte – wie z. B. bestimmte IT-Systeme, Produktionsanlagen, Forschungsdaten oder vertrauliche Kundeninformationen – aufmerksam zu machen. Dazu können sowohl technische als auch organisatorischen Schutzmaßnahmen gehören. Der Begriff „zielgruppengerecht“ meint dabei, dass Inhalte in einer Form, Tiefe und Sprache bereitgestellt werden, die für die jeweiligen Nutzenden verständlich, relevant und handlungsnah sind. Für die Zielgruppengerechtigkeit ist eine Zielgruppenanalyse zweckmäßig. Die Schutzmaßnahmen ergeben sich aus der konkreten Implementierung der Anforderungen durch die Institution.

Control: SENS.7.2 - Virensan

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: b791d70f-b022-4a9e-bcf1-e4406c441981
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Interpersoneller Kommunikation SOLLTE zum Virensan von Dateien aus externen Quellen sensibilisieren.

Guidance

Dateien aus externen Quellen (z.B. per E-Mail oder Messenger) könnten Schadprogramme enthalten. Bevor diese Dateien geöffnet oder anderweitig verarbeitet werden, ist eine Überprüfung mit einem Virenschutzprogramm oder einem dafür vorgesehenen Prüfsystem (z.B. Datenträgerschleuse) vorzunehmen.

Control: SENS.7.3 - Automatische Antworten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 534179b0-fccb-42b5-95b3-e0d5a1778dec
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Interpersoneller Kommunikation SOLLTE gegen die Ausgabe vertraulicher Daten durch AutoReply-Funktionen sensibilisieren.

Guidance

AutoReply-Funktionen – etwa automatische Abwesenheitsnotizen oder Standardantworten in E-Mail- oder Messaging-Systemen – könnten unbeabsichtigt vertrauliche Informationen an unberechtigte Empfänger preisgeben. In der Praxis könnte dies dazu führen, dass sensible Projektdetails, interne Kontaktdaten oder Hinweise auf Abwesenheiten an Angreifer gelangen, die solche Informationen gezielt zur Planung von Social-Engineering-Angriffen oder zur Umgehung von Sicherheitsmaßnahmen nutzen. Im Kontext dieser Anforderung bezeichnet „AutoReply“ die automatische Generierung und Versendung von Nachrichten durch Kommunikationssysteme ohne aktives Zutun der nutzenden Person, typischerweise ausgelöst durch eingehende Nachrichten.

Control: SENS.7.4 - SPAM - Löschen oder Melden

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 93be24dd-88cd-4b1a-b86a-45feb987a4c
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Interpersoneller Kommunikation SOLLTE zum Löschen oder Melden von SPAM sensibilisieren.

Guidance

Spam – also unerwünschte, oft massenhaft versendete Nachrichten – könnte nicht nur den Posteingang überfluten und Arbeitszeit binden, sondern häufig auch Schadsoftware, Phishing-Links oder betrügerische Inhalte enthalten. Werden solche Nachrichten unbeachtet geöffnet oder beantwortet, könnte dies beispielsweise zu einer unbemerkten Offenlegung vertraulicher Informationen, zur Infektion von Endgeräten oder zur Kompromittierung von Benutzerkonten führen. Spam in E-Mails, Chat-Apps oder SMS kann oft an einer Kombination auffälliger Merkmale erkannt werden: (1) unerwartete oder anonyme Absender, (2) untypische Schreibweisen des Namens oder der Adresse, (3) drängender oder alarmierender Tonfall („sofort handeln“), (4) Links mit ungewöhnlichen oder verkürzten Domains, (5) fehlerhafte oder maschinell wirkende Sprache, (6) unpassende Dateianhänge oder Bilddateien sowie (7) Inhalte, die nicht zum bisherigen Kontext der Kommunikation passen. In Chat-Apps und SMS können zudem (8) fremdsprachige Nachrichten ohne Bezug, (9) Einladungen zu unbekannten Gruppen oder (10) Aufforderungen, auf externe Links zu klicken, verdächtig wirken. Das bewusste Hinterfragen solcher Signale kann helfen, Spam frühzeitig zu erkennen und unschädlich zu machen.

Links

required: SENS.2.2 Meldewege

Control: SENS.7.5 - SPAM - Nichtbeantwortung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 0711ec2e-61da-4448-bcc8-464b41154ff1
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Interpersoneller Kommunikation SOLLTE zum Nichtbeantworten von SPAM sensibilisieren.

Guidance

Das Nichtbeantworten von Spam kann dazu beitragen, die eigene Angriffsfläche zu verringern und das Risiko von Folgeschäden zu minimieren. Spam – im Kontext hier als unerwünschte, massenhaft versendete elektronische Nachrichten verstanden, die oft mit betrügerischen oder schädigenden Absichten einhergehen – kann als Einfallstor für Phishing, Schadsoftware oder Betrugsversuche dienen. Eine Antwort, selbst in Form einer scheinbar harmlosen Rückfrage, kann Angreifenden bestätigen, dass die Adresse aktiv genutzt wird, was zu einer Zunahme der Spam-Flut oder gezielten Social-Engineering-Angriffen führen könnte. Spammer erraten Zieladressen oft nur und erhalten durch die Antwort weitere Hinweise auf Angriffsmöglichkeiten (z.B. Schema gültiger Mailadressen, E-Mail-Signaturen, aktive Server).

Control: SENS.7.6 - SPAM - Links

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: bee9f242-644f-40f5-be85-a699c8c383eb
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Interpersoneller Kommunikation SOLLTE gegen das Öffnen von Links in SPAM sensibilisieren.

Guidance

Spam kann Phishing-Versuche enthalten, die zur Preisgabe sensibler Zugangsdaten verleiten, oder auf Webseiten führen, die Schadsoftware ausliefern. Angreifer versuchen oft, ihre Opfer zum unerwarteten Aufruf von Internetseiten zu drängen und nutzen täuschend echt aussehende Webseiten um Zugangsdaten oder IBAN-Nummern abzufischen. Im Zweifelsfall ist es sinnvoll stattdessen sinnvoll, Rücksprache über andere, bereits bekannte Erreichbarkeiten (z.B. Telefonnummer, bekannter Link im Intranet) zu halten und die Echtheit der Nachricht zu verifizieren, oder über die Meldewege einen potenziellen Vorfall zu melden.

Control: SENS.7.7 - SPAM - Anhänge

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 5003cefa-020f-445f-8e23-4add09f63a47
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Interpersoneller Kommunikation SOLLTE gegen das Öffnen von Anhängen in SPAM sensibilisieren.

Guidance

Das Öffnen von Anhängen in unerwünschten oder verdächtigen Nachrichten könnte dazu führen, dass Schadsoftware in die Systeme einer Institution gelangt oder vertrauliche Informationen abfließen. Angreifer versuchen oft, ihre Opfer zum Öffnen von Dateien zu drängen und nutzen diese dann, um Schadprogramme auszuführen. Im Zweifelsfall ist es sinnvoll stattdessen sinnvoll, Rücksprache über andere, bereits bekannte Erreichbarkeiten (z.B. Telefonnummer, bekannter Link im Intranet) zu halten und die Echtheit der Nachricht zu verifizieren, oder über die Meldewege einen potenziellen Vorfall zu melden. Nützlich sind zudem kompakte Checklisten, die die wichtigsten Prüfkriterien vor dem Öffnen eines Anhangs auflisten, wie z. B. die Überprüfung der Absenderadresse, die Plausibilität des Inhalts und die Art der Datei.

Control: SENS.7.8 - Gefälschte E-Mails

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 94709673-e417-4e77-be9e-b17f47cce437
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von E-Mailn SOLLTE zum Erkennen von gefälschten E-Mails sensibilisieren.

Guidance

Spam in E-Mails kann oft an einer Kombination auffälliger Merkmale erkannt werden: (1) unerwartete oder anonyme Absender, (2) untypische Schreibweisen des Namens oder der Adresse, (3) Absendernamen, der nicht zur Absender-Mailadresse passt, (4) drängender oder alarmierender Tonfall („sofort handeln“), (5) Links mit ungewöhnlichen oder verkürzten Domains, (6) fehlerhafte oder maschinell wirkende Sprache, (7) unpassende Dateianhänge oder Bilddateien sowie (8) Inhalte, die nicht zum bisherigen Kontext der Kommunikation passen.

Control: SENS.7.9 - Aktive Inhalte

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: d4253a3f-ba3b-4446-b6cc-bfbd9285eb27
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Office-Anwendungen SOLLTE zur Überprüfung aktiver Inhalte vor der Aktivierung sensibilisieren.

Guidance

Office-Dateien mit aktiven Inhalten (z.B. Makros) können Schadprogramme enthalten. In diesem Kontext bedeutet „aktive Inhalte“ jegliche Funktionen in Office-Dokumenten, die über reine Text- oder Datenanzeige hinaus eigenständig Code ausführen oder externe Ressourcen ansprechen können. Bei unbekannten oder unerwarteten Dokumenten mit solchen Inhalten ist es sinnvoll, zunächst Rücksprache mit der absendenden Person zu halten, um die Echtheit des Dokumentes zu bestätigen und zu klären, ob die aktiven Inhalte für die Kommunikation zwingend erforderlich sind. Werden aktive Inhalte tatsächlich benötigt, so ist eine Prüfung des Quellcodes vor der Ausführung sinnvoll, die über die Meldewege angestoßen werden kann. Wurde für bestimmte aktive Inhalte bereits eine Freigabe erteilt, so kann deren erneute Prüfung bei jedem Öffnen des Dokumenten entfallen.

Links

related: KONF.12.1.11 Aktive Dateiinhalte

Control: SENS.7.10 - Trennen nicht benötigter Anschlüsse

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 2e5be22a-6fc5-49b3-ae53-66dc4105e058
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Virtualisierungslösungen SOLLTE zum Trennen nicht benötigter Verbindungen zwischen Host und virtuellem Gast sensibilisieren.

Guidance

Werden unnötige Verbindungen zwischen Host und Gast nicht getrennt, könnte dies zu unautorisiertem Zugriff auf Daten oder Systeme führen, etwa wenn eine Malware aus dem Gast Zugriff auf Host-Ressourcen erhält oder wenn sensible Dateien versehentlich zwischen beiden Umgebungen ausgetauscht werden. Durch eine saubere Trennung kann das Risiko seitlicher Bewegungen innerhalb der IT-Infrastruktur verringert werden und die Integrität einzelner Arbeitsumgebungen kann erhalten bleiben. Dies betrifft z.B. angeschlossene Geräte und Schnittstellen wie Drucker, USB-Sticks oder auch die Netzanbindung. Auch einfache Checklisten für IT-Personal und Nutzende können helfen, das Bewusstsein zu stärken, dass Komfortfunktionen wie „Drag & Drop“ zwischen Host und Gast zwar praktisch erscheinen, aber potenziell eine unnötige Angriffsfläche eröffnen können.

Control: SENS.7.11 - Heimliche Aufzeichnung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: e5552e03-45ba-4bd4-8022-c4d46eb1c856
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von VK-Anwendungen SOLLTE gegen die heimliche Bild- oder Tonaufzeichnung bei einer Videokonferenz sensibilisieren.

Guidance

Heimliche Aufzeichnungen verletzen die Vertraulichkeit der Kommunikation. Eine Aufzeichnung von Wort und Bild ohne den Willen der Aufgezeichneten kann zudem eine Persönlichkeitsrechtverletzung bis hin zur Straftat (§ 201 StGB) darstellen. Dies gilt auch für Aufzeichnungen, die KI-gestützt ausgewertet werden.

Control: SENS.7.12 - Öffentliche WLANs

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 172adca9-01ae-4e68-815d-eff8157dab27
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Endgeräten SOLLTE gegen die Risiken der Nutzung öffentlicher WLANs sensibilisieren.

Guidance

„Öffentliches WLAN“ meint frei zugängliche oder nur schwach kontrollierte Funknetze, deren Betreiber, Konfiguration und Schutzmechanismen unbekannt sind. In öffentlichen WLANs übertragenen Datenverkehr könnte von Dritten abgefangen werden. Angriffe wie Man-in-the-Middle, gefälschte Hotspots (Evil Twins), Session-Hijacking oder Phishing über Captive Portals könnten zu Kontoübernahmen, Datenabfluss oder Schadsoftware führen. Dies gilt auch dann, wenn das WLAN verschlüsselt ist.

Control: SENS.7.13 - Unverschlüsselte WLANs

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: b0c8ba84-b24f-4209-a739-ea13c2aea349
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Endgeräten SOLLTE gegen die Risiken der Nutzung unverschlüsselter WLANs sensibilisieren.

Guidance

Ohne Verschlüsselung könnten die über WLAN übertragenen Daten abgehört werden, z.B. Zugangsdaten, Session-Hijacking, Umleitungen durch DNS-Spoofing oder „Evil-Twins“. Ebenso könnte Schadcode über manipulierte Update-Kanäle oder Portalseiten eingeschleust werden. Im Kontext dieser Anforderung bedeutet „unverschlüsseltes WLAN“ offene Wi-Fi-Netze ohne WPA2/WPA3-Schutz, bei denen ein Captive Portal allein keine Funkstreckenverschlüsselung bereitstellt.

Control: SENS.7.14 - Unautorisierte WLANs

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 007d7888-bcc0-4595-b448-f178962c609f
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Sensibilisierung für Nutzende von Endgeräten KANN die Nutzung unautorisierter WLANs untersagen.

Guidance

Zwar sind immer mehr Verbindungen automatisch verschlüsselt, dennoch bergen WLAN-Verbindungen außerhalb der Institution das Risiko, dass Verbindungsdaten abgefangen oder IT-Systeme angegriffen werden.

Links

required: ASST.4.1 Autorisierung von Schnittstellen

Control: SENS.7.15 - Social Engineering Anrufe

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 6f6dcfa4-7c22-4e39-a1a2-c88ed0e9ee74
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von TK-Anwendungen SOLLTE gegen Social Engineering Anrufe sensibilisieren.

Guidance

Social Engineering bezeichnet in diesem Zusammenhang die bewusste Täuschung oder Beeinflussung einer Person, um sie zu Handlungen zu bewegen, die im Interesse des Angreifenden liegen, beispielsweise das Preisgeben von Passwörtern, internen Abläufen oder technischen Zugangsdaten. Ein Angriff könnte sich etwa darin äußern, dass sich eine Person am Telefon glaubhaft als IT-Support, Vorgesetzte oder externe Partnerin ausgibt, um den Eindruck einer legitimen Anfrage zu erwecken. Solche Vorfälle könnten zu unbefugtem Zugriff auf interne Systeme, zum Auslösen von Störungen oder zur Vorbereitung weiterer Angriffe führen. Typischerweise sind solche Anrufe daran zu erkennen, dass von unbekannten Personen zu unüberlegten Handlungen gedrängt wird. Hiergegen hilft es, den Gesprächspartner zunächst zu authentifizieren, bevor über Vertrauliches gesprochen oder Handlungen angestoßen werden. Angezeigte Rufnummern oder Nutzernamen könnten dagegen manipuliert sein (Caller ID Spoofing) - sie sind zur Authentifizierung des Gesprächspartners eher nicht geeignet. Das Mithören Dritter ist hier insbesondere im öffentlichen Raum zu bedenken, kann aber auch bei unverschlüsselten Verbindungen auftreten oder beim Gesprächspartner.

Control: SENS.7.16 - Mailbox-PIN und Co.

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 9721c369-8d8a-4c8f-9a32-3e25b2003359
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von TK-Anwendungen SOLLTE zur Vergabe eigener Zugangsdaten zum Zugriff auf Aufzeichnungen sensibilisieren.

Guidance

Der Begriff Zugangsdaten bezeichnet in diesem Kontext die für den Zugriff auf gespeicherte Aufzeichnungen notwendigen Authentisierungsinformationen, wie Passwörter, PINs oder Zugangstokens. Aufzeichnungen sind hierbei gespeicherte Mitschnitte oder Protokolle von Kommunikationssitzungen in TK-Anwendungen (z. B. Mailbox, Sprach-, Video- oder Chat-Verläufe), sofern deren Speicherung aktiviert wurde. Verfügt der Server über keine Funktion zum Speichern von Sprachaufzeichnungen (z.B. Voice-Mailbox mit PIN oder Gesprächsaufzeichnung bei Tastendruck) oder ist diese deaktiviert, so ist die Anforderung entbehrlich.

Control: SENS.7.17 - Unverschlüsseltes Telefonieren

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 789dbb4e-30fe-46ce-822c-06965e00f9c8
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von TK-Anwendungen SOLLTE gegen die Kommunikation über unverschlüsselte Telekommunikationsverbindungen sensibilisieren.

Guidance

Hilfreich ist es hierbei darüber zu informieren, zu welchen Empfängerkreisen mit welchem Schutzniveau über welche Anwendungen kommuniziert werden kann. Telefonie über das öffentliche Telefonnetz ist noch immer häufig unverschlüsselt, während z.B. viele moderne Messenger-Apps eine Ende-zu-Ende-Verschlüsselung ermöglichen. Relevant ist dabei auch der Aufbau von Konferenzschaltungen: Wählt sich z.B. ein Teilnehmer über das öffentliche Telefonnetz ein, so ist diese Verbindung typischerweise unverschlüsselt, wodurch die Gespräche aller Konferenzteilnehmer abgehört werden können, auch wenn die anderen Teilnehmer über eine verschlüsselte Verbindung in der Konferenz sind.

Links

related: ASST.4.1 Autorisierung von Schnittstellen

Control: SENS.7.18 - Mobiltelefone in Sicherheitsbereichen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: d657ce0c-6970-4955-9452-d538a3fded99
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Sensibilisierung für Nutzende von Mobiltelefonen KANN das Mitführen von Mobiltelefonen in Sicherheitsbereichen untersagen.

Guidance

Das Mitführen von Mobiltelefonen in besonders geschützten Bereichen kann untersagt werden, um das Risiko unbefugter Informationsabflüsse, unbeabsichtigter Datenaufzeichnungen oder unkontrollierter Funkübertragungen zu reduzieren. Mobiltelefone verfügen heute fast immer über hochauflösende Kameras, Mikrofone, GPS-Module und vielfältige Funktechnologien (z. B. LTE, WLAN, Bluetooth), die sowohl gezielt als auch unbeabsichtigt vertrauliche Informationen erfassen und weitergeben können. So könnte etwa ein Besuchender in einem Forschungsbereich versehentlich sensible Projektdaten fotografieren, oder ein infiziertes Gerät könnte über eine Funkverbindung Schadsoftware ins interne Netz einschleusen. Auch unbeabsichtigte Sprachaufzeichnungen in Besprechungen, die durch Assistenzfunktionen aktiviert werden, könnten sicherheitskritische Informationen in Cloud-Dienste übertragen. Das Verbot oder die Einschränkung des Mitführens in bestimmten Bereichen kann daher ein wirksames Mittel sein, um die Angriffsfläche für Spionage, Sabotage oder unkontrollierte Datenverbreitung deutlich zu verringern.

Links

required: GEB.4.1 Einrichtung

related: DET.4.19 Unautorisierte Sendeanlagen

Control: SENS.7.19 - Unverschlüsselte SMS oder MMS

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 99a4ed67-648c-4dfb-8fcf-2ce1b8a907db
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Sensibilisierung für Nutzende von Mobiltelefonen KANN den Versand von SMS oder MMS untersagen.

Guidance

SMS und MMS werden in der Regel unverschlüsselt übertragen und daher nicht für sensible Informationen geeignet. Stattdessen kann oft auf verschlüsselte Anwendungen zurückgegriffen werden.

Control: SENS.7.20 - Authentifizierung von Gesprächspartnern

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 820687b2-4447-455d-9c9f-236c7333db82
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Informationen SOLLTE zur Authentifizierung von Gesprächspartnern vor der Weitergabe von Informationen sensibilisieren.

Guidance

Die Authentifizierung von Gesprächspartnern ist die verlässliche Verifikation der Identität einer Person, bevor vertrauliche oder schützenswerte Informationen mündlich, telefonisch oder über andere elektronische Kommunikationsmittel weitergegeben werden. Dazu gehört es insbesondere sicherzustellen, dass die anfragende Person tatsächlich diejenige ist, für die sie sich ausgibt („authentication of interlocutors“). Ziel ist es zu verhindern, dass unberechtigte Dritte durch Täuschung an vertrauliche Inhalte gelangen. Ohne diese Überprüfung könnten Angriffe wie Social Engineering, CEO-Fraud oder Phishing erfolgreich sein – ein Angreifer könnte sich z. B. am Telefon als interner Kollege, vertrauter Dienstleister oder sogar als Behördenvertreter ausgeben, um Zugang zu Kundenlisten, Zugangsdaten oder Projektplänen zu erhalten. Dies gilt insbesondere am Telefon, aber auch in persönlichen Gesprächen mit Unbekannten. Sinnvoll ist es, hierzu ein einheitliches Verfahren zu etablieren, bei dem vor Auskunftserteilung anfragende Personen durch gezielte Rückfragen oder Vergleich mit bekannten Kontaktdaten überprüft werden. Beispiele können sein: (1) Rückruf unter der im internen Verzeichnis hinterlegten Telefonnummer, (2) Abgleich spezifischer interner Referenzen oder Codes, (3) Nachfrage nach Details, die nur legitim Berechtigte kennen können (z.B. Aktenzeichen), oder (4) die Nutzung anderer sicherer Kommunikationskanäle, die bereits für die jeweilige Person verifiziert wurden.

Control: SENS.7.21 - Rechtsunsicherheit von Faxen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 19a80332-263d-421d-927c-2d99ad0ce9c0
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Faxen SOLLTE gegen die Rechtsunsicherheit bei Empfang oder Versand von Faxen sensibilisieren.

Guidance

Faxe enthalten nicht die originale, eigenhändige Unterschrift und erfüllen daher nicht die gesetzliche Schriftform (§ 126 BGB).

Control: SENS.7.22 - Unverschlüsselte Faxleitungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 6de76a23-9301-4203-9561-c56f459b8a1f
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Faxen SOLLTE gegen die Risiken der unauthen-tisierten und unverschlüsselten Faxnutzung sensibilisieren.

Guidance

Da Faxverbindungen in der Regel weder eine Authentifikation des Empfängers noch eine Transportverschlüsselung vornehmen, können diese leicht abgefangen oder manipuliert werden. Dem kann durch eine Ankündigung sowie eine Sende- und Empfangsbestätigung entgegengewirkt werden.

Control: SENS.7.23 - Geolokation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 48be8fcc-4642-42b6-8a53-b8baf85f6b2a
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Endgeräten SOLLTE über Standortbestimmungsfunktionen von mobilen Endgeräten sensibilisieren.

Guidance

Zum Beispiel könnten Webseiten über Schnittstellen von Webbrowsern auf Standort-Sensoren (GPS, Mobilfunk etc.) zugreifen. Auch Mobilfunkanbieter sind in der Lage, Geostandorte über das Mobilfunksignal zu erfassen.

Control: SENS.7.24 - Zertifikatswarnungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 777774af-92c0-41ee-8f3e-953b88ffd800
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Webbrowsern SOLLTE gegen das unautorisierte Übergehen einer Zertifikatswarnung bei der Webnutzung sensibilisieren.

Guidance

Zeigt der Browser oder eine andere Anwendung eine Zertifikatswarnung an, dann besteht das Risiko, dass es sich um einen Angriff handelt. Im Zweifel ist es hier angebracht, über die bekannten Meldewege nachzufragen und den Zugang zu bestimmten Seiten oder Anwendungen autorisieren zu lassen.

Control: SENS.7.25 - Zugang zum Fahrzeug

Tag: "Physical Access Control"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.7 Umgang mit spezifischen Zielobjekten
UUID: 9cb473cd-cf71-4fe4-9ccd-b527f1a353ab
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Fahrzeugen SOLLTE zu Schutzmaßnahmen vor dem Zugang Unbefugter zu Fahrzeugen sensibilisieren.

Guidance

Kann dazu beitragen, unbefugte Nutzung, Manipulation oder Diebstahl von Fahrzeugen und deren Ausrüstung zu verhindern. Dies ist besonders relevant, wenn Fahrzeuge sensible Materialien, technische Geräte, vertrauliche Unterlagen oder digitale Speichermedien enthalten, die bei ungeschütztem Zugang in falsche Hände geraten könnten. Ein unachtsig abgestelltes und nicht verriegeltes Fahrzeug könnte beispielsweise dazu führen, dass wertvolle Ausrüstung entwendet, ein GPS-System manipuliert oder vertrauliche Einsatzpläne aus dem Handschuhfach entnommen werden. Auch das Auslesen elektronischer Schnittstellen (z. B. OBD-Port) könnte möglich sein, wenn ein Fahrzeug ungesichert ist. Im Kontext dieser Anforderung bedeutet „Unbefugte“ jede Person, die nicht ausdrücklich durch die Institution autorisiert ist, Zugang zum Fahrzeug oder dessen Inhalten zu erlangen; „Zugang“ umfasst dabei sowohl den physischen Einstieg in das Fahrzeug als auch den Zugriff auf dessen Inhalte oder elektronische Systeme. Die Umsetzung dieser Sensibilisierung kann beispielsweise beinhalten, dass Fahrzeug beim Verlassen stets zu verriegeln und wertvolle Gegenstände oder vertrauliche Unterlagen nicht sichtbar im Innenraum zu lassen. Auch das Aktivieren werkseitiger oder nachgerüsteter Alarmanlagen oder Wegfahrsperren ist sinnvoll. Zudem ist es zweckmäßig, Fahrzeuge nur dort abzustellen, wo sie durch Sicherheitsmaßnahmen wie Zugangskontrollen und Alarmanlagen vor unbefugtem Zugriff geschützt sind und die erlaubten Datenlokalisationen es zulassen.

Links

required: ASST.3.10 Autorisierung von Datenlokalisationen

Control: SENS.8.1 - Risiken der Nutzung von mobilen Endgeräten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.8 Physische Sicherheit
UUID: d3d8d31b-bbc8-4e63-9f09-4dc19897323c
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Endgeräten SOLLTE gegen Risiken der Nutzung von mobilen Endgeräten sensibilisieren.

Guidance

Bei der Nutzung mobiler Endgeräte wie Smartphones, Tablets und Laptops ist Vorsicht geboten, da diese Geräte häufig außerhalb gesicherter Umgebungen betrieben werden und dort typischerweise einer höheren Gefährdungslage ausgesetzt sind. Beispiele sind z.B. Abhandenkommen von Geräten oder Zugang von Unbefugten zu Informationen im öffentlichen Verkehr. Durch den konsequenten Einsatz von Gerätesperren, Verschlüsselung, vertrauenswürdigen Netzwerken sowie der geschützten Verwahrung von Geräten kann das Risiko einer unbefugten Nutzung erheblich reduziert werden.

Links

related: ASST.6.1 Abhandenkommen

Control: SENS.8.2 - Schließen von Türen und Fenstern

Tag: "Physical Access Control"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.8 Physische Sicherheit
UUID: 2a761948-b26a-4e19-8a9d-75f78ac19811
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Gebäuden SOLLTE zum Verschließen von Fenstern und Türen beim Verlassen von Räumlichkeiten anweisen.

Guidance

Durch unverschlossene Türen und Fenster könnten Unbefugte Zutritt erlangen und (in Außenwänden) auch Umwelteinflüsse wirksam werden (Regen, Sturm, Frost), so dass IT, sensible Informationen und andere Werte in Gefahr geraten, zerstört, beschädigt, ausgespäht oder entfernt werden könnten. Sobald die Anwesenheit von Personen in einem Raum endet, sind Türen und Fenster daher so zu schließen, dass von Außen das unbefugte Öffnen und (in Außenwänden) das Eindringen von Umwelteinflüssen verhindert wird. Türen werden z.B. abgeschlossen oder Türschließsysteme in den entsprechenden Betriebszustand gebracht, Fenster ganz geschlossen und verriegelt. Nicht erforderlich ist das Verschließen der Türen von fensterlosen Innenräumen, in denen keine IT, sensible Informationen oder andere Werte aufbewahrt werden, oder wenn Risiken praktisch ausgeschlossen werden können (z.B. Kippen von Außenfenstern in höheren Geschossen bei gutem Wetter vor kurzer Abwesenheit). Dies gilt auch für Gemeinschaftsräume, in denen sich IT-Systeme oder Datenträger befinden, z.B. VK-Konferenzzimmer.

Control: SENS.8.3 - Mitbringen von IT-Systemen

Tag: "Bring Your Own Device"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.8 Physische Sicherheit

UUID: 6988844b-ed26-4ad3-83f6-ba5cf223070b

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Sensibilisierung für Nutzende KANN das Mitbringen unautorisierter IT-Systeme untersagen.

Guidance

Fremde IT-Systeme sind ein Risiko, weil sie an das interne Netz angeschlossen, zum Mithören von Gesprächen oder zur Standortverfolgung missbraucht werden können. Relevant sind dabei sowohl Geräte der Mitarbeitenden, als auch von Externen. Dies kann auch durch eine Hinterlegung von Geräten an der Pforte oder in verschließbaren Fächern am Eingang umgesetzt werden.

Control: SENS.8.4 - Begleitung Externer

Tags: "Physical Access Control" "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.8 Physische Sicherheit
UUID: 1f0a8e0c-33cd-407a-9579-e2dcc6d46515
Aufwand: 4
Sicherheitsstufe: erhöht

Untergeordnete Controls

- SENS.8.4.1 Beaufsichtigung Externer

Statement

Sensibilisierung für Mitarbeitende von Standorten KANN zur Begleitung von Externen anweisen.

Guidance

Dies dient in erster Linie dazu, unbefugte oder unbeaufsichtigte Zugriffe auf sensible Bereiche, Informationen oder Systeme zu verhindern. Ohne eine solche Begleitung kann es leicht zu Situationen kommen, in denen Externe absichtlich oder versehentlich sicherheitskritische Bereiche betreten, vertrauliche Informationen einsehen oder technische Geräte unsachgemäß manipulieren. Die Begleitung Externer, die wie Interne sicherheitsüberprüft und geschult wurden, ist entbehrlich.

Control: SENS.8.4.1 - Aufsicht Externer

Tag: "Physical Access Control"

Info

Control der Klasse "BSI-Stand-der-Technik-Kern"
Gruppe: SENS.8 Physische Sicherheit
Übergeordnetes Control:
SENS.8.4 Begleitung Externer
UUID: 2b9cec51-f841-4ba6-b50d-29c1c2f2c21d
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Mitarbeitende von Standorten SOLLTE zur Aufsicht von Externen in sensiblen Bereichen anweisen.

Guidance

Erhalten Externe wie z.B. IT-Dienstleister Zugang zu Standorten, an denen sensible Informationen verarbeitet werden, so stellt eine Aufsicht sicher, dass Externe nur soweit Zugriff auf diese Informationen erhalten, wie für die Erledigung der Aufgabe erforderlich.

Links

related: ASST.5.6 Wartung durch Externe

Control: SENS.8.5 - Verwahrung Intern

Tag: "Physical Access Control"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.8 Physische Sicherheit

UUID: a5504b88-679b-418b-ab9e-5741317f29ff

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende von Räumen SOLLTE zur sicheren Verwahrung von IT-Systemen und Datenträgern sensibilisieren.

Guidance

Herumliegende vertrauliche Dokumente und Datenträger sind ein leichtes Ziel für Diebe und können versehentlich verloren gehen. Hiergegen hilft die Verwahrung in einem verschlossenen Schrank oder anderweitig entsprechend geschützt. Dies ist besonders wichtig in Räumlichkeiten, welche oft zusammen mit oder ausschließlich von externen Personen genutzt werden, z.B. Konferenz- oder Veranstaltungsräume.

Control: SENS.8.6 - Rückgabe nicht mehr benötigter Assets

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.8 Physische Sicherheit
UUID: 857f189a-5ede-47d6-89d5-faff63d736d2
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zur Rückgabe nicht mehr benötigter Assets anweisen.

Guidance

Dies gilt z.B. bei einem Wechsel der Aufgaben oder der Beendigung des Vertragsverhältnisses zwischen Nutzenden und der Institution.

Control: SENS.8.7 - Verwendung von Brandschuttmitteln

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.8 Physische Sicherheit
UUID: 37823d46-59ad-487b-bba1-5917c017c625
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Mitarbeitende SOLLTE zur korrekten Verwendung bereitgestellter Brandschutz-Hilfsmittel sensibilisieren.

Guidance

Hierzu zählt z.B. die Einweisung in die korrekte Verwendung von Handfeuerlöschern, welche in Serverräumen oder Rechenzentren bereitgestellt werden.

Control: SENS.8.8 - Verwendung von Wasserschutzmitteln

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.8 Physische Sicherheit
UUID: 75859261-aa48-4faf-9489-3d875e585f9d
Aufwand: 3
Sicherheitsstufe: erhöht

Statement

Sensibilisierung für Mitarbeitende KANN zur korrekten Verwendung bereitgestellter Wasserschutz-Hilfsmittel sensibilisieren.

Guidance

Ohne ausreichende Kenntnisse könnte ein Mitarbeitender im Ernstfall zögern oder Hilfsmittel falsch anwenden, wodurch wertvolle Geräte ungeschützt bleiben oder unnötige Verzögerungen bei der Eindämmung eintreten könnten. Eine rechtzeitige und richtige Anwendung kann dagegen die Ausbreitung von Wasserschäden begrenzen, Datenverluste vermeiden und den Wiederanlauf kritischer Arbeitsprozesse erheblich erleichtern. Im Kontext dieser Anforderung bedeutet „Wasserschutz-Hilfsmittel“ einfache technische oder organisatorische Werkzeuge, die zur Eindämmung, Ableitung oder Beseitigung von Wasser im Notfall eingesetzt werden können, etwa Sandsäcke, Absperrschotten, Wassermelder oder Tauchpumpen. Konkrete Maßnahmen können sein: (1) Mitarbeitende regelmäßig in kurzen Übungen mit der Handhabung der vorhandenen Hilfsmittel vertraut machen, z. B. das Einsetzen von Absperrschotten an Türen oder den Betrieb einer Tauchpumpe an einem vorbereiteten Testbecken, (2) an den Aufbewahrungsorten der Hilfsmittel laminierte Schritt-für-Schritt-Anleitungen anbringen, die im Ernstfall sofort verständlich sind, (3) visuelle Markierungen oder QR-Codes platzieren, die auf kurze Videosequenzen zur Anwendung verweisen. Auch kleine Tipps können die Wirksamkeit erhöhen, etwa dass Hilfsmittel geordnet nach Dringlichkeit bereitliegen können oder dass bei Tauchpumpen vorab Kabel und Steckdosen auf sichere Reichweite geprüft werden können.

Control: SENS.9.1 - Verarbeitung in der Öffentlichkeit

Tags: "Physical Access Control" "Shoulder Surfing"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.9 Mobiles Arbeiten
UUID: 4d8775fd-52b0-491f-b0ce-7a8ceaba4819
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE gegen die Verarbeitung von vertraulichen Informationen in der Öffentlichkeit sensibilisieren.

Guidance

Die Anforderung zielt darauf ab, das Risiko unbeabsichtigter Informationsabflüsse in öffentlichen Räumen zu reduzieren. Ohne entsprechende Aufmerksamkeit könnte etwa ein unbefugter Dritter vertrauliche Daten über die Schulter mitlesen, Fotos von Bildschirmen aufnehmen oder Gesprächsinhalte mithören, was im schlimmsten Fall zu Identitätsdiebstahl oder geschäftsschädigender Weitergabe von Insiderinformationen führen könnte. Unachtsamkeit könnte dabei z.B. einen Verstoß gegen Arbeitsanweisungen und das Gesetz zum Schutz von Geschäftsgeheimnissen (GeschGehG) darstellen. Im vorliegenden Kontext bedeutet „öffentliche Verarbeitung“ die Nutzung mobiler Geräte wie Laptops, Tablets oder Smartphones in frei zugänglichen Umgebungen, in denen unbekannte Personen mitlesen oder mithören könnten, zum Beispiel in Verkehrsmitteln, Cafés, Flughäfen oder Co-Working-Spaces. Zudem helfen Schutzmaßnahmen wie das Sitzen mit dem Rücken zur Wand oder die Verwendung von Displayschutzfolien und abdeckenden Kopfhörern.

Links

related: ASST.3.10 Autorisierung von Datenlokalationen

Control: SENS.9.2 - Vorsicht vor Mithören

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.9 Mobiles Arbeiten

UUID: bd43cb07-83d9-4105-9039-3dba57a180e9

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE gegen das Abhören von Gesprächen beim mobilen Arbeiten sensibilisieren.

Guidance

Das Abhören von Gesprächen bezeichnet im Kontext des mobilen Arbeitens das unbefugte Mithören vertraulicher oder sensibler Inhalte durch Dritte, sei es absichtlich (z. B. durch Spionage) oder unbeabsichtigt (z. B. durch zufällige Umstehende). Mobiles Arbeiten ist das Arbeiten an Orten außerhalb der Kontrolle der Institution, wie z. B. im Homeoffice, auf Reisen oder in öffentlichen Bereichen. Ohne entsprechende Vorsicht könnte die Preisgabe geschäftsrelevanter Daten über Produkte, interne Strategien oder persönliche Informationen erfolgen, was im schlimmsten Fall zu wirtschaftlichen Schäden oder Reputationsverlust führen könnte. Das betrifft insbesondere Anrufe und Videokonferenzen. Hierbei hilft es, Gespräche mit vertraulichem Inhalt nach Möglichkeit in geschützte Räume zu verlagern oder, falls dies nicht möglich ist, ihre Sprache bewusst zu kodieren bzw. zu abstrahieren. Technische Hilfsmittel wie Headsets mit Geräuschunterdrückung können die Verständlichkeit für autorisierte Gesprächspartner verbessern, während Umstehende weniger Details wahrnehmen. Auch einfache Verhaltenshinweise wie das Abwenden vom Publikumsverkehr, die Wahl einer Sitzposition mit Abstand zu anderen Personen oder die Nutzung digitaler Chatkanäle anstelle mündlicher Gespräche in unsicheren Umgebungen kann das Risiko verringern.

Links

related: ASST.3.10 Autorisierung von Datenlokationen

Control: SENS.9.3 - Verwahrung außer Haus

Tag: "Physical Access Control"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.9 Mobiles Arbeiten
UUID: 65a6dd9c-baab-49b8-8d28-ee4cab5b52a9
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zur Verwahrung von IT-Systemen und Datenträgern beim mobilen Arbeiten anweisen.

Guidance

Die Verwahrung von IT-Systemen und Datenträgern bedeutet, diese so zu sichern, dass sie nicht unbeabsichtigt verloren gehen, beschädigt oder unbefugt eingesehen werden können. An mobilen Arbeitsplätzen ist das Risiko eines Zugriffs Unbefugter oder Verlustes typischerweise höher als in Bürogebäuden. Dagegen hilft es, alle Hardware und Dokumente so aufzubewahren, dass unbefugter Zugang und unrechtmäßiger Zugriff verhindert wird. Hierzu können z.B. Koffer mit Schloss oder Hotelsafes genutzt werden. Eine regelmäßige Überprüfung dieser Maßnahmen wird empfohlen.

Links

related: ASST.3.10 Autorisierung von Datenlokationen

Control: SENS.9.4 - Mobile Arbeit mit Dokumenten

Tag: "Physical Access Control"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.9 Mobiles Arbeiten
UUID: 4e9f2d62-dfe7-43a6-abb7-3c2e12df08b6
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE über den sicheren Umgang mit analogen Dokumenten beim mobilen Arbeiten sensibilisieren.

Guidance

Unter analogen Dokumenten sind hier alle physischen Informations- und Datenträger wie Ausdrucke, Notizbücher oder Verträge zu verstehen, die sensible oder vertrauliche Inhalte enthalten. Unbeaufsichtigte oder ungeschützte Dokumente könnten unterwegs leicht verloren gehen oder in unbefugte Hände gelangen, was zu ungewollter Preisgabe interner Informationen führt. Daher ist es sinnvoll (1) Unterlagen unterwegs stets in verschließbaren Taschen oder Mappen zu transportieren und so vor unbefugtem Zugriff zu schützen, (2) beim Arbeiten außerhalb der Institution nur die wirklich notwendigen Ausdrucke mitzunehmen und alle übrigen Dokumente in gesicherten Ablagen zu belassen. (3) Papierstapel durch neutrale Umschläge abzudecken oder in blickdichten Aktenhüllen mitzuführen, sodass neugierige Blicke verhindert werden, (4) temporäre Notizen nach Gebrauch einer sicheren Vernichtung zuzuführen, etwa durch mobile Reißwolf-Lösungen oder durch Rückgabe an eine zentrale Aktenvernichtung. Auch für mitgenommene analoge Dokumente gelten zudem die Regelungen und Verfahren zum Löschen und Vernichten.

Links

related: ASST.3.10 Autorisierung von Datenlokationen

related: ASST.7.3.2 Löschverfahren

Control: SENS.9.5 - Mitnahme zur mobilen Arbeit

Tag: "Physical Access Control"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.9 Mobiles Arbeiten

UUID: 3c678c4b-a10d-4f6d-ab63-d34cd84ecef

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE gegen die Mitnahme nicht erforderlicher IT-Systeme und Datenträger sensibilisieren.

Guidance

Außerhalb der Institution sind die Möglichkeiten zum Schutz von IT-Systemen und Daten geringer. Es ist daher ratsam, die mitgenommenen Geräte und Dokumente auf das erforderliche Maß zu beschränken und stattdessen nach der Rückkehr intern weiter daran zu arbeiten. Welche IT-Systeme und Datenträger erforderlich sind, ergibt sich aus der Festlegung erlaubter Datenlokationen sowie den Aufgaben der Nutzenden.

Links

required: ASST.3.10 Autorisierung von Datenlokationen

related: ASST.3.10 Autorisierung von Datenlokationen

Control: SENS.9.6 - Mitnahme ins Ausland

Tag: "Auslandsreisen"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.9 Mobiles Arbeiten
UUID: 2181d821-efad-48d7-9c12-7c1aad40bfb1
Aufwand: 3
Sicherheitsstufe: erhöht

Statement

Sensibilisierung für Nutzende KANN die Mitnahme nicht erforderlicher IT-Systeme und Datenträger bei Auslandsreisen untersagen.

Guidance

Auf Auslandsreisen ist das Risiko für Spionage erhöht und der Rechtsschutz für Betroffene typischerweise geringer, insbesondere im EU-Ausland. Es ist daher ratsam, die mitgenommenen Geräte und sensiblen Informationen auf das für das Geschäft erforderliche Mindestmaß zu beschränken und stattdessen nach der Rückkehr an einem besser geschützten Standort weiter daran zu arbeiten. Welche IT-Systeme und Datenträger erforderlich sind, ergibt sich aus der Festlegung erlaubter Datenlokationen sowie den Aufgaben der Nutzenden. Ist die Nutzung von Informationen oder Assets der Institution im Ausland nicht vorgesehen (vgl. Anforderung Datenlokationen), dann ist die Anforderung entbehrlich.

Links

required: ASST.3.10 Autorisierung von Datenlokationen

related: ASST.3.10 Autorisierung von Datenlokationen

Control: SENS.9.7 - Reise- und Sicherheitshinweise

Tags: "Auslandsreisen" "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.9 Mobiles Arbeiten
UUID: 3b4e6be6-5648-468f-bc05-89191c9cdd90
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Nutzende SOLLTE zu Reise- und Sicherheitshinweisen des Auswärtigen Amtes bei Auslandsreisen ins außereuropäische Ausland sensibilisieren.

Guidance

Dies kann dazu beitragen, frühzeitig potenzielle Gefahren zu erkennen und das Verhalten an die spezifischen Risiken des Ziellandes anzupassen. Dies umfasst unter anderem Hinweise zu politischen Unruhen, Naturkatastrophen, Kriminalitätslagen oder besonderen Einreise- und Sicherheitsbestimmungen. Ohne solche Kenntnisse könnten Reisende unvorbereitet in Situationen geraten, in denen dienstliche Geräte kompromittiert werden, wenn unsichere Netzwerke genutzt werden. Ebenso könnten fehlende Kenntnisse über lokale Gesetze dazu führen, dass mitgeführte elektronische Geräte bei der Einreise beschlagnahmt oder inspiziert werden. Sinnvoll ist es, sich vor der Arbeitsreisen in das außereuropäische Ausland über aktuelle Reise- und Sicherheitshinweise beim [Auswärtigen Amt](<https://www.auswaertiges-amt.de/de/reiseundsicherheit/reise-und-sicherheitshinweise>) zu informieren. Ist die Nutzung von Informationen oder Assets der Institution im Ausland nicht vorgesehen (vgl. Anforderung Datenlokationen), dann ist die Anforderung entbehrlich.

Links

related: ASST.3.10 Autorisierung von Datenlokationen

Control: SENS.10.1 - Grundprinzipien der Systemadministration

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.10 Administration

UUID: 27a41327-328d-4213-a39b-fe549f241921

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Administrierende SOLLTE zu den Grundprinzipien der sicheren Administration sensibilisieren.

Guidance

Administrierende sind durch ihre weitreichenden Zugangs- und Zugriffsberechtigungen, sowie ihre Verantwortung für die Aufrechterhaltung der Infrastruktur von besonderer Bedeutung für die Informations- und Cybersicherheit. Hier bedeutet „sichere Administration“, dass administrative Tätigkeiten so gestaltet werden, dass Vertraulichkeit, Integrität und Verfügbarkeit der Systeme möglichst gewahrt bleiben. Dazu zählen etwa Zugriffskontrolle und Rechtevergabe nach dem Least-Privilege-Prinzip, Netzwerksegmentierung, Systemhärtung, Loganalyse, Datensicherungen und Monitoring sowie die Vorbereitung für Notfälle. Um dies sicherzustellen ist es wichtig, die festgelegten Regeln (z.B. IT-Betriebskonzept) zu kennen und auf deren Einhaltung zu achten.

Control: SENS.10.2 - Umgang mit privilegierten Berechtigungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.10 Administration
UUID: df690f55-b161-42fd-8cdb-383a553dddfe
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Administrierende SOLLTE zum Umgang mit privilegierten Berechtigungen sensibilisieren.

Guidance

Privilegierte Berechtigungen (auch „administrative Rechte“, „Root-Berechtigungen“ oder „elevated privileges“ genannt) ermöglichen weitreichende Systemeingriffe und können bei unsachgemäßer Verwendung schwerwiegende Sicherheitsvorfälle verursachen. Beispielsweise könnte ein Administrator mit Root-Zugriff versehentlich kritische Systemdateien löschen, sensible Daten einsehen, oder Angreifer könnten solche Zugangsdaten abgreifen und mit diesen durch Lateral Movement ungehindert im Netzwerk agieren. Dies wird besonders deutlich an realen Vorfällen, bei denen Administratoren durch Social Engineering zum Einsatz ihrer Berechtigungen manipuliert wurden oder durch mangelndes Bewusstsein für Sicherheitsimplikationen ihrer Handlungen Schwachstellen selbst geschaffen haben. Stattdessen ist es sinnvoll, solche Berechtigungen nur dann zu verwenden, wenn sie für die aktuelle Aktion erforderlich sind, z.B. durch sudo. Zudem ist es bei diesen Zugangsdaten besonders wichtig, dass sie nicht ungeschützt abgelegt werden. Das betrifft auch Zugangsdaten, die in Skripten oder Anwendungen hinterlegt werden um diese auszuführen: Werden diese beim Aufruf von Kommandozeilenbefehlen oder in Skripten mitgespeichert, könnten sie in Protokollen oder im Prozessspeicher sichtbar sein und missbraucht werden. Sinnvoll ist stattdessen die Verwendung von Passwort-Managern, Umgebungsvariablen oder speziellen Secrets-Management-Lösungen. Dazu gehört auch die regelmäßige Rotation solcher Zugangsdaten bei Dienstkonten (Service Accounts).

Control: SENS.10.3 - Systemadministration - Sicherheitsvorfälle

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.10 Administration
UUID: 019ea9a4-70dd-4e10-adfa-37467144aca3
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Administrierende SOLLTE zu Verfahren und Regelungen bei Sicherheitsvorfällen sensibilisieren.

Guidance

Für die Behandlung und Nachsorge bei Sicherheitsvorfällen sind die festgelegten Verfahren und Regelungen einzuhalten. Hierzu gehört etwa das Erkennen auffälliger Logeinträge, der Umgang mit kompromittierten Administratorpasswörtern oder das strukturierte Sammeln erster Fakten, bevor ein Incident-Response-Team übernimmt. Effektiv kann auch ein klar dokumentiertes Ablaufdiagramm sein, das den Meldeweg und zulässige Sofortmaßnahmen visuell darstellt und in Administrationshandbüchern oder direkt im Ticket-System hinterlegt ist.

Links

required: REA.1.1 Verfahren und Regelungen

Control: SENS.10.4 - Systemadministration - Strukturierte Verkabelung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.10 Administration
UUID: fd852545-bf6f-4e5b-adc0-e169cc0548fa
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Administrierende von Netzen SOLLTE zur strukturierten Verkabelung sensibilisieren.

Guidance

Eine strukturierte Verkabelung kann die Übersichtlichkeit, Fehlertoleranz und Betriebssicherheit von Netzwerken erheblich verbessern. Sie dient dazu, Kabelwege und -anschlüsse einheitlich zu planen, zu dokumentieren und physisch so zu gestalten, dass Fehlverkabelungen, Kabelschäden oder unbefugte Eingriffe erschwert werden. Ohne solche Maßnahmen kann es zu chaotischen Verkabelungen kommen, die Fehlerdiagnosen erschweren, längere Ausfallzeiten verursachen oder im schlimmsten Fall unbemerkt unautorisierte Geräte ins Netz einschleusen lassen. So könnte etwa ein unbeschriftetes Patchkabel versehentlich abgezogen werden, wodurch kritische Systeme offline gehen, oder ein Kabelbündel könnte bei einer unachtsamen Bewegung beschädigt werden, was zu intermittierenden Netzwerkausfällen führt. Im konkreten Kontext bezeichnet „strukturierte Verkabelung“ ein einheitlich aufgebautes und dokumentiertes System von Kabeln, Anschlüssen und Patchfeldern, das nach anerkannten Standards (z. B. nach DIN EN 50173 und 50174) geplant und umgesetzt wird. Dazu gehören die Auswahl geeigneter Kabel, normgerechte Verlegungswege unter Berücksichtigung von EN 50310 sowie die Einhaltung von Mindestbiegeradien und Trennungsabständen zu elektrischen Leitungen. Administrierende können durch klare Kabelführung, Farbcodierungen, eindeutige Beschriftungen und eine nachvollziehbare Dokumentation ihre Arbeitsumgebung übersichtlicher und sicherer gestalten.

Control: SENS.10.5 - Systemadministration - Internetnutzung

Tags: "Privilege Escalation" "Insider Threat" "Privilegierte Rechte"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: SENS.10 Administration

UUID: 888c76ab-d8f0-42ff-a791-8a31f17f6ad0

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Administrierende SOLLTE gegen den Internetzugriff über ein Administrationskonto sensibilisieren.

Guidance

Administrationskonten sind im konkreten Kontext privilegierte Benutzerkonten, die erweiterte Rechte für Konfigurations-, Installations- oder Wartungsaufgaben besitzen. Internetzugriff bezeichnet dabei das Herstellen von Verbindungen zu externen Diensten oder Webseiten außerhalb der institutionseigenen Netze. Ein solcher Zugriff mit einem Administrationskonto stellt ein erhebliches Risiko dar: Schadsoftware könnte mit denselben hohen Rechten ausgeführt werden oder Anmeldedaten könnten über unsichere Webseiten abgegriffen werden. Hiervon können Zugriffe ausgenommen werden, die zur Administration des Systems mit diesen Rechten erforderlich sind, z.B. Download von Sicherheitsupdates durch Applikationen, die zur Ausführung administrative Rechte benötigen.

Links

required: BER.3.5 Privilegierte Zugangskonten

Control: SENS.11.1 - Sensibilisierung der Institutionsleitung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.11 Sensibilisierung der Leitungsebene
UUID: 72f91d4a-67c7-4e93-a9b8-a4bb1157e4a6
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Institutionsleitung SOLLTE zur Bedeutung der Informationssicherheit für den Schutz der Geschäftsprozesse sensibilisieren.

Guidance

Informationssicherheit ist kein Selbstzweck, sondern soll die Verarbeitung von Informationen in Geschäftsprozessen zur Erreichung der Geschäftsziele schützen. Weil Umfang und Integration von Informationsverarbeitungen in Geschäftsprozessen zunehmen, sind Datenverluste, Cyberangriffe und andere elementare Gefährdungen eine zunehmend ernste Bedrohung.

Control: SENS.11.2 - Führen als Vorbild

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.11 Sensibilisierung der Leitungsebene
UUID: c5032864-bc5c-4f60-a136-9b10aa2f3f10
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Führungskräfte SOLLTE zu ihrer Vorbildfunktion bei der Informationssicherheit sensibilisieren.

Guidance

Die Vorbildfunktion von Führungskräften ist entscheidend, um eine robuste Sicherheitskultur zu etablieren und die Einhaltung der geschulten Inhalte im Arbeitsalltag zu gewährleisten.

Control: SENS.11.3 - Whaling

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.11 Sensibilisierung der Leitungsebene
UUID: e8b12560-18b1-4e31-955a-68804003008b
Aufwand: 1
Sicherheitsstufe: normal-SdT

Statement

Sensibilisierung für Führungskräfte SOLLTE gegen gezielte Angriffe auf Führungskräfte sensibilisieren.

Guidance

Gezielte Angriffe auf Führungskräfte, auch Whaling genannt, sind eine besondere Form des Social Engineering, bei der Täter sehr spezifisch auf leitende Personen einer Institution abzielen. Im Gegensatz zu herkömmlichem Phishing sind diese Angriffe stark personalisiert, häufig inhaltlich gut recherchiert und auf die Entscheidungsbefugnisse und den Einfluss der Führungsperson zugeschnitten. Die Täter setzen dabei häufig auf die jeweilige Situation zugeschnittene Social Engineering Techniken wie Spear Phishing (z.B. anhand von Angaben in sozialen Netzwerken), CEO-Fraud oder Deepfakes ein. Ein Vorfall könnte z.B. dazu führen, dass ein CFO durch eine täuschend echte E-Mail zur Freigabe von Überweisungen verleitet wird oder Aktivisten sich eine Videokonferenz mit bekannten Persönlichkeiten erschleichen, um diese bloßzustellen. Zur Verringerung des Risikos können konkrete Hinweise im Alltag beachtet werden: (1) Besonders aufmerksam sollte auf Nachrichten reagiert werden, die Dringlichkeit betonen, ungewöhnliche Geldtransfers verlangen oder auf streng vertrauliche Projekte Bezug nehmen. (2) Absenderadressen sollten sorgfältig geprüft werden – bereits kleine Abweichungen in Domainnamen können Manipulation anzeigen. (3) Zur Bestätigung verdächtiger Anfragen kann ein zweiter, unabhängiger Kommunikationskanal wie ein Rückruf unter offiziell bekannter Nummer genutzt werden. Zusätzlich kann darauf geachtet werden, keine sensiblen Informationen über öffentliche Plattformen preiszugeben, da solche Details als Grundlage für Angriffe dienen könnten. Auch eine feste Routine – etwa keine Zahlungen ausschließlich aufgrund einer E-Mail freizugeben – kann dazu beitragen, auch unter Zeitdruck resilient zu bleiben.

Control: SENS.12.1 - Hohe Risiken

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: SENS.12 Spezifische Risiken
UUID: f1191c38-3df5-4cc4-adfd-46863a2671a8
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Sensibilisierung für Nutzende KANN gegen die in der Risikoanalyse festgestellten hohen Risiken sensibilisieren.

Guidance

Werden in einer Risikoanalyse bei hohem Schutzbedarf spezielle hohe Risiken festgestellt, so sind betroffene Nutzende auf diese Risiken hinzuweisen. Praktische Maßnahmen können (1) interaktive Trainings zu den jeweils relevanten Angriffsmethoden wie Social Engineering oder Ransomware umfassen, (2) Fallbeispiele aus der eigenen Branche einbeziehen, die konkrete Handlungsweisen aufzeigen, oder (3) wiederkehrende Awareness-Impulse wie Übungen einsetzen, die das Gelernte im Alltag verankern.

Control: REA.1.1 - Verfahren und Regelungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: REA.1 Grundlagen
UUID: 1b647d38-5403-4e4d-8f28-ab4160cad840
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- REA.1.1.1 Dokumentation
- REA.1.1.2 Zuweisung der Aufgaben
- REA.1.1.3 Bekanntgabe

Statement

Sicherheitsvorfallsbehandlung MUSS Verfahren und Regelungen zur Behandlung von Sicherheitsvorfällen verankern.

Guidance

Bei Sicherheitsvorfällen gilt es, schnell und systematisch zu reagieren, um weitere Schäden von Daten, Assets oder Personen abzuwenden. Auch erfahrene Experten benötigen dafür klare Anleitungen, um keine Arbeitsschritte zu vergessen oder rechtlichen Unsicherheiten bei der Ermittlung von Ursachen und Ergreifung von Gegenmaßnahmen ausgesetzt zu sein. Die bei der Festlegung des Verfahrens im Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Control: REA.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.1 Grundlagen

Übergeordnetes Control:

REA.1.1 Verfahren und Regelungen

UUID: eb369c39-cde2-4572-b4cb-f8cbe6636691

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: REA.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.1 Grundlagen

Übergeordnetes Control:

REA.1.1 Verfahren und Regelungen

UUID: faee003e-0688-4625-b1df-859ee523d39e

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, rea.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es, die Zuweisung anhand von Rollen (z. B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: REA.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.1 Grundlagen

Übergeordnetes Control:

REA.1.1 Verfahren und Regelungen

UUID: 4d47147b-84cb-49c4-b1ce-286eb13fc667

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: REA.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.1 Grundlagen

UUID: 118f25c8-37b1-413e-9223-d73f689cd181

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung MUSS die Verfahren und Regelungen {{ insert: param, rea.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: REA.1.3 - Übungen zur Vorfallsbehandlung

Tag: "Kompetenzmanagement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.1 Grundlagen

UUID: 3dc90c0b-c5bb-49e1-bb56-10397acc8be9

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Sicherheitsvorfallsbehandlung KANN die Abwehrfähigkeit durch Übungen {{ insert: param, rea.1.3-prm1 }} überprüfen.

Guidance

Komplexere Sicherheitsvorfälle treten auch in größeren Institutionen relativ selten auf. Gleichzeitig erfordern sie dann eine schnelle und kompetente Beurteilung und Behandlung. Um diese sicherzustellen, bietet sich eine regelmäßige Übung an, bei welcher der gesamte Lebenszyklus eines Vorfalls (von der Alarmierung über die Beweissicherung bis zur Nachbehandlung) geübt wird. Beispiele sind Simulationen von Datenleaks, Hacking-Angriffen oder des Ausfalls eines Rechenzentrums. Hierbei sind Übungen effektiver, wenn sie nicht nur theoretisch („nach Papierlage“) vorgenommen werden, sondern soweit wie möglich unter Realbedingungen, z.B. durch das Schwenken auf einen Ausweichsitz zu Zeiten, in denen dadurch keine Geschäftsprozesse beeinträchtigt werden. Zu einer Übung kann sowohl der Umgang mit technischen Werkzeugen als auch mit Verfahrensweisen, Zuständigkeiten im Team und Vertretungsregelungen gehören.

Control: REA.2.1 - Triage und Erstreaktion

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: REA.2 Reaktion
UUID: 988a898a-f7c3-4e6c-9746-8b20e2e85ecd
Aufwand: 2
Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung SOLLTE Meldungen einer Priorität zuweisen.

Guidance

Triage ist ein strukturiertes Vorgehen zur Priorisierung und Ersteinschätzung von Sicherheitsvorfällen, mit dem Ziel, rasch und effizient auf Bedrohungen zu reagieren, Ressourcen gezielt einzusetzen und weitere Schäden zu minimieren. Dabei wird festgestellt, welche Vorfälle sofortige Aufmerksamkeit benötigen, welche weiter analysiert oder beobachtet werden oder irrelevante Fehllarme sind. Kritische Vorfälle können z.B. ein Virenfund auf einem Server, Ransomwarevorfälle oder Spionage durch professionelle Täter sein. Die Umsetzung kann auch automatisiert durch EDR/SOAR geschehen. Eine Erstreaktion ist eine schnelle Handlung, die dazu dient, weitere Schäden wie eine Ausbreitung von Angriffen oder Störungen in Geschäftsprozessen zu vermeiden. Sie kann z.B. in der Abschaltung betroffener Systeme, der Deaktivierung eines Zugangskonto, der Information Nutzender über eine Störung oder der Aktivierung eines Ausweichrechenzentrums bestehen.

Control: REA.2.2 - Automatische Erstreaktion

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: REA.2 Reaktion
UUID: 3c124fd5-bd24-4864-a931-b3a226177f2e
Aufwand: 4
Sicherheitsstufe: erhöht

Statement

Sicherheitsvorfallsbehandlung KANN eine automatische Erstreaktion aktivieren.

Guidance

Die automatische Erstreaktion kann je nach Risikoprofil durch institutionseigene Host- oder Network Intrusion Prevention Systeme (HIPS / NIPS) oder eine vergleichbare Cloud-Lösung umgesetzt werden.

Control: REA.2.3 - Dokumentation von Vorfällen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.2 Reaktion

UUID: 484b2d34-72ad-4472-b5c9-bf0643f7afd7

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung SOLLTE den Vorfall dokumentieren.

Guidance

Dokumentation des Vorfalls meint hier die nachvollziehbare, strukturierte und revisionssichere Aufzeichnung aller für eine spätere Auswertung relevanten Informationen zu einem Sicherheitsvorfall („security incident“). Dazu gehören insbesondere Zeitpunkt, Art, Ausmaß, betroffene Systeme oder Daten sowie eingeleitete Sofortmaßnahmen. Sie dient nicht allein der internen Nachvollziehbarkeit, sondern potenziell auch der rechtlichen Beweissicherung („evidence preservation“) und Verbesserung des Sicherheitsmanagements. Eine lückenhafte oder unvollständige Dokumentation könnte dazu führen, dass Ursachenanalysen fehlschlagen, Wiederholungen nicht verhindert werden oder rechtliche Nachweispflichten – etwa im Rahmen von Datenschutzvorfällen – nicht erfüllt werden könnten. Eine sorgfältig geführte Aufzeichnung kann dagegen die Transparenz im Incident-Handling erhöhen, interne Lernprozesse fördern und Verantwortlichkeiten eindeutig nachvollziehbar machen. Sinnvolle Varianten der Umsetzung können in Form von (1) standardisierten Incident-Report-Templates, (2) elektronischen Ticket- oder Case-Management-Systemen zur Vorfallserfassung oder (3) forensischen Protokollen mit Zeitstempeln und Beweismitteln erfolgen.

Control: REA.2.4 - Diagnosedaten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: REA.2 Reaktion
UUID: b812b0ef-680c-4285-982c-8f0829fd0930
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung SOLLTE Diagnosemethoden für den Fall, dass der Vorfall sich mit den standardisiert erfassten Informationen nicht ausreichend analysieren lässt, verankern.

Guidance

Der Begriff Diagnosemethoden bezeichnet in diesem Kontext strukturierte Verfahren, Werkzeuge oder Analyseansätze, die eingesetzt werden können, um bei Sicherheitsvorfällen zusätzliche Informationen zu gewinnen, wenn die standardisierten Erstinformationen nicht ausreichen. Der Sinn der Vorschrift liegt darin, die Gefahr zu reduzieren, dass ein Vorfall unvollständig verstanden bleibt und dadurch falsche Entscheidungen getroffen werden. Eine Institution kann die Anforderung durch verschiedene technische und prozessuale Maßnahmen abbilden. So kann sie (1) erweiterte Protokollierungsoptionen aktivieren, etwa durch temporäres Erhöhen von Log-Levels in relevanten Systemen, (2) Datensicherungen einzelner betroffener Systeme, Anwendungen oder Netzwerksegmente vornehmen, um die Nachvollziehbarkeit zu gewährleisten, und (3) spezielle Analysewerkzeuge einsetzen, beispielsweise für Speicherabbilder oder Netzwerkanomalien. Ergänzend kann es sinnvoll sein, ein Playbook mit typischen Diagnosepfaden für häufige Vorfallarten bereitzuhalten, sodass Mitarbeitende bei Bedarf gezielt auf tiefergehende Analysen zurückgreifen können.

Control: REA.2.5 - IT-Forensik

Tag: "Advanced Persistent Threats (APT)"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: REA.2 Reaktion
UUID: 6de9ac83-2280-4fbd-ac54-f570faa7b211
Aufwand: 3
Sicherheitsstufe: erhöht

Untergeordnete Controls

- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.5.3 Forensik-Dienstleister

Statement

Sicherheitsvorfallsbehandlung KANN eine forensische Analyse bei Vorfällen, die {{ insert: param, rea.2.5-prm1 }} erfüllen, ausführen.

Guidance

Bei einer forensischen Analyse werden Beweise gesichert und Erkenntnisse zur Verbesserung von Schutzmaßnahmen gegen künftige Vorfälle gewonnen. Die Kriterien richten sich nach dem Schutzbedarf der betroffenen Informationen, Compliance-Verpflichtungen und dem Risikoprofil der Institution als Ganzes. Kriterien können, z.B. Anzeichen für einen (auch teilweise) erfolgreichen, gezielten Angriff, eine Straftat im Zusammenhang mit der Informationsverarbeitung oder eine Kompromittierung schützenswerter Informationen sein. Die Forensik kann durch eigenes qualifiziertes Personal oder durch einen im Vorfeld festgelegten, im Ernstfall zu beauftragenden Dienstleister geschehen. Zur Vorgehensweise können sowohl technische Werkzeuge, als auch rechtliche Rahmenbedingungen und Dokumentationsvorgaben gehören. Für Details siehe BSI-Leitfaden „IT-Forensik“.

Control: REA.2.5.1 - Rechtssichere Beweissicherung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.2 Reaktion

Übergeordnetes Control:

REA.2.5 IT-Forensik

UUID: 73f6c601-3d1c-464f-9728-2e58b819dd3e

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung SOLLTE rechtlich relevante Beweise rechtssicher dokumentieren.

Guidance

Rechtlich relevant sind Beweise, wenn Anzeichen dafür vorliegen, dass bei einem Sicherheitsvorfall gegen Compliance-Verpflichtungen oder interne Arbeitsanweisungen verstoßen wurde. Beispiele sind Vorfälle wie z.B. unberechtigten Zugriffen oder Manipulationen von Daten. Beweise sind rechtssicher dokumentiert, wenn nachvollziehbar ist, wie sie erhoben wurden und sie außerdem sowohl gegen unautorisierte Einsicht als auch Veränderung geschützt aufbewahrt werden. Die Nachvollziehbarkeit von Veränderungen kann z.B. durch eine kryptografische Signatur oder getrennt aufbewahrte Checksummen sichergestellt werden. Außerdem ist es sinnvoll, die Originaldaten aufzubewahren, z.B. als Originaldatenträger oder Sicherungskopie. Für Details siehe BSI-Leitfaden „IT-Forensik“.

Control: REA.2.5.2 - Vier-Augen-Prinzip

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.2 Reaktion

Übergeordnetes Control:

REA.2.5 IT-Forensik

UUID: 6ff56f07-8d72-4f04-9fe9-8f48c89b2e78

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Sicherheitsvorfallsbehandlung KANN zur Forensik ein Vier-Augen-Prinzip verankern.

Guidance

Wenn IT-Forensische Untersuchungen alleine vorgenommen werden, könnte das dokumentierte Vorgehen und damit die Stichhaltigkeit der Beweise bei einer gerichtlichen Überprüfung angezweifelt werden. Besser ist es, solche Untersuchungen gemeinsam mit einem Zeugen vorzunehmen, der qualifiziert ist zu beurteilen, welche Arbeitsschritte dabei vorgenommen wurden. Der Zeuge beglaubigt insbesondere die Prüfsummen der Dokumentation. Allerdings ist es auch ohne Vier-Augen-Prinzip möglich Belege für ein korrektes Vorgehen zu erbringen, beispielsweise durch Vorlage der unveränderten originalen Speichermedien.

Control: REA.2.5.3 - Forensik-Dienstleister

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: REA.2 Reaktion
Übergeordnetes Control:
REA.2.5 IT-Forensik
UUID: ef31b4b8-5e5d-46fc-9baa-237808678a6d
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Sicherheitsvorfallsbehandlung KANN die Bereitschaft eines Forensik-Dienstleisters binnen {{ insert: param, rea.2.5.3-prm1 }} vereinbaren.

Guidance

Um im Ernstfall eine schnelle Untersuchung von Sicherheitsvorfällen zu ermöglichen, kann die Institution bereits unabhängig von einem Vorfall einen Vertrag mit einem qualifizierten Forensik-Dienstleister abschließen. Die Anforderung ist erst umgesetzt, wenn der Dienstleister für den Ernstfall eine Erstreaktion innerhalb einer bestimmten Frist garantiert. Die Untersuchung aller Ergebnisse kann die Frist überschreiten.

Control: REA.2.6 - Ursachenanalyse und Behandlung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: REA.2 Reaktion
UUID: 585be170-c0ef-4b07-9016-71955cb17269
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.3 Koordinierung
- REA.2.6.4 Service Level
- REA.2.6.5 Eskalation

Statement

Sicherheitsvorfallsbehandlung SOLLTE eine Vorgehensweise zur Ursachenanalyse und Behandlung verankern.

Guidance

Um einen Vorfall vollständig beheben zu können, ist es zweckmäßig, zunächst zu analysieren, wie der Vorfall zustande kam (Root Cause Analysis): Welche Personen und Systeme sind betroffen? Welche systematischen Schwachstellen haben zu dem Vorfall geführt? Die Behebung des Vorfalls orientiert sich dann an diesen Erkenntnissen, z.B. durch Schließen der Sicherheitslücken und Wiederherstellung von Daten und Anwendungen. Je nach Vorfall kann die Behandlung durch das Schließen ausgenutzter Sicherheitslücken, einem Test anderer IT-Systeme auf vergleichbare Schwachstellen oder dem Austausch betroffener IT-Systeme, Anwendungen oder Datenbestände umgesetzt werden. Sind die Originaldaten oder -Systeme nicht mehr zu retten, so kann die Neuinstallation betroffener Systeme und die Wiederherstellung von Daten aus Backups eine Möglichkeit der Behandlung sein.

Control: REA.2.6.1 - Dokumentation des Vorgehens

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.2 Reaktion

Übergeordnetes Control:

REA.2.6 Ursachenanalyse und Behandlung

UUID: 0dec7e28-dd82-46b2-9128-f520d7d24c3c

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung SOLLTE die zur Behandlung durchgeführten Tätigkeiten dokumentieren.

Control: REA.2.6.2 - Kommunikation bei Vorfällen

Tag: "Kontakt mit Behörden"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: REA.2 Reaktion
Übergeordnetes Control:
REA.2.6 Ursachenanalyse und Behandlung
UUID: 5af2ba47-33f4-4623-a519-e0f727596890
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- REA.2.6.2.1 Information zuständiger Behörden

Statement

Sicherheitsvorfallsbehandlung SOLLTE eine Vorgehensweise zur Kommunikation bei Vorfällen unter Berücksichtigung von Compliance-Verpflichtungen, Bedürfnissen der interessierten Parteien und der Geschäftsziele verankern.

Guidance

Hierzu gehören beispielsweise Meldepflichten gegenüber Aufsichts- oder Ermittlungsbehörden oder die Information Betroffener. Für personenbezogene Daten siehe auch Art. 34 DSGVO. Für weitere Details siehe ISO/IEC 27035. Bei den Compliance-Verpflichtungen sind einerseits Verpflichtungen zu beachten, die eine Meldung oder einen bestimmten Umfang für Meldungen fordern (z.B. Art. 33 DSGVO), andererseits aber auch Verpflichtungen zur Wahrung der Vertraulichkeit, z.B. aus dem Datenschutz, vertraglicher Pflichten zur Wahrung fremder Geschäftsgeheimnisse oder der staatlichen Geheimhaltung. Im Zweifelsfall ist hier die Inanspruchnahme interner oder externer Rechtsberatung hier empfehlenswert.

Control: REA.2.6.2.1 - Information zuständiger Behörden

Tag: "Kontakt mit Behörden"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: REA.2 Reaktion
Übergeordnetes Control:
REA.2.6.2 Kommunikation bei Vorfällen
UUID: d0c11aa7-cae9-48ca-b4a6-734b0adf336f
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung SOLLTE bei Vorfällen die zuständigen Behörden im Einklang mit den Compliance-Verpflichtungen informieren.

Control: REA.2.6.3 - Koordinierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.2 Reaktion

Übergeordnetes Control:

REA.2.6 Ursachenanalyse und Behandlung

UUID: 4d71c3c6-52f6-44bc-97db-3df446665918

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung SOLLTE die Koordinierung bei Vorfällen verankern.

Guidance

Die Koordinierung der Behandlung von Sicherheitsvorfällen dient dazu, die Auswirkungen auf Daten, Systeme oder Personen zu minimieren, Compliance-Verpflichtungen zu erfüllen und die Wirksamkeit von Gegenmaßnahmen zu verstärken. Hierzu gehören interessierte Parteien wie Aufsichts- und Ermittlungsbehörden, Lieferanten oder Kunden. Für weitere Details siehe ISO/IEC 27035.

Control: REA.2.6.4 - Service Level

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.2 Reaktion

Übergeordnetes Control:

REA.2.6 Ursachenanalyse und Behandlung

UUID: 21a311d8-46eb-4844-b6ae-7ec7597fb124

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Sicherheitsvorfallsbehandlung KANN Service Level verankern.

Guidance

Service Level bei der Sicherheitsvorfallsbehandlung legen verbindliche Zielvorgaben für Reaktions- und Bearbeitungszeiten fest, z. B. wie schnell ein Sicherheitsvorfall erkannt, bestätigt, eingestuft und gelöst werden muss. Damit wird sichergestellt, dass alle Beteiligten klare Erwartungen an Schnelligkeit und Qualität der Reaktion haben.

Control: REA.2.6.5 - Eskalation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.2 Reaktion

Übergeordnetes Control:

REA.2.6 Ursachenanalyse und Behandlung

UUID: 5e9084e2-adb6-417d-b4fb-59735ac5aae9

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung SOLLTE eine Eskalationsleiter verankern.

Guidance

Eine Eskalationsleiter (engl. escalation matrix oder escalation path) bezeichnet in diesem Kontext eine festgelegte Reihenfolge von Melde- und Entscheidungsstufen, die im Falle eines Sicherheitsvorfalls eingehalten wird, um eine zeitgerechte und angemessene Reaktion sicherzustellen. Sie definiert, welche Rollen oder Funktionen bei bestimmten Schweregraden eines Vorfalls informiert, einbezogen oder zur Entscheidung befugt sind. Der Begriff ist hier prozessual zu verstehen, also nicht als hierarchische Personalstruktur, sondern als abgestufter Kommunikations- und Entscheidungsmechanismus innerhalb des Sicherheitsvorfallsprozesses. Der Zweck einer solchen Eskalationsleiter liegt darin, dass sicherheitsrelevante Ereignisse nicht auf operativer Ebene „steckenbleiben“, sondern in ihrer Kritikalität und potenziellen Auswirkung auf höhere Entscheidungsebenen eskaliert werden können. Dadurch kann verhindert werden, dass etwa ein anhaltender Systemausfall, ein möglicher Datenabfluss oder ein Angriff auf kritische Systeme unbemerkt bleibt oder verspätet adressiert wird. Eine wirksam verankerte Eskalationsleiter kann somit sicherstellen, dass die Reaktionszeit kurz, die Zuständigkeiten eindeutig und die Kommunikation nachvollziehbar bleiben. Hier empfiehlt es sich die Anforderung im Zusammenhang mit Notfallplänen, Krisenmanagement und Business Continuity Management zu betrachten – siehe auch Praktik Notfallplanung. Beispiele für Eskalationsstufen: (1) Ereignis, (2) sicherheitsrelevantes Ereignis, (3) sicherheitskritisches Ereignis, (4) Sicherheitsvorfall, (5) Notfall (siehe Notfallplanung), (6) Krise. Die Einstufung erfolgt entsprechend der Definition, die jede Institution für sich festlegt.

Links

related: NOT.1.1 Verfahren und Regelungen

Control: REA.3.1 - Verbesserung durch Erkenntnisse

Tag: "Kompetenzmanagement"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: REA.3 Nachbereitung
UUID: eb3880e9-a0da-4372-84a7-7b0b69b8a852
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- REA.3.1.1 Quantitative Analyse

Statement

Sicherheitsvorfallsbehandlung SOLLTE bisherige Maßnahmen anhand von Erkenntnissen aus Informationssicherheitsvorfällen {{ insert: param, rea.3.1-prm1 }} überprüfen.

Guidance

Erkenntnisse meint hier sowohl technische Aspekte („technical findings“), organisatorische Schwachstellen („process deficiencies“) als auch menschliche Faktoren („human factors“). Dabei ist es zielführend, sich nicht nur auf die unmittelbaren Ursachen zu beschränken (z.B. „Administrierende haben vergessen eine abhängige Komponente zu aktualisieren“), sondern nach den tieferen prozessualen oder technischen Ursachen zu suchen (sog. Root Cause Analyse), z.B. „Abhängigkeiten wurden bislang nicht dokumentiert“. Dabei kann es helfen, wenn alle Beteiligten verstehen, dass es nicht um Schuldzuweisungen geht, sondern um kontinuierliche Verbesserung der Informationssicherheit. Neben technischen Verbesserungen sind dabei auch organisatorische Maßnahmen sinnvoll. Beispielsweise können reale Beispiele in Schulungen verwendet werden, was die Bedeutung für die tägliche Arbeit der Teilnehmenden verdeutlicht und ähnliche Vorfälle in Zukunft vermeiden hilft. Ein regelmäßiger Überprüfungsrythmus – regelmäßig kann hier je nach Kritikalität der Systeme etwa quartalsweise, halbjährlich oder nach jedem relevanten Vorfall bedeuten – dient dazu, bestehende sicherheitsrelevante Maßnahmen anhand der aus Vorfällen gewonnenen Erkenntnisse neu zu bewerten. Die regelmäßige Überprüfung kann verhindern, dass sich Schwachstellen verfestigen, die sonst unentdeckt bleiben könnten, beispielsweise unerkannte Fehlkonfigurationen oder wiederkehrende

Bedienfehler, die bei zukünftigen Angriffen ausgenutzt werden könnten. Gleichzeitig kann sie dazu beitragen, dass eingeführte Verbesserungen nachhaltig wirken und im Alltag nicht wieder verwässern, was die Resilienz der Institution erhöhen kann. Mögliche Optionen reichen von strukturierten Lessons-Learned-Sitzungen über die Pflege eines Katalogs wiederkehrender Ursachen bis hin zur Integration von Anpassungen in technische Härtingsmaßnahmen oder Arbeitsanweisungen.

Links

related: TEST.5.5 Rückblick

related: DLS.3.1 Einhaltung der Sicherheitsvorgaben

related: NOT.3.4 Funktionstest

Control: REA.3.1.1 - Quantitative Analyse

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: REA.3 Nachbereitung

Übergeordnetes Control:

REA.3.1 Verbesserung durch Erkenntnisse

UUID: b2a6adf2-ffe3-4b9d-9678-e938e425cb58

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Sicherheitsvorfallsbehandlung SOLLTE Erkenntnisse einschließlich Art, Umfang und Schäden des Vorfalls dokumentieren.

Guidance

Die Erkenntnisse (findings) umfassen hier eine systematisch strukturierte Auswertung eines Informationssicherheitsvorfalls (security incident), wobei Art die konkrete Typisierung des Ereignisses meint (z.B. unbefugter Zugriff, Fehlkonfiguration, Manipulation), Umfang die tatsächlich betroffenen IT-Systeme, Daten oder Prozesse beschreibt (impact scope) und Schäden sowohl technische als auch betriebswirtschaftliche Beeinträchtigungen bezeichnet (damage bzw. loss). Solch strukturierte Informationen können helfen, wiederkehrende Angriffsmuster oder Probleme zu erkennen und so die Eintrittswahrscheinlichkeit oder das Schadensausmaß zukünftiger Vorfälle zu verringern, während unzureichend dokumentierte Erkenntnisse dazu führen könnten, dass Ursachen im Dunkeln bleiben oder Gegenmaßnahmen nicht auch auf zukünftige Vorfälle wirken können. In der praktischen Umsetzung bietet es sich dazu an Incident-Reports zu erstellen, die sowohl eine quantitative Einordnung anhand von Klassifikationsschemata, als auch eine qualitative Beschreibung von Ursache und Gegenmaßnahmen erfasst wird. Diese Berichte können beispielsweise in ein zentrales, revisionssicheres Register für Vorfallsdokumentationen oder herstellerneutrale Ticket- oder IR-Tools abgelegt werden.

Control: TEST.1.1 - Verfahren und Regelungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.1 Grundlagen
UUID: 90b547d2-dd84-4344-8432-5ecf460cbcb6
Aufwand: 0
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- TEST.1.1.1 Dokumentation
- TEST.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.3 Bekanntgabe

Statement

Änderungen und Tests MUSS Verfahren und Regelungen zum Management von Neueinführungen, Änderungen oder der Entfernung von Komponenten {{ insert: param, test.1.1-prm1 }} verankern.

Guidance

Verfahren und Regelungen beschreiben die formalisierten Abläufe, nach denen Änderungen an informationstechnischen Komponenten – also Hardware, Software oder Konfigurationen – geplant, bewertet, genehmigt und umgesetzt werden; im Englischen ist hier oft von Change Management Procedures die Rede. Weil moderne Infrastrukturen komplexe Abhängigkeiten haben, könnten Änderungen an Systemen und Anwendungen sonst zu unbeabsichtigten Ausfällen oder Sicherheitslücken führen. Dies betrifft auch die Neueinführung von Systemen oder Anwendungen in den Informationsverbund, oder deren Entfernung. Das Ziel der Änderung können Sicherheitsaktualisierungen ebenso wie funktionelle Änderungen sein, da sich auch vermeintlich rein funktionelle Änderungen häufig auf die Sicherheit auswirken. KPI zur Leistungsmessung können z.B. die Fehlerquote bei Änderungen (CFR), die mittlere Wiederherstellungszeit (MTTR) und die Vorlaufzeit für Änderungen (Lead Time) sein. Die Verfahren und Regelungen können dabei entweder einheitlich für den gesamten Informationsverbund, oder alternativ pro Geschäftsprozess oder (Kategorie von) IT-System festgelegt werden, um spezifischen Risiken oder Kontexten gerecht zu werden. Die Umsetzung kann in einem eigenen Prozess, oder integriert in andere Prozesse und Aufgaben, erfolgen. Die bei der Festlegung des Verfahrens im

Einzelnen zu berücksichtigenden Inhalte ergeben sich aus den Anforderungen dieser Praktik.

Control: TEST.1.1.1 - Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.1 Grundlagen
Übergeordnetes Control:
TEST.1.1 Verfahren und Regelungen
UUID: 84b22af7-e18f-4eef-90ee-824d03ed6794
Aufwand: 0
Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests MUSS die Verfahren und Regelungen dokumentieren.

Guidance

Ohne eine Dokumentation könnte die Einhaltung der Verfahren und Regelungen von der Tagesform oder dem individuellen Wissen einzelner Mitarbeiter abhängen, was zu inkonsistenten Entscheidungen und Fehlern führen könnte; insbesondere beim Ausscheiden eines langjährigen Administrators könnte wertvolles prozessuales Wissen verloren gehen. Eine klare Dokumentation sichert die Verbindlichkeit und Wiederholbarkeit und dient als unverzichtbare Grundlage für die Einarbeitung neuer Kollegen, für die Durchführung von Audits und zur einheitlichen Anwendung der Regeln in der gesamten Institution. Die Dokumentation kann in einem eigenständigen Dokument als Richtlinie erfolgen, aber auch als Abschnitt in einem bereits bestehenden Dokument oder über die digital strukturierte Erfassung von Maßnahmen zur Umsetzung der Anforderungen, etwa über eine Software zum Management der Informationssicherheit. Sinnvoll ist es Ort und Struktur der Dokumentation an der jeweiligen Zielgruppe, d.h. den für das Management und die Umsetzung verantwortlichen Personen oder Rollen, auszurichten.

Control: TEST.1.1.2 - Zuweisung der Aufgaben

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.1 Grundlagen

Übergeordnetes Control:

TEST.1.1 Verfahren und Regelungen

UUID: c6cf1fc0-2c5f-473d-858a-ca7c417f272a

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests MUSS die mit den Verfahren und Regelungen verbundenen Aufgaben {{ insert: param, test.1.1.2-prm1 }} zuweisen.

Guidance

Die Zuweisung von Aufgaben bezeichnet die eindeutige und verbindliche Übertragung von konkreten Tätigkeiten und Verantwortlichkeiten des Änderungsprozesses, wie etwa die Risikobewertung, die technische Umsetzung oder die finale Freigabe, an definierte Stellen in der Institution. Der Sinn dieser Vorschrift ist es, die Verantwortlichkeit ("Accountability") für jeden einzelnen Schritt im Prozess klarzustellen. Ohne eine solche Zuweisung könnten kritische Prüfungen unterbleiben, weil sich niemand explizit zuständig fühlt, was wiederum die Wahrscheinlichkeit fehlgeschlagener Änderungen erhöht. Eine klare Regelung kann sicherstellen, dass keine Aufgaben übersehen werden und jede Tätigkeit von einer dafür qualifizierten und befugten Stelle ausgeführt wird, was die Prozesssicherheit signifikant erhöht. Eine bewährte Methode zur Umsetzung ist die Erstellung einer RACI-Matrix (Responsible, Accountable, Consulted, Informed), die tabellarisch für jeden Prozessschritt darstellt, wer für die Durchführung verantwortlich ist, wer die Gesamtverantwortung trägt, wer zu konsultieren und wer zu informieren ist. Diese Zuständigkeiten können auch direkt in einem Workflow- oder Ticketsystem abgebildet werden, sodass Aufgaben, wie beispielsweise Genehmigungsschritte, automatisch an die richtige Gruppe oder Person weitergeleitet werden. Sinnvoll ist es die Zuweisung anhand von Rollen (z.B. "Anwendungsverantwortlicher", "Netzwerkadministrator", "Change Manager") vorzunehmen, statt an konkrete Personen. Dieser Ansatz stellt sicher, dass die Prozesse auch bei Personalwechseln stabil weiterlaufen, da die Zuständigkeit an die Funktion und nicht an das Individuum gebunden ist.

Control: TEST.1.1.3 - Bekanntgabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.1 Grundlagen

Übergeordnetes Control:

TEST.1.1 Verfahren und Regelungen

UUID: 8b0e6953-2916-48ed-aed9-44a06f83fe77

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests MUSS die zuständigen Personen oder Rollen über die Verfahren und Regelungen informieren.

Guidance

Wenn die Zuständigen die etablierten Verfahren nicht kennen, besteht die Gefahr, dass diese – sei es aus Unwissenheit oder Bequemlichkeit – umgangen werden, was die Schutzwirkung des gesamten Managementsystems untergräbt. So könnte ein neuer Systemadministrator eine weitreichende Konfigurationsänderung vornehmen, ohne den vorgeschriebenen Genehmigungsprozess zu durchlaufen, was zu einem unbemerkten Sicherheitsrisiko führen könnte. Eine gezielte Information kann hingegen die Akzeptanz der Regelungen fördern und sicherstellen, dass alle Beteiligten ihre Rolle im Prozess verstehen und die Abläufe korrekt anwenden. Zur Umsetzung ist es sinnvoll die Dokumentation im Rahmen eines Onboarding-Prozesses bekanntzugeben und bei allen Änderungen eine automatische Benachrichtigung aller zuständigen Personen oder Rollen anzustoßen.

Control: TEST.1.2 - Regelmäßige Überprüfung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.1 Grundlagen

UUID: d7d1a4e4-2fbc-404c-a245-a82174f694d4

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests MUSS die Verfahren und Regelungen {{ insert: param, test.1.2-prm1 }} und anlassbezogen auf Aktualität überprüfen.

Guidance

Eine geplante Überprüfung der etablierten Verfahren und Regelungen dient dazu festzustellen, ob diese noch wirksam, effizient und an die aktuellen Gegebenheiten angepasst sind. Eine anlassbezogene Überprüfung wird durch spezifische Ereignisse ausgelöst, wie etwa einen schwerwiegenden Sicherheitsvorfall, eine strategische Neuausrichtung der IT oder neue gesetzliche Anforderungen. Der Zweck dieser Anforderung ist es, die kontinuierliche Verbesserung und Anpassungsfähigkeit des Prozesses sicherzustellen, da veraltete Regelungen neuen technologischen Entwicklungen oder Bedrohungen nicht mehr gerecht werden könnten; ein vor Jahren für monolithische Anwendungen konzipierter Prozess ist beispielsweise für agile Entwicklungsmethoden oder Microservice-Architekturen ungeeignet. Die regelmäßige Überprüfung kann die Effektivität des Sicherheitsmanagements langfristig aufrechterhalten und die Resilienz der Institution stärken.

Control: TEST.1.3 - Einschränkung von Änderungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.1 Grundlagen

UUID: 85d5939d-b2e4-419f-9205-ad1e2a61cb7c

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE die Durchführung von Änderungen auf Administrierende einschränken.

Guidance

Ziel ist es, zu verhindern, dass unautorisierte Personen Eingriffe in produktive Systeme vornehmen. Ohne diese Einschränkung könnte Schadcode eingeschleust werden, Konfigurationen unbeabsichtigt verändert oder sensible Daten offengelegt werden. Die klare Zuweisung an Administrierende kann gleichzeitig sicherstellen, dass Änderungen nachvollziehbar und fachgerecht durchgeführt werden, wodurch die Stabilität und Verfügbarkeit von Systemen geschützt werden kann. Eine Institution kann die Anforderung beispielsweise durch folgende Maßnahmen umsetzen: (1) Verwendung von Rollenkonzepten, bei denen nur Administrierende Schreibrechte in produktiven Systemen besitzen, während anderen Rollen lediglich Leserechte eingeräumt werden können, (2) Einsatz von Testumgebungen oder Sandbox-Systemen, in denen auch Nicht-Administrierende Änderungen gefahrlos vorbereiten und dokumentieren können, (3) Einführung von Change-Management-Workflows mit Genehmigungsschritten, so dass Administrierende Änderungen erst nach dokumentierter Prüfung umsetzen können, und (4) Einsatz von technischen Kontrollmechanismen wie „Just-in-Time“-Privilegien oder Protokollierung von administrativen Sitzungen, wodurch die Nachvollziehbarkeit und Integrität der Änderungen verbessert werden kann.

Control: TEST.2.1 - Versionshistorie

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.2 Vorbereitung
UUID: 4fb97f16-4d41-49cb-99fe-ff623b2a2874
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE eine Versionshistorie wesentlicher Änderungen protokollieren.

Guidance

Wesentlich sind Änderungen, wenn sie Auswirkungen auf die Informationssicherheit von Produktivsystemen und -anwendungen haben können, die über eine geringe Anzahl von Nutzenden hinausgeht.

Links

related: KONF.2.1.1 Versionierung der Systemkonfiguration

Control: TEST.2.2 - Folgenabschätzung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.2 Vorbereitung
UUID: fcba1d19-78ec-4d60-8760-f34c081c2386
Aufwand: 2
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- TEST.2.2.1 Kategorisierung von Änderungen
- TEST.2.2.2 Anpassung der Dokumentation
- TEST.2.2.3 Dokumentation der Abhängigkeiten

Statement

Änderungen und Tests für Administrierende SOLLTE zu einer strukturierten Folgenabschätzung vor wesentlichen Änderungen anweisen.

Guidance

Sinnvoll ist es die Ausführlichkeit der Folgenabschätzung an Umfang und Reichweite der Änderungen, sowie dem Risikoprofil betroffener Assets zu orientieren: Empfehlenswert ist es die Änderungen je nach Abschätzung der Folgen in Klassen einzusortieren (z.B. Geringe Auswirkungen, Mittlere Auswirkungen, Hohe Auswirkungen) und die weitere Prüftiefe nach dieser Einstufung auszurichten.

Control: TEST.2.2.1 - Kategorisierung von Änderungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.2 Vorbereitung

Übergeordnetes Control:

TEST.2.2 Folgenabschätzung

UUID: fc6014c5-d95d-428b-96bd-9f5ef9fba660

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE Änderungsvorhaben einer Kategorie zuweisen.

Guidance

Dabei werden Änderungen je nach Abschätzung der Folgen in Kategorien einsortiert, die im Verhältnis zu den möglichen Auswirkungen stehen (z.B. Geringe Auswirkungen, Mittlere Auswirkungen, Hohe Auswirkungen). Umfang und Tiefe der weiterer Prüfungen kann dann nach dieser Einstufung ausgerichtet werden.

Control: TEST.2.2.2 - Anpassung der Dokumentation

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.2 Vorbereitung

Übergeordnetes Control:

TEST.2.2 Folgenabschätzung

UUID: 474497ca-0e99-4f0a-8f84-abdea042aa80

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE die geplanten Änderungen dokumentieren.

Guidance

Je nach Inhalt der Änderung können hierzu Konfigurationsdateien, Sicherheitsrichtlinien, oder begleitende Dokumente wie ein IT-Betriebshandbuch oder für Nutzende gedachte Anwenderhandbücher oder Wikis gehören.

Control: TEST.2.2.3 - Dokumentation der Abhängigkeiten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.2 Vorbereitung
Übergeordnetes Control:
TEST.2.2 Folgenabschätzung
UUID: e3dfaa37-9789-4b95-8cbb-32e70addab94
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE von der Änderung betroffene Abhängigkeiten dokumentieren.

Guidance

Betroffene Abhängigkeiten sind sowohl alle Systeme und Anwendungen, die durch die geplanten Änderungen beeinflusst werden könnten, als auch die Abhängigkeiten der zu ändernden Systeme oder Anwendungen selbst (Up- and Downstream Dependency Management). Hierzu können z.B. Programmquellbibliotheken, angebundene Systeme, Netzanbindungen oder Anwendungen zählen.

Control: TEST.3.1 - Sicherheitstest

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.3 Tests
UUID: 2edf4a68-0d86-4da9-ada4-9939c2508f2c
Aufwand: 3
Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- TEST.3.1.1 Dokumentation von Testergebnissen
- TEST.3.1.2 Integritätstest
- TEST.3.1.3 Testdaten
- TEST.3.1.4 Testumgebung
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.3.1.10 Penetrationstest bei Änderungen

Statement

Änderungen und Tests SOLLTE vor wesentlichen Änderungen die Einhaltung der Sicherheitsanforderungen testen.

Guidance

Änderungen sind wesentlich, wenn sie die Informationssicherheit von Produkktivsystemen und -anwendungen betreffen und über eine geringe Anzahl von Nutzenden hinaus Auswirkungen haben können. Dabei sind sowohl die Sicherheitsanforderungen relevant, die direkt durch IT-Produkte umgesetzt werden (technische Anforderungen), als auch die prozessualen Anforderungen, die von der Änderung betroffen sind, etwa zur Überwachung von Ereignissen oder zur Sensibilisierung des Personals. Die Sicherheitsanforderungen ergeben sich aus den für das jeweilige Zielobjekt geltenden Vorgaben aus allen Praktiken. Sowohl die Funktionalität einzelner Module als auch das Zusammenspiel von Schnittstellen ist wichtig, um Sicherheitslücken frühzeitig zu erkennen.

Links

related: DET.5.3 Schwachstellenscans

Control: TEST.3.1.1 - Dokumentation von Testergebnissen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.3 Tests

Übergeordnetes Control:

TEST.3.1 Sicherheitstest

UUID: b7a747d3-cb11-46ce-8d0c-c57cc31d5ad5

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE Tests einschließlich Prüfschritte, Ergebnissen und ggf. vorgenommenen Korrekturen dokumentieren.

Guidance

Die Dokumentation von Tests zielt primär darauf ab, Transparenz und Nachvollziehbarkeit bei Änderungen zu gewährleisten, was das Risiko unbeabsichtigter Sicherheitslücken, Systemausfälle oder Datenverluste erheblich reduzieren kann. Ohne strukturierte Testdokumentation könnten beispielsweise fehlerhafte Konfigurationsänderungen unbemerkt in Produktivsysteme gelangen, was potenziell zu Verfügbarkeitsstörungen, verfälschten Daten oder kompromittierten Anwendungen führen könnte. Ein dokumentierter Testprozess ermöglicht zudem eine effektive Ursachenanalyse bei auftretenden Störungen, da alle durchgeführten Änderungen mit ihren beabsichtigten Wirkungen transparent nachvollzogen werden können. Eine nachvollziehbare und digital strukturierte Verknüpfung von Anforderung zu Prüfschritt und Prüfergebnissen kann durch OSCAL-Dokumente als strukturierte Daten erstellt werden. Gezielte Tests vor wesentlichen Änderungen tragen dazu bei, unbeabsichtigte Schwachstellen zu vermeiden, die zu unbefugtem Datenzugriff, Verlust von Geschäftsinformationen oder Ausfällen kritischer Systeme führen könnten. Je nach Art und Umfang der Änderungen lassen sich beispielsweise physische Zustände oder die Ausführung von Systemfunktionen verifizieren. Dabei werden sowohl die gewünschten Sicherheitsfunktionen als auch unerwünschte Zustände getestet, zum Beispiel, dass keine unautorisierten Funktionen aktiviert sind oder Apps ungewollt mit unbekannten Internetservern kommunizieren. Anwendbare Testarten umfassen statische und dynamische Tests, Unit- und Integrationstests sowie Re-

gressionstests. Relevant ist dabei sowohl das Testen von manuellen Eingaben über die Benutzerschnittstelle als auch der Zugriffe über das Netzwerk, etwa über eine API. Die Tests können automatisiert (z. B. Unit-Tests, CI/CD-Tests, Schwachstellen-scanner) oder manuell unterstützt (z. B. Click-Tests oder die Auswertung von LLM-Zusammenfassungen) durchgeführt werden. Sinnvoll ist es, automatische Tests für alle Funktionen und Codepfade einzusetzen, ergänzt durch manuelle Tests der wichtigsten Funktionen, wie Authentifizierung und Verschlüsselung, sowie durch Stichproben der übrigen Funktionen.

Control: TEST.3.1.2 - Integritätstest

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.3 Tests

Übergeordnetes Control:

TEST.3.1 Sicherheitstest

UUID: f59da6fb-9fb8-4eaa-b338-1081e9094029

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE die Integrität von Installationsdateien testen.

Guidance

Dies kann z.B. durch Vergleich von Prüfsummen geschehen. Wenn möglich ist der Einsatz automatisierter Prüfungen empfehlenswert, es kann aber auch ein manueller Abgleich z.B. mit der Herstellerwebseite erfolgen.

Links

related: DET.5.10.4 Integritätsprüfung von Patches

Control: TEST.3.1.3 - Testdaten

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.3 Tests

Übergeordnetes Control:

TEST.3.1 Sicherheitstest

UUID: 8a88300f-98ee-41e3-9622-be00c705f252

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE die Testfälle abdeckende, aber unkritische Testdaten verankern.

Guidance

Testdaten (engl. test data) sind synthetisch erstellte oder abstrahierte Daten, die zur Durchführung von Testfällen genutzt werden. „Unkritisch“ bedeutet hier, dass die Daten keinen schützenswerten Daten wie Geschäftsgeheimnisse oder sicherheitsrelevanten Konfigurationsdetails enthalten. Testfälle (engl. test cases) sind vorab definierte Szenarien oder Abläufe, die das Verhalten einer Anwendung oder eines Systems gezielt prüfen sollen. Der Zweck der Anforderung liegt darin, sicherzustellen, dass Testaktivitäten einerseits realistische Bedingungen nachbilden, andererseits aber keine Risiken durch unbeabsichtigte Preisgabe oder Manipulation produktiver Daten entstehen. Ein Vorfall könnte beispielsweise darin bestehen, dass versehentlich echte Kundendaten in einer Testumgebung landen und durch unzureichende Sicherung Dritten zugänglich werden; durch den Einsatz unkritischer Testdaten kann dieses Risiko vermieden und dennoch die Qualität der Tests gewährleistet werden. Eine Institution kann die Anforderung praktisch umsetzen, indem sie Testdatensätze automatisiert generieren lässt, etwa durch Anonymisierung oder Pseudonymisierung produktiver Daten oder durch die Nutzung von Zufallswerten, die für Testlogik realistisch wirken. Zusätzlich kann es hilfreich sein, Regeln für Entwickler und Tester festzulegen, die dokumentieren, welche Arten von Daten zulässig sind. Auch Tools zur data masking oder synthetic data generation können verwendet werden, um komplexe Datenstrukturen ohne reale Inhalte nachzubilden.

Control: TEST.3.1.4 - Testumgebung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.3 Tests

Übergeordnetes Control:

TEST.3.1 Sicherheitstest

UUID: 9c86f2de-9a7a-4fff-b833-7e596fdb32a8

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE eine dedizierte Testumgebung installieren.

Guidance

Eine dedizierte Testumgebung (auch Entwicklungsumgebung oder Laborumgebung genannt) ist hier eine von der Produktionsumgebung unabhängige Infrastruktur, die speziell für die Durchführung von Änderungen, Prüfungen und Qualitätssicherungsmaßnahmen vorgesehen ist. Sie dient dazu, geplante Anpassungen, Updates oder Neuentwicklungen realistisch nachzustellen, ohne die Verfügbarkeit oder Integrität der produktiven Systeme und Daten zu gefährden. Zur Produktivumgebung zählen dabei auch Betriebssysteme, verwendete Datenbanken und Netzschnittstellen. Dediziert bedeutet in diesem Zusammenhang, dass Ressourcen – beispielsweise Server, Datenbanken, Netzsegmente oder virtuelle Umgebungen – ausschließlich für Testzwecke bereitgestellt werden und nicht gleichzeitig produktiven Aufgaben dienen. Der Zweck dieser Vorgabe liegt darin, unbeabsichtigte Auswirkungen von Änderungen auf laufende Systeme zu vermeiden. Ohne eine solche Testumgebung könnte ein fehlerhaftes Update unmittelbar zu Produktionsausfällen führen oder sensible Daten unbeabsichtigt preisgeben. Eine Trennung kann dagegen sicherstellen, dass Schwachstellen oder Inkompatibilitäten frühzeitig erkannt werden, wodurch die Stabilität und Sicherheit der produktiven Systeme erhalten bleiben. Zur Umsetzung kann eine Institution verschiedene Maßnahmen einsetzen: (1) Sie kann separate physische oder virtuelle Serverlandschaften bereitstellen, die die Produktionsumgebung realitätsnah abbilden. (2) Sie kann Testdatenbanken mit anonymisierten oder synthetisch generierten Daten nutzen, um Datenschutzrisiken zu vermeiden. (3) Sie kann durch ein definiertes Deployment-Verfahren sicherstellen, dass Änderungen zunächst automatisiert in die Testumgebung ausgerollt und dort validiert werden,

bevor eine Freigabe für die Produktion erfolgt.

Links

related: ARCH.7.3 Entwicklungs- und Testumgebungen

related: ARCH.2.2.8 Segmentierung von Test und Betrieb

Control: TEST.3.1.5 - Kontinuierliche Tests

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.3 Tests

Übergeordnetes Control:

TEST.3.1 Sicherheitstest

UUID: 73fab6c7-c60f-4ee5-bd97-e842915cf98d

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Änderungen und Tests KANN die Auswirkungen bei jeder Änderung automatisch testen.

Guidance

„Automatisch testen“ meint den Einsatz technischer Verfahren oder Werkzeuge („continuous testing“), um bei Änderungen an Systemen oder Anwendungen unmittelbar und ohne manuelles Eingreifen Prüfungen auszuführen. Gemeint sind hier vordefinierte Testszenarien, die mit jedem Update, Patch oder Konfigurationswechsel ablaufen und systematisch überprüfen, ob die vorgesehenen Funktionen erhalten bleiben und ob unerwünschte Nebenwirkungen auftreten. Der Zweck liegt darin, dass Änderungen zwar notwendig sind, diese aber unbeabsichtigte Sicherheitslücken oder Funktionsstörungen mit sich bringen könnten – ein fehlerhaftes Update könnte beispielsweise Authentifizierungsprozesse umgehen lassen oder kritische Daten unzugänglich machen. Durch automatisierte Tests kann die Institution dagegen frühzeitig erkennen, ob eine Änderung die Vertraulichkeit, Integrität oder Verfügbarkeit gefährden könnte, und die Fehlerquote im Betrieb insgesamt senken. Umsetzungsmöglichkeiten können unterschiedlich gestaltet werden: Eine Institution kann (1) Continuous-Integration/Continuous-Delivery-Pipelines (CI/CD) einrichten, in die automatisierte Unit- und Integrationstests integriert sind, (2) produktionsnahe Szenarien in Testumgebungen abbilden und in denen Sicherheitstests automatisch mitlaufen, oder (3) Skripte einsetzen, die nach Konfigurationsänderungen direkt auf bekannte Schwachstellen oder das Vorhandensein von Sicherheitsfunktionen prüfen. Auch die Verwendung von Regressionstests, die kritische Kernfunktionen gezielt wiederholt prüfen, kann ein bewährtes Mittel sein, um sicherzustellen, dass durch eine Änderung keine unbeabsichtigten Seiteneffekte

te ausgelöst werden. Automatische Test ermöglichen es auch die Dokumentation der Testergebnisse automatisiert zu erstellen, sodass Verantwortliche sofort eine Übersicht über den Status erhalten.

Control: TEST.3.1.6 - Chaos Engineering

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.3 Tests

Übergeordnetes Control:

TEST.3.1 Sicherheitstest

UUID: 32a4ff7c-ee41-4d31-8a1e-f15ea1373181

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Änderungen und Tests KANN die Resilienz bei Simulation verschiedenartiger Störungen testen.

Guidance

Chaos Engineering kann helfen, die Zuverlässigkeit von Systemen oder Anwendungen zu erhöhen, indem es die Resilienz, also die Fähigkeit bei störenden Einflüssen den Betrieb fortzusetzen oder wiederherzustellen, durch simulierte Ausfälle oder Störungen testet. Dabei ist jedoch zu beachten, dass dabei keine geschäftskritischen, im Betrieb befindlichen Dienste gestört werden. Daher ist der Ansatz nur nach einer Analyse und Abwägung der Risiken sinnvoll. Zweckmäßig ist es dabei, geschäftskritische Systeme und Anwendungen mit hohen Auswirkungen zu priorisieren, häufige Ausfallmodi zu testen, kritische Abhängigkeiten unter Stress zu setzen, vergangene Vorfälle nachzubilden und Systemannahmen durch methodische Prozesse zu hinterfragen. Hierzu kann eine Karte der Abhängigkeiten verwendet werden oder eine Analyse kritischer Pfade. Wertvolle Experimente können Netzwerkbeeinträchtigungen, Dienstauffälle, Abhängigkeitsunterbrechungen, Ressourcenerschöpfung, Multiregionsausfälle und Zeitsynchronisationsprobleme umfassen. Geschäftskritische Dienste können dabei z.B. durch eine Begrenzung auf bestimmte Systeme, oder Durchführung solcher Tests nur außerhalb der Betriebszeiten geschützt werden.

Control: TEST.3.1.7 - Analyse der Zusammensetzung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.3 Tests

Übergeordnetes Control:

TEST.3.1 Sicherheitstest

UUID: ab876d7f-a36e-4efe-94b3-d62af35b3ca8

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Änderungen und Tests KANN die Zusammensetzung der Änderungen testen.

Guidance

Eine Analyse der Zusammensetzung (Composition Analysis) ist die systematische Untersuchung und Bewertung der Bestandteile einer Software oder eines Systems – insbesondere in Bezug auf deren Herkunft, Eigenschaften und potenzielle Schwachstellen. Hierzu können auch (teil-)automatisierte Lösungen eingesetzt werden, z.B. können SBOMs in eine Plattform zur Verwaltung von Schwachstellen importiert werden, die eine Bereitstellung blockiert, wenn eine CVSS ≥ 9.0 -Schwachstelle keine kompensierende Maßnahme hat.

Control: TEST.3.1.8 - Fuzzing

Tag: "Error Handling"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.3 Tests
Übergeordnetes Control:
TEST.3.1 Sicherheitstest
UUID: 5bd70855-3756-4f70-b5d5-98e5211cd1ed
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Änderungen und Tests KANN die Stabilität gegen Fehlerzustände oder Abstürze bei der Eingabe großer Mengen an Zufallsdaten testen.

Guidance

Fuzzing ist eine automatisierte Softwaretestmethode, mit der unerwartete Schwachstellen und Fehler in Anwendungen durch Eingabe zufälliger, unerwarteter oder ungültiger Daten aufgedeckt werden können. Der Hauptzweck besteht darin, Grenzbedingungen zu prüfen und Programmabstürze, Speicherlecks oder sicherheitskritische Fehler wie Buffer Overflows zu identifizieren, bevor Angreifer diese ausnutzen können. Kann durch spezialisierte Tools oder kontinuierliches Fuzzing in der CI/CD-Pipeline umgesetzt werden. Für einen effektiven Einsatz empfiehlt es sich, mit strukturiertem Fuzzing zu beginnen, das auf bekannten Protokollspezifikationen oder Datenformaten basiert, Fuzzing-Tests in die frühen Phasen des Entwicklungszyklus zu integrieren, alle gefundenen Fehler systematisch zu dokumentieren und zu beheben, sowie regelmäßig neue Testfälle auf Basis entdeckter Schwachstellen zu entwickeln, um die Testabdeckung kontinuierlich zu verbessern.

Control: TEST.3.1.9 - Lasttest

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.3 Tests
Übergeordnetes Control:
TEST.3.1 Sicherheitstest
UUID: ae64d67c-c9fd-48cd-837e-f71ebc850e29
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Änderungen und Tests KANN die Belastbarkeit bei hoher Auslastung testen.

Guidance

Ziel ist es, die Dimensionierung der Ressourcen zu verifizieren und Fehler zu entdecken, die nur bei höherer Last auftreten. Hierzu können z.B. eine hohe Zahl gleichzeitiger Verbindungen, große Datenmengen oder eine hohe Zahl paralleler Interaktionen genutzt werden. Die Höhe der Auslastung kann sich dabei z.B. nach der maximalen Anzahl erwarteter gleichzeitiger Nutzungen richten.

Control: TEST.3.1.10 - Penetrationstest bei Änderungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.3 Tests

Übergeordnetes Control:

TEST.3.1 Sicherheitstest

UUID: d994f7fa-1271-4563-9fc5-e3189fb362b7

Aufwand: 5

Sicherheitsstufe: erhöht

Statement

Änderungen und Tests KANN bekannte Schwachstellen bei kritischen Änderungen testen.

Guidance

Bei einem Penetrationstest führen qualifizierte Sicherheitsexperten kontrollierte Angriffe auf Systeme, Anwendungen oder Netzwerke durch. Der primäre Zweck besteht darin, die tatsächliche Angriffsfläche aus der Perspektive eines potenziellen Angreifers zu bewerten, reale Ausnutzungsmöglichkeiten zu demonstrieren und die Wirksamkeit implementierter Sicherheitsmaßnahmen unter realistischen Bedingungen zu verifizieren. Praktische Umsetzungsbeispiele umfassen Black-Box-Tests ohne Vorkenntnisse des Systems, Grey-Box-Tests mit begrenztem Zugang und Wissen sowie White-Box-Tests mit vollständigem Quellcode-Zugriff, wobei Tools zur Automatisierung und Strukturierung der Tests eingesetzt werden können. Für ein effektives Pentesting empfiehlt es sich, den Testumfang klar zu definieren und zu dokumentieren, realistische Angriffsziele und Erfolgsmetriken festzulegen, ausreichend Zeit für die Behebung identifizierter Schwachstellen im Release-Plan einzuplanen, ein erfahrenes, unabhängiges Testteam einzusetzen, das nicht an der Entwicklung beteiligt war, sowie Re-Tests nach der Behebung von Schwachstellen durchzuführen, um sicherzustellen, dass alle identifizierten Risiken vor dem Produktivgang angemessen adressiert wurden.

Links

related: DET.5.4 Regelmäßige Penetrationstests

related: DET.5.2 Schwachstellenregister

Control: TEST.3.2 - Testabdeckung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.3 Tests
UUID: 15a34e7f-067f-4f27-92a8-4d32cce4dee6
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE die Testabdeckung {{ insert: param, test.3.2-prm1 }} überprüfen.

Guidance

Ein ungenügendes Testverfahren könnte beispielsweise dazu führen, dass Schwachstellen in kritischen Anwendungen unentdeckt bleiben, was wiederum zu Datenverlust, unbefugtem Zugriff oder Systemausfällen führen könnte. Ein Beispiel hierfür ist der Fall einer industriellen Steuerungsanlage, bei der eine nicht ausreichend getestete Firmware-Aktualisierung zu einem Sicherheitsversagen und anschließendem Produktionsausfall führt. Der Begriff "Testabdeckung" (engl. "test coverage") bezeichnet hierbei den Umfang, in dem Komponenten, Funktionen und Schnittstellen eines Systems durch strukturierte Tests überprüft werden. Zur Umsetzung kann eine Institution verschiedene Maßnahmen implementieren: Für Software kann ein Code-Coverage-Monitoring etabliert werden, während für Hardware systematische Testmatrizen entwickelt werden können, die alle relevanten Betriebsparameter und Umgebungsbedingungen abdecken. Test-Dashboards können sowohl Software- als auch Hardware-Metriken visualisieren und in Entwicklungs- bzw. Implementierungsprozesse integriert werden. Für Hardware können FMEA-Analysen (Failure Mode and Effects Analysis) die kritischen zu testenden Komponenten identifizieren, während Software durch automatisierte CI/CD-Tests abgesichert werden kann. Bei der Implementierung empfiehlt es sich, einen risikobasierten Ansatz zu verfolgen, bei dem zuerst sicherheitskritische Komponenten umfassend getestet werden. Zudem kann eine systematische Dokumentation aller Testfälle und -ergebnisse, sowohl für Hardware- als auch für Software-Komponenten, die Nachvollziehbarkeit und kontinuierliche Verbesserung der Testabdeckung unterstützen. Zudem kann eine Kombination aus verschiedenen Testebenen (z.B. Stichproben, automatisierte und manuelle Verfahren, Unit-, Integrations- und Systemtests) eine umfassendere

Abdeckung gewährleisten.

Control: TEST.4.1 - Autorisierung von Änderungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.4 Freigabe

UUID: 1aa8319f-93fb-4236-991a-d799ab69e0c2

Aufwand: 3

Sicherheitsstufe: normal-SdT

Untergeordnete Controls

- TEST.4.1.1 Unabhängigkeit der Autorisierung
- TEST.4.1.2 Dokumentation der Freigabe

Statement

Änderungen und Tests SOLLTE kritische Änderungen anhand von Kriterien einschließlich der Sicherheitsanforderungen autorisieren.

Guidance

Änderungen gelten als kritisch, wenn sie breite Auswirkungen auf Geschäftsprozesse haben, beispielsweise die Aktivierung der Zwei-Faktor-Authentifizierung am zentralen Verzeichnisdienst. Die Kritikalität ergibt sich zudem aus Art und Umfang der Änderung, etwa bei umfangreichen Migrationen oder sicherheitsrelevanten Fehlerbehebungen. Kritische Änderungen betreffen häufig die Bereitstellung für eine große Zahl interner oder externer Nutzer oder Eingriffe in hochverfügbare Systeme. Zu den maßgeblichen Kriterien für die Freigabe zählen das fehlerfreie Durchlaufen definierter Tests, eine ausreichende Nutzerakzeptanz in einem Beta-Test und das erfolgreiche Bestehen von Penetrationstests. Zweckmäßig ist eine mehrstufige Autorisierung, in der Änderungen anhand der prognostizierten Auswirkungen den Kategorien niedrig, mittel oder hoch zugeordnet und mit abgestuften Genehmigungsanforderungen verknüpft werden. Während bei geringfügigen Änderungen an unkritischen Systemen eine konzentrierte Prüfung grundlegender Sicherheitsanforderungen wie Authentifizierung, Verschlüsselung und Härtung ausreichen kann, erfordern umfangreiche Vorhaben mit hohem Risikoprofil in der Regel automatisierte Prüfmechanismen, ergänzt durch Checklisten für manuelle Tätigkeiten, um die Auswirkungen verlässlich beherrschbar zu halten.

Links

related: DET.5.1 Zeitnahes Schwachstellenmanagement

related: BES.5.9.1 Autorisierung von Änderungen

Control: TEST.4.1.1 - Unabhängigkeit der Autorisierung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.4 Freigabe

Übergeordnetes Control:

TEST.4.1 Autorisierung von Änderungen

UUID: a0cd7536-0e8f-4658-99d4-c04f93dad878

Aufwand: 4

Sicherheitsstufe: erhöht

Untergeordnete Controls

- TEST.4.1.1.1 Staging

Statement

Änderungen und Tests KANN kritische Änderungen auch durch eine von der Implementierung unabhängige Person autorisieren.

Guidance

Eine Freigabe durch eine unabhängige Person ist die nachweisliche Bestätigung der Testergebnisse durch eine fachlich qualifizierte, aber nicht an der Entwicklung, Durchführung oder unmittelbaren Implementierung der getesteten Änderung beteiligte Person. Ziel ist es, Objektivität und Unvoreingenommenheit sicherzustellen und das Vier-Augen-Prinzip für kritische Änderungen zu wahren. Hierbei genügt es, wenn neben beteiligten Personen auch eine unabhängige Person die Änderung autorisiert hat, wie z.B. bei einem Change Advisory Board, an dem mehrere Personen beteiligt sind. Die geltenden Anforderungen sind alle für das Zielobjekt ausgewählten Sicherheitsanforderungen, z.B. Verifikation korrekter TLS-Konfiguration oder Fertigstellung einer Datensicherung mit korrektem Umfang zu geforderter Zeit gemäß Konzept. Empfehlenswert ist es den Prozess in einem Versionkontrollsystem abzubilden, sodass die Dokumentation der Änderungen und der Freigabe weitestgehend automatisiert stattfindet.

Control: TEST.4.1.1.1 - Staging

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.4 Freigabe

Übergeordnetes Control:

TEST.4.1.1 Unabhängigkeit der Autorisierung

UUID: 27cb8300-6019-432f-a688-82544667aca0

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE die freizugebenden Änderungen in einer von der Produktumgebung getrennten Staging-Umgebung, deren Komponenten so weit wie möglich der Produktivumgebung entsprechen, testen.

Guidance

Eine Staging-Umgebung ist von der Produktivumgebung getrennt, wenn sie keine IT-Systeme, Anwendungen oder Datenquellen der Produktivumgebung verwendet. Sie entspricht so weit wie möglich der Produktivumgebung, damit zwischen Freigabe und Produktivbetrieb möglichst wenige Abweichungen vorkommen, z.B. hinsichtlich der Schwachstellen eingesetzter Softwareversionen oder der Verfügbarkeit von Ressourcen in verschiedenen Rechenzentren.

Control: TEST.4.1.2 - Dokumentation der Freigabe

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.4 Freigabe

Übergeordnetes Control:

TEST.4.1 Autorisierung von Änderungen

UUID: 97bc7db7-ea9d-47ea-9402-163af7470f4b

Aufwand: 4

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE die Freigabe einschließlich Zeitpunkt, Vorhaben, Freigabekriterien und freigebender Personen dokumentieren.

Guidance

Je nach Organisationstruktur kann es sinnvoll sein, weitere Angaben aufzuführen, z.B. in der Freigabe durchgeführte Prüfschritte oder weitere beteiligte Personen. Allerdings kann sich die Freigabe auch auf eine Dokumentation der zuvor durchgeführten Tests stützen. In jedem Fall handelt es sich nur dann um eine Freigabe, wenn die entscheidenden Personen oder Rollen eine eigenständige Entscheidung getroffen haben, die auf einer eigenen Untersuchung des Änderungsvorhabens basiert.

Links

related: ASST.5.7 Dokumentation von Wartungen

Control: TEST.4.2 - Signatur

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.4 Freigabe
UUID: 9a713453-4359-4383-a94d-5cfeeae045b8
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Änderungen und Tests KANN eine Signatur der Freigabeerklärung ausführen.

Guidance

Die Signatur der Freigabeerklärung ist hier als eine digitale oder handschriftliche Unterschrift zu verstehen, die dokumentiert, dass eine geplante Änderung oder ein Test geprüft, bewertet und zur Umsetzung freigegeben wurde. Die Signatur kann damit sowohl eine elektronische Signatur nach gängigen Standards (z. B. qualifizierte elektronische Signatur im Ticketsystem) als auch eine händische Unterschrift sein. Sie stellt nicht nur eine rechtliche, sondern vor allem eine technische und organisatorische Nachvollziehbarkeit sicher, indem eindeutig erkennbar wird, wer eine Entscheidung zur Durchführung von Änderungen verantwortet hat. Die Freigabe durch eine Signatur kann dazu beitragen, dass unbeabsichtigte oder fehlerhafte Änderungen nicht unkontrolliert in den Betrieb gelangen. Ein fehlender Nachweis könnte im Vorfallfall zu Streitigkeiten über Verantwortlichkeiten führen oder die forensische Nachvollziehbarkeit erschweren. Ebenso könnte ohne dokumentierte Freigabe eine ungetestete Änderung produktive Systeme beeinträchtigen und Ausfälle oder Datenverlust verursachen. Durch eine dokumentierte Signatur kann hingegen nachvollziehbar gemacht werden, dass fachliche, technische und sicherheitsrelevante Prüfungen stattgefunden haben und die Entscheidung zur Umsetzung bewusst und überprüfbar getroffen wurde.

Control: TEST.4.3 - Rückfalllösung

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"

Gruppe: TEST.4 Freigabe

UUID: aacff36a-50db-4403-9a46-34fa044a8a4d

Aufwand: 3

Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE eine Rückfalllösung verankern.

Guidance

Kritisch sind administrative Änderungen an geschäftskritischen Systemen, da ihr Ausfall gravierende Folgen haben könnte. Die Kritikalität ergibt sich außerdem aus Art und Umfang der Änderungen, z.B. umfangreiche Migration oder Bugfix. Maßnahmen können z.B. die Wiederherstellung aus einer vorher erstellten aktuellen Datensicherung, einer Versionsverwaltung oder Blue-Green-Deployment sein.

Control: TEST.4.4 - Geregelte Notfalländerungen

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.4 Freigabe
UUID: fe2a551e-4660-4796-92bf-2304adb70a61
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE Regelungen für Notfalländerungen einschließlich Vorgehensweise, Zuständigkeiten, erforderlicher Ressourcen und minimaler Prüfschritte verankern.

Guidance

Ein Notfall-Deployment-Prozess ermöglicht eine schnelle Reaktion auf akute Bedrohungen. Als Notfall-Ereignisse kommen z.B. Zero-Day-Exploits, kritische Sicherheitslücken mit aktiver Ausnutzung, schwerwiegende Produktionsfehler mit Geschäftsauswirkungen oder koordinierte Cyberangriffe in Frage. Zu einer strukturierten Vorgehensweise können z.B. gehören: (1) Ein Eskalationsverfahren mit definierten Kommunikationswegen, z.B. zum ISB und Administrierenden, welche über Rufbereitschaftspläne und automatisierte Alarmierungssysteme erreichbar sind und Zugriffsrechte auf isolierte Notfall-Deployment-Umgebungen, vorkonfigurierte Rollback-Mechanismen sowie dedizierte Notfall-Builds mit minimalen Abhängigkeiten besitzen. (2) Minimale Prüfschritte können z.B. eine beschleunigte Sicherheitsvalidierung kritischer Codeänderungen, automatisierte Sicherheits-scans zur Identifikation offensichtlicher Schwachstellen, die Verifizierung der Code-Integrität durch mindestens zwei autorisierte Personen nach dem Vier-Augen-Prinzip sowie ein dokumentierter Genehmigungsprozess mit expliziter Abzeichnung durch den CISO oder einen designierten Stellvertreter sein. (3) Eine Nachbereitung mit Post-Incident-Analyse zur Dokumentation der getroffenen Maßnahmen, identifizierten Verbesserungspotenzialen und notwendigen Nacharbeiten.

Links

related: NOT.1.1 Verfahren und Regelungen

Control: TEST.5.1 - Information betroffener Kreise

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.5 Bereitstellung
UUID: 1532f91b-d1a5-405f-ada6-11e4b53ae436
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE von der Änderung betroffene Kreise informieren.

Guidance

Betroffene Kreise können je nach Vorhaben z.B. interne oder externe Nutzende, IT-Betrieb, das Monitoring-Team, die Öffentlichkeitsarbeit oder ISB sein. Erforderliche Informationen können z.B. zu erwartende Ausfallzeiten oder Beginn und Ende des Wartungsfensters, die Vorgehensweise zum Bezug von Sicherheitsupdates oder anzupassende Sicherheitseinstellungen sein, die Nutzende selbst vornehmen können.

Links

related: ASST.5.5 Wartungsfenster

Control: TEST.5.2 - Verschlüsselte Bereitstellung

Tag: "Cryptography"

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.5 Bereitstellung
UUID: 1a332c02-bbc6-49f5-a123-ad41532409ac
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE die Bereitstellung verschlüsseln.

Guidance

Das Konzept der Bereitstellung (engl. Deployment oder Provisioning) bezieht sich hier auf den Vorgang des Übertragens, Installierens oder Aktivierens von Software-Artefakten, Konfigurationen, Skripten oder anderen digitalen Gütern von einer gesicherten Umgebung (z.B. Test- oder Staging-Umgebung) in die Ziel- oder Produktionsumgebung. Die Verschlüsselung dieser Bereitstellung meint dabei die kryptografische Sicherung des Datenstroms oder der übertragenen Daten während des Transports, sodass diese für unbefugte Dritte unlesbar sind. Diese Vorschrift dient primär dem Schutz vor der Offenlegung sensibler Daten oder der Manipulation der ausgelieferten Artefakte: Ein Angreifer, der den Übertragungsweg abhört, könnte ohne Verschlüsselung leicht auf vertrauliche Informationen zugreifen, etwa proprietären Quellcode oder sensible Konfigurationsparameter (wie Passwörter oder API-Schlüssel), was zur Geheimhaltung (Confidentiality) in der Institution im Widerspruch stünde. Außerdem könnte ein Man-in-the-Middle-Angriff die übertragenen Daten manipulieren und so bösartigen Code in die Produktionsumgebung einschleusen, bevor die Integrity-Checks greifen, was die Integrität der bereitgestellten Lösungen gefährden könnte. Technisch kann die Institution dies gewährleisten, indem alle Deployment-Pipelines ausschließlich gesicherte Kommunikationsprotokolle nutzen. Zusätzlich ist es sinnvoll die Bereitstellungs-Artefakte digital zu signieren und diese Signatur erst nach erfolgreicher End-zu-End-Integritätsprüfung (z.B. durch Prüfsummen wie SHA-256) auf dem Zielsystem zur Installation freigeben, was einen Manipulationsversuch im Transit erschwert.

Control: TEST.5.3 - Schrittweiser Rollout

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.5 Bereitstellung
UUID: e692fd9c-02b4-48f9-8645-11ea5662b695
Aufwand: 5
Sicherheitsstufe: erhöht

Statement

Änderungen und Tests KANN die Inbetriebnahme stufenweise ausführen.

Guidance

Inbetriebnahme (engl. deployment oder rollout) meint hier die technische und organisatorische Überführung einer Änderung oder Neuerung – etwa an IT-Systemen, Anwendungen oder Konfigurationen – vom Test- in den Produktivbetrieb. Eine stufenweise Inbetriebnahme (auch phased deployment, gradual rollout oder staged release) meint dabei das gezielte Ausrollen von Änderungen in mehreren kontrollierten Schritten, etwa nach Rollen, geografischen Standorten oder Systemkomponenten gruppiert, anstatt in einem einzigen vollständigen Übergang. Diese Methode kann gezielt dazu genutzt werden, Probleme frühzeitig zu erkennen und zu verhindern, dass diese sich flächendeckend auf die gesamte Infrastruktur auswirken. Ziel ist insbesondere, mögliche Risiken aus unzureichend getesteten Änderungen zu reduzieren – etwa wenn fehlerhafte Updates zu Systemausfällen, Datenverlusten oder Funktionseinschränkungen führen könnten. Auch unbeabsichtigte Interaktionen mit bestehenden Komponenten, die im Testsystem nicht abgebildet waren, könnten auftreten. Ein simples Rolling-Release-Modell, bei dem kleinschrittige Änderungen allen betroffenen Geräte gleichzeitig bereitgestellt werden, genügt NICHT um die Anforderung zu erfüllen. Ein schrittweiser Rollout ist in verschiedenen Varianten möglich: (1) der Einsatz von sogenannten Canary Releases, bei denen Änderungen zuerst auf ein kleines, repräsentatives Nutzersegment ausgerollt werden, (2) der automatisierte Rollout nach dem One-Some-All-Prinzip, (3) das gezielte Aktivieren neuer Funktionen über Feature Toggles, die zentrale Steuerung ermöglichen, oder (4) das parallele Führen alter und neuer Systemversionen in einer Blue-Green Deployment-Struktur.

Control: TEST.5.4 - Persistenz

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.5 Bereitstellung
UUID: 09606d16-376b-44be-b12e-35829f10d4e4
Aufwand: 3
Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE die Persistenz nach wesentlichen Änderungen testen.

Guidance

Persistenz bedeutet hier, dass eine wesentliche Änderung nach ihrer Einführung dauerhaft wirksam bleibt, also auch nach einem Neustart, einem System-Update oder einem Rückspielen von Konfigurations-Backups nicht unbeabsichtigt verloren geht. Dies könnte beispielsweise dazu führen, dass eine sicherheitsrelevante Konfiguration nach einem Reboot verschwindet oder eine Migration zu einem neuen Anbieter scheitert, weil Daten oder Regeln nicht portabel waren. Eine Institution kann die Anforderung praktisch umsetzen, indem Änderungen nach Abschluss nicht nur funktional, sondern auch über System- und Lebenszyklusereignisse hinweg überprüft werden. Dazu kann es hilfreich sein, Änderungen gezielt mit simulierten Neustarts, Failover-Tests oder dem erneuten Einspielen von Standard-Backups zu validieren. Um den laufenden Betrieb hierdurch nicht zu beeinträchtigen können Systeme oder Anwendungsinstanzen nacheinander oder zu unkritischen Zeiten neu gestartet werden.

Control: TEST.5.5 - Rückblick

Info

Control der Klasse "BSI-Stand-der-Technik-Kernel"
Gruppe: TEST.5 Bereitstellung
UUID: 3e647e0e-ec8e-4ca5-8474-c511b25e53af
Aufwand: 4
Sicherheitsstufe: normal-SdT

Statement

Änderungen und Tests SOLLTE die Erreichung der Bereitstellungsziele {{ insert: param, test.5.5-prm1 }} überprüfen.

Guidance

Ein effektiver Änderungsmanagementprozess profitiert von systematischen Überprüfungen nach der Implementierung. Dabei wird bewertet, ob die definierten Bereitstellungsziele tatsächlich erreicht wurden und ob Änderungen unbeabsichtigte Auswirkungen auf Sicherheit, Stabilität oder Verfügbarkeit hatten. Die gewonnenen Erkenntnisse können genutzt werden, um zukünftige Änderungen gezielter zu planen und Risiken zu reduzieren.

Links

related: REA.3.1 Verbesserung durch Erkenntnisse